

Cyber Security and Forensic Analysis

Complete Research Reference Book

Comprehensive Table of Contents
(Advanced Ph.D. & Research Level)



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Written by

Dr. Shiv Kumar

PhD Computer Science

Cyber Security and Forensic Analysis

Complete Research Reference Book

Comprehensive Table of Contents

PART-I

Foundations of Cyber Security

Chapter 1

Introduction to Cyber Security

- Evolution of Information Security
 - History of Cyber Warfare
 - Digital Transformation
 - Security Concepts
 - CIA Triad
 - Parkerian Hexad
 - Security Models
 - Data Classification
 - Risk Terminologies
 - Threat Landscape
- 
-

Chapter 2

Fundamental Concepts

- Authentication
 - Authorization
 - Accountability
 - Availability
 - Confidentiality
 - Integrity
 - Non-repudiation
 - Privacy
 - Trust
 - Security Governance
-

Chapter 3

Cyber Security Domains

- Network Security
 - Information Security
 - Cloud Security
 - Endpoint Security
 - Mobile Security
 - Application Security
 - Database Security
 - Wireless Security
 - IoT Security
 - OT Security
 - ICS Security
 - Critical Infrastructure Security
-

PART-II

Operating Systems Security

Windows Security

- Windows Architecture
 - Registry Analysis
 - Active Directory
 - NTFS Permissions
 - Group Policy
 - Windows Defender
 - BitLocker
 - Windows Event Logs
 - Sysinternals
 - Credential Guard
 - LSASS Protection
 - Windows Internals
-

Linux Security

- Linux Architecture
- Kernel Security
- SELinux
- AppArmor

- iptables
- nftables
- SSH Security
- PAM
- Log Analysis
- Linux Forensics

macOS Security

- macOS Architecture
- Gatekeeper
- SIP
- XProtect
- FileVault
- TCC
- Apple Silicon Security

PART-III

Networking Security

- OSI Model Security
- TCP/IP Deep Analysis
- Routing Security
- Switching Security
- VLAN
- VPN
- MPLS
- DNS Security
- DHCP Security
- ARP Security
- IPv6 Security
- BGP Security
- Network Hardening

PART-IV

Cryptography

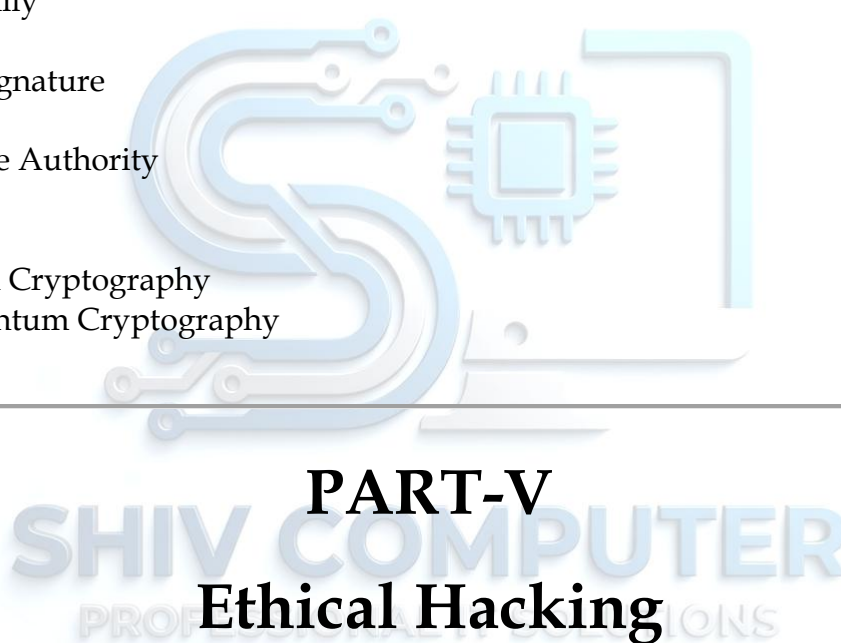
Classical Cryptography

- Caesar Cipher

- Vigenère Cipher
- Hill Cipher
- Playfair Cipher

Modern Cryptography

- DES
- Triple DES
- AES
- Blowfish
- Twofish
- IDEA
- RC4
- RSA
- ECC
- Diffie-Hellman
- ElGamal
- SHA Family
- HMAC
- Digital Signature
- PKI
- Certificate Authority
- SSL
- TLS
- Quantum Cryptography
- Post Quantum Cryptography



PART-V

Ethical Hacking

- Foot printing
- Reconnaissance
- Google Dorking
- OSINT
- Enumeration
- Vulnerability Assessment
- Exploitation
- Privilege Escalation
- Maintaining Access
- Covering Tracks
- Reporting

PART-VI

Malware Analysis

- Virus
- Worm
- Trojan
- Rootkit
- Bootkit
- Spyware
- Adware
- Ransomware
- Cryptojacking
- Malware Reverse Engineering
- Dynamic Analysis
- Static Analysis
- Memory Injection
- Packers
- Obfuscation

PART-VII

Digital Forensics

- Introduction
- Evidence
- Chain of Custody
- Evidence Handling
- Forensic Readiness
- Forensic Standards
- ISO 27037
- ISO 27041
- ISO 27042
- ISO 27043

PART-VIII

Computer Forensics

- Disk Acquisition
- Bit by Bit Imaging
- Live Acquisition

- Dead Acquisition
- File Systems
- FAT
- NTFS
- exFAT
- APFS
- EXT4
- Deleted File Recovery
- Timeline Analysis

PART-IX

Memory Forensics

- RAM Acquisition
- Volatility
- Rekall
- Memory Artifacts
- Malware Detection
- Process Analysis
- DLL Injection
- Rootkits

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

PART-X

Mobile Forensics

- Android Architecture
- iOS Architecture
- SIM Analysis
- Call Logs
- WhatsApp Analysis
- Telegram
- Signal
- Facebook
- Instagram
- Cloud Backup
- Cellebrite

- Magnet AXIOM
-

PART-XI

Network Forensics

- Packet Capture
 - Wireshark
 - TCPDump
 - Zeek
 - NetworkMiner
 - IDS Analysis
 - Firewall Logs
 - NetFlow
 - DNS Investigation
-

PART-XII

Cloud Forensics

- AWS
 - Azure
 - Google Cloud
 - SaaS
 - PaaS
 - IaaS
 - Container Forensics
 - Kubernetes
 - Docker
 - Cloud Evidence
-

PART-XIII

IoT Forensics

- Smart Devices
- Smart Home
- Wearables
- Automotive Systems
- Drone Forensics

PART-XIV

AI and Cyber Security

- Machine Learning
 - Deep Learning
 - AI Threat Detection
 - AI Malware
 - AI SOC
 - LLM Security
 - Prompt Injection
 - AI Forensics
 - Explainable AI
-

PART-XV

Cyber Threat Intelligence

- IOC
 - IOA
 - MITRE ATT&CK
 - Diamond Model
 - Kill Chain
 - Threat Hunting
 - Malware Campaign Analysis
-

PART-XVI

Incident Response

- NIST Framework
- Preparation
- Detection
- Containment
- Eradication
- Recovery

PART-XVII

Penetration Testing

- PTES
 - OWASP
 - Internal Testing
 - External Testing
 - Wireless Testing
 - Web Testing
 - API Testing
 - Reporting
-

PART-XVIII

Web Application Security

- HTTP
 - HTTPS
 - OWASP Top 10
 - SQL Injection
 - XSS
 - CSRF
 - SSRF
 - XXE
 - RCE
 - File Upload
 - Session Hijacking
-

PART-XIX

Secure Software Development

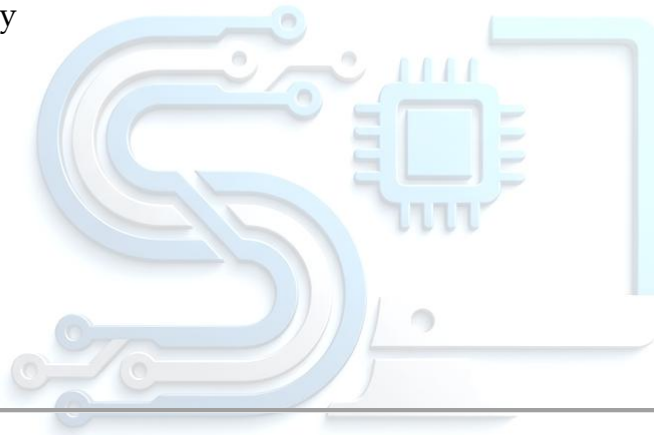
- SDLC
- DevSecOps

- Threat Modeling
 - Code Review
 - Static Analysis
 - Dynamic Analysis
 - Secure Coding Standards
-

PART-XX

Cloud Native Security

- Docker
- Kubernetes
- Service Mesh
- Container Escape
- Runtime Security



PART-XXI

Blockchain Security

- Blockchain Architecture
 - Smart Contracts
 - Ethereum Security
 - Bitcoin Security
 - NFT Security
 - DeFi Risks
-

PART-XXII

SCADA & ICS Security

- PLC
- RTU

- DCS
 - Industrial Protocols
 - Stuxnet Analysis
-

PART-XXIII

Cyber Laws

- Indian IT Act
 - Digital Evidence Act
 - GDPR
 - HIPAA
 - PCI-DSS
 - ISO 27001
 - NIST CSF
 - CERT-In Guidelines
-

PART-XXIV

Cyber Crime Investigation

- Crime Scene Investigation
 - Evidence Collection
 - Seizure Procedure
 - Court Presentation
 - Expert Witness
-

PART-XXV

Artificial Intelligence Forensics

- Deepfake Detection
 - AI Generated Evidence
 - Synthetic Media Analysis
 - Model Investigation
-

PART-XXVI

Quantum Computing and Security

- Quantum Algorithms
 - Shor Algorithm
 - Grover Algorithm
 - PQC Migration
-

PART-XXVII

Cyber Warfare

- Nation State Attacks
 - Cyber Espionage
 - Information Warfare
 - Hybrid Warfare
-

PART-XXVIII

Digital Evidence Management

- Evidence Preservation
 - Chain of Custody
 - Court Admissibility
 - Hash Validation
-

PART-XXIX

Security Operations Center (SOC)

- SIEM
 - SOAR
 - SOC Architecture
 - SOC Automation
 - Detection Engineering
-

PART-XXX

Research Methodology

- Research Design
- Literature Review
- Gap Analysis
- Hypothesis Development
- Data Collection
- Statistical Analysis
- SPSS
- R Programming
- Python Research
- Research Ethics

PARTS XXXI-L (Advanced Specialized Topics)

इन 20 अतिरिक्त भागों में निम्न विषयों का विस्तृत समावेश

- Reverse Engineering
- Firmware Analysis
- BIOS & UEFI Forensics
- GPU Forensics
- Memory Dump Analysis
- Email Forensics
- Browser Forensics
- Cryptocurrency Forensics
- Dark Web Investigation
- OSINT Intelligence
- Digital Profiling
- Satellite & Drone Cyber Security
- Vehicle Hacking
- Smart City Security
- Healthcare Cyber Security
- Banking Security
- FinTech Security
- Cyber Insurance
- Supply Chain Security
- Zero Trust Architecture
- SASE & SSE
- XDR, MDR, EDR
- Purple Team Operations
- Red Team Exercises
- Blue Team Operations

- Purple Team Simulation
- Adversary Emulation
- Cyber Range Design
- National Cyber Defence
- Critical Infrastructure Protection
- Space Cyber Security
- Cyber Psychology
- Human Factors in Security
- Insider Threat Management
- Digital Ethics
- Privacy Engineering
- Quantum Internet Security
- Future of Cyber Defence
- Emerging Technologies
- Open Research Problems
- Future Research Directions

अंतिम परिशिष्ट (Appendices)

- Appendix A – Cyber Security Terminology (5000+ Terms)
- Appendix B – RFC Reference Guide
- Appendix C – MITRE ATT&CK Matrix
- Appendix D – OWASP Cheat Sheets
- Appendix E – NIST Publications Index
- Appendix F – ISO/IEC Standards
- Appendix G – CERT-In Advisories
- Appendix H – Digital Forensics Checklists
- Appendix I – Cyber Investigation Forms
- Appendix J – Evidence Templates
- Appendix K – Cyber Security Audit Checklists
- Appendix L – Risk Assessment Templates
- Appendix M – Incident Response Playbooks
- Appendix N – Forensic Report Formats
- Appendix O – International Case Studies
- Appendix P – Indian Cyber Crime Case Studies
- Appendix Q – Cyber Security Tools Encyclopedia (1000+ Tools)
- Appendix R – Research Papers Bibliography (1000+ References)
- Appendix S – Glossary
- Appendix T – Comprehensive Index

अध्याय 1

Introduction to Cyber Security

(साइबर सुरक्षा का परिचय)

1.1 प्रस्तावना (Introduction)

आज का युग डिजिटल युग (Digital Era) है। वर्तमान समय में लगभग प्रत्येक व्यक्ति, संस्था, उद्योग, बैंक, अस्पताल, विद्यालय, विश्वविद्यालय तथा सरकार अपने महत्वपूर्ण कार्यों के लिए कंप्यूटर, इंटरनेट एवं डिजिटल तकनीकों का उपयोग करती हैं। इन प्रणालियों में अत्यंत संवेदनशील जानकारी (Sensitive Information) जैसे बैंकिंग डेटा, आधार संख्या, चिकित्सा रिकॉर्ड, अनुसंधान डेटा, रक्षा संबंधी सूचनाएँ, व्यापारिक रहस्य तथा व्यक्तिगत जानकारी संग्रहीत रहती हैं।

जैसे-जैसे डिजिटल तकनीक का विस्तार हुआ है, वैसे-वैसे साइबर अपराध (Cyber Crime) भी अत्यधिक बढ़े हैं। हैकर (Hackers), साइबर अपराधी (Cyber Criminals), आतंकी संगठन तथा राष्ट्र-प्रायोजित (Nation-State) हमलावर इन प्रणालियों पर आक्रमण करके डेटा चोरी, आर्थिक नुकसान, जासूसी, ब्लैकमेल, सेवा बाधित (Service Disruption) तथा राष्ट्रीय सुरक्षा को प्रभावित करने का प्रयास करते हैं।

इन्हीं खतरों से कंप्यूटर, नेटवर्क, डेटा और डिजिटल सेवाओं की सुरक्षा करने की विज्ञान एवं तकनीक को Cyber Security (साइबर सुरक्षा) कहा जाता है।

1.2 Cyber Security की परिभाषा (Definition)

Cyber Security वह प्रक्रिया, तकनीक, नीति (Policy), मानक (Standards), उपकरण (Tools) और नियंत्रण (Controls) का समुच्चय है जिसके माध्यम से कंप्यूटर सिस्टम, नेटवर्क, सर्वर, मोबाइल उपकरण, क्लाउड सेवाओं और डिजिटल डेटा को अनधिकृत पहुँच (Unauthorized Access), साइबर हमलों (Cyber Attacks), डेटा चोरी, वायरस, रैनसमवेयर तथा अन्य डिजिटल खतरों से सुरक्षित रखा जाता है।

सरल शब्दों में: - "डिजिटल दुनिया में उपलब्ध सभी संसाधनों की सुरक्षा सुनिश्चित करने की प्रक्रिया को साइबर सुरक्षा कहते हैं।"

1.3 Cyber Security की आवश्यकता

यदि साइबर सुरक्षा न हो तो—

- बैंक खातों से धन चोरी हो सकता है।
- अस्पतालों के मरीजों का डेटा लीक हो सकता है।
- सरकारी वेबसाइट हैक हो सकती हैं।
- सेना की गोपनीय जानकारी चोरी हो सकती है।
- विश्वविद्यालयों के परीक्षा परिणाम बदले जा सकते हैं।
- किसी व्यक्ति की पहचान (Identity) चोरी की जा सकती है।
- उद्योगों के व्यापारिक रहस्य (Trade Secrets) चोरी हो सकते हैं।

उदाहरण 1 : बैंक

मान लीजिए किसी बैंक में 50 लाख ग्राहकों का डेटा रखा हुआ है। यदि कोई हैकर उस बैंक के सर्वर में घुस जाए और—

- ग्राहकों के खाते बदल दे।
- पैसा दूसरे खाते में भेज दे।
- ATM PIN चुरा ले।
- नेट बैंकिंग पासवर्ड चुरा ले।

तो करोड़ों रुपये का नुकसान हो सकता है।

इसीलिए बैंक

- Firewall
- IDS
- IPS
- Encryption
- Multi Factor Authentication
- SIEM
- SOC

का उपयोग करते हैं।

उदाहरण 2 : विद्यालय

एक विद्यालय में विद्यार्थियों का

- नाम
- आधार
- अंकपत्र
- फीस
- फोटो
- अभिभावकों का मोबाइल नंबर

सर्वर पर संग्रहीत है।

यदि कोई छात्र या बाहरी व्यक्ति

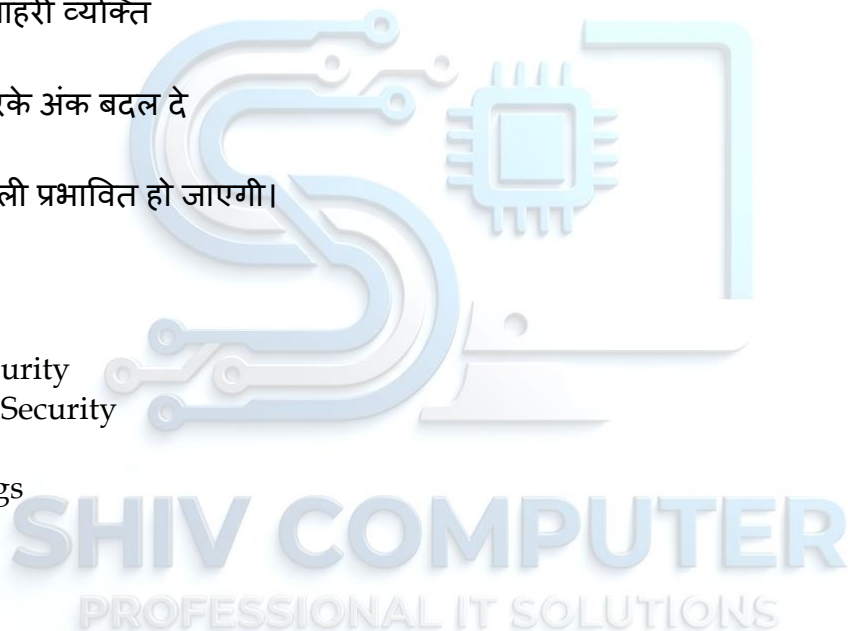
डेटाबेस में प्रवेश करके अंक बदल दे

तो पूरी परीक्षा प्रणाली प्रभावित हो जाएगी।

इसलिए

- Login Security
- Database Security
- Backup
- Audit Logs

आवश्यक हैं।



उदाहरण 3 : अस्पताल

यदि अस्पताल का सर्वर Ransomware से संक्रमित हो जाए

तो

- मरीजों का रिकॉर्ड लॉक हो जाएगा।
- ऑपरेशन रुक सकते हैं।
- डॉक्टर रिपोर्ट नहीं देख पाएंगे।
- ICU प्रभावित हो सकता है।

ऐसी घटनाएँ विश्वभर में कई बार हो चुकी हैं।

उदाहरण 4 : मोबाइल फोन

यदि आपने किसी फर्जी App को Camera Microphone Location SMS Contacts की Permission दे दी, तो वह App आपकी

- फोटो
- वीडियो
- OTP
- बैंक संदेश
- पासवर्ड

चुरा सकती है।

उदाहरण 5 : सोशल मीडिया

यदि किसी व्यक्ति ने, Facebook, Instagram, WhatsApp, का Password किसी को बता दिया, तो

- उसका Account Hack हो सकता है।
- Fake पोस्ट डाली जा सकती हैं।
- लोगों से पैसे मांगे जा सकते हैं।

1.4 Cyber Space क्या है?

Cyber Space एक आभासी (Virtual) डिजिटल वातावरण है जहाँ

- Internet
- Computer
- Mobile
- Cloud
- IoT
- Server
- Satellite
- Digital Communication

Cyber Space का उदाहरण

जब आप

- UPI से भुगतान करते हैं
- Gmail खोलते हैं
- WhatsApp चलाते हैं
- YouTube देखते हैं
- ऑनलाइन खरीदारी करते हैं

तो आप Cyber Space का उपयोग कर रहे होते हैं।

1.5 Cyber Threat क्या है?

कोई भी ऐसी घटना जो

- Data
- Computer
- Network
- Information

को नुकसान पहुँचा सकती है उसे Cyber Threat कहते हैं।

उदाहरण

- Virus
- Malware
- Trojan
- Worm
- Spyware
- Ransomware
- Phishing
- Social Engineering

- Data Theft
- Insider Attack
- DDoS Attack

1.6 Cyber Attack क्या है?

जब कोई व्यक्ति जानबूझकर किसी Computer System पर हमला करता है तो उसे Cyber Attack कहते हैं।

उदाहरण

एक Hacker किसी कंपनी की Website पर एक साथ 10 लाख Request भेज देता है। Website बंद हो जाती है। इसे DDoS Attack कहते हैं।

1.7 Cyber Crime क्या है?

जब कंप्यूटर अथवा इंटरनेट का उपयोग करके कोई अवैध कार्य किया जाता है तो उसे Cyber Crime कहते हैं।

उदाहरण

- Online Fraud
 - ATM Fraud
 - UPI Fraud
 - Identity Theft
 - Fake Website
 - Online Blackmail
 - Cyber Terrorism
 - Child Exploitation
 - Data Theft
 - Digital Forgery
-

1.8 Cyber Security के मुख्य उद्देश्य

(1) Confidentiality (गोपनीयता)

जानकारी केवल अधिकृत व्यक्ति ही देख सके।

उदाहरण

विद्यालय के परीक्षा परिणाम केवल परीक्षा नियंत्रक ही देख सके।

(2) Integrity (अखंडता)

डेटा बिना अनुमति बदला न जा सके।

उदाहरण

किसी छात्र के 80 अंक को कोई 95 न कर सके।

(3) Availability (उपलब्धता)

सिस्टम आवश्यकता पड़ने पर उपलब्ध रहे।

उदाहरण

बैंक का सर्वर 24x7 चलता रहे।

(4) Authentication (प्रमाणीकरण)

यह सुनिश्चित करना कि उपयोगकर्ता वास्तव में वही है जो वह होने का दावा कर रहा है।

उदाहरण

पासवर्ड + OTP + फिंगरप्रिंट से लॉगिन।

(5) Authorization (अधिकार निर्धारण)

प्रत्येक उपयोगकर्ता को केवल उतनी ही अनुमति मिले जितनी उसके कार्य के लिए आवश्यक है।

उदाहरण

विद्यालय में:

- शिक्षक अंक दर्ज कर सकता है।
- छात्र केवल अपने अंक देख सकता है।
- प्रधानाचार्य सभी रिकॉर्ड देख सकते हैं।

(6) Accountability (उत्तरदायित्व)

किस उपयोगकर्ता ने कब और क्या कार्य किया, इसका रिकॉर्ड रखा जाए।

उदाहरण

यदि किसी कर्मचारी ने डेटा हटाया, तो लॉग से पता चल सके कि यह किसने और कब किया।

1.9 वास्तविक जीवन का केस स्टडी

केस: एक विद्यालय का ERP सिस्टम

मान लीजिए एक विद्यालय का ERP सिस्टम है, जिसमें:

- 2,000 छात्रों का डेटा
- फीस रिकॉर्ड
- परीक्षा परिणाम
- शिक्षकों का विवरण
- अभिभावकों की जानकारी

संग्रहीत है।

यदि:

- एडमिन पासवर्ड बहुत कमजोर है (admin123)

- बैकअप नहीं लिया जाता
- डेटाबेस एन्क्रिप्टेड नहीं है
- सभी कर्मचारियों को पूर्ण अधिकार दिए गए हैं

तो कोई हमलावर:

- परिणाम बदल सकता है।
- फीस रिकॉर्ड मिटा सकता है।
- डेटा चोरी कर सकता है।
- वेबसाइट बंद कर सकता है।

यदि वही विद्यालय निम्न सुरक्षा उपाय अपनाता है:

- Multi-Factor Authentication (MFA)
- Role-Based Access Control (RBAC)
- नियमित बैकअप
- डेटा एन्क्रिप्शन
- फ़ायरवॉल और IDS/IPS
- सुरक्षा ऑडिट
- लॉग मॉनिटरिंग

तो हमले की संभावना और प्रभाव दोनों काफी कम हो जाते हैं।

अध्याय का सार (Summary)

Cyber Security केवल एंटीवायरस इंस्टॉल करने का नाम नहीं है, बल्कि यह **लोगों (People)**, **प्रक्रियाओं (Processes)**, **तकनीकों (Technology)**, **नीतियों (Policies)** और **कानूनी ढाँचों (Legal Frameworks)** का समन्वित क्षेत्र है। इसका उद्देश्य डिजिटल परिसंपत्तियों (Digital Assets) की **गोपनीयता (Confidentiality)**, **अखंडता (Integrity)** और **उपलब्धता (Availability)** को बनाए रखना है। आज के समय में बैंकिंग, शिक्षा, स्वास्थ्य, उद्योग, रक्षा, ई-गवर्नेंस और व्यक्तिगत जीवन—सभी क्षेत्रों में साइबर सुरक्षा एक अनिवार्य आवश्यकता बन चुकी है।

1.2 Evolution of Information Security

(सूचना सुरक्षा का विकास)

1. परिचय (Introduction)

सूचना सुरक्षा (Information Security) का अर्थ केवल कंप्यूटर या इंटरनेट की सुरक्षा नहीं है, बल्कि किसी भी प्रकार की सूचना (Information) – चाहे वह कागज़ पर लिखी हो, डिजिटल रूप में संग्रहीत हो, या मौखिक रूप से साझा की जा रही हो—उसे अनधिकृत पहुँच (Unauthorized Access), परिवर्तन (Modification), प्रकटीकरण (Disclosure), नष्ट होने (Destruction) अथवा चोरी (Theft) से सुरक्षित रखना है।

आज Information Security एक बहुविषयक (Multidisciplinary) क्षेत्र बन चुका है, जिसमें कंप्यूटर विज्ञान, नेटवर्किंग, क्रिप्टोग्राफी, कानून, प्रबंधन, मनोविज्ञान और कृत्रिम बुद्धिमत्ता (AI) जैसी अनेक शाखाओं का समावेश है। इसका विकास हजारों वर्षों में हुआ है।

2. Information Security का ऐतिहासिक विकास

चरण 1: प्राचीन काल (Ancient Era)

सूचना सुरक्षा की शुरुआत कंप्यूटर से नहीं हुई, बल्कि तब हुई जब मनुष्य ने महत्वपूर्ण संदेशों को दूसरों से छिपाना शुरू किया।

प्रमुख विशेषताएँ

- गुप्त संदेश (Secret Messages)
- संकेत भाषा (Codes)
- प्रतीकों का उपयोग
- दूत (Messenger) द्वारा संदेश प्रेषण

उदाहरण

राजा अपने सेनापति को युद्ध योजना भेजते थे। यदि संदेश शत्रु के हाथ लग जाता, तो पूरा युद्ध प्रभावित हो सकता था। इसलिए संदेशों को विशेष संकेतों या गुप्त लिपि में लिखा जाता था।

सुरक्षा उद्देश्य: केवल अधिकृत व्यक्ति ही संदेश पढ़ सके।

चरण 2: प्राचीन क्रिप्टोग्राफी (Classical Cryptography)

सूचना की गोपनीयता बनाए रखने के लिए संदेशों को सांकेतिक भाषा में बदलने की तकनीक विकसित हुई।

प्रमुख विधियाँ

- Caesar Cipher
- Spartan Scytale
- Atbash Cipher
- Vigenère Cipher

उदाहरण

मूल संदेश:

ATTACK AT DAWN

यदि Caesar Cipher में प्रत्येक अक्षर को 3 स्थान आगे बढ़ाया जाए, तो:

DWWDFN DW GDZQ

अब यह संदेश केवल वही व्यक्ति पढ़ सकता है जिसे इस नियम की जानकारी हो।

3. औद्योगिक क्रांति (Industrial Revolution)

18वीं और 19वीं शताब्दी में टेलीग्राफ और टेलीफोन के आगमन से संचार तेज हुआ, लेकिन संदेशों को बीच में सुनने (Interception) का खतरा भी बढ़ गया।

सुरक्षा उपाय

- Morse Code
- Telegraph Encryption
- सुरक्षित संचार चैनल

उदाहरण

दो देशों के बीच सैन्य आदेश टेलीग्राफ से भेजे जाते थे। यदि कोई तीसरा पक्ष संदेश पढ़ लेता, तो राष्ट्रीय सुरक्षा खतरे में पड़ सकती थी।

4. विश्व युद्धों का काल (World War Era)

प्रथम और द्वितीय विश्व युद्ध के दौरान सूचना सुरक्षा का महत्व अत्यधिक बढ़ गया।

प्रमुख विकास

- Enigma Machine
- Cipher Machines
- Code Breaking
- Signals Intelligence (SIGINT)

उदाहरण

द्वितीय विश्व युद्ध में जर्मनी ने **Enigma Machine** का उपयोग करके अपने सैन्य संदेश एन्क्रिप्ट किए। बाद में मित्र राष्ट्रों के क्रिप्टोविश्लेषकों ने इन्हें डिक्रिप्ट कर युद्ध की दिशा बदलने में महत्वपूर्ण भूमिका निभाई।

महत्व: इस काल ने आधुनिक क्रिप्टोग्राफी और सूचना सुरक्षा की नींव रखी।

5. मेनफ्रेम कंप्यूटर युग (1950-1970)

कंप्यूटरों के आगमन के साथ सूचना सुरक्षा ने नया स्वरूप लिया।

मुख्य विशेषताएँ

- बड़े Mainframe Computer
- सीमित उपयोगकर्ता
- भौतिक सुरक्षा (Physical Security)
- पासवर्ड आधारित लॉगिन

उदाहरण

एक विश्वविद्यालय में केवल अधिकृत शोधकर्ता ही Mainframe पर लॉगिन कर सकते थे। गलत व्यक्ति को प्रवेश न मिले, इसलिए उपयोगकर्ता नाम और पासवर्ड की व्यवस्था की गई।

6. नेटवर्किंग युग (1970-1990)

जब कंप्यूटर नेटवर्क बनने लगे, तो नए प्रकार के खतरे सामने आए।

नई चुनौतियाँ

- Unauthorized Access
- Network Hacking
- Virus
- Worm
- Password Cracking

प्रमुख विकास

- TCP/IP
- Firewall
- Access Control
- Antivirus

उदाहरण

यदि कोई कर्मचारी कंपनी के नेटवर्क से गोपनीय फाइलें कॉपी कर ले, तो केवल कंप्यूटर की सुरक्षा पर्याप्त नहीं होगी; नेटवर्क सुरक्षा भी आवश्यक होगी।

7. इंटरनेट क्रांति (1990-2010)

इंटरनेट के व्यापक प्रसार ने सूचना सुरक्षा को वैश्विक विषय बना दिया।

नई समस्याएँ

- Phishing
- Website Hacking
- Email Fraud
- Identity Theft
- Online Banking Fraud
- Malware
- Spyware

प्रमुख तकनीकें

- SSL/TLS
- VPN
- IDS
- IPS
- PKI
- Digital Certificates

एक व्यक्ति को बैंक के नाम से नकली ईमेल प्राप्त हुआ। उसने अपना पासवर्ड दर्ज कर दिया और उसका बैंक खाता खाली हो गया। यह **Phishing Attack** का उदाहरण है।

8. क्लाउड एवं मोबाइल युग (2010-2020)

डेटा स्थानीय कंप्यूटरों से हटकर क्लाउड सर्वरों पर संग्रहीत होने लगा।

नई चुनौतियाँ

- Cloud Data Breach
- Mobile Malware
- BYOD (Bring Your Own Device)
- API Security
- Data Privacy

सुरक्षा समाधान

- Multi-Factor Authentication (MFA)
- Mobile Device Management (MDM)
- Cloud Security
- Endpoint Detection & Response (EDR)

उदाहरण

एक कर्मचारी अपने मोबाइल से कार्यालय की ईमेल एक्सेस करता है। यदि मोबाइल चोरी हो जाए और उसमें स्क्रीन लॉक न हो, तो संवेदनशील जानकारी लीक हो सकती है।

9. कृत्रिम बुद्धिमत्ता (AI) एवं आधुनिक युग (2020-वर्तमान)

आज Information Security केवल पारंपरिक सुरक्षा तक सीमित नहीं है। AI, Machine Learning और Automation ने सुरक्षा और हमलों दोनों को अधिक उन्नत बना दिया है।

आधुनिक खतरे

- AI आधारित Malware
- Deepfake
- Ransomware-as-a-Service (RaaS)
- Supply Chain Attack
- Zero-Day Exploit
- Cloud Misconfiguration
- IoT Attacks

आधुनिक समाधान

- AI आधारित Threat Detection
- Behavioral Analytics
- Zero Trust Architecture
- XDR (Extended Detection and Response)
- SOAR (Security Orchestration, Automation and Response)

उदाहरण

एक बैंक का सुरक्षा तंत्र AI की सहायता से यह पहचान लेता है कि किसी उपयोगकर्ता के खाते से असामान्य स्थान और समय पर लॉगिन हो रहा है। सिस्टम स्वतः उस लॉगिन को रोक देता है और उपयोगकर्ता से अतिरिक्त सत्यापन माँगता है।

10. Information Security का विकास: समयरेखा

काल	प्रमुख विशेषता	मुख्य सुरक्षा उपाय
प्राचीन काल	गुप्त संदेश	सांकेतिक भाषा
मध्यकाल	कूटलेखन	Cipher तकनीक
औद्योगिक युग	टेलीग्राफ	सुरक्षित संचार
विश्व युद्ध	सैन्य संदेश	Enigma, Cryptography
मेनफ्रेम युग	केंद्रीकृत कंप्यूटर	Password, Physical Security
नेटवर्क युग	LAN/WAN	Firewall, Antivirus
इंटरनेट युग	वेब सेवाएँ	SSL/TLS, IDS/IPS
क्लाउड युग	Cloud Computing	MFA, IAM, Cloud Security
AI युग	बुद्धिमान सुरक्षा	AI, Zero Trust, XDR

11. वास्तविक जीवन के अध्ययन (Case Studies)

केस स्टडी 1: बैंकिंग

एक बैंक प्रतिदिन लाखों ऑनलाइन लेन-देन करता है। यदि डेटा बिना एन्क्रिप्शन के भेजा जाए, तो हमलावर नेटवर्क से उसे पढ़ सकते हैं। इसलिए HTTPS, TLS, डिजिटल प्रमाणपत्र और MFA का उपयोग किया जाता है।

केस स्टडी 2: विश्वविद्यालय

एक विश्वविद्यालय में शोधार्थियों का शोध डेटा, परीक्षा परिणाम और वित्तीय जानकारी संग्रहीत है। यदि उचित Role-Based Access Control (RBAC) न हो, तो कोई कर्मचारी अनधिकृत रूप से डेटा बदल सकता है। इसलिए उपयोगकर्ताओं को उनकी भूमिका के अनुसार सीमित अधिकार दिए जाते हैं।

केस स्टडी 3: अस्पताल

एक अस्पताल में मरीजों की चिकित्सा रिपोर्ट, दवाओं का इतिहास और व्यक्तिगत जानकारी होती है। यदि रैनसमवेयर हमला हो जाए, तो उपचार प्रभावित हो सकता है। इसलिए नियमित बैकअप, नेटवर्क विभाजन (Network Segmentation), एंडपॉइंट सुरक्षा और निरंतर निगरानी आवश्यक है।

12. Information Security के विकास से प्राप्त प्रमुख शिक्षाएँ

1. सूचना सुरक्षा केवल तकनीकी समस्या नहीं, बल्कि प्रबंधन और मानव व्यवहार से भी जुड़ी है।
 2. प्रत्येक नई तकनीक के साथ नए सुरक्षा जोखिम उत्पन्न होते हैं।
 3. केवल फ़ायरवॉल या एंटीवायरस पर्याप्त नहीं; बहु-स्तरीय सुरक्षा (Defense in Depth) आवश्यक है।
 4. उपयोगकर्ता जागरूकता (Security Awareness) सुरक्षा की पहली और सबसे महत्वपूर्ण परत है।
 5. AI, Quantum Computing और Cloud जैसी उभरती तकनीकों के साथ Information Security लगातार विकसित हो रही है।
-

अध्याय का निष्कर्ष (Conclusion)

Information Security का विकास मानव सभ्यता के साथ-साथ निरंतर हुआ है। प्रारंभिक काल में यह गुप्त संदेशों की सुरक्षा तक सीमित था, जबकि आज यह वैश्विक डिजिटल अवसंरचना, क्लाउड, कृत्रिम बुद्धिमत्ता, मोबाइल उपकरण, इंटरनेट ऑफ थिंग्स (IoT) और राष्ट्रीय सुरक्षा तक विस्तृत हो चुका है। आधुनिक सूचना सुरक्षा का उद्देश्य केवल डेटा की रक्षा करना नहीं, बल्कि **गोपनीयता (Confidentiality)**, **अखंडता (Integrity)**, **उपलब्धता (Availability)**, **प्रामाणिकता (Authenticity)** और **उत्तरदायित्व (Accountability)** सुनिश्चित करना है। यही कारण है कि Information Security आज साइबर सुरक्षा, डिजिटल फॉरेंसिक, जोखिम प्रबंधन और राष्ट्रीय साइबर रक्षा की आधारशिला मानी जाती है।



अध्याय 1.3

History of Cyber Warfare

(साइबर युद्ध का इतिहास)

1. प्रस्तावना (Introduction)

मानव सभ्यता के इतिहास में युद्ध (War) सदैव शक्ति, संसाधनों और राजनीतिक प्रभाव स्थापित करने का माध्यम रहे हैं। प्रारंभिक काल में युद्ध तलवार, भाले और धनुष-बाण से लड़े जाते थे। समय के साथ बारूद, तोप, टैंक, युद्धपोत, पनडुब्बियाँ, लड़ाकू विमान और परमाणु हथियार विकसित हुए। 21वीं शताब्दी में युद्ध का एक नया आयाम सामने आया—साइबर युद्ध (Cyber Warfare)।

साइबर युद्ध वह स्थिति है जिसमें कोई राष्ट्र, उसके समर्थन से कार्य करने वाला समूह, या अत्यधिक संगठित साइबर हमलावर किसी अन्य राष्ट्र, सरकार, सेना, बैंक, ऊर्जा संयंत्र, संचार प्रणाली, परिवहन नेटवर्क या महत्वपूर्ण डिजिटल अवसंरचना (Critical Infrastructure) को कंप्यूटर नेटवर्क और इंटरनेट के माध्यम से निशाना बनाते हैं।

आज साइबर युद्ध को भूमि (Land), जल (Sea), वायु (Air) और अंतरिक्ष (Space) के बाद युद्ध का पाँचवाँ आयाम (Fifth Domain of Warfare) माना जाता है।

2. साइबर युद्ध (Cyber Warfare) की परिभाषा

Cyber Warfare वह संगठित और रणनीतिक गतिविधि है जिसमें डिजिटल माध्यमों का उपयोग करके किसी राष्ट्र या संगठन की सूचना प्रणाली, संचार नेटवर्क, आर्थिक संरचना या रक्षा तंत्र को क्षति पहुँचाने, बाधित करने, नियंत्रित करने या जासूसी करने का प्रयास किया जाता है।

सरल शब्दों में:

"जब किसी देश की महत्वपूर्ण डिजिटल प्रणालियों पर राजनीतिक, सैन्य या रणनीतिक उद्देश्य से योजनाबद्ध साइबर हमला किया जाता है, तो उसे साइबर युद्ध कहते हैं।"

3. पारंपरिक युद्ध और साइबर युद्ध में अंतर

आधार	पारंपरिक युद्ध	साइबर युद्ध
माध्यम	सैनिक, हथियार	कंप्यूटर, नेटवर्क, इंटरनेट
लक्ष्य	भौतिक क्षेत्र	डिजिटल अवसंरचना
लागत	अत्यधिक	तुलनात्मक रूप से कम
पहचान	स्पष्ट	अक्सर छिपी हुई
प्रभाव	भवन, सेना, जनहानि डेटा, सेवाएँ, अर्थव्यवस्था, बिजली, संचार	
समय	सीमित	24x7, निरंतर

4. साइबर युद्ध का ऐतिहासिक विकास

चरण 1: शीत युद्ध (Cold War) - 1947 से 1991

कंप्यूटरों के प्रारंभिक उपयोग के साथ अमेरिका और सोवियत संघ ने डिजिटल संचार की सुरक्षा पर ध्यान देना शुरू किया।

मुख्य विशेषताएँ

- सैन्य कंप्यूटरों का उपयोग
- एन्क्रिप्टेड संचार
- उपग्रह संचार
- प्रारंभिक नेटवर्क सुरक्षा

उदाहरण

यदि किसी देश की मिसाइल नियंत्रण प्रणाली से जुड़े संदेश शत्रु द्वारा पढ़ लिए जाएँ, तो राष्ट्रीय सुरक्षा गंभीर संकट में पड़ सकती है। इसलिए उन्नत क्रिप्टोग्राफी विकसित की गई।

चरण 2: इंटरनेट का उदय (1990-2000)

इंटरनेट के प्रसार के साथ सरकारी नेटवर्क और सैन्य प्रणालियाँ वैश्विक नेटवर्क से जुड़ने लगीं।

नई चुनौतियाँ

- वेबसाइट हैकिंग
- ईमेल हमले
- नेटवर्क घुसपैठ
- डेटा चोरी

उदाहरण

यदि रक्षा मंत्रालय की वेबसाइट हैक होकर गलत सूचना प्रदर्शित करने लगे, तो जनता में भ्रम और अविश्वास फैल सकता है।

चरण 3: संगठित साइबर हमलों का दौर (2000-2010)

इस अवधि में साइबर हमले अधिक योजनाबद्ध और बड़े पैमाने पर होने लगे।

प्रमुख विशेषताएँ

- DDoS हमले
- सरकारी वेबसाइटों पर हमले
- बैंकिंग नेटवर्क पर हमले
- साइबर जासूसी (Cyber Espionage)

अध्ययन: एस्टोनिया (2007)

2007 में एस्टोनिया पर व्यापक Distributed Denial of Service (DDoS) हमले हुए।

प्रभाव:

- सरकारी वेबसाइटें बंद
- बैंकिंग सेवाएँ बाधित
- समाचार पोर्टल प्रभावित
- संचार व्यवस्था पर असर

यह घटना आधुनिक साइबर युद्ध के शुरुआती बड़े उदाहरणों में गिनी जाती है।

चरण 4: औद्योगिक नियंत्रण प्रणालियों पर हमले (2010-2020)

इस अवधि में हमलों का लक्ष्य केवल वेबसाइटें नहीं रहीं, बल्कि बिजली संयंत्र, जल आपूर्ति, उद्योग और परमाणु सुविधाएँ भी बनने लगीं।

अध्ययन: Stuxnet

Stuxnet एक अत्यंत उन्नत कंप्यूटर वर्म था जिसने औद्योगिक नियंत्रण प्रणालियों (Industrial Control Systems - ICS) और PLC आधारित उपकरणों को लक्ष्य बनाया।

विशेषताएँ:

- Windows सिस्टम को संक्रमित करना
- PLC निर्देशों में परिवर्तन
- सामान्य संचालन का भ्रम बनाए रखना
- भौतिक उपकरणों को नुकसान पहुँचाना

यह घटना दिखाती है कि साइबर हमला केवल डेटा नहीं, बल्कि वास्तविक मशीनों और औद्योगिक प्रक्रियाओं को भी प्रभावित कर सकता है।

चरण 5: आधुनिक साइबर युद्ध (2020-वर्तमान)

आज साइबर युद्ध बहुआयामी हो चुका है।

प्रमुख लक्ष्य

- ऊर्जा ग्रिड
- बैंकिंग प्रणाली
- एयर ट्रैफिक नियंत्रण
- अस्पताल
- दूरसंचार
- क्लाउड सेवाएँ
- रक्षा नेटवर्क
- उपग्रह संचार

नई तकनीकें

- AI आधारित हमले
- Deepfake

- Supply Chain Attack
 - Ransomware
 - Cloud Attack
 - IoT Attack
 - Zero-Day Exploits
-

5. साइबर युद्ध के प्रमुख उद्देश्य

- राष्ट्रीय सुरक्षा को कमजोर करना
 - आर्थिक नुकसान पहुँचाना
 - महत्वपूर्ण सेवाओं को बाधित करना
 - सैन्य जानकारी प्राप्त करना
 - जनता में भय और भ्रम फैलाना
 - राजनीतिक प्रभाव स्थापित करना
-

6. साइबर युद्ध में उपयोग किए जाने वाले प्रमुख हथियार

1. Malware

दुर्भावनापूर्ण सॉफ्टवेयर जो डेटा चुराने या सिस्टम को नुकसान पहुँचाने के लिए बनाया जाता है।

2. Ransomware

डेटा को एन्क्रिप्ट करके फिरौती की मांग करना।

उदाहरण: यदि किसी अस्पताल की सभी फाइलें एन्क्रिप्ट हो जाएँ, तो इलाज प्रभावित हो सकता है।

3. DDoS Attack

एक साथ लाखों अनुरोध भेजकर वेबसाइट या सर्वर को अनुपलब्ध कर देना।

4. Zero-Day Exploit

सॉफ्टवेयर की ऐसी कमजोरी का उपयोग करना जिसके लिए अभी तक सुरक्षा पैच उपलब्ध न हो।

5. Advanced Persistent Threat (APT)

दीर्घकालिक, योजनाबद्ध और अत्यधिक परिष्कृत हमला, जिसका उद्देश्य लंबे समय तक किसी नेटवर्क में छिपकर संवेदनशील जानकारी प्राप्त करना होता है।

7. वास्तविक जीवन पर आधारित उदाहरण

उदाहरण 1: विद्युत ग्रिड

यदि किसी देश के बिजली नियंत्रण केंद्र के SCADA नेटवर्क में घुसपैठ हो जाए और ट्रांसफॉर्मर या नियंत्रण संकेतों में बदलाव कर दिया जाए, तो व्यापक बिजली कटौती हो सकती है।

उदाहरण 2: बैंकिंग प्रणाली

यदि राष्ट्रीय भुगतान प्रणाली (Payment Network) पर हमला हो जाए, तो:

- ऑनलाइन भुगतान रुक सकते हैं।
 - ATM सेवाएँ बाधित हो सकती हैं।
 - वित्तीय लेन-देन प्रभावित हो सकते हैं।
-

उदाहरण 3: अस्पताल

यदि किसी बड़े अस्पताल के नेटवर्क पर रैनसमवेयर हमला हो जाए:

- मरीजों का रिकॉर्ड उपलब्ध नहीं रहेगा।
 - ऑपरेशन स्थगित हो सकते हैं।
 - आपातकालीन सेवाएँ प्रभावित होंगी।
-

उदाहरण 4: विश्वविद्यालय

यदि किसी विश्वविद्यालय के सर्वर पर साइबर हमला हो:

- परीक्षा परिणाम बदले जा सकते हैं।
- शोध डेटा चोरी हो सकता है।
- प्रवेश प्रक्रिया बाधित हो सकती है।

8. साइबर युद्ध से बचाव की रणनीतियाँ

- Zero Trust Architecture
- Multi-Factor Authentication (MFA)
- Network Segmentation
- नियमित Patch Management
- Security Operations Center (SOC)
- Threat Intelligence
- Intrusion Detection/Prevention Systems (IDS/IPS)
- नियमित Vulnerability Assessment एवं Penetration Testing
- Incident Response Plan
- Digital Forensics Readiness

9. भारत में साइबर सुरक्षा की भूमिका

भारत में डिजिटल सेवाओं के विस्तार—जैसे डिजिटल भुगतान, ई-गवर्नेंस, स्वास्थ्य, शिक्षा और रक्षा प्रणालियों—के कारण साइबर सुरक्षा का महत्व लगातार बढ़ रहा है।

प्रमुख संस्थाएँ:

- **CERT-In (Indian Computer Emergency Response Team)**
- **National Critical Information Infrastructure Protection Centre (NCIIPC)**
- **Defence Cyber Agency (DCA)**
- **Indian Cyber Crime Coordination Centre (I4C)**

ये संस्थाएँ साइबर घटनाओं की निगरानी, प्रतिक्रिया, समन्वय और महत्वपूर्ण अवसंरचना की सुरक्षा में महत्वपूर्ण भूमिका निभाती हैं।

10. भविष्य की चुनौतियाँ

भविष्य में साइबर युद्ध और अधिक जटिल हो सकता है, क्योंकि इसमें निम्न तकनीकों की भूमिका बढ़ रही है:

- कृत्रिम बुद्धिमत्ता (AI)
- क्वांटम कंप्यूटिंग
- 6G नेटवर्क
- Internet of Things (IoT)
- Autonomous Vehicles
- Smart Cities
- Space-Based Communication Systems

अध्याय का निष्कर्ष

साइबर युद्ध आधुनिक विश्व की सबसे महत्वपूर्ण सुरक्षा चुनौतियों में से एक है। यह केवल कंप्यूटर हैकिंग तक सीमित नहीं, बल्कि किसी राष्ट्र की ऊर्जा, बैंकिंग, स्वास्थ्य, संचार, परिवहन, रक्षा और प्रशासनिक प्रणालियों को प्रभावित करने की क्षमता रखता है। इसलिए आधुनिक राष्ट्रों के लिए साइबर सुरक्षा, डिजिटल फॉरेंसिक, खतरा खुफिया (Threat Intelligence), उन्नत निगरानी और अंतरराष्ट्रीय सहयोग राष्ट्रीय सुरक्षा की अनिवार्य आवश्यकताएँ बन चुके हैं।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय 1.4

Digital Transformation (डिजिटल परिवर्तन)

1. परिचय (Introduction)

डिजिटल ट्रांसफॉर्मेशन (Digital Transformation) केवल कागजी कार्यों को कंप्यूटर पर लाना या इंटरनेट का उपयोग करना नहीं है, बल्कि यह एक व्यापक प्रक्रिया है जिसके अंतर्गत किसी संगठन, उद्योग, संस्था या सरकार के व्यावसायिक मॉडल (Business Model), कार्यप्रणाली (Operations), सेवाएँ (Services), निर्णय प्रक्रिया (Decision Making), ग्राहक अनुभव (Customer Experience) और संगठनात्मक संस्कृति (Organizational Culture) को डिजिटल तकनीकों की सहायता से पूरी तरह बदल दिया जाता है।

दूसरे शब्दों में,

"Digital Transformation वह रणनीतिक प्रक्रिया है जिसमें आधुनिक डिजिटल तकनीकों का उपयोग करके किसी संस्था के कार्य करने के तरीके, सेवाओं और निर्णय लेने की प्रक्रिया को अधिक कुशल, सुरक्षित, तेज, पारदर्शी और बुद्धिमान बनाया जाता है।"

आज के समय में Artificial Intelligence (AI), Cloud Computing, Big Data, Internet of Things (IoT), Blockchain, Robotics, Machine Learning, 5G, Edge Computing और Cyber Security इस परिवर्तन के प्रमुख आधार हैं।

2. Digital Transformation का इतिहास

(1) Manual Era (1950 से पहले)

सभी कार्य हाथ से किए जाते थे।

उदाहरण

- रजिस्टर में हिसाब-किताब
- कागज़ पर पत्राचार

- फाइलों में रिकॉर्ड
- हस्तलिखित परीक्षा परिणाम

समस्याएँ

- डेटा खो जाने का खतरा
- अधिक समय
- अधिक मानव त्रुटियाँ
- खोजने में कठिनाई

(2) Computerization Era (1960–1990)

कंप्यूटरों का उपयोग शुरू हुआ।

उदाहरण

- Payroll Software
- Basic Database
- Accounting Software

लाभ

- तेज गणना
- डेटा स्टोरेज
- रिपोर्ट निर्माण



(3) Internet Era (1990–2010)

इंटरनेट ने पूरी दुनिया को जोड़ दिया।

उदाहरण

- Email
- E-Commerce
- Online Banking
- Online Education
- Web Portals

(4) Smart Digital Era (2010-वर्तमान)

अब केवल कंप्यूटर नहीं, बल्कि पूरा इकोसिस्टम डिजिटल हो चुका है।

प्रमुख तकनीकें

- AI
- IoT
- Cloud
- Big Data
- Blockchain
- Robotics
- Digital Twin
- Edge Computing

3. Digital Transformation की आवश्यकता

आज प्रत्येक संस्था को निम्न कारणों से Digital Transformation अपनाना पड़ रहा है—

- कार्य की गति बढ़ाने के लिए
- लागत कम करने के लिए
- डेटा की सुरक्षा के लिए
- बेहतर निर्णय लेने के लिए
- ग्राहक अनुभव सुधारने के लिए
- वैश्विक प्रतिस्पर्धा में बने रहने के लिए
- रिमोट कार्य (Remote Work) को सक्षम बनाने के लिए

4. Digital Transformation के प्रमुख घटक

(1) Digital Data

पहले डेटा कागज़ पर होता था।

अब

- Database
- Cloud
- Data Lake
- Data Warehouse

(2) Cloud Computing

डेटा स्थानीय कंप्यूटर की बजाय क्लाउड पर रखा जाता है।

उदाहरण

विद्यालय अपना ERP क्लाउड पर होस्ट करता है, जिससे विभिन्न शाखाएँ एक ही सिस्टम का उपयोग कर सकती हैं।

(3) Artificial Intelligence (AI)

AI डेटा का विश्लेषण करके निर्णय लेने में सहायता करता है।

उदाहरण

बैंक AI की सहायता से संदिग्ध लेन-देन (Fraud Detection) की पहचान करता है।

(4) Internet of Things (IoT)

इंटरनेट से जुड़े उपकरण आपस में डेटा साझा करते हैं।

उदाहरण

स्मार्ट क्लासरूम में उपस्थिति, तापमान और ऊर्जा उपयोग का स्वचालित नियंत्रण।

(5) Big Data Analytics

विशाल मात्रा में डेटा का विश्लेषण।

उदाहरण

विश्वविद्यालय कई वर्षों के परीक्षा परिणामों का विश्लेषण करके विद्यार्थियों की सफलता के पैटर्न पहचानता है।

(6) Cyber Security

जितना अधिक डिजिटलीकरण होगा, उतनी अधिक सुरक्षा आवश्यक होगी।

उदाहरण

यदि बैंक पूरी तरह डिजिटल है, तो MFA, Encryption, Firewall, IDS/IPS और Security Operations Center (SOC) आवश्यक हैं।

5. Digital Transformation के प्रमुख क्षेत्र

(1) शिक्षा (Education)

पहले

- हस्तलिखित उपस्थिति
- कागज़ी अंकपत्र
- ऑफलाइन प्रवेश

अब

- Online Admission
- ERP System
- Digital Attendance
- Smart Classroom
- E-Learning
- Digital Certificates

उदाहरण

एक विद्यालय में ERP प्रणाली के माध्यम से:

- फीस ऑनलाइन जमा
- उपस्थिति मोबाइल ऐप से
- परीक्षा परिणाम ऑनलाइन
- अभिभावकों को SMS/ईमेल सूचना
-

(2) बैंकिंग

पहले

- पासबुक
- चेक
- लंबी कतारें

अब

- UPI
- Mobile Banking
- Internet Banking
- AI आधारित Fraud Detection

(3) स्वास्थ्य (Healthcare)

पहले

- कागजी पर्ची
- फाइल आधारित रिकॉर्ड

अब

- Electronic Health Records (EHR)
- Telemedicine
- AI Diagnosis
- Digital Prescription

(4) कृषि (Agriculture)

उदाहरण

- Smart Irrigation
- Drone Monitoring
- Soil Sensors
- Weather Prediction
- AI आधारित फसल सलाह

(5) उद्योग (Industry 4.0)

- Smart Factory
 - Robotics
 - Predictive Maintenance
 - Digital Twin
 - Industrial IoT
-

(6) शासन (Digital Governance)

उदाहरण

- ऑनलाइन प्रमाणपत्र
 - डिजिटल भुगतान
 - ई-टेंडरिंग
 - भूमि अभिलेखों का डिजिटलीकरण
 - ऑनलाइन शिकायत निवारण
-

6. Digital Transformation और Cyber Security का संबंध

जैसे-जैसे संस्थाएँ डिजिटल होती हैं, साइबर जोखिम भी बढ़ते हैं।

प्रमुख जोखिम

- Data Breach
- Ransomware
- Insider Threat
- Cloud Misconfiguration
- Identity Theft
- Phishing
- Supply Chain Attack

इसलिए Digital Transformation का अभिन्न अंग Cyber Security है।

7. वास्तविक जीवन के केस स्टडी

केस स्टडी 1: विद्यालय ERP

मान लीजिए किसी विद्यालय में पहले सभी कार्य रजिस्टर में होते थे।

समस्याएँ

- फीस खोजने में समय
- अंकपत्र तैयार करने में देरी
- डेटा खोने का खतरा
- अभिभावकों से संवाद में कठिनाई

Digital Transformation के बाद

- ERP लागू
- ऑनलाइन फीस
- स्वचालित रसीद
- SMS सूचना
- ऑनलाइन रिपोर्ट कार्ड
- डिजिटल बैकअप
- Role-Based Access Control

परिणाम: समय की बचत, त्रुटियों में कमी, पारदर्शिता और बेहतर प्रबंधन।

केस स्टडी 2: अस्पताल

एक अस्पताल ने Electronic Health Record (EHR) प्रणाली अपनाई।

लाभ

- मरीज का इतिहास तुरंत उपलब्ध
- दवा संबंधी त्रुटियों में कमी
- ऑनलाइन अपॉइंटमेंट
- दूरस्थ परामर्श (Telemedicine)

सुरक्षा उपाय

- डेटा एन्क्रिप्शन
- MFA
- Audit Logs
- नियमित बैकअप

केस स्टडी 3: बैंक

एक बैंक ने AI आधारित Fraud Detection प्रणाली लागू की।

यदि

- ग्राहक सामान्यतः उत्तर प्रदेश से लेन-देन करता है।
- अचानक विदेश से बड़ी राशि निकालने का प्रयास होता है।

AI सिस्टम इस व्यवहार को असामान्य मानकर अतिरिक्त सत्यापन या लेन-देन रोक सकता है।

8. Digital Transformation की चुनौतियाँ

- साइबर हमलों में वृद्धि
- डेटा गोपनीयता
- कर्मचारियों का प्रशिक्षण
- परिवर्तन के प्रति प्रतिरोध
- लागत
- पुराने सिस्टम के साथ एकीकरण
- कानूनी अनुपालन (Compliance)

9. सफल Digital Transformation के लिए आवश्यक तत्व

1. स्पष्ट डिजिटल रणनीति
2. नेतृत्व का समर्थन
3. प्रशिक्षित मानव संसाधन
4. मजबूत Cyber Security Framework

5. नियमित जोखिम मूल्यांकन
6. डेटा गवर्नेंस
7. व्यवसाय निरंतरता योजना (Business Continuity)
8. आपदा पुनर्प्राप्ति (Disaster Recovery)
9. निरंतर नवाचार और सुधार

10. भविष्य की दिशा

आने वाले वर्षों में Digital Transformation निम्न तकनीकों से और अधिक प्रभावित होगा:

- Generative AI
- Autonomous Systems
- Quantum Computing
- 6G Communication
- Digital Twins
- Smart Cities
- Edge AI
- Extended Reality (XR)
- Blockchain आधारित डिजिटल पहचान
- Zero Trust आधारित सुरक्षा मॉडल

अध्याय का निष्कर्ष

Digital Transformation केवल तकनीक अपनाने की प्रक्रिया नहीं, बल्कि संगठन की कार्य संस्कृति, निर्णय प्रणाली और सेवा मॉडल का व्यापक पुनर्गठन है। इसका उद्देश्य दक्षता, पारदर्शिता, नवाचार और बेहतर उपयोगकर्ता अनुभव प्रदान करना है। हालांकि, जैसे-जैसे संस्थाएँ डिजिटल होती हैं, साइबर जोखिम भी बढ़ते हैं। इसलिए Digital Transformation और Cyber Security एक-दूसरे के पूरक हैं—सुरक्षा के बिना डिजिटल परिवर्तन अधूरा है।

अध्याय 1.5

Security Concepts

(सुरक्षा की मूलभूत अवधारणाएँ)

1. प्रस्तावना (Introduction)

Security Concepts (सुरक्षा की मूलभूत अवधारणाएँ) साइबर सुरक्षा (Cyber Security) की आधारशिला हैं। यदि इन अवधारणाओं को सही प्रकार से नहीं समझा जाए, तो किसी भी सुरक्षा प्रणाली (Security System) का प्रभावी निर्माण संभव नहीं है।

सुरक्षा का अर्थ केवल कंप्यूटर पर एंटीवायरस इंस्टॉल करना नहीं है, बल्कि डेटा (Data), सूचना (Information), नेटवर्क (Network), सॉफ्टवेयर (Software), हार्डवेयर (Hardware), उपयोगकर्ता (Users), प्रक्रियाओं (Processes) और सेवाओं (Services) की समग्र सुरक्षा सुनिश्चित करना है।

साइबर सुरक्षा के सभी मानक—जैसे ISO/IEC 27001, NIST Cybersecurity Framework, CIS Controls, COBIT तथा Zero Trust Architecture—इन्हीं मूलभूत सिद्धांतों पर आधारित हैं।

2. Security (सुरक्षा) क्या है?

Security वह स्थिति है जिसमें किसी परिसंपत्ति (Asset) को अनधिकृत पहुँच (Unauthorized Access), परिवर्तन (Modification), प्रकटीकरण (Disclosure), चोरी (Theft), विनाश (Destruction) या सेवा बाधित (Disruption) होने से सुरक्षित रखा जाए।

सरल शब्दों में:

"किसी भी मूल्यवान संसाधन (Asset) को संभावित खतरों (Threats) से सुरक्षित रखने की प्रक्रिया को Security कहते हैं।"

3. Information Security और Cyber Security में अंतर

आधार	Information Security	Cyber Security
उद्देश्य	किसी भी प्रकार की सूचना की सुरक्षा	डिजिटल प्रणालियों एवं नेटवर्क की सुरक्षा
डेटा का स्वरूप	कागज़ी, मौखिक एवं डिजिटल	केवल डिजिटल
दायरा	व्यापक	अपेक्षाकृत सीमित
उदाहरण	गोपनीय फाइल को तिजोरी में रखना	सर्वर पर Firewall लगाना

4. Asset (परिसंपत्ति)

Asset वह वस्तु, सूचना या संसाधन है जिसका संगठन के लिए मूल्य (Value) हो।

उदाहरण

- ग्राहक डेटा
- बैंकिंग रिकॉर्ड
- सर्वर
- वेबसाइट
- शोध प्रबंध (Research Data)
- ईमेल
- क्लाउड स्टोरेज
- स्रोत कोड (Source Code)

वास्तविक उदाहरण

यदि किसी विश्वविद्यालय का Ph.D. शोध डेटा नष्ट हो जाए, तो वर्षों का शोध समाप्त हो सकता है। इसलिए वह डेटा एक महत्वपूर्ण Information Asset है।

5. Threat (खतरा)

Threat वह संभावित घटना या परिस्थिति है जो किसी Asset को नुकसान पहुँचा सकती है।

उदाहरण

- Hacker
- Malware
- Fire
- Flood
- Power Failure
- Insider Attack
- Phishing
- Ransomware

उदाहरण

एक कर्मचारी जानबूझकर कंपनी का गोपनीय डेटा USB Drive में कॉपी करके बाहर ले जाता है। यह **Insider Threat** है।

6. Vulnerability (कमज़ोरी)

Vulnerability किसी सिस्टम, नेटवर्क या प्रक्रिया की ऐसी कमजोरी है जिसका लाभ उठाकर हमलावर हमला कर सकता है।

उदाहरण

- कमजोर पासवर्ड (123456)
- पुराना (Outdated) सॉफ्टवेयर
- बिना अपडेट का ऑपरेटिंग सिस्टम
- गलत कॉन्फिगरेशन (Misconfiguration)
- खुला नेटवर्क पोर्ट

उदाहरण

यदि विद्यालय के ERP सिस्टम का एडमिन पासवर्ड admin123 है, तो यह एक गंभीर Vulnerability है।

7. Exploit

Exploit वह तकनीक या कोड है जिसके माध्यम से किसी Vulnerability का लाभ उठाकर हमला किया जाता है।

उदाहरण

यदि किसी वेबसाइट में SQL Injection की कमजोरी है और हमलावर उसी का उपयोग करके डेटाबेस तक पहुँच जाता है, तो प्रयुक्त SQL Injection तकनीक Exploit कहलाती है।

8. Risk (जोखिम)

Risk वह संभावना है कि कोई Threat किसी Vulnerability का लाभ उठाकर Asset को नुकसान पहुँचाए।

सरल सूत्र

$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$

उदाहरण

- Asset: बैंक का ग्राहक डेटा
- Threat: Hacker
- Vulnerability: कमजोर पासवर्ड
- Impact: करोड़ों रुपये का नुकसान

इस स्थिति में Risk बहुत अधिक है।

9. Attack Surface

Attack Surface उन सभी बिंदुओं (Entry Points) का समूह है जहाँ से कोई हमलावर सिस्टम पर हमला कर सकता है।

उदाहरण

- वेबसाइट
- मोबाइल ऐप

- API
- Wi-Fi
- VPN
- ईमेल सर्वर
- USB पोर्ट

जितना बड़ा Attack Surface होगा, सुरक्षा की चुनौती उतनी अधिक होगी।

10. Security Controls (सुरक्षा नियंत्रण)

Security Controls वे उपाय हैं जिनका उद्देश्य जोखिम को कम करना होता है।

(क) Preventive Controls (निवारक)

हमले को होने से पहले रोकना।

उदाहरण:

- Firewall
- MFA
- Encryption
- Strong Password Policy

(ख) Detective Controls (पता लगाने वाले)

हमले का पता लगाना।

उदाहरण:

- IDS
- SIEM
- Audit Logs
- Security Monitoring

(ग) Corrective Controls (सुधारात्मक)

हमले के बाद सिस्टम को पुनः सामान्य स्थिति में लाना।

उदाहरण:

- Backup Restore
- Patch Management
- Incident Response

11. Defense in Depth (बहु-स्तरीय सुरक्षा)

किसी एक सुरक्षा उपाय पर निर्भर रहने के बजाय कई स्तरों पर सुरक्षा लागू करना।

उदाहरण

एक बैंक में:

- Firewall
- IDS/IPS
- MFA
- Database Encryption
- Endpoint Protection
- SOC Monitoring

यदि एक सुरक्षा परत विफल हो जाए, तो दूसरी परत सुरक्षा प्रदान करती है।

12. Least Privilege Principle (न्यूनतम अधिकार सिद्धांत)

प्रत्येक उपयोगकर्ता को केवल उतने ही अधिकार दिए जाएँ जितने उसके कार्य के लिए आवश्यक हों।

उदाहरण

विद्यालय में:

- छात्र केवल अपने परिणाम देख सकता है।
- शिक्षक अंक दर्ज कर सकता है।
- प्रधानाचार्य सभी रिकॉर्ड देख सकते हैं।
- सिस्टम एडमिन कॉन्फिगरेशन बदल सकता है।

13. Need-to-Know Principle

हर उपयोगकर्ता को केवल वही जानकारी उपलब्ध हो जो उसके कार्य के लिए आवश्यक हो।

उदाहरण

अस्पताल में रिसेप्शन कर्मचारी को मरीज का नाम और अपॉइंटमेंट दिखे, लेकिन विस्तृत चिकित्सा इतिहास केवल डॉक्टर देख सकें।

14. Separation of Duties (कर्तव्यों का पृथक्करण)

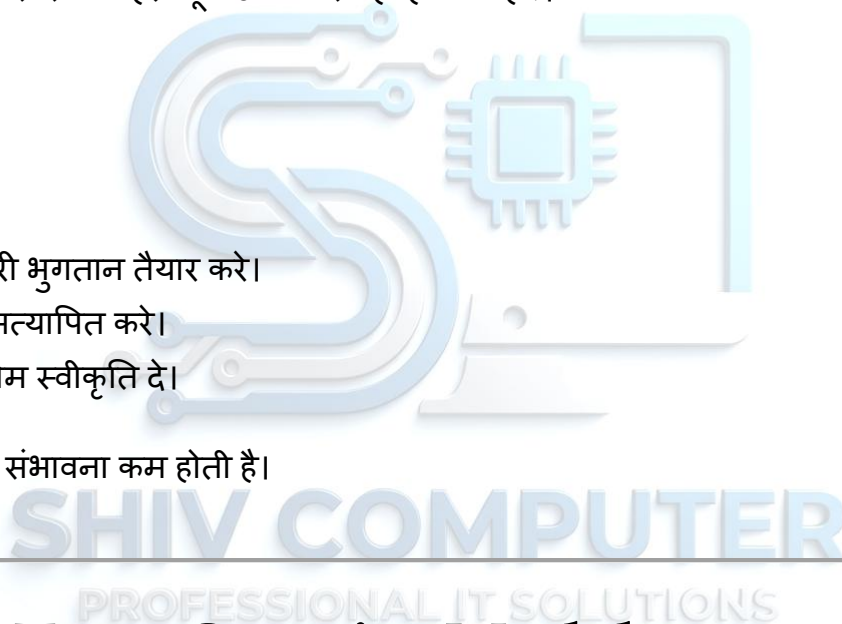
एक ही व्यक्ति के पास सभी महत्वपूर्ण अधिकार नहीं होने चाहिए।

उदाहरण

बैंक में:

- एक कर्मचारी भुगतान तैयार करे।
- दूसरा उसे सत्यापित करे।
- तीसरा अंतिम स्वीकृति दे।

इससे धोखाधड़ी की संभावना कम होती है।



15. Zero Trust Security Model

इस सिद्धांत का मूल विचार है:

"Never Trust, Always Verify."

अर्थात् किसी उपयोगकर्ता या डिवाइस पर केवल नेटवर्क के अंदर होने के कारण भरोसा नहीं किया जाता; प्रत्येक अनुरोध का सत्यापन किया जाता है।

उदाहरण

कर्मचारी कार्यालय के नेटवर्क में होने पर भी संवेदनशील डेटा देखने से पहले MFA पूरा करेगा।

16. Security by Design

सुरक्षा को बाद में जोड़ने के बजाय सिस्टम के डिज़ाइन चरण से ही शामिल किया जाए।

उदाहरण

नई ERP प्रणाली बनाते समय शुरुआत से:

- Password Hashing
- Input Validation
- Encryption
- Secure Coding
- Role-Based Access Control

जैसी सुविधाएँ शामिल की जाएँ।

17. वास्तविक जीवन के केस स्टडी

केस स्टडी 1: विद्यालय ERP

समस्या:

- सभी कर्मचारियों का एक ही पासवर्ड
- कोई लॉग मॉनिटरिंग नहीं
- बैकअप नहीं

परिणाम:

- छात्र परिणाम बदल दिए गए।
- फीस रिकॉर्ड मिट गए।

समाधान:

- Role-Based Access Control
- MFA
- Audit Logs
- नियमित Backup

केस स्टडी 2: बैंक

स्थिति:

एक बैंक केवल पासवर्ड आधारित लॉगिन उपयोग कर रहा था।

जोखिम:

Phishing द्वारा पासवर्ड चोरी हो सकता था।

समाधान:

- Multi-Factor Authentication
- व्यवहार-आधारित निगरानी (Behavior Analytics)
- Fraud Detection

केस स्टडी 3: अस्पताल

अस्पताल में सभी डॉक्टर और कर्मचारी एक ही साझा लॉगिन का उपयोग कर रहे थे।

समस्या:

किसने मरीज का रिकॉर्ड बदला, यह पता नहीं चल सकता था।

समाधान:

- प्रत्येक कर्मचारी के लिए अलग User ID
- Audit Trail
- Accountability

18. Security Concepts का महत्व

इन मूलभूत अवधारणाओं के बिना:

- सुरक्षित नेटवर्क नहीं बनाया जा सकता।
- सुरक्षित सॉफ्टवेयर विकसित नहीं किया जा सकता।
- डिजिटल फॉरेंसिक प्रभावी नहीं हो सकती।
- जोखिम प्रबंधन (Risk Management) संभव नहीं होता।
- किसी संगठन में सुरक्षा शासन (Security Governance) लागू नहीं किया जा सकता।

अध्याय का सार (Summary)

Security Concepts किसी भी Cyber Security Framework की नींव हैं। **Asset, Threat, Vulnerability, Risk, Security Controls, Defense in Depth, Least Privilege, Zero Trust और Security by Design** जैसे सिद्धांत आधुनिक डिजिटल सुरक्षा के मूल आधार हैं। एक प्रभावी सुरक्षा प्रणाली केवल तकनीकी समाधान नहीं, बल्कि **लोगों (People), प्रक्रियाओं (Processes) और तकनीक (Technology)** के संतुलित समन्वय पर आधारित होती है।



अध्याय 1.6

CIA Triad (Confidentiality – Integrity – Availability)

1. प्रस्तावना (Introduction)

यदि Cyber Security को एक विशाल भवन माना जाए, तो CIA Triad उसकी सबसे मजबूत नींव (Foundation) है।

विश्व की लगभग सभी Cyber Security Frameworks जैसे—

- ISO/IEC 27001
- NIST Cybersecurity Framework
- COBIT
- CIS Controls
- PCI-DSS
- HIPAA
- GDPR

प्रत्यक्ष या अप्रत्यक्ष रूप से CIA Triad पर आधारित हैं।

Cyber Security का मुख्य उद्देश्य किसी भी Information Asset की

- गोपनीयता (Confidentiality)
- अखंडता (Integrity)
- उपलब्धता (Availability)

को बनाए रखना है।

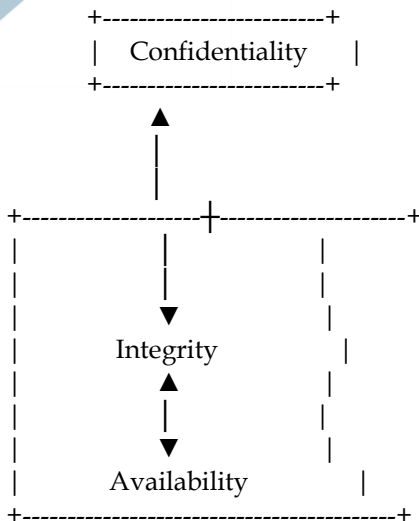
इन्हीं तीन सिद्धांतों को संयुक्त रूप से CIA Triad कहा जाता है।

2. CIA Triad क्या है?

CIA Triad तीन महत्वपूर्ण सुरक्षा सिद्धांतों का समूह है।

Information Security

CIA TRIAD



इनमें से किसी एक सिद्धांत के विफल होने पर सम्पूर्ण सुरक्षा प्रभावित हो सकती है।

3. Confidentiality (गोपनीयता)

परिभाषा

Confidentiality का अर्थ है—

"सूचना केवल उसी व्यक्ति तक पहुँचे जिसे उसे देखने का अधिकार हो।"

अर्थात्

Unauthorized Person

डेटा

न देख सके

न कॉपी कर सके

न डाउनलोड कर सके।

उदाहरण

विद्यालय के ERP में

सभी छात्रों का डेटा देख सकते हैं।

लेकिन

Student

केवल अपना Result देख सकता है।

दूसरा उदाहरण

बैंक में

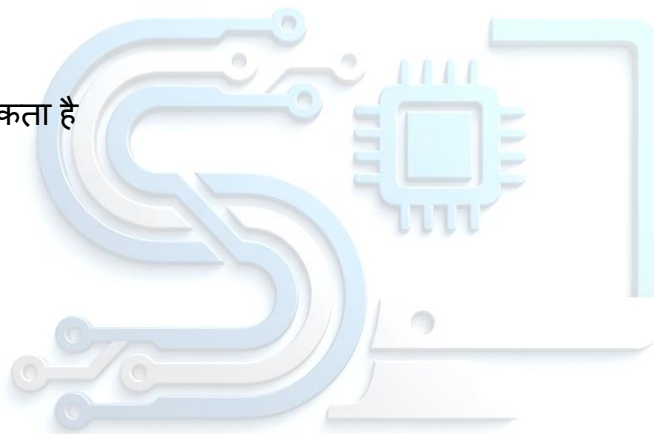
Cashier

Account Balance देख सकता है

लेकिन

Server Configuration

नहीं देख सकता।



तीसरा उदाहरण

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Hospital में

Doctor

Medical History देख सकता है

लेकिन

Receptionist

सिर्फ Appointment देख सकता है।

Confidentiality बनाए रखने की तकनीकें

Password

उदाहरण

Username

shiv

Password

Multi Factor Authentication

Password

-

OTP

-

Fingerprint

Encryption

यदि डेटा चोरी हो जाए

तो भी

कोई पढ़ न सके।

Access Control

RBAC

ABAC

MAC

DAC

VPN



Smart Card

Data Classification

Confidentiality Failure

यदि

विश्वविद्यालय का

Question Paper

Exam से पहले

Internet पर Leak हो जाए

तो

Confidentiality समाप्त हो गई।



वास्तविक केस

यदि किसी बैंक का

Customer Database

Dark Web पर बिकने लगे

तो

Confidentiality पूरी तरह नष्ट हो चुकी है।

4. Integrity (अखंडता)

परिभाषा

Integrity का अर्थ है—

डेटा

बिना अनुमति

बदला न जा सके।

यदि बदला जाए

तो उसका पता चल जाए।

उदाहरण

Student का Result

85 Marks

था।

किसी Hacker ने

95

कर दिया।

अब

डेटा सही नहीं रहा।

Integrity समाप्त हो गई।



दूसरा उदाहरण

Doctor ने

Blood Group

A+

लिखा था।

किसी ने

B+

कर दिया।

यह मरीज के जीवन के लिए खतरनाक हो सकता है।

तीसरा उदाहरण

Company का

Salary Data

किसी Insider ने बदल दिया।

अब

Employees को गलत Salary मिल जाएगी।

Integrity बनाए रखने की तकनीक

Hashing

SHA-256

SHA-3

Digital Signature

Checksum

Version Control

Blockchain

Database Constraints

उदाहरण

मान लीजिए

Original File

Cyber Security

इसका Hash

ABC123XYZ

अब

यदि कोई

एक अक्षर भी बदल दे

Cyber Security

↓

Cyber Securiti

तो

Hash

पूरी तरह बदल जाएगा।

इससे पता चल जाएगा

कि File बदल गई है।



Integrity Failure

Exam से पहले

बदल दिया गया।

अब

पूरा Exam गलत हो गया।

5. Availability (उपलब्धता)

परिभाषा

Availability का अर्थ है—

जब Authorized User

डेटा चाहे

तब

डेटा उपलब्ध होना चाहिए।



उदाहरण

यदि

ATM

24 घंटे चलना चाहिए

लेकिन

Server Down है

तो

Availability समाप्त हो गई।

दूसरा उदाहरण

Hospital

का

Patient Database

Emergency में

Open ही नहीं हो रहा।

Availability समाप्त।

तीसरा उदाहरण

UPI Server

Festival के दिन

Crash हो गया।

लाखों लोग

Payment नहीं कर पाए।

Availability Failure



Availability बनाए रखने की तकनीक

Backup

Disaster Recovery

High Availability Cluster

Load Balancer

RAID

Generator

UPS

Cloud Redundancy

Failover Server

DDoS Protection

Availability Failure

Website

पर

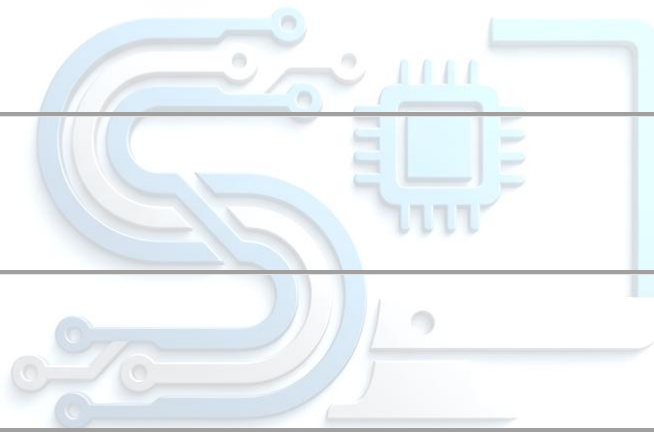
1 करोड़ Request

भेज दी गई।

Website बंद हो गई।

इसे कहते हैं

DDoS Attack



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

6. CIA Triad का वास्तविक उदाहरण

विद्यालय ERP

मान लीजिए

एक School ERP है।

उसमें

2000 Students हैं।

Confidentiality

Student

सिर्फ

अपना Result देख सकता है।

Teacher

अपनी Class देख सकता है।

Principal

सब कुछ।



Integrity

Teacher

Result डाल सकता है।

Student

Marks नहीं बदल सकता।

यदि कोई बदले

तो Audit Log में रिकॉर्ड होगा।

Availability

Result वाले दिन

5000 Parent

Website खोल रहे हैं।

Website

Crash नहीं होनी चाहिए।

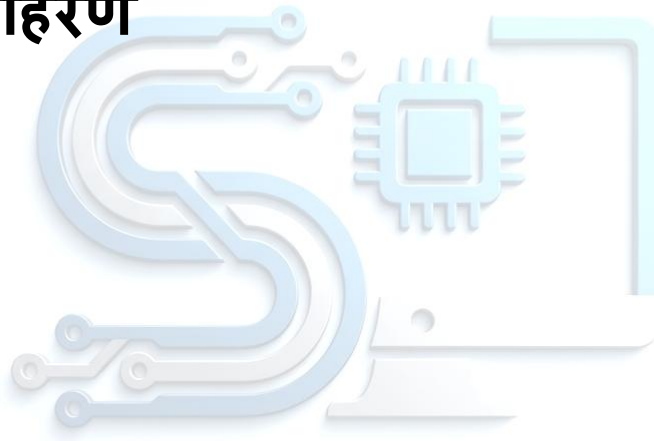
7. बैंक का उदाहरण

Suppose

State Bank

के Server में

1 करोड़ Account हैं।



Confidentiality

कोई Customer

दूसरे Customer का Balance

न देख सके।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Integrity

Transaction

₹10,000

का था।

Network में

₹1,00,000

न बन जाए।

Availability

24×7

ATM

UPI

Net Banking

चलते रहें।

8. अस्पताल का उदाहरण

Hospital में

Patient Record

संग्रहित हैं।



Confidentiality

केवल Doctor

Medical History देखे।

Integrity

Medicine

गलत न बदल जाए।

Availability

Emergency में

Report

तुरन्त उपलब्ध हो।

9. यदि CIA Triad में से एक भी असफल हो जाए

CIA	क्या होगा?
Confidentiality समाप्त	Data Leak
Integrity समाप्त	गलत Data
Availability समाप्त	Service बंद

10. CIA Triad का आधुनिक विस्तार

आज केवल CIA पर्याप्त नहीं माना जाता। आधुनिक सुरक्षा मॉडल में निम्न तत्व भी जोड़े जाते हैं:

- **Authenticity (प्रामाणिकता)** - उपयोगकर्ता और डेटा की वास्तविकता की पुष्टि।
- **Authorization (अधिकार निर्धारण)** - कौन क्या कर सकता है।
- **Accountability (उत्तरदायित्व)** - किसने क्या किया, इसका रिकॉर्ड।
- **Non-Repudiation (अस्वीकरण-असम्भवता)** - कोई उपयोगकर्ता अपने किए गए कार्य से बाद में इनकार न कर सके।
- **Privacy (गोपनीय व्यक्तिगत जानकारी की सुरक्षा)** - व्यक्तिगत डेटा का वैधानिक और नैतिक संरक्षण।
- **Resilience (लचीलापन)** - हमले के बाद भी सेवाओं को शीघ्र पुनर्स्थापित करने की क्षमता।

11. शोध (Research) दृष्टिकोण

Ph.D. स्तर पर CIA Triad का अध्ययन केवल परिभाषाओं तक सीमित नहीं रहता। शोधकर्ता निम्न प्रश्नों का विश्लेषण करते हैं:

- Cloud Computing में Confidentiality कैसे सुनिश्चित की जाए?
- AI आधारित प्रणालियों में Integrity का सत्यापन कैसे किया जाए?

- Critical Infrastructure (जैसे बिजली ग्रिड) की Availability बनाए रखने के लिए कौन-सी High Availability Architecture सर्वोत्तम है?
- Quantum Computing के युग में Confidentiality बनाए रखने हेतु Post-Quantum Cryptography की क्या भूमिका होगी?

अध्याय का निष्कर्ष (Conclusion)

CIA Triad आधुनिक सूचना सुरक्षा का सबसे मौलिक और सर्वाधिक प्रभावशाली मॉडल है। किसी भी सुरक्षित प्रणाली का मूल्यांकन इस आधार पर किया जाता है कि वह Confidentiality (गोपनीयता), Integrity (अखंडता) और Availability (उपलब्धता) को किस स्तर तक बनाए रखती है। बैंकिंग, स्वास्थ्य, शिक्षा, रक्षा, ई-गवर्नेंस, क्लाउड कंप्यूटिंग और औद्योगिक नियंत्रण प्रणालियाँ—सभी क्षेत्रों में इन तीनों सिद्धांतों का संतुलन अत्यंत आवश्यक है।

मुख्य संदेश: यदि किसी प्रणाली में केवल एक तत्व मजबूत हो और अन्य दो कमजोर हों, तो वह प्रणाली पूर्णतः सुरक्षित नहीं मानी जा सकती। प्रभावी साइबर सुरक्षा का उद्देश्य CIA Triad के तीनों स्तंभों को समान रूप से सुदृढ़ रखना है।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय 1.7

Parkerian Hexad (पार्केरियन हेक्साड)

सूचना सुरक्षा का उन्नत मॉडल (Advanced Information Security Model)

1. प्रस्तावना (Introduction)

सूचना सुरक्षा (Information Security) के क्षेत्र में CIA Triad (Confidentiality, Integrity और Availability) को सुरक्षा का मूल आधार माना जाता है। अनेक वर्षों तक यही मॉडल सूचना सुरक्षा के मूल्यांकन का प्रमुख आधार रहा। किन्तु समय के साथ यह अनुभव किया गया कि केवल तीन सिद्धांत आधुनिक सूचना सुरक्षा की सभी आवश्यकताओं को पूर्ण रूप से व्यक्त नहीं कर सकते।

इसी आवश्यकता को ध्यान में रखते हुए प्रसिद्ध सूचना सुरक्षा विशेषज्ञ Donn B. Parker ने 1998 में एक उन्नत सुरक्षा मॉडल प्रस्तुत किया, जिसे Parkerian Hexad कहा जाता है।

"Hexad" का अर्थ है छः (Six)। इस मॉडल में सूचना सुरक्षा को छह मूलभूत गुणों (Security Attributes) के आधार पर समझाया गया है।

Parkerian Hexad आधुनिक Information Security का विस्तृत मॉडल है, जो CIA Triad का विस्तार (Extension) माना जाता है।

2. Parkerian Hexad क्या है?

Parkerian Hexad सूचना सुरक्षा का ऐसा मॉडल है जिसमें किसी भी सूचना या सूचना प्रणाली की सुरक्षा का मूल्यांकन निम्न छह आधारों पर किया जाता है—

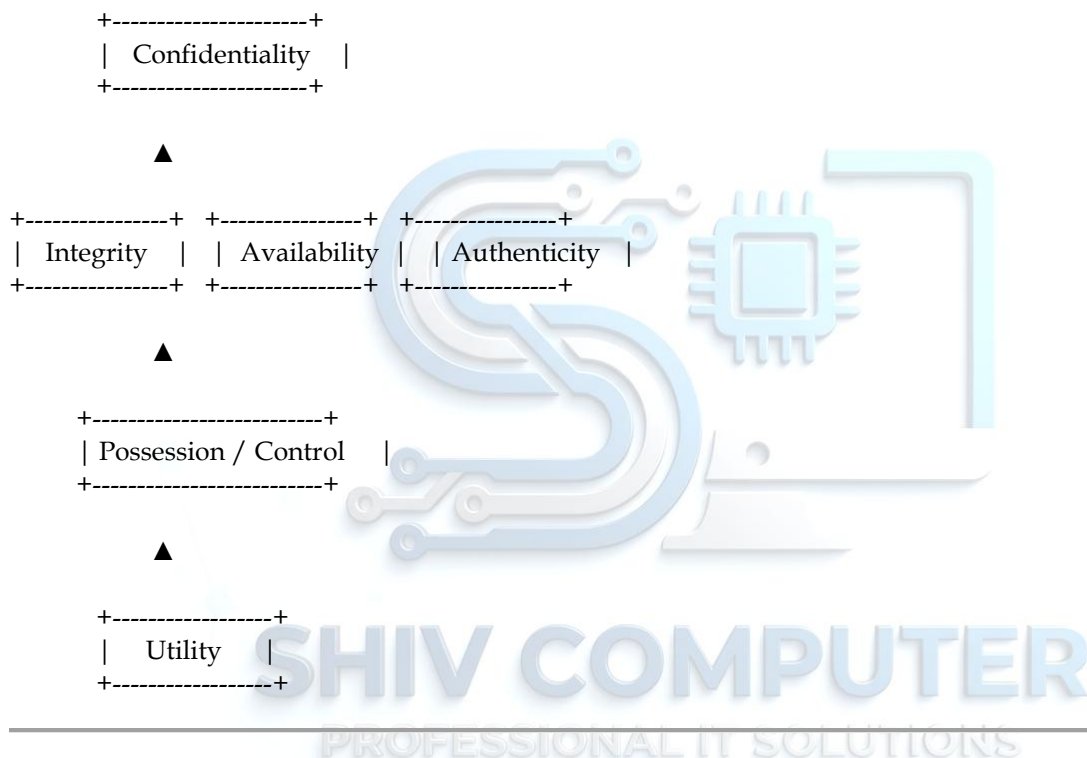
1. Confidentiality (गोपनीयता)
2. Integrity (अखंडता)
3. Availability (उपलब्धता)
4. Possession or Control (स्वामित्व या नियंत्रण)

5. Authenticity (प्रामाणिकता)
6. Utility (उपयोगिता)

इन छह तत्वों का उद्देश्य यह सुनिश्चित करना है कि सूचना केवल सुरक्षित ही न रहे, बल्कि सही व्यक्ति के नियंत्रण में, सही रूप में, सही समय पर और उपयोग योग्य अवस्था में भी उपलब्ध हो।

3. Parkerian Hexad का संरचनात्मक चित्र

PARKERIAN HEXAD



4. Confidentiality (गोपनीयता)

परिभाषा

सूचना केवल अधिकृत (Authorized) व्यक्तियों द्वारा ही देखी जा सके।

उदाहरण

विद्यालय के ERP सिस्टम में—

- Principal सभी विद्यार्थियों का डेटा देख सकते हैं।

- Class Teacher केवल अपनी कक्षा का डेटा देख सकता है।
- Student केवल अपना Result देख सकता है।

यदि कोई बाहरी व्यक्ति डेटाबेस डाउनलोड कर ले, तो Confidentiality समाप्त हो जाती है।

सुरक्षा उपाय

- Encryption
 - Multi-Factor Authentication (MFA)
 - Role-Based Access Control (RBAC)
 - VPN
 - Data Classification
-

5. Integrity (अखंडता)

परिभाषा

सूचना सही (Accurate), पूर्ण (Complete) और बिना अनुमति परिवर्तित न होने वाली होनी चाहिए।

उदाहरण

यदि किसी छात्र के 82 अंक को हैकर 98 कर दे, तो परिणाम की Integrity नष्ट हो जाती है।

सुरक्षा उपाय

- Hash Functions (SHA-256)
 - Digital Signature
 - Checksum
 - Audit Logs
 - Version Control
-

6. Availability (उपलब्धता)

परिभाषा

जब अधिकृत उपयोगकर्ता को सूचना की आवश्यकता हो, तब वह उपलब्ध होनी चाहिए।

उदाहरण

यदि अस्पताल का सर्वर आपातकाल के समय बंद हो जाए, तो डॉक्टर मरीज की रिपोर्ट नहीं देख पाएंगे।

यह Availability Failure है।

सुरक्षा उपाय

- Backup
 - Disaster Recovery
 - RAID
 - Failover Server
 - Load Balancer
 - DDoS Protection
-

7. Possession or Control (स्वामित्व या नियंत्रण)

परिभाषा

Possession का अर्थ है कि सूचना या उसका संग्रहण माध्यम (Storage Media) किसके नियंत्रण में है।

यह आवश्यक नहीं कि किसी ने डेटा पढ़ लिया हो; केवल उसका नियंत्रण खो जाना भी सुरक्षा घटना हो सकती है।

उदाहरण 1

एक बैंक कर्मचारी का लैपटॉप चोरी हो जाता है।

डेटा एन्क्रिप्टेड है, इसलिए चोर उसे पढ़ नहीं सकता।

फिर भी बैंक ने उस डेटा पर अपना Possession (नियंत्रण) खो दिया है।

उदाहरण 2

किसी कंपनी की Backup Hard Disk खो जाती है।

भले ही डेटा सुरक्षित हो, लेकिन नियंत्रण समाप्त हो चुका है।

उदाहरण 3

एक पेन ड्राइव में परीक्षा प्रश्नपत्र रखा है। पेन ड्राइव रास्ते में खो जाती है। यदि प्रश्नपत्र एन्क्रिप्टेड है, तो गोपनीयता बनी रह सकती है, लेकिन संस्था का उस माध्यम पर नियंत्रण समाप्त हो गया।

सुरक्षा उपाय

- Asset Tracking
 - Device Encryption
 - Remote Wipe
 - Physical Security
 - Secure Storage
-

8. Authenticity (प्रामाणिकता)

परिभाषा

Authenticity का अर्थ है कि सूचना, उपयोगकर्ता या स्रोत वास्तविक (Genuine) और सत्यापित (Verified) हो।

उदाहरण 1

बैंक की वेबसाइट जैसी दिखने वाली नकली वेबसाइट बनाई गई।

यदि उपयोगकर्ता उस पर अपना Username और Password दर्ज कर देता है, तो वह वास्तविक बैंक नहीं बल्कि फर्जी वेबसाइट होती है।

Authenticity का अभाव है।

उदाहरण 2

किसी शोध पत्र में लेखक का नाम बदल दिया गया।

अब उस दस्तावेज़ की Authenticity समाप्त हो गई।

उदाहरण 3

ईमेल ऐसा प्रतीत होता है कि वह विश्वविद्यालय के कुलपति द्वारा भेजा गया है, जबकि वास्तव में वह साइबर अपराधी द्वारा भेजा गया फ़िशिंग ईमेल है।

सुरक्षा उपाय

- Digital Signature
 - Digital Certificates
 - Public Key Infrastructure (PKI)
 - Email Authentication (SPF, DKIM, DMARC)
 - Biometric Authentication
-

9. Utility (उपयोगिता)

परिभाषा

सूचना ऐसी अवस्था में हो कि उसका वास्तविक उपयोग किया जा सके।

यदि सूचना उपलब्ध है, लेकिन उपयोग योग्य नहीं है, तो उसकी Utility समाप्त मानी जाएगी।

उदाहरण 1

एक फ़ाइल एन्क्रिप्टेड है, लेकिन उसकी डिक्प्रिप्शन Key हमेशा के लिए खो गई।

डेटा मौजूद है, पर पढ़ा नहीं जा सकता।

Utility समाप्त हो गई।

उदाहरण 2

विश्वविद्यालय का डेटाबेस उपलब्ध है, लेकिन पूरी तरह भ्रष्ट (Corrupted) हो चुका है।

डेटा मौजूद है, पर उपयोग नहीं किया जा सकता।

उदाहरण 3

किसी अस्पताल का बैकअप केवल ऐसे पुराने फॉर्मेट में है जिसे वर्तमान सॉफ्टवेयर पढ़ ही नहीं सकता।

डेटा सुरक्षित है, लेकिन चिकित्सकीय उपयोग के योग्य नहीं।

सुरक्षा उपाय

- Standard File Formats
- Data Validation
- Key Management
- Regular Backup Testing
- Data Recovery Testing

10. CIA Triad और Parkerian Hexad की तुलना

विशेषता	CIA Triad	Parkerian Hexad
Confidentiality	✓	✓
Integrity	✓	✓
Availability	✓	✓
Possession/Control	X	✓
Authenticity	X	✓
Utility	X	✓

निष्कर्ष: Parkerian Hexad, CIA Triad का विस्तारित और अधिक व्यावहारिक रूप है।

11. वास्तविक जीवन का समग्र उदाहरण

मान लीजिए किसी विश्वविद्यालय में Ph.D. शोध प्रबंध (Thesis Repository) संग्रहीत है।

- **Confidentiality:** केवल शोधार्थी, मार्गदर्शक और अधिकृत परीक्षक ही शोध प्रबंध देख सकते हैं।
- **Integrity:** शोध दस्तावेज़ में बिना अनुमति कोई संशोधन नहीं किया जा सकता।
- **Availability:** Viva के समय सर्वर हमेशा उपलब्ध रहता है।
- **Possession:** बैकअप ड्राइव सुरक्षित डेटा सेंटर में संरक्षित है और उसका नियंत्रण विश्वविद्यालय के पास है।
- **Authenticity:** शोध प्रबंध पर शोधार्थी एवं मार्गदर्शक के Digital Signatures लगे हैं।
- **Utility:** दस्तावेज़ PDF/A जैसे मानक प्रारूप में सुरक्षित है और भविष्य में भी पढ़ा जा सकता है।

यदि इन छह में से किसी एक तत्व में भी कमी हो, तो पूरी सूचना सुरक्षा प्रभावित हो सकती है।

12. Parkerian Hexad के लाभ

- CIA Triad की सीमाओं को दूर करता है।
- आधुनिक डिजिटल वातावरण के लिए अधिक उपयुक्त है।
- Cloud Computing, Digital Forensics और Cyber Investigation में उपयोगी।
- डिजिटल साक्ष्यों (Digital Evidence) की गुणवत्ता का बेहतर मूल्यांकन करता है।
- Information Governance और Risk Management में सहायक है।

13. Parkerian Hexad की सीमाएँ

- व्यवहार में CIA Triad की तुलना में कम अपनाया जाता है।
- कुछ संगठनों के लिए छहों गुणों का एक साथ मूल्यांकन जटिल हो सकता है।
- आधुनिक Zero Trust Architecture जैसे मॉडलों में अतिरिक्त सुरक्षा तत्वों की भी आवश्यकता होती है।

14. शोध (Research) दृष्टिकोण

Ph.D. स्तर पर Parkerian Hexad का उपयोग निम्न शोध क्षेत्रों में किया जाता है—

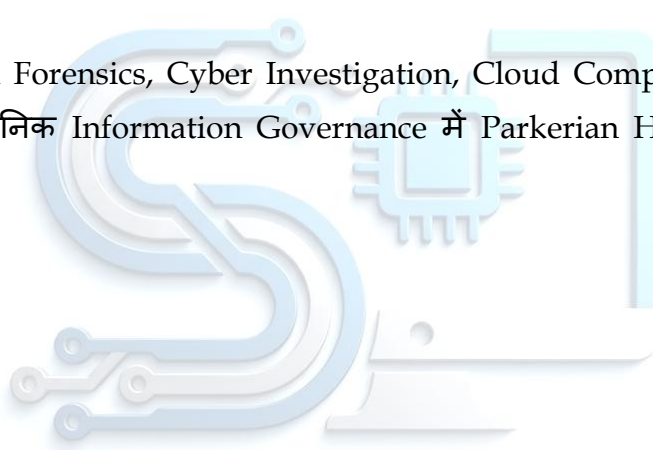
- Digital Evidence Evaluation
- Cloud Security Assessment
- Cyber Forensics

- Digital Trust Framework
- Information Governance
- AI आधारित Information Assurance
- Critical Infrastructure Protection
- Blockchain आधारित Authenticity Verification

अध्याय का निष्कर्ष

Parkerian Hexad सूचना सुरक्षा का एक उन्नत और व्यापक मॉडल है, जो CIA Triad को तीन अतिरिक्त आयाम—Possession/Control, Authenticity और Utility—से समृद्ध करता है। आधुनिक डिजिटल युग में केवल डेटा को गोपनीय, अखंड और उपलब्ध रखना पर्याप्त नहीं है; यह भी आवश्यक है कि डेटा सही नियंत्रण में हो, उसका स्रोत प्रमाणित हो और वह वास्तविक उपयोग के योग्य बना रहे।

यही कारण है कि Digital Forensics, Cyber Investigation, Cloud Computing, Digital Evidence Management तथा आधुनिक Information Governance में Parkerian Hexad का अध्ययन अत्यंत महत्वपूर्ण माना जाता है।



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय 1.8

Security Models (सुरक्षा मॉडल)

1. प्रस्तावना (Introduction)

किसी भी भवन के निर्माण से पहले उसका **नक्शा (Blueprint)** तैयार किया जाता है। इसी प्रकार किसी सुरक्षित सूचना प्रणाली (Secure Information System) के निर्माण से पहले यह निर्धारित करना आवश्यक होता है कि कौन किस जानकारी तक पहुँच सकता है, कौन उसे बदल सकता है, किन परिस्थितियों में पहुँच की अनुमति होगी और सुरक्षा नियमों का पालन कैसे सुनिश्चित किया जाएगा।

इन्हीं नियमों और सिद्धांतों के व्यवस्थित समूह को **Security Model (सुरक्षा मॉडल)** कहा जाता है।

Security Model एक **सैद्धांतिक (Theoretical)** एवं **गणितीय (Mathematical)** ढाँचा है जो यह निर्धारित करता है कि किसी सूचना प्रणाली में **Subjects (उपयोगकर्ता, प्रक्रियाएँ)**, **Objects (डेटा, फ़ाइलें, डेटाबेस)** तथा उनके बीच होने वाली **क्रियाओं (Operations)** को किस प्रकार नियंत्रित किया जाए ताकि सूचना की **Confidentiality (गोपनीयता)**, **Integrity (अखंडता)**, **Availability (उपलब्धता)**, **Authenticity (प्रामाणिकता)** तथा **Accountability (उत्तरदायित्व)** सुरक्षित रहे।

आधुनिक ऑपरेटिंग सिस्टम, डेटाबेस, क्लाउड प्लेटफ़ॉर्म, सैन्य नेटवर्क, बैंकिंग प्रणाली तथा सरकारी सूचना प्रणालियाँ विभिन्न Security Models के सिद्धांतों पर आधारित होती हैं।

2. Security Model क्या है?

Security Model वह औपचारिक (Formal) नियमों का समूह है जो यह निर्धारित करता है कि:

- कौन-सा उपयोगकर्ता किस सूचना तक पहुँच सकता है।
- कौन डेटा पढ़ सकता है।
- कौन डेटा बदल सकता है।
- कौन डेटा मिटा सकता है।
- कौन डेटा साझा कर सकता है।
- किन परिस्थितियों में पहुँच रोकी जाएगी।

सरल शब्दों में:

3. Security Models की आवश्यकता

यदि कोई सुरक्षा मॉडल न हो, तो:

- कर्मचारी किसी भी फ़ाइल को पढ़ सकते हैं।
- छात्र परीक्षा परिणाम बदल सकते हैं।
- बैंक कर्मचारी ग्राहकों का डेटा कॉपी कर सकते हैं।
- हैकर आसानी से संवेदनशील जानकारी तक पहुँच सकते हैं।

इसलिए प्रत्येक संगठन को स्पष्ट सुरक्षा मॉडल अपनाना आवश्यक है।

4. Security Model के मुख्य घटक

(1) Subject

जो कार्य करता है।

उदाहरण:

- User
- Administrator
- Process
- Application

(2) Object

जिस पर कार्य किया जाता है।

उदाहरण:

- File
- Database
- Printer
- Email
- Cloud Storage

(3) Access Rights

- Read
 - Write
 - Execute
 - Delete
 - Modify
 - Copy
-

(4) Security Policy

वे नियम जो बताते हैं कि कौन-सा Subject किस Object पर कौन-सा Operation कर सकता है।

5. प्रमुख Security Models

आधुनिक सूचना सुरक्षा में निम्न मॉडल सर्वाधिक महत्वपूर्ण माने जाते हैं:

1. Bell-LaPadula Model
 2. Biba Integrity Model
 3. Clark-Wilson Model
 4. Brewer-Nash (Chinese Wall) Model
 5. Graham-Denning Model
 6. Harrison-Ruzzo-Ullman (HRU) Model
 7. Lattice-Based Security Model
 8. Information Flow Model
 9. Take-Grant Model
 10. Non-Interference Model
-

6. Bell-LaPadula Model (BLP)

परिचय

यह मॉडल 1973 में David Bell एवं Leonard LaPadula द्वारा विकसित किया गया।

इसका मुख्य उद्देश्य Confidentiality (गोपनीयता) की रक्षा करना है।

यह विशेष रूप से सैन्य एवं सरकारी संस्थाओं में उपयोग किया जाता है।

सुरक्षा स्तर (Security Levels)

- Top Secret
 - Secret
 - Confidential
 - Restricted
 - Unclassified
-

मुख्य नियम

(1) No Read Up

उपयोगकर्ता अपने स्तर से ऊपर की जानकारी नहीं पढ़ सकता।

उदाहरण

यदि किसी अधिकारी का स्तर "Secret" है, तो वह "Top Secret" फ़ाइल नहीं पढ़ सकता।

(2) No Write Down

उच्च स्तर का उपयोगकर्ता निम्न स्तर की फ़ाइल में नहीं लिख सकता।

उदाहरण

यदि Top Secret अधिकारी Confidential फ़ाइल में लिखेगा, तो संवेदनशील जानकारी नीचे के स्तर तक पहुँच सकती है।

इसलिए यह निषिद्ध है।

उपयोग

- सेना
- रक्षा मंत्रालय
- परमाणु अनुसंधान

- खुफिया एजेंसियाँ

7. Biba Integrity Model

उद्देश्य

यह मॉडल Integrity (अखंडता) की सुरक्षा करता है।

मुख्य नियम

No Read Down

उच्च Integrity वाला उपयोगकर्ता निम्न Integrity स्रोत से डेटा नहीं पढ़ेगा।

No Write Up

निम्न Integrity वाला उपयोगकर्ता उच्च Integrity डेटा में परिवर्तन नहीं करेगा।

उदाहरण

विश्वविद्यालय के परिणाम डेटाबेस में—

Student

Result नहीं बदल सकता।

केवल Controller of Examination ही संशोधन कर सकता है।

8. Clark-Wilson Model

यह मॉडल व्यावसायिक (Commercial) संगठनों के लिए विकसित किया गया।

इसका मुख्य उद्देश्य धोखाधड़ी रोकना तथा डेटा की शुद्धता बनाए रखना है।

प्रमुख सिद्धांत

- Well-Formed Transactions
- Separation of Duties
- Auditing
- Certification Rules

उदाहरण

बैंक में:

- कर्मचारी भुगतान तैयार करता है।
- प्रबंधक सत्यापित करता है।
- वित्त अधिकारी स्वीकृत करता है।

एक ही व्यक्ति पूरी प्रक्रिया नहीं कर सकता।

9. Brewer–Nash Model (Chinese Wall Model)

यह मॉडल Conflict of Interest (हितों के टकराव) को रोकने के लिए बनाया गया।

उदाहरण

एक चार्टर्ड अकाउंटेंट यदि कंपनी A का गोपनीय डेटा देख चुका है, तो उसे उसी उद्योग की प्रतिस्पर्धी कंपनी B का गोपनीय डेटा देखने की अनुमति नहीं होगी।

उपयोग

- ऑडिट फर्म
- कानूनी सलाहकार
- वित्तीय संस्थाएँ
- परामर्श कंपनियाँ

10. Graham-Denning Model

यह मॉडल Access Rights के प्रबंधन पर केंद्रित है।

यह बताता है कि:

- उपयोगकर्ता कैसे बनाए जाएँ।
- उपयोगकर्ता कैसे हटाए जाएँ।
- अधिकार कैसे दिए जाएँ।
- अधिकार कैसे वापस लिए जाएँ।

उदाहरण

विद्यालय ERP में:

- नया शिक्षक नियुक्त होने पर नया User Account बनाया जाता है।
- सेवा समाप्त होने पर Account हटाया जाता है।
- अतिरिक्त अधिकार आवश्यकता अनुसार दिए या हटाए जाते हैं।

11. Harrison-Ruzzo-Ullman (HRU) Model

यह मॉडल Access Matrix पर आधारित है।

यह अध्ययन करता है कि किसी सिस्टम में अधिकार (Rights) कैसे फैलते हैं और क्या वे अनियंत्रित रूप से लीक हो सकते हैं।

उदाहरण

यदि एक उपयोगकर्ता दूसरे को अधिकार देता है और वह तीसरे को दे देता है, तो समय के साथ अनधिकृत व्यक्तियों तक भी अधिकार पहुँच सकते हैं।

12. Lattice-Based Security Model

इस मॉडल में प्रत्येक Subject और Object को एक सुरक्षा स्तर दिया जाता है।

पहुँच का निर्णय इन स्तरों के संबंध (Dominance Relation) के आधार पर किया जाता है।

उदाहरण

Top Secret उपयोगकर्ता Secret डेटा देख सकता है, लेकिन Secret उपयोगकर्ता Top Secret डेटा नहीं देख सकता।

13. Information Flow Model

यह मॉडल नियंत्रित करता है कि सूचना किस दिशा में प्रवाहित हो सकती है।

उदाहरण

रक्षा मंत्रालय का गोपनीय डेटा सार्वजनिक वेबसाइट पर प्रकाशित नहीं होना चाहिए।

14. Take-Grant Model

यह मॉडल अध्ययन करता है कि अधिकार (Rights) एक उपयोगकर्ता से दूसरे तक कैसे स्थानांतरित होते हैं।

उदाहरण

यदि विभागाध्यक्ष किसी शिक्षक को रिपोर्ट देखने का अधिकार देता है, तो क्या वह शिक्षक वही अधिकार किसी अन्य कर्मचारी को दे सकता है? इस प्रश्न का विश्लेषण Take-Grant Model करता है।

15. Non-Interference Model

इस मॉडल का उद्देश्य यह सुनिश्चित करना है कि उच्च सुरक्षा स्तर की गतिविधियाँ निम्न सुरक्षा स्तर के उपयोगकर्ताओं को प्रभावित न करें।

उदाहरण

रक्षा प्रणाली में चल रही गुप्त प्रक्रिया का कोई प्रभाव सार्वजनिक उपयोगकर्ता के आउटपुट पर नहीं दिखना चाहिए।

16. वास्तविक केस स्टडी

केस 1: बैंक

- Bell-LaPadula: ग्राहक डेटा की गोपनीयता।
- Clark-Wilson: लेन-देन की शुद्धता।
- Graham-Denning: कर्मचारियों के अधिकारों का प्रबंधन।

केस 2: विश्वविद्यालय ERP

- Biba: परीक्षा परिणाम की अखंडता।
- Graham-Denning: शिक्षक एवं छात्र खातों का प्रबंधन।
- HRU: Role-Based Access के विस्तार का नियंत्रण।

केस 3: रक्षा मंत्रालय

- Bell-LaPadula: Top Secret दस्तावेज़।
- Lattice Model: सुरक्षा स्तरों का नियंत्रण।
- Information Flow Model: गोपनीय जानकारी का नियंत्रित प्रवाह।

17. सभी Security Models की तुलना

मॉडल	मुख्य उद्देश्य	प्रमुख उपयोग
Bell-LaPadula	Confidentiality	रक्षा, सेना
Biba	Integrity	शिक्षा, बैंकिंग
Clark-Wilson	व्यावसायिक अखंडता	बैंक, ERP
Brewer-Nash	Conflict of Interest	ऑडिट, वित्त
Graham-Denning	Access Management	ERP, IAM
HRU	अधिकारों का विश्लेषण	Operating Systems
Lattice	सुरक्षा स्तर	सैन्य प्रणाली
Information Flow	डेटा प्रवाह नियंत्रण	सरकारी नेटवर्क
Take-Grant	अधिकार स्थानांतरण	एक्सेस नियंत्रण
Non-Interference	सूचना पृथक्करण	उच्च सुरक्षा प्रणालियाँ

18. आधुनिक परिप्रेक्ष्य

आज के Cloud Computing, AI, IoT और Zero Trust वातावरण में कोई एक Security Model सभी समस्याओं का समाधान नहीं करता। इसलिए आधुनिक संगठन अनेक मॉडलों के सिद्धांतों का संयोजन अपनाते हैं।

उदाहरण के लिए:

- Bell-LaPadula → गोपनीयता
- Biba → डेटा की अखंडता
- Clark-Wilson → सुरक्षित व्यावसायिक लेन-देन
- Graham-Denning → उपयोगकर्ता एवं अधिकार प्रबंधन
- Zero Trust Architecture → प्रत्येक अनुरोध का सत्यापन
- Role-Based Access Control (RBAC) और Attribute-Based Access Control (ABAC) → आधुनिक अभिगम नियंत्रण

19. शोध (Research) दृष्टिकोण

Ph.D. स्तर पर Security Models का अध्ययन निम्न विषयों से जुड़ा है:

- Formal Verification of Security Policies
- AI आधारित Access Control
- Cloud Security Models
- Zero Trust Security Architecture
- Privacy-Preserving Data Sharing
- Blockchain आधारित Access Control
- Digital Forensics में Policy Enforcement
- Quantum Computing और Future Security Models

अध्याय का निष्कर्ष

Security Models सूचना सुरक्षा के औपचारिक आधार हैं। वे केवल तकनीकी नियम नहीं, बल्कि ऐसे सिद्धांत हैं जो यह निर्धारित करते हैं कि सूचना किस प्रकार सुरक्षित रहेगी, कौन उसे देख सकेगा, कौन संशोधित कर सकेगा और किन परिस्थितियों में पहुँच नियंत्रित होगी।

व्यावहारिक रूप से कोई एक मॉडल सभी आवश्यकताओं को पूरा नहीं करता। इसलिए आधुनिक साइबर सुरक्षा में विभिन्न मॉडलों के सिद्धांतों का संयोजन किया जाता है, जिससे Confidentiality, Integrity, Availability, Authenticity, Accountability तथा Governance का संतुलित संरक्षण सुनिश्चित किया जा सके।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय 1.9

Data Classification (डेटा वर्गीकरण)

1. प्रस्तावना (Introduction)

डिजिटल युग में Data (डेटा) किसी भी व्यक्ति, संगठन, उद्योग, विश्वविद्यालय अथवा राष्ट्र की सबसे मूल्यवान परिसंपत्ति (Valuable Asset) बन चुका है। बैंकिंग, स्वास्थ्य, शिक्षा, ई-गवर्नेंस, रक्षा, अनुसंधान, उद्योग तथा डिजिटल सेवाओं का संपूर्ण संचालन डेटा पर आधारित है। यदि सभी प्रकार के डेटा को समान स्तर की सुरक्षा दी जाए, तो सुरक्षा प्रबंधन अत्यधिक महंगा, जटिल और अप्रभावी हो जाएगा। दूसरी ओर, यदि अत्यधिक संवेदनशील जानकारी को सामान्य डेटा की तरह सुरक्षित रखा जाए, तो गोपनीय सूचनाओं के लीक होने, आर्थिक हानि, कानूनी विवाद तथा राष्ट्रीय सुरक्षा पर गंभीर प्रभाव पड़ सकता है।

इसी समस्या के समाधान के लिए Data Classification (डेटा वर्गीकरण) की अवधारणा विकसित की गई।

Data Classification वह व्यवस्थित प्रक्रिया है जिसके माध्यम से किसी डेटा को उसकी संवेदनशीलता (Sensitivity), गोपनीयता (Confidentiality), व्यावसायिक महत्ता (Business Value), कानूनी आवश्यकताओं (Legal Requirements) तथा संभावित जोखिम (Risk) के आधार पर विभिन्न श्रेणियों में विभाजित किया जाता है।

सरल

शब्दों

में:

"डेटा वर्गीकरण वह प्रक्रिया है जिसमें प्रत्येक डेटा को उसकी महत्ता और संवेदनशीलता के अनुसार अलग-अलग सुरक्षा स्तर प्रदान किया जाता है।"

2. Data Classification की आवश्यकता

किसी संगठन में लाखों फ़ाइलें, ईमेल, दस्तावेज़, डेटाबेस रिकॉर्ड, चित्र, वीडियो और बैकअप मौजूद हो सकते हैं। यदि इन सभी पर समान सुरक्षा नीति लागू कर दी जाए, तो संसाधनों का दुरुपयोग होगा।

डेटा वर्गीकरण निम्न कारणों से आवश्यक है:

- संवेदनशील जानकारी की सुरक्षा।
- अनधिकृत पहुँच (Unauthorized Access) को रोकना।
- कानूनी एवं नियामकीय अनुपालन (Compliance) सुनिश्चित करना।

- सुरक्षा लागत का अनुकूलन।
- डेटा साझा करने के नियम निर्धारित करना।
- जोखिम प्रबंधन (Risk Management) को प्रभावी बनाना।
- Incident Response एवं Digital Forensics को सरल बनाना।

3. Data Classification के उद्देश्य

- डेटा की गोपनीयता बनाए रखना।
- आवश्यकतानुसार डेटा की उपलब्धता सुनिश्चित करना।
- डेटा की अखंडता (Integrity) सुरक्षित रखना।
- सुरक्षा नियंत्रणों का सही चयन करना।
- डेटा के जीवनचक्र (Data Lifecycle) का प्रभावी प्रबंधन करना।
- व्यवसाय की निरंतरता (Business Continuity) सुनिश्चित करना।

4. Data Classification के आधार

डेटा को निम्न मानदंडों के आधार पर वर्गीकृत किया जाता है:

1. Sensitivity (संवेदनशीलता)
2. Business Value (व्यावसायिक महत्ता)
3. Legal & Regulatory Requirements (कानूनी आवश्यकताएँ)
4. Confidentiality Requirements (गोपनीयता स्तर)
5. Impact of Data Loss (डेटा हानि का प्रभाव)
6. Data Owner की आवश्यकताएँ
7. Retention Period (डेटा संरक्षण अवधि)

5. Data Classification के प्रमुख स्तर

(1) Public Data (सार्वजनिक डेटा)

परिभाषा

ऐसा डेटा जिसे किसी भी व्यक्ति के साथ साझा किया जा सकता है और जिसके सार्वजनिक होने से कोई सुरक्षा जोखिम उत्पन्न नहीं होता।

उदाहरण

- विश्वविद्यालय की वेबसाइट
- सार्वजनिक अधिसूचना
- समाचार विज्ञप्ति
- विद्यालय का टाइम-टेबल
- सरकारी योजनाओं की जानकारी
- कंपनी का प्रचार-पत्र (Brochure)

सुरक्षा स्तर

- न्यूनतम सुरक्षा
- सामान्य Backup
- Website Security पर्याप्त

(2) Internal Data (आंतरिक डेटा)

परिभाषा

ऐसा डेटा जो केवल संगठन के कर्मचारियों या अधिकृत व्यक्तियों के लिए हो।

उदाहरण

- कर्मचारियों की आंतरिक ईमेल
- कार्यालय की बैठक के मिनट्स
- परियोजना प्रगति रिपोर्ट
- विभागीय कार्ययोजना
- विद्यालय का स्टाफ़ ड्यूटी चार्ट

सुरक्षा उपाय

- Login आधारित पहुँच
- Role-Based Access Control (RBAC)
- VPN (यदि दूरस्थ पहुँच हो)

(3) Confidential Data (गोपनीय डेटा)

परिभाषा

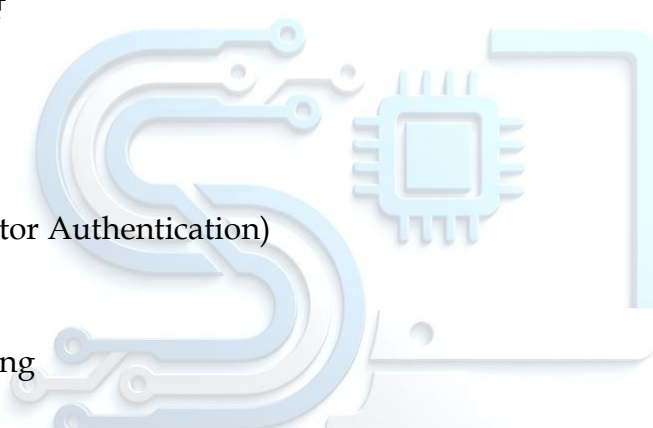
ऐसा डेटा जिसके लीक होने पर संगठन को आर्थिक, कानूनी या प्रतिष्ठागत नुकसान हो सकता है।

उदाहरण

- बैंक ग्राहकों का डेटा
- कर्मचारियों का वेतन विवरण
- विद्यार्थियों के परीक्षा परिणाम
- शोध प्रबंध (Thesis) का अप्रकाशित मसौदा
- अनुबंध (Contracts)
- व्यापारिक योजनाएँ

सुरक्षा उपाय

- Encryption
- MFA (Multi-Factor Authentication)
- Audit Logs
- नियमित Backup
- Access Monitoring



(4) Secret Data (अत्यंत गोपनीय डेटा)

परिभाषा

ऐसा डेटा जिसके लीक होने से संगठन या सरकार को गंभीर नुकसान हो सकता है।

उदाहरण

- रक्षा परियोजनाओं की तकनीकी जानकारी
- संवेदनशील सरकारी दस्तावेज़
- परमाणु अनुसंधान से संबंधित रिपोर्ट
- खुफिया एजेंसियों की कार्ययोजना

सुरक्षा उपाय

- End-to-End Encryption
- Air-Gapped Systems

- Hardware Security Modules (HSM)
- Strict Need-to-Know Policy
- Continuous Monitoring

(5) Top Secret Data (सर्वोच्च गोपनीय डेटा)

परिभाषा

ऐसा डेटा जिसके लीक होने से राष्ट्रीय सुरक्षा, रक्षा व्यवस्था या अंतरराष्ट्रीय संबंधों पर अत्यंत गंभीर प्रभाव पड़ सकता है।

उदाहरण

- युद्धकालीन सैन्य रणनीति
- मिसाइल नियंत्रण प्रणाली का डेटा
- राष्ट्रीय सुरक्षा एजेंसियों की गुप्त योजनाएँ
- उच्च स्तरीय खुफिया जानकारी

सुरक्षा उपाय

- अत्यधिक सीमित पहुँच
- Multi-Person Authorization
- Offline Secure Storage
- Biometric एवं Smart Card आधारित Authentication
- Continuous Security Audit

6. Data Classification का सारांश

वर्ग	संवेदनशीलता	उदाहरण	सुरक्षा स्तर
Public	बहुत कम	वेबसाइट, प्रेस विज्ञप्ति	न्यूनतम
Internal	कम	कार्यालय ईमेल	मध्यम
Confidential	अधिक	बैंक डेटा, परीक्षा परिणाम	उच्च
Secret	बहुत अधिक	रक्षा दस्तावेज़	अत्यधिक उच्च
Top Secret	सर्वोच्च	सैन्य रणनीति	सर्वोच्च सुरक्षा

7. Data Classification का वास्तविक उदाहरण

केस स्टडी: विश्वविद्यालय ERP

एक विश्वविद्यालय की ERP प्रणाली में निम्न डेटा उपलब्ध है:

डेटा	वर्गीकरण
विश्वविद्यालय की वेबसाइट	Public
स्टाफ़ मीटिंग नोट्स	Internal
विद्यार्थियों के अंक	Confidential
प्रश्नपत्र (परीक्षा से पूर्व)	Secret
परीक्षा प्रश्नपत्र निर्माण प्रणाली की Master Encryption Keys	Top Secret

यदि प्रश्नपत्र परीक्षा से पहले सार्वजनिक हो जाए, तो पूरी परीक्षा प्रक्रिया प्रभावित हो सकती है।

8. बैंक का उदाहरण

डेटा	वर्गीकरण
बैंक की शाखाओं की सूची	Public
कर्मचारियों की आंतरिक रिपोर्ट	Internal
ग्राहक खाते का विवरण	Confidential
Fraud Detection Algorithm	Secret
Master Cryptographic Keys	Top Secret

9. अस्पताल का उदाहरण

डेटा	वर्गीकरण
अस्पताल का पता	Public
कर्मचारियों की ड्यूटी सूची	Internal
मरीज की मेडिकल रिपोर्ट	Confidential
अनुसंधान परीक्षण (Clinical Trial) डेटा	Secret

डेटा	वर्गीकरण
राष्ट्रीय स्वास्थ्य सुरक्षा से संबंधित विशेष डेटा	Top Secret (यदि लागू हो)

10. Data Labeling (डेटा लेबलिंग)

डेटा वर्गीकरण तभी प्रभावी होता है जब प्रत्येक दस्तावेज़ या फ़ाइल पर उसका सुरक्षा स्तर स्पष्ट रूप से अंकित हो।

उदाहरण:

- PUBLIC
- INTERNAL
- CONFIDENTIAL
- SECRET
- TOP SECRET

डिजिटल दस्तावेज़ों में Metadata Tags, Watermarks और Classification Labels का उपयोग किया जाता है।

11. Data Handling (डेटा प्रबंधन)

प्रत्येक वर्ग के डेटा के लिए अलग नियम होने चाहिए।

Public

- ईमेल द्वारा साझा किया जा सकता है।
- वेबसाइट पर प्रकाशित किया जा सकता है।

Internal

- केवल कर्मचारियों के साथ साझा।
- सार्वजनिक क्लाउड पर बिना अनुमति अपलोड नहीं।

Confidential

- Encryption आवश्यक।
- केवल अधिकृत व्यक्तियों को पहुँच।

Secret

- सुरक्षित नेटवर्क।
- Need-to-Know आधार पर पहुँच।

Top Secret

- Air-Gapped Systems
- Physical Security
- Continuous Monitoring
- Multi-Person Approval

12. Data Retention (डेटा संरक्षण अवधि)

हर डेटा को अनिश्चितकाल तक सुरक्षित रखना उचित नहीं होता।

उदाहरण:

- वित्तीय रिकॉर्ड – निर्धारित कानूनी अवधि तक।
- परीक्षा परिणाम – विश्वविद्यालय नीति के अनुसार।
- CCTV फुटेज – सीमित अवधि तक।
- लॉग फ़ाइलें – सुरक्षा नीति के अनुसार।

Retention Policy संगठन के Compliance एवं कानूनी नियमों पर आधारित होती है।

13. Data Disposal (डेटा का सुरक्षित निस्तारण)

डेटा हटाने समय केवल Delete करना पर्याप्त नहीं है।

सुरक्षित निस्तारण के उपाय:

- Secure Erase
- Cryptographic Erasure
- Disk Wiping
- Physical Destruction (हार्ड डिस्क श्रेडिंग)
- Media Sanitization

14. Data Classification और Cyber Security

डेटा वर्गीकरण निम्न सुरक्षा उपायों के चयन में सहायता करता है:

- Access Control
 - Encryption
 - Backup Strategy
 - Incident Response
 - Digital Forensics
 - Data Loss Prevention (DLP)
 - Cloud Security
 - Identity and Access Management (IAM)
-

15. सामान्य त्रुटियाँ

- सभी डेटा को Public मान लेना।
 - अत्यधिक वर्गीकरण (Overclassification) करना।
 - वर्गीकरण के बाद नियमित समीक्षा न करना।
 - कर्मचारियों को प्रशिक्षण न देना।
 - लेबलिंग न करना।
 - वर्गीकरण नीति का दस्तावेजीकरण न करना।
-

16. शोध (Research) दृष्टिकोण

Ph.D. स्तर पर Data Classification निम्न शोध क्षेत्रों से जुड़ा हुआ है:

- AI आधारित Automatic Data Classification
 - Machine Learning द्वारा Sensitive Data Detection
 - Cloud Data Classification Framework
 - Privacy-Preserving Data Sharing
 - Data Loss Prevention (DLP)
 - Zero Trust आधारित Data Protection
 - Digital Rights Management (DRM)
 - Information Lifecycle Governance
 - Data Sovereignty एवं Cross-Border Data Transfer
-

अध्याय का निष्कर्ष

Data Classification आधुनिक Information Security का एक अनिवार्य घटक है। यह केवल डेटा को श्रेणियों में बाँटने की प्रक्रिया नहीं, बल्कि सुरक्षा नीति, जोखिम प्रबंधन, कानूनी अनुपालन और डिजिटल फॉरेंसिक का आधार है।

एक प्रभावी Data Classification Framework संगठन को यह सुनिश्चित करने में सहायता करता है कि प्रत्येक सूचना को उसकी वास्तविक संवेदनशीलता के अनुरूप सुरक्षा प्रदान की जाए। इससे संसाधनों का बेहतर उपयोग, सुरक्षा जोखिमों में कमी, नियामकीय अनुपालन तथा डिजिटल परिसंपत्तियों का प्रभावी संरक्षण संभव होता है।

मुख्य

संदेश:

"सभी डेटा समान नहीं होते, इसलिए सभी डेटा को समान सुरक्षा देना भी उचित नहीं है। सही डेटा को सही स्तर की सुरक्षा देना ही प्रभावी साइबर सुरक्षा की पहचान है।"



अध्याय 1.10

Risk Terminologies

(जोखिम संबंधी पारिभाषिक शब्दावली)

1. प्रस्तावना (Introduction)

आधुनिक डिजिटल युग में लगभग प्रत्येक संगठन—चाहे वह बैंक हो, विश्वविद्यालय, अस्पताल, उद्योग, सरकारी विभाग या रक्षा संगठन—अपनी अधिकांश सेवाएँ सूचना प्रौद्योगिकी (Information Technology) पर निर्भर होकर संचालित करता है। जैसे-जैसे डिजिटल सेवाओं का विस्तार हुआ है, वैसे-वैसे साइबर जोखिम (Cyber Risks) भी बढ़े हैं।

कोई भी प्रणाली पूर्णतः सुरक्षित (100% Secure) नहीं होती। प्रत्येक प्रणाली में कुछ न कुछ कमजोरियाँ (Vulnerabilities) होती हैं, जिनका लाभ उठाकर हमलावर (Threat Actor) आर्थिक, तकनीकी, कानूनी या प्रतिष्ठागत नुकसान पहुँचा सकते हैं। इन संभावित खतरों को समझने, उनका मूल्यांकन करने तथा उन्हें नियंत्रित करने के लिए Risk Management की आवश्यकता होती है।

Risk Management को समझने के लिए सबसे पहले Risk Terminologies (जोखिम संबंधी पारिभाषिक शब्दावली) का गहन अध्ययन आवश्यक है। यही शब्दावली ISO/IEC 27005, NIST Risk Management Framework (RMF), COBIT, CIS Controls तथा अन्य अंतरराष्ट्रीय सुरक्षा मानकों का आधार है।

2. Risk (जोखिम)

परिभाषा

Risk वह संभावना (Likelihood) है कि कोई Threat किसी Vulnerability का लाभ उठाकर किसी Asset को नुकसान पहुँचाए, जिससे संगठन पर प्रतिकूल प्रभाव (Impact) पड़े।

सरल शब्दों में

"Risk = किसी खतरे के घटित होने की संभावना × उससे होने वाला प्रभाव।"

इसे सामान्य रूप से इस प्रकार भी समझाया जाता है:

$$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$$

उदाहरण

एक बैंक के सर्वर में पुराना (Outdated) ऑपरेटिंग सिस्टम चल रहा है।

- **Asset:** बैंक का सर्वर
- **Threat:** Hacker
- **Vulnerability:** पुराना OS
- **Impact:** ग्राहक डेटा चोरी, आर्थिक नुकसान

यह एक उच्च (High) Risk की स्थिति है।

3. Asset (परिसंपत्ति)

परिभाषा

Asset वह संसाधन है जिसका संगठन के लिए आर्थिक, तकनीकी, कानूनी या रणनीतिक मूल्य हो।

Asset के प्रकार

(क) Physical Assets

- Server
- Laptop
- Mobile
- Router
- Hard Disk

(ख) Information Assets

- Customer Database
- Student Records
- Medical Reports
- Source Code

- Research Papers
-

(ग) Human Assets

- कर्मचारी
 - Administrator
 - Security Analyst
-

(घ) Intangible Assets

- Brand Value
 - Reputation
 - Intellectual Property
 - Patents
-

उदाहरण

विश्वविद्यालय का Ph.D. Thesis Repository एक अत्यंत महत्वपूर्ण Information Asset है।

4. Threat (खतरा)

परिभाषा

Threat वह संभावित घटना, व्यक्ति या परिस्थिति है जो किसी Asset को नुकसान पहुँचा सकती है।

Threat के प्रकार

प्राकृतिक (Natural Threats)

- भूकंप
 - बाढ़
 - आग
 - बिजली गिरना
-

मानवीय (Human Threats)

- Hacker
 - Insider
 - Terrorist
 - Cyber Criminal
-

तकनीकी (Technical Threats)

- Malware
 - Ransomware
 - Virus
 - Worm
 - DDoS Attack
-

उदाहरण

यदि किसी कर्मचारी को Phishing ईमेल भेजकर उसका पासवर्ड चुरा लिया जाए, तो Phishing एक Threat है।

5. Threat Actor (खतरा उत्पन्न करने वाला)

Threat Actor वह व्यक्ति, समूह या संस्था है जो जानबूझकर या अनजाने में सुरक्षा को प्रभावित करती है।

उदाहरण

- Script Kiddie
 - Cyber Criminal
 - Nation-State
 - Hacktivist
 - Insider
 - Competitor
-

6. Vulnerability (कमजोरी)

परिभाषा

Vulnerability वह कमजोरी है जिसका लाभ उठाकर हमला किया जा सकता है।

उदाहरण

- Default Password
- Open Port
- SQL Injection
- Weak Encryption
- Unpatched Software
- Misconfiguration

वास्तविक उदाहरण

विद्यालय ERP का Password:

admin123

यह एक गंभीर Vulnerability है।

7. Exploit

Exploit वह तकनीक, प्रोग्राम या कोड है जो किसी Vulnerability का लाभ उठाकर हमला करता है।

उदाहरण

यदि वेबसाइट SQL Injection के प्रति असुरक्षित है और हमलावर उसी कमजोरी का उपयोग कर डेटाबेस पढ़ लेता है, तो प्रयुक्त SQL Injection तकनीक Exploit कहलाती है।

8. Attack (आक्रमण)

Attack वह वास्तविक प्रयास है जिसके माध्यम से Threat Actor किसी Vulnerability का उपयोग करके Asset को प्रभावित करता है।

उदाहरण

- Phishing Attack
 - Malware Attack
 - DDoS Attack
 - Password Attack
 - Insider Attack
-

9. Attack Vector (हमले का माध्यम)

Attack Vector वह मार्ग या तरीका है जिसके माध्यम से हमलावर सिस्टम तक पहुँचता है।

उदाहरण

- Email
 - USB Drive
 - Wi-Fi
 - Website
 - Mobile App
 - Cloud API
-

10. Attack Surface

Attack Surface उन सभी संभावित प्रवेश बिंदुओं का समूह है जहाँ से हमला किया जा सकता है।

उदाहरण

एक विश्वविद्यालय ERP में:

- Website
- Mobile App
- Database Server
- Admin Panel
- API
- Wi-Fi
- Email Server

इन सभी का संयुक्त समूह Attack Surface कहलाता है।

11. Impact (प्रभाव)

Impact वह वास्तविक क्षति है जो किसी सफल साइबर घटना के बाद होती है।

प्रकार

- आर्थिक नुकसान
- प्रतिष्ठा की हानि
- कानूनी दंड
- सेवा बाधित होना
- राष्ट्रीय सुरक्षा पर प्रभाव

उदाहरण

यदि बैंक का ग्राहक डेटा लीक हो जाए:

- ग्राहक विश्वास कम होगा।
- आर्थिक दंड लग सकता है।
- कानूनी कार्रवाई हो सकती है।

12. Likelihood (संभाव्यता)

Likelihood किसी घटना के घटित होने की संभावना है।

स्तर

- Very Low
- Low
- Medium
- High
- Very High

उदाहरण

यदि कोई Server वर्षों से अपडेट नहीं हुआ है, तो उस पर साइबर हमले की संभावना (Likelihood) अधिक होगी।

13. Risk Appetite (जोखिम स्वीकार्यता)

Risk Appetite वह सीमा है जिसके भीतर संगठन जोखिम स्वीकार करने को तैयार होता है।

उदाहरण

एक स्टार्टअप सीमित बजट के कारण कुछ मध्यम जोखिम स्वीकार कर सकता है, जबकि रक्षा संगठन लगभग शून्य जोखिम नीति अपनाता है।

14. Risk Tolerance (जोखिम सहनशीलता)

यह उस सीमा को दर्शाता है जिसके भीतर जोखिम होने पर भी संगठन अपना कार्य सामान्य रूप से जारी रख सकता है।

15. Risk Assessment (जोखिम मूल्यांकन)

Risk Assessment वह प्रक्रिया है जिसमें जोखिमों की पहचान, विश्लेषण और प्राथमिकता तय की जाती है।

चरण

1. Asset Identification
 2. Threat Identification
 3. Vulnerability Analysis
 4. Risk Calculation
 5. Risk Prioritization
-

उदाहरण

एक अस्पताल पहले मरीजों के रिकॉर्ड को सबसे महत्वपूर्ण Asset मानता है, फिर उन पर संभावित Threats और Vulnerabilities का विश्लेषण करता है।

16. Risk Analysis (जोखिम विश्लेषण)

जोखिम का विस्तृत अध्ययन दो प्रमुख प्रकारों में किया जाता है:

Qualitative Risk Analysis

- Low
- Medium
- High

Quantitative Risk Analysis

संख्यात्मक (Monetary) आधार पर जोखिम का मूल्यांकन।

17. Risk Matrix

Likelihood	Low Impact	Medium Impact	High Impact
Low	Low Risk	Low Risk	Medium Risk
Medium	Low Risk	Medium Risk	High Risk
High	Medium Risk	High Risk	Critical Risk

18. Risk Treatment (जोखिम उपचार)

जोखिमों से निपटने के चार प्रमुख तरीके:

(1) Risk Avoidance

जोखिम वाले कार्य को ही न करना।

उदाहरण: असुरक्षित सॉफ्टवेयर का उपयोग बंद करना।

(2) Risk Mitigation

सुरक्षा उपाय अपनाकर जोखिम कम करना।

उदाहरण: Firewall, MFA, Encryption लागू करना।

(3) Risk Transfer

जोखिम किसी अन्य पक्ष को स्थानांतरित करना।

उदाहरण: Cyber Insurance लेना।

(4) Risk Acceptance

जोखिम को स्वीकार करना।

उदाहरण: कम प्रभाव वाले जोखिम पर अतिरिक्त लागत न करना।

19. Residual Risk

सभी सुरक्षा उपाय लागू करने के बाद भी जो जोखिम शेष रह जाता है, उसे Residual Risk कहते हैं।

उदाहरण

Firewall, Antivirus और MFA लगाने के बाद भी Zero-Day Attack का जोखिम बना रह सकता है।

20. Risk Register

Risk Register वह दस्तावेज़ है जिसमें सभी जोखिमों का विवरण रखा जाता है।

इसमें सामान्यतः निम्न जानकारी होती है:

- Risk ID
- Description
- Asset
- Threat
- Vulnerability
- Likelihood
- Impact
- Risk Level
- Owner
- Mitigation Plan
- Status

21. वास्तविक केस स्टडी

केस स्टडी: विश्वविद्यालय ERP

Asset: Student Database

Threat: Hacker

Vulnerability: Weak Password

Attack Vector: Login Page

Attack: Brute Force

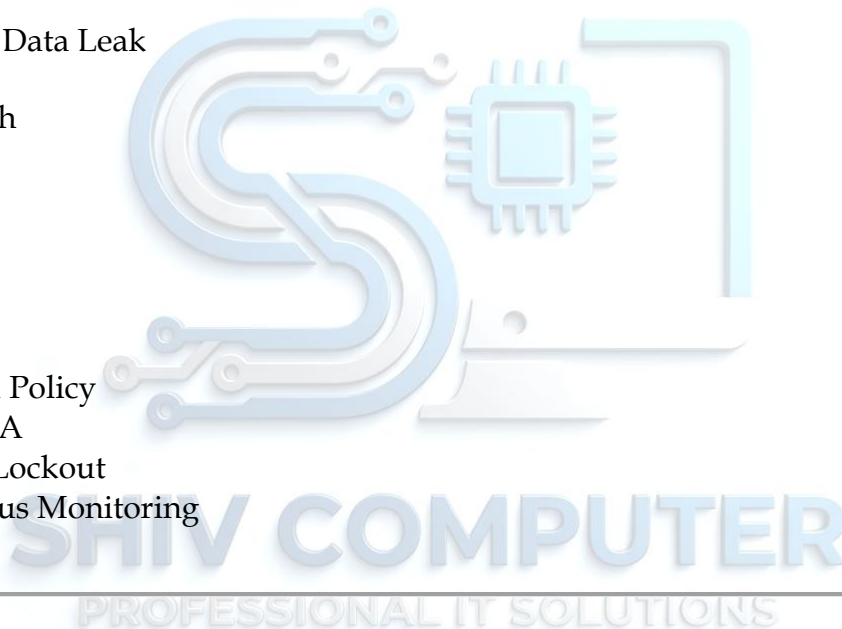
Impact: Student Data Leak

Likelihood: High

Risk: Critical

Mitigation:

- MFA
- Password Policy
- CAPTCHA
- Account Lockout
- Continuous Monitoring



केस स्टडी: अस्पताल

Asset: Electronic Health Records (EHR)

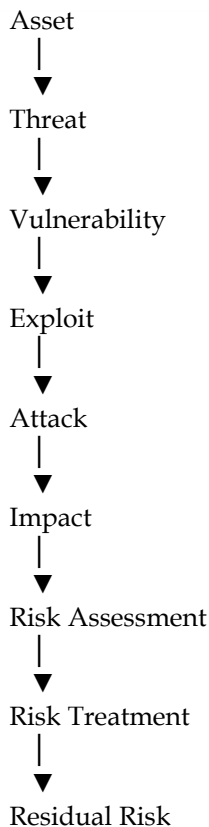
Threat: Ransomware

Impact: आपातकालीन सेवाएँ बाधित

Risk Treatment:

- Offline Backup
- Network Segmentation
- Incident Response Plan
- नियमित Patch Management

22. Risk Terminologies का परस्पर संबंध



23. आधुनिक परिप्रेक्ष्य

आज के Cloud Computing, AI, IoT और Digital Forensics वातावरण में जोखिम प्रबंधन निरंतर (Continuous Risk Management) प्रक्रिया बन चुका है। आधुनिक संगठन AI आधारित Threat Intelligence, Continuous Vulnerability Management, Security Information and Event Management (SIEM), Extended Detection and Response (XDR) तथा Zero Trust Architecture का उपयोग करके जोखिमों की पहचान और नियंत्रण करते हैं।

24. शोध (Research) दृष्टिकोण

Ph.D. स्तर पर Risk Terminologies निम्न शोध क्षेत्रों से संबंधित हैं:

- Quantitative Cyber Risk Modeling
- FAIR (Factor Analysis of Information Risk)
- AI आधारित Risk Prediction
- Threat Intelligence Frameworks
- Cyber Risk Analytics
- Digital Forensics Risk Assessment

- Critical Infrastructure Risk Management
- Enterprise Risk Governance
- Cyber Resilience Metrics

अध्याय का निष्कर्ष

Risk Terminologies साइबर सुरक्षा एवं डिजिटल फॉरेंसिक की आधारभूत भाषा हैं। किसी भी प्रभावी सुरक्षा कार्यक्रम की शुरुआत Asset, Threat, Vulnerability, Attack, Impact और Risk की सही पहचान से होती है। जब इन अवधारणाओं को व्यवस्थित रूप से समझकर Risk Assessment, Risk Treatment और Continuous Monitoring लागू किए जाते हैं, तब संगठन अपनी डिजिटल परिसंपत्तियों की प्रभावी सुरक्षा कर सकता है।

मुख्य

संदेश:

"जो संगठन अपने जोखिमों को पहचानता, मापता और नियंत्रित करता है, वही वास्तविक अर्थों में सुरक्षित संगठन कहलाता है।"



अध्याय 1.11

Threat Landscape (साइबर खतरा परिदृश्य)

(आधुनिक साइबर खतरों का व्यापक अध्ययन, वर्गीकरण, उदाहरण एवं केस स्टडी सहित)

1. प्रस्तावना (Introduction)

21वीं शताब्दी में सूचना प्रौद्योगिकी (Information Technology) मानव जीवन के प्रत्येक क्षेत्र—बैंकिंग, स्वास्थ्य, शिक्षा, रक्षा, उद्योग, परिवहन, ई-गवर्नेंस, अनुसंधान तथा संचार—का अभिन्न अंग बन चुकी है। इंटरनेट, क्लाउड कंप्यूटिंग, मोबाइल डिवाइस, इंटरनेट ऑफ थिंग्स (IoT), कृत्रिम बुद्धिमत्ता (AI) तथा डिजिटल भुगतान प्रणालियों के तीव्र विकास ने जहाँ कार्यक्षमता और सुविधा में अभूतपूर्व वृद्धि की है, वहीं साइबर खतरों (Cyber Threats) की संख्या, जटिलता और प्रभाव भी तेजी से बढ़े हैं।

इन सभी संभावित, सक्रिय एवं उभरते हुए साइबर खतरों के समग्र परिदृश्य (Overall Environment) को Threat Landscape (खतरा परिदृश्य) कहा जाता है।

Threat Landscape केवल वर्तमान खतरों का विवरण नहीं है, बल्कि यह यह भी दर्शाता है कि कौन हमला कर सकता है, क्यों कर सकता है, किस माध्यम से कर सकता है, किस प्रकार की प्रणालियाँ लक्ष्य बन सकती हैं, संभावित प्रभाव क्या होंगे तथा भविष्य में कौन-से नए खतरे उभर सकते हैं।

सरल

शब्दों

में:

"Threat Landscape किसी संगठन, उद्योग या राष्ट्र के सामने उपस्थित सभी वर्तमान, संभावित और भविष्य के साइबर खतरों का समग्र विश्लेषण है।"

2. Threat Landscape की आवश्यकता

यदि किसी संगठन को यह ज्ञात ही न हो कि उसके सामने किस प्रकार के खतरे हैं, तो वह उचित सुरक्षा रणनीति नहीं बना सकता।

Threat Landscape का अध्ययन निम्न कारणों से आवश्यक है:

- संभावित खतरों की पहचान।
- सुरक्षा निवेश (Security Investment) की प्राथमिकता तय करना।
- Risk Assessment को सटीक बनाना।
- Incident Response की तैयारी।
- Cyber Resilience में वृद्धि।
- Threat Intelligence का प्रभावी उपयोग।
- Zero Trust Security Architecture को लागू करना।

3. Threat Landscape के प्रमुख घटक

एक Threat Landscape सामान्यतः निम्न घटकों से मिलकर बनता है:

1. Assets (परिसंपत्तियाँ)
2. Threat Actors (हमलावर)
3. Threat Vectors (हमले के माध्यम)
4. Vulnerabilities (कमज़ोरियाँ)
5. Attack Techniques
6. Target Systems
7. Business Impact
8. Emerging Threats

4. Threat Actors (खतरा उत्पन्न करने वाले)

(क) Cyber Criminals

इनका मुख्य उद्देश्य आर्थिक लाभ प्राप्त करना होता है।

उदाहरण

- Ransomware गिरोह
- बैंकिंग ट्रोजन संचालक
- ऑनलाइन धोखाधड़ी करने वाले

(ख) Nation-State Attackers

किसी राष्ट्र द्वारा समर्थित या प्रायोजित समूह।

उद्देश्य

- साइबर जासूसी
- रक्षा जानकारी प्राप्त करना
- महत्वपूर्ण अवसंरचना (Critical Infrastructure) को प्रभावित करना

उदाहरण

- रक्षा नेटवर्क पर हमले
- ऊर्जा संयंत्रों की निगरानी
- उपग्रह संचार पर साइबर गतिविधियाँ

(ग) Insider Threat

संगठन का कर्मचारी, ठेकेदार या अधिकृत उपयोगकर्ता।

उदाहरण

एक कर्मचारी ग्राहक डेटाबेस को निजी लाभ के लिए कॉपी कर लेता है।

(घ) Hacktivists

राजनीतिक या सामाजिक विचारधारा से प्रेरित समूह।

उदाहरण

किसी सरकारी वेबसाइट को Deface करना।

(ङ) Script Kiddies

कम तकनीकी ज्ञान वाले व्यक्ति जो तैयार Hacking Tools का उपयोग करते हैं।

(च) Terrorist Organizations

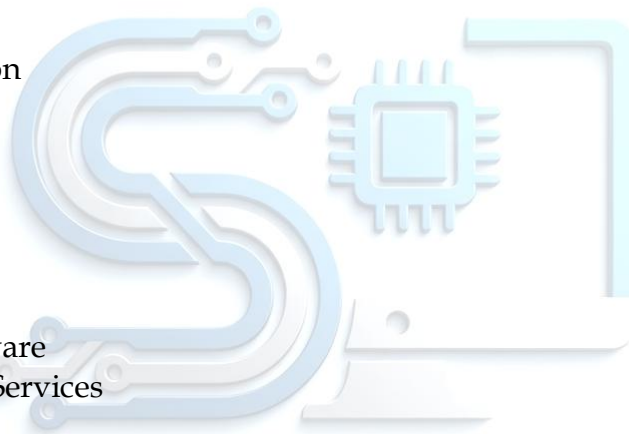
डिजिटल माध्यमों का उपयोग कर दहशत फैलाने या महत्वपूर्ण सेवाओं को बाधित करने का प्रयास कर सकते हैं।

5. Threat Vectors (हमले के माध्यम)

हमलावर विभिन्न माध्यमों से सिस्टम तक पहुँचने का प्रयास करते हैं।

प्रमुख Threat Vectors

- Email
- Website
- Mobile Application
- Cloud Services
- USB Devices
- Wi-Fi
- VPN
- Social Media
- APIs
- Third-Party Software
- Remote Desktop Services



6. Threat Categories (खतरों की प्रमुख श्रेणियाँ)

(1) Malware

Malicious Software जो सिस्टम को नुकसान पहुँचाने के लिए बनाया जाता है।

प्रकार

- Virus
- Worm
- Trojan
- Spyware
- Rootkit
- Adware
- Bot

उदाहरण

एक Trojan बैंकिंग एप्लिकेशन में Login Credentials चुरा सकता है।

(2) Ransomware

डेटा को एन्क्रिप्ट कर फिरौती की मांग करना।

उदाहरण

अस्पताल का पूरा Patient Database एन्क्रिप्ट हो जाता है और उपचार सेवाएँ प्रभावित होती हैं।

(3) Phishing

नकली ईमेल, वेबसाइट या संदेश के माध्यम से गोपनीय जानकारी प्राप्त करना।

उदाहरण

उपयोगकर्ता को बैंक की नकली वेबसाइट पर Login करने के लिए प्रेरित किया जाता है।

(4) Social Engineering

तकनीकी कमजोरियों के बजाय मानव मनोविज्ञान का दुरुपयोग।

उदाहरण

कोई व्यक्ति स्वयं को IT Administrator बताकर OTP पूछता है।

(5) Distributed Denial of Service (DDoS)

एक साथ अत्यधिक अनुरोध भेजकर सेवा को अनुपलब्ध बना देना।

उदाहरण

विश्वविद्यालय की ऑनलाइन प्रवेश वेबसाइट आवेदन की अंतिम तिथि पर ठप हो जाती है।

(6) Insider Attack

अधिकृत उपयोगकर्ता द्वारा जानबूझकर या अनजाने में सुरक्षा उल्लंघन।

(7) Supply Chain Attack

हमलावर सीधे लक्ष्य पर नहीं बल्कि उसके Software Vendor, Library या Service Provider को लक्ष्य बनाता है।

उदाहरण

किसी ERP सॉफ्टवेयर के अपडेट पैकेज में दुर्भावनापूर्ण कोड सम्मिलित कर दिया जाए।

(8) Zero-Day Attack

ऐसी Vulnerability का दुरुपयोग जिसके लिए अभी सुरक्षा पैच उपलब्ध न हो।

(9) Advanced Persistent Threat (APT)

दीर्घकालिक, गुप्त एवं अत्यधिक परिष्कृत हमला।

विशेषताएँ

- लंबे समय तक नेटवर्क में छिपे रहना
 - डेटा चोरी
 - साइबर जासूसी
 - अत्यधिक संसाधनों का उपयोग
-

(10) Cloud Threats

- Misconfiguration
 - Data Exposure
 - Weak Identity Management
 - Insecure APIs
-

(11) IoT Threats

- Smart Camera Hacking
 - Smart Meter Manipulation
 - Industrial Sensor Attack
-

(12) AI आधारित खतरे

- Deepfake
 - AI Generated Phishing
 - Automated Malware
 - AI-Powered Password Cracking
-

7. Threat Landscape का क्षेत्रवार अध्ययन

(क) बैंकिंग

प्रमुख खतरे

- ATM Malware
 - UPI Fraud
 - Credential Theft
 - Banking Trojan
-

(ख) शिक्षा

प्रमुख खतरे

- Result Tampering
 - Question Paper Leak
 - Student Data Theft
 - ERP Attack
-

(ग) स्वास्थ्य

प्रमुख खतरे

- Medical Record Theft
- Ransomware
- Connected Medical Device Attack

(घ) उद्योग

प्रमुख खतरे

- Industrial Espionage
- SCADA Attack
- PLC Manipulation

(ङ) सरकारी संस्थाएँ

प्रमुख खतरे

- Cyber Espionage
- Website Defacement
- Data Breach
- Critical Infrastructure Attack

8. वास्तविक केस स्टडी

केस स्टडी 1: विश्वविद्यालय

स्थिति

ऑनलाइन परीक्षा पोर्टल में कमजोर Password Policy थी।

परिणाम

हमलावर ने Administrator Account प्राप्त कर लिया।

- प्रश्नपत्र चोरी
- परीक्षा परिणाम में परिवर्तन
- वेबसाइट बंद

सीखी गई बातें

- MFA आवश्यक
- Strong Password Policy
- Audit Logs
- SIEM Monitoring

केस स्टडी 2: अस्पताल

स्थिति

एक कर्मचारी ने Phishing Email खोल दिया।

परिणाम

- Ransomware सक्रिय
- मरीजों का डेटा एन्क्रिप्ट
- ऑपरेशन स्थगित

समाधान

- Offline Backup
- Email Security Gateway
- User Awareness Training
- Network Segmentation

केस स्टडी 3: बैंक

स्थिति

मोबाइल बैंकिंग API में Authentication की कमजोरी थी।

परिणाम

हमलावरों ने अनधिकृत लेन-देन किए।

समाधान

- API Gateway
- OAuth 2.0

- Token Validation
- Continuous Monitoring

9. Threat Landscape Analysis

Threat Landscape का विश्लेषण निम्न चरणों में किया जाता है:

1. Asset Identification
2. Threat Identification
3. Vulnerability Assessment
4. Threat Intelligence Collection
5. Risk Analysis
6. Control Selection
7. Continuous Monitoring

10. Threat Intelligence

Threat Landscape को समझने के लिए Threat Intelligence अत्यंत महत्वपूर्ण है।

प्रकार

- Strategic Intelligence
- Tactical Intelligence
- Operational Intelligence
- Technical Intelligence

उदाहरण

यदि किसी संगठन को पहले से जानकारी मिल जाए कि एक नया Ransomware अभियान शिक्षा संस्थानों को लक्ष्य बना रहा है, तो वह समय रहते सुरक्षा उपाय लागू कर सकता है।

11. आधुनिक सुरक्षा उपाय

Threat Landscape का प्रभावी सामना करने के लिए निम्न उपाय अपनाए जाते हैं:

- Zero Trust Architecture
- Multi-Factor Authentication (MFA)
- Endpoint Detection and Response (EDR)

- Extended Detection and Response (XDR)
- Security Information and Event Management (SIEM)
- Security Operations Center (SOC)
- Threat Hunting
- Vulnerability Management
- Patch Management
- Network Segmentation
- Backup एवं Disaster Recovery
- User Security Awareness Training

12. भविष्य के उभरते खतरे (Emerging Threats)

आने वाले वर्षों में निम्न खतरे अधिक महत्वपूर्ण होंगे:

- Quantum Computing आधारित क्रिप्टोग्राफिक हमले
- AI-संचालित स्वचालित साइबर हमले
- Autonomous Vehicle Hacking
- Smart City Infrastructure Attacks
- 6G Network Threats
- Satellite Communication Attacks
- Digital Identity Fraud
- Supply Chain Ecosystem Attacks

13. शोध (Research) दृष्टिकोण

Ph.D. स्तर पर Threat Landscape का अध्ययन निम्न विषयों पर केंद्रित हो सकता है:

- AI आधारित Threat Prediction
- Threat Intelligence Platforms
- Cyber Threat Hunting
- Adversary Emulation
- MITRE ATT&CK Framework का उपयोग
- Threat Modeling (STRIDE, PASTA, OCTAVE)
- Cyber Kill Chain Analysis
- Cloud एवं IoT Threat Landscape
- Critical Infrastructure Protection
- National Cyber Defense Strategy

अध्याय का निष्कर्ष

Threat Landscape आधुनिक साइबर सुरक्षा का गतिशील (Dynamic) और निरंतर परिवर्तित होने वाला आयाम है। यह केवल वर्तमान साइबर खतरों का अध्ययन नहीं, बल्कि भविष्य में उभरने वाले जोखिमों, हमलावरों की रणनीतियों, तकनीकी विकास तथा सुरक्षा उपायों का समग्र विश्लेषण भी है।

किसी भी संगठन के लिए प्रभावी साइबर सुरक्षा तभी संभव है जब वह अपने Threat Landscape को निरंतर समझे, अद्यतन रखे, Threat Intelligence का उपयोग करे तथा बदलते हुए खतरों के अनुरूप अपनी सुरक्षा रणनीति को विकसित करता रहे।

मुख्य संदेश:

"जिस संगठन को अपने Threat Landscape की स्पष्ट समझ होती है, वही समय रहते खतरों की पहचान, जोखिमों का आकलन और प्रभावी सुरक्षा नियंत्रण लागू कर सकता है। यही सक्रिय (Proactive) साइबर सुरक्षा की वास्तविक पहचान है।"



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय 2 : मौलिक अवधारणाएँ

(Fundamental Concepts)

(Cyber Security एवं Information Security के संदर्भ में)

2.1 परिचय (Introduction)

किसी भी विषय को गहराई से समझने से पहले उसके Fundamental Concepts (मौलिक सिद्धांत) को समझना आवश्यक होता है। साइबर सुरक्षा (Cyber Security) एवं सूचना सुरक्षा (Information Security) में भी अनेक ऐसे मूलभूत सिद्धांत हैं जिनके आधार पर संपूर्ण सुरक्षा तंत्र निर्मित होता है।

आज लगभग प्रत्येक कार्य—बैंकिंग, शिक्षा, चिकित्सा, सरकारी सेवाएँ, ई-कॉमर्स, सोशल मीडिया, उद्योग तथा सैन्य संगठन—डिजिटल माध्यमों पर आधारित हैं। इसलिए डेटा, नेटवर्क, कंप्यूटर सिस्टम और डिजिटल संसाधनों की सुरक्षा अत्यंत आवश्यक हो गई है।

Fundamental Concepts वे आधारभूत सिद्धांत हैं जिनका उद्देश्य यह सुनिश्चित करना है कि—

- डेटा सुरक्षित रहे।
- केवल अधिकृत व्यक्ति ही डेटा तक पहुँच सके।
- डेटा में बिना अनुमति परिवर्तन न हो।
- आवश्यकता पड़ने पर डेटा उपलब्ध रहे।
- उपयोगकर्ता की पहचान सत्यापित हो।
- प्रत्येक गतिविधि का रिकॉर्ड उपलब्ध रहे।

2.2 सूचना (Information)

परिभाषा

जब किसी डेटा को व्यवस्थित करके उपयोगी बनाया जाता है तब वह सूचना (Information) कहलाती है।

सूत्र

$\text{Data} + \text{Processing} = \text{Information}$

उदाहरण

विद्यालय में निम्न डेटा है—

विद्यार्थी अंक

राहुल 78

सीमा 90

मोहन 65

यह केवल डेटा है।

यदि इन अंकों के आधार पर मेरिट सूची बनाई जाए—

1. सीमा
2. राहुल
3. मोहन

तो यह सूचना (Information) बन जाती है।

2.3 डेटा (Data)

डेटा कच्चे तथ्यों (Raw Facts) का संग्रह होता है।

यह निम्न प्रकार का हो सकता है—

- संख्या
- अक्षर
- चित्र
- वीडियो
- ऑडियो
- दस्तावेज़

उदाहरण

- 150
- Shiv Kumar
- 25/07/2026
- Photo.jpg
- Salary.pdf

2.4 सूचना सुरक्षा (Information Security)

परिभाषा

सूचना सुरक्षा वह प्रक्रिया है जिसके द्वारा किसी भी प्रकार की सूचना को

- चोरी
- परिवर्तन
- नष्ट होने
- अनधिकृत पहुँच

से सुरक्षित रखा जाता है।

Information Security केवल कंप्यूटर तक सीमित नहीं होती।

इसमें शामिल हैं—

- कागजी दस्तावेज
- हार्ड डिस्क
- पेन ड्राइव
- मोबाइल
- क्लाउड डेटा
- सर्वर



उदाहरण

एक अस्पताल में मरीजों की मेडिकल रिपोर्ट रखी हुई है।

यदि कोई व्यक्ति बिना अनुमति रिपोर्ट देख लेता है तो

Information Security का उल्लंघन होगा।

2.5 साइबर सुरक्षा (Cyber Security)

परिभाषा

Cyber Security वह तकनीक एवं प्रक्रिया है जिसके द्वारा

- Computer
- Network
- Internet
- Server
- Software
- Database
- Mobile

को साइबर हमलों से सुरक्षित रखा जाता है।

उदाहरण

यदि कोई हैकर बैंक सर्वर को हैक करने का प्रयास करता है तो

Firewall

Antivirus

IDS

IPS

Encryption

का उपयोग करके बैंक स्वयं की सुरक्षा करता है।

2.6 सूचना सुरक्षा एवं साइबर सुरक्षा में अंतर

सूचना सुरक्षा

सभी प्रकार की सूचना की सुरक्षा केवल डिजिटल सूचना की सुरक्षा

कागज भी शामिल

इंटरनेट आवश्यक नहीं

साइबर सुरक्षा

केवल डिजिटल सिस्टम

इंटरनेट आधारित हमलों से सुरक्षा

उदाहरण

यदि किसी कार्यालय की अलमारी में रखी फाइल सुरक्षित रखी जाती है

→ Information Security

यदि वही फाइल ऑनलाइन सर्वर पर सुरक्षित रखी जाती है

→ Cyber Security

2.7 डिजिटल संपत्ति (Digital Assets)

वे सभी संसाधन जो डिजिटल रूप में उपलब्ध हों।

जैसे—

- Database
- Source Code
- Email
- Website
- Mobile App
- Password
- Cloud Storage
- Customer Data

उदाहरण

Amazon का पूरा Product Database एक Digital Asset है।

2.8 संपत्ति (Asset)

Asset वह वस्तु होती है जिसका संगठन के लिए मूल्य (Value) हो।

Asset के प्रकार

(1) Hardware

- Computer
- Laptop
- Server
- Router

(2) Software

- Windows
- Linux
- ERP Software

(3) Information

- Student Database
- Bank Records

(4) Human Asset

- कर्मचारी
- Administrator

(5) Reputation

किसी संस्था की प्रतिष्ठा भी Asset होती है।

उदाहरण

यदि किसी बैंक का ग्राहक डेटा चोरी हो जाए

तो

- आर्थिक नुकसान

- ग्राहक का विश्वास कम होना
- प्रतिष्ठा खराब होना

ये सभी Asset Loss हैं।

2.9 खतरा (Threat)

Threat वह संभावना है जिससे किसी सिस्टम को नुकसान पहुँच सकता है।

उदाहरण

- Hacker
 - Virus
 - Earthquake
 - Fire
 - Flood
 - Employee Mistake
-

उदाहरण

किसी कंपनी में कर्मचारी अपना Password सभी को बता देता है।

यह Threat है।

2.10 Vulnerability (कमजोरी)

System की वह कमजोरी जिसका लाभ उठाकर हमला किया जा सके।

उदाहरण

- Weak Password
- पुराना Windows
- बिना Antivirus

- Open USB Port
- Unpatched Server

उदाहरण

Password = 123456

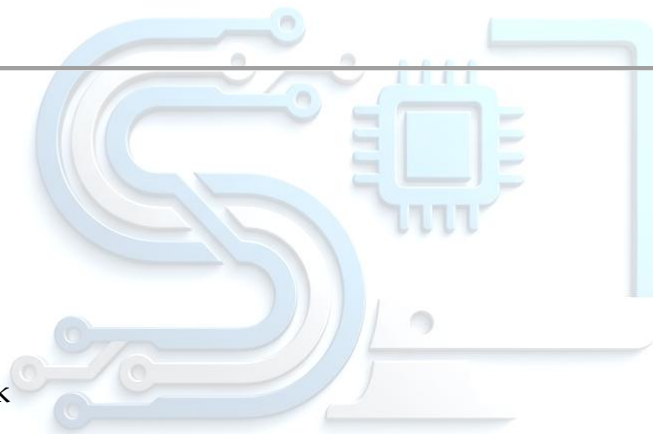
यह एक Vulnerability है।

2.11 Attack

जब कोई Threat वास्तव में हमला करता है।

उदाहरण

- SQL Injection
- Malware Attack
- DDoS
- Ransomware
- Password Attack



उदाहरण

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

यदि Hacker Password Guess करके Login कर जाए

तो यह Attack कहलाएगा।

2.12 Exploit

Exploit वह तकनीक या प्रोग्राम होता है जो Vulnerability का लाभ उठाता है।

उदाहरण

पुराने Windows में एक Security Bug है।

Hacker उसी Bug का उपयोग करके System Hack कर देता है।

यही Exploit है।

2.13 Risk

Risk वह संभावना है कि Threat किसी Vulnerability का उपयोग करके नुकसान पहुँचा दे।

सूत्र

$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$

उदाहरण

Server में Security Patch नहीं लगा।

Internet से जुड़ा हुआ है।

Hack होने की संभावना अधिक है।

यह High Risk है।



2.14 Control (Security Control)

Risk कम करने के लिए अपनाए गए उपाय।

उदाहरण

- Firewall
- Antivirus
- Encryption
- Access Control
- Backup
- MFA
- CCTV

2.15 Authentication

उपयोगकर्ता की पहचान सत्यापित करना।

उदाहरण

ATM Card + PIN

अन्य उदाहरण

- Password
- OTP
- Fingerprint
- Face Recognition

2.16 Authorization

Authentication के बाद यह तय करना कि उपयोगकर्ता क्या-क्या कर सकता है।

उदाहरण

विद्यालय ERP में—

Admin

- छात्र जोड़ सकता है।

Teacher

- केवल अंक भर सकता है।

Student

- केवल अपना Result देख सकता है।

2.17 Accounting (Auditing)

किस उपयोगकर्ता ने

- कब Login किया
- क्या बदला
- कितना समय कार्य किया

इन सभी का रिकॉर्ड रखना।

उदाहरण

Windows Event Log

Linux Syslog

2.18 Confidentiality (गोपनीयता)

सूचना केवल अधिकृत व्यक्ति ही देख सके।

उदाहरण

बैंक खाते की जानकारी केवल ग्राहक और बैंक अधिकारी देखें।

2.19 Integrity (अखंडता)

डेटा बिना अनुमति बदला न जाए।

उदाहरण

विश्वविद्यालय का परीक्षा परिणाम।

यदि कोई अंक बदल दे

2.20 Availability (उपलब्धता)

जब आवश्यकता हो तब सिस्टम उपलब्ध रहे।

उदाहरण

UPI Payment Server

यदि Server बंद है

तो Availability नहीं है।

2.21 Non-Repudiation

कोई व्यक्ति बाद में यह न कह सके कि उसने कार्य नहीं किया।

उदाहरण

Digital Signature

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

2.22 Accountability

प्रत्येक कार्य के लिए जिम्मेदार व्यक्ति की पहचान होना।

उदाहरण

Audit Log बताता है कि

Admin ने Database Delete किया।

2.23 Privacy

किसी व्यक्ति की व्यक्तिगत जानकारी की सुरक्षा।

उदाहरण

- Aadhaar Number
 - Mobile Number
 - Medical Report
 - Bank Account
-

2.24 Encryption

Plain Text को Cipher Text में बदलना।

उदाहरण

HELLO

↓

8sd#9Kd@

2.25 Decryption

Cipher Text को पुनः पढ़ने योग्य बनाना।

2.26 Backup

डेटा की अतिरिक्त सुरक्षित प्रति बनाना।

उदाहरण

2.27 Disaster Recovery

आपदा के बाद सिस्टम को पुनः चालू करना।

उदाहरण

यदि Server Room में आग लग जाए

तो Backup Server से कार्य प्रारंभ करना।

2.28 Business Continuity

किसी भी परिस्थिति में संगठन का कार्य निरंतर चलता रहे।

उदाहरण

बैंक का मुख्य Server बंद होने पर दूसरा Data Center चालू हो जाना।

अध्याय का सारांश

इस अध्याय में साइबर सुरक्षा एवं सूचना सुरक्षा की सभी प्रमुख मौलिक अवधारणाओं का अध्ययन किया गया। डेटा, सूचना, सूचना सुरक्षा, साइबर सुरक्षा, डिजिटल संपत्ति, खतरा (Threat), कमजोरी (Vulnerability), हमला (Attack), जोखिम (Risk), सुरक्षा नियंत्रण (Security Controls), प्रमाणीकरण (Authentication), प्राधिकरण (Authorization), लेखा-परीक्षण (Accounting), CIA Triad (Confidentiality, Integrity, Availability), गोपनीयता (Privacy), एन्क्रिप्शन (Encryption), बैकअप (Backup), डिज़ास्टर रिकवरी (Disaster Recovery) तथा बिज़नेस कंटीन्यूटी (Business Continuity) जैसे सिद्धांत किसी भी सुरक्षित सूचना प्रणाली की नींव हैं। इन अवधारणाओं की स्पष्ट समझ के बिना प्रभावी साइबर सुरक्षा नीति, जोखिम प्रबंधन, नेटवर्क सुरक्षा तथा डिजिटल फॉरेंसिक का अध्ययन अधूरा माना जाता है।



प्रमाणीकरण (Authentication)

(साइबर सुरक्षा एवं सूचना सुरक्षा में विस्तृत अध्ययन)

1. परिचय (Introduction)

आज के डिजिटल युग में लगभग प्रत्येक ऑनलाइन सेवा—जैसे इंटरनेट बैंकिंग, ई-मेल, सोशल मीडिया, विश्वविद्यालय पोर्टल, सरकारी वेबसाइट, क्लाउड स्टोरेज, एटीएम, मोबाइल एप्लिकेशन तथा कार्यालयों के कंप्यूटर नेटवर्क—का उपयोग करने से पहले उपयोगकर्ता की पहचान सत्यापित की जाती है। इस प्रक्रिया को **प्रमाणीकरण (Authentication)** कहते हैं।

यदि किसी सिस्टम में उपयोगकर्ता की पहचान सत्यापित किए बिना प्रवेश की अनुमति दे दी जाए, तो कोई भी अनधिकृत व्यक्ति डेटा चुरा सकता है, उसमें परिवर्तन कर सकता है या सिस्टम का दुरुपयोग कर सकता है। इसलिए Authentication किसी भी सुरक्षित सूचना प्रणाली की पहली और सबसे महत्वपूर्ण सुरक्षा परत (First Line of Defense) मानी जाती है।

2. प्रमाणीकरण (Authentication) की परिभाषा

Authentication वह प्रक्रिया है जिसके द्वारा किसी उपयोगकर्ता, कंप्यूटर, मोबाइल डिवाइस या अन्य इकाई की पहचान (Identity) की पुष्टि की जाती है, ताकि यह सुनिश्चित किया जा सके कि वह वास्तव में वही व्यक्ति या उपकरण है जो होने का दावा कर रहा है।

सरल भाषा में:

"किसी व्यक्ति या डिवाइस की पहचान को प्रमाणित करने की प्रक्रिया को प्रमाणीकरण (Authentication) कहते हैं।"

3. प्रमाणीकरण की आवश्यकता

Authentication का मुख्य उद्देश्य यह सुनिश्चित करना है कि केवल अधिकृत (Authorized) उपयोगकर्ता ही सिस्टम, नेटवर्क या डेटा तक पहुँच प्राप्त कर सके।

यदि प्रमाणीकरण न हो, तो निम्न समस्याएँ उत्पन्न हो सकती हैं—

- डेटा चोरी (Data Theft)

- पहचान की चोरी (Identity Theft)
- बैंक खाते से धन की चोरी
- ई-मेल अकाउंट हैक होना
- सरकारी रिकॉर्ड में छेड़छाड़
- परीक्षा परिणाम बदलना
- संवेदनशील दस्तावेजों का दुरुपयोग

4. प्रमाणीकरण कैसे कार्य करता है?

Authentication की प्रक्रिया सामान्यतः निम्न चरणों में होती है—

1. उपयोगकर्ता अपना **यूजर आईडी (User ID)** दर्ज करता है।
2. सिस्टम उससे पहचान प्रमाण (Password, OTP, Fingerprint आदि) माँगता है।
3. सिस्टम उपलब्ध जानकारी का अपने डेटाबेस में संग्रहीत जानकारी से मिलान करता है।
4. यदि जानकारी सही होती है, तो उपयोगकर्ता को प्रवेश (Access) प्रदान किया जाता है।
5. यदि जानकारी गलत होती है, तो प्रवेश अस्वीकार (Access Denied) कर दिया जाता है।

5. प्रमाणीकरण के प्रमुख प्रकार

(Types of Authentication)

(1) ज्ञान आधारित प्रमाणीकरण (Something You Know)

इसमें उपयोगकर्ता ऐसी जानकारी देता है जो केवल उसे ज्ञात होती है।

उदाहरण

- Password
- PIN
- Security Question
- Pattern Lock

उदाहरण

ATM मशीन में

- ATM Card

- PIN Number

दर्ज करने पर बैंक आपकी पहचान सत्यापित करता है।

(2) स्वामित्व आधारित प्रमाणीकरण (Something You Have)

इसमें उपयोगकर्ता के पास कोई विशेष वस्तु होती है।

उदाहरण

- Smart Card
- ATM Card
- USB Security Token
- OTP प्राप्त करने वाला मोबाइल
- Hardware Token

उदाहरण

यदि बैंक आपके मोबाइल पर OTP भेजता है और वही OTP दर्ज करने पर लॉगिन सफल होता है, तो यह स्वामित्व आधारित प्रमाणीकरण है।

(3) जैविक प्रमाणीकरण (Something You Are)

इसमें व्यक्ति के शारीरिक या जैविक गुणों का उपयोग किया जाता है।

उदाहरण

- Fingerprint
- Face Recognition
- Iris Scan
- Retina Scan
- Voice Recognition
- Palm Scan

उदाहरण

मोबाइल फोन को अंगुली के निशान (Fingerprint) से अनलॉक करना।

(4) व्यवहार आधारित प्रमाणीकरण (Something You Do)

इसमें व्यक्ति के व्यवहार का विश्लेषण किया जाता है।

उदाहरण

- Typing Pattern
- Mouse Movement
- Signature Verification
- Walking Pattern (Gait Analysis)

उदाहरण

यदि बैंक यह पहचान ले कि उपयोगकर्ता सामान्यतः कानपुर से लॉगिन करता है लेकिन अचानक किसी अन्य देश से संदिग्ध तरीके से लॉगिन हो रहा है, तो अतिरिक्त सत्यापन माँगा जा सकता है।

6. प्रमाणीकरण के स्तर (Authentication Factors)

(क) Single-Factor Authentication (SFA)

इसमें केवल एक माध्यम से पहचान सत्यापित की जाती है।

उदाहरण

केवल Password

(ख) Two-Factor Authentication (2FA)

इसमें दो अलग-अलग प्रमाणीकरण कारकों का उपयोग किया जाता है।

उदाहरण

Password + OTP

या

ATM Card + PIN

(ग) Multi-Factor Authentication (MFA)

इसमें दो या दो से अधिक प्रमाणीकरण कारकों का उपयोग किया जाता है।

उदाहरण

Password + OTP + Fingerprint

यह सबसे सुरक्षित प्रमाणीकरण विधियों में से एक है।

7. वास्तविक जीवन के उदाहरण

उदाहरण 1 : इंटरनेट बैंकिंग

मान लीजिए राहुल इंटरनेट बैंकिंग में लॉगिन करता है।

1. User ID दर्ज करता है।
2. Password दर्ज करता है।
3. मोबाइल पर OTP प्राप्त होता है।
4. OTP दर्ज करता है।
5. बैंक पहचान सत्यापित कर लॉगिन की अनुमति देता है।

यह Two-Factor Authentication का उदाहरण है।

उदाहरण 2 : मोबाइल फोन

स्मार्टफोन खोलने के लिए—

- Fingerprint
- Face Unlock
- PIN

का उपयोग किया जाता है।

यह जैविक प्रमाणीकरण (Biometric Authentication) का उदाहरण है।

उदाहरण 3 : विश्वविद्यालय ERP प्रणाली

एक विश्वविद्यालय ERP में—

- छात्र (Student)
- शिक्षक (Teacher)
- प्रशासक (Admin)

तीनों के अलग-अलग लॉगिन होते हैं।

प्रत्येक उपयोगकर्ता अपना User ID और Password दर्ज करता है। सिस्टम उसकी पहचान सत्यापित करता है और फिर उसके अधिकारों के अनुसार प्रवेश देता है।

उदाहरण 4 : एटीएम मशीन

ATM में—

- ATM Card
- PIN

दोनों की आवश्यकता होती है। यदि PIN गलत है, तो बैंक लेन-देन की अनुमति नहीं देता।

8. Authentication और Authorization में अंतर

आधार	Authentication (प्रमाणीकरण)	Authorization (प्राधिकरण)
उद्देश्य	उपयोगकर्ता की पहचान सत्यापित करना	उपयोगकर्ता को क्या-क्या करने की अनुमति है, यह निर्धारित करना
प्रक्रिया	पहले होती है	Authentication के बाद होती है
प्रश्न	"आप कौन हैं?"	"आप क्या कर सकते हैं?"
उदाहरण	Password, OTP, Fingerprint	Read, Write, Delete, Modify की अनुमति

उदाहरण:

यदि कोई शिक्षक विद्यालय के ERP में लॉगिन करता है, तो पहले उसका User ID और Password जाँचा जाएगा (Authentication)। सफल प्रमाणीकरण के बाद उसे केवल अंक दर्ज करने की अनुमति मिलेगी, लेकिन छात्र रिकॉर्ड हटाने की अनुमति नहीं होगी (Authorization)।

9. प्रमाणीकरण के लाभ

- केवल अधिकृत उपयोगकर्ता को प्रवेश मिलता है।
- डेटा चोरी की संभावना कम होती है।
- अनधिकृत लॉगिन रोके जा सकते हैं।
- ऑनलाइन बैंकिंग अधिक सुरक्षित होती है।
- साइबर अपराधों का जोखिम कम होता है।
- उपयोगकर्ता की पहचान की पुष्टि होती है।
- संगठन की सूचना सुरक्षा मजबूत होती है।

10. प्रमाणीकरण की सीमाएँ

- कमजोर Password आसानी से अनुमान लगाए जा सकते हैं।
- OTP आधारित प्रणाली में SIM Swapping का खतरा हो सकता है।
- बायोमेट्रिक सेंसर कभी-कभी गलत पहचान कर सकते हैं।
- यदि उपयोगकर्ता Password साझा कर दे, तो सुरक्षा प्रभावित हो सकती है।
- केवल Single-Factor Authentication आधुनिक साइबर हमलों के विरुद्ध पर्याप्त नहीं माना जाता।

11. सुरक्षित प्रमाणीकरण के सर्वोत्तम उपाय (Best Practices)

- कम से कम 12-16 अक्षरों का मजबूत Password रखें।
- Password में बड़े अक्षर, छोटे अक्षर, अंक और विशेष चिन्ह का उपयोग करें।
- प्रत्येक वेबसाइट के लिए अलग Password रखें।
- जहाँ संभव हो, Multi-Factor Authentication (MFA) सक्षम करें।
- OTP किसी के साथ साझा न करें।
- सार्वजनिक कंप्यूटर पर लॉगिन करने के बाद हमेशा Logout करें।
- संदिग्ध लॉगिन गतिविधियों की नियमित जाँच करें।

12. परीक्षा की दृष्टि से महत्वपूर्ण बिंदु

- Authentication का अर्थ है **उपयोगकर्ता की पहचान सत्यापित करना**।
- यह सूचना सुरक्षा की पहली सुरक्षा परत (First Line of Defense) है।
- इसके प्रमुख प्रकार हैं—Knowledge-based, Possession-based, Biometric और Behavioral Authentication।
- आधुनिक प्रणालियों में **Multi-Factor Authentication (MFA)** सबसे अधिक सुरक्षित माना जाता है।
- Authentication और Authorization अलग-अलग अवधारणाएँ हैं; पहले पहचान सत्यापित होती है, उसके बाद अधिकार (Permissions) प्रदान किए जाते हैं।

निष्कर्ष

प्रमाणीकरण (Authentication) साइबर सुरक्षा की आधारभूत और अत्यंत महत्वपूर्ण प्रक्रिया है। यह सुनिश्चित करता है कि केवल वही व्यक्ति, उपकरण या सेवा किसी सिस्टम तक पहुँच प्राप्त करे जिसकी पहचान सत्यापित हो चुकी है। आज बैंकिंग, ई-कॉमर्स, सरकारी सेवाओं, क्लाउड कंप्यूटिंग, मोबाइल एप्लिकेशन, विश्वविद्यालय ERP तथा कॉर्पोरेट नेटवर्क में सुरक्षित प्रमाणीकरण के लिए Password, OTP, Smart Card, Fingerprint, Face Recognition और Multi-Factor Authentication जैसी तकनीकों का व्यापक उपयोग किया जाता है। मजबूत प्रमाणीकरण न केवल डेटा की गोपनीयता और सुरक्षा सुनिश्चित करता है, बल्कि साइबर हमलों, पहचान की चोरी और अनधिकृत पहुँच के जोखिम को भी काफी हद तक कम करता है।

Authentication (प्रमाणीकरण)

परिभाषा, उद्देश्य, प्रकार, कार्यप्रणाली एवं उदाहरण सहित विस्तृत अध्ययन

1. परिचय (Introduction)

आज के डिजिटल युग में लगभग प्रत्येक व्यक्ति इंटरनेट का उपयोग करता है। इंटरनेट बैंकिंग, एटीएम, मोबाइल बैंकिंग, ई-मेल, सोशल मीडिया, ऑनलाइन शॉपिंग, क्लाउड स्टोरेज, सरकारी पोर्टल, विश्वविद्यालय पोर्टल तथा कार्यालयों के डिजिटल सिस्टम में उपयोगकर्ता की पहचान सुनिश्चित करना अत्यंत आवश्यक है। यदि किसी भी सिस्टम में यह सत्यापित न किया जाए कि लॉगिन करने वाला व्यक्ति वास्तव में वही है जिसका वह दावा कर

रहा है, तो अनधिकृत व्यक्ति संवेदनशील जानकारी तक पहुँच सकता है। इसी समस्या के समाधान के लिए **Authentication (प्रमाणीकरण)** का उपयोग किया जाता है।

Authentication सूचना सुरक्षा (Information Security) एवं साइबर सुरक्षा (Cyber Security) का एक अत्यंत महत्वपूर्ण सिद्धांत है। यह किसी भी सुरक्षित प्रणाली (Secure System) की पहली सुरक्षा परत (First Line of Defense) मानी जाती है।

2. Authentication की परिभाषा (Definition)

Authentication (प्रमाणीकरण) वह प्रक्रिया है जिसके द्वारा किसी उपयोगकर्ता (User), कंप्यूटर, डिवाइस या एप्लिकेशन की पहचान (Identity) को सत्यापित (Verify) किया जाता है कि वह वास्तव में वही है जिसका वह दावा कर रहा है।

सरल शब्दों में—

"किसी व्यक्ति की पहचान की पुष्टि करने की प्रक्रिया को Authentication कहते हैं।"

3. Authentication की आवश्यकता (Need of Authentication)

यदि किसी सिस्टम में Authentication न हो, तो कोई भी व्यक्ति बिना अनुमति किसी अन्य उपयोगकर्ता का डेटा देख सकता है या उसमें परिवर्तन कर सकता है।

Authentication निम्न उद्देश्यों की पूर्ति करता है—

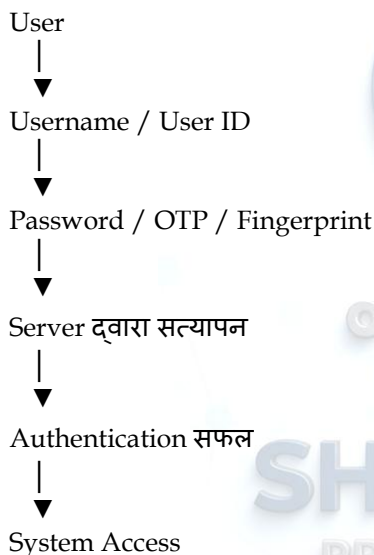
- केवल अधिकृत (Authorized) उपयोगकर्ता को प्रवेश देना।
- संवेदनशील जानकारी की सुरक्षा करना।
- डेटा चोरी (Data Theft) को रोकना।
- साइबर अपराधों को कम करना।
- बैंकिंग एवं वित्तीय लेन-देन को सुरक्षित बनाना।
- उपयोगकर्ता की वास्तविक पहचान सुनिश्चित करना।
- संगठन की सुरक्षा नीति (Security Policy) का पालन कराना।

4. Authentication कैसे कार्य करता है? (Working of Authentication)

Authentication की सामान्य प्रक्रिया निम्न चरणों में होती है—

1. उपयोगकर्ता अपना Username या User ID दर्ज करता है।
2. इसके बाद Password, OTP, Fingerprint, Face Recognition आदि के माध्यम से अपनी पहचान सिद्ध करता है।
3. सिस्टम डेटाबेस में संग्रहीत जानकारी से तुलना करता है।
4. यदि जानकारी सही पाई जाती है, तो उपयोगकर्ता का प्रमाणीकरण सफल हो जाता है।
5. इसके बाद उपयोगकर्ता को सिस्टम में प्रवेश (Access) प्रदान किया जाता है।

सरल प्रवाह (Flow):



5. Authentication के प्रमुख प्रकार (Types of Authentication)

(A) Password Authentication (पासवर्ड आधारित प्रमाणीकरण)

यह सबसे सामान्य और व्यापक रूप से प्रयुक्त Authentication है। उपयोगकर्ता अपना Username तथा Password दर्ज करता है।

उदाहरण

- Gmail Login

- Facebook Login
- University ERP
- Windows Login

लाभ

- सरल
- कम लागत
- आसानी से लागू किया जा सकता है।

हानियाँ

- कमजोर पासवर्ड आसानी से अनुमानित हो सकते हैं।
- Phishing या Keylogger के माध्यम से चोरी हो सकते हैं।

(B) PIN Authentication (पिन आधारित प्रमाणीकरण)

PIN (Personal Identification Number) संख्यात्मक कोड होता है।

उदाहरण

- ATM PIN
- UPI PIN
- Debit Card PIN
- Mobile SIM PIN

यदि ATM कार्ड चोरी हो जाए लेकिन PIN ज्ञात न हो, तो धन निकालना कठिन होगा।

(C) OTP Authentication (One-Time Password)

OTP एक अस्थायी पासवर्ड होता है जो केवल एक बार और सीमित समय के लिए मान्य होता है।

उदाहरण

- नेट बैंकिंग
- UPI भुगतान
- आधार आधारित सेवाएँ
- ऑनलाइन टिकट बुकिंग

यदि कोई व्यक्ति आपका Password जान भी ले, तो OTP के बिना लॉगिन नहीं कर पाएगा।

(D) Biometric Authentication (बायोमेट्रिक प्रमाणीकरण)

इसमें उपयोगकर्ता की जैविक (Biological) विशेषताओं के आधार पर पहचान की जाती है।

प्रकार

- Fingerprint
- Face Recognition
- Iris Scan
- Retina Scan
- Voice Recognition
- Palm Recognition

उदाहरण

- स्मार्टफोन Unlock
- Aadhaar Authentication
- Attendance System
- Airport e-Gate

(E) Smart Card Authentication (स्मार्ट कार्ड आधारित प्रमाणीकरण)

Smart Card में सुरक्षित डिजिटल जानकारी संग्रहीत रहती है।

उदाहरण

- बैंक Smart Card
- कर्मचारी Identity Card
- Metro Smart Card
- Digital Certificate Card

(F) Token Authentication

इसमें विशेष सुरक्षा उपकरण (Hardware Token) या Software Token का उपयोग किया जाता है।

उदाहरण

- RSA Security Token
- Google Authenticator

- Microsoft Authenticator
-

(G) Certificate-Based Authentication

इसमें Digital Certificate का उपयोग किया जाता है।

उदाहरण

- सरकारी वेबसाइट
 - VPN
 - HTTPS Server Authentication
 - डिजिटल हस्ताक्षर (Digital Signature)
-

6. Authentication के तीन प्रमुख कारक (Authentication Factors)

(1) Something You Know (जो आपको ज्ञात है)

- Password
- PIN
- Security Question

उदाहरण: Gmail का Password।

(2) Something You Have (जो आपके पास है)

- ATM Card
- Mobile Phone
- Smart Card
- Security Token

उदाहरण: बैंक OTP प्राप्त करने वाला मोबाइल।

(3) Something You Are (जो आप हैं)

- Fingerprint

- Face
- Iris
- Voice

उदाहरण: मोबाइल का Face Unlock।

7. Multi-Factor Authentication (MFA)

जब उपयोगकर्ता की पहचान सत्यापित करने के लिए दो या दो से अधिक Authentication Factors का उपयोग किया जाता है, तो इसे **Multi-Factor Authentication (MFA)** कहते हैं।

उदाहरण

उदाहरण 1 : नेट बैंकिंग

1. Username
2. Password
3. OTP

तीनों के सही होने पर ही लॉगिन संभव होता है।

उदाहरण 2 : ATM

1. ATM Card
2. PIN

उदाहरण 3 : स्मार्टफोन

1. Fingerprint
2. PIN

8. Authentication बनाम Authorization

आधार Authentication Authorization

अर्थ पहचान की पुष्टि अधिकार प्रदान करना

उद्देश्य "आप कौन हैं?" "आप क्या कर सकते हैं?"

आधार Authentication Authorization

क्रम पहले होता है बाद में होता है

उदाहरण Password, OTP Read, Write, Delete Permission

उदाहरण

एक विश्वविद्यालय ERP में—

- शिक्षक (Teacher) अपना Username और Password दर्ज करता है। यह **Authentication** है।
- सफल प्रमाणीकरण के बाद वह केवल छात्रों के अंक दर्ज कर सकता है, लेकिन फीस रिकॉर्ड नहीं बदल सकता। यह **Authorization** है।

9. Authentication के लाभ

- डेटा की सुरक्षा बढ़ती है।
- अनधिकृत प्रवेश रोका जाता है।
- पहचान की पुष्टि होती है।
- साइबर हमलों का जोखिम कम होता है।
- ऑनलाइन बैंकिंग सुरक्षित होती है।
- सरकारी सेवाओं में पारदर्शिता बढ़ती है।
- डिजिटल लेन-देन अधिक सुरक्षित बनते हैं।
- उपयोगकर्ता की गोपनीयता (Privacy) सुरक्षित रहती है।

10. Authentication की सीमाएँ

- कमजोर Password होने पर सुरक्षा कम हो जाती है।
- Phishing Attack से उपयोगकर्ता धोखा खा सकता है।
- OTP SIM Swap Attack का शिकार हो सकता है।
- Biometric Sensor खराब होने पर प्रमाणीकरण कठिन हो सकता है।
- हार्डवेयर Token खो जाने पर असुविधा हो सकती है।

11. वास्तविक जीवन के उदाहरण

उदाहरण 1 : ATM

- कार्ड डालना → पहचान का पहला चरण।
- PIN दर्ज करना → प्रमाणीकरण।
- सही PIN होने पर लेन-देन की अनुमति।

उदाहरण 2 : Gmail Login

- Username दर्ज करना।
- Password दर्ज करना।
- OTP (यदि 2-Step Verification चालू हो)।
- सफल सत्यापन के बाद ई-मेल तक पहुँच।

उदाहरण 3 : आधार आधारित उपस्थिति

- कर्मचारी Fingerprint स्कैन करता है।
- सिस्टम आधार डेटाबेस से मिलान करता है।
- पहचान सही होने पर उपस्थिति दर्ज हो जाती है।

उदाहरण 4 : विश्वविद्यालय ERP

- छात्र अपना Enrollment Number और Password दर्ज करता है।
- प्रमाणीकरण सफल होने पर वह केवल अपना परिणाम, उपस्थिति और प्रोफाइल देख सकता है।

12. निष्कर्ष (Conclusion)

Authentication किसी भी सूचना प्रणाली की सुरक्षा का मूल आधार है। यह सुनिश्चित करता है कि केवल वही व्यक्ति या डिवाइस किसी सिस्टम में प्रवेश करे जिसकी पहचान सत्यापित हो चुकी है। आधुनिक समय में केवल पासवर्ड आधारित प्रमाणीकरण पर्याप्त नहीं माना जाता; इसलिए **Multi-Factor Authentication (MFA)**, **Biometric Authentication** तथा **OTP आधारित प्रमाणीकरण** का उपयोग तेजी से बढ़ रहा है। बैंकिंग, ई-गवर्नेंस, क्लाउड सेवाओं, विश्वविद्यालय पोर्टलों और कॉर्पोरेट नेटवर्क में Authentication अनिवार्य सुरक्षा तंत्र है, जो डेटा की गोपनीयता, अखंडता और सुरक्षित पहुँच सुनिश्चित करने में महत्वपूर्ण भूमिका निभाता है।

परीक्षा की दृष्टि से महत्वपूर्ण बिंदु

- Authentication की परिभाषा।
- Authentication के उद्देश्य।
- Authentication के प्रकार।
- Authentication के तीन प्रमुख कारक (Knowledge, Possession, Inherence Factors)।
- Multi-Factor Authentication (MFA) की अवधारणा।
- Authentication एवं Authorization में अंतर।
- ATM, नेट बैंकिंग, आधार और विश्वविद्यालय ERP जैसे वास्तविक जीवन के उदाहरण।



Authorization (प्राधिकरण / अधिकार प्रदान करना)

परिभाषा, उद्देश्य, प्रकार, कार्यप्रणाली एवं उदाहरण सहित विस्तृत अध्ययन

1. परिचय (Introduction)

किसी भी सुरक्षित कंप्यूटर प्रणाली (Computer System), नेटवर्क (Network), वेबसाइट (Website), मोबाइल एप्लिकेशन (Mobile Application) या डेटाबेस (Database) में केवल उपयोगकर्ता की पहचान सत्यापित (Authentication) कर लेना ही पर्याप्त नहीं होता। यह भी आवश्यक है कि यह निर्धारित किया जाए कि वह उपयोगकर्ता कौन-कौन से कार्य कर सकता है और किन संसाधनों तक उसकी पहुँच (Access) होगी। इसी प्रक्रिया को **Authorization (प्राधिकरण)** कहा जाता है।

उदाहरण के लिए, किसी विश्वविद्यालय के ERP (Enterprise Resource Planning) सिस्टम में **प्राचार्य (Principal)**, **शिक्षक (Teacher)**, **लेखाकार (Accountant)** तथा **विद्यार्थी (Student)** सभी लॉगिन करते हैं। इन सभी की पहचान Authentication द्वारा सत्यापित की जाती है, परंतु सभी को समान अधिकार नहीं दिए जाते। प्राचार्य पूरे सिस्टम का प्रबंधन कर सकते हैं, शिक्षक केवल अंक एवं उपस्थिति दर्ज कर सकते हैं, लेखाकार केवल शुल्क (Fees) से संबंधित कार्य कर सकता है, जबकि विद्यार्थी केवल अपना परिणाम और प्रोफाइल देख सकता है। यह अधिकारों का निर्धारण ही Authorization है।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

2. Authorization की परिभाषा (Definition)

Authorization (प्राधिकरण) वह प्रक्रिया है जिसके द्वारा यह निर्धारित किया जाता है कि सफलतापूर्वक प्रमाणित (Authenticated) उपयोगकर्ता को कौन-कौन से संसाधनों (Resources) और कार्यों (Operations) की अनुमति दी जाएगी।

सरल शब्दों में—

"Authentication यह सिद्ध करता है कि आप कौन हैं, जबकि Authorization यह निर्धारित करता है कि आप क्या कर सकते हैं।"

3. Authorization की आवश्यकता (Need of Authorization)

यदि सभी उपयोगकर्ताओं को समान अधिकार दे दिए जाएँ, तो डेटा की सुरक्षा समाप्त हो जाएगी। Authorization निम्न कारणों से आवश्यक है—

- संवेदनशील डेटा को सुरक्षित रखने के लिए।
- केवल अधिकृत व्यक्तियों को आवश्यक कार्य करने की अनुमति देने के लिए।
- डेटा में अनधिकृत परिवर्तन रोकने के लिए।
- गोपनीय जानकारी की सुरक्षा के लिए।
- संगठन की सुरक्षा नीति (Security Policy) लागू करने के लिए।
- प्रत्येक कर्मचारी को उसके कार्य के अनुसार सीमित अधिकार देने के लिए (Principle of Least Privilege)।
- साइबर हमलों और आंतरिक दुरुपयोग (Insider Threat) को कम करने के लिए।

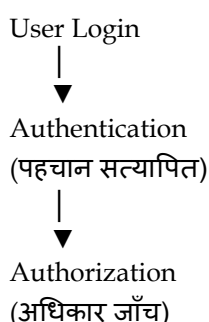
4. Authorization कैसे कार्य करता है? (Working of Authorization)

Authorization सामान्यतः Authentication के बाद कार्य करता है।

प्रक्रिया

1. उपयोगकर्ता अपना Username और Password दर्ज करता है।
2. सिस्टम Authentication द्वारा उसकी पहचान सत्यापित करता है।
3. सिस्टम उपयोगकर्ता की भूमिका (Role), समूह (Group) या Access Policy की जाँच करता है।
4. निर्धारित अधिकारों के अनुसार संसाधनों तक पहुँच प्रदान करता है।
5. उपयोगकर्ता केवल उन्हीं कार्यों को कर सकता है जिनकी अनुमति उसे दी गई है।

कार्यप्रवाह (Flow)



5. Authorization के प्रमुख तत्व (Elements)

(1) User (उपयोगकर्ता)

जिसे सिस्टम का उपयोग करना है।

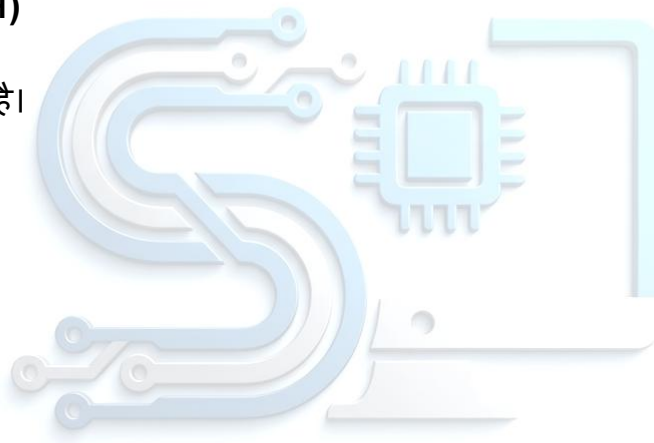
उदाहरण: शिक्षक, छात्र, कर्मचारी।

(2) Resource (संसाधन)

जिस पर कार्य किया जाना है।

उदाहरण:

- Database
- File
- Printer
- Application
- Server



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

(3) Permission (अनुमति)

संसाधन पर कौन-सा कार्य किया जा सकता है।

जैसे—

- Read (पढ़ना)
 - Write (लिखना)
 - Update (संशोधन)
 - Delete (हटाना)
 - Execute (चलाना)
-

(4) Policy (नीति)

6. Authorization के प्रकार (Types of Authorization)

(A) Role-Based Access Control (RBAC)

इस प्रणाली में अधिकार उपयोगकर्ता की भूमिका (Role) के आधार पर दिए जाते हैं।

उदाहरण

विद्यालय ERP –

भूमिका	अधिकार
Principal	सभी कार्य
Teacher	उपस्थिति एवं अंक दर्ज करना
Accountant	फीस प्रबंधन
Student	परिणाम देखना

RBAC बड़े संगठनों में सबसे अधिक उपयोग किया जाता है।

(B) Discretionary Access Control (DAC)

इसमें किसी फ़ाइल या संसाधन का स्वामी (Owner) यह तय करता है कि किसे अनुमति दी जाए।

उदाहरण

आपने अपने कंप्यूटर में एक फ़ोल्डर बनाया।

आपने उसे केवल दो कर्मचारियों के साथ साझा किया।

यह DAC है।

(C) Mandatory Access Control (MAC)

इसमें अधिकार सरकार या संगठन द्वारा निर्धारित सुरक्षा स्तर (Security Level) के आधार पर दिए जाते हैं।

उदाहरण

भारतीय सेना, रक्षा मंत्रालय तथा परमाणु अनुसंधान संस्थानों में—

- Top Secret
- Secret
- Confidential
- Restricted

के आधार पर पहुँच दी जाती है।

(D) Attribute-Based Access Control (ABAC)

इसमें निर्णय कई विशेषताओं (Attributes) के आधार पर लिया जाता है।

जैसे—

- समय (Time)
- स्थान (Location)
- विभाग (Department)
- डिवाइस
- IP Address

उदाहरण

कंपनी का नियम—

- केवल कार्यालय नेटवर्क से Login की अनुमति।
- रात 10 बजे के बाद Login निषिद्ध।

7. Authorization के स्तर (Levels)

File Level Authorization

किसी विशेष फ़ाइल तक पहुँच।

Folder Level Authorization

पूरे फ़ोल्डर की अनुमति।

Database Authorization

Database Table तक पहुँच।

Network Authorization

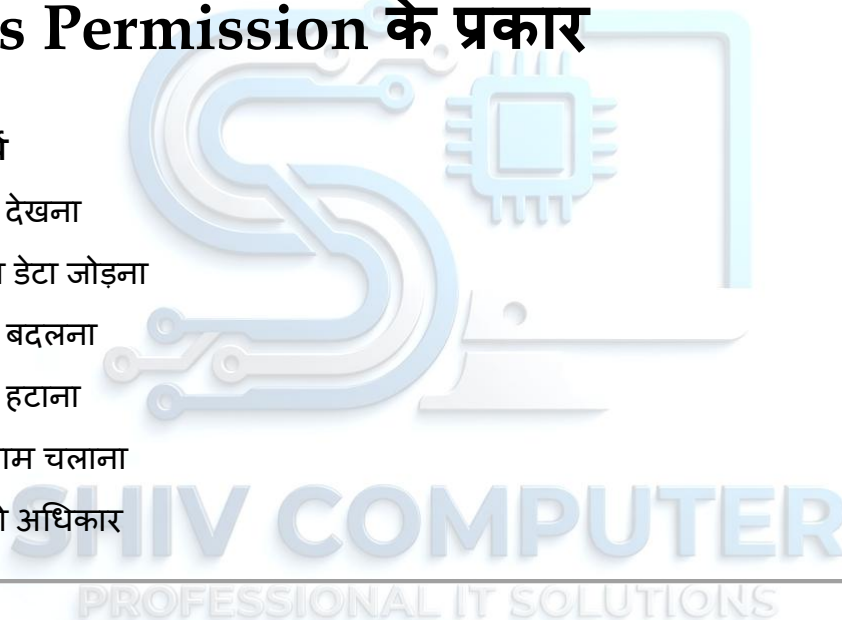
नेटवर्क संसाधनों का उपयोग।

Application Authorization

किसी विशेष एप्लिकेशन के Feature का उपयोग।

8. Access Permission के प्रकार

अनुमति	कार्य
Read	डेटा देखना
Write	नया डेटा जोड़ना
Modify	डेटा बदलना
Delete	डेटा हटाना
Execute	प्रोग्राम चलाना
Full Control	सभी अधिकार



9. वास्तविक जीवन के उदाहरण

उदाहरण 1 : विश्वविद्यालय ERP

Principal

- छात्र जोड़ना
- शिक्षक जोड़ना
- फीस देखना
- परिणाम प्रकाशित करना

Teacher

- केवल अंक दर्ज करना
- उपस्थिति भरना

Student

- केवल अपना Result देखना

यह Authorization है।

उदाहरण 2 : बैंक

ग्राहक

- अपना बैलेंस देख सकता है।
- पैसे निकाल सकता है।
- अपने खाते में राशि जमा कर सकता है।

बैंक कर्मचारी

- ग्राहक के खाते की जानकारी अपडेट कर सकता है।

बैंक प्रबंधक

- ऋण स्वीकृत कर सकता है।
 - बड़े लेन-देन को अनुमोदित कर सकता है।
-

उदाहरण 3 : Windows Operating System

यदि आप Administrator हैं—

- Software Install कर सकते हैं।
- Driver Install कर सकते हैं।
- User Account बना सकते हैं।

यदि आप Standard User हैं—

- केवल सामान्य कार्य कर सकते हैं।
- सिस्टम सेटिंग्स नहीं बदल सकते।

उदाहरण 4 : Google Drive

यदि किसी फ़ाइल पर—

- **Viewer** अधिकार है → केवल देख सकते हैं।
- **Commenter** अधिकार है → टिप्पणी कर सकते हैं।
- **Editor** अधिकार है → संपादन कर सकते हैं।

10. Authorization के लाभ

- डेटा सुरक्षित रहता है।
- अनधिकृत पहुँच रोकी जाती है।
- कार्यों का स्पष्ट विभाजन होता है।
- सुरक्षा नीति लागू करना आसान होता है।
- डेटा में अनावश्यक परिवर्तन नहीं होते।
- कर्मचारियों की जिम्मेदारी स्पष्ट रहती है।
- Insider Threat का जोखिम कम होता है।
- संगठन का नियंत्रण बेहतर होता है।

11. Authorization की सीमाएँ

- गलत Permission Configuration से सुरक्षा खतरे में पड़ सकती है।
- बड़े संगठनों में Permission Management जटिल हो सकता है।
- यदि Administrator गलती से अधिक अधिकार दे दे, तो डेटा का दुरुपयोग संभव है।
- Roles और Policies को समय-समय पर अपडेट करना आवश्यक होता है।

12. Authentication एवं Authorization में अंतर

आधार Authentication (प्रमाणीकरण)

अर्थ उपयोगकर्ता की पहचान सत्यापित करना

Authorization (प्राधिकरण)

उपयोगकर्ता को अधिकार प्रदान करना

आधार Authentication (प्रमाणीकरण)

उद्देश्य "आप कौन हैं?"

क्रम पहले होता है

आधार Username, Password, OTP, Fingerprint Role, Permission, Policy

परिणाम पहचान सत्यापित

Authorization (प्राधिकरण)

"आप क्या कर सकते हैं?"

बाद में होता है

कार्य करने की अनुमति

13. परीक्षा हेतु महत्वपूर्ण उदाहरण

उदाहरण 1 : ATM

- ATM Card + PIN → Authentication
- केवल अपने खाते से पैसे निकालने की अनुमति → Authorization

उदाहरण 2 : नेट बैंकिंग

- Username + Password + OTP → Authentication
- Fund Transfer, Statement Download, Bill Payment जैसी अनुमतियाँ → Authorization

उदाहरण 3 : विद्यालय ERP

- छात्र Login करता है → Authentication
- छात्र केवल अपना परिणाम देख सकता है, अन्य छात्रों का नहीं → Authorization

उदाहरण 4 : अस्पताल प्रबंधन प्रणाली

- डॉक्टर Login करता है → Authentication
- डॉक्टर केवल अपने विभाग के मरीजों की रिपोर्ट देख और अपडेट कर सकता है → Authorization

14. निष्कर्ष (Conclusion)

Authorization किसी भी सुरक्षित सूचना प्रणाली का अत्यंत महत्वपूर्ण सुरक्षा तंत्र है। यह सुनिश्चित करता है कि प्रमाणित (Authenticated) उपयोगकर्ता केवल उन्हीं संसाधनों और कार्यों तक पहुँच प्राप्त करे जिनकी उसे

आवश्यकता और अनुमति है। आधुनिक संगठनों में **Role-Based Access Control (RBAC)**, **Attribute-Based Access Control (ABAC)** तथा **Mandatory Access Control (MAC)** जैसी प्रणालियाँ व्यापक रूप से उपयोग की जाती हैं। प्रभावी Authorization प्रणाली न केवल डेटा की सुरक्षा बढ़ाती है, बल्कि संगठन में कार्यों का स्पष्ट विभाजन, जवाबदेही (Accountability) तथा न्यूनतम विशेषाधिकार (Principle of Least Privilege) को भी सुनिश्चित करती है।

परीक्षा की दृष्टि से महत्वपूर्ण बिंदु

- Authorization की परिभाषा।
- Authorization की आवश्यकता एवं उद्देश्य।
- Authorization की कार्यप्रणाली।
- Authorization के प्रकार (RBAC, DAC, MAC, ABAC)।
- Access Permission (Read, Write, Modify, Delete, Execute)।
- Authentication एवं Authorization में अंतर।
- बैंक, विश्वविद्यालय ERP, Windows तथा Google Drive जैसे वास्तविक जीवन के उदाहरण।
- **Principle of Least Privilege (PoLP)** का महत्व और भूमिका।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Accountability

(उत्तरदायित्व / जवाबदेही)

1. परिचय (Introduction)

किसी भी सुरक्षित सूचना प्रणाली (Information System) में केवल उपयोगकर्ता की पहचान सत्यापित (Authentication) करना और उसे आवश्यक अधिकार (Authorization) देना ही पर्याप्त नहीं होता। यह भी आवश्यक है कि सिस्टम में होने वाली प्रत्येक गतिविधि (Activity) का रिकॉर्ड रखा जाए तथा यह सुनिश्चित किया जाए कि किसी विशेष कार्य के लिए कौन-सा उपयोगकर्ता उत्तरदायी (Responsible) है। इसी सिद्धांत को Accountability (उत्तरदायित्व या जवाबदेही) कहा जाता है।

आधुनिक साइबर सुरक्षा में Accountability का अत्यधिक महत्व है क्योंकि यह किसी भी घटना (Incident), त्रुटि (Error), डेटा चोरी (Data Breach) या साइबर अपराध (Cyber Crime) की स्थिति में यह पता लगाने में सहायता करती है कि किस उपयोगकर्ता ने, कब, कहाँ और कौन-सा कार्य किया।

2. Accountability की परिभाषा (Definition)

Accountability (उत्तरदायित्व) वह सुरक्षा सिद्धांत है जिसके अनुसार किसी सूचना प्रणाली में किए गए प्रत्येक कार्य (Action) को किसी विशिष्ट उपयोगकर्ता (Specific User) से जोड़ा जा सके और आवश्यकता पड़ने पर उस कार्य के लिए उसे उत्तरदायी (Responsible) ठहराया जा सके।

सरल शब्दों में—

"किसी भी डिजिटल कार्य के लिए जिम्मेदार व्यक्ति की पहचान सुनिश्चित करना और उसके कार्यों का रिकॉर्ड रखना ही Accountability कहलाता है।"

3. Accountability की आवश्यकता (Need of Accountability)

यदि किसी संगठन में Accountability न हो, तो यह पता लगाना कठिन हो जाएगा कि—

- किसने डेटा देखा?

- किसने फ़ाइल बदली?
- किसने रिकॉर्ड हटाया?
- किसने सिस्टम में लॉगिन किया?
- किसने सुरक्षा नियमों का उल्लंघन किया?

ऐसी स्थिति में किसी भी घटना की जाँच (Investigation) और दोषी व्यक्ति की पहचान करना लगभग असंभव हो जाएगा।

4. Accountability के उद्देश्य (Objectives)

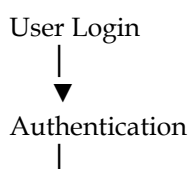
- प्रत्येक उपयोगकर्ता की गतिविधियों का रिकॉर्ड रखना।
- डेटा में अनधिकृत परिवर्तन करने वाले व्यक्ति की पहचान करना।
- साइबर अपराधों की जाँच में सहायता करना।
- संगठन में अनुशासन और पारदर्शिता बनाए रखना।
- उपयोगकर्ताओं को जिम्मेदारी के साथ कार्य करने के लिए प्रेरित करना।
- कानूनी एवं नियामक आवश्यकताओं (Compliance) का पालन करना।
- डिजिटल फॉरेंसिक (Digital Forensics) के लिए साक्ष्य उपलब्ध कराना।

5. Accountability कैसे कार्य करती है? (Working of Accountability)

Accountability सामान्यतः निम्न चरणों के माध्यम से कार्य करती है—

1. उपयोगकर्ता सिस्टम में Login करता है (Authentication)।
2. उसे आवश्यक अधिकार दिए जाते हैं (Authorization)।
3. उपयोगकर्ता द्वारा किया गया प्रत्येक कार्य सिस्टम Log में दर्ज किया जाता है।
4. Log में समय (Time), तिथि (Date), उपयोगकर्ता (User), IP Address तथा गतिविधि (Activity) का विवरण सुरक्षित रहता है।
5. किसी घटना की स्थिति में इन्हीं Logs का विश्लेषण करके जिम्मेदार व्यक्ति की पहचान की जाती है।

कार्यप्रवाह (Flow)



Authorization



User Activity



Audit Log / System Log



Investigation & Accountability

6. Accountability के प्रमुख घटक (Components)

(1) Unique User ID (विशिष्ट उपयोगकर्ता पहचान)

प्रत्येक उपयोगकर्ता का अलग User ID होना चाहिए।

उदाहरण:

- Teacher01
- Student1025
- Admin01

यदि सभी लोग एक ही User ID का उपयोग करें, तो Accountability समाप्त हो जाएगी।

(2) Authentication

सिस्टम को पहले यह सुनिश्चित करना होता है कि लॉगिन करने वाला व्यक्ति वास्तविक उपयोगकर्ता ही है।

उदाहरण:

- Username + Password
- OTP
- Fingerprint

(3) Authorization

Authentication के बाद उपयोगकर्ता को उसके कार्य के अनुसार अधिकार दिए जाते हैं।

(4) Audit Log

Audit Log वह रिकॉर्ड है जिसमें प्रत्येक गतिविधि सुरक्षित रहती है।

इसमें सामान्यतः निम्न जानकारी होती है—

- User ID
- Date
- Time
- IP Address
- Device Name
- Activity
- Result (Success / Failure)

(5) Monitoring

सिस्टम की गतिविधियों पर निरंतर निगरानी रखी जाती है।

7. Accountability के उदाहरण

उदाहरण 1 : विश्वविद्यालय ERP

मान लीजिए एक विश्वविद्यालय के ERP सिस्टम में तीन उपयोगकर्ता हैं—

- Principal
- Teacher
- Student

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

यदि Teacher ने छात्र के अंक बदल दिए, तो Audit Log में रिकॉर्ड होगा—

समय उपयोगकर्ता कार्य

10:35 AM Teacher01 अंक संशोधित

अब यह स्पष्ट है कि अंक किसने बदले।

उदाहरण 2 : बैंक

एक बैंक कर्मचारी ने ग्राहक के खाते का पता बदल दिया।

System Log में रिकॉर्ड—

User : Employee105
Time : 02:15 PM
Action : Address Updated
Branch : Kanpur

यदि विवाद उत्पन्न होता है, तो बैंक तुरंत जिम्मेदार कर्मचारी की पहचान कर सकता है।

उदाहरण 3 : अस्पताल

एक डॉक्टर ने मरीज की रिपोर्ट में संशोधन किया।

Log में दर्ज होगा—

- Doctor ID
- Date
- Time
- Patient ID
- Modified Record

इससे यह स्पष्ट रहेगा कि रिपोर्ट में परिवर्तन किसने किया।

उदाहरण 4 : Windows Operating System

Administrator ने नया Software Install किया।

Windows Event Log में रिकॉर्ड—

User : Administrator
Software : Antivirus
Time : 11:20 AM
Status : Installed Successfully

उदाहरण 5 : Google Workspace

यदि किसी कर्मचारी ने कंपनी की गोपनीय फ़ाइल Delete कर दी—

Google Admin Console में दर्ज होगा—

- किसने Delete किया।
- कब Delete किया।
- किस IP Address से किया।

8. Accountability सुनिश्चित करने के उपाय

(1) Unique User Account

प्रत्येक कर्मचारी का अलग User Account होना चाहिए।

(2) Strong Authentication

- Password
- OTP
- MFA
- Biometric

(3) Audit Logging

सभी गतिविधियों का रिकॉर्ड रखना।

(4) Access Control

केवल आवश्यक अधिकार देना।

(5) Regular Monitoring

Security Logs की नियमित समीक्षा करना।

(6) Digital Signature

महत्वपूर्ण दस्तावेज़ों पर Digital Signature का उपयोग करना।

(7) Time Synchronization

सभी सिस्टम का समय (Time) सही होना चाहिए ताकि Logs विश्वसनीय रहें।

9. Accountability के लाभ

- दोषी व्यक्ति की पहचान आसान होती है।
- साइबर अपराधों की जाँच में सहायता मिलती है।
- उपयोगकर्ता जिम्मेदारी से कार्य करते हैं।
- डेटा में अनधिकृत परिवर्तन कम होते हैं।
- संगठन में पारदर्शिता बढ़ती है।
- कानूनी साक्ष्य (Legal Evidence) उपलब्ध होते हैं।
- Digital Forensics को मजबूत आधार मिलता है।

10. Accountability की सीमाएँ

- यदि Logs सुरक्षित न हों, तो उन्हें बदला जा सकता है।
- अधिक Logs होने पर उनका विश्लेषण कठिन हो सकता है।
- गलत समय (Incorrect System Time) होने पर जाँच प्रभावित हो सकती है।
- Shared User ID होने पर वास्तविक जिम्मेदार व्यक्ति की पहचान कठिन हो जाती है।

11. Accountability, Authentication, Authorization और Auditing में अंतर

आधार	Authentication	Authorization	Accountability	Auditing
उद्देश्य	पहचान सत्यापित करना	अधिकार देना	जिम्मेदारी तय करना	गतिविधियों का रिकॉर्ड एवं समीक्षा
प्रश्न	आप कौन हैं?	आप क्या कर सकते हैं?	आपने क्या किया?	क्या हुआ और कब हुआ?
कार्य	Login	Access Control	Responsibility	Log Analysis
उदाहरण	Password	Read/Write Permission	User Action Tracking	Event Logs

12. वास्तविक जीवन का समेकित उदाहरण

मान लीजिए किसी विद्यालय के ERP सिस्टम में छात्र का परिणाम बिना अनुमति बदल दिया गया।

1. **Authentication** – शिक्षक ने Username और Password से लॉगिन किया।
2. **Authorization** – शिक्षक को केवल अंक दर्ज करने का अधिकार था।
3. **Accountability** – सिस्टम ने रिकॉर्ड किया कि Teacher01 ने 21 जुलाई 2026 को सुबह 10:35 बजे छात्र के अंक बदले।
4. **Auditing** – प्रशासक (Administrator) ने Audit Log की जाँच की और घटना की पुष्टि की।

इस प्रकार Accountability के कारण जिम्मेदार व्यक्ति की पहचान संभव हुई।

13. निष्कर्ष (Conclusion)

Accountability साइबर सुरक्षा का एक अत्यंत महत्वपूर्ण सिद्धांत है, जो यह सुनिश्चित करता है कि किसी भी सूचना प्रणाली में किए गए प्रत्येक कार्य के लिए जिम्मेदार व्यक्ति की पहचान की जा सके। यह सिद्धांत **Audit Logs, Unique User ID, Authentication, Authorization** तथा **Monitoring** पर आधारित होता है। बैंकिंग, ई-गवर्नेंस, अस्पताल, विश्वविद्यालय, क्लाउड सेवाओं तथा कॉर्पोरेट नेटवर्क में Accountability के बिना सुरक्षित और विश्वसनीय सूचना प्रणाली की कल्पना नहीं की जा सकती। यह केवल सुरक्षा ही नहीं, बल्कि पारदर्शिता (Transparency), उत्तरदायित्व (Responsibility) तथा डिजिटल फॉरेंसिक्स (Digital Forensics) के लिए भी अत्यंत आवश्यक है।

परीक्षा की दृष्टि से महत्वपूर्ण बिंदु

1. Accountability की परिभाषा एवं उद्देश्य।
2. Accountability की कार्यप्रणाली।
3. Accountability के प्रमुख घटक (Unique User ID, Authentication, Authorization, Audit Log, Monitoring)।
4. Accountability सुनिश्चित करने के उपाय।
5. Accountability के लाभ एवं सीमाएँ।
6. **Authentication, Authorization, Accountability और Auditing** में अंतर।
7. बैंक, विश्वविद्यालय ERP, अस्पताल और Windows Event Log जैसे वास्तविक जीवन के उदाहरण।

Availability (उपलब्धता)

1. परिचय (Introduction)

Availability (उपलब्धता) सूचना सुरक्षा (Information Security) और साइबर सुरक्षा (Cyber Security) के सबसे महत्वपूर्ण सिद्धांतों में से एक है। यह CIA Triad (Confidentiality, Integrity, Availability) का तीसरा और अत्यंत महत्वपूर्ण स्तंभ है।

किसी भी संगठन में केवल डेटा को गोपनीय (Confidential) और सही (Integrity) रखना पर्याप्त नहीं होता। यदि आवश्यकता के समय डेटा, नेटवर्क, सर्वर या कोई सेवा उपलब्ध (Available) ही न हो, तो वह संगठन अपना कार्य सही ढंग से नहीं कर पाएगा। इसलिए यह सुनिश्चित करना आवश्यक है कि अधिकृत (Authorized) उपयोगकर्ता जब भी किसी सूचना, सिस्टम या सेवा का उपयोग करना चाहें, वह बिना अनावश्यक विलंब (Delay) के उपलब्ध हो।

उदाहरण के लिए, यदि किसी बैंक का सर्वर कार्य समय के दौरान बंद हो जाए, तो ग्राहक न तो पैसे निकाल पाएंगे, न ही ऑनलाइन लेन-देन कर पाएंगे। इसी प्रकार यदि किसी अस्पताल का मरीज प्रबंधन सिस्टम (Hospital Management System) बंद हो जाए, तो डॉक्टर समय पर मरीजों का उपचार नहीं कर पाएंगे। ऐसी परिस्थितियों में Availability का महत्व स्पष्ट हो जाता है।

2. Availability की परिभाषा (Definition)

Availability (उपलब्धता) वह सुरक्षा सिद्धांत है जिसके अनुसार अधिकृत उपयोगकर्ताओं को आवश्यकता पड़ने पर सूचना (Information), सिस्टम (System), नेटवर्क (Network), एप्लिकेशन (Application) और सेवाएँ (Services) बिना बाधा के उपलब्ध हों।

सरल शब्दों में—

"जब आवश्यकता हो, तब सही समय पर सही उपयोगकर्ता को आवश्यक सूचना और सेवाएँ उपलब्ध कराना ही Availability कहलाता है।"

3. Availability के उद्देश्य (Objectives)

Availability का मुख्य उद्देश्य यह सुनिश्चित करना है कि—

- डेटा हमेशा उपलब्ध रहे।
- सर्वर और नेटवर्क लगातार कार्य करते रहें।
- उपयोगकर्ता बिना रुकावट सेवाओं का उपयोग कर सकें।
- सिस्टम में न्यूनतम Downtime हो।
- आपदा (Disaster) या हार्डवेयर खराब होने पर भी सेवाएँ शीघ्र पुनः चालू हो जाएँ।
- संगठन का कार्य निरंतर चलता रहे (Business Continuity)।

4. Availability का महत्व (Importance)

आज लगभग सभी सेवाएँ डिजिटल माध्यम पर निर्भर हैं। यदि कोई सेवा उपलब्ध न हो, तो संगठन को आर्थिक, सामाजिक तथा प्रतिष्ठात्मक (Reputational) नुकसान हो सकता है।

Availability का महत्व निम्न क्षेत्रों में विशेष रूप से देखा जाता है—

- बैंकिंग सेवाएँ
- अस्पताल
- रेलवे आरक्षण
- हवाई अड्डे
- ई-कॉमर्स वेबसाइट
- विश्वविद्यालय ERP
- क्लाउड सेवाएँ
- सरकारी पोर्टल
- मोबाइल बैंकिंग
- UPI भुगतान प्रणाली



5. Availability कैसे सुनिश्चित की जाती है? (How Availability is Maintained?)

Availability बनाए रखने के लिए अनेक तकनीकी उपाय अपनाए जाते हैं—

(1) Backup (बैकअप)

महत्वपूर्ण डेटा की नियमित प्रतिलिपि (Backup) बनाई जाती है ताकि डेटा नष्ट होने पर उसे पुनः प्राप्त किया जा सके।

उदाहरण

किसी विश्वविद्यालय का छात्र डेटाबेस प्रतिदिन रात 12 बजे Backup लिया जाता है।

यदि मुख्य Server खराब हो जाए तो Backup से डेटा पुनः प्राप्त किया जा सकता है।

(2) Redundancy (अतिरिक्त संसाधन)

एक ही सेवा के लिए एक से अधिक Server या उपकरण रखे जाते हैं।

उदाहरण

यदि मुख्य Web Server बंद हो जाए तो दूसरा Server स्वतः कार्य प्रारंभ कर देता है।

इसे Failover भी कहा जाता है।

(3) UPS एवं Power Backup

बिजली जाने पर UPS या Generator द्वारा Server चालू रखा जाता है।

उदाहरण

बैंक के Data Center में 24×7 UPS और Generator उपलब्ध रहते हैं।

(4) Disaster Recovery (आपदा पुनर्प्राप्ति)

प्राकृतिक या मानव-निर्मित आपदा के बाद सेवाओं को शीघ्र पुनः चालू करने की योजना।

उदाहरण

यदि Data Center में आग लग जाए तो दूसरा Disaster Recovery Site सक्रिय कर दी जाती है।

(5) नियमित Maintenance

हार्डवेयर, सॉफ्टवेयर और नेटवर्क का समय-समय पर रखरखाव किया जाता है।

(6) Load Balancing

जब किसी वेबसाइट पर बहुत अधिक उपयोगकर्ता आते हैं, तो उनके अनुरोध (Requests) कई Servers में बाँट दिए जाते हैं।

उदाहरण

Amazon या Flipkart की वेबसाइट पर त्योहारी सेल के दौरान लाखों उपयोगकर्ता एक साथ आते हैं। Load Balancer ट्रैफिक को कई Servers में विभाजित कर देता है।

(7) RAID (Redundant Array of Independent Disks)

डेटा को कई Hard Disks में सुरक्षित रखा जाता है ताकि एक Disk खराब होने पर भी डेटा उपलब्ध रहे।

6. Availability को प्रभावित करने वाले खतरे (Threats to Availability)

(A) DDoS Attack (Distributed Denial of Service)

इस हमले में लाखों नकली Requests भेजकर Server को व्यस्त कर दिया जाता है, जिससे वास्तविक उपयोगकर्ता सेवा का उपयोग नहीं कर पाते।

उदाहरण

यदि किसी बैंक की वेबसाइट पर DDoS Attack हो जाए, तो ग्राहक लॉगिन नहीं कर पाएँगे।

(B) Hardware Failure

Hard Disk, RAM, Server या Router खराब हो जाना।

(C) Software Failure

Bug, Crash या Operating System Failure।

(D) Power Failure

बिजली चले जाने से Server बंद हो सकता है।

(E) Natural Disaster

- भूकंप
 - बाढ़
 - आग
 - तूफान
-

(F) Ransomware Attack

हमलावर डेटा को Encrypt कर देता है और उपयोगकर्ता अपने डेटा तक पहुँच नहीं बना पाते।

7. Availability बनाए रखने के उपाय

- नियमित Backup लेना।
 - UPS एवं Generator का उपयोग।
 - Redundant Servers स्थापित करना।
 - RAID Storage का उपयोग।
 - Firewall एवं Intrusion Prevention System (IPS) का उपयोग।
 - DDoS Protection लागू करना।
 - समय-समय पर Software Update करना।
 - Disaster Recovery Plan तैयार रखना।
 - Cloud Backup रखना।
 - नियमित Monitoring करना।
-

8. वास्तविक जीवन के उदाहरण

उदाहरण 1 : बैंक

एक बैंक का ATM Server 24 घंटे चालू रहता है।

यदि Server बंद हो जाए—

- ग्राहक पैसे नहीं निकाल पाएँगे।
- Balance Check नहीं होगा।
- UPI भुगतान प्रभावित होगा।

इसलिए बैंक Backup Server और UPS का उपयोग करता है।

उदाहरण 2 : अस्पताल

अस्पताल में मरीजों की रिपोर्ट Online Server पर संग्रहीत है।

यदि Server बंद हो जाए—

- डॉक्टर रिपोर्ट नहीं देख पाएँगे।
- उपचार में विलंब होगा।

इसलिए अस्पताल High Availability Server का उपयोग करता है।

उदाहरण 3 : रेलवे आरक्षण

त्योहारों के समय लाखों लोग एक साथ टिकट बुक करते हैं।

यदि Website बंद हो जाए, तो टिकट बुकिंग रुक जाएगी।

इसलिए रेलवे Load Balancer और Multiple Servers का उपयोग करता है।

उदाहरण 4 : विश्वविद्यालय ERP

परीक्षा परिणाम घोषित होने के दिन लाखों छात्र एक साथ लॉगिन करते हैं।

यदि Server Crash हो जाए, तो छात्र परिणाम नहीं देख पाएँगे।

इसलिए अतिरिक्त Servers एवं Load Balancing का उपयोग किया जाता है।

उदाहरण 5 : Cloud Storage

Google Drive या OneDrive जैसी सेवाओं में डेटा अनेक Data Centers में संग्रहीत रहता है।

यदि एक Data Center बंद हो जाए, तो दूसरा Data Center सेवा प्रदान करता है।

9. Availability के लाभ

- सेवाएँ निरंतर उपलब्ध रहती हैं।
- उपयोगकर्ताओं का विश्वास बढ़ता है।
- व्यापार में रुकावट नहीं आती।
- आर्थिक नुकसान कम होता है।
- आपदा के बाद शीघ्र पुनः कार्य प्रारंभ हो जाता है।
- ग्राहक संतुष्टि बढ़ती है।
- संगठन की प्रतिष्ठा सुरक्षित रहती है।

10. Availability की सीमाएँ

- High Availability Infrastructure महँगा होता है।
- Backup एवं Redundancy बनाए रखना कठिन हो सकता है।
- कई Servers के कारण रखरखाव (Maintenance) का खर्च बढ़ता है।
- DDoS जैसे बड़े हमलों से पूर्ण सुरक्षा चुनौतीपूर्ण होती है।

11. Availability, Confidentiality एवं Integrity में अंतर

आधार	Confidentiality (गोपनीयता)	Integrity (अखंडता)	Availability (उपलब्धता)
उद्देश्य	डेटा को अनधिकृत पहुँच से डेटा को सही एवं अपरिवर्तित आवश्यकता पड़ने पर डेटा बचाना	रखना	उपलब्ध रखना

आधार	Confidentiality (गोपनीयता)	Integrity (अखंडता)	Availability (उपलब्धता)
मुख्य प्रश्न कौन देख सकता है?		डेटा सही है या नहीं?	डेटा उपलब्ध है या नहीं?
सुरक्षा उपाय	Encryption, Control	Access Hashing, Digital Signature	Backup, Redundancy, UPS
उदाहरण	बैंक खाते की जानकारी सुरक्षित परीक्षा परीणाम में अनधिकृत रखना	बदलाव रोकना	बैंक सर्वर को 24×7 चालू रखना

12. परीक्षा हेतु समेकित उदाहरण

मान लीजिए किसी विश्वविद्यालय का ERP सिस्टम है—

- छात्र केवल अपना परिणाम देख सकते हैं। → **Confidentiality**
- परिणाम में बिना अनुमति कोई बदलाव नहीं कर सकता। → **Integrity**
- परिणाम घोषित होने के दिन वेबसाइट बिना रुके सभी छात्रों को उपलब्ध रहती है। → **Availability**

इस प्रकार CIA Triad के तीनों सिद्धांत मिलकर सूचना सुरक्षा सुनिश्चित करते हैं।

13. निष्कर्ष (Conclusion)

Availability सूचना सुरक्षा का एक मूलभूत सिद्धांत है, जिसका उद्देश्य यह सुनिश्चित करना है कि अधिकृत उपयोगकर्ताओं को आवश्यकता पड़ने पर सूचना, सिस्टम और सेवाएँ बिना बाधा के उपलब्ध रहें। आधुनिक संगठनों में Backup, Redundancy, Load Balancing, RAID, Disaster Recovery, Cloud Infrastructure तथा High Availability Architecture जैसी तकनीकों का उपयोग करके सेवाओं की निरंतर उपलब्धता सुनिश्चित की जाती है। यदि किसी संगठन में Availability पर पर्याप्त ध्यान न दिया जाए, तो डेटा सुरक्षित होने के बावजूद उसका उपयोग समय पर नहीं हो सकेगा, जिससे आर्थिक, परिचालन (Operational) और प्रतिष्ठात्मक नुकसान हो सकता है।

परीक्षा की दृष्टि से महत्वपूर्ण बिंदु

1. Availability की परिभाषा।
2. Availability का उद्देश्य एवं महत्व।

3. Availability बनाए रखने के उपाय (Backup, Redundancy, UPS, RAID, Load Balancing, Disaster Recovery)।
4. Availability को प्रभावित करने वाले खतरे (DDoS, Hardware Failure, Power Failure, Natural Disaster, Ransomware)।
5. Availability, Confidentiality एवं Integrity में अंतर।
6. बैंक, अस्पताल, रेलवे, विश्वविद्यालय ERP तथा Cloud Services के वास्तविक उदाहरण।
7. **High Availability (HA), Failover, Business Continuity और Disaster Recovery** की अवधारणाएँ तथा उनका महत्व।



Confidentiality (गोपनीयता)

परिभाषा, उद्देश्य, सिद्धांत, तकनीकें, महत्व, खतरे एवं उदाहरण सहित
विस्तृत अध्ययन

अध्याय की रूपरेखा

1. परिचय (Introduction)
2. Confidentiality की परिभाषा
3. Confidentiality का अर्थ
4. Confidentiality के उद्देश्य
5. Confidentiality का महत्व
6. Confidentiality कैसे कार्य करती है?
7. Confidentiality के मूल सिद्धांत
8. Confidentiality बनाए रखने की तकनीकें
9. Access Control
10. Encryption
11. Password Security
12. Multi-Factor Authentication (MFA)
13. Biometric Authentication
14. Data Classification
15. Need-to-Know Principle
16. Principle of Least Privilege (PoLP)
17. Non-Disclosure Agreement (NDA)
18. Physical Security
19. Network Security
20. Cloud Confidentiality
21. Database Confidentiality
22. Mobile Device Confidentiality
23. Email Confidentiality
24. Confidentiality पर खतरे
25. Confidentiality के उल्लंघन के परिणाम
26. Confidentiality बनाए रखने के सर्वोत्तम उपाय
27. वास्तविक जीवन के उदाहरण
28. Confidentiality, Privacy एवं Secrecy में अंतर
29. Confidentiality, Integrity एवं Availability में अंतर
30. निष्कर्ष
31. परीक्षा हेतु महत्वपूर्ण बिंदु

1. परिचय (Introduction)

Confidentiality (गोपनीयता) सूचना सुरक्षा (Information Security) का सबसे महत्वपूर्ण सिद्धांत है। यह CIA Triad (Confidentiality, Integrity, Availability) का पहला स्तंभ है। इसका मुख्य उद्देश्य यह सुनिश्चित करना है कि संवेदनशील (Sensitive) अथवा गोपनीय (Confidential) जानकारी केवल उन्हीं व्यक्तियों को उपलब्ध हो जिन्हें उसे देखने या उपयोग करने का अधिकार (Authorization) प्राप्त है।

आज के डिजिटल युग में सरकार, बैंक, अस्पताल, विश्वविद्यालय, रक्षा संस्थान, उद्योग, ई-कॉमर्स कंपनियाँ और क्लाउड सेवाएँ प्रतिदिन करोड़ों संवेदनशील सूचनाओं का आदान-प्रदान करती हैं। यदि यह जानकारी गलत व्यक्ति के हाथ लग जाए तो आर्थिक हानि, प्रतिष्ठा की क्षति, कानूनी कार्रवाई तथा राष्ट्रीय सुरक्षा तक प्रभावित हो सकती है। इसलिए Confidentiality किसी भी सूचना सुरक्षा नीति (Information Security Policy) का आधार है।

2. Confidentiality की परिभाषा (Definition)

Confidentiality वह सुरक्षा सिद्धांत है जिसके अनुसार सूचना (Information), डेटा (Data) अथवा संसाधन (Resource) केवल अधिकृत (Authorized) व्यक्तियों द्वारा ही देखे, उपयोग किए या साझा किए जा सकते हैं।

सरल परिभाषा

"सूचना को अनधिकृत (Unauthorized) व्यक्तियों की पहुँच, उपयोग या प्रकटीकरण (Disclosure) से सुरक्षित रखना ही Confidentiality कहलाता है।"

3. Confidentiality का अर्थ

Confidentiality का अर्थ केवल डेटा को छिपाना नहीं है, बल्कि यह सुनिश्चित करना है कि—

- सही व्यक्ति को सही समय पर सही सूचना मिले।
- गलत व्यक्ति सूचना तक पहुँच न बना सके।
- सूचना का अनधिकृत प्रकटीकरण न हो।
- सूचना का उपयोग केवल निर्धारित उद्देश्य के लिए हो।

4. Confidentiality के उद्देश्य (Objectives)

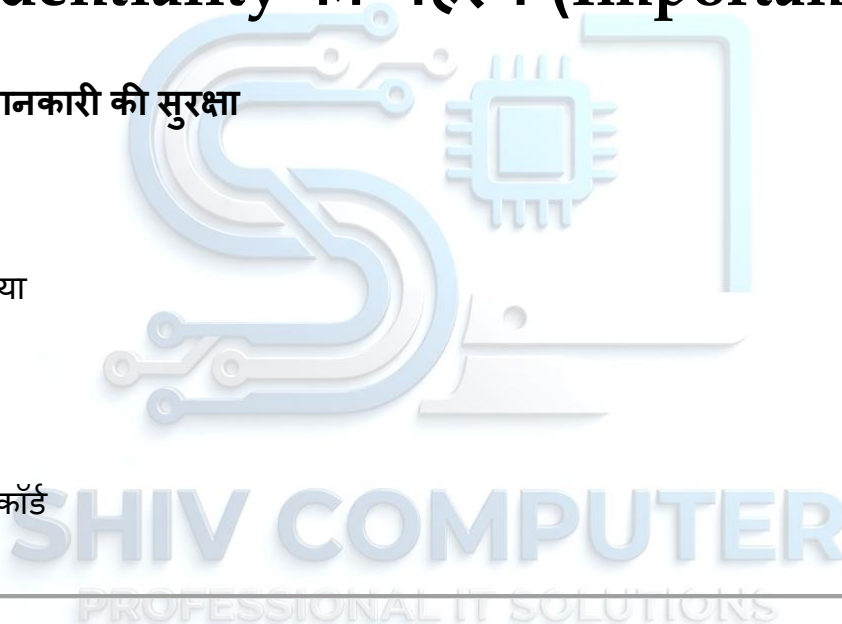
- गोपनीय जानकारी की सुरक्षा करना।
- अनधिकृत उपयोगकर्ताओं को डेटा तक पहुँचने से रोकना।
- व्यक्तिगत एवं व्यावसायिक गोपनीयता बनाए रखना।
- राष्ट्रीय सुरक्षा से संबंधित सूचनाओं की रक्षा करना।
- ग्राहकों के विश्वास को बनाए रखना।
- कानूनी एवं नियामकीय आवश्यकताओं (Compliance) का पालन करना।
- डेटा चोरी (Data Theft) और डेटा लीक (Data Leakage) को रोकना।

5. Confidentiality का महत्व (Importance)

(1) व्यक्तिगत जानकारी की सुरक्षा

उदाहरण—

- आधार संख्या
- पैन कार्ड
- बैंक खाता
- पासपोर्ट
- मेडिकल रिकॉर्ड



(2) व्यापारिक गोपनीयता

किसी कंपनी के—

- Source Code
- Financial Report
- Product Design
- ग्राहक सूची

यदि लीक हो जाएँ, तो कंपनी को भारी नुकसान हो सकता है।

(3) राष्ट्रीय सुरक्षा

सेना, रक्षा अनुसंधान, परमाणु कार्यक्रम एवं खुफिया एजेंसियों की जानकारी अत्यंत गोपनीय होती है।

(4) बैंकिंग सुरक्षा

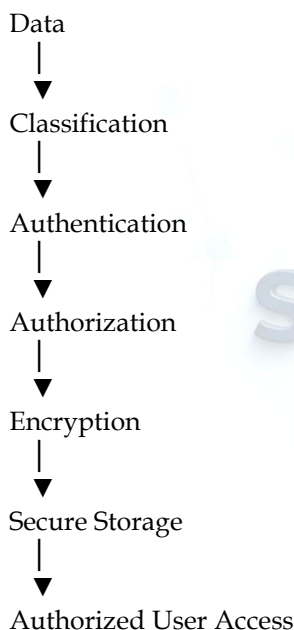
यदि बैंक ग्राहकों के खाते की जानकारी सार्वजनिक हो जाए, तो धोखाधड़ी (Fraud) बढ़ सकती है।

(5) चिकित्सा क्षेत्र

मरीजों की स्वास्थ्य रिपोर्ट गोपनीय रखी जाती है।

6. Confidentiality कैसे कार्य करती है?

Confidentiality बनाए रखने के लिए कई सुरक्षा उपाय एक साथ कार्य करते हैं।



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

7. Confidentiality के मूल सिद्धांत

(A) Authentication

पहले उपयोगकर्ता की पहचान सत्यापित की जाती है।

उदाहरण

(B) Authorization

पहचान सत्यापित होने के बाद यह तय किया जाता है कि उपयोगकर्ता क्या देख सकता है।

(C) Access Control

अनधिकृत उपयोगकर्ताओं को प्रवेश नहीं दिया जाता।

(D) Encryption

डेटा को इस प्रकार परिवर्तित किया जाता है कि बिना Key के उसे पढ़ा न जा सके।

(E) Monitoring

सिस्टम पर लगातार निगरानी रखी जाती है।

8. Confidentiality बनाए रखने की प्रमुख तकनीकें

8.1 Access Control

Access Control यह निर्धारित करता है कि कौन-सा उपयोगकर्ता किस संसाधन तक पहुँच सकता है।

उदाहरण

विद्यालय ERP में—

- छात्र → केवल अपना परिणाम।
 - शिक्षक → अंक दर्ज कर सकता है।
 - Principal → सभी रिकॉर्ड देख सकता है।
-

8.2 Encryption (एन्क्रिप्शन)

Encryption डेटा को Plain Text से Cipher Text में बदल देता है।

उदाहरण

Plain Text
Password123

↓

Cipher Text
A9\$Kx#82P@L

यदि कोई हमलावर डेटा चुरा भी ले, तो Key के बिना उसे पढ़ नहीं सकता।

8.3 Password Security

मजबूत Password गोपनीयता की पहली सुरक्षा है।

मजबूत Password की विशेषताएँ

- कम से कम 12-16 अक्षर
- बड़े और छोटे अक्षर
- अंक
- विशेष चिन्ह

उदाहरण

Shiv@2026#Cyber!

8.4 Multi-Factor Authentication (MFA)

Password के साथ OTP या Fingerprint का उपयोग।

उदाहरण

Net Banking

- Username
- Password
- OTP

8.5 Biometric Authentication

- Fingerprint
- Face Recognition
- Iris Scan

8.6 Digital Certificate

HTTPS, VPN एवं Digital Signature में उपयोग।

8.7 Data Masking

संवेदनशील डेटा का कुछ भाग छिपा दिया जाता है।

उदाहरण

9876543210

↓

987*****10

8.8 Tokenization

वास्तविक डेटा की जगह Token का उपयोग किया जाता है।

उदाहरण

Credit Card Number

5214 8754 6548 6542

↓

TKN-9XH53A

9. Data Classification

डेटा को उसकी संवेदनशीलता के आधार पर वर्गीकृत किया जाता है।

श्रेणी

विवरण

Public

सार्वजनिक जानकारी

श्रेणी	विवरण
Internal	केवल संस्था के लिए
Confidential	अधिकृत व्यक्तियों तक सीमित
Secret	अत्यंत संवेदनशील
Top Secret	राष्ट्रीय सुरक्षा स्तर की जानकारी

10. Need-to-Know Principle

किसी व्यक्ति को केवल वही जानकारी दी जाए जिसकी उसे वास्तव में आवश्यकता हो।

उदाहरण

विद्यालय में—

लेखाकार को छात्रों के स्वास्थ्य रिकॉर्ड देखने की आवश्यकता नहीं होती।

11. Principle of Least Privilege (PoLP)

प्रत्येक उपयोगकर्ता को केवल न्यूनतम आवश्यक अधिकार दिए जाएँ।

उदाहरण

शिक्षक परिणाम देख सकता है, लेकिन फीस रिकॉर्ड नहीं बदल सकता।

12. Non-Disclosure Agreement (NDA)

NDA एक कानूनी अनुबंध है जिसमें कर्मचारी यह वचन देता है कि वह संस्था की गोपनीय जानकारी किसी अन्य व्यक्ति को साझा नहीं करेगा।

13. Physical Security

Confidentiality केवल डिजिटल सुरक्षा तक सीमित नहीं है।

भौतिक सुरक्षा भी आवश्यक है।

- Server Room Lock
 - CCTV
 - Biometric Entry
 - Security Guard
-

14. Network Security

- Firewall
 - VPN
 - IDS
 - IPS
 - Secure Wi-Fi
 - TLS/SSL
-

15. Cloud Confidentiality

Cloud में डेटा सुरक्षित रखने हेतु—

- End-to-End Encryption
 - Identity and Access Management (IAM)
 - Cloud Access Control
 - Key Management
 - Backup
-

16. Database Confidentiality

- Database Encryption
 - Row-Level Security
 - Column-Level Security
 - Database Audit
 - User Privileges
-

17. Mobile Device Confidentiality

- Screen Lock
- Fingerprint
- Face Unlock

- Remote Wipe
 - Device Encryption
-

18. Email Confidentiality

- Email Encryption
 - Digital Signature
 - Spam Filter
 - Secure Attachment
 - S/MIME
 - PGP
-

19. Confidentiality पर प्रमुख खतरे (Threats)

बाहरी खतरे

- Hacking
- Phishing
- Malware
- Ransomware
- Spyware
- Password Attack
- Brute Force Attack
- Social Engineering

आंतरिक खतरे

- असंतुष्ट कर्मचारी
- गलत Permission
- Shared Password
- डेटा की लापरवाही से साझेदारी

भौतिक खतरे

- Laptop चोरी
 - Pen Drive खोना
 - दस्तावेज़ चोरी
 - Server Room में अनधिकृत प्रवेश
-

20. Confidentiality के उल्लंघन के परिणाम

- Data Leakage
- Identity Theft
- Financial Loss
- Reputation Damage
- Legal Action
- Customer Trust Loss
- Business Failure
- National Security Risk

21. Confidentiality बनाए रखने के सर्वोत्तम उपाय (Best Practices)

- मजबूत Password का उपयोग।
- Multi-Factor Authentication लागू करना।
- डेटा को Encrypt करना।
- नियमित Backup लेना।
- Access Control लागू करना।
- समय-समय पर Password बदलना।
- कर्मचारियों को Security Awareness Training देना।
- नियमित Security Audit करना।
- VPN का उपयोग करना।
- Public Wi-Fi पर संवेदनशील कार्य न करना।
- USB Device Control लागू करना।
- आवश्यकता से अधिक अधिकार (Privileges) न देना।
- संवेदनशील दस्तावेजों का सुरक्षित निस्तारण (Secure Disposal) करना।

22. वास्तविक जीवन के उदाहरण

उदाहरण 1 : बैंक

ग्राहक के खाते का बैलेंस केवल वही ग्राहक और अधिकृत बैंक अधिकारी देख सकते हैं।

यह Confidentiality है।

उदाहरण 2 : अस्पताल

मरीज की मेडिकल रिपोर्ट केवल डॉक्टर और मरीज देख सकते हैं।

उदाहरण 3 : विश्वविद्यालय

छात्र केवल अपना परिणाम देख सकता है।

दूसरे छात्रों का नहीं।

उदाहरण 4 : WhatsApp

End-to-End Encryption के कारण संदेश केवल भेजने वाला और प्राप्तकर्ता पढ़ सकते हैं।

उदाहरण 5 : सेना

सैन्य अभियान की जानकारी केवल अधिकृत अधिकारियों तक सीमित रहती है।

23. Confidentiality, Privacy एवं Secrecy में अंतर

आधार	Confidentiality	Privacy	Secrecy
अर्थ	अधिकृत व्यक्तियों तक सीमित रखना	जानकारी व्यक्ति की निजी जानकारी की सुरक्षा	जानकारी को पूरी तरह गुप्त रखना
उदाहरण	बैंक रिकॉर्ड	मेडिकल रिकॉर्ड	सैन्य योजना

24. Confidentiality, Integrity एवं Availability में अंतर

आधार Confidentiality**Integrity****Availability**

उद्देश्य डेटा को अनधिकृत पहुँच से बचना

डेटा की शुद्धता बनाए रखना

आवश्यकता पड़ने पर डेटा उपलब्ध रखना

प्रश्न कौन देख सकता है?

क्या डेटा सही है?

क्या डेटा उपलब्ध है?

उपाय Encryption, Access Control

Hashing, Signature

Digital Backup, Redundancy

25. निष्कर्ष (Conclusion)

Confidentiality सूचना सुरक्षा का मूल आधार है। इसका उद्देश्य केवल डेटा को छिपाना नहीं, बल्कि यह सुनिश्चित करना है कि संवेदनशील जानकारी केवल अधिकृत व्यक्तियों तक ही सीमित रहे। आधुनिक सूचना प्रणालियों में Authentication, Authorization, Access Control, Encryption, Multi-Factor Authentication, Data Classification, Need-to-Know Principle, Least Privilege, Cloud Security, Network Security, Database Security तथा Security Awareness जैसे अनेक उपाय मिलकर Confidentiality को मजबूत बनाते हैं। यदि गोपनीयता भंग हो जाती है, तो इससे आर्थिक हानि, प्रतिष्ठा की क्षति, कानूनी दंड और राष्ट्रीय सुरक्षा तक प्रभावित हो सकती है। इसलिए प्रत्येक संगठन को तकनीकी, प्रशासनिक तथा भौतिक सुरक्षा उपायों का समुचित उपयोग करके Confidentiality सुनिश्चित करनी चाहिए।

26. परीक्षा की दृष्टि से अत्यंत महत्वपूर्ण बिंदु

1. Confidentiality की परिभाषा एवं उद्देश्य।
2. CIA Triad में Confidentiality का स्थान।
3. Confidentiality बनाए रखने की तकनीकें (Encryption, Access Control, MFA, Data Masking, Tokenization)।
4. Data Classification एवं Need-to-Know Principle।
5. Principle of Least Privilege (PoLP)।
6. NDA (Non-Disclosure Agreement) का महत्व।
7. Cloud, Database, Network एवं Mobile Confidentiality।
8. Confidentiality पर प्रमुख खतरे एवं उनके समाधान।
9. Confidentiality, Privacy एवं Secrecy में अंतर।
10. Confidentiality, Integrity एवं Availability में अंतर।
11. बैंक, अस्पताल, विश्वविद्यालय, WhatsApp और सेना से संबंधित वास्तविक जीवन के उदाहरण।
12. परीक्षा में उत्तर लिखते समय परिभाषा, आरेख, सारणी और कम-से-कम 3-5 वास्तविक उदाहरण अवश्य लिखें, इससे उत्तर अधिक प्रभावशाली और पूर्ण माना जाता है।

Integrity (अखंडता / डेटा की शुद्धता)

अध्याय की रूपरेखा

1. परिचय (Introduction)
2. Integrity की परिभाषा
3. Integrity का अर्थ
4. Integrity के उद्देश्य
5. CIA Triad में Integrity का स्थान
6. Integrity का महत्व
7. Integrity कैसे कार्य करती है?
8. Integrity बनाए रखने के प्रमुख सिद्धांत
9. Integrity सुनिश्चित करने की तकनीकें
10. Hash Function
11. Checksum
12. Digital Signature
13. Message Authentication Code (MAC)
14. Database Integrity
15. File Integrity Monitoring (FIM)
16. Version Control
17. Backup एवं Recovery
18. Access Control
19. Audit Trail एवं Logging
20. Integrity पर खतरे
21. Integrity बनाए रखने के सर्वोत्तम उपाय
22. वास्तविक जीवन के उदाहरण
23. Confidentiality, Integrity एवं Availability में अंतर
24. निष्कर्ष
25. परीक्षा हेतु महत्वपूर्ण बिंदु

1. परिचय (Introduction)

Integrity (अखंडता) सूचना सुरक्षा (Information Security) का दूसरा प्रमुख सिद्धांत है तथा यह CIA Triad (Confidentiality, Integrity, Availability) का दूसरा स्तंभ है।

Confidentiality यह सुनिश्चित करती है कि डेटा केवल अधिकृत व्यक्ति ही देख सकें, जबकि Integrity यह सुनिश्चित करती है कि डेटा सही (Correct), पूर्ण (Complete), सटीक (Accurate) तथा अपरिवर्तित (Unaltered) रहे।

यदि किसी डेटा में बिना अनुमति (Unauthorized) परिवर्तन कर दिया जाए, कुछ जानकारी हटा दी जाए या गलत जानकारी जोड़ दी जाए, तो डेटा की अखंडता (Integrity) समाप्त हो जाती है। इसलिए किसी भी सूचना प्रणाली की विश्वसनीयता (Reliability) बनाए रखने के लिए Integrity अत्यंत आवश्यक है।

उदाहरण के लिए, यदि किसी विश्वविद्यालय के परीक्षा परिणाम में किसी छात्र के 75 अंक को बदलकर 95 कर दिया जाए, तो परिणाम की Integrity नष्ट हो जाएगी। इसी प्रकार यदि किसी बैंक खाते की शेष राशि (Balance) ₹10,000 से बदलकर ₹1,00,000 कर दी जाए, तो बैंकिंग प्रणाली पर से विश्वास समाप्त हो जाएगा।

2. Integrity की परिभाषा (Definition)

Integrity वह सुरक्षा सिद्धांत है जिसके अनुसार सूचना या डेटा को बिना अनुमति बदला, हटाया या नष्ट नहीं किया जा सकता तथा उसकी शुद्धता, पूर्णता और विश्वसनीयता बनी रहती है।

सरल परिभाषा

"डेटा को सही, पूर्ण और बिना अनधिकृत परिवर्तन के सुरक्षित रखना ही Integrity कहलाता है।"

3. Integrity का अर्थ

Integrity का अर्थ केवल डेटा को सुरक्षित रखना नहीं है, बल्कि यह सुनिश्चित करना भी है कि—

- डेटा सही (Correct) हो।
- डेटा पूर्ण (Complete) हो।
- डेटा में बिना अनुमति कोई परिवर्तन न हो।
- डेटा का स्रोत (Source) विश्वसनीय हो।
- डेटा आवश्यकता के अनुसार अद्यतन (Updated) हो।

4. Integrity के उद्देश्य (Objectives)

- डेटा की शुद्धता बनाए रखना।

- डेटा में अनधिकृत संशोधन रोकना।
- गलत जानकारी के उपयोग को रोकना।
- निर्णय लेने के लिए विश्वसनीय डेटा उपलब्ध कराना।
- कानूनी एवं व्यावसायिक विश्वसनीयता बनाए रखना।
- डिजिटल लेन-देन की प्रामाणिकता सुनिश्चित करना।

5. CIA Triad में Integrity का स्थान

CIA Triad के तीन सिद्धांत हैं—

- **Confidentiality** – डेटा को अनधिकृत पहुँच से सुरक्षित रखना।
- **Integrity** – डेटा को सही एवं अपरिवर्तित रखना।
- **Availability** – आवश्यकता पड़ने पर डेटा उपलब्ध रखना।

यदि Integrity समाप्त हो जाए, तो डेटा उपलब्ध होने और गोपनीय होने के बावजूद उसका कोई महत्व नहीं रहेगा।

6. Integrity का महत्व (Importance)

(1) बैंकिंग प्रणाली

यदि खाते का बैलेंस गलत हो जाए, तो वित्तीय नुकसान होगा।

(2) चिकित्सा क्षेत्र

यदि मरीज की दवा या रक्त समूह की जानकारी बदल जाए, तो गलत उपचार हो सकता है।

(3) शिक्षा

यदि परीक्षा परिणाम बदल दिए जाएँ, तो विद्यार्थियों के भविष्य पर प्रभाव पड़ेगा।

(4) ई-कॉमर्स

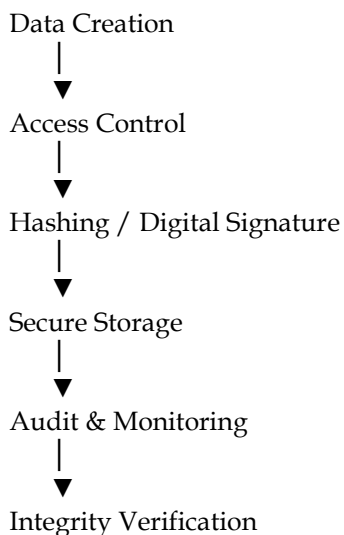
यदि उत्पाद का मूल्य ₹500 के स्थान पर ₹50 दिखने लगे, तो कंपनी को नुकसान होगा।

(5) रक्षा एवं अंतरिक्ष

यदि मिसाइल नियंत्रण प्रणाली का डेटा बदल जाए, तो गंभीर राष्ट्रीय सुरक्षा संकट उत्पन्न हो सकता है।

7. Integrity कैसे कार्य करती है?

डेटा की अखंडता बनाए रखने के लिए विभिन्न तकनीकी एवं प्रशासनिक उपाय अपनाए जाते हैं।



8. Integrity बनाए रखने के प्रमुख सिद्धांत

(1) Accuracy (शुद्धता)

डेटा में कोई त्रुटि नहीं होनी चाहिए।

(2) Completeness (पूर्णता)

सभी आवश्यक जानकारी उपलब्ध होनी चाहिए।

(3) Consistency (संगति)

सभी स्थानों पर डेटा समान होना चाहिए।

(4) Validity (वैधता)

डेटा निर्धारित नियमों के अनुसार होना चाहिए।

(5) Authenticity (प्रामाणिकता)

9. Integrity सुनिश्चित करने की प्रमुख तकनीकें

9.1 Hash Function (हैश फ़ंक्शन)

Hash Function किसी भी डेटा को एक निश्चित लंबाई (Fixed Length) के Hash Value में बदल देता है।

यदि डेटा में एक अक्षर भी बदल जाए, तो Hash पूरी तरह बदल जाता है।

उदाहरण

Original Data

Cyber Security

↓

SHA-256 Hash

8f14e45fcee167a5a36dedd4bea2543...

यदि "Cyber Security" को "Cyber security" (S छोटा) कर दें, तो Hash पूरी तरह बदल जाएगा।

उपयोग

- Password Storage
- File Verification
- Blockchain
- Digital Signature

9.2 Checksum

Checksum डेटा की शुद्धता जाँचने की सरल तकनीक है।

उदाहरण

इंटरनेट से Software डाउनलोड करते समय वेबसाइट SHA256 Checksum देती है।

डाउनलोड के बाद यदि Checksum समान है, तो File सही है।

9.3 Digital Signature (डिजिटल हस्ताक्षर)

Digital Signature यह सुनिश्चित करता है कि—

- दस्तावेज़ असली है।
- दस्तावेज़ में परिवर्तन नहीं हुआ।
- दस्तावेज़ सही व्यक्ति द्वारा भेजा गया।

उदाहरण

Income Tax Return

GST Return

e-Tender

e-Office Documents

9.4 Message Authentication Code (MAC)

MAC संदेश की Integrity एवं Authenticity दोनों सुनिश्चित करता है।

उदाहरण

Online Banking Transactions

9.5 File Integrity Monitoring (FIM)

FIM लगातार यह जाँचता है कि किसी महत्वपूर्ण File में परिवर्तन हुआ या नहीं।

उदाहरण

यदि Server की Configuration File बदल जाए, तो Administrator को Alert प्राप्त होगा।

9.6 Database Integrity

Database में सही डेटा बनाए रखने के लिए Constraints का उपयोग किया जाता है।

प्रमुख Constraints

- Primary Key
- Foreign Key
- Unique
- Check
- Not Null

उदाहरण

Student Roll Number दो बार नहीं हो सकता।

9.7 Version Control

किसी दस्तावेज़ या Source Code के प्रत्येक परिवर्तन का रिकॉर्ड रखा जाता है।

उदाहरण

Git

GitHub

GitLab

यदि गलती हो जाए, तो पुराना Version वापस लाया जा सकता है।

9.8 Backup एवं Recovery

यदि डेटा खराब हो जाए, तो Backup से पुनः प्राप्त किया जा सकता है।

9.9 Access Control

केवल अधिकृत उपयोगकर्ता को डेटा संशोधित करने की अनुमति दी जाती है।

9.10 Audit Trail एवं Logging

प्रत्येक परिवर्तन का रिकॉर्ड रखा जाता है।

User : Teacher01

Action : Marks Updated

Time : 11:15 AM

Date : 22 July 2026

10. Integrity पर प्रमुख खतरे (Threats)

(A) Malware

Virus एवं Trojan डेटा बदल सकते हैं।

(B) Ransomware

डेटा को Encrypt कर देता है।

(C) SQL Injection

Database में अनधिकृत परिवर्तन कर सकता है।

(D) Insider Threat

असंतुष्ट कर्मचारी डेटा बदल सकता है।

(E) Human Error

गलती से डेटा Delete या Modify हो सकता है।

(F) Software Bug

Programming Error के कारण गलत डेटा संग्रहीत हो सकता है।

(G) Hardware Failure

Hard Disk खराब होने से डेटा भ्रष्ट (Corrupt) हो सकता है।

11. Integrity बनाए रखने के सर्वोत्तम उपाय (Best Practices)

- Hash Function का उपयोग।
- Digital Signature लागू करना।
- Database Constraints का उपयोग।
- नियमित Backup लेना।
- Access Control लागू करना।
- Strong Authentication एवं MFA का उपयोग।
- File Integrity Monitoring (FIM) लागू करना।
- Audit Logs सुरक्षित रखना।
- नियमित Software Updates करना।
- Anti-Malware एवं Antivirus का उपयोग।
- कर्मचारियों को सुरक्षा प्रशिक्षण देना।
- Version Control का उपयोग करना।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

12. वास्तविक जीवन के उदाहरण

उदाहरण 1 : विश्वविद्यालय परीक्षा परिणाम

यदि छात्र के 80 अंक को बिना अनुमति 95 कर दिया जाए—

→ Integrity का उल्लंघन।

उदाहरण 2 : बैंक

यदि ग्राहक के खाते का बैलेंस ₹20,000 से ₹2,00,000 कर दिया जाए—

उदाहरण 3 : अस्पताल

यदि मरीज का Blood Group "B+" से "O-" कर दिया जाए—

→ गंभीर चिकित्सीय जोखिम।

उदाहरण 4 : रेलवे आरक्षण

यदि किसी यात्री की सीट संख्या बदल जाए—

→ डेटा की Integrity प्रभावित।

उदाहरण 5 : ई-कॉमर्स

यदि ₹45,000 का Laptop गलती से ₹450 दिखने लगे—

→ Product Database की Integrity प्रभावित।

उदाहरण 6 : Digital Forensics

जब किसी हार्ड डिस्क की Forensic Image बनाई जाती है, तो MD5 या SHA-256 Hash निकाला जाता है।

यदि जाँच के दौरान Hash समान रहता है, तो यह प्रमाणित होता है कि डिजिटल साक्ष्य (Digital Evidence) में कोई परिवर्तन नहीं हुआ और उसकी Integrity सुरक्षित है।

13. Confidentiality, Integrity एवं Availability में अंतर

आधार	Confidentiality	Integrity	Availability
उद्देश्य	डेटा को अनधिकृत पहुँच से बचाना	डेटा को सही एवं अपरिवर्तित रखना	आवश्यकता पड़ने पर डेटा उपलब्ध रखना
मुख्य प्रश्न	कौन देख सकता है?	क्या डेटा सही है?	क्या डेटा उपलब्ध है?
प्रमुख उपाय	Encryption, Access Control	Hashing, Digital Signature, Checksum	Backup, Redundancy, UPS

14. निष्कर्ष (Conclusion)

Integrity सूचना सुरक्षा का अत्यंत महत्वपूर्ण सिद्धांत है, जो यह सुनिश्चित करता है कि डेटा अपने पूरे जीवनचक्र (Data Life Cycle) के दौरान सही (Accurate), पूर्ण (Complete), विश्वसनीय (Reliable) और अपरिवर्तित (Unaltered) बना रहे। आधुनिक सूचना प्रणालियों में Hashing, Checksum, Digital Signature, Message Authentication Code (MAC), Database Constraints, File Integrity Monitoring (FIM), Version Control, Access Control तथा Audit Logging जैसी तकनीकों का उपयोग करके डेटा की अखंडता सुनिश्चित की जाती है।

बैंकिंग, ई-गवर्नेंस, स्वास्थ्य सेवाओं, विश्वविद्यालयों, क्लाउड कम्प्यूटिंग तथा डिजिटल फोरेंसिक जैसे क्षेत्रों में Integrity का विशेष महत्व है। विशेष रूप से Digital Forensics में किसी डिजिटल साक्ष्य की स्वीकार्यता (Admissibility) उसके Hash Value द्वारा प्रमाणित Integrity पर निर्भर करती है। यदि डेटा की Integrity नष्ट हो जाए, तो उस पर आधारित निर्णय, लेन-देन तथा कानूनी साक्ष्य विश्वसनीय नहीं माने जाते।

15. परीक्षा की दृष्टि से अत्यंत महत्वपूर्ण बिंदु

1. Integrity की परिभाषा एवं उद्देश्य।
2. CIA Triad में Integrity का स्थान।
3. Integrity बनाए रखने की प्रमुख तकनीकें (Hashing, Checksum, Digital Signature, MAC, FIM)।
4. Database Integrity एवं Constraints।
5. Version Control एवं Audit Trail का महत्व।

6. Integrity पर प्रमुख खतरे एवं उनके समाधान।
7. Digital Forensics में Hash Value का महत्व।
8. बैंक, अस्पताल, विश्वविद्यालय, ई-कॉमर्स एवं रेलवे से संबंधित वास्तविक उदाहरण।
9. Confidentiality, Integrity एवं Availability (CIA Triad) में अंतर।
10. उत्तर लिखते समय परिभाषा, कार्यप्रणाली, तकनीकें, आरेख, तालिका तथा वास्तविक उदाहरण अवश्य शामिल करें, इससे उत्तर अधिक प्रभावशाली और पूर्ण माना जाता है।



Non-Repudiation (अस्वीकरण-असम्भवता / कार्य से इनकार न कर सकना)

परिभाषा, उद्देश्य, सिद्धांत, महत्व, तकनीकें, कार्यप्रणाली एवं उदाहरण सहित विस्तृत अध्ययन

अध्याय की रूपरेखा

1. परिचय (Introduction)
2. Non-Repudiation की परिभाषा
3. Non-Repudiation का अर्थ
4. Non-Repudiation की आवश्यकता
5. उद्देश्य (Objectives)
6. कार्यप्रणाली (Working)
7. Non-Repudiation के प्रमुख तत्व
8. Digital Signature
9. Digital Certificate
10. Public Key Infrastructure (PKI)
11. Hash Function
12. Timestamp
13. Audit Log
14. Email Non-Repudiation
15. E-Commerce में Non-Repudiation
16. Banking में Non-Repudiation
17. E-Governance में Non-Repudiation
18. Digital Forensics में महत्व
19. Non-Repudiation पर खतरे
20. Non-Repudiation सुनिश्चित करने के उपाय
21. वास्तविक जीवन के उदाहरण
22. Authentication, Authorization, Accountability एवं Non-Repudiation में अंतर
23. Advantages एवं Limitations
24. निष्कर्ष
25. परीक्षा हेतु महत्वपूर्ण बिंदु

1. परिचय (Introduction)

सूचना सुरक्षा (Information Security) में केवल यह सुनिश्चित करना पर्याप्त नहीं है कि सही व्यक्ति सिस्टम में प्रवेश करे (Authentication), उसे उचित अधिकार मिलें (Authorization), डेटा सुरक्षित रहे (Confidentiality), सही रहे (Integrity) और आवश्यकता पड़ने पर उपलब्ध हो (Availability)। यह भी आवश्यक है कि कोई उपयोगकर्ता किसी डिजिटल कार्य (Digital Transaction) को करने के बाद यह दावा न कर सके कि उसने वह कार्य किया ही नहीं।

यही सिद्धांत Non-Repudiation (अस्वीकरण-असम्भवता) कहलाता है।

आधुनिक डिजिटल दुनिया में बैंकिंग, ई-कॉमर्स, ऑनलाइन भुगतान, ई-टेंडर, ई-गवर्नेंस, डिजिटल अनुबंध (Digital Contracts), ई-मेल तथा डिजिटल हस्ताक्षर (Digital Signature) जैसी सेवाओं में Non-Repudiation अत्यंत महत्वपूर्ण है।

यदि यह सिद्धांत लागू न हो, तो कोई भी व्यक्ति ऑनलाइन भुगतान करने, अनुबंध पर हस्ताक्षर करने या महत्वपूर्ण ई-मेल भेजने के बाद यह कह सकता है कि "मैंने यह कार्य नहीं किया।" इससे विवाद, धोखाधड़ी और कानूनी समस्याएँ उत्पन्न हो सकती हैं।

2. Non-Repudiation की परिभाषा (Definition)

Non-Repudiation वह सुरक्षा सिद्धांत है जो यह सुनिश्चित करता है कि किसी डिजिटल कार्य, संदेश या लेन-देन के बाद संबंधित व्यक्ति उस कार्य से बाद में इनकार (Repudiate) नहीं कर सकता।

सरल परिभाषा

"किसी उपयोगकर्ता द्वारा किए गए डिजिटल कार्य का ऐसा प्रमाण उपलब्ध होना कि वह बाद में यह न कह सके कि उसने वह कार्य नहीं किया, Non-Repudiation कहलाता है।"

3. Non-Repudiation का अर्थ

Repudiation का अर्थ है—

किसी कार्य, संदेश या लेन-देन से इनकार करना।

Non-Repudiation का अर्थ है—

ऐसा प्रमाण होना जिससे इनकार करना संभव न हो।

अर्थात यदि किसी व्यक्ति ने—

- ई-मेल भेजा,
- डिजिटल हस्ताक्षर किए,
- ऑनलाइन भुगतान किया,
- अनुबंध स्वीकार किया,

तो बाद में वह यह नहीं कह सकता कि "मैंने ऐसा नहीं किया।"

4. Non-Repudiation की आवश्यकता (Need)

यदि Non-Repudiation न हो, तो—

- ऑनलाइन धोखाधड़ी बढ़ जाएगी।
- कोई व्यक्ति भुगतान से इनकार कर सकता है।
- डिजिटल अनुबंध अमान्य हो सकते हैं।
- न्यायालय में डिजिटल साक्ष्य स्वीकार करना कठिन होगा।
- ई-कॉमर्स पर विश्वास कम हो जाएगा।

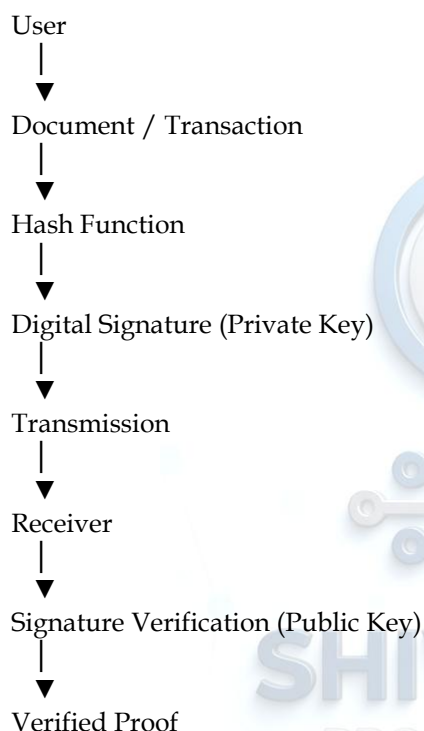
5. Non-Repudiation के उद्देश्य (Objectives)

- डिजिटल लेन-देन का विश्वसनीय प्रमाण देना।
- उपयोगकर्ता को उसके कार्य के लिए उत्तरदायी बनाना।
- धोखाधड़ी (Fraud) रोकना।
- कानूनी साक्ष्य (Legal Evidence) उपलब्ध कराना।
- ई-कॉमर्स एवं बैंकिंग में विश्वास बढ़ाना।
- डिजिटल दस्तावेजों की प्रामाणिकता सिद्ध करना।
- विवादों (Disputes) का समाधान करना।

6. Non-Repudiation कैसे कार्य करता है? (Working)

Non-Repudiation सामान्यतः Public Key Cryptography तथा Digital Signature पर आधारित होता है।

कार्यप्रवाह



यदि हस्ताक्षर सफलतापूर्वक सत्यापित हो जाते हैं, तो यह सिद्ध हो जाता है कि दस्तावेज़ वास्तव में उसी व्यक्ति द्वारा भेजा गया था और उसमें कोई परिवर्तन नहीं हुआ।

7. Non-Repudiation के प्रमुख तत्व

(1) Authentication

पहले उपयोगकर्ता की पहचान सत्यापित की जाती है।

(2) Digital Signature

यह सबसे महत्वपूर्ण तकनीक है।

Digital Signature यह प्रमाणित करता है कि—

- दस्तावेज़ किसने भेजा।
 - दस्तावेज़ में परिवर्तन नहीं हुआ।
 - भेजने वाला व्यक्ति बाद में इनकार नहीं कर सकता।
-

(3) Digital Certificate

Digital Certificate उपयोगकर्ता की पहचान प्रमाणित करता है।

इसे सामान्यतः Certificate Authority (CA) जारी करती है।

(4) Hash Function

दस्तावेज़ का Hash तैयार किया जाता है।

यदि दस्तावेज़ बदलता है, तो Hash भी बदल जाता है।

(5) Timestamp

दस्तावेज़ पर समय और तिथि अंकित की जाती है।

यह प्रमाणित करता है कि कार्य कब किया गया।

(6) Audit Log

सभी गतिविधियों का रिकॉर्ड रखा जाता है।

8. Digital Signature की भूमिका

Digital Signature Non-Repudiation का सबसे महत्वपूर्ण साधन है।

यह तीन कार्य करता है—

- Authentication
- Integrity
- Non-Repudiation

उदाहरण

यदि किसी अधिकारी ने PDF पर Digital Signature किया है—

तो वह बाद में यह नहीं कह सकता कि उसने हस्ताक्षर नहीं किए।

9. Public Key Infrastructure (PKI)

PKI वह प्रणाली है जो—

- Digital Certificate जारी करती है।
- Public एवं Private Key का प्रबंधन करती है।
- Digital Signature को सत्यापित करती है।

10. Timestamp का महत्व

Timestamp यह प्रमाणित करता है—

- दस्तावेज़ कब बनाया गया।
- कब हस्ताक्षर किया गया।
- कब भेजा गया।

उदाहरण

Date : 22 July 2026

Time : 10:45 AM

11. Audit Log

Audit Log में दर्ज होता है—

- User ID
- IP Address
- Device Name
- Date
- Time
- Activity

12. Email Non-Repudiation

यदि कोई अधिकारी Digital Signature के साथ ई-मेल भेजता है—

तो वह बाद में यह नहीं कह सकता कि उसने ई-मेल नहीं भेजा।

13. Banking में Non-Repudiation

उदाहरण

नेट बैंकिंग में—

- ग्राहक Login करता है।
- OTP दर्ज करता है।
- Transaction करता है।
- Transaction ID बनती है।
- बैंक Log सुरक्षित रखता है।

अब ग्राहक यह नहीं कह सकता कि उसने लेन-देन नहीं किया (यदि उसके प्रमाणीकरण विवरण सही उपयोग हुए हों और धोखाधड़ी का कोई प्रमाण न हो)।

14. E-Commerce में Non-Repudiation

Amazon या Flipkart जैसी वेबसाइट पर—

- Order Confirmation
- Payment Receipt
- Invoice
- Email Confirmation

15. E-Governance में Non-Repudiation

भारत सरकार की अनेक सेवाओं में—

- Income Tax Return
- GST Return
- e-Tender
- DigiLocker Documents

Digital Signature एवं Digital Certificate का उपयोग किया जाता है।

16. Digital Forensics में महत्व

Digital Forensics में यह सिद्ध करना आवश्यक होता है कि—

- डिजिटल साक्ष्य किसने बनाया।
- कब बनाया।
- किसने संशोधित किया।
- किसने भेजा।

Non-Repudiation इस प्रमाण को मजबूत बनाता है।

17. Non-Repudiation पर प्रमुख खतरे

- Private Key चोरी होना।
 - Password साझा करना।
 - Malware द्वारा Key चोरी।
 - Fake Digital Certificate।
 - Insider Attack।
 - कमजोर Audit Logs।
 - System Clock में छेड़छाड़।
-

18. Non-Repudiation सुनिश्चित करने के उपाय

- Digital Signature का उपयोग।
- PKI लागू करना।
- मजबूत Authentication।
- Multi-Factor Authentication (MFA)।
- सुरक्षित Private Key Storage (जैसे HSM या Smart Card)।
- Timestamping।
- सुरक्षित Audit Logs।
- नियमित Security Audit।
- Encryption का उपयोग।
- मजबूत Access Control।

19. वास्तविक जीवन के उदाहरण

उदाहरण 1 : Income Tax Return

करदाता Digital Signature के साथ Income Tax Return जमा करता है।

बाद में वह यह नहीं कह सकता कि उसने Return दाखिल नहीं किया।

उदाहरण 2 : ऑनलाइन बैंकिंग

ग्राहक ₹50,000 का ऑनलाइन भुगतान करता है।

बैंक के पास—

- Transaction ID
- OTP Verification
- IP Address
- Timestamp
- Audit Log

सभी रिकॉर्ड उपलब्ध होते हैं।

उदाहरण 3 : विश्वविद्यालय

परीक्षा नियंत्रक Digital Signature के साथ परिणाम प्रकाशित करता है।

बाद में वह परिणाम प्रकाशित करने से इनकार नहीं कर सकता।

उदाहरण 4 : E-Tender

कंपनी Digital Signature के साथ Tender जमा करती है।

बाद में यह नहीं कह सकती कि उसने Tender जमा नहीं किया।

उदाहरण 5 : अस्पताल

डॉक्टर Digital Signature से मरीज की रिपोर्ट प्रमाणित करता है।

रिपोर्ट का कानूनी महत्व बढ़ जाता है।

20. Authentication, Authorization, Accountability एवं Non-Repudiation में अंतर

आधार	Authentication	Authorization	Accountability	Non-Repudiation
उद्देश्य	पहचान सत्यापित करना	अधिकार देना	जिम्मेदारी तय करना	कार्य से इनकार रोकना
प्रश्न	आप कौन हैं?	आप क्या कर सकते हैं?	आपने क्या किया?	क्या आप कार्य से इनकार कर सकते हैं?
प्रमुख तकनीक	Password, OTP	Roles, Permissions	Audit Logs	Digital Signature, PKI

21. Advantages (लाभ)

- कानूनी प्रमाण उपलब्ध होते हैं।

- धोखाधड़ी कम होती है।
- डिजिटल लेन-देन सुरक्षित बनते हैं।
- ई-कॉमर्स में विश्वास बढ़ता है।
- बैंकिंग अधिक सुरक्षित होती है।
- डिजिटल अनुबंध विश्वसनीय बनते हैं।
- डिजिटल फॉरेंसिक में सहायता मिलती है।

22. Limitations (सीमाएँ)

- PKI लागू करना महंगा हो सकता है।
- Private Key खोने या चोरी होने पर गंभीर जोखिम होता है।
- Certificate Management जटिल हो सकता है।
- Digital Signature के लिए अतिरिक्त अवसंरचना (Infrastructure) की आवश्यकता होती है।

23. निष्कर्ष (Conclusion)

Non-Repudiation आधुनिक सूचना सुरक्षा का एक अत्यंत महत्वपूर्ण सिद्धांत है, जो यह सुनिश्चित करता है कि किसी डिजिटल कार्य, संदेश या लेन-देन के बाद संबंधित व्यक्ति उस कार्य से इनकार न कर सके। यह मुख्य रूप से Digital Signature, Digital Certificate, Public Key Infrastructure (PKI), Hash Function, Timestamp तथा Audit Logs पर आधारित होता है। बैंकिंग, ई-गवर्नेंस, ई-कॉमर्स, डिजिटल अनुबंध, क्लाउड सेवाओं तथा डिजिटल फॉरेंसिक में इसका विशेष महत्व है। यह न केवल डिजिटल लेन-देन की विश्वसनीयता बढ़ाता है, बल्कि कानूनी साक्ष्य उपलब्ध कराकर विवादों के समाधान में भी महत्वपूर्ण भूमिका निभाता है।

24. परीक्षा की दृष्टि से अत्यंत महत्वपूर्ण बिंदु

1. Non-Repudiation की परिभाषा।
2. Repudiation एवं Non-Repudiation में अंतर।
3. Non-Repudiation के उद्देश्य एवं आवश्यकता।
4. Digital Signature की भूमिका।
5. Digital Certificate एवं PKI का महत्व।
6. Hash Function, Timestamp एवं Audit Log का उपयोग।
7. बैंकिंग, ई-गवर्नेंस, E-Commerce और Digital Forensics में उपयोग।

8. Authentication, Authorization, Accountability एवं Non-Repudiation में अंतर।
9. Non-Repudiation के लाभ एवं सीमाएँ।
10. उत्तर लिखते समय Digital Signature आधारित कार्यप्रवाह, तालिका तथा वास्तविक जीवन के उदाहरण अवश्य लिखें, क्योंकि विश्वविद्यालय एवं प्रतियोगी परीक्षाओं में इससे उत्तर अधिक अंक प्राप्त करता है।



Privacy (गोपनीयता / निजता)

परिभाषा, उद्देश्य, सिद्धांत, प्रकार, महत्व, तकनीकें, खतरे एवं उदाहरण सहित विस्तृत अध्ययन

अध्याय की रूपरेखा

1. परिचय (Introduction)
 2. Privacy की परिभाषा
 3. Privacy का अर्थ
 4. Privacy की आवश्यकता
 5. Privacy के उद्देश्य
 6. Privacy के मूल सिद्धांत
 7. Privacy के प्रकार
 8. Personally Identifiable Information (PII)
 9. Sensitive Personal Information (SPI)
 10. Privacy एवं Confidentiality में अंतर
 11. Privacy एवं Security का संबंध
 12. Privacy बनाए रखने की तकनीकें
 13. Data Minimization
 14. Data Masking
 15. Encryption
 16. Anonymization एवं Pseudonymization
 17. Consent Management
 18. Privacy by Design
 19. Data Retention Policy
 20. Privacy पर प्रमुख खतरे
 21. Privacy बनाए रखने के सर्वोत्तम उपाय
 22. वास्तविक जीवन के उदाहरण
 23. Privacy से संबंधित कानून
 24. Advantages एवं Limitations
 25. निष्कर्ष
 26. परीक्षा हेतु महत्वपूर्ण बिंदु
-

1. परिचय (Introduction)

डिजिटल युग में इंटरनेट, स्मार्टफोन, सोशल मीडिया, ऑनलाइन बैंकिंग, ई-कॉमर्स, क्लाउड कम्प्यूटिंग तथा कृत्रिम बुद्धिमत्ता (Artificial Intelligence) के बढ़ते उपयोग के कारण प्रत्येक व्यक्ति का बहुत-सा व्यक्तिगत डेटा (Personal Data) डिजिटल रूप में संग्रहीत होने लगा है। इस डेटा में नाम, पता, मोबाइल नंबर, ई-मेल, बैंक विवरण, आधार संख्या, चिकित्सा रिकॉर्ड, फोटो, वीडियो, स्थान (Location), बायोमेट्रिक जानकारी और ऑनलाइन गतिविधियाँ शामिल हो सकती हैं।

यदि इस प्रकार की जानकारी बिना व्यक्ति की अनुमति के एकत्रित, उपयोग, साझा या प्रकाशित की जाती है, तो उसकी **Privacy (निजता)** का उल्लंघन होता है।

Privacy केवल सूचना को छिपाने का विषय नहीं है, बल्कि यह प्रत्येक व्यक्ति का अधिकार है कि उसकी व्यक्तिगत जानकारी का उपयोग **कब, कैसे, किस उद्देश्य से और किसके द्वारा किया जाएगा**, इसका नियंत्रण उसी के पास हो।

2. Privacy की परिभाषा (Definition)

Privacy (निजता) वह अधिकार और सिद्धांत है जिसके अनुसार किसी व्यक्ति की व्यक्तिगत जानकारी (Personal Information) का संग्रह (Collection), उपयोग (Use), भंडारण (Storage), साझा करना (Sharing) तथा प्रसंस्करण (Processing) उसकी जानकारी और अनुमति (Consent) के अनुसार किया जाए।

सरल परिभाषा

"किसी व्यक्ति की व्यक्तिगत जानकारी को उसकी इच्छा, अनुमति और निर्धारित उद्देश्य के अनुसार सुरक्षित रखना तथा उसका अनधिकृत उपयोग न होने देना ही Privacy कहलाता है।"

3. Privacy का अर्थ

Privacy का अर्थ है—

- व्यक्ति की निजी जानकारी पर उसका नियंत्रण।
- व्यक्तिगत जीवन में अनावश्यक हस्तक्षेप से सुरक्षा।
- डेटा के उपयोग पर व्यक्ति की सहमति (Consent)।
- केवल आवश्यक जानकारी का संग्रह।
- जानकारी का सीमित और उद्देश्यपूर्ण उपयोग।

4. Privacy की आवश्यकता (Need of Privacy)

Privacy निम्न कारणों से आवश्यक है—

- व्यक्ति की पहचान की सुरक्षा।
- वित्तीय धोखाधड़ी रोकना।
- पहचान की चोरी (Identity Theft) रोकना।
- व्यक्तिगत स्वतंत्रता की रक्षा।
- सामाजिक एवं व्यावसायिक प्रतिष्ठा बनाए रखना।
- डेटा के दुरुपयोग को रोकना।
- नागरिकों के मौलिक अधिकारों की रक्षा करना।

5. Privacy के उद्देश्य (Objectives)

- व्यक्तिगत डेटा की सुरक्षा।
- डेटा के अनधिकृत उपयोग को रोकना।
- व्यक्ति को उसके डेटा पर नियंत्रण देना।
- डेटा साझा करने में पारदर्शिता लाना।
- कानूनी नियमों का पालन करना।
- उपयोगकर्ता का विश्वास बनाए रखना।
- डेटा का केवल वैध उद्देश्य के लिए उपयोग करना।

6. Privacy के मूल सिद्धांत (Privacy Principles)

Privacy के अंतरराष्ट्रीय सिद्धांतों में सामान्यतः निम्न बिंदु शामिल होते हैं—

(1) Lawfulness (वैधता)

डेटा का संग्रह कानून के अनुसार होना चाहिए।

(2) Fairness (निष्पक्षता)

उपयोगकर्ता के साथ निष्पक्ष व्यवहार किया जाए।

(3) Transparency (पारदर्शिता)

उपयोगकर्ता को बताया जाए कि उसका डेटा क्यों एकत्रित किया जा रहा है।

(4) Purpose Limitation (उद्देश्य सीमा)

डेटा का उपयोग केवल उसी उद्देश्य के लिए हो जिसके लिए उसे लिया गया था।

(5) Data Minimization (न्यूनतम डेटा संग्रह)

केवल आवश्यक डेटा ही एकत्रित किया जाए।

(6) Accuracy (शुद्धता)

डेटा सही एवं अद्यतन होना चाहिए।

(7) Storage Limitation (सीमित भंडारण)

डेटा को आवश्यकता से अधिक समय तक न रखा जाए।

(8) Integrity and Confidentiality

डेटा सुरक्षित एवं गोपनीय रखा जाए।

(9) Accountability

डेटा नियंत्रक (Data Controller) अपने कार्यों के लिए उत्तरदायी हो।

7. Privacy के प्रकार (Types of Privacy)

(A) Information Privacy

व्यक्तिगत जानकारी की सुरक्षा।

उदाहरण

- आधार संख्या
- बैंक खाता
- मेडिकल रिपोर्ट

(B) Communication Privacy

संचार (Communication) की गोपनीयता।

उदाहरण

- ई-मेल
 - WhatsApp संदेश
 - फोन कॉल
-

(C) Location Privacy

व्यक्ति के स्थान (Location) की सुरक्षा।

उदाहरण

Google Maps Location History

(D) Financial Privacy

बैंक एवं वित्तीय जानकारी की सुरक्षा।

(E) Medical Privacy

मरीज की स्वास्थ्य जानकारी की सुरक्षा।

(F) Online Privacy

वेब ब्राउज़िंग, Cookies तथा Search History की सुरक्षा।

8. Personally Identifiable Information (PII)

PII वह जानकारी है जिससे किसी व्यक्ति की पहचान की जा सकती है।

उदाहरण

- नाम
- फोटो
- मोबाइल नंबर
- ई-मेल
- आधार संख्या
- पैन कार्ड
- पासपोर्ट संख्या
- ड्राइविंग लाइसेंस

9. Sensitive Personal Information (SPI)

यह अत्यधिक संवेदनशील व्यक्तिगत जानकारी होती है।

उदाहरण

- Fingerprint
- Iris Scan
- DNA Data
- Password
- बैंक PIN
- मेडिकल रिकॉर्ड
- बायोमेट्रिक डेटा



10. Privacy एवं Confidentiality में अंतर

आधार	Privacy (निजता)	Confidentiality (गोपनीयता)
अर्थ	व्यक्ति की निजी जानकारी पर उसका नियंत्रण	डेटा को अनधिकृत पहुँच से बचाना
केंद्र	व्यक्ति (Person)	सूचना (Information)
उद्देश्य	व्यक्तिगत अधिकारों की रक्षा	जानकारी की सुरक्षा
उदाहरण	मरीज तय करता है कि उसकी रिपोर्ट कौन देखे	अस्पताल रिपोर्ट को सुरक्षित रखता है

11. Privacy एवं Security का संबंध

Privacy और Security एक-दूसरे से जुड़े हुए हैं, लेकिन समान नहीं हैं।

- Security डेटा की सुरक्षा करती है।
- Privacy यह नियंत्रित करती है कि डेटा का उपयोग कैसे और किसके द्वारा किया जाएगा।

यदि Security कमजोर होगी, तो Privacy भी प्रभावित होगी।

12. Privacy बनाए रखने की प्रमुख तकनीकें

(1) Encryption

डेटा को Cipher Text में बदल दिया जाता है।

(2) Access Control

केवल अधिकृत व्यक्ति को डेटा देखने की अनुमति।

(3) Authentication

उपयोगकर्ता की पहचान सत्यापित करना।

(4) Multi-Factor Authentication (MFA)

Password + OTP + Fingerprint

(5) Data Masking

डेटा का कुछ भाग छिपा देना।

उदाहरण

9876543210

↓

987*****10

(6) Tokenization

वास्तविक डेटा के स्थान पर Token का उपयोग।

(7) Anonymization

डेटा से पहचान योग्य जानकारी पूरी तरह हटा दी जाती है।

उदाहरण

Research Data में नाम हटाकर केवल आयु और लिंग रखना।

(8) Pseudonymization

व्यक्ति का वास्तविक नाम बदलकर एक Code या ID का उपयोग करना।

उदाहरण

Patient-001

Student-105

(9) Consent Management

उपयोगकर्ता से स्पष्ट अनुमति लेना।

(10) Privacy by Design

सिस्टम की शुरुआत से ही Privacy को ध्यान में रखकर डिज़ाइन करना।

13. Data Minimization

केवल उतनी ही जानकारी लेना जितनी वास्तव में आवश्यक हो।

उदाहरण

यदि किसी वेबसाइट को केवल ई-मेल चाहिए, तो आधार संख्या नहीं माँगनी चाहिए।

14. Data Retention Policy

डेटा को केवल निर्धारित अवधि तक सुरक्षित रखा जाए।

उदाहरण—

कर्मचारी का रिकॉर्ड नौकरी समाप्त होने के बाद निर्धारित अवधि तक ही रखा जाए।

15. Privacy पर प्रमुख खतरे (Threats)

तकनीकी खतरे

- Hacking
- Malware
- Spyware
- Phishing
- Ransomware
- Data Breach

मानवीय खतरे

- Social Engineering
- Insider Threat
- Shared Password
- लापरवाही

- Cookies Tracking
- Browser Fingerprinting
- Ad Tracking
- Fake Apps

16. Privacy बनाए रखने के सर्वोत्तम उपाय (Best Practices)

- मजबूत Password का उपयोग।
- Multi-Factor Authentication लागू करना।
- सार्वजनिक Wi-Fi पर संवेदनशील कार्य न करना।
- App Permissions की नियमित समीक्षा करना।
- केवल विश्वसनीय वेबसाइटों का उपयोग करना।
- नियमित Software Update करना।
- VPN का उपयोग करना।
- Browser Privacy Settings सक्षम रखना।
- सोशल मीडिया पर अनावश्यक जानकारी साझा न करना।
- Data Encryption का उपयोग करना।
- Privacy Policy पढ़कर ही सेवा का उपयोग करना।

17. वास्तविक जीवन के उदाहरण

उदाहरण 1 : अस्पताल

मरीज यह तय करता है कि उसकी मेडिकल रिपोर्ट कौन देख सकता है।

→ Privacy

उदाहरण 2 : बैंक

ग्राहक की अनुमति के बिना उसका खाता विवरण किसी तीसरे व्यक्ति को नहीं दिया जाता।

उदाहरण 3 : WhatsApp

उपयोगकर्ता यह नियंत्रित कर सकता है कि उसका Last Seen, Profile Photo और Status कौन देखे।

उदाहरण 4 : सोशल मीडिया

Facebook या Instagram पर उपयोगकर्ता यह निर्धारित कर सकता है कि उसकी पोस्ट Public होगी या केवल Friends के लिए।

उदाहरण 5 : विश्वविद्यालय

छात्र का मोबाइल नंबर और पता केवल प्रशासनिक उपयोग के लिए रखा जाता है और सार्वजनिक नहीं किया जाता।

18. Privacy से संबंधित कानून (संक्षिप्त परिचय)

विभिन्न देशों में Privacy की सुरक्षा के लिए अलग-अलग कानून बनाए गए हैं।

उदाहरण—

- भारत – डिजिटल व्यक्तिगत डेटा संरक्षण अधिनियम (Digital Personal Data Protection Act, 2023)।
- यूरोपीय संघ – General Data Protection Regulation (GDPR)।
- अमेरिका – विभिन्न राज्यों के अलग-अलग डेटा गोपनीयता कानून (जैसे CCPA)।

इन कानूनों का उद्देश्य व्यक्तिगत डेटा के संग्रह, उपयोग और सुरक्षा के लिए नियम निर्धारित करना है।

19. Advantages (लाभ)

- व्यक्तिगत स्वतंत्रता की रक्षा।
- पहचान की चोरी में कमी।
- उपयोगकर्ता का विश्वास बढ़ता है।

- कानूनी अनुपालन (Compliance) सुनिश्चित होता है।
- डेटा का दुरुपयोग कम होता है।
- साइबर अपराधों का जोखिम घटता है।

20. Limitations (सीमाएँ)

- Privacy लागू करना महँगा हो सकता है।
- अत्यधिक डेटा संग्रह करने वाले संगठनों के लिए प्रबंधन जटिल हो सकता है।
- उपयोगकर्ता स्वयं भी अनजाने में निजी जानकारी साझा कर देते हैं।
- नई तकनीकों (AI, IoT, Big Data) के कारण Privacy की चुनौतियाँ लगातार बढ़ रही हैं।

21. निष्कर्ष (Conclusion)

Privacy प्रत्येक व्यक्ति का एक महत्वपूर्ण अधिकार है और आधुनिक सूचना सुरक्षा का मूल तत्व भी है। इसका उद्देश्य केवल व्यक्तिगत जानकारी को छिपाना नहीं, बल्कि व्यक्ति को उसके डेटा पर नियंत्रण प्रदान करना है। आधुनिक प्रणालियों में Encryption, Access Control, Authentication, Data Minimization, Consent Management, Anonymization, Pseudonymization तथा Privacy by Design जैसी तकनीकों और सिद्धांतों के माध्यम से Privacy सुनिश्चित की जाती है। बैंकिंग, स्वास्थ्य, शिक्षा, ई-कॉमर्स, सोशल मीडिया और सरकारी सेवाओं में Privacy का विशेष महत्व है। मजबूत Privacy व्यवस्था न केवल उपयोगकर्ता का विश्वास बढ़ाती है, बल्कि कानूनी अनुपालन तथा सुरक्षित डिजिटल वातावरण भी सुनिश्चित करती है।

22. परीक्षा की दृष्टि से अत्यंत महत्वपूर्ण बिंदु

1. Privacy की परिभाषा एवं उद्देश्य।
2. Privacy की आवश्यकता और महत्व।
3. Privacy के मूल सिद्धांत (Lawfulness, Transparency, Purpose Limitation, Data Minimization आदि)।
4. PII एवं Sensitive Personal Information (SPI) में अंतर।
5. Privacy बनाए रखने की तकनीकें (Encryption, Data Masking, Tokenization, Anonymization, Pseudonymization, MFA)।
6. Privacy एवं Confidentiality में अंतर।

7. Privacy एवं Security का संबंध।
8. Privacy पर प्रमुख खतरे एवं उनके समाधान।
9. भारत के **Digital Personal Data Protection Act, 2023** का संक्षिप्त परिचय।
10. अस्पताल, बैंक, सोशल मीडिया, विश्वविद्यालय तथा WhatsApp से संबंधित वास्तविक जीवन के उदाहरण।
11. उत्तर लिखते समय परिभाषा, तालिका, आरेख और कम-से-कम 4-5 वास्तविक उदाहरण अवश्य लिखें, इससे उत्तर अधिक प्रभावशाली और परीक्षा की दृष्टि से पूर्ण माना जाता है।



Trust (विश्वास)

साइबर सुरक्षा एवं सूचना सुरक्षा में विश्वास (Trust)

परिभाषा, सिद्धांत, प्रकार, महत्व, कार्यप्रणाली, मॉडल, उदाहरण एवं अनुप्रयोग सहित विस्तृत अध्ययन

अध्याय की रूपरेखा

1. परिचय (Introduction)
2. Trust की परिभाषा
3. Trust का अर्थ
4. Trust की आवश्यकता
5. Trust के उद्देश्य
6. Trust के मूल सिद्धांत
7. Trust के प्रमुख घटक
8. Trust कैसे स्थापित होता है?
9. Trust के प्रकार
10. Trust Model
11. Zero Trust Security Model
12. Chain of Trust
13. Root of Trust (RoT)
14. Trusted Computing
15. Trusted Platform Module (TPM)
16. Digital Certificate एवं Trust
17. Public Key Infrastructure (PKI)
18. Trust Relationship
19. Trust in Cloud Computing
20. Trust in Networking
21. Trust in E-Commerce
22. Trust in Banking
23. Trust in Digital Forensics
24. Trust पर खतरे
25. Trust बनाए रखने के उपाय
26. वास्तविक जीवन के उदाहरण
27. Advantages एवं Limitations
28. निष्कर्ष

1. परिचय (Introduction)

मानव जीवन में **विश्वास (Trust)** का अत्यधिक महत्व है। हम किसी डॉक्टर, बैंक, शिक्षक, मित्र या सरकारी संस्था पर तभी विश्वास करते हैं जब हमें यह विश्वास हो कि वे सही, सुरक्षित और ईमानदारी से कार्य करेंगे।

इसी प्रकार **साइबर सुरक्षा (Cyber Security)** एवं **सूचना सुरक्षा (Information Security)** में भी Trust एक अत्यंत महत्वपूर्ण अवधारणा है। जब कोई उपयोगकर्ता किसी वेबसाइट, सर्वर, मोबाइल एप्लिकेशन, क्लाउड सेवा या नेटवर्क का उपयोग करता है, तो वह यह अपेक्षा करता है कि—

- उसकी जानकारी सुरक्षित रहे।
- उसकी पहचान सही ढंग से सत्यापित हो।
- डेटा में कोई अनधिकृत परिवर्तन न हो।
- सेवा विश्वसनीय और उपलब्ध रहे।
- कोई तीसरा व्यक्ति उसकी जानकारी का दुरुपयोग न कर सके।

यदि यह विश्वास समाप्त हो जाए, तो उपयोगकर्ता उस सेवा का उपयोग करना बंद कर देता है। इसलिए आधुनिक सूचना प्रणालियों की सफलता का आधार Trust है।

2. Trust की परिभाषा (Definition)

Trust (**विश्वास**) वह स्थिति है जिसमें एक उपयोगकर्ता, सिस्टम, डिवाइस या संगठन को यह भरोसा होता है कि दूसरा उपयोगकर्ता, सिस्टम या सेवा अपेक्षित सुरक्षा नियमों (Security Policies), नैतिक मानकों और तकनीकी नियंत्रणों के अनुसार सही एवं सुरक्षित कार्य करेगी।

सरल परिभाषा

"जब किसी उपयोगकर्ता या प्रणाली को यह भरोसा हो कि दूसरा उपयोगकर्ता, डिवाइस या सेवा विश्वसनीय, सुरक्षित और सही व्यवहार करेगी, तो उसे Trust कहते हैं।"

3. Trust का अर्थ

साइबर सुरक्षा में Trust का अर्थ केवल विश्वास करना नहीं है, बल्कि **प्रमाण (Evidence)** और **सत्यापन (Verification)** के आधार पर विश्वास स्थापित करना है।

उदाहरण के लिए—

- HTTPS वेबसाइट पर ताले (🔒) का चिन्ह देखकर ब्राउज़र उस वेबसाइट के डिजिटल प्रमाणपत्र (Digital Certificate) की जाँच करता है।
- यदि प्रमाणपत्र वैध (Valid) है, तभी ब्राउज़र उस वेबसाइट पर Trust करता है।

अर्थात् आधुनिक साइबर सुरक्षा में "Trust is earned through verification, not assumption."

4. Trust की आवश्यकता (Need of Trust)

यदि Trust न हो तो—

- कोई ऑनलाइन बैंकिंग नहीं करेगा।
- कोई ई-कॉमर्स वेबसाइट से खरीदारी नहीं करेगा।
- क्लाउड सेवाओं का उपयोग कम हो जाएगा।
- डिजिटल हस्ताक्षर (Digital Signature) स्वीकार नहीं किए जाएँगे।
- ई-गवर्नेंस सेवाओं पर लोगों का विश्वास कम हो जाएगा।

5. Trust के उद्देश्य (Objectives)

- सुरक्षित संचार स्थापित करना।
- उपयोगकर्ता की पहचान पर विश्वास करना।
- डेटा की गोपनीयता और अखंडता बनाए रखना।
- सुरक्षित लेन-देन सुनिश्चित करना।
- डिजिटल सेवाओं में विश्वसनीयता बढ़ाना।
- साइबर हमलों से सुरक्षा बढ़ाना।
- उपयोगकर्ताओं का विश्वास बनाए रखना।

6. Trust के मूल सिद्धांत (Principles of Trust)

(1) Authentication

पहचान सत्यापित किए बिना Trust स्थापित नहीं किया जा सकता।

उदाहरण: बैंक में Username + Password + OTP।

(2) Authorization

विश्वास के आधार पर भी प्रत्येक उपयोगकर्ता को केवल आवश्यक अधिकार दिए जाते हैं।

(3) Integrity

विश्वास तभी संभव है जब डेटा सही और अपरिवर्तित हो।

(4) Confidentiality

गोपनीय जानकारी सुरक्षित रहे।

(5) Availability

सेवा आवश्यकता पड़ने पर उपलब्ध हो।

(6) Accountability

किए गए कार्यों का रिकॉर्ड उपलब्ध हो।

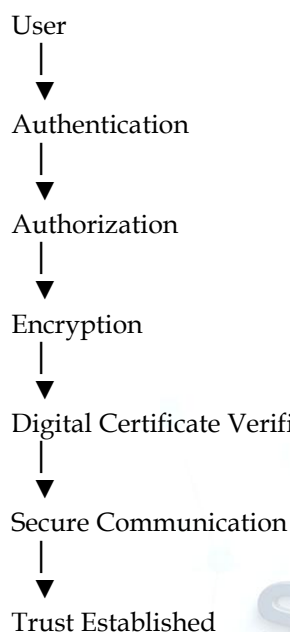
7. Trust के प्रमुख घटक (Components)

घटक	विवरण
Identity	उपयोगकर्ता की पहचान
Authentication	पहचान का सत्यापन
Authorization	अधिकार निर्धारण
Integrity	डेटा की शुद्धता
Confidentiality	डेटा की गोपनीयता

घटक	विवरण
Availability	सेवा की उपलब्धता
Audit	गतिविधियों का रिकॉर्ड
Digital Certificate	विश्वसनीय पहचान
Encryption	सुरक्षित संचार

8. Trust कैसे स्थापित होता है?

Trust स्थापित करने के लिए निम्न चरण अपनाए जाते हैं—



9. Trust के प्रकार (Types of Trust)

(A) User Trust

उपयोगकर्ता और सिस्टम के बीच विश्वास।

उदाहरण: Gmail Login।

(B) Device Trust

किसी डिवाइस की विश्वसनीयता।

उदाहरण: केवल कंपनी का अधिकृत लैपटॉप ही ऑफिस नेटवर्क में लॉगिन कर सकता है।

(C) Network Trust

नेटवर्क के विभिन्न उपकरणों के बीच विश्वास।

(D) Application Trust

सॉफ्टवेयर की विश्वसनीयता।

(E) Organizational Trust

कंपनी और ग्राहक के बीच विश्वास।

(F) Third-Party Trust

बाहरी सेवा प्रदाताओं पर विश्वास।

10. Trust Model

Trust Model वह नियमों का समूह है जिसके आधार पर यह तय किया जाता है कि किस पर और किन परिस्थितियों में विश्वास किया जाएगा।

मुख्य Trust Models –

- Hierarchical Trust Model
 - Web of Trust
 - Bridge Trust Model
 - Zero Trust Model
-

11. Zero Trust Security Model

परिचय

पहले नेटवर्क के अंदर मौजूद उपयोगकर्ताओं पर स्वतः विश्वास किया जाता था। आधुनिक साइबर सुरक्षा में यह दृष्टिकोण बदल गया है।

Zero Trust Model का सिद्धांत है—

"Never Trust, Always Verify."

अर्थात्—

- किसी उपयोगकर्ता, डिवाइस या एप्लिकेशन पर केवल नेटवर्क के अंदर होने के कारण विश्वास नहीं किया जाएगा।
- प्रत्येक अनुरोध (Request) का सत्यापन आवश्यक होगा।

मुख्य सिद्धांत

- Identity Verification
- MFA
- Least Privilege
- Continuous Monitoring
- Micro-Segmentation

उदाहरण

कंपनी का कर्मचारी कार्यालय नेटवर्क में होने पर भी हर संवेदनशील एप्लिकेशन के लिए MFA द्वारा सत्यापित होगा।

12. Chain of Trust

विश्वास की एक श्रृंखला जिसमें प्रत्येक स्तर अगले स्तर की विश्वसनीयता की पुष्टि करता है।

उदाहरण

```

Root CA
|
Intermediate CA
|
Website Certificate
|
User Browser
  
```

यदि Root Certificate विश्वसनीय है, तो उसके द्वारा जारी अन्य प्रमाणपत्र भी विश्वसनीय माने जाते हैं।

13. Root of Trust (RoT)

Root of Trust वह मूल हार्डवेयर या सॉफ्टवेयर घटक है जिस पर पूरे सिस्टम की सुरक्षा आधारित होती है।

उदाहरण

- Trusted Platform Module (TPM)
- Secure Boot
- Hardware Security Module (HSM)

14. Trusted Computing

यह ऐसी तकनीक है जिसमें कंप्यूटर केवल विश्वसनीय (Trusted) सॉफ्टवेयर और हार्डवेयर के साथ कार्य करता है।

15. Trusted Platform Module (TPM)

TPM एक विशेष सुरक्षा चिप है जो—

- Encryption Keys सुरक्षित रखती है।
- BitLocker Encryption को सुरक्षित बनाती है।
- Secure Boot में सहायता करती है।

उदाहरण

Windows 11 में TPM 2.0 अनिवार्य है।

16. Digital Certificate एवं Trust

HTTPS वेबसाइटों में Digital Certificate उपयोगकर्ता और वेबसाइट के बीच विश्वास स्थापित करता है।

उदाहरण

जब आप बैंक की वेबसाइट खोलते हैं—

<https://bank.com>

ब्राउज़र पहले SSL/TLS Certificate की जाँच करता है।

यदि Certificate Valid है—

तो ताले (🔒) का चिन्ह दिखाई देता है।

17. Public Key Infrastructure (PKI)

PKI Trust स्थापित करने की सबसे महत्वपूर्ण प्रणाली है।

इसमें—

- Certificate Authority (CA)
- Registration Authority (RA)
- Digital Certificate
- Public Key
- Private Key

शामिल होते हैं।

18. Trust Relationship

दो या अधिक सिस्टम के बीच स्थापित विश्वास।

उदाहरण

Microsoft Active Directory में दो Domains के बीच Trust Relationship बनाई जाती है ताकि दोनों डोमेन के उपयोगकर्ता आवश्यक संसाधनों का साझा उपयोग कर सकें।

19. Cloud Computing में Trust

Cloud Provider पर Trust के लिए—

- Encryption
- Access Control
- Identity Management
- Audit Logs
- Compliance Certification (जैसे ISO 27001, SOC 2)

20. Networking में Trust

नेटवर्क उपकरण—

- Router
- Switch
- Firewall

एक-दूसरे की पहचान प्रमाणित करते हैं।

उदाहरण

VPN Tunnel स्थापित करने से पहले दोनों सिरों (Endpoints) का Authentication किया जाता है।

21. E-Commerce में Trust

Amazon, Flipkart जैसी वेबसाइटें Trust बनाए रखने के लिए—

- HTTPS
- OTP
- Secure Payment Gateway
- Digital Invoice
- Refund Policy

का उपयोग करती हैं।

22. Banking में Trust

बैंक निम्न तकनीकों से विश्वास स्थापित करते हैं—

- MFA
- OTP
- Encryption
- Transaction Logs
- Digital Certificate
- Fraud Detection System

23. Digital Forensics में Trust

डिजिटल साक्ष्य (Digital Evidence) पर विश्वास तभी किया जाता है जब—

- Hash Value समान हो।
- Chain of Custody सुरक्षित हो।
- Audit Trail उपलब्ध हो।

24. Trust पर प्रमुख खतरे (Threats)

- Phishing Attack
- Fake Website
- Spoofing
- Fake Digital Certificate
- Insider Threat
- Malware
- Social Engineering
- DNS Poisoning
- Certificate Forgery

25. Trust बनाए रखने के सर्वोत्तम उपाय (Best Practices)

- Multi-Factor Authentication लागू करें।
- केवल विश्वसनीय SSL/TLS Certificate का उपयोग करें।
- Zero Trust Architecture अपनाएँ।
- नियमित Security Audit करें।
- Patch Management करें।
- Strong Password Policy लागू करें।
- Least Privilege Principle अपनाएँ।
- Trusted Hardware (TPM, HSM) का उपयोग करें।
- कर्मचारियों को Security Awareness Training दें।
- नियमित Log Monitoring करें।

26. वास्तविक जीवन के उदाहरण

उदाहरण 1 : नेट बैंकिंग

ग्राहक बैंक की वेबसाइट खोलता है। HTTPS प्रमाणपत्र, OTP और MFA के माध्यम से सुरक्षित लॉगिन होता है। ग्राहक को विश्वास होता है कि उसका लेन-देन सुरक्षित है।

उदाहरण 2 : UPI भुगतान

UPI ऐप PIN सत्यापित करता है, बैंक सर्वर लेन-देन की पुष्टि करता है और Transaction ID जारी होती है। इससे उपयोगकर्ता और बैंक दोनों के बीच Trust स्थापित होता है।

उदाहरण 3 : विश्वविद्यालय ERP

शिक्षक Username और Password से लॉगिन करता है। केवल अधिकृत शिक्षक ही अंक दर्ज कर सकते हैं। छात्र केवल अपना परिणाम देख सकते हैं। यह Trust आधारित Access Control का उदाहरण है।

उदाहरण 4 : WhatsApp

WhatsApp में End-to-End Encryption के कारण उपयोगकर्ताओं को विश्वास रहता है कि उनके संदेश केवल प्रेषक और प्राप्तकर्ता ही पढ़ सकते हैं।

उदाहरण 5 : Windows 11 Secure Boot

कंप्यूटर चालू होने पर Secure Boot केवल विश्वसनीय (Signed) Boot Loader को चलने देता है। यदि कोई दुर्भावनापूर्ण Boot Loader हो, तो सिस्टम उसे रोक देता है।

27. Trust के लाभ (Advantages)

- सुरक्षित डिजिटल वातावरण।

- उपयोगकर्ता का विश्वास बढ़ता है।
- साइबर हमलों का जोखिम कम होता है।
- सुरक्षित ऑनलाइन लेन-देन।
- डिजिटल सेवाओं की विश्वसनीयता बढ़ती है।
- कानूनी एवं व्यावसायिक भरोसा मजबूत होता है।
- डेटा की सुरक्षा बेहतर होती है।

28. Trust की सीमाएँ (Limitations)

- Trust एक बार स्थापित होने के बाद भी समय-समय पर सत्यापन आवश्यक है।
- गलत कॉन्फिगरेशन से Trust का दुरुपयोग हो सकता है।
- फर्जी प्रमाणपत्र (Fake Certificates) जोखिम पैदा कर सकते हैं।
- Zero Trust लागू करना जटिल और महँगा हो सकता है।
- मानव त्रुटि (Human Error) Trust को कमजोर कर सकती है।

29. निष्कर्ष (Conclusion)

Trust आधुनिक साइबर सुरक्षा का मूल आधार है। यह केवल विश्वास की भावना नहीं, बल्कि तकनीकी सत्यापन (Technical Verification), पहचान प्रमाणीकरण (Authentication), प्राधिकरण (Authorization), डिजिटल प्रमाणपत्र (Digital Certificates), एन्क्रिप्शन (Encryption) और निरंतर निगरानी (Continuous Monitoring) पर आधारित एक वैज्ञानिक सुरक्षा सिद्धांत है। आज बैंकिंग, क्लाउड कम्प्यूटिंग, ई-कॉमर्स, सरकारी सेवाओं, विश्वविद्यालय ERP, डिजिटल फॉरेंसिक और कॉर्पोरेट नेटवर्क में Trust स्थापित करने के लिए PKI, Digital Signature, TLS/SSL, MFA, Zero Trust Architecture तथा TPM जैसी तकनीकों का व्यापक उपयोग किया जाता है।

विशेष रूप से आधुनिक साइबर सुरक्षा का नया दृष्टिकोण Zero Trust है, जिसका सिद्धांत है—

"Never Trust, Always Verify."

यानी किसी भी उपयोगकर्ता, डिवाइस या एप्लिकेशन पर बिना सत्यापन के विश्वास नहीं किया जाता। यही सिद्धांत आधुनिक सुरक्षित डिजिटल प्रणालियों की नींव बन चुका है।

30. परीक्षा की दृष्टि से अत्यंत महत्वपूर्ण बिंदु

1. Trust की परिभाषा एवं उद्देश्य।
2. Trust के प्रमुख घटक (Identity, Authentication, Authorization, Integrity, Confidentiality, Availability)।
3. Trust स्थापित करने की प्रक्रिया।
4. Trust के प्रकार।
5. Trust Model एवं Zero Trust Model।
6. Chain of Trust एवं Root of Trust।
7. Trusted Platform Module (TPM) का महत्व।
8. PKI एवं Digital Certificate की भूमिका।
9. Cloud Computing, Banking, Networking एवं Digital Forensics में Trust का उपयोग।
10. Trust पर प्रमुख खतरे एवं उनके समाधान।
11. **उत्तर लिखते समय Trust की अवधारणा, Zero Trust का सिद्धांत ("Never Trust, Always Verify"), कार्यप्रवाह आरेख, तालिकाएँ तथा वास्तविक जीवन के उदाहरण अवश्य लिखें, क्योंकि विश्वविद्यालय एवं प्रतियोगी परीक्षाओं में इन बिंदुओं पर अक्सर प्रश्न पूछे जाते हैं।**



अध्याय 3

Cyber Security Domains

(साइबर सुरक्षा के प्रमुख क्षेत्र)

परिचय (Introduction)

आज का युग डिजिटल युग है। प्रत्येक व्यक्ति, संस्था, उद्योग, बैंक, विद्यालय, विश्वविद्यालय, अस्पताल तथा सरकार अपनी अधिकांश सेवाएँ इंटरनेट एवं कंप्यूटर नेटवर्क के माध्यम से संचालित कर रही हैं। जैसे-जैसे डिजिटल तकनीक का विस्तार हुआ है, वैसे-वैसे साइबर अपराध (Cyber Crime) और साइबर हमलों (Cyber Attacks) में भी अत्यधिक वृद्धि हुई है।

इसी कारण Cyber Security केवल एक विषय नहीं बल्कि अनेक विशिष्ट क्षेत्रों (Domains) का समूह बन चुका है।

Cyber Security Domain का अर्थ है—

साइबर सुरक्षा का वह विशेष क्षेत्र जिसमें किसी निश्चित प्रकार के सिस्टम, नेटवर्क, डेटा, एप्लिकेशन या उपयोगकर्ता की सुरक्षा के लिए अलग-अलग तकनीकों, नियमों एवं प्रक्रियाओं का उपयोग किया जाता है।

दूसरे शब्दों में—

Cyber Security Domains विभिन्न विशेषज्ञताओं (Specializations) का समूह हैं, जिनका उद्देश्य डिजिटल संसाधनों की गोपनीयता (Confidentiality), अखंडता (Integrity), उपलब्धता (Availability) तथा विश्वसनीयता (Trust) बनाए रखना है।

Cyber Security Domains का महत्व

यदि Cyber Security को एक बड़े अस्पताल के समान माना जाए, तो उसके विभिन्न विभाग (जैसे Surgery, Cardiology, Neurology) अलग-अलग कार्य करते हैं।

उसी प्रकार Cyber Security में भी अनेक Domains होते हैं जो अलग-अलग प्रकार के खतरों से सुरक्षा प्रदान करते हैं।

उदाहरण

यदि कोई कंपनी है—

- Network Security → नेटवर्क की सुरक्षा करेगा।
- Application Security → Software की सुरक्षा करेगा।
- Information Security → डेटा की सुरक्षा करेगा।
- Cloud Security → Cloud Server की सुरक्षा करेगा।
- Mobile Security → मोबाइल की सुरक्षा करेगा।
- Incident Response → हमला होने पर कार्य करेगा।
- Digital Forensics → अपराधी को खोजेगा।

Cyber Security के प्रमुख Domains

Cyber Security के अनेक Domains हैं, जिनमें प्रमुख निम्नलिखित हैं—

1. Information Security
2. Network Security
3. Application Security
4. Cloud Security
5. Endpoint Security
6. Mobile Security
7. Internet of Things (IoT) Security
8. Operational Technology (OT) Security
9. Critical Infrastructure Security
10. Identity and Access Management (IAM)
11. Data Security
12. Cryptography
13. Digital Forensics
14. Incident Response
15. Security Operations Center (SOC)
16. Penetration Testing
17. Vulnerability Assessment
18. Malware Analysis
19. Cyber Threat Intelligence
20. Governance, Risk and Compliance (GRC)

अब प्रत्येक Domain का विस्तृत अध्ययन करते हैं।

1. Information Security (सूचना सुरक्षा)

परिचय

Information Security (InfoSec) वह क्षेत्र है जिसमें किसी भी प्रकार की सूचना (Information) की सुरक्षा की जाती है।

यह केवल कंप्यूटर में रखे डेटा तक सीमित नहीं है।

इसमें शामिल हैं—

- Digital Files
- Printed Documents
- Database
- Email
- Personal Records
- Government Documents

उद्देश्य

- Confidentiality
- Integrity
- Availability

इसे CIA Triad कहा जाता है।

उदाहरण

एक अस्पताल के मरीजों का रिकॉर्ड Database में रखा है।

यदि कोई व्यक्ति बिना अनुमति रिकॉर्ड बदल दे—

- मरीज की दवा बदल सकती है।
- गलत ऑपरेशन हो सकता है।

Information Security इसे रोकती है।

सुरक्षा उपाय

- Encryption
- Password
- Backup
- Access Control
- Data Classification

2. Network Security (नेटवर्क सुरक्षा)

परिचय

जब दो या दो से अधिक कंप्यूटर आपस में जुड़े होते हैं, तो उनके बीच डेटा सुरक्षित रखने की प्रक्रिया Network Security कहलाती है।

उद्देश्य

- Unauthorized Access रोकना
- Data Leakage रोकना
- Network Monitoring
- Malware रोकना

उपयोग किए जाने वाले उपकरण

- Firewall
- IDS
- IPS
- VPN
- NAC

उदाहरण

एक बैंक के सभी ATM नेटवर्क से जुड़े हैं।

यदि Hacker नेटवर्क में प्रवेश कर जाए तो—

- पैसे ट्रांसफर कर सकता है।
- ATM बंद कर सकता है।

Firewall और IDS इसे रोकते हैं।

3. Application Security (एप्लिकेशन सुरक्षा)

Application Security का उद्देश्य Software एवं Web Application को सुरक्षित बनाना है।

खतरे

- SQL Injection
- XSS
- CSRF
- Buffer Overflow
- Authentication Bypass

उदाहरण

यदि Online Banking Website में SQL Injection है—

Hacker पूरा Database चुरा सकता है।

सुरक्षा

- Secure Coding
- Input Validation
- Authentication
- Authorization
- Patch Management

4. Cloud Security (क्लाउड सुरक्षा)

Cloud में रखे गए Data, Server, Virtual Machine तथा Services की सुरक्षा Cloud Security कहलाती है।

Cloud Platforms

- AWS
 - Microsoft Azure
 - Google Cloud
-

खतरे

- Data Breach
 - Misconfiguration
 - Weak Password
 - Account Hijacking
-

उदाहरण

यदि Amazon AWS Bucket Public हो जाए—

सारा डेटा इंटरनेट पर दिखाई देने लगेगा।

सुरक्षा

- IAM
 - Encryption
 - MFA
 - Cloud Firewall
 - Logging
-

5. Endpoint Security

Endpoint वे सभी Devices हैं जो Network से जुड़े हैं।

जैसे—

- Laptop
 - Desktop
 - Mobile
 - Printer
 - POS Machine
-

सुरक्षा

- Antivirus
- EDR
- Patch Update
- USB Control

उदाहरण

किसी कर्मचारी ने Pendrive लगाई जिसमें Virus था।

Endpoint Security वायरस को रोक देती है।

6. Mobile Security

आज अधिकांश कार्य Mobile से होते हैं।

इसलिए Mobile Security अत्यंत आवश्यक है।

खतरे

- Fake Apps
- Banking Trojan
- Spyware
- SMS Phishing
- QR Fraud

उदाहरण

UPI App डाउनलोड करने के बजाय Fake App डाउनलोड कर लिया।

Bank Account खाली हो सकता है।

सुरक्षा

- Official Play Store
- Biometric Lock
- Device Encryption
- MFA

7. IoT Security (Internet of Things Security)

IoT Devices इंटरनेट से जुड़े Smart Devices होते हैं।

जैसे—

- Smart TV
- CCTV
- Smart Lock
- Smart Bulb
- Smart Refrigerator

खतरे

- Default Password
- Botnet
- Device Hijacking

उदाहरण

Mirai Botnet ने हजारों CCTV Camera Hack कर दिए थे।

सुरक्षा

- Password बदलना
- Firmware Update
- Network Isolation

8. Operational Technology (OT) Security

OT उन Systems की सुरक्षा करता है जो मशीनों को नियंत्रित करते हैं।

उदाहरण

- Factory
- Power Plant
- Railway
- Water Supply

यदि Power Plant Hack हो जाए—

पूरे शहर की बिजली बंद हो सकती है।

9. Critical Infrastructure Security

देश की महत्वपूर्ण सेवाओं की सुरक्षा।

इसमें शामिल हैं—

- बिजली
- रेलवे
- एयरपोर्ट
- बैंक
- सेना
- अस्पताल



उदाहरण

यदि रेलवे कंट्रोल सिस्टम Hack हो जाए—

ट्रेन दुर्घटना हो सकती है।

10. Identity and Access Management (IAM)

IAM यह तय करता है—

कौन?

क्या Access करेगा?

कब करेगा?

Components

- Authentication
- Authorization
- Single Sign-On
- Multi-Factor Authentication

उदाहरण

Student केवल अपना Result देख सकता है।

Principal पूरे स्कूल का Data देख सकता है।

11. Data Security

डेटा की सुरक्षा।

उपाय

- Encryption
- Backup
- DLP
- Access Control

उदाहरण

यदि Laptop चोरी हो जाए—

12. Cryptography

डेटा को गुप्त रूप में बदलने की तकनीक।

प्रकार

- Symmetric Encryption
 - Asymmetric Encryption
 - Hashing
 - Digital Signature
-

उदाहरण

HTTPS वेबसाइट SSL/TLS Encryption का उपयोग करती हैं।

13. Digital Forensics

Cyber Crime के डिजिटल साक्ष्य एकत्रित करना, सुरक्षित रखना, विश्लेषण करना और न्यायालय में प्रस्तुत करना।

कार्य

- Hard Disk Analysis
 - Mobile Analysis
 - Email Analysis
 - Memory Analysis
 - Log Analysis
-

उदाहरण

किसी कर्मचारी ने कंपनी का Secret Data चुराया।

Digital Forensics द्वारा—

- USB History
- Browser History
- Deleted Files
- Email Logs

निकाले जा सकते हैं।

14. Incident Response

Cyber Attack होने के बाद की प्रक्रिया।

चरण

1. Preparation
2. Detection
3. Containment
4. Eradication
5. Recovery
6. Lessons Learned

उदाहरण

Ransomware Attack होने पर—

- सिस्टम अलग करना
- Malware हटाना
- Backup Restore करना

15. Security Operations Center (SOC)

SOC एक ऐसा केंद्र है जहाँ 24×7 Cyber Security Monitoring होती है।

कार्य

- Log Monitoring
- Threat Detection
- Incident Response
- SIEM Monitoring

उदाहरण

बैंक का SOC रात में Login Attack पकड़ लेता है।

16. Penetration Testing

Ethical Hacker द्वारा सिस्टम की सुरक्षा जांचना।

प्रकार

- Black Box
- White Box
- Grey Box

उदाहरण

बैंक स्वयं Ethical Hacker को नियुक्त करता है।

17. Vulnerability Assessment

System में मौजूद कमजोरियों की पहचान करना।

Tools

- Nessus
- OpenVAS

उदाहरण

Server में पुराना Software मिला।

Report में लिखा गया—

"Update Required"

18. Malware Analysis

Virus, Worm, Trojan, Ransomware आदि का अध्ययन।

उद्देश्य

- Malware कैसे कार्य करता है?
- कैसे फैलता है?
- कैसे रोका जाए?

उदाहरण

WannaCry Ransomware का Analysis करके उसका व्यवहार समझा गया।

19. Cyber Threat Intelligence (CTI)

भविष्य के Cyber Attacks की जानकारी एकत्र करना।

स्रोत

- Dark Web
- Threat Feeds

- Security Reports
 - Honeypots
-

उदाहरण

यदि सूचना मिले कि किसी बैंक पर नया Ransomware आने वाला है—

पहले से सुरक्षा बढ़ा दी जाती है।

20. Governance, Risk and Compliance (GRC)

यह Domain सुनिश्चित करता है कि संगठन साइबर सुरक्षा नीतियों, जोखिम प्रबंधन तथा कानूनी नियमों का पालन करे।

भाग

- Governance (नीतियाँ एवं प्रबंधन)
 - Risk Management (जोखिम पहचान और नियंत्रण)
 - Compliance (कानूनों एवं मानकों का पालन)
-

उदाहरण

एक कंपनी ISO/IEC 27001 के अनुसार अपनी सूचना सुरक्षा नीति लागू करती है और नियमित ऑडिट कराती है।

Cyber Security Domains का सारांश (Summary)

Domain	मुख्य उद्देश्य	उदाहरण
Information Security	सूचना की सुरक्षा	अस्पताल का मरीज डेटा
Network Security	नेटवर्क की सुरक्षा	बैंक ATM नेटवर्क
Application Security	सॉफ्टवेयर सुरक्षा	इंटरनेट बैंकिंग
Cloud Security	क्लाउड सुरक्षा	AWS, Azure
Endpoint Security	डिवाइस सुरक्षा	लैपटॉप, डेस्कटॉप
Mobile Security	मोबाइल सुरक्षा	UPI ऐप
IoT Security	स्मार्ट डिवाइस सुरक्षा	CCTV, Smart Lock
OT Security	औद्योगिक नियंत्रण प्रणाली	बिजली संयंत्र
Critical Infrastructure Security	राष्ट्रीय महत्वपूर्ण सेवाएँ	रेलवे, एयरपोर्ट
IAM	पहचान एवं अभिगम नियंत्रण	छात्र/प्राचार्य अधिकार
Data Security	डेटा सुरक्षा	एन्क्रिप्टेड लैपटॉप
Cryptography	डेटा एन्क्रिप्शन	HTTPS
Digital Forensics	डिजिटल साक्ष्य विश्लेषण	साइबर अपराध जांच
Incident Response	साइबर घटना का प्रबंधन	Ransomware Recovery
SOC	24x7 निगरानी	बैंक SOC
Penetration Testing	सुरक्षा परीक्षण	Ethical Hacking
Vulnerability Assessment	कमजोरियों की पहचान	Server Scan
Malware Analysis	मैलवेयर अध्ययन	WannaCry Analysis
Cyber Threat Intelligence	खतरे की पूर्व जानकारी	Threat Feeds
GRC	नीतियाँ, जोखिम व अनुपालन	ISO/IEC 27001

निष्कर्ष

Cyber Security एक बहुआयामी (Multi-disciplinary) क्षेत्र है जिसमें प्रत्येक डोमेन का अपना विशिष्ट उद्देश्य और कार्यक्षेत्र होता है। आधुनिक संगठनों में केवल एक सुरक्षा उपाय पर्याप्त नहीं होता; बल्कि Information Security, Network Security, Application Security, Cloud Security, Identity and Access Management, Digital Forensics, Incident Response, SOC, Threat Intelligence तथा Governance जैसे सभी डोमेन मिलकर एक व्यापक सुरक्षा ढाँचा (Defense-in-Depth) तैयार करते हैं। किसी भी संगठन की प्रभावी साइबर सुरक्षा रणनीति तभी सफल मानी जाती है जब ये सभी डोमेन समन्वित रूप से कार्य करें और बदलते साइबर खतरों के अनुसार निरंतर अद्यतन किए जाएँ।

Network Security (नेटवर्क सुरक्षा)

अध्याय – Network Security (नेटवर्क सुरक्षा)

1. परिचय (Introduction)

आज के समय में लगभग सभी कंप्यूटर, मोबाइल, सर्वर, बैंकिंग सिस्टम, विद्यालय, विश्वविद्यालय, अस्पताल, सरकारी कार्यालय और उद्योग किसी न किसी नेटवर्क (Network) से जुड़े हुए हैं। जब दो या दो से अधिक कंप्यूटर या अन्य डिजिटल उपकरण आपस में डेटा (Data) का आदान-प्रदान करते हैं, तो उन्हें सुरक्षित रखना अत्यंत आवश्यक हो जाता है। यही कार्य Network Security (नेटवर्क सुरक्षा) का है।

Network Security साइबर सुरक्षा (Cyber Security) का एक महत्वपूर्ण डोमेन है, जिसका उद्देश्य कंप्यूटर नेटवर्क, नेटवर्क उपकरणों (Network Devices), नेटवर्क सेवाओं (Network Services) तथा नेटवर्क पर प्रवाहित होने वाले डेटा (Data in Transit) को अनधिकृत पहुँच (Unauthorized Access), चोरी (Data Theft), परिवर्तन (Modification), विनाश (Destruction) तथा साइबर हमलों (Cyber Attacks) से सुरक्षित रखना है।

सरल शब्दों में—

नेटवर्क सुरक्षा वह प्रक्रिया है जिसके द्वारा नेटवर्क में जुड़े सभी उपकरणों, डेटा तथा संचार (Communication) को सुरक्षित रखा जाता है ताकि केवल अधिकृत (Authorized) उपयोगकर्ता ही संसाधनों का उपयोग कर सकें।

2. नेटवर्क (Network) क्या है?

Network दो या दो से अधिक कंप्यूटर, सर्वर, मोबाइल, प्रिंटर या अन्य डिजिटल उपकरणों का ऐसा समूह है जो किसी माध्यम (Cable या Wireless) द्वारा जुड़े होते हैं और आपस में डेटा का आदान-प्रदान करते हैं।

उदाहरण

- विद्यालय का कंप्यूटर लैब
- बैंक की सभी शाखाएँ
- रेलवे आरक्षण प्रणाली
- इंटरनेट
- विश्वविद्यालय का LAN
- अस्पताल का नेटवर्क

3. Network Security की परिभाषा

Network Security वह तकनीक, नीति (Policy), प्रक्रिया (Procedure) तथा हार्डवेयर एवं सॉफ्टवेयर का समूह है, जिसका उद्देश्य नेटवर्क की गोपनीयता (Confidentiality), अखंडता (Integrity), उपलब्धता (Availability) तथा विश्वसनीयता (Reliability) को बनाए रखना है।

4. Network Security के उद्देश्य (Objectives)

Network Security के मुख्य उद्देश्य निम्नलिखित हैं—

(1) Confidentiality (गोपनीयता)

डेटा केवल अधिकृत व्यक्ति ही देख सके।

उदाहरण

बैंक ग्राहक का ATM PIN केवल ग्राहक और बैंक सर्वर तक सीमित रहे।

(2) Integrity (अखंडता)

डेटा रास्ते में बदला न जा सके।

उदाहरण

₹50,000 का ऑनलाइन भुगतान रास्ते में बदलकर ₹5,00,000 न हो जाए।

(3) Availability (उपलब्धता)

नेटवर्क हमेशा उपलब्ध रहे।

उदाहरण

ऑनलाइन परीक्षा के समय सर्वर बंद नहीं होना चाहिए।

(4) Authentication (प्रमाणीकरण)

उपयोगकर्ता की पहचान सत्यापित करना।

उदाहरण

Username + Password + OTP

(5) Authorization (अधिकार)

किसे क्या अनुमति है।

उदाहरण

Teacher विद्यार्थी के अंक बदल सकता है, लेकिन विद्यार्थी नहीं।

(6) Accountability (उत्तरदायित्व)

किसने क्या किया उसका रिकॉर्ड रखना।

उदाहरण

Server Log में लिखा रहेगा कि किसने Login किया।

5. Network Security की आवश्यकता

यदि Network Security न हो तो—

- डेटा चोरी हो सकता है।
- बैंक खाते हैक हो सकते हैं।
- वेबसाइट बंद हो सकती है।
- वायरस पूरे नेटवर्क में फैल सकता है।
- सरकारी गोपनीय जानकारी लीक हो सकती है।
- उद्योगों का उत्पादन रुक सकता है।

- अस्पताल का मरीज डेटा नष्ट हो सकता है।

6. Network Security के मुख्य घटक (Components)

(1) Firewall

Firewall नेटवर्क का सुरक्षा द्वार (Security Gate) होता है।

यह Incoming तथा Outgoing Traffic को नियंत्रित करता है।

कार्य

- अनधिकृत ट्रैफिक रोकना
- Port Filtering
- Packet Filtering
- Application Filtering

उदाहरण

यदि कोई Hacker Port 22 से प्रवेश करना चाहता है और Firewall ने उसे Block किया है, तो हमला असफल हो जाएगा।

(2) IDS (Intrusion Detection System)

IDS नेटवर्क की निगरानी करता है।

यह केवल हमला पहचानता है।

उदाहरण

यदि कोई व्यक्ति 1000 बार गलत Password डालता है, IDS Alert देगा।

(3) IPS (Intrusion Prevention System)

IPS हमला पहचानने के साथ-साथ उसे रोक भी देता है।

Brute Force Attack शुरू होते ही IPS IP Address Block कर देता है।

(4) Antivirus

नेटवर्क में Virus, Worm, Trojan आदि को पहचानकर हटाता है।

(5) VPN (Virtual Private Network)

VPN इंटरनेट पर सुरक्षित (Encrypted) कनेक्शन बनाता है।

उदाहरण

घर से कर्मचारी कंपनी के सर्वर से VPN द्वारा सुरक्षित रूप से जुड़ता है।

(6) Proxy Server

उपयोगकर्ता और इंटरनेट के बीच मध्यस्थ (Mediator) का कार्य करता है।

लाभ

- Privacy
 - Content Filtering
 - Speed बढ़ाना (Caching)
-

(7) Access Control

यह तय करता है कि कौन किस संसाधन तक पहुँच सकता है।

(8) NAC (Network Access Control)

नेटवर्क में प्रवेश करने वाले प्रत्येक Device की जाँच करता है।

यदि Device सुरक्षित नहीं है, तो प्रवेश नहीं मिलता।

7. Network Security के प्रकार

(1) Physical Security

नेटवर्क उपकरणों की भौतिक सुरक्षा।

उदाहरण

- Server Room
- CCTV
- Biometric Lock
- Security Guard

(2) Technical Security

Software आधारित सुरक्षा।

उदाहरण

Firewall

Encryption

IDS

IPS



(3) Administrative Security

Policy और नियम।

उदाहरण

- Password Policy
- User Policy
- Access Policy
- Backup Policy

8. Network Security में प्रयुक्त तकनीकें

Encryption

डेटा को गुप्त रूप में बदलना।

Digital Signature

डेटा भेजने वाले की पहचान सिद्ध करना।

SSL/TLS

HTTPS वेबसाइटों की सुरक्षा।

IPsec

VPN में प्रयुक्त सुरक्षा प्रोटोकॉल।

SSH

Secure Remote Login.

WPA3

Wi-Fi सुरक्षा।

9. Network Devices

Network Security में निम्न उपकरण उपयोग होते हैं—

- Router
- Switch
- Hub

- Bridge
- Gateway
- Firewall
- Modem
- Access Point
- Proxy Server

10. सामान्य नेटवर्क हमले (Common Network Attacks)

(1) DoS Attack (Denial of Service)

एक सिस्टम पर अत्यधिक ट्रैफिक भेजकर उसे बंद करना।

उदाहरण

एक वेबसाइट पर लाखों Request भेजना।

(2) DDoS Attack

हजारों संक्रमित कंप्यूटर (Botnet) एक साथ हमला करते हैं।

उदाहरण

ई-कॉमर्स वेबसाइट सेल के दौरान बंद हो जाती है।

(3) Man-in-the-Middle (MITM)

हमलावर दो पक्षों के बीच बैठकर डेटा पढ़ता या बदलता है।

उदाहरण

Public Wi-Fi पर Banking Login करना।

(4) Packet Sniffing

नेटवर्क पैकेट को चोरी-छिपे पढ़ना।

उदाहरण

असुरक्षित HTTP ट्रैफिक।

(5) Spoofing

नकली पहचान बनाकर हमला करना।

प्रकार

- IP Spoofing
 - ARP Spoofing
 - DNS Spoofing
 - Email Spoofing
-

(6) Session Hijacking

किसी उपयोगकर्ता का Session चुराना।

(7) Password Attack

- Dictionary Attack
 - Brute Force Attack
 - Rainbow Table Attack
-

(8) Malware Attack

- Virus
 - Worm
 - Trojan
 - Spyware
 - Ransomware
-

11. Network Security Policies

अच्छी सुरक्षा के लिए निम्न नीतियाँ आवश्यक हैं—

- Password Policy
- Backup Policy
- Update Policy
- Incident Response Policy
- Remote Access Policy
- BYOD Policy
- Email Policy
- Internet Usage Policy

12. नेटवर्क सुरक्षा के सर्वोत्तम उपाय (Best Practices)

1. मजबूत पासवर्ड (Strong Password) का उपयोग करें।
2. Multi-Factor Authentication (MFA) सक्षम करें।
3. Firewall हमेशा सक्रिय रखें।
4. नियमित रूप से सिस्टम और सॉफ्टवेयर अपडेट करें।
5. Antivirus/EDR का उपयोग करें।
6. नियमित Backup लें और उसकी जाँच करें।
7. नेटवर्क को Segmentation द्वारा अलग-अलग भागों में विभाजित करें।
8. केवल HTTPS और सुरक्षित प्रोटोकॉल (SSH, SFTP) का उपयोग करें।
9. सार्वजनिक Wi-Fi पर संवेदनशील कार्य करते समय VPN का उपयोग करें।
10. नियमित Vulnerability Assessment और Penetration Testing कराएँ।
11. SIEM एवं लॉग मॉनिटरिंग लागू करें।
12. कर्मचारियों को Cyber Security Awareness Training दें।

13. वास्तविक जीवन के उदाहरण (Real-Life Examples)

उदाहरण 1 – बैंक नेटवर्क

एक बैंक की 500 शाखाएँ MPLS/VPN नेटवर्क से जुड़ी हैं। प्रत्येक शाखा में Firewall, IDS/IPS और एन्क्रिप्टेड संचार लागू है। यदि कोई संदिग्ध लॉगिन प्रयास होता है, तो SOC (Security Operations Center) तुरंत अलर्ट प्राप्त करता है और आवश्यक कार्रवाई करता है।

उदाहरण 2 – विश्वविद्यालय

विश्वविद्यालय के नेटवर्क में विद्यार्थियों, शिक्षकों और प्रशासन के लिए अलग-अलग VLAN बनाई गई हैं। प्रत्येक उपयोगकर्ता को केवल उसके कार्य के अनुसार Access दिया जाता है। इससे यदि किसी विद्यार्थी के सिस्टम में Malware आ भी जाए, तो वह पूरे नेटवर्क में आसानी से नहीं फैल पाता।

उदाहरण 3 – अस्पताल

अस्पताल में मरीजों का डेटा सुरक्षित सर्वर पर रखा जाता है। डॉक्टर VPN के माध्यम से दूरस्थ स्थान से सुरक्षित रूप से रिकॉर्ड देख सकते हैं। सभी संवेदनशील डेटा को Encryption द्वारा सुरक्षित किया जाता है और नियमित Backup लिया जाता है।

14. Network Security के लाभ

- डेटा चोरी से सुरक्षा
- हैकिंग के जोखिम में कमी
- व्यवसाय की निरंतरता (Business Continuity)
- ग्राहक का विश्वास बढ़ना
- कानूनी एवं नियामक अनुपालन (Compliance)
- वित्तीय नुकसान में कमी
- साइबर हमलों का शीघ्र पता लगना
- सुरक्षित ऑनलाइन बैंकिंग और ई-कॉमर्स

15. सारांश (Summary)

Network Security किसी भी आधुनिक डिजिटल संगठन की सुरक्षा का आधार है। यह केवल Firewall लगाने तक सीमित नहीं है, बल्कि इसमें सुरक्षित नेटवर्क डिज़ाइन, Access Control, Encryption, IDS/IPS, VPN, लॉग मॉनिटरिंग, नियमित अपडेट, सुरक्षा नीतियाँ, उपयोगकर्ता प्रशिक्षण और निरंतर निगरानी जैसे अनेक पहलू शामिल हैं। एक प्रभावी Network Security व्यवस्था संगठन के डेटा, सेवाओं और प्रतिष्ठा की रक्षा करती है तथा साइबर हमलों के प्रभाव को न्यूनतम करती है।

अध्याय – Information Security (सूचना सुरक्षा)

1. परिचय (Introduction)

आज का युग **डिजिटल सूचना (Digital Information)** का युग है। वर्तमान समय में प्रत्येक व्यक्ति, विद्यालय, विश्वविद्यालय, अस्पताल, बैंक, उद्योग तथा सरकारी विभाग अपने महत्वपूर्ण दस्तावेज़, रिकॉर्ड, वित्तीय जानकारी, शोध, ई-मेल, फोटो, वीडियो तथा अन्य संवेदनशील सूचनाओं को डिजिटल रूप में संग्रहीत (Store) करते हैं।

सूचना (Information) किसी भी संगठन की सबसे मूल्यवान संपत्ति (Valuable Asset) होती है। यदि यह सूचना चोरी हो जाए, बदल दी जाए, नष्ट हो जाए या गलत व्यक्ति के हाथ लग जाए, तो व्यक्ति, संस्था या देश को भारी आर्थिक, सामाजिक और कानूनी नुकसान हो सकता है।

इसीलिए **Information Security (InfoSec)** का उद्देश्य सूचना को हर प्रकार के खतरे से सुरक्षित रखना है।

2. Information Security क्या है?

Information Security (InfoSec) वह प्रक्रिया है जिसके द्वारा किसी भी प्रकार की सूचना (Information) को **अनधिकृत पहुँच (Unauthorized Access)**, **परिवर्तन (Modification)**, **चोरी (Theft)**, **नष्ट होने (Destruction)**, **लीक (Disclosure)** तथा **दुरुपयोग (Misuse)** से सुरक्षित रखा जाता है।

यह सुरक्षा केवल कंप्यूटर में रखे डेटा तक सीमित नहीं होती, बल्कि हर प्रकार की सूचना पर लागू होती है।

उदाहरण

- कंप्यूटर में रखी फाइलें
- बैंक का ग्राहक डेटा
- अस्पताल का मरीज रिकॉर्ड
- विश्वविद्यालय का परीक्षा परिणाम
- सरकारी गोपनीय दस्तावेज़
- कागज़ी फाइलें
- USB Drive
- मोबाइल में सेव जानकारी
- क्लाउड स्टोरेज
- ई-मेल

Information Security वह प्रक्रिया है जो यह सुनिश्चित करती है कि सही व्यक्ति सही समय पर सही सूचना तक सुरक्षित रूप से पहुँच सके, जबकि अनधिकृत व्यक्ति उससे दूर रहे।

3. Information Security की परिभाषा

Information Security वह अनुशासन (Discipline) है जिसमें नीतियों (Policies), प्रक्रियाओं (Procedures), तकनीकों (Technologies) तथा नियंत्रणों (Controls) का उपयोग करके सूचना की गोपनीयता (Confidentiality), अखंडता (Integrity) और उपलब्धता (Availability) सुनिश्चित की जाती है।

4. Information Security के उद्देश्य (Objectives)

Information Security के तीन मुख्य उद्देश्य CIA Triad कहलाते हैं।

(1) Confidentiality (गोपनीयता)

अर्थ

सूचना केवल अधिकृत (Authorized) व्यक्ति ही देख सके।

उदाहरण

एक बैंक ग्राहक का ATM PIN केवल ग्राहक और बैंक सर्वर को ही पता होना चाहिए।

यदि कोई हैकर PIN जान लेता है, तो गोपनीयता समाप्त हो जाती है।

गोपनीयता बनाए रखने के उपाय

- Password
- Encryption
- Biometric Authentication
- Access Control
- Multi-Factor Authentication (MFA)

(2) Integrity (अखंडता)

अर्थ

सूचना में बिना अनुमति कोई परिवर्तन न हो।

उदाहरण

विश्वविद्यालय के परीक्षा परिणाम में छात्र के 75 अंक को किसी ने बदलकर 95 कर दिया।

यह Integrity का उल्लंघन है।

अखंडता बनाए रखने के उपाय

- Hashing
- Digital Signature
- Version Control
- Audit Log

(3) Availability (उपलब्धता)

अर्थ

जब अधिकृत उपयोगकर्ता को आवश्यकता हो, तब सूचना उपलब्ध हो।

उदाहरण

अस्पताल के डॉक्टर को ऑपरेशन के समय मरीज का रिकॉर्ड तुरंत मिल जाना चाहिए।

यदि सर्वर बंद हो जाए और रिकॉर्ड उपलब्ध न हो, तो Availability प्रभावित होती है।

उपलब्धता बनाए रखने के उपाय

- Backup
- Redundant Server
- UPS
- Disaster Recovery Plan
- High Availability Systems

5. Information Security के अन्य सिद्धांत

CIA Triad के अतिरिक्त आधुनिक Information Security में निम्न सिद्धांत भी महत्वपूर्ण हैं।

(1) Authentication (प्रमाणीकरण)

उपयोगकर्ता की पहचान सत्यापित करना।

उदाहरण

- Username + Password
- OTP
- Fingerprint
- Face Recognition

(2) Authorization (प्राधिकरण)

यह निर्धारित करना कि उपयोगकर्ता क्या कर सकता है।

उदाहरण

- छात्र केवल अपना परिणाम देख सकता है।
- शिक्षक अंक दर्ज कर सकता है।
- परीक्षा नियंत्रक परिणाम संशोधित कर सकता है।

(3) Accountability (उत्तरदायित्व)

किस उपयोगकर्ता ने क्या कार्य किया, इसका रिकॉर्ड रखना।

उदाहरण

यदि किसी कर्मचारी ने फाइल हटाई, तो Audit Log में उसका विवरण उपलब्ध रहेगा।

(4) Non-Repudiation (अस्वीकरण-असम्भवता)

भेजने वाला या प्राप्त करने वाला बाद में यह नहीं कह सकता कि उसने कार्य नहीं किया।

डिजिटल हस्ताक्षर (Digital Signature) द्वारा भेजे गए दस्तावेज़।

(5) Privacy (गोपनीय निजी जानकारी की सुरक्षा)

व्यक्ति की व्यक्तिगत जानकारी की सुरक्षा करना।

उदाहरण

- आधार संख्या
 - मोबाइल नंबर
 - स्वास्थ्य रिकॉर्ड
 - बैंक विवरण
-

6. Information Security का महत्व

Information Security निम्न कारणों से अत्यंत आवश्यक है—

- व्यक्तिगत जानकारी की सुरक्षा
 - बैंकिंग लेन-देन की सुरक्षा
 - सरकारी गोपनीय सूचनाओं की सुरक्षा
 - व्यापारिक रहस्यों (Trade Secrets) की रक्षा
 - साइबर अपराधों की रोकथाम
 - कानूनी अनुपालन (Compliance)
 - ग्राहक का विश्वास बनाए रखना
 - आर्थिक नुकसान से बचाव
-

7. सूचना के प्रकार (Types of Information)

Information Security सभी प्रकार की सूचनाओं की रक्षा करती है।

(1) व्यक्तिगत सूचना

- नाम
 - पता
 - मोबाइल नंबर
 - आधार संख्या
-

(2) वित्तीय सूचना

- बैंक खाता
 - क्रेडिट कार्ड
 - UPI जानकारी
-

(3) व्यावसायिक सूचना

- कंपनी का डेटा
 - ग्राहक सूची
 - बिक्री रिपोर्ट
-

(4) सरकारी सूचना

- रक्षा संबंधी दस्तावेज़
 - नीति दस्तावेज़
 - नागरिक रिकॉर्ड
-

(5) चिकित्सा सूचना

- मरीज का इतिहास
 - दवा विवरण
 - परीक्षण रिपोर्ट
-

(6) शैक्षणिक सूचना

- परीक्षा परिणाम
- छात्र रिकॉर्ड



8. Information Security के खतरे (Threats)

(1) Malware

- Virus
- Worm
- Trojan
- Spyware
- Ransomware

उदाहरण: रैनसमवेयर कंपनी की सभी फाइलों को एन्क्रिप्ट कर फिरोती मांगता है।

(2) Phishing

नकली ई-मेल या वेबसाइट के माध्यम से पासवर्ड चोरी करना।

उदाहरण: बैंक के नाम से नकली ई-मेल भेजकर लॉगिन विवरण मांगना।

(3) Insider Threat

संगठन का कर्मचारी ही जानकारी चुरा ले।

उदाहरण: कर्मचारी ग्राहक सूची को प्रतियोगी कंपनी को बेच दे।

(4) Social Engineering

लोगों को धोखा देकर जानकारी प्राप्त करना।

उदाहरण: कोई व्यक्ति स्वयं को बैंक अधिकारी बताकर OTP पूछ ले।

(5) Data Leakage

संवेदनशील जानकारी का अनजाने या जानबूझकर बाहर जाना।

(6) Human Error

गलती से गलत व्यक्ति को ई-मेल भेज देना।

(7) Physical Theft

लैपटॉप, हार्ड डिस्क या USB चोरी हो जाना।

9. Information Security Controls (सुरक्षा नियंत्रण)

(A) Administrative Controls

ये नीतियों और प्रक्रियाओं से संबंधित होते हैं।

उदाहरण

- Information Security Policy
- Password Policy
- Backup Policy
- Employee Training
- Risk Assessment

(B) Technical Controls

ये तकनीकी साधनों द्वारा लागू किए जाते हैं।

उदाहरण

- Firewall
- Encryption
- Antivirus
- MFA
- IDS/IPS
- Access Control
- Data Loss Prevention (DLP)

(C) Physical Controls

ये भौतिक सुरक्षा से संबंधित होते हैं।

उदाहरण

- CCTV
- Security Guard
- Biometric Door Lock
- Fire Alarm
- Server Room Access Control

10. Data Classification (डेटा वर्गीकरण)

सूचना की संवेदनशीलता के आधार पर वर्गीकरण किया जाता है।

श्रेणी	विवरण	उदाहरण
Public	सभी के लिए उपलब्ध	कंपनी की वेबसाइट
Internal	केवल कर्मचारियों के लिए	आंतरिक सूचना
Confidential	सीमित व्यक्तियों के लिए	वेतन विवरण
Secret	अत्यधिक संवेदनशील	रक्षा दस्तावेज़
Top Secret	सर्वोच्च गोपनीय	राष्ट्रीय सुरक्षा योजना

11. Information Security में प्रयुक्त प्रमुख तकनीकें

- Encryption (AES, RSA)
- Hashing (SHA-256)
- Digital Signature
- Access Control
- Identity and Access Management (IAM)
- Data Loss Prevention (DLP)
- Backup & Recovery
- Tokenization
- Security Information and Event Management (SIEM)
- Multi-Factor Authentication (MFA)

12. Information Security के वास्तविक उदाहरण

उदाहरण 1 – बैंक

एक बैंक अपने ग्राहकों के खाते की जानकारी को AES एन्क्रिप्शन द्वारा सुरक्षित रखता है। ग्राहक लॉगिन के समय पासवर्ड के साथ OTP भी दर्ज करता है। इससे गोपनीयता और प्रमाणीकरण दोनों सुनिश्चित होते हैं।

उदाहरण 2 – अस्पताल

अस्पताल में मरीजों का मेडिकल रिकॉर्ड केवल अधिकृत डॉक्टर और संबंधित चिकित्सा कर्मचारी ही देख सकते हैं। प्रत्येक एक्सेस का लॉग रखा जाता है और नियमित बैकअप लिया जाता है।

उदाहरण 3 – विश्वविद्यालय

विश्वविद्यालय में छात्र केवल अपना परिणाम देख सकता है, जबकि शिक्षक अंक दर्ज कर सकते हैं और परीक्षा नियंत्रक परिणाम प्रकाशित कर सकता है। यह **Role-Based Access Control (RBAC)** का उदाहरण है।

उदाहरण 4 – सरकारी विभाग

रक्षा मंत्रालय के गोपनीय दस्तावेज़ एन्क्रिप्टेड सर्वर में संग्रहीत किए जाते हैं। केवल अधिकृत अधिकारियों को डिजिटल प्रमाणपत्र (Digital Certificate) के माध्यम से पहुँच प्रदान की जाती है।

13. Information Security के लाभ

- सूचना की गोपनीयता बनी रहती है।
- डेटा में अनधिकृत परिवर्तन नहीं होता।
- आवश्यक समय पर सूचना उपलब्ध रहती है।
- साइबर हमलों का जोखिम कम होता है।
- कानूनी नियमों और मानकों का पालन आसान होता है।
- ग्राहक और नागरिकों का विश्वास बढ़ता है।
- आर्थिक एवं प्रतिष्ठागत नुकसान कम होता है।

- संगठन की कार्यक्षमता और विश्वसनीयता बढ़ती है।

14. Information Security और Cyber Security में अंतर

आधार	Information Security	Cyber Security
कार्यक्षेत्र	सभी प्रकार की सूचना की सुरक्षा	डिजिटल सिस्टम, नेटवर्क और साइबर स्पेस की सुरक्षा
सूचना	डिजिटल और कागज़ी दोनों	मुख्यतः डिजिटल
उद्देश्य	सूचना की सुरक्षा	साइबर हमलों से सुरक्षा
उदाहरण	गोपनीय फाइलों की सुरक्षा	नेटवर्क, सर्वर और वेबसाइट की सुरक्षा

15. निष्कर्ष (Conclusion)

Information Security किसी भी संगठन की सुरक्षा व्यवस्था का मूल आधार है। इसका उद्देश्य केवल डेटा को सुरक्षित रखना नहीं, बल्कि यह सुनिश्चित करना भी है कि सूचना **गोपनीय (Confidential)**, **अखंड (Integrity युक्त)** और **उपलब्ध (Available)** रहे। आधुनिक युग में बैंकिंग, स्वास्थ्य, शिक्षा, ई-गवर्नेंस, ई-कॉमर्स तथा उद्योग जैसे सभी क्षेत्रों में Information Security अनिवार्य हो चुकी है। प्रभावी सुरक्षा नीतियाँ, एन्क्रिप्शन, एक्सेस कंट्रोल, नियमित बैकअप, उपयोगकर्ता जागरूकता और निरंतर निगरानी मिलकर एक मजबूत Information Security Framework का निर्माण करते हैं, जो संगठन को साइबर खतरों और डेटा उल्लंघनों (Data Breaches) से सुरक्षित रखता है।

अध्याय – Cloud Security (क्लाउड सुरक्षा)

1. परिचय (Introduction)

वर्तमान समय में अधिकांश संस्थाएँ, कंपनियाँ, बैंक, विद्यालय, विश्वविद्यालय, अस्पताल तथा सरकारी विभाग अपने डेटा, एप्लिकेशन और सेवाओं को स्थानीय कंप्यूटर (Local Server) के बजाय Cloud (क्लाउड) पर संग्रहीत (Store) और संचालित (Operate) कर रहे हैं।

Cloud Computing ने आईटी क्षेत्र में क्रांति ला दी है। इससे डेटा कहीं से भी, कभी भी और किसी भी अधिकृत उपयोगकर्ता द्वारा इंटरनेट के माध्यम से उपयोग किया जा सकता है। लेकिन जहाँ सुविधा बढ़ी है, वहीं डेटा चोरी (Data Breach), अनधिकृत पहुँच (Unauthorized Access), रैनसमवेयर (Ransomware), गलत कॉन्फिगरेशन (Misconfiguration) और साइबर हमलों का जोखिम भी बढ़ गया है।

इसी कारण Cloud Security (क्लाउड सुरक्षा) अत्यंत महत्वपूर्ण हो गई है।

Cloud Security वह प्रक्रिया है जिसमें Cloud पर संग्रहीत डेटा, एप्लिकेशन, सर्वर, नेटवर्क, उपयोगकर्ताओं तथा सेवाओं को साइबर हमलों, डेटा चोरी, अनधिकृत पहुँच और अन्य सुरक्षा खतरों से सुरक्षित रखा जाता है।

2. Cloud क्या है?

Cloud (क्लाउड) इंटरनेट के माध्यम से उपलब्ध कंप्यूटिंग संसाधनों (Computing Resources) का एक समूह है, जहाँ उपयोगकर्ता बिना अपना सर्वर खरीदे निम्न सेवाओं का उपयोग कर सकता है—

- Data Storage
- Virtual Server
- Database
- Software
- Networking
- Backup
- Artificial Intelligence Services
- Email Services

Cloud में उपयोगकर्ता अपने डेटा और एप्लिकेशन को इंटरनेट के माध्यम से कहीं से भी एक्सेस कर सकता है।

3. Cloud Security की परिभाषा

Cloud Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें तकनीकों (Technologies), नीतियों (Policies), प्रक्रियाओं (Procedures) तथा नियंत्रणों (Controls) का उपयोग करके Cloud Environment की गोपनीयता (Confidentiality), अखंडता (Integrity), उपलब्धता (Availability) तथा विश्वसनीयता (Reliability) सुनिश्चित की जाती है।

4. Cloud Security के उद्देश्य (Objectives)

Cloud Security के प्रमुख उद्देश्य निम्नलिखित हैं—

(1) Confidentiality (गोपनीयता)

Cloud में रखा गया डेटा केवल अधिकृत उपयोगकर्ता ही देख सके।

उदाहरण

किसी बैंक के ग्राहकों का डेटा Cloud Database में रखा है। यदि कोई अनधिकृत व्यक्ति उसे देख ले, तो गोपनीयता भंग हो जाएगी।

(2) Integrity (अखंडता)

डेटा में बिना अनुमति परिवर्तन न हो।

उदाहरण

विश्वविद्यालय का परीक्षा परिणाम Cloud पर संग्रहीत है। यदि कोई हैकर अंक बदल दे, तो Integrity समाप्त हो जाएगी।

(3) Availability (उपलब्धता)

डेटा और सेवाएँ आवश्यकता पड़ने पर हमेशा उपलब्ध रहें।

उदाहरण

यदि अस्पताल का Cloud Server बंद हो जाए, तो डॉक्टर मरीजों का रिकॉर्ड नहीं देख पाएँगे।

(4) Authentication (प्रमाणीकरण)

Cloud उपयोगकर्ता की पहचान सत्यापित करना।

उदाहरण

Username + Password + OTP + Fingerprint

(5) Authorization (प्राधिकरण)

किस उपयोगकर्ता को कौन-सी Cloud Service उपयोग करने की अनुमति है।

5. Cloud Computing के प्रमुख सेवा मॉडल (Service Models)

(1) IaaS (Infrastructure as a Service)

इस मॉडल में Cloud Provider उपयोगकर्ता को Virtual Server, Storage, Network आदि उपलब्ध कराता है।

उदाहरण

- Virtual Machine
- Storage
- Network

उपयोगकर्ता स्वयं Operating System तथा Software स्थापित करता है।

(2) PaaS (Platform as a Service)

Cloud Provider विकास (Development) के लिए प्लेटफॉर्म उपलब्ध कराता है।

उदाहरण

डेवलपर केवल Application बनाता है, Server Management की आवश्यकता नहीं होती।

(3) SaaS (Software as a Service)

Cloud पर तैयार Software उपलब्ध कराया जाता है।

उदाहरण

- Email
- Online Office Suite
- CRM Software

उपयोगकर्ता केवल Software का उपयोग करता है।

6. Cloud Deployment Models

(1) Public Cloud

Cloud सभी उपयोगकर्ताओं के लिए उपलब्ध होता है।

उदाहरण

किसी स्टार्टअप ने Public Cloud पर अपनी वेबसाइट होस्ट की।

(2) Private Cloud

Cloud केवल एक संस्था के उपयोग के लिए होता है।

उदाहरण

रक्षा विभाग का निजी Cloud।

(3) Hybrid Cloud

Public तथा Private Cloud का संयोजन।

उदाहरण

विश्वविद्यालय छात्रों का सामान्य डेटा Public Cloud में तथा परीक्षा से संबंधित संवेदनशील डेटा Private Cloud में रखता है।

(4) Community Cloud

एक ही प्रकार की आवश्यकताओं वाले कई संगठन मिलकर उपयोग करते हैं।

उदाहरण

कई सरकारी विभाग साझा Cloud Infrastructure का उपयोग करें।

7. Cloud Security के प्रमुख घटक (Components)

(1) Identity and Access Management (IAM)

IAM यह निर्धारित करता है कि कौन Cloud में क्या कर सकता है।

कार्य

- User Authentication
- Role-Based Access Control (RBAC)
- Least Privilege Principle
- Multi-Factor Authentication (MFA)

उदाहरण

छात्र केवल अपना रिकॉर्ड देख सकता है, जबकि प्रशासक (Administrator) सभी रिकॉर्ड प्रबंधित कर सकता है।

(2) Data Encryption

Cloud में डेटा को एन्क्रिप्ट कर सुरक्षित किया जाता है।

प्रकार

- Data at Rest (संग्रहित डेटा)
- Data in Transit (प्रेषित डेटा)
- Data in Use (प्रसंस्करण के दौरान डेटा)

उदाहरण

यदि किसी ने Cloud Storage की हार्ड डिस्क चुरा ली, तो एन्क्रिप्टेड डेटा पढ़ा नहीं जा सकेगा।

(3) Firewall

Cloud Firewall अनधिकृत नेटवर्क ट्रैफिक को रोकता है।

(4) Virtual Private Network (VPN)

दूरस्थ उपयोगकर्ता और Cloud के बीच सुरक्षित एन्क्रिप्टेड कनेक्शन स्थापित करता है।

(5) Security Monitoring

Cloud गतिविधियों की निरंतर निगरानी की जाती है।

उदाहरण

- Login Attempts
- Failed Authentication
- Data Download
- Configuration Changes

(6) Backup and Disaster Recovery

डेटा की नियमित प्रतिलिपि (Backup) बनाई जाती है तथा आपदा की स्थिति में उसे पुनः प्राप्त (Recovery) किया जाता है।

8. Cloud Security में प्रयुक्त प्रमुख तकनीकें

- AES Encryption
- RSA Encryption
- TLS/SSL
- Digital Certificate
- Identity and Access Management (IAM)
- Security Information and Event Management (SIEM)
- Cloud Access Security Broker (CASB)
- Data Loss Prevention (DLP)
- Web Application Firewall (WAF)
- Endpoint Detection and Response (EDR)

9. Cloud Security के खतरे (Threats)

(1) Data Breach

अनधिकृत व्यक्ति द्वारा संवेदनशील डेटा प्राप्त कर लेना।

उदाहरण

किसी कंपनी का ग्राहक डेटा सार्वजनिक हो जाना।

(2) Misconfiguration

Cloud की गलत सेटिंग्स के कारण डेटा सार्वजनिक हो जाना।

उदाहरण

Storage Bucket को Public Access दे देना।

(3) Weak Password

कमजोर पासवर्ड के कारण Cloud Account Hack हो जाना।

(4) Account Hijacking

हमलावर उपयोगकर्ता का Cloud Account अपने नियंत्रण में ले लेता है।

उदाहरण

Phishing द्वारा Password चुरा लेना।

(5) Insider Threat

कंपनी का कर्मचारी ही डेटा चोरी कर ले।

(6) Malware Attack

Cloud Server में Malware स्थापित कर देना।

(7) Denial of Service (DoS/DDoS)

Cloud Service को अत्यधिक ट्रैफिक भेजकर अनुपलब्ध करना।

(8) API Attack

Cloud API की कमजोरी का लाभ उठाकर हमला करना।

(9) Data Loss

हार्डवेयर विफलता, मानव त्रुटि या साइबर हमले के कारण डेटा नष्ट होना।

(10) Ransomware

Cloud Storage को एन्क्रिप्ट कर फिरोती माँगना।

10. Shared Responsibility Model

Cloud Security में सुरक्षा की जिम्मेदारी Cloud Provider और ग्राहक (Customer) दोनों की होती है।

Cloud Provider की जिम्मेदारी ग्राहक की जिम्मेदारी

Physical Data Center	User Account Security
Server Hardware	Password Management
Network Infrastructure	Data Encryption
Hypervisor Security	Access Control
Power & Cooling	Application Security
Physical Access	Backup Policy

11. Cloud Security Best Practices

1. Multi-Factor Authentication (MFA) सक्षम करें।
2. Strong Password Policy अपनाएँ।
3. Least Privilege Principle लागू करें।
4. सभी डेटा को Encryption द्वारा सुरक्षित रखें।
5. नियमित Backup लें।
6. Cloud Configuration का समय-समय पर Audit करें।
7. सभी API Keys सुरक्षित रखें।
8. IAM Roles का सही उपयोग करें।
9. नियमित Vulnerability Assessment और Penetration Testing कराएँ।
10. सभी Security Logs की निगरानी करें।
11. Public Access केवल आवश्यकता होने पर ही दें।
12. नियमित Patch Management करें।

12. Cloud Security के वास्तविक उदाहरण

उदाहरण 1 – बैंक

एक बैंक अपने ग्राहक डेटा को Cloud Database में AES-256 एन्क्रिप्शन के साथ संग्रहीत करता है। प्रत्येक कर्मचारी के लिए Multi-Factor Authentication तथा Role-Based Access Control लागू किया गया है। सभी गतिविधियों की निगरानी SIEM द्वारा की जाती है।

उदाहरण 2 - विश्वविद्यालय

विश्वविद्यालय छात्रों के रिकॉर्ड, परीक्षा परिणाम और अध्ययन सामग्री Cloud पर संग्रहीत करता है। छात्रों को केवल अपना डेटा देखने की अनुमति होती है, जबकि परीक्षा नियंत्रक सभी परिणाम प्रबंधित कर सकता है।

उदाहरण 3 - अस्पताल

अस्पताल मरीजों की मेडिकल रिपोर्ट Cloud Storage में रखता है। डॉक्टर VPN के माध्यम से सुरक्षित रूप से रिकॉर्ड देख सकते हैं। डेटा का दैनिक बैकअप लिया जाता है और Disaster Recovery योजना तैयार रहती है।

उदाहरण 4 - ई-कॉमर्स कंपनी

एक ई-कॉमर्स वेबसाइट अपने उत्पाद, ग्राहक डेटा और भुगतान सेवाएँ Cloud पर संचालित करती है। Web Application Firewall (WAF), DDoS Protection, TLS Encryption और नियमित Security Monitoring के माध्यम से ग्राहकों की जानकारी सुरक्षित रखी जाती है।

13. Cloud Security के लाभ

- कहीं से भी सुरक्षित पहुँच (Anywhere Secure Access)
 - उच्च उपलब्धता (High Availability)
 - डेटा का एन्क्रिप्शन
 - कम हार्डवेयर लागत
 - स्वचालित बैकअप
 - तेज़ Disaster Recovery
 - बेहतर Scalability
 - उन्नत निगरानी (Monitoring)
 - अनुपालन (Compliance) में सहायता
 - व्यवसाय की निरंतरता (Business Continuity)
-

14. Cloud Security की चुनौतियाँ

- डेटा गोपनीयता बनाए रखना
- Cloud Configuration Errors
- Insider Threat
- Multi-Cloud Management की जटिलता
- API Security
- Compliance Requirements
- Shared Responsibility को सही ढंग से लागू करना
- तेजी से बदलते साइबर खतरे

15. Cloud Security और Traditional Security में अंतर

आधार	Traditional Security	Cloud Security
सर्वर का स्थान	संगठन के परिसर में	Cloud Data Center
रखरखाव	संगठन स्वयं करता है	Cloud Provider + ग्राहक
स्केलेबिलिटी	सीमित	आवश्यकता अनुसार बढ़ाई/घटाई जा सकती है
लागत	अधिक	उपयोग के अनुसार (Pay-as-you-go)
बैकअप	मैन्युअल/स्थानीय	स्वचालित एवं वितरित
सुरक्षा मॉडल	पूर्णतः संगठन की जिम्मेदारी	Shared Responsibility Model

16. निष्कर्ष (Conclusion)

Cloud Security आधुनिक साइबर सुरक्षा का एक अत्यंत महत्वपूर्ण क्षेत्र है। आज अधिकांश डिजिटल सेवाएँ, बैंकिंग, शिक्षा, स्वास्थ्य, ई-कॉमर्स तथा सरकारी अनुप्रयोग Cloud पर आधारित हैं। इसलिए केवल डेटा को Cloud में स्थानांतरित करना पर्याप्त नहीं है, बल्कि उसकी सुरक्षा सुनिश्चित करना भी आवश्यक है। मजबूत Identity and Access Management (IAM), Encryption, Multi-Factor Authentication (MFA), Backup एवं Disaster Recovery, Security Monitoring, Cloud Configuration Management तथा Shared Responsibility Model का सही पालन करके Cloud वातावरण को सुरक्षित बनाया जा सकता है। प्रभावी Cloud Security न केवल डेटा की गोपनीयता, अखंडता और उपलब्धता बनाए रखती है, बल्कि संगठन की विश्वसनीयता, कानूनी अनुपालन और व्यवसाय की निरंतरता को भी सुदृढ़ करती है।

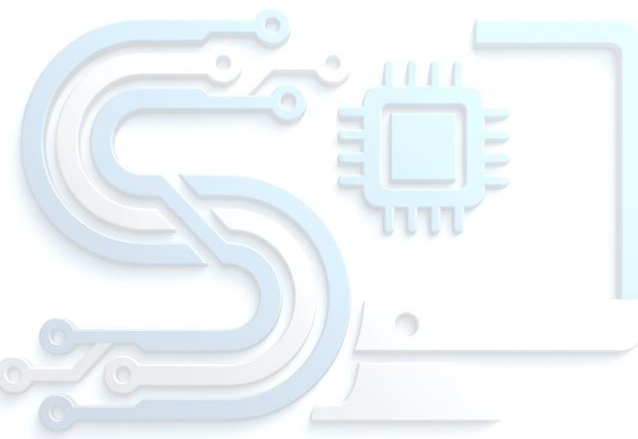
अध्याय – Endpoint Security (एंडपॉइंट सुरक्षा)

उदाहरण सहित अत्यंत विस्तृत अध्ययन

1. परिचय (Introduction)

डिजिटल युग में किसी भी संगठन का नेटवर्क केवल सर्वर (Server) तक सीमित नहीं होता, बल्कि उससे जुड़े अनेक उपकरण (Devices) भी उसका महत्वपूर्ण हिस्सा होते हैं। जैसे—

- Desktop Computer
- Laptop
- Mobile Phone
- Tablet
- Printer
- Scanner
- POS Machine
- ATM Machine
- Smart TV
- IP Camera
- Medical Devices
- IoT Devices



इन सभी उपकरणों को **Endpoint (एंडपॉइंट)** कहा जाता है।

यदि इनमें से कोई एक भी डिवाइस असुरक्षित हो जाए, तो हैकर उसी के माध्यम से पूरे नेटवर्क में प्रवेश कर सकता है। इसलिए प्रत्येक Endpoint की सुरक्षा करना अत्यंत आवश्यक है। यही कार्य **Endpoint Security** का है।

Endpoint Security वह प्रक्रिया है जिसके द्वारा नेटवर्क से जुड़े प्रत्येक डिवाइस (Endpoint) को वायरस, मैलवेयर, रैनसमवेयर, हैकिंग, अनधिकृत पहुँच तथा अन्य साइबर हमलों से सुरक्षित रखा जाता है।

2. Endpoint क्या होता है?

Endpoint वह कोई भी उपकरण (Device) है जो किसी नेटवर्क से जुड़कर डेटा का आदान-प्रदान करता है।

उदाहरण

- Desktop Computer
- Laptop

- Smartphone
- Tablet
- Printer
- ATM
- POS Machine
- CCTV Camera
- Biometric Machine
- Smart Watch
- IoT Devices
- Medical Equipment
- Industrial Controller

3. Endpoint Security की परिभाषा

Endpoint Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें हार्डवेयर, सॉफ्टवेयर, नीतियों (Policies) तथा निगरानी (Monitoring) के माध्यम से नेटवर्क से जुड़े प्रत्येक Endpoint Device को साइबर खतरों से सुरक्षित रखा जाता है।

4. Endpoint Security के उद्देश्य (Objectives)

Endpoint Security के मुख्य उद्देश्य हैं—

(1) Unauthorized Access रोकना

केवल अधिकृत उपयोगकर्ता ही डिवाइस का उपयोग कर सके।

उदाहरण

कंपनी के लैपटॉप में केवल कर्मचारी ही Login कर सके।

(2) Malware से सुरक्षा

Virus, Worm, Trojan, Spyware और Ransomware जैसे Malware को रोकना।

(3) Data Protection

(4) Network Protection

यदि एक डिवाइस संक्रमित हो जाए तो संक्रमण पूरे नेटवर्क में न फैले।

(5) Compliance

संगठन की सुरक्षा नीतियों और कानूनी मानकों का पालन सुनिश्चित करना।

5. Endpoint Security क्यों आवश्यक है?

आज अधिकांश कर्मचारी—

- Work From Home करते हैं।
- अपने Laptop से कार्यालय के Server से जुड़ते हैं।
- Mobile से Email पढ़ते हैं।
- Cloud Services का उपयोग करते हैं।

यदि इन डिवाइसों की सुरक्षा न हो तो—

- पूरा संगठन खतरे में आ सकता है।
 - डेटा चोरी हो सकता है।
 - Ransomware पूरे नेटवर्क में फैल सकता है।
 - बैंकिंग जानकारी लीक हो सकती है।
-

6. Endpoint Security के प्रमुख घटक (Components)

(1) Antivirus Software

Antivirus वायरस और अन्य Malware को पहचानकर हटाता है।

कार्य

- Virus Scan
- Malware Detection
- File Protection
- Email Protection

उदाहरण

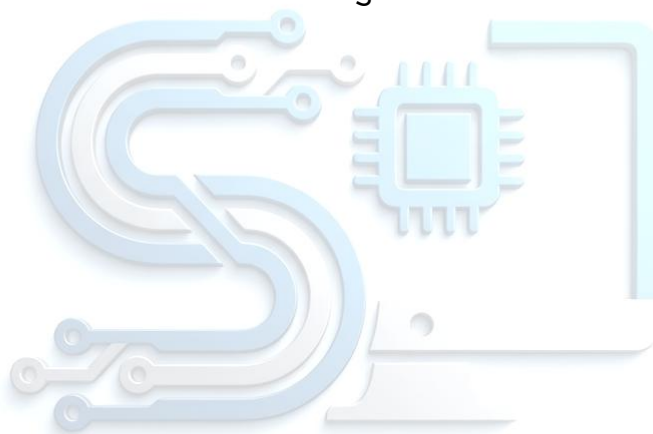
यदि USB Drive में Virus है, तो Antivirus उसे पहचानकर Quarantine कर देता है।

(2) Anti-Malware

सिर्फ Virus ही नहीं, बल्कि सभी प्रकार के Malware से सुरक्षा प्रदान करता है।

सुरक्षा

- Spyware
- Adware
- Trojan
- Worm
- Rootkit
- Ransomware



(3) Firewall

SHIV COMPUTER

Endpoint Firewall आने-जाने वाले नेटवर्क ट्रैफिक को नियंत्रित करता है।

उदाहरण

Windows Defender Firewall किसी संदिग्ध एप्लिकेशन को इंटरनेट से जुड़ने से रोक सकता है।

(4) Endpoint Detection and Response (EDR)

EDR आधुनिक Endpoint Security का महत्वपूर्ण भाग है।

कार्य

- Real-Time Monitoring
- Threat Detection
- Behavioral Analysis

- Automatic Isolation
- Incident Investigation

उदाहरण

यदि कोई Ransomware किसी कंप्यूटर की हजारों फाइलों को तेजी से Encrypt करना शुरू कर दे, तो EDR उस सिस्टम को नेटवर्क से अलग (Isolate) कर सकता है।

(5) Data Encryption

डिवाइस में संग्रहीत डेटा को एन्क्रिप्ट किया जाता है।

उदाहरण

Laptop चोरी होने पर भी एन्क्रिप्टेड हार्ड डिस्क का डेटा पढ़ा नहीं जा सकेगा।

(6) Device Control

USB, CD/DVD, Bluetooth आदि के उपयोग को नियंत्रित करना।

उदाहरण

कंपनी की नीति के अनुसार USB Drive का उपयोग प्रतिबंधित किया जा सकता है।

(7) Patch Management

Operating System और Software को समय-समय पर अपडेट करना।

उदाहरण

Windows Security Updates इंस्टॉल करना।

(8) Application Control

केवल अधिकृत Software चलाने की अनुमति देना।

उदाहरण

7. Endpoint Security में प्रयुक्त तकनीकें

- Antivirus
 - Anti-Malware
 - EDR (Endpoint Detection and Response)
 - XDR (Extended Detection and Response)
 - Disk Encryption
 - Host Firewall
 - Device Control
 - Application Whitelisting
 - Multi-Factor Authentication (MFA)
 - Zero Trust Security
 - Behavioral Analysis
 - AI-Based Threat Detection
-

8. Endpoint Security के खतरे (Threats)

(1) Virus

ऐसा Malware जो स्वयं को अन्य फाइलों में जोड़कर फैलता है।

उदाहरण

USB Drive के माध्यम से फैलने वाला Virus।

(2) Worm

नेटवर्क के माध्यम से स्वयं फैलने वाला Malware।

उदाहरण

एक संक्रमित कंप्यूटर से पूरे कार्यालय के नेटवर्क में फैल जाना।

(3) Trojan Horse

उपयोगी Software के रूप में दिखाई देने वाला Malware।

उदाहरण

नकली PDF Reader इंस्टॉल करना।

(4) Spyware

उपयोगकर्ता की गतिविधियों पर निगरानी रखने वाला Malware।

उदाहरण

Password रिकॉर्ड करना।

(5) Ransomware

डेटा को एन्क्रिप्ट कर फिरौती माँगना।

उदाहरण

कंपनी की सभी फाइलें लॉक कर देना।

(6) Phishing

नकली Email या Website द्वारा Login Credentials चोरी करना।

(7) USB-Based Attack

संक्रमित USB द्वारा Malware फैलाना।

(8) Insider Threat

कर्मचारी द्वारा जानबूझकर डेटा चोरी करना।

(9) Lost or Stolen Device

Laptop या Mobile चोरी हो जाना।

(10) Unpatched Software

पुराने Software की कमजोरी (Vulnerability) का लाभ उठाकर हमला करना।

9. Endpoint Security Policies

संगठन में निम्न नीतियाँ लागू की जाती हैं—

- Password Policy
 - Device Usage Policy
 - USB Policy
 - BYOD (Bring Your Own Device) Policy
 - Software Installation Policy
 - Patch Management Policy
 - Backup Policy
 - Remote Access Policy
-

10. Endpoint Security के वास्तविक उदाहरण

उदाहरण 1 – बैंक

बैंक के प्रत्येक कर्मचारी को एन्क्रिप्टेड Laptop दिया जाता है। सभी Laptop में EDR, Antivirus और Multi-Factor Authentication लागू है। यदि कोई संदिग्ध गतिविधि होती है, तो Security Team को तुरंत सूचना मिलती है।

उदाहरण 2 – अस्पताल

डॉक्टरों के Laptop और Tablets में मरीजों का डेटा रखा जाता है। सभी डिवाइस Full Disk Encryption, Password Protection और Remote Wipe सुविधा से सुरक्षित हैं। यदि कोई डिवाइस चोरी हो जाए, तो उसका डेटा दूर से मिटाया जा सकता है।

उदाहरण 3 – विश्वविद्यालय

विश्वविद्यालय के Computer Lab में केवल अधिकृत Software इंस्टॉल किए जा सकते हैं। छात्रों को Administrator अधिकार नहीं दिए जाते। सभी सिस्टम नियमित रूप से अपडेट किए जाते हैं।

उदाहरण 4 – कंपनी

एक कर्मचारी के Laptop में Ransomware ई-मेल अटैचमेंट से सक्रिय हो जाता है। EDR असामान्य गतिविधि पहचानकर Laptop को नेटवर्क से अलग कर देता है, जिससे संक्रमण अन्य सिस्टम तक नहीं पहुँचता।

11. Endpoint Security के सर्वोत्तम उपाय (Best Practices)

1. मजबूत Password और Multi-Factor Authentication (MFA) का उपयोग करें।
2. सभी डिवाइसों में Antivirus और EDR स्थापित करें।
3. Operating System तथा Software को नियमित रूप से अपडेट करें।
4. Full Disk Encryption सक्षम करें।
5. केवल विश्वसनीय स्रोतों से Software इंस्टॉल करें।
6. USB Device Control लागू करें।
7. नियमित Backup लें।
8. Application Whitelisting अपनाएँ।
9. Remote Lock और Remote Wipe सुविधा सक्षम करें।
10. उपयोगकर्ताओं को Phishing और Social Engineering के प्रति जागरूक करें।
11. Zero Trust Security Model लागू करें।
12. नियमित Security Audit और Vulnerability Assessment कराएँ।

12. Endpoint Security के लाभ

- प्रत्येक डिवाइस की सुरक्षा
- Malware संक्रमण में कमी
- डेटा चोरी से सुरक्षा

- Remote Work को सुरक्षित बनाना
- Compliance आवश्यकताओं का पालन
- साइबर हमलों का शीघ्र पता लगाना
- नेटवर्क में संक्रमण फैलने से रोकना
- संगठन की उत्पादकता और विश्वसनीयता बढ़ाना

13. Endpoint Security की चुनौतियाँ

- बड़ी संख्या में Endpoint Devices का प्रबंधन
- कर्मचारियों के व्यक्तिगत (BYOD) उपकरणों की सुरक्षा
- Zero-Day Vulnerabilities
- Remote Work Environment
- IoT Devices की सुरक्षा
- लगातार विकसित होते Malware
- Patch Management में देरी
- उपयोगकर्ताओं की लापरवाही

14. Endpoint Security और Network Security में अंतर

आधार	Endpoint Security	Network Security
सुरक्षा का केंद्र	व्यक्तिगत डिवाइस (Laptop, Mobile, Desktop आदि)	संपूर्ण नेटवर्क और डेटा संचार
मुख्य उद्देश्य	प्रत्येक Endpoint की सुरक्षा	नेटवर्क ट्रैफिक और नेटवर्क संसाधनों की सुरक्षा
प्रमुख तकनीकें	Antivirus, EDR, Encryption, Device Control	Firewall, IDS, IPS, VPN, Network Segmentation
सुरक्षा का दायरा	डिवाइस स्तर (Device Level)	नेटवर्क स्तर (Network Level)
उदाहरण	कर्मचारी का लैपटॉप सुरक्षित करना	बैंक के सभी ATM नेटवर्क को सुरक्षित करना

15. निष्कर्ष (Conclusion)

Endpoint Security आधुनिक साइबर सुरक्षा का अत्यंत महत्वपूर्ण स्तंभ है, क्योंकि आज अधिकांश साइबर हमलों की शुरुआत किसी न किसी Endpoint Device से होती है। यदि एक भी लैपटॉप, मोबाइल या अन्य डिवाइस असुरक्षित रह जाए, तो पूरा संगठन जोखिम में आ सकता है। इसलिए Antivirus, EDR, Full Disk Encryption, Multi-Factor Authentication (MFA), Patch Management, Device Control, Application Whitelisting और Zero Trust Security जैसी तकनीकों का समुचित उपयोग आवश्यक है। एक प्रभावी Endpoint Security Framework न केवल व्यक्तिगत डिवाइसों की सुरक्षा करता है, बल्कि पूरे संगठन के नेटवर्क, डेटा और व्यवसाय की निरंतरता (Business Continuity) को भी मजबूत बनाता है।



अध्याय – Mobile Security (मोबाइल सुरक्षा)

1. परिचय (Introduction)

वर्तमान डिजिटल युग में मोबाइल फोन (Smartphone) केवल बातचीत का माध्यम नहीं रह गया है, बल्कि यह एक पर्सनल कंप्यूटर (Personal Computer) का कार्य करता है। आज हम मोबाइल का उपयोग निम्न कार्यों के लिए करते हैं—

- इंटरनेट चलाना
- ऑनलाइन बैंकिंग
- UPI भुगतान
- ई-मेल भेजना
- सरकारी सेवाओं का उपयोग
- सोशल मीडिया
- वीडियो कॉन्फ्रेंसिंग
- क्लाउड स्टोरेज
- ऑनलाइन खरीदारी
- कार्यालय के कार्य (Work from Home)
- डिजिटल दस्तावेज़ संग्रहीत करना

चूँकि मोबाइल में हमारी व्यक्तिगत, वित्तीय और व्यावसायिक जानकारी होती है, इसलिए यह साइबर अपराधियों (Cyber Criminals) का प्रमुख लक्ष्य बन गया है।

इसी कारण Mobile Security (मोबाइल सुरक्षा) साइबर सुरक्षा का एक अत्यंत महत्वपूर्ण डोमेन है।

Mobile Security वह प्रक्रिया है जिसके द्वारा स्मार्टफोन, टैबलेट तथा अन्य मोबाइल उपकरणों को वायरस, मैलवेयर, डेटा चोरी, अनधिकृत पहुँच, साइबर हमलों तथा गोपनीयता संबंधी खतरों से सुरक्षित रखा जाता है।

2. Mobile Security क्या है?

Mobile Security में हार्डवेयर, ऑपरेटिंग सिस्टम, एप्लिकेशन, नेटवर्क तथा मोबाइल में संग्रहीत डेटा की सुरक्षा शामिल होती है।

यह सुनिश्चित करती है कि—

- मोबाइल सुरक्षित रहे।
- डेटा चोरी न हो।
- अनधिकृत व्यक्ति मोबाइल का उपयोग न कर सके।
- बैंकिंग जानकारी सुरक्षित रहे।
- उपयोगकर्ता की गोपनीयता (Privacy) बनी रहे।

3. Mobile Security की परिभाषा

Mobile Security वह सुरक्षा व्यवस्था (Security Framework) है जिसमें तकनीकी उपायों, नीतियों तथा प्रक्रियाओं द्वारा मोबाइल डिवाइस, उसके ऑपरेटिंग सिस्टम, एप्लिकेशन, नेटवर्क कनेक्शन तथा डेटा को साइबर खतरों से सुरक्षित रखा जाता है।

4. Mobile Security के उद्देश्य (Objectives)

(1) डेटा की गोपनीयता (Confidentiality)

मोबाइल में मौजूद जानकारी केवल अधिकृत उपयोगकर्ता ही देख सके।

उदाहरण

यदि मोबाइल चोरी हो जाए, तो उसमें मौजूद फोटो, दस्तावेज़ और बैंकिंग ऐप का डेटा सुरक्षित रहे।

(2) डेटा की अखंडता (Integrity)

डेटा में बिना अनुमति कोई परिवर्तन न हो।

उदाहरण

बैंकिंग ऐप के लेन-देन का रिकॉर्ड बदला न जा सके।

(3) उपलब्धता (Availability)

आवश्यकता पड़ने पर मोबाइल और उसका डेटा उपलब्ध रहे।

उदाहरण

आपातकाल में डॉक्टर तुरंत मरीज की मेडिकल रिपोर्ट मोबाइल पर देख सके।

(4) प्रमाणीकरण (Authentication)

मोबाइल का उपयोग केवल वास्तविक मालिक ही कर सके।

उदाहरण

- PIN
 - Password
 - Fingerprint
 - Face Unlock
-

(5) गोपनीयता (Privacy)

व्यक्तिगत जानकारी सुरक्षित रहे।

उदाहरण

संपर्क सूची, संदेश, स्थान (Location), फोटो और स्वास्थ्य संबंधी जानकारी किसी अनधिकृत व्यक्ति तक न पहुँचे।

5. Mobile Security क्यों आवश्यक है?

आज मोबाइल में निम्न प्रकार की संवेदनशील जानकारी रहती है—

- बैंक खाता विवरण
- UPI Apps
- ATM Card जानकारी
- आधार कार्ड
- PAN कार्ड
- पासपोर्ट की कॉपी

- ई-मेल
- ऑफिस फाइलें
- क्लाउड अकाउंट
- सोशल मीडिया अकाउंट
- निजी फोटो और वीडियो

यदि मोबाइल असुरक्षित हो जाए, तो—

- बैंक खाते से धन चोरी हो सकता है।
- पहचान की चोरी (Identity Theft) हो सकती है।
- निजी जानकारी लीक हो सकती है।
- कंपनी का गोपनीय डेटा चोरी हो सकता है।

6. Mobile Security के प्रमुख घटक (Components)

(1) Screen Lock Security

मोबाइल की पहली सुरक्षा स्क्रीन लॉक है।

प्रकार

- PIN
- Password
- Pattern Lock
- Fingerprint
- Face Recognition

उदाहरण

6 अंकों का PIN + Fingerprint सबसे सुरक्षित विकल्पों में से एक है।

(2) Device Encryption

मोबाइल में संग्रहीत डेटा को एन्क्रिप्ट किया जाता है।

लाभ

यदि मोबाइल चोरी हो जाए, तो डेटा पढ़ा नहीं जा सकेगा।

(3) Secure Boot

मोबाइल चालू होते समय केवल अधिकृत ऑपरेटिंग सिस्टम ही लोड होता है।

(4) Application Security

मोबाइल ऐप्स की सुरक्षा।

उपाय

- केवल आधिकारिक App Store से ऐप डाउनलोड करें।
- ऐप Permissions की समीक्षा करें।
- नियमित अपडेट करें।

(5) Network Security

मोबाइल द्वारा उपयोग किए जाने वाले नेटवर्क की सुरक्षा।

उदाहरण

- WPA3 सुरक्षित Wi-Fi
- VPN
- HTTPS

(6) Backup

डेटा का नियमित बैकअप लेना।

उदाहरण

Cloud Backup या Local Backup।

(7) Remote Lock / Remote Wipe

यदि मोबाइल चोरी हो जाए, तो उसे दूर से लॉक या उसका डेटा मिटाया जा सकता है।

7. Mobile Security में प्रयुक्त तकनीकें

- Full Device Encryption
- Secure Boot
- Biometric Authentication
- Multi-Factor Authentication (MFA)
- VPN
- Mobile Antivirus
- Mobile Device Management (MDM)
- Mobile Threat Defense (MTD)
- Sandboxing
- Application Signing
- Secure Element (SE)
- Trusted Execution Environment (TEE)

8. Mobile Security के खतरे (Threats)

(1) Malware

मोबाइल में वायरस या अन्य हानिकारक सॉफ्टवेयर का प्रवेश।

प्रकार

- Virus
- Worm
- Trojan
- Spyware
- Adware
- Ransomware

(2) Fake Applications

नकली ऐप्स के माध्यम से डेटा चोरी।

उदाहरण

नकली बैंकिंग ऐप इंस्टॉल करना।

(3) Phishing

नकली लिंक या ई-मेल द्वारा Login जानकारी प्राप्त करना।

उदाहरण

"आपका बैंक खाता बंद हो जाएगा" जैसे संदेश भेजकर नकली वेबसाइट पर ले जाना।

(4) Smishing (SMS Phishing)

SMS द्वारा धोखाधड़ी।

उदाहरण

"आपने ₹50,000 जीते हैं, लिंक पर क्लिक करें।"

(5) Vishing

फोन कॉल द्वारा जानकारी प्राप्त करना।

उदाहरण

कोई व्यक्ति स्वयं को बैंक अधिकारी बताकर OTP पूछे।

(6) QR Code Fraud

नकली QR Code स्कैन करवाकर भुगतान कराना।

(7) Public Wi-Fi Attack

असुरक्षित Wi-Fi के माध्यम से डेटा चोरी।

(8) Bluetooth Attack

अनधिकृत Bluetooth Connection।

(9) SIM Swapping

हमलावर नया SIM जारी कराकर OTP प्राप्त कर लेता है।

(10) Mobile Theft

मोबाइल चोरी हो जाना।

9. Mobile Operating System Security

Android Security

विशेषताएँ

- Google Play Protect
- Application Sandbox
- Verified Boot
- Permission Management
- Regular Security Updates

iOS Security

विशेषताएँ

- Secure Enclave
- App Store Review
- Full Device Encryption
- Face ID
- Touch ID

10. Mobile Device Management (MDM)

MDM का उपयोग बड़े संगठनों में किया जाता है।

कार्य

- Remote Lock
- Remote Wipe
- Application Management
- Device Tracking
- Policy Enforcement

उदाहरण

यदि कंपनी का मोबाइल खो जाए, तो आईटी विभाग उसका डेटा दूर से मिटा सकता है।

11. Mobile Threat Defense (MTD)

MTD मोबाइल में होने वाले साइबर हमलों का पता लगाता है।

कार्य

- Malware Detection
- Phishing Protection
- Network Monitoring
- Risk Assessment

12. Mobile Security Best Practices

1. मजबूत PIN या Password का उपयोग करें।
2. Fingerprint या Face Unlock सक्षम करें।
3. Multi-Factor Authentication (MFA) का उपयोग करें।
4. केवल आधिकारिक App Store से ऐप डाउनलोड करें।
5. अनावश्यक ऐप Permissions बंद रखें।
6. Operating System और Apps को नियमित रूप से अपडेट करें।
7. Google Play Protect या विश्वसनीय Mobile Security Solution सक्रिय रखें।
8. सार्वजनिक Wi-Fi पर संवेदनशील कार्य करते समय VPN का उपयोग करें।
9. नियमित बैकअप लें।
10. Remote Lock और Remote Wipe सुविधा सक्षम करें।
11. Root या Jailbreak किए गए डिवाइस का उपयोग न करें।
12. किसी को भी OTP, PIN या Password साझा न करें।
13. QR Code स्कैन करने से पहले उसके स्रोत की पुष्टि करें।
14. Bluetooth और NFC को आवश्यकता न होने पर बंद रखें।

13. Mobile Security के वास्तविक उदाहरण

उदाहरण 1 – UPI Fraud

एक उपयोगकर्ता को नकली UPI ऐप डाउनलोड करने के लिए संदेश मिलता है। ऐप इंस्टॉल करने के बाद उसके बैंक खाते की जानकारी चोरी हो जाती है और खाते से धन निकाल लिया जाता है।

बचाव: केवल आधिकारिक App Store से ऐप डाउनलोड करें।

उदाहरण 2 – मोबाइल चोरी

एक कर्मचारी का कार्यालय का मोबाइल चोरी हो जाता है।

मोबाइल में—

- Full Device Encryption
- Fingerprint Lock
- Remote Wipe

सक्रिय होने के कारण कंपनी का डेटा सुरक्षित रहता है।

उदाहरण 3 – Public Wi-Fi

एक व्यक्ति कैफे के मुफ्त Wi-Fi से इंटरनेट बैंकिंग करता है। हमलावर असुरक्षित नेटवर्क का लाभ उठाकर उसकी जानकारी चुराने का प्रयास करता है।

बचाव: VPN का उपयोग करें और केवल HTTPS वेबसाइटों पर ही लॉगिन करें।

उदाहरण 4 – QR Code Scam

एक दुकानदार के भुगतान स्टैंड पर नकली QR Code चिपका दिया जाता है। ग्राहक भुगतान करता है, लेकिन धन हमलावर के खाते में चला जाता है।

बचाव: भुगतान से पहले QR Code की पुष्टि करें।

14. Mobile Security के लाभ

- व्यक्तिगत जानकारी की सुरक्षा
- बैंकिंग लेन-देन की सुरक्षा
- पहचान की चोरी से बचाव
- डेटा एन्क्रिप्शन
- सुरक्षित ऑनलाइन भुगतान
- साइबर हमलों में कमी
- व्यवसायिक डेटा की सुरक्षा
- उपयोगकर्ता की गोपनीयता की रक्षा

15. Mobile Security की चुनौतियाँ

- तेजी से बढ़ते मोबाइल Malware
- Fake Apps
- Social Engineering
- BYOD (Bring Your Own Device)
- Operating System Fragmentation
- Zero-Day Vulnerabilities
- असुरक्षित Public Wi-Fi
- उपयोगकर्ताओं की जागरूकता की कमी

16. Mobile Security और Endpoint Security में अंतर

आधार	Mobile Security	Endpoint Security
सुरक्षा का केंद्र	मोबाइल और टैबलेट	सभी प्रकार के Endpoint Devices
मुख्य उद्देश्य	मोबाइल डिवाइस की सुरक्षा	नेटवर्क से जुड़े सभी उपकरणों की सुरक्षा
प्रमुख तकनीकें	MDM, MTD, Mobile Antivirus, Secure Boot	EDR, Antivirus, Device Control, Disk Encryption
उदाहरण	UPI ऐप और स्मार्टफोन की सुरक्षा	कंपनी के Laptop, Desktop और Printer की सुरक्षा

17. निष्कर्ष (Conclusion)

Mobile Security आधुनिक साइबर सुरक्षा का अत्यंत महत्वपूर्ण क्षेत्र है, क्योंकि स्मार्टफोन आज व्यक्तिगत और व्यावसायिक जीवन का अभिन्न अंग बन चुके हैं। मोबाइल में बैंकिंग, पहचान, स्वास्थ्य, संचार और कार्यालय से संबंधित संवेदनशील जानकारी संग्रहीत रहती है। इसलिए **मजबूत प्रमाणीकरण (PIN, Password, Biometrics), Full Device Encryption, नियमित अपडेट, आधिकारिक ऐप स्टोर से ही ऐप इंस्टॉल करना, VPN का उपयोग, Multi-Factor Authentication (MFA), Mobile Device Management (MDM) तथा Mobile Threat Defense (MTD)** जैसी तकनीकों का उपयोग अनिवार्य है। इन उपायों के माध्यम से मोबाइल उपकरणों को सुरक्षित रखा जा सकता है तथा डेटा चोरी, पहचान की चोरी, वित्तीय धोखाधड़ी और अन्य साइबर खतरों के जोखिम को काफी हद तक कम किया जा सकता है।



अध्याय – Application Security

(एप्लिकेशन सुरक्षा)

1. परिचय (Introduction)

आज लगभग प्रत्येक कार्य किसी न किसी **Software Application** के माध्यम से किया जाता है। चाहे बैंकिंग हो, रेलवे टिकट बुकिंग, अस्पताल प्रबंधन, विद्यालय का ERP, विश्वविद्यालय का परिणाम पोर्टल, ई-कॉमर्स वेबसाइट, मोबाइल बैंकिंग, सोशल मीडिया या सरकारी सेवाएँ—सभी एप्लिकेशन पर आधारित हैं।

इन एप्लिकेशनों में उपयोगकर्ताओं की अत्यंत संवेदनशील जानकारी होती है, जैसे—

- नाम
- मोबाइल नंबर
- आधार संख्या
- बैंक विवरण
- पासवर्ड
- मेडिकल रिकॉर्ड
- परीक्षा परिणाम
- कार्यालय का गोपनीय डेटा

यदि एप्लिकेशन में कोई सुरक्षा कमजोरी (Security Vulnerability) हो, तो साइबर अपराधी उस कमजोरी का लाभ उठाकर डेटा चोरी, डेटा में बदलाव, वित्तीय धोखाधड़ी या पूरे सिस्टम को नियंत्रित कर सकते हैं।

इसी कारण **Application Security (एप्लिकेशन सुरक्षा)** साइबर सुरक्षा का एक अत्यंत महत्वपूर्ण क्षेत्र है।

Application Security वह प्रक्रिया है जिसके द्वारा किसी **Software, Web Application** या **Mobile Application** को उसके विकास (Development), परीक्षण (Testing), तैनाती (Deployment) और उपयोग (Operation) के प्रत्येक चरण में साइबर खतरों से सुरक्षित रखा जाता है।

2. Application क्या है?

Application (एप्लिकेशन) वह सॉफ्टवेयर होता है जो उपयोगकर्ता के किसी विशेष कार्य को पूरा करता है।

- Microsoft Word
- Google Chrome
- WhatsApp
- Paytm
- PhonePe
- Amazon App
- Flipkart App
- Online Banking Application
- School ERP
- Hospital Management System
- Railway Reservation System

3. Application Security क्या है?

Application Security का उद्देश्य यह सुनिश्चित करना है कि—

- एप्लिकेशन सुरक्षित हो।
- डेटा सुरक्षित रहे।
- केवल अधिकृत उपयोगकर्ता ही प्रवेश कर सके।
- हैकर किसी कमजोरी का लाभ न उठा सके।
- एप्लिकेशन हमेशा उपलब्ध रहे।

4. Application Security की परिभाषा

Application Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें तकनीकों, नीतियों, परीक्षणों और नियंत्रणों का उपयोग करके सॉफ्टवेयर एवं वेब/मोबाइल एप्लिकेशन को विकास से लेकर उपयोग तक प्रत्येक चरण में सुरक्षित बनाया जाता है।

5. Application Security के उद्देश्य (Objectives)

(1) Confidentiality (गोपनीयता)

उपयोगकर्ता का डेटा सुरक्षित रहे।

उदाहरण

ऑनलाइन बैंकिंग में ग्राहक का पासवर्ड किसी अन्य व्यक्ति को दिखाई न दे।

(2) Integrity (अखंडता)

डेटा में बिना अनुमति परिवर्तन न हो।

उदाहरण

विश्वविद्यालय के परिणाम में अंक बदले न जा सकें।

(3) Availability (उपलब्धता)

एप्लिकेशन हमेशा उपलब्ध रहे।

उदाहरण

ऑनलाइन परीक्षा के समय पोर्टल बंद न हो।

(4) Authentication (प्रमाणीकरण)

केवल वास्तविक उपयोगकर्ता ही लॉगिन कर सके।

उदाहरण

Username + Password + OTP

(5) Authorization (प्राधिकरण)

प्रत्येक उपयोगकर्ता को उसके अधिकार के अनुसार ही सुविधाएँ मिलें।

उदाहरण

छात्र अपना परिणाम देख सकता है, लेकिन दूसरे छात्र का परिणाम नहीं।

(6) Non-Repudiation

किसी उपयोगकर्ता द्वारा किए गए कार्य का रिकॉर्ड सुरक्षित रहे।

उदाहरण

ऑनलाइन भुगतान का डिजिटल रिकॉर्ड।

6. Application Security क्यों आवश्यक है?

यदि एप्लिकेशन सुरक्षित नहीं है, तो—

- डेटा चोरी हो सकता है।
- पासवर्ड लीक हो सकते हैं।
- बैंक खाते से धन चोरी हो सकता है।
- वेबसाइट हैक हो सकती है।
- कंपनी का गोपनीय डेटा लीक हो सकता है।
- उपयोगकर्ता का विश्वास समाप्त हो सकता है।

7. Application Security Life Cycle (ASLC)

Application Security केवल अंतिम चरण में नहीं की जाती, बल्कि पूरे जीवनचक्र (Life Cycle) में लागू होती है।

चरण

1. Requirement Analysis
2. Secure Design
3. Secure Coding
4. Security Testing
5. Deployment
6. Monitoring
7. Maintenance

8. Secure Software Development Life Cycle (SSDLC)

सुरक्षित सॉफ्टवेयर विकसित करने की प्रक्रिया।

चरण

- Security Requirements
- Threat Modeling
- Secure Coding
- Code Review
- Security Testing
- Deployment
- Continuous Monitoring

9. Application Security के प्रमुख घटक

(1) Authentication

उपयोगकर्ता की पहचान सत्यापित करना।

उदाहरण

- Password
- OTP
- Fingerprint
- Face Recognition
- Multi-Factor Authentication (MFA)

(2) Authorization

उपयोगकर्ता को उसके अधिकार के अनुसार सुविधाएँ देना।

उदाहरण

Admin → सभी अधिकार

Teacher → अंक दर्ज करना

Student → केवल परिणाम देखना

(3) Session Management

लॉगिन Session को सुरक्षित रखना।

उदाहरण

15 मिनट निष्क्रिय रहने पर स्वतः Logout।

(4) Input Validation

उपयोगकर्ता द्वारा दर्ज किए गए इनपुट की जाँच करना।

उदाहरण

मोबाइल नंबर वाले फ़ील्ड में केवल अंक स्वीकार करना।

(5) Output Encoding

डेटा को सुरक्षित रूप में प्रदर्शित करना ताकि Cross-Site Scripting (XSS) जैसे हमलों से बचा जा सके।

(6) Encryption

डेटा को एन्क्रिप्ट करना।

उदाहरण

Password को Plain Text में न रखकर Hash करना।

(7) Logging and Monitoring

सभी महत्वपूर्ण गतिविधियों का रिकॉर्ड रखना।

10. Application Security में प्रयुक्त प्रमुख तकनीकें

- HTTPS
- SSL/TLS
- Multi-Factor Authentication (MFA)
- JSON Web Token (JWT)
- OAuth 2.0
- OpenID Connect (OIDC)
- Web Application Firewall (WAF)
- CAPTCHA
- Digital Signature
- Secure Cookies
- Hashing (SHA-256)
- Encryption (AES, RSA)

11. Application Security के प्रमुख खतरे (Threats)

(1) SQL Injection

क्या है?

हमलावर SQL Query में दुर्भावनापूर्ण (Malicious) कोड जोड़कर Database तक पहुँच प्राप्त कर लेता है।

उदाहरण

यदि Login Form इनपुट को सही ढंग से Validate नहीं करता, तो हमलावर Database से डेटा निकाल सकता है।

बचाव

- Prepared Statements
- Parameterized Queries
- Input Validation

(2) Cross-Site Scripting (XSS)

क्या है?

हमलावर वेबसाइट में JavaScript कोड इंजेक्ट करता है।

उदाहरण

उपयोगकर्ता का Session Cookie चोरी करना।

बचाव

- Output Encoding
 - Content Security Policy (CSP)
 - Input Validation
-

(3) Cross-Site Request Forgery (CSRF)

क्या है?

उपयोगकर्ता की जानकारी के बिना उसकी ओर से अनुरोध (Request) भेजना।

उदाहरण

लॉगिन उपयोगकर्ता के बैंक खाते से धन स्थानांतरित करना।

बचाव

- CSRF Token
 - SameSite Cookies
-

(4) Broken Authentication

कमजोर Login प्रणाली।

उदाहरण

कमजोर Password स्वीकार करना।

बचाव

- MFA
 - Strong Password Policy
 - Account Lockout
-

(5) Broken Access Control

उपयोगकर्ता बिना अनुमति दूसरे उपयोगकर्ता का डेटा देख सके।

उदाहरण

Student दूसरे छात्र का Result देख ले।

बचाव

- Role-Based Access Control (RBAC)
 - Least Privilege Principle
-

(6) Security Misconfiguration

गलत Configuration के कारण सुरक्षा कमजोर हो जाना।

उदाहरण

Debug Mode Production में चालू रहना।

(7) Sensitive Data Exposure

संवेदनशील डेटा का असुरक्षित रूप में संग्रहीत होना।

उदाहरण

Password को Plain Text में Database में रखना।

(8) Insecure File Upload

हानिकारक फाइल अपलोड कर Server पर Code चलाना।

(9) Command Injection

Server पर दुर्भावनापूर्ण Commands चलवाना।

(10) API Security Issues

असुरक्षित API के माध्यम से डेटा चोरी।

12. OWASP Top 10 (संक्षिप्त परिचय)

OWASP (Open Worldwide Application Security Project) वेब एप्लिकेशन की प्रमुख सुरक्षा कमजोरियों की सूची प्रकाशित करता है।

मुख्य श्रेणियाँ—

- Broken Access Control
- Cryptographic Failures
- Injection
- Insecure Design
- Security Misconfiguration
- Vulnerable Components
- Identification and Authentication Failures
- Software and Data Integrity Failures
- Security Logging Failures
- Server-Side Request Forgery (SSRF)

13. Application Security Testing

(1) Static Application Security Testing (SAST)

Source Code का विश्लेषण।

(2) Dynamic Application Security Testing (DAST)

चल रही (Running) Application का परीक्षण।

(3) Interactive Application Security Testing (IAST)

Runtime के दौरान Application का विश्लेषण।

(4) Software Composition Analysis (SCA)

Third-Party Libraries की सुरक्षा जाँच।

(5) Penetration Testing

Ethical Hacker द्वारा सुरक्षा परीक्षण।

14. Secure Coding Best Practices

1. Input Validation करें।
2. Parameterized Queries का उपयोग करें।
3. Password Hashing (जैसे bcrypt, Argon2) करें।
4. HTTPS अनिवार्य करें।
5. Sensitive Data Encrypt करें।
6. Error Messages में संवेदनशील जानकारी न दिखाएँ।
7. नियमित Code Review करें।
8. Third-Party Libraries अपडेट रखें।
9. Security Headers लागू करें।
10. Logging और Monitoring सक्षम रखें।

15. वास्तविक उदाहरण (Real-Life Examples)

उदाहरण 1 – बैंकिंग एप्लिकेशन

एक बैंकिंग ऐप में Login के लिए—

- Username
- Password
- OTP

तीनों आवश्यक हैं।

सभी लेन-देन TLS Encryption द्वारा सुरक्षित किए जाते हैं।

उदाहरण 2 – विद्यालय ERP

Teacher केवल अंक दर्ज कर सकता है।

Student केवल अपना Result देख सकता है।

Principal सभी रिपोर्ट देख सकता है।

यह Role-Based Access Control (RBAC) का उदाहरण है।

उदाहरण 3 – ई-कॉमर्स वेबसाइट

ग्राहक का Password Hash करके Database में संग्रहीत किया जाता है। भुगतान HTTPS के माध्यम से किया जाता है और WAF वेबसाइट को सामान्य वेब हमलों से सुरक्षित रखता है।

उदाहरण 4 – अस्पताल

मरीजों के मेडिकल रिकॉर्ड एन्क्रिप्टेड Database में रखे जाते हैं। केवल अधिकृत डॉक्टर और संबंधित चिकित्सा कर्मचारी ही उन्हें देख सकते हैं। प्रत्येक Access का Audit Log रखा जाता है।

16. Application Security के लाभ

- डेटा चोरी से सुरक्षा
- सुरक्षित ऑनलाइन लेन-देन
- उपयोगकर्ताओं का विश्वास बढ़ना
- कानूनी अनुपालन (Compliance)
- व्यवसाय की निरंतरता
- साइबर हमलों में कमी
- बेहतर उपयोगकर्ता अनुभव
- संगठन की प्रतिष्ठा की रक्षा

17. Application Security की चुनौतियाँ

- तेजी से विकसित होते साइबर हमले
- Zero-Day Vulnerabilities
- असुरक्षित Third-Party Libraries
- API Security
- Cloud आधारित Applications
- DevSecOps का कार्यान्वयन
- मानव त्रुटियाँ
- जटिल Application Architecture

18. Application Security और Network Security में अंतर

आधार	Application Security	Network Security
सुरक्षा का केंद्र	Software, Web एवं Mobile Applications	नेटवर्क और डेटा संचार
मुख्य उद्देश्य	एप्लिकेशन की कमजोरियों से सुरक्षा	नेटवर्क ट्रैफिक और नेटवर्क संसाधनों की सुरक्षा
प्रमुख तकनीकें	Secure Coding, WAF, SAST, DAST, MFA	Firewall, IDS, IPS, VPN
उदाहरण	इंटरनेट बैंकिंग एप्लिकेशन	बैंक का ATM नेटवर्क

19. Application Security और Information Security में अंतर

आधार	Application Security	Information Security
सुरक्षा का केंद्र	एप्लिकेशन	सभी प्रकार की सूचना
मुख्य उद्देश्य	एप्लिकेशन को सुरक्षित बनाना	सूचना की गोपनीयता, अखंडता और उपलब्धता
उदाहरण	ERP Software	छात्र रिकॉर्ड, बैंक डेटा

20. निष्कर्ष (Conclusion)

Application Security आधुनिक साइबर सुरक्षा का अत्यंत महत्वपूर्ण क्षेत्र है, क्योंकि आज लगभग सभी डिजिटल सेवाएँ सॉफ्टवेयर और वेब एप्लिकेशन पर आधारित हैं। किसी भी एप्लिकेशन की सुरक्षा केवल Firewall लगाने से सुनिश्चित नहीं होती, बल्कि **Secure Software Development Life Cycle (SSDLC)**, **Secure Coding**, **Authentication**, **Authorization**, **Encryption**, **Input Validation**, **Security Testing (SAST, DAST, IAST)**, **Web Application Firewall (WAF)** तथा **निरंतर मॉनिटरिंग** का समुचित उपयोग आवश्यक है। एक सुरक्षित एप्लिकेशन उपयोगकर्ता की गोपनीयता की रक्षा करता है, डेटा चोरी और साइबर हमलों के जोखिम को कम करता है तथा संगठन की विश्वसनीयता, कानूनी अनुपालन और व्यवसाय की निरंतरता को मजबूत बनाता है।



अध्याय – Database Security (डेटाबेस सुरक्षा)

1. परिचय (Introduction)

आज के डिजिटल युग में लगभग प्रत्येक संस्था, कंपनी, बैंक, विद्यालय, विश्वविद्यालय, अस्पताल, ई-कॉमर्स वेबसाइट तथा सरकारी विभाग अपने महत्वपूर्ण डेटा को Database (डेटाबेस) में संग्रहीत (Store) करते हैं।

उदाहरण के लिए—

- बैंक ग्राहकों के खाते
- अस्पताल के मरीजों का रिकॉर्ड
- विश्वविद्यालय के छात्रों का परिणाम
- ई-कॉमर्स वेबसाइट के ऑर्डर
- सरकारी नागरिक डेटा
- कर्मचारियों का वेतन विवरण

यदि Database सुरक्षित नहीं है, तो हैकर लाखों लोगों का डेटा चुरा सकते हैं, बदल सकते हैं या नष्ट कर सकते हैं। इससे आर्थिक हानि, कानूनी समस्याएँ तथा संगठन की प्रतिष्ठा को गंभीर नुकसान हो सकता है।

इसी कारण Database Security (डेटाबेस सुरक्षा) साइबर सुरक्षा का अत्यंत महत्वपूर्ण क्षेत्र है।

Database Security वह प्रक्रिया है जिसके द्वारा Database, उसमें संग्रहीत डेटा, Database Server, Database Management System (DBMS) तथा Database उपयोगकर्ताओं को अनधिकृत पहुँच, डेटा चोरी, डेटा परिवर्तन, डेटा नष्ट होने तथा अन्य साइबर खतरों से सुरक्षित रखा जाता है।

2. Database क्या है?

Database एक व्यवस्थित (Organized) संग्रह (Collection) है, जिसमें डेटा को इस प्रकार संग्रहीत किया जाता है कि उसे आसानी से खोजा (Search), संशोधित (Update), जोड़ा (Insert) और हटाया (Delete) जा सके।

उदाहरण

एक विद्यालय के Database में—

- छात्र का नाम

- कक्षा
- रोल नंबर
- जन्मतिथि
- अंक
- फीस विवरण

सभी जानकारी सुरक्षित रूप से संग्रहीत रहती है।

3. Database Security क्या है?

Database Security का उद्देश्य Database की—

- गोपनीयता (Confidentiality)
- अखंडता (Integrity)
- उपलब्धता (Availability)

को बनाए रखना है।

इसमें केवल डेटा ही नहीं, बल्कि Database Software, Server, Backup, नेटवर्क और Database Administrator (DBA) की सुरक्षा भी शामिल होती है।

4. Database Security की परिभाषा

Database Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें तकनीकों, नीतियों, प्रक्रियाओं तथा नियंत्रणों के माध्यम से Database और उसमें संग्रहीत जानकारी को साइबर खतरों, अनधिकृत पहुँच तथा डेटा उल्लंघन (Data Breach) से सुरक्षित रखा जाता है।

5. Database Security के उद्देश्य (Objectives)

(1) Confidentiality (गोपनीयता)

Database का डेटा केवल अधिकृत उपयोगकर्ता ही देख सके।

उदाहरण

बैंक ग्राहक का खाता विवरण केवल ग्राहक और अधिकृत बैंक कर्मचारी ही देख सकते हैं।

(2) Integrity (अखंडता)

डेटा में बिना अनुमति कोई परिवर्तन न हो।

उदाहरण

विश्वविद्यालय के परीक्षा परिणाम में अंक बदले न जा सकें।

(3) Availability (उपलब्धता)

Database आवश्यकता पड़ने पर हमेशा उपलब्ध रहे।

उदाहरण

अस्पताल में डॉक्टर मरीज का रिकॉर्ड किसी भी समय देख सके।

(4) Authentication (प्रमाणीकरण)

Database उपयोगकर्ता की पहचान सत्यापित करना।

(5) Authorization (प्राधिकरण)

प्रत्येक उपयोगकर्ता को उसके कार्य के अनुसार ही अधिकार देना।

(6) Accountability (उत्तरदायित्व)

किसने कौन-सा डेटा देखा या बदला, उसका रिकॉर्ड रखना।

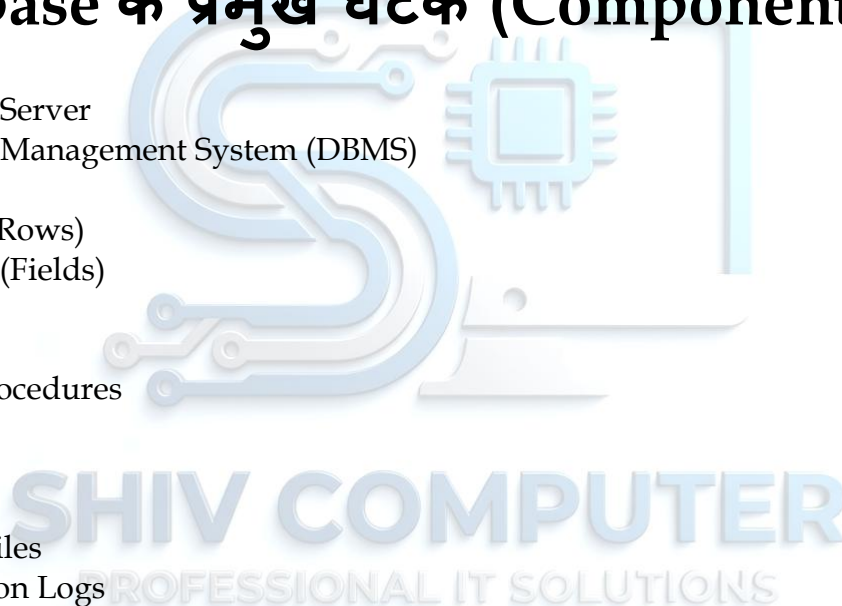
6. Database Security क्यों आवश्यक है?

यदि Database सुरक्षित नहीं है—

- डेटा चोरी हो सकता है।
- ग्राहक की व्यक्तिगत जानकारी लीक हो सकती है।
- बैंक खाते से धन की चोरी हो सकती है।
- सरकारी गोपनीय जानकारी उजागर हो सकती है।
- कंपनी की प्रतिष्ठा को नुकसान हो सकता है।
- कानूनी दंड (Legal Penalty) लग सकता है।

7. Database के प्रमुख घटक (Components)

- Database Server
- Database Management System (DBMS)
- Tables
- Records (Rows)
- Columns (Fields)
- Index
- Views
- Stored Procedures
- Triggers
- Users
- Roles
- Backup Files
- Transaction Logs



8. Database Management System (DBMS)

DBMS वह सॉफ्टवेयर है जो Database का प्रबंधन करता है।

प्रमुख DBMS

- Oracle Database
- MySQL
- Microsoft SQL Server
- PostgreSQL
- MariaDB
- SQLite
- MongoDB (NoSQL)

9. Database Security के प्रमुख घटक

(1) Authentication

Database में प्रवेश करने वाले उपयोगकर्ता की पहचान सत्यापित करना।

उदाहरण

Username + Password + Multi-Factor Authentication (MFA)

(2) Authorization

किस उपयोगकर्ता को कौन-सा कार्य करने की अनुमति है।

उदाहरण

उपयोगकर्ता अनुमति

Student केवल अपना परिणाम देख सकता है

Teacher अंक दर्ज कर सकता है

Principal सभी रिकॉर्ड देख और संशोधित कर सकता है

(3) Access Control

Database तक पहुँच को नियंत्रित करना।

प्रकार

- Role-Based Access Control (RBAC)
- Attribute-Based Access Control (ABAC)
- Mandatory Access Control (MAC)
- Discretionary Access Control (DAC)

(4) Data Encryption

डेटा को एन्क्रिप्ट करना।

प्रकार

(A) Data at Rest

Database में संग्रहीत डेटा।

(B) Data in Transit

नेटवर्क के माध्यम से भेजा जा रहा डेटा।

(C) Data in Use

प्रसंस्करण (Processing) के दौरान डेटा।

(5) Backup

डेटा की नियमित प्रतिलिपि बनाना।

प्रकार

- Full Backup
- Incremental Backup
- Differential Backup

(6) Audit Logging

Database में होने वाली प्रत्येक गतिविधि का रिकॉर्ड रखना।

उदाहरण

- Login
- Logout
- Insert
- Update
- Delete

10. Database Security में प्रयुक्त तकनीकें

- Encryption (AES, RSA)
 - Transparent Data Encryption (TDE)
 - SSL/TLS
 - Multi-Factor Authentication (MFA)
 - Role-Based Access Control (RBAC)
 - Database Activity Monitoring (DAM)
 - Data Masking
 - Tokenization
 - Backup & Recovery
 - Database Firewall
-

11. Database Security के प्रमुख खतरे (Threats)

(1) SQL Injection

क्या है?

हमलावर SQL Query में दुर्भावनापूर्ण कोड जोड़कर Database तक पहुँच प्राप्त कर लेता है।

उदाहरण

यदि Login Form सुरक्षित न हो, तो हमलावर बिना Password के Database में प्रवेश कर सकता है।

बचाव

- Prepared Statements
 - Parameterized Queries
 - Input Validation
-

(2) Insider Threat

संगठन का कर्मचारी ही डेटा चोरी कर ले।

उदाहरण

कर्मचारी ग्राहक सूची बाहर बेच दे।

(3) Weak Password

(4) Privilege Escalation

कम अधिकार वाला उपयोगकर्ता अधिक अधिकार प्राप्त कर ले।

(5) Malware

Database Server में Malware स्थापित कर देना।

(6) Ransomware

Database को एन्क्रिप्ट कर फिरोती माँगना।

(7) Data Leakage

संवेदनशील जानकारी का बाहर जाना।

(8) Backup Theft

Backup File चोरी हो जाना।

(9) Misconfiguration

Database की गलत Configuration।

उदाहरण

Database Port इंटरनेट पर खुला छोड़ देना।

(10) Denial of Service (DoS)

12. Database Security Policies

- Password Policy
- Backup Policy
- Access Control Policy
- Patch Management Policy
- Audit Policy
- Data Retention Policy
- Disaster Recovery Policy
- Encryption Policy

13. Database Security Best Practices

1. Strong Password और MFA का उपयोग करें।
2. Database को सार्वजनिक इंटरनेट पर सीधे उपलब्ध न करें।
3. नियमित Backup लें।
4. Encryption लागू करें।
5. Role-Based Access Control (RBAC) अपनाएँ।
6. केवल आवश्यक Ports ही खुले रखें।
7. Database Server को नियमित रूप से Update करें।
8. Audit Logs की निगरानी करें।
9. SQL Injection से बचाव के लिए Parameterized Queries का उपयोग करें।
10. Database Firewall लागू करें।
11. नियमित Vulnerability Assessment और Penetration Testing कराएँ।
12. Least Privilege Principle अपनाएँ।

14. Database Security के वास्तविक उदाहरण

उदाहरण 1 – बैंक

बैंक का Database ग्राहकों के खाते, लेन-देन और ATM जानकारी संग्रहीत करता है। सभी डेटा TDE (Transparent Data Encryption) द्वारा एन्क्रिप्ट किए जाते हैं। केवल अधिकृत बैंक अधिकारी ही Role-Based Access Control (RBAC) के माध्यम से आवश्यक जानकारी देख सकते हैं।

उदाहरण 2 – अस्पताल

अस्पताल के Database में मरीजों की रिपोर्ट, दवाइयाँ और मेडिकल इतिहास सुरक्षित रहता है। डॉक्टर केवल अपने मरीजों की जानकारी देख सकते हैं। सभी गतिविधियों का Audit Log रखा जाता है।

उदाहरण 3 – विश्वविद्यालय

विश्वविद्यालय के Database में छात्र, शिक्षक, परीक्षा परिणाम और फीस रिकॉर्ड संग्रहीत हैं। छात्रों को केवल अपना परिणाम देखने की अनुमति है, जबकि परीक्षा नियंत्रक परिणाम संशोधित कर सकता है।

उदाहरण 4 – ई-कॉमर्स वेबसाइट

एक ई-कॉमर्स कंपनी के Database में ग्राहक, ऑर्डर और भुगतान संबंधी जानकारी होती है। Password Hash किए जाते हैं, भुगतान डेटा एन्क्रिप्ट किया जाता है और Database Firewall बाहरी हमलों से सुरक्षा प्रदान करता है।

15. Database Security के लाभ

- डेटा चोरी से सुरक्षा
- ग्राहक की गोपनीयता की रक्षा
- डेटा की अखंडता बनी रहती है
- सुरक्षित ऑनलाइन सेवाएँ
- कानूनी अनुपालन (Compliance)
- व्यवसाय की निरंतरता
- साइबर हमलों में कमी
- संगठन की विश्वसनीयता बढ़ती है

16. Database Security की चुनौतियाँ

- SQL Injection

- Zero-Day Vulnerabilities
- Insider Threat
- Cloud Databases की सुरक्षा
- बड़ी मात्रा में डेटा का प्रबंधन
- Backup Security
- Compliance Requirements
- तेज़ी से विकसित होते साइबर खतरे

17. Database Security और Application Security में अंतर

आधार	Database Security	Application Security
सुरक्षा का केंद्र	Database और DBMS	Software, Web एवं Mobile Applications
मुख्य उद्देश्य	डेटा और Database Server की सुरक्षा	एप्लिकेशन को सुरक्षित बनाना
प्रमुख तकनीकें	Encryption, RBAC, Database Firewall, TDE	Secure Coding, WAF, SAST, DAST
उदाहरण	बैंक का ग्राहक Database	इंटरनेट बैंकिंग एप्लिकेशन

18. Database Security और Information Security में अंतर

आधार	Database Security	Information Security
सुरक्षा का दायरा	Database में संग्रहीत डेटा	सभी प्रकार की सूचना (डिजिटल एवं भौतिक)
मुख्य उद्देश्य	Database की सुरक्षा	सूचना की गोपनीयता, अखंडता और उपलब्धता
उदाहरण	MySQL Database	कागज़ी दस्तावेज़, ई-मेल, Database, फाइलें

19. Database Security में DBA (Database Administrator) की भूमिका

एक Database Administrator (DBA) Database Security बनाए रखने में महत्वपूर्ण भूमिका निभाता है।

मुख्य कार्य—

- Database Installation एवं Configuration
- User और Role Management
- Backup एवं Recovery
- Performance Monitoring
- Security Patch Installation
- Access Control लागू करना
- Audit Logs की समीक्षा
- Disaster Recovery योजना तैयार करना
- Database Encryption लागू करना

20. निष्कर्ष (Conclusion)

Database Security आधुनिक साइबर सुरक्षा का एक अत्यंत महत्वपूर्ण क्षेत्र है, क्योंकि किसी भी संगठन की सबसे मूल्यवान संपत्ति उसका डेटा होता है। यदि Database सुरक्षित नहीं है, तो वित्तीय हानि, डेटा उल्लंघन (Data Breach), कानूनी दंड और प्रतिष्ठा को गंभीर नुकसान हो सकता है। प्रभावी Authentication, Authorization, Role-Based Access Control (RBAC), Encryption (Data at Rest एवं Data in Transit), Transparent Data Encryption (TDE), Backup एवं Disaster Recovery, Audit Logging, Database Activity Monitoring (DAM) तथा नियमित Vulnerability Assessment जैसे उपाय Database को सुरक्षित रखते हैं। एक मजबूत Database Security Framework संगठन की गोपनीय जानकारी की रक्षा करता है, उपयोगकर्ताओं का विश्वास बढ़ाता है और व्यवसाय की निरंतरता (Business Continuity) सुनिश्चित करता है।

अध्याय – Wireless Security (वायरलेस सुरक्षा)

1. परिचय (Introduction)

आज के समय में अधिकांश लोग Wi-Fi, Bluetooth, NFC, मोबाइल नेटवर्क (3G/4G/5G), ZigBee, RFID तथा अन्य वायरलेस तकनीकों का उपयोग करते हैं। इन तकनीकों की सबसे बड़ी विशेषता यह है कि इनमें डेटा का आदान-प्रदान बिना किसी तार (Wire) के रेडियो तरंगों (Radio Waves) के माध्यम से होता है।

वायरलेस नेटवर्क ने संचार को तेज़, सुविधाजनक और लचीला (Flexible) बना दिया है, लेकिन इसके साथ सुरक्षा संबंधी अनेक चुनौतियाँ भी उत्पन्न हुई हैं। क्योंकि डेटा हवा (Air Medium) के माध्यम से प्रसारित होता है, इसलिए यदि उचित सुरक्षा उपाय न किए जाएँ, तो कोई भी हमलावर नेटवर्क में घुसपैठ (Intrusion), डेटा चोरी (Data Theft), जासूसी (Eavesdropping) या अन्य साइबर हमले कर सकता है।

इसी कारण Wireless Security (वायरलेस सुरक्षा) साइबर सुरक्षा का एक महत्वपूर्ण डोमेन है।

Wireless Security वह प्रक्रिया है जिसके द्वारा Wi-Fi, Bluetooth, NFC, RFID, मोबाइल नेटवर्क तथा अन्य वायरलेस संचार प्रणालियों को अनधिकृत पहुँच, डेटा चोरी, साइबर हमलों और गोपनीयता संबंधी खतरों से सुरक्षित रखा जाता है।

2. Wireless Network क्या है?

Wireless Network वह नेटवर्क है जिसमें उपकरण (Devices) आपस में रेडियो तरंगों (Radio Waves), माइक्रोवेव (Microwave) या इन्फ्रारेड (Infrared) के माध्यम से बिना तार के जुड़े रहते हैं।

उदाहरण

- Wi-Fi
- Bluetooth
- 4G / 5G Mobile Network
- Hotspot
- ZigBee
- NFC
- RFID
- Satellite Communication

3. Wireless Security क्या है?

Wireless Security का उद्देश्य—

- वायरलेस नेटवर्क को सुरक्षित बनाना
- डेटा चोरी रोकना
- अनधिकृत उपयोगकर्ता को रोकना
- सुरक्षित संचार सुनिश्चित करना
- नेटवर्क की गोपनीयता बनाए रखना

4. Wireless Security की परिभाषा

Wireless Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें तकनीकों, प्रोटोकॉल, एन्क्रिप्शन, प्रमाणीकरण और नीतियों के माध्यम से वायरलेस नेटवर्क तथा वायरलेस उपकरणों को साइबर खतरों से सुरक्षित रखा जाता है।

5. Wireless Security के उद्देश्य (Objectives)

(1) Confidentiality (गोपनीयता)

डेटा केवल अधिकृत उपयोगकर्ता ही देख सके।

उदाहरण

घर के Wi-Fi का Password केवल परिवार के सदस्यों को पता हो।

(2) Integrity (अखंडता)

डेटा में रास्ते में कोई परिवर्तन न हो।

उदाहरण

ऑनलाइन बैंकिंग का डेटा सुरक्षित रूप से सर्वर तक पहुँचे।

(3) Availability (उपलब्धता)

Wireless Network आवश्यकता पड़ने पर उपलब्ध रहे।

(4) Authentication (प्रमाणीकरण)

केवल अधिकृत उपयोगकर्ता ही नेटवर्क से जुड़ सके।

(5) Authorization (प्राधिकरण)

प्रत्येक उपयोगकर्ता को उसके अधिकार के अनुसार पहुँच मिले।

6. Wireless Network के प्रकार

(1) WLAN (Wireless Local Area Network)

घर, कार्यालय या विद्यालय में Wi-Fi आधारित नेटवर्क।

(2) WWAN (Wireless Wide Area Network)

मोबाइल नेटवर्क (3G, 4G, 5G)।

(3) WPAN (Wireless Personal Area Network)

कम दूरी का नेटवर्क।

उदाहरण

Bluetooth

(4) WMAN (Wireless Metropolitan Area Network)

किसी शहर या बड़े क्षेत्र को जोड़ने वाला नेटवर्क।

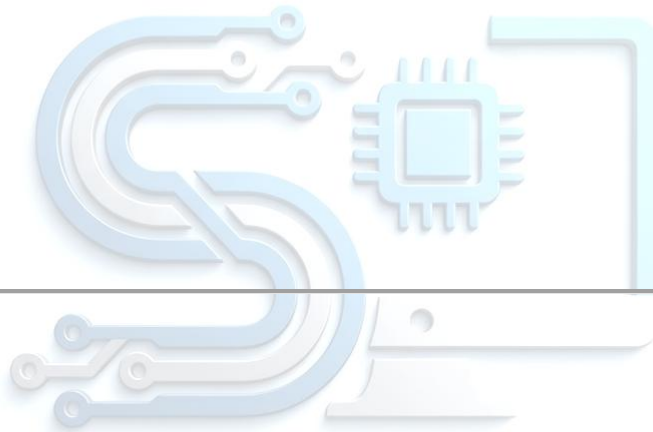
7. Wireless Communication Technologies

(1) Wi-Fi

IEEE 802.11 मानक पर आधारित वायरलेस नेटवर्क।

उपयोग

- घर
- कार्यालय
- विद्यालय
- कैफे
- हवाई अड्डे



(2) Bluetooth

कम दूरी की वायरलेस तकनीक।

उदाहरण

- वायरलेस हेडफोन
- स्मार्टवॉच
- कीबोर्ड
- माउस

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

(3) NFC (Near Field Communication)

बहुत कम दूरी पर डेटा का आदान-प्रदान।

उदाहरण

- Contactless Payment
- Metro Card

- Access Card

(4) RFID (Radio Frequency Identification)

रेडियो तरंगों से पहचान करना।

उदाहरण

- कर्मचारी ID कार्ड
- पुस्तकालय प्रबंधन
- टोल प्लाज़ा

(5) ZigBee

कम ऊर्जा (Low Power) वाली IoT तकनीक।

उदाहरण

Smart Home Devices

(6) Mobile Network (3G/4G/5G)

मोबाइल संचार के लिए उपयोग।

8. Wireless Security के प्रमुख घटक

(1) Encryption

डेटा को एन्क्रिप्ट करना।

उदाहरण

WPA2 और WPA3 Encryption।

(2) Authentication

नेटवर्क से जुड़ने वाले उपयोगकर्ता की पहचान करना।

उदाहरण

Wi-Fi Password

(3) Access Control

कौन नेटवर्क से जुड़ सकता है।

उदाहरण

MAC Address Filtering

(4) Firewall

वायरलेस नेटवर्क की सुरक्षा।

(5) VPN

Public Wi-Fi पर सुरक्षित कनेक्शन।

(6) Intrusion Detection System (IDS)

संदिग्ध गतिविधियों का पता लगाना।

(7) Wireless Intrusion Prevention System (WIPS)

अनधिकृत Access Point और हमलों को पहचानकर रोकना।

9. Wi-Fi Security Standards

(1) WEP (Wired Equivalent Privacy)

पुराना और असुरक्षित मानक।

स्थिति

अब उपयोग नहीं करना चाहिए।

(2) WPA (Wi-Fi Protected Access)

WEP से अधिक सुरक्षित।

(3) WPA2

आज भी व्यापक रूप से उपयोग किया जाता है।

विशेषताएँ

- AES Encryption
- मजबूत सुरक्षा



(4) WPA3

सबसे आधुनिक और अधिक सुरक्षित Wi-Fi मानक।

विशेषताएँ

- बेहतर Encryption
- Dictionary Attack से सुरक्षा
- Forward Secrecy

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

10. Wireless Security के प्रमुख खतरे (Threats)

(1) Rogue Access Point

हमलावर नकली Wi-Fi Access Point बना देता है।

"Free Airport Wi-Fi"

(2) Evil Twin Attack

नकली Wi-Fi नेटवर्क बनाकर उपयोगकर्ताओं का डेटा चुराना।

(3) Packet Sniffing

वायरलेस डेटा को बीच में पढ़ना।

(4) Man-in-the-Middle (MITM)

हमलावर उपयोगकर्ता और सर्वर के बीच बैठ जाता है।

(5) Wi-Fi Password Cracking

कमज़ोर Password तोड़ना।

(6) Bluetooth Attack

प्रकार

- Bluejacking
 - Bluesnarfing
 - Bluebugging
-

(7) Deauthentication Attack

उपयोगकर्ता को Wi-Fi से जबरन Disconnect करना।

(8) Replay Attack

(9) Jamming Attack

रेडियो सिग्नल में बाधा उत्पन्न करना।

(10) Public Wi-Fi Attack

असुरक्षित सार्वजनिक Wi-Fi का दुरुपयोग।

11. Wireless Security में प्रयुक्त तकनीकें

- WPA3
 - AES Encryption
 - VPN
 - MAC Address Filtering
 - Captive Portal
 - Wireless IDS
 - Wireless IPS
 - RADIUS Authentication
 - 802.1X Authentication
 - Network Segmentation
- 

12. Wireless Security Best Practices

1. WPA3 या कम से कम WPA2 का उपयोग करें।
2. Wi-Fi का Default Password तुरंत बदलें।
3. मजबूत और जटिल Password रखें।
4. Router Firmware नियमित रूप से अपडेट करें।
5. WPS (Wi-Fi Protected Setup) बंद रखें।
6. Guest Network अलग बनाएँ।
7. VPN का उपयोग करें, विशेषकर Public Wi-Fi पर।
8. Bluetooth आवश्यकता न होने पर बंद रखें।
9. MAC Address Filtering लागू करें (यह अतिरिक्त सुरक्षा है, पूर्ण सुरक्षा नहीं)।
10. Hidden SSID पर निर्भर न रहें; यह सुरक्षा का विकल्प नहीं है।

11. नियमित रूप से Router Logs की जाँच करें।
12. Wireless IDS/WIPS का उपयोग बड़े संगठनों में करें।

13. Wireless Security Policies

- Wi-Fi Usage Policy
- Password Policy
- Guest Access Policy
- Remote Access Policy
- Mobile Device Policy
- BYOD (Bring Your Own Device) Policy
- Wireless Monitoring Policy

14. Wireless Security के वास्तविक उदाहरण

उदाहरण 1 - घर का Wi-Fi

एक परिवार ने Router में—

- WPA3 Encryption
- मजबूत Password
- Guest Network

सक्रिय किया है।

इससे पड़ोसी बिना अनुमति नेटवर्क का उपयोग नहीं कर सकते।

उदाहरण 2 - बैंक

बैंक कर्मचारियों के लिए Enterprise Wi-Fi उपलब्ध है।

- WPA3 Enterprise
- RADIUS Server
- 802.1X Authentication
- Network Segmentation

के माध्यम से सुरक्षित कनेक्शन स्थापित किया जाता है।

उदाहरण 3 – विश्वविद्यालय

विश्वविद्यालय में छात्रों और शिक्षकों के लिए अलग-अलग Wi-Fi नेटवर्क हैं। प्रत्येक उपयोगकर्ता को Login Credentials के आधार पर Access मिलता है। Wireless IDS संदिग्ध Access Point का पता लगाता है।

उदाहरण 4 – कैफे

एक उपयोगकर्ता Public Wi-Fi से इंटरनेट बैंकिंग करता है। यदि वह VPN का उपयोग नहीं करता, तो हमलावर MITM Attack का प्रयास कर सकता है।

बचाव: VPN और HTTPS का उपयोग करें।

15. Wireless Security के लाभ

- सुरक्षित वायरलेस संचार
- डेटा चोरी में कमी
- सुरक्षित मोबाइल कार्य (Mobile Workforce)
- उपयोगकर्ताओं की गोपनीयता की रक्षा
- व्यवसाय की निरंतरता
- सुरक्षित Remote Access
- नेटवर्क की विश्वसनीयता में वृद्धि

16. Wireless Security की चुनौतियाँ

- Rogue Access Points
- Public Wi-Fi के खतरे
- Bluetooth Vulnerabilities
- IoT Devices की सुरक्षा
- तेजी से बदलते वायरलेस हमले
- कमजोर Password
- Signal Interference
- बड़े वायरलेस नेटवर्क का प्रबंधन

17. Wireless Security और Network Security में अंतर

आधार	Wireless Security	Network Security
सुरक्षा का केंद्र	Wi-Fi, Bluetooth, NFC, RFID, मोबाइल नेटवर्क	Wired एवं Wireless दोनों प्रकार के नेटवर्क
मुख्य उद्देश्य	वायरलेस संचार की सुरक्षा	पूरे नेटवर्क की सुरक्षा
प्रमुख तकनीकें	WPA3, WIPS, RADIUS, VPN	Firewall, IDS, IPS, VPN, Network Segmentation
उदाहरण	घर का Wi-Fi सुरक्षित करना	पूरे बैंक नेटवर्क की सुरक्षा

18. Wireless Security और Mobile Security में अंतर

आधार	Wireless Security	Mobile Security
सुरक्षा का केंद्र	वायरलेस नेटवर्क	मोबाइल डिवाइस
मुख्य उद्देश्य	सुरक्षित वायरलेस संचार	मोबाइल डेटा एवं एप्लिकेशन की सुरक्षा
उदाहरण	Wi-Fi Router	Smartphone

19. आधुनिक Wireless Security प्रवृत्तियाँ (Emerging Trends)

- WPA3 Enterprise का बढ़ता उपयोग
- Wi-Fi 6 और Wi-Fi 7 में उन्नत सुरक्षा सुविधाएँ
- Zero Trust Network Access (ZTNA) आधारित वायरलेस पहुँच
- AI आधारित Wireless Threat Detection
- Cloud-Managed Wi-Fi Security
- IoT Device Isolation और Micro-Segmentation
- 802.1X और Certificate-Based Authentication का बढ़ता उपयोग

20. निष्कर्ष (Conclusion)

Wireless Security आधुनिक साइबर सुरक्षा का अत्यंत महत्वपूर्ण भाग है क्योंकि अधिकांश डिजिटल संचार आज Wi-Fi, Bluetooth, 4G/5G तथा अन्य वायरलेस तकनीकों पर निर्भर है। वायरलेस नेटवर्क में डेटा हवा के माध्यम से प्रसारित होता है, इसलिए **Encryption (WPA3/AES)**, **मजबूत प्रमाणीकरण (Authentication)**, **VPN**, **Wireless IDS/WIPS**, **Firmware Updates**, **Guest Network**, **Network Segmentation** तथा **उपयोगकर्ता जागरूकता** अत्यंत आवश्यक हैं। एक मजबूत Wireless Security Framework न केवल डेटा की गोपनीयता, अखंडता और उपलब्धता सुनिश्चित करता है, बल्कि संगठनों और व्यक्तिगत उपयोगकर्ताओं को वायरलेस आधारित साइबर हमलों से प्रभावी रूप से सुरक्षित भी रखता है।



अध्याय – IoT Security (Internet of Things Security)

अध्याय – IoT Security (इंटरनेट ऑफ थिंग्स सुरक्षा)

1. परिचय (Introduction)

वर्तमान समय में इंटरनेट केवल कंप्यूटर और मोबाइल तक सीमित नहीं रह गया है। आज अनेक स्मार्ट उपकरण (Smart Devices) भी इंटरनेट से जुड़े हुए हैं, जो बिना मानव हस्तक्षेप के आपस में डेटा का आदान-प्रदान करते हैं और स्वतः कार्य करते हैं। इस तकनीक को Internet of Things (IoT) कहा जाता है।

उदाहरण के लिए—

- Smart TV
- Smart Refrigerator
- Smart Watch
- Smart Bulb
- Smart Lock
- CCTV Camera
- Smart AC
- Smart Car
- Fitness Band
- Smart Meter
- Smart Speaker
- Industrial Sensors
- Smart Medical Devices

इन सभी उपकरणों में सेंसर (Sensors), प्रोसेसर (Processor), नेटवर्क कनेक्टिविटी (Network Connectivity) तथा सॉफ्टवेयर होता है।

चूँकि ये उपकरण इंटरनेट से जुड़े होते हैं, इसलिए साइबर अपराधी इन्हें भी निशाना बनाते हैं। यदि IoT Device सुरक्षित न हो, तो हैकर उस डिवाइस पर नियंत्रण प्राप्त कर सकता है, उपयोगकर्ता की निजी जानकारी चुरा सकता है या पूरे नेटवर्क पर हमला कर सकता है।

इसी कारण IoT Security (Internet of Things Security) साइबर सुरक्षा का एक अत्यंत महत्वपूर्ण क्षेत्र है।

IoT Security वह प्रक्रिया है जिसके द्वारा इंटरनेट से जुड़े स्मार्ट उपकरणों (Smart Devices), उनके डेटा, संचार तथा नेटवर्क को साइबर खतरों, अनधिकृत पहुँच और डेटा चोरी से सुरक्षित रखा जाता है।

2. Internet of Things (IoT) क्या है?

Internet of Things (IoT) ऐसी तकनीक है जिसमें विभिन्न भौतिक उपकरण (Physical Devices) इंटरनेट के माध्यम से एक-दूसरे से जुड़े रहते हैं और डेटा का आदान-प्रदान करते हैं।

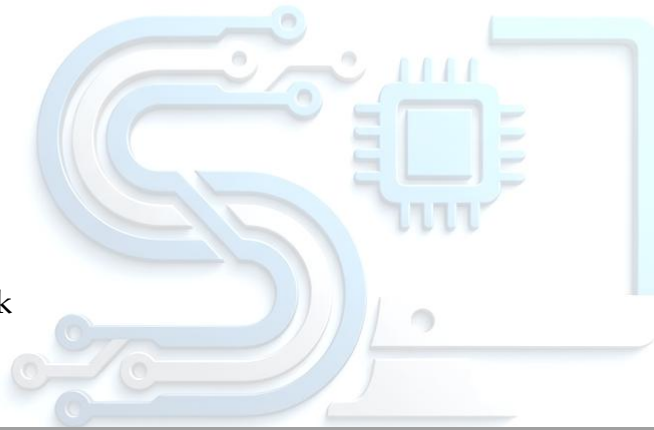
इन उपकरणों में सामान्यतः निम्न घटक होते हैं—

- Sensors
- Microcontroller / Processor
- Internet Connection
- Software
- Cloud Platform

उदाहरण

घर

- Smart Bulb
- Smart Fan
- Smart Door Lock
- Smart Camera



अस्पताल

- Heart Rate Monitor
- Smart ECG Machine
- Smart Insulin Pump

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

उद्योग

- Temperature Sensor
- Smart Machine
- Smart Robot

कृषि

- Smart Irrigation System
- Soil Moisture Sensor

परिवहन

- Smart Traffic Signal
- Connected Car
- GPS Tracker

3. IoT Security क्या है?

IoT Security का उद्देश्य—

- IoT Devices को सुरक्षित रखना।
- उनके डेटा को सुरक्षित रखना।
- अनधिकृत व्यक्ति को डिवाइस नियंत्रित करने से रोकना।
- नेटवर्क में Malware फैलने से रोकना।
- IoT Ecosystem की विश्वसनीयता बनाए रखना।

4. IoT Security की परिभाषा

IoT Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें तकनीकों, नीतियों, एन्क्रिप्शन, प्रमाणीकरण तथा निगरानी के माध्यम से इंटरनेट से जुड़े उपकरणों, उनके डेटा और संचार को साइबर हमलों से सुरक्षित रखा जाता है।

5. IoT Security के उद्देश्य (Objectives)

(1) Confidentiality (गोपनीयता)

IoT Device द्वारा भेजा गया डेटा केवल अधिकृत व्यक्ति ही देख सके।

उदाहरण

Smart Camera की Live Video केवल घर का मालिक ही देख सके।

(2) Integrity (अखंडता)

डेटा में कोई अनधिकृत परिवर्तन न हो।

उदाहरण

Temperature Sensor का वास्तविक डेटा बदला न जा सके।

(3) Availability (उपलब्धता)

IoT Device हमेशा कार्य करने के लिए उपलब्ध रहे।

उदाहरण

Smart Fire Alarm हमेशा सक्रिय रहे।

(4) Authentication (प्रमाणीकरण)

केवल अधिकृत उपयोगकर्ता ही IoT Device नियंत्रित कर सके।

(5) Authorization (प्राधिकरण)

प्रत्येक उपयोगकर्ता को उसके अधिकार के अनुसार ही नियंत्रण मिले।

6. IoT Architecture

IoT System सामान्यतः चार स्तरों में कार्य करता है—

(1) Device Layer

यह वास्तविक IoT Device होता है।

उदाहरण

- Smart Watch

- Sensor
- CCTV

(2) Network Layer

डेटा इंटरनेट के माध्यम से भेजा जाता है।

उदाहरण

Wi-Fi

Bluetooth

5G

LoRaWAN

(3) Cloud Layer

डेटा Cloud में संग्रहीत और विश्लेषित किया जाता है।

(4) Application Layer

मोबाइल App या Web Dashboard द्वारा उपयोगकर्ता डिवाइस को नियंत्रित करता है।

7. IoT Security के प्रमुख घटक (Components)

(1) Device Authentication

IoT Device की पहचान सत्यापित करना।

उदाहरण

Digital Certificate

(2) User Authentication

उदाहरण

Username + Password + OTP

(3) Encryption

डेटा को सुरक्षित रूप में भेजना।

उदाहरण

TLS

AES

(4) Secure Firmware

केवल अधिकृत Firmware ही Install हो।

(5) Secure Boot

डिवाइस चालू होने पर केवल Trusted Software चले।

(6) Access Control

किस उपयोगकर्ता को कौन-सा IoT Device नियंत्रित करने की अनुमति है।

(7) Monitoring

सभी IoT Devices की लगातार निगरानी।

8. IoT Security में प्रयुक्त तकनीकें

- TLS / SSL
- AES Encryption
- RSA Encryption
- Secure Boot
- Secure Firmware Update
- Digital Certificate
- Public Key Infrastructure (PKI)
- Identity and Access Management (IAM)
- Network Segmentation
- Zero Trust Security
- AI आधारित Threat Detection
- Device Identity Management

9. IoT Security के प्रमुख खतरे (Threats)

(1) Default Password

अधिकांश IoT Devices में Default Password होता है।

उदाहरण

Username : admin

Password : admin

यदि इसे नहीं बदला गया तो हैकर आसानी से डिवाइस नियंत्रित कर सकता है।

(2) Weak Authentication

कमज़ोर Password।

(3) Unpatched Firmware

Firmware Update न होने से Vulnerability बनी रहती है।

(4) Malware

IoT Devices में Malware स्थापित हो जाना।

(5) Botnet Attack

हजारों IoT Devices को संक्रमित कर Botnet बनाना।

उदाहरण

Mirai Botnet

Mirai Malware ने लाखों IoT Devices (विशेषकर CCTV Camera और Router) को संक्रमित कर बड़े पैमाने पर DDoS Attack किए।

(6) Data Theft

Sensor Data चोरी करना।

(7) Device Hijacking

IoT Device का नियंत्रण प्राप्त कर लेना।

(8) Eavesdropping

नेटवर्क के माध्यम से डेटा सुनना।

(9) Denial of Service (DoS)

IoT Device को अनुपलब्ध करना।

(10) Physical Attack

डिवाइस तक सीधे पहुँचकर छेड़छाड़ करना।

10. IoT Security Best Practices

1. Default Password तुरंत बदलें।
2. मजबूत Password और Multi-Factor Authentication (MFA) का उपयोग करें।
3. Firmware नियमित रूप से अपडेट करें।
4. केवल विश्वसनीय निर्माता (Trusted Vendor) के IoT Devices खरीदें।
5. डेटा Encryption सक्षम रखें।
6. IoT Devices को मुख्य नेटवर्क से अलग (Network Segmentation) रखें।
7. अनावश्यक Services और Ports बंद रखें।
8. Remote Access केवल आवश्यकता होने पर सक्षम करें।
9. नियमित Security Monitoring करें।
10. IoT Devices की सूची (Inventory) बनाए रखें।
11. Device Logs की समीक्षा करें।
12. Zero Trust Security अपनाएँ।

11. IoT Security Policies

- Device Management Policy
- Password Policy
- Firmware Update Policy
- Remote Access Policy
- Network Segmentation Policy
- Incident Response Policy
- Vendor Management Policy

12. IoT Security के वास्तविक उदाहरण

उदाहरण 1 – Smart Home

एक घर में—

- Smart Door Lock
- Smart Camera
- Smart Bulb
- Smart Speaker

सभी Wi-Fi से जुड़े हैं।

यदि Wi-Fi Password कमजोर हो, तो हमलावर कैमरा देख सकता है।

बचाव

- WPA3
- मजबूत Password
- MFA

उदाहरण 2 – Smart Hospital

मरीजों के—

- Heart Monitor
- ECG Machine
- Smart Pump

सभी IoT आधारित हैं।

यदि किसी हमलावर ने Medical Device नियंत्रित कर लिया, तो मरीज की जान खतरे में पड़ सकती है।

उदाहरण 3 – Smart Factory

एक उद्योग में सभी मशीनें Sensor द्वारा नियंत्रित होती हैं।

यदि Sensor Data बदल दिया जाए, तो पूरी उत्पादन प्रक्रिया प्रभावित हो सकती है।

उदाहरण 4 – Smart Agriculture

Soil Moisture Sensor के आधार पर सिंचाई होती है।

यदि Sensor Hack हो जाए, तो गलत समय पर सिंचाई हो सकती है, जिससे फसल को नुकसान होगा।

13. IoT Security के लाभ

- सुरक्षित Smart Home
- सुरक्षित Smart City
- उद्योगों में सुरक्षित Automation
- स्वास्थ्य सेवाओं की विश्वसनीयता
- डेटा गोपनीयता
- Cyber Attack में कमी
- बेहतर Device Management
- व्यवसाय की निरंतरता

14. IoT Security की चुनौतियाँ

- लाखों IoT Devices का प्रबंधन
- कमजोर Hardware
- Default Password
- सीमित Processing Power
- Firmware Update में कठिनाई
- विभिन्न निर्माताओं के अलग-अलग मानक
- Physical Tampering
- Zero-Day Vulnerabilities



15. IoT Security और Endpoint Security में अंतर

आधार	IoT Security	Endpoint Security
सुरक्षा का केंद्र	Smart Devices और Sensors	Laptop, Desktop, Mobile आदि
मुख्य उद्देश्य	IoT Ecosystem की सुरक्षा	व्यक्तिगत Endpoint की सुरक्षा
उदाहरण	Smart Camera	Office Laptop

16. IoT Security और Mobile Security में अंतर

17. IoT Security में उभरती तकनीकें (Emerging Technologies)

- Artificial Intelligence (AI) आधारित Threat Detection
- Machine Learning (ML) द्वारा असामान्य व्यवहार की पहचान
- Blockchain आधारित Device Identity Management
- Zero Trust Architecture
- Edge Computing Security
- Hardware Root of Trust
- Secure Element Chips
- Post-Quantum Cryptography (भविष्य की एन्क्रिप्शन तकनीक)

18. वास्तविक साइबर घटना – Mirai Botnet

Mirai Botnet (2016) IoT सुरक्षा का एक प्रसिद्ध उदाहरण है।

क्या हुआ?

- लाखों CCTV Camera, DVR और Router में Default Username/Password का उपयोग किया जा रहा था।
- Mirai Malware ने इन कमजोर IoT Devices को संक्रमित कर लिया।
- संक्रमित डिवाइसों का उपयोग करके बड़े पैमाने पर Distributed Denial of Service (DDoS) हमले किए गए।
- कई प्रमुख इंटरनेट सेवाएँ अस्थायी रूप से प्रभावित हुईं।

इससे सीख

- Default Password कभी न रखें।
- Firmware नियमित रूप से अपडेट करें।
- IoT Devices की निगरानी करें।

19. IoT Security के लाभ और भविष्य

भविष्य में Smart City, Smart Hospital, Smart Agriculture, Autonomous Vehicles और Industrial Automation के बढ़ते उपयोग के साथ IoT Security का महत्व और अधिक बढ़ेगा। सुरक्षित IoT अवसंरचना (Infrastructure) डिजिटल अर्थव्यवस्था, सार्वजनिक सेवाओं और राष्ट्रीय सुरक्षा के लिए अत्यंत आवश्यक होगी।

20. निष्कर्ष (Conclusion)

IoT Security आधुनिक साइबर सुरक्षा का तेजी से विकसित होने वाला क्षेत्र है। इंटरनेट से जुड़े स्मार्ट उपकरण हमारे घर, उद्योग, अस्पताल, कृषि और परिवहन जैसे अनेक क्षेत्रों में उपयोग किए जा रहे हैं। इन उपकरणों की सुरक्षा के लिए **मजबूत प्रमाणीकरण (Authentication), Encryption, Secure Boot, Firmware Updates, Network Segmentation, Identity and Access Management (IAM)** तथा **निरंतर मॉनिटरिंग** आवश्यक हैं। एक प्रभावी IoT Security Framework न केवल उपकरणों और डेटा की रक्षा करता है, बल्कि पूरे IoT Ecosystem की विश्वसनीयता, उपलब्धता और सुरक्षित संचालन को भी सुनिश्चित करता है।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय – OT Security (Operational Technology Security)

उदाहरण सहित अत्यंत विस्तृत अध्ययन

1. परिचय (Introduction)

आधुनिक औद्योगिक युग में केवल कंप्यूटर और सूचना प्रणाली (Information Technology - IT) ही महत्वपूर्ण नहीं हैं, बल्कि वे प्रणालियाँ भी अत्यंत महत्वपूर्ण हैं जो मशीनों, कारखानों, बिजलीघरों, तेल एवं गैस संयंत्रों, रेलवे, जल आपूर्ति, अस्पतालों और अन्य महत्वपूर्ण अवसंरचनाओं (Critical Infrastructure) को नियंत्रित करती हैं। इन प्रणालियों को Operational Technology (OT) कहा जाता है।

OT प्रणाली का मुख्य कार्य भौतिक उपकरणों (Physical Devices), औद्योगिक मशीनों (Industrial Machines), सेंसर (Sensors), वाल्व (Valves), मोटर (Motors), रोबोट (Robots) और उत्पादन प्रक्रियाओं (Production Processes) की निगरानी (Monitoring) एवं नियंत्रण (Control) करना है।

पहले OT नेटवर्क इंटरनेट से अलग (Isolated) रहते थे, लेकिन आज Industry 4.0, Industrial Internet of Things (IIoT), Cloud Computing, Remote Monitoring और Digital Transformation के कारण ये नेटवर्क इंटरनेट तथा IT नेटवर्क से जुड़ गए हैं। इससे उत्पादकता तो बढ़ी है, लेकिन साइबर हमलों का खतरा भी कई गुना बढ़ गया है।

इसी कारण OT Security (Operational Technology Security) साइबर सुरक्षा का एक अत्यंत महत्वपूर्ण और विशिष्ट डोमेन बन चुका है।

OT Security वह प्रक्रिया है जिसके द्वारा औद्योगिक नियंत्रण प्रणालियों (Industrial Control Systems - ICS), SCADA Systems, PLC, DCS, RTU, Sensors, Actuators तथा अन्य Operational Technology उपकरणों और नेटवर्क को साइबर हमलों, अनधिकृत पहुँच, डेटा में छेड़छाड़ तथा संचालन (Operations) में बाधा से सुरक्षित रखा जाता है।

2. Operational Technology (OT) क्या है?

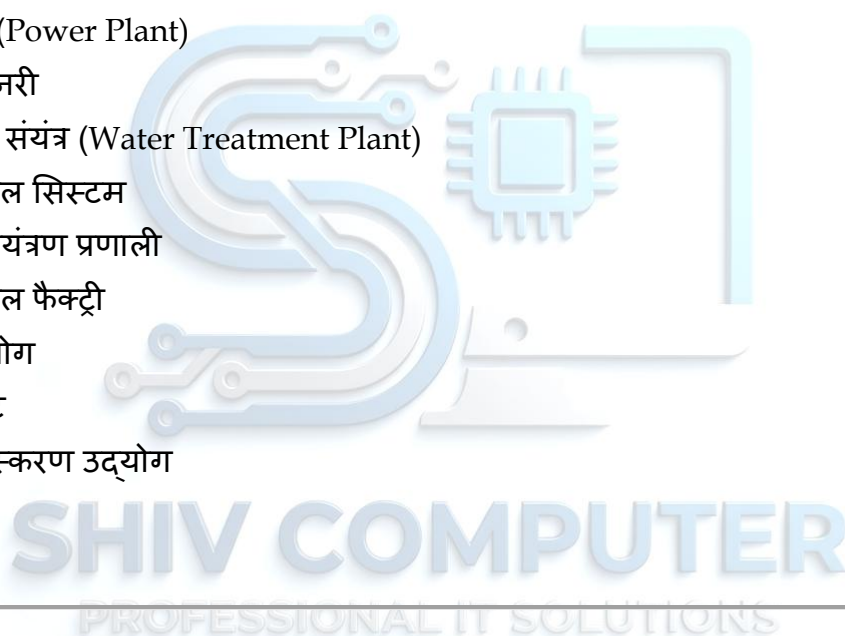
Operational Technology (OT) ऐसी तकनीक है जो भौतिक प्रक्रियाओं (Physical Processes) की निगरानी, नियंत्रण और स्वचालन (Automation) का कार्य करती है।

OT का मुख्य उद्देश्य—

- मशीनों को नियंत्रित करना
- उत्पादन प्रक्रिया चलाना
- तापमान नियंत्रित करना
- बिजली वितरण नियंत्रित करना
- गैस एवं तेल पाइपलाइन नियंत्रित करना
- जल आपूर्ति नियंत्रित करना
- रेलवे सिग्नल नियंत्रित करना

उदाहरण

- बिजलीघर (Power Plant)
- तेल रिफाइनरी
- जल शोधन संयंत्र (Water Treatment Plant)
- रेलवे सिग्नल सिस्टम
- मेट्रो रेल नियंत्रण प्रणाली
- ऑटोमोबाइल फैक्ट्री
- सीमेंट उद्योग
- स्टील प्लांट
- खाद्य प्रसंस्करण उद्योग
- स्मार्ट ग्रिड



3. OT Security क्या है?

OT Security का उद्देश्य—

- औद्योगिक उपकरणों की सुरक्षा
- उत्पादन प्रक्रिया की सुरक्षा
- मानव जीवन की सुरक्षा
- Critical Infrastructure की सुरक्षा
- साइबर हमलों से संचालन को सुरक्षित रखना

4. OT Security की परिभाषा

OT Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें तकनीकी नियंत्रण, नीतियाँ, निगरानी और सुरक्षा उपायों के माध्यम से औद्योगिक नियंत्रण प्रणालियों तथा उनसे जुड़े उपकरणों को साइबर खतरों से सुरक्षित रखा जाता है।

5. OT Security के उद्देश्य (Objectives)

(1) Safety (सुरक्षा)

OT में सबसे पहला उद्देश्य मानव जीवन एवं मशीनों की सुरक्षा है।

उदाहरण

यदि किसी परमाणु संयंत्र में नियंत्रण प्रणाली से छेड़छाड़ हो जाए, तो गंभीर दुर्घटना हो सकती है।

(2) Availability (उपलब्धता)

OT Systems का लगातार कार्यरत रहना अत्यंत आवश्यक है।

उदाहरण

बिजलीघर 24x7 संचालित रहना चाहिए।

(3) Integrity (अखंडता)

सेंसर और नियंत्रण आदेशों (Control Commands) में कोई अनधिकृत परिवर्तन न हो।

उदाहरण

तापमान सेंसर का डेटा सही रहे।

(4) Confidentiality (गोपनीयता)

औद्योगिक प्रक्रियाओं और नियंत्रण संबंधी जानकारी सुरक्षित रहे।

(5) Reliability (विश्वसनीयता)

प्रणाली हमेशा अपेक्षित तरीके से कार्य करे।

6. OT और IT में अंतर

आधार	OT (Operational Technology)	IT (Information Technology)
मुख्य उद्देश्य	मशीनों एवं प्रक्रियाओं का नियंत्रण	सूचना का प्रबंधन
प्राथमिकता	Safety एवं Availability	Confidentiality
उपकरण	PLC, SCADA, DCS, RTU, Sensors	Server, PC, Laptop
प्रभाव	भौतिक नुकसान, उत्पादन बंद	डेटा हानि, वित्तीय नुकसान
अपडेट	सीमित एवं योजनाबद्ध	नियमित अपडेट

7. OT Architecture

OT प्रणाली सामान्यतः निम्न स्तरों में कार्य करती है—

Level 0

Physical Process

- Sensors
 - Actuators
-

Level 1

Basic Control

- PLC
 - RTU
-

Level 2

Supervisory Control

- HMI (Human Machine Interface)
 - SCADA
-

Level 3

Operations Management

- Production Servers
 - Historian Server
-

Level 4

Enterprise IT Network

- ERP
 - Email
 - Database
-

Level 5

Cloud Services

- Remote Monitoring
 - Analytics
-

8. OT Security के प्रमुख घटक

(1) Industrial Control System (ICS)

उद्योग की संपूर्ण नियंत्रण प्रणाली।

(2) SCADA (Supervisory Control and Data Acquisition)

दूरस्थ स्थानों से मशीनों की निगरानी।

बिजली वितरण प्रणाली।

(3) PLC (Programmable Logic Controller)

औद्योगिक मशीनों का नियंत्रण।

(4) DCS (Distributed Control System)

बड़े उद्योगों में वितरित नियंत्रण।

(5) RTU (Remote Terminal Unit)

दूरस्थ सेंसर डेटा संग्रह।

(6) HMI (Human Machine Interface)

ऑपरेटर द्वारा मशीन नियंत्रित करने का इंटरफ़ेस।

9. OT Security में प्रयुक्त तकनीकें

- Network Segmentation
- Industrial Firewall
- Unidirectional Gateway (Data Diode)
- Multi-Factor Authentication (MFA)
- VPN
- Secure Remote Access
- Security Information and Event Management (SIEM)
- Intrusion Detection System (IDS)
- Intrusion Prevention System (IPS)
- Industrial Intrusion Detection (IIDS)
- Endpoint Protection
- Asset Inventory
- Patch Management

10. OT Security के प्रमुख खतरे (Threats)

(1) Malware

औद्योगिक सिस्टम में दुर्भावनापूर्ण सॉफ्टवेयर।

(2) Ransomware

पूरे उत्पादन संयंत्र को बंद कर देना।

(3) Insider Threat

कर्मचारी द्वारा जानबूझकर नुकसान।

(4) Remote Access Attack

VPN या Remote Access का दुरुपयोग।

(5) Supply Chain Attack

Vendor Software के माध्यम से हमला।

(6) Denial of Service (DoS)

SCADA Server को अनुपलब्ध करना।

(7) Unauthorized Command Injection

PLC को गलत Command भेजना।

(8) Sensor Manipulation

Sensor Data बदल देना।

(9) Physical Tampering

उपकरणों से छेड़छाड़।

(10) Zero-Day Vulnerability

नई खोजी गई कमजोरी का दुरुपयोग।

11. OT Security Best Practices

1. IT और OT नेटवर्क अलग रखें।
 2. Network Segmentation लागू करें।
 3. Default Password बदलें।
 4. Multi-Factor Authentication का उपयोग करें।
 5. केवल अधिकृत Remote Access दें।
 6. Patch Management योजनाबद्ध तरीके से करें।
 7. Asset Inventory बनाए रखें।
 8. नियमित Backup लें।
 9. Incident Response Plan तैयार रखें।
 10. नियमित Security Audit करें।
 11. OT कर्मचारियों को Cyber Security प्रशिक्षण दें।
 12. USB Devices का नियंत्रित उपयोग करें।
-

12. OT Security Policies

- Industrial Security Policy
- Remote Access Policy
- Patch Management Policy
- Vendor Access Policy
- Incident Response Policy
- Backup Policy

13. वास्तविक उदाहरण

उदाहरण 1 – बिजलीघर (Power Plant)

Power Plant में SCADA System बिजली उत्पादन नियंत्रित करता है।

यदि कोई हमलावर SCADA Server पर नियंत्रण प्राप्त कर ले, तो बिजली आपूर्ति बाधित हो सकती है।

बचाव

- Network Segmentation
 - Industrial Firewall
 - SIEM Monitoring
-

उदाहरण 2 – जल शोधन संयंत्र

Water Treatment Plant में PLC पानी में क्लोरीन की मात्रा नियंत्रित करता है।

यदि PLC में गलत Command भेज दी जाए, तो पानी असुरक्षित हो सकता है।

उदाहरण 3 – ऑटोमोबाइल फैक्ट्री

Robotic Assembly Line PLC द्वारा नियंत्रित होती है।

यदि Malware PLC Program बदल दे, तो उत्पादन रुक सकता है।

उदाहरण 4 – तेल एवं गैस पाइपलाइन

SCADA System Pipeline Pressure नियंत्रित करता है।

Sensor Data बदलने पर दुर्घटना हो सकती है।

14. वास्तविक साइबर घटना – Stuxnet

Stuxnet OT Security के इतिहास का सबसे प्रसिद्ध साइबर हमला माना जाता है।

क्या हुआ?

- Stuxnet Malware विशेष रूप से औद्योगिक PLC को लक्ष्य बनाकर बनाया गया था।
- इसने Siemens PLC नियंत्रित प्रणालियों को प्रभावित किया।
- मशीनें सामान्य दिखाई देती थीं, लेकिन अंदर ही अंदर गलत तरीके से कार्य कर रही थीं।
- इससे औद्योगिक उपकरणों को भौतिक क्षति पहुँची।

सीख

- OT नेटवर्क को अलग रखें।
- USB Devices नियंत्रित करें।
- PLC Program Integrity जाँचें।
- नियमित Security Monitoring करें।

15. OT Security के लाभ

- उत्पादन की निरंतरता
- मानव जीवन की सुरक्षा
- Critical Infrastructure की सुरक्षा
- मशीनों की विश्वसनीयता
- आर्थिक नुकसान में कमी
- Cyber Attack का प्रभाव कम
- Regulatory Compliance
- सुरक्षित Industrial Automation

16. OT Security की चुनौतियाँ

- पुराने (Legacy) उपकरण
- लंबे समय तक चलने वाली मशीनें
- Patch लागू करने में कठिनाई
- Vendor Dependency

- IT और OT का एकीकरण
- IIoT के कारण बढ़ता Attack Surface
- Physical Security की आवश्यकता
- Skilled OT Security Professionals की कमी

17. OT Security और IoT Security में अंतर

आधार	OT Security	IoT Security
उद्देश्य	औद्योगिक नियंत्रण प्रणाली की सुरक्षा	Smart Devices की सुरक्षा
उपकरण	PLC, SCADA, DCS	Smart Watch, Camera, Sensor
प्राथमिकता	Safety एवं Availability	Device एवं Data Security
उपयोग	उद्योग, बिजलीघर, जल संयंत्र	Smart Home, Smart City

18. OT Security और IT Security में अंतर

आधार	OT Security	IT Security
मुख्य लक्ष्य	मशीनों एवं संचालन की सुरक्षा	डेटा एवं सूचना की सुरक्षा
प्राथमिकता	Safety → Availability → Integrity → Confidentiality	Confidentiality → Integrity → Availability (CIA)
प्रभाव	उत्पादन बंद, भौतिक नुकसान	डेटा चोरी, वित्तीय नुकसान
उदाहरण	SCADA System	Office Server

19. OT Security में उभरती तकनीकें (Emerging Trends)

- Industrial IoT (IIoT) Security
- AI आधारित Anomaly Detection
- Zero Trust Architecture
- Digital Twin Security
- Cloud-Connected OT Monitoring
- Predictive Maintenance Security
- IEC 62443 आधारित सुरक्षा मॉडल
- Behavior Analytics for Industrial Networks

20. OT Security के प्रमुख अंतरराष्ट्रीय मानक (Standards)

OT वातावरण की सुरक्षा के लिए कई अंतरराष्ट्रीय मानक और फ्रेमवर्क अपनाए जाते हैं—

- IEC 62443 – Industrial Automation and Control Systems Security
- NIST Cybersecurity Framework (CSF) – जोखिम-आधारित साइबर सुरक्षा ढाँचा
- NIST SP 800-82 – Industrial Control Systems (ICS) Security Guide
- ISA/IEC 62443 – औद्योगिक नियंत्रण प्रणालियों की सुरक्षा आवश्यकताएँ
- ISO/IEC 27001 – सूचना सुरक्षा प्रबंधन प्रणाली (OT संगठनों में भी सहायक)

21. निष्कर्ष (Conclusion)

OT Security आधुनिक औद्योगिक और राष्ट्रीय अवसंरचना की सुरक्षा का आधार है। बिजली उत्पादन, जल आपूर्ति, तेल एवं गैस, परिवहन, विनिर्माण (Manufacturing), स्वास्थ्य सेवाएँ तथा अन्य महत्वपूर्ण औद्योगिक प्रणालियाँ OT पर निर्भर करती हैं। इन प्रणालियों पर सफल साइबर हमला केवल डेटा हानि तक सीमित नहीं रहता, बल्कि उत्पादन रुकना, आर्थिक क्षति, पर्यावरणीय नुकसान और मानव जीवन को खतरा जैसी गंभीर स्थितियाँ उत्पन्न कर सकता है। इसलिए Network Segmentation, Industrial Firewalls, Secure Remote Access, Multi-Factor Authentication (MFA), Asset Inventory, नियमित Patch Management, Security Monitoring, Backup एवं Disaster Recovery, तथा IEC 62443 जैसे मानकों का पालन करना अत्यंत आवश्यक है। एक मजबूत OT Security Framework उद्योगों की निरंतरता, सुरक्षा, विश्वसनीयता और राष्ट्रीय महत्वपूर्ण अवसंरचना (Critical Infrastructure) की रक्षा सुनिश्चित करता है।

अध्याय – ICS Security (Industrial Control Systems Security)

उदाहरण सहित अत्यंत विस्तृत अध्ययन

1. परिचय (Introduction)

आधुनिक उद्योगों (Industries) में उत्पादन (Production), बिजली वितरण (Power Distribution), जल आपूर्ति (Water Supply), तेल एवं गैस (Oil & Gas), रेलवे, मेट्रो, रासायनिक उद्योग (Chemical Plants), परमाणु ऊर्जा संयंत्र (Nuclear Power Plants), खाद्य उद्योग तथा अन्य महत्वपूर्ण अवसंरचनाओं (Critical Infrastructure) का संचालन **Industrial Control Systems (ICS)** द्वारा किया जाता है।

Industrial Control Systems ऐसे कंप्यूटर आधारित नियंत्रण तंत्र (Control Systems) हैं जो मशीनों, सेंसरों, मोटरों, वाल्वों तथा औद्योगिक प्रक्रियाओं को **स्वचालित (Automated)** रूप से नियंत्रित करते हैं।

पहले ICS नेटवर्क पूरी तरह अलग (Air-Gapped) होते थे, लेकिन आज **Industrial Internet of Things (IIoT), Cloud Computing, Remote Monitoring, Digital Transformation** और **Enterprise IT Integration** के कारण ये नेटवर्क इंटरनेट तथा IT प्रणालियों से जुड़ गए हैं। इससे संचालन अधिक कुशल हुआ है, परंतु साइबर हमलों का जोखिम भी बढ़ गया है।

यदि कोई हमलावर ICS प्रणाली पर नियंत्रण प्राप्त कर ले, तो—

- उत्पादन रुक सकता है।
- बिजली आपूर्ति बाधित हो सकती है।
- जल शोधन संयंत्र प्रभावित हो सकता है।
- गैस पाइपलाइन में दुर्घटना हो सकती है।
- मानव जीवन खतरे में पड़ सकता है।

इसी कारण **ICS Security (Industrial Control Systems Security)** साइबर सुरक्षा का अत्यंत महत्वपूर्ण क्षेत्र है।

ICS Security वह प्रक्रिया है जिसके द्वारा औद्योगिक नियंत्रण प्रणालियों (Industrial Control Systems), उनसे जुड़े उपकरणों, नेटवर्क, नियंत्रण सॉफ्टवेयर तथा औद्योगिक प्रक्रियाओं को साइबर खतरों, अनधिकृत पहुँच, डेटा में छेड़छाड़ और संचालन संबंधी जोखिमों से सुरक्षित रखा जाता है।

2. Industrial Control System (ICS) क्या है?

Industrial Control System (ICS) कंप्यूटर, सेंसर, नियंत्रकों (Controllers), संचार नेटवर्क तथा नियंत्रण सॉफ्टवेयर का ऐसा समूह है जो औद्योगिक प्रक्रियाओं की निगरानी (Monitoring) और नियंत्रण (Control) करता है।

उदाहरण

- बिजलीघर
- तेल रिफाइनरी
- सीमेंट उद्योग
- स्टील प्लांट
- जल शोधन संयंत्र
- रेलवे सिग्नल प्रणाली
- ऑटोमोबाइल फैक्ट्री
- खाद्य प्रसंस्करण उद्योग

3. ICS Security क्या है?

ICS Security का उद्देश्य—

- औद्योगिक नियंत्रण प्रणाली की सुरक्षा
- मशीनों की सुरक्षा
- उत्पादन की निरंतरता
- कर्मचारियों की सुरक्षा
- पर्यावरण की सुरक्षा
- Critical Infrastructure की सुरक्षा

4. ICS Security की परिभाषा

ICS Security वह सुरक्षा प्रणाली (Security Framework) है जिसमें तकनीकी, प्रशासनिक और भौतिक सुरक्षा उपायों के माध्यम से Industrial Control Systems तथा उनसे जुड़े नेटवर्क और उपकरणों को साइबर हमलों एवं अनधिकृत गतिविधियों से सुरक्षित रखा जाता है।

5. ICS Security के उद्देश्य (Objectives)

(1) Safety (सुरक्षा)

मानव जीवन और मशीनों की सुरक्षा।

उदाहरण

यदि रासायनिक संयंत्र में दबाव (Pressure) नियंत्रित न रहे, तो विस्फोट हो सकता है।

(2) Availability (उपलब्धता)

ICS को 24×7 बिना रुकावट कार्य करना चाहिए।

उदाहरण

बिजली उत्पादन संयंत्र लगातार संचालित रहना चाहिए।

(3) Integrity (अखंडता)

सेंसर डेटा और नियंत्रण आदेशों में कोई छेड़छाड़ न हो।

(4) Confidentiality (गोपनीयता)

औद्योगिक प्रक्रियाओं की गोपनीय जानकारी सुरक्षित रहे।

(5) Reliability (विश्वसनीयता)

ICS हमेशा सही और अपेक्षित परिणाम दे।

6. ICS Architecture

ICS में सामान्यतः निम्न घटक होते हैं—

(1) Sensors

भौतिक मान (Physical Parameters) मापते हैं।

उदाहरण

- Temperature Sensor
 - Pressure Sensor
 - Flow Sensor
 - Level Sensor
-

(2) Actuators

नियंत्रण आदेश के अनुसार कार्य करते हैं।

उदाहरण

- Motor
 - Pump
 - Valve
 - Relay
-

(3) PLC (Programmable Logic Controller)

मशीनों को नियंत्रित करता है।

(4) RTU (Remote Terminal Unit)

दूरस्थ स्थानों से डेटा संग्रह करता है।

(5) HMI (Human Machine Interface)

ऑपरेटर मशीन की स्थिति देखता और नियंत्रित करता है।

(6) SCADA (Supervisory Control and Data Acquisition)

पूरे उद्योग की निगरानी एवं नियंत्रण करता है।

(7) Historian Server

औद्योगिक डेटा का रिकॉर्ड रखता है।

(8) Engineering Workstation

PLC Program विकसित एवं संशोधित करने हेतु।

7. ICS के प्रकार

(1) SCADA System

दूरस्थ नियंत्रण प्रणाली।

(2) DCS (Distributed Control System)

बड़े उद्योगों में वितरित नियंत्रण।

(3) PLC Based System

स्वचालित मशीन नियंत्रण।

(4) Hybrid ICS

SCADA और DCS का संयोजन।

8. ICS Security के प्रमुख घटक

(1) Asset Inventory

सभी ICS उपकरणों की सूची।

(2) Authentication

केवल अधिकृत व्यक्ति ही प्रणाली नियंत्रित करे।

(3) Access Control

उपयोगकर्ता के अधिकार निर्धारित करना।

(4) Network Segmentation

IT और ICS नेटवर्क अलग रखना।

(5) Industrial Firewall

ICS नेटवर्क की सुरक्षा।

(6) Monitoring

सभी गतिविधियों की निगरानी।

(7) Backup एवं Recovery

PLC Programs तथा Configuration का Backup।

9. ICS Security में प्रयुक्त तकनीकें

- Industrial Firewall

- Network Segmentation
 - VLAN
 - VPN
 - Multi-Factor Authentication (MFA)
 - Security Information and Event Management (SIEM)
 - Industrial IDS (IIDS)
 - Industrial IPS
 - Secure Remote Access
 - Data Diode (Unidirectional Gateway)
 - Application Whitelisting
 - Endpoint Protection
 - Patch Management
 - Asset Discovery
-

10. ICS Security के प्रमुख खतरे (Threats)

(1) Malware

ICS Server में Malware।

(2) Ransomware

उत्पादन प्रणाली को बंद कर देना।

(3) PLC Program Modification

PLC Logic बदल देना।

(4) SCADA Manipulation

SCADA Commands बदल देना।

(5) Sensor Spoofing

गलत Sensor Data भेजना।

(6) Insider Threat

कर्मचारी द्वारा नुकसान।

(7) Supply Chain Attack

Vendor Software द्वारा हमला।

(8) Remote Access Attack

VPN या Remote Desktop का दुरुपयोग।

(9) Physical Tampering

PLC या Sensor से छेड़छाड़।

(10) Zero-Day Vulnerability

नई सुरक्षा कमजोरी का दुरुपयोग।

11. ICS Security Best Practices

1. IT एवं ICS नेटवर्क अलग रखें।
2. PLC Program का Backup रखें।
3. केवल अधिकृत USB Devices का उपयोग करें।
4. Default Password बदलें।
5. Multi-Factor Authentication लागू करें।
6. नियमित Security Audit करें।
7. Asset Inventory बनाए रखें।
8. Network Monitoring करें।
9. Vendor Access नियंत्रित रखें।
10. Change Management लागू करें।
11. नियमित Patch Management करें।

12. ICS Security Policies

- Industrial Security Policy
 - PLC Change Policy
 - Remote Access Policy
 - Backup Policy
 - Vendor Access Policy
 - Patch Management Policy
 - Incident Response Policy
 - Disaster Recovery Policy
-

13. वास्तविक उदाहरण

उदाहरण 1 – जल शोधन संयंत्र

SCADA System पानी की गुणवत्ता नियंत्रित करता है।

यदि हमलावर Chemical Dosage बदल दे, तो पानी पीने योग्य नहीं रहेगा।

उदाहरण 2 – बिजलीघर

PLC Turbine Speed नियंत्रित करता है।

यदि PLC Program बदल जाए, तो Turbine क्षतिग्रस्त हो सकती है।

उदाहरण 3 – ऑटोमोबाइल उद्योग

Robotic Arm PLC द्वारा नियंत्रित होता है।

यदि PLC Logic बदल जाए, तो उत्पादन रुक सकता है।

उदाहरण 4 – तेल रिफाइनरी

Pressure Sensor गलत डेटा भेजे तो पाइपलाइन दुर्घटना हो सकती है।

14. वास्तविक साइबर घटनाएँ

(1) Stuxnet Attack (2010)

- Siemens PLC को लक्ष्य बनाया गया।
- PLC Logic बदल दिया गया।
- मशीनें सामान्य दिखाई देती थीं लेकिन गलत तरीके से कार्य कर रही थीं।
- औद्योगिक उपकरणों को भौतिक क्षति पहुँची।

सीख

- PLC Program Integrity जाँचें।
- USB Security लागू करें।
- Network Segmentation करें।

(2) Triton / Trisis Malware (2017)

- Industrial Safety Systems (SIS) को लक्ष्य बनाया गया।
- उद्देश्य सुरक्षा प्रणालियों को निष्क्रिय करना था।
- इससे स्पष्ट हुआ कि हमलावर केवल डेटा नहीं, बल्कि Safety Systems को भी निशाना बना सकते हैं।

15. ICS Security के लाभ

- उत्पादन की निरंतरता
- मशीनों की सुरक्षा
- कर्मचारियों की सुरक्षा
- पर्यावरण संरक्षण
- Critical Infrastructure की सुरक्षा
- आर्थिक नुकसान में कमी
- नियामकीय अनुपालन (Compliance)

- औद्योगिक विश्वसनीयता

16. ICS Security की चुनौतियाँ

- Legacy Systems
- पुराने Operating Systems
- Patch लागू करने में कठिनाई
- Vendor Dependency
- IT और OT का एकीकरण
- Remote Access के बढ़ते जोखिम
- IIoT Devices का बढ़ता उपयोग
- कुशल ICS Security विशेषज्ञों की कमी

17. ICS Security और OT Security में अंतर

आधार	ICS Security	OT Security
दायरा	Industrial Control Systems की सुरक्षा	संपूर्ण Operational Technology की सुरक्षा
मुख्य फोकस	PLC, SCADA, DCS, HMI, RTU	ICS + अन्य औद्योगिक उपकरण एवं प्रक्रियाएँ
उदाहरण	जल संयंत्र का SCADA	पूरे उद्योग का OT वातावरण

18. ICS Security और IT Security में अंतर

आधार	ICS Security	IT Security
मुख्य उद्देश्य	मशीनों एवं औद्योगिक प्रक्रियाओं की सुरक्षा	सूचना एवं डेटा की सुरक्षा
प्राथमिकता	Safety → Availability → Integrity → Confidentiality	Confidentiality → Integrity → Availability
प्रभाव	उत्पादन बंद, भौतिक नुकसान	डेटा चोरी, वित्तीय नुकसान
उदाहरण	PLC एवं SCADA	Email Server, Database

19. ICS Security के प्रमुख मानक (Standards)

ICS सुरक्षा के लिए निम्न अंतरराष्ट्रीय मानक व्यापक रूप से अपनाए जाते हैं—

- IEC 62443 – Industrial Automation and Control Systems Security
- NIST SP 800-82 – Guide to Industrial Control Systems (ICS) Security
- NIST Cybersecurity Framework (CSF)
- ISA/IEC 62443
- ISO/IEC 27001 (सहायक सूचना सुरक्षा प्रबंधन मानक)

20. भविष्य की प्रवृत्तियाँ (Emerging Trends)

- Industrial Internet of Things (IIoT) Security
- AI आधारित Anomaly Detection
- Zero Trust Architecture
- Digital Twin Security
- Cloud-Based ICS Monitoring
- Behavior Analytics
- Predictive Maintenance Security
- Industrial SOC (Security Operations Center)

21. निष्कर्ष (Conclusion)

ICS Security आधुनिक उद्योगों और राष्ट्रीय महत्वपूर्ण अवसंरचना (Critical Infrastructure) की सुरक्षा का आधार है। Industrial Control Systems बिजली उत्पादन, जल आपूर्ति, तेल एवं गैस, विनिर्माण, परिवहन और रासायनिक उद्योगों जैसी महत्वपूर्ण सेवाओं को नियंत्रित करते हैं। इन प्रणालियों पर साइबर हमला केवल डेटा हानि तक सीमित नहीं रहता, बल्कि उत्पादन रुकना, मशीनों को क्षति, पर्यावरणीय नुकसान और मानव जीवन के लिए गंभीर खतरा उत्पन्न कर सकता है। इसलिए Network Segmentation, Industrial Firewalls, Multi-Factor Authentication (MFA), Secure Remote Access, Application Whitelisting, Patch Management, Asset Inventory, Security Monitoring, Backup एवं Disaster Recovery तथा IEC 62443 और NIST SP 800-82 जैसे मानकों का पालन अत्यंत आवश्यक है। एक मजबूत ICS Security Framework औद्योगिक प्रणालियों की सुरक्षा, विश्वसनीयता, उपलब्धता और सुरक्षित संचालन सुनिश्चित करता है।

PART – II

Operating Systems Security (ऑपरेटिंग सिस्टम सुरक्षा)

1. परिचय (Introduction)

आज के डिजिटल युग में Operating System (OS) किसी भी कंप्यूटर, लैपटॉप, सर्वर, मोबाइल फोन, टैबलेट तथा एम्बेडेड डिवाइस (Embedded Device) का सबसे महत्वपूर्ण सॉफ्टवेयर होता है। यह हार्डवेयर (Hardware) और उपयोगकर्ता (User) के बीच एक सेतु (Bridge) का कार्य करता है तथा सभी एप्लिकेशन (Applications) और सिस्टम संसाधनों (System Resources) का प्रबंधन करता है।

यदि ऑपरेटिंग सिस्टम सुरक्षित नहीं है, तो कोई भी साइबर अपराधी (Cyber Criminal) पूरे सिस्टम पर नियंत्रण प्राप्त कर सकता है। इसके परिणामस्वरूप—

- डेटा चोरी (Data Theft)
- पासवर्ड चोरी
- बैंकिंग जानकारी की चोरी
- रैनसमवेयर (Ransomware) हमला
- सिस्टम क्रैश
- नेटवर्क पर हमला
- पहचान की चोरी (Identity Theft)
- संवेदनशील जानकारी का लीक होना

जैसी गंभीर समस्याएँ उत्पन्न हो सकती हैं।

इसी कारण Operating System Security (ऑपरेटिंग सिस्टम सुरक्षा) साइबर सुरक्षा (Cyber Security) का एक अत्यंत महत्वपूर्ण भाग है।

Operating System Security वह प्रक्रिया है जिसके द्वारा किसी ऑपरेटिंग सिस्टम तथा उसके संसाधनों (Resources), उपयोगकर्ताओं (Users), फाइलों (Files), प्रक्रियाओं (Processes), सेवाओं (Services) और नेटवर्क को अनधिकृत पहुँच (Unauthorized Access), साइबर हमलों (Cyber Attacks), वायरस, मैलवेयर तथा अन्य सुरक्षा खतरों से सुरक्षित रखा जाता है।

2. Operating System (OS) क्या है?

Operating System (OS) वह सिस्टम सॉफ्टवेयर (System Software) है जो कंप्यूटर के हार्डवेयर और उपयोगकर्ता के बीच इंटरफ़ेस (Interface) का कार्य करता है तथा सभी हार्डवेयर और सॉफ्टवेयर संसाधनों का प्रबंधन करता है।

सरल परिभाषा

Operating System वह मूल सॉफ्टवेयर है जो कंप्यूटर को चलाने, संसाधनों का प्रबंधन करने तथा उपयोगकर्ता और हार्डवेयर के बीच संचार स्थापित करने का कार्य करता है।

3. Operating System के प्रमुख उदाहरण

Desktop Operating Systems

- Microsoft Windows
- Linux
- Ubuntu
- Fedora
- Debian
- macOS

Mobile Operating Systems

- Android
- iOS

Server Operating Systems

- Windows Server
- Red Hat Enterprise Linux (RHEL)
- Ubuntu Server
- SUSE Linux Enterprise

Embedded Operating Systems

- FreeRTOS
 - VxWorks
 - QNX
-

4. Operating System Security क्या है?

Operating System Security का उद्देश्य ऑपरेटिंग सिस्टम के प्रत्येक घटक को सुरक्षित बनाना है ताकि—

- केवल अधिकृत उपयोगकर्ता ही सिस्टम का उपयोग कर सकें।
- डेटा सुरक्षित रहे।
- वायरस और मैलवेयर से सुरक्षा मिले।
- सिस्टम स्थिर (Stable) एवं विश्वसनीय (Reliable) रहे।
- साइबर हमलों से बचाव हो।

5. Operating System Security की परिभाषा

Operating System Security वह सुरक्षा ढाँचा (Security Framework) है जिसमें तकनीकी उपायों, नीतियों (Policies), प्रक्रियाओं (Procedures) और सुरक्षा नियंत्रणों (Security Controls) के माध्यम से ऑपरेटिंग सिस्टम तथा उससे जुड़े संसाधनों की सुरक्षा सुनिश्चित की जाती है।

6. Operating System Security के उद्देश्य (Objectives)

(1) Confidentiality (गोपनीयता)

सिस्टम में संग्रहीत डेटा केवल अधिकृत उपयोगकर्ता ही देख सके।

उदाहरण:

किसी विद्यालय के ERP Server में छात्रों के परिणाम केवल अधिकृत शिक्षक और प्रशासक ही देख सकें।

(2) Integrity (अखंडता)

फाइलों और सिस्टम सेटिंग्स में बिना अनुमति परिवर्तन न हो।

उदाहरण:

Windows की System Files को Malware बदल न सके।

(3) Availability (उपलब्धता)

ऑपरेटिंग सिस्टम आवश्यकता पड़ने पर हमेशा उपलब्ध रहे।

उदाहरण:

Hospital Server 24×7 चालू रहे।

(4) Authentication (प्रमाणीकरण)

उपयोगकर्ता की सही पहचान सुनिश्चित करना।

उदाहरण:

- Password
- Fingerprint
- Smart Card
- Face Recognition
- Multi-Factor Authentication (MFA)

(5) Authorization (प्राधिकरण)

प्रत्येक उपयोगकर्ता को केवल उसके कार्य के अनुसार अधिकार देना।

(6) Accountability (उत्तरदायित्व)

सिस्टम में किए गए प्रत्येक कार्य का रिकॉर्ड रखना।

7. Operating System Security क्यों आवश्यक है?

यदि ऑपरेटिंग सिस्टम सुरक्षित नहीं है, तो—

- पूरा कंप्यूटर Hack हो सकता है।
- Malware पूरे नेटवर्क में फैल सकता है।

- बैंकिंग जानकारी चोरी हो सकती है।
- सरकारी डेटा लीक हो सकता है।
- व्यवसाय ठप हो सकता है।
- रैनसमवेयर पूरा सिस्टम लॉक कर सकता है।

8. Operating System Security के प्रमुख घटक (Components)

- User Authentication
- User Accounts
- Access Control
- File System Security
- Memory Protection
- Process Security
- Device Security
- Network Security
- Patch Management
- System Logging
- Backup & Recovery
- Encryption
- Antivirus / Anti-malware
- Firewall
- Secure Boot

SHIV COMPUTER

9. Operating System Security के मुख्य सिद्धांत

(1) Least Privilege Principle

उपयोगकर्ता को केवल उतने ही अधिकार दिए जाएँ जितने आवश्यक हों।

(2) Defense in Depth

एक के ऊपर एक कई सुरक्षा परतें (Layers) लागू करना।

(3) Separation of Duties

महत्वपूर्ण कार्यों की जिम्मेदारी अलग-अलग व्यक्तियों में बाँटना।

(4) Fail Secure

यदि सिस्टम में त्रुटि हो, तो वह सुरक्षित स्थिति (Secure State) में जाए।

(5) Zero Trust

किसी भी उपयोगकर्ता या डिवाइस पर स्वतः विश्वास न करना; प्रत्येक अनुरोध का सत्यापन करना।

10. Operating System Security के प्रमुख सुरक्षा तंत्र

(1) User Authentication

- Password
- PIN
- OTP
- Fingerprint
- Smart Card
- Face Recognition
- MFA

(2) User Account Management

- Administrator Account
- Standard User Account
- Guest Account (यदि आवश्यक हो)
- Service Accounts

(3) File Permissions

फाइलों पर पढ़ने (Read), लिखने (Write) और चलाने (Execute) की अनुमति नियंत्रित करना।

(4) Access Control Models

- DAC (Discretionary Access Control)
 - MAC (Mandatory Access Control)
 - RBAC (Role-Based Access Control)
 - ABAC (Attribute-Based Access Control)
-

(5) Process Isolation

एक प्रक्रिया दूसरी प्रक्रिया की मेमोरी में हस्तक्षेप न कर सके।

(6) Memory Protection

Memory Corruption से सुरक्षा।

उदाहरण:

- DEP (Data Execution Prevention)
 - ASLR (Address Space Layout Randomization)
-

(7) Secure Boot

केवल विश्वसनीय (Trusted) Boot Loader और OS ही Boot हो।

(8) Disk Encryption

पूरे Storage को Encrypt करना।

उदाहरण:

- BitLocker (Windows)
 - LUKS (Linux)
 - FileVault (macOS)
-

(9) Firewall

अनधिकृत नेटवर्क ट्रैफिक को रोकना।

(10) Antivirus / Anti-malware

Malware, Virus, Worm, Trojan आदि का पता लगाना और हटाना।

11. Operating System Security में प्रयुक्त तकनीकें

- Secure Boot
 - Trusted Platform Module (TPM)
 - UEFI Secure Boot
 - BitLocker
 - FileVault
 - SELinux
 - AppArmor
 - Windows Defender
 - Microsoft Defender Firewall
 - Linux iptables / nftables
 - Sandboxing
 - Virtualization Security
 - Application Whitelisting
-

12. Operating System Security के प्रमुख खतरे (Threats)

- Virus
 - Worm
 - Trojan Horse
 - Ransomware
 - Spyware
 - Rootkit
 - Keylogger
 - Privilege Escalation
 - Buffer Overflow
 - DLL Hijacking
 - Bootkit
 - Insider Threat
 - Zero-Day Exploits
-

13. Operating System Security Best Practices

1. Operating System को नियमित रूप से Update करें।
2. Strong Password और MFA का उपयोग करें।
3. Administrator Account का सीमित उपयोग करें।
4. Firewall हमेशा सक्रम रखें।
5. Antivirus/Anti-malware को अपडेट रखें।
6. केवल विश्वसनीय Software ही Install करें।
7. Disk Encryption सक्रम करें।
8. नियमित Backup लें।
9. USB Devices का नियंत्रित उपयोग करें।
10. Audit Logs की नियमित समीक्षा करें।
11. Unused Services बंद रखें।
12. Security Policies लागू करें।

14. वास्तविक उदाहरण (Real-Life Examples)

उदाहरण 1 – बैंक

Bank Server में Windows Server का उपयोग किया जाता है। BitLocker द्वारा Disk Encryption, Active Directory आधारित Authentication और Firewall लागू किए जाते हैं।

उदाहरण 2 – विश्वविद्यालय

Linux Server पर छात्रों के परिणाम सुरक्षित रखे जाते हैं। केवल अधिकृत उपयोगकर्ताओं को Role-Based Access Control (RBAC) के माध्यम से पहुँच दी जाती है।

उदाहरण 3 – अस्पताल

Hospital Server में नियमित Backup, Antivirus, Disk Encryption और Audit Logging लागू होती है ताकि मरीजों का डेटा सुरक्षित रहे।

उदाहरण 4 – व्यक्तिगत कंप्यूटर

एक उपयोगकर्ता अपने Windows 11 कंप्यूटर में—

- Microsoft Defender
- BitLocker
- Windows Firewall
- TPM 2.0
- Secure Boot
- Fingerprint Login

का उपयोग करता है, जिससे उसका सिस्टम Malware और अनधिकृत पहुँच से सुरक्षित रहता है।

15. Operating System Security के लाभ

- डेटा की सुरक्षा
 - उपयोगकर्ता प्रमाणीकरण
 - सिस्टम की विश्वसनीयता
 - Malware से सुरक्षा
 - सुरक्षित नेटवर्क कनेक्शन
 - कानूनी अनुपालन (Compliance)
 - व्यवसाय की निरंतरता
 - Cyber Attack का जोखिम कम होना
-

16. Operating System Security की चुनौतियाँ

- Zero-Day Vulnerabilities
 - Legacy Operating Systems
 - Malware का तेजी से विकास
 - Patch Management
 - Insider Threat
 - Social Engineering
 - Misconfiguration
 - Third-Party Software Vulnerabilities
-

17. Operating System Security और Application Security में अंतर

आधार	Operating System Security	Application Security
सुरक्षा का केंद्र	Operating System	Software / Web / Mobile Applications
मुख्य उद्देश्य	OS और System Resources की सुरक्षा	एप्लिकेशन की सुरक्षा
उदाहरण	Windows 11 Security	Internet Banking Application

18. Operating System Security और Network Security में अंतर

आधार	Operating System Security	Network Security
सुरक्षा का केंद्र	कंप्यूटर का OS	नेटवर्क और संचार
मुख्य उद्देश्य	सिस्टम संसाधनों की सुरक्षा	नेटवर्क ट्रैफिक और उपकरणों की सुरक्षा
उदाहरण	BitLocker, Secure Boot	Firewall, IDS, IPS, VPN

19. आधुनिक प्रवृत्तियाँ (Emerging Trends)

- AI आधारित Threat Detection
- Zero Trust Operating Systems
- Hardware-Assisted Security
- Virtualization-Based Security (VBS)
- Confidential Computing
- Secure Containers
- Cloud-Integrated OS Security
- Endpoint Detection and Response (EDR)

20. निष्कर्ष (Conclusion)

Operating System Security किसी भी कंप्यूटर प्रणाली की सुरक्षा का आधार (Foundation) है। ऑपरेटिंग सिस्टम ही हार्डवेयर, एप्लिकेशन और उपयोगकर्ता के बीच समन्वय स्थापित करता है, इसलिए इसकी सुरक्षा अत्यंत आवश्यक है। Authentication, Authorization, Access Control, Disk Encryption, Secure Boot, Firewall, Antivirus, नियमित Updates, Patch Management तथा Backup & Recovery जैसे सुरक्षा उपाय ऑपरेटिंग सिस्टम को साइबर हमलों, मैलवेयर, डेटा चोरी और अनधिकृत पहुँच से सुरक्षित रखते हैं। एक मजबूत Operating System Security Framework न केवल डेटा और सिस्टम संसाधनों की रक्षा करता है, बल्कि संपूर्ण आईटी अवसंरचना (IT Infrastructure) की विश्वसनीयता, उपलब्धता और सुरक्षित

संचालन भी सुनिश्चित करता है। बिल्कुल। Registry Analysis को केवल परिभाषा के रूप में नहीं, बल्कि PhD स्तर पर वास्तविक उदाहरणों (Real-world Examples), Digital Forensic Investigation, Malware Analysis, Cyber Crime Investigation, तथा Windows Internal Architecture के साथ समझना आवश्यक है। नीचे इसका विस्तृत विवरण प्रस्तुत है।

अध्याय : Registry Analysis (Windows Registry Analysis)

भाग – 1 : परिचय एवं मूल अवधारणा (Introduction and Basic Concepts)

1. Windows Registry क्या है?

Windows Registry, Microsoft Windows Operating System का Central Hierarchical Database है, जिसमें कंप्यूटर की लगभग सभी महत्वपूर्ण सेटिंग्स, हार्डवेयर कॉन्फिगरेशन, सॉफ्टवेयर जानकारी, उपयोगकर्ता (User) की Preferences तथा सुरक्षा (Security) से संबंधित डेटा संग्रहीत रहता है।

यदि हम किसी कंप्यूटर की तुलना मानव शरीर से करें, तो:

- CPU = मस्तिष्क
- RAM = अल्पकालिक स्मृति
- Hard Disk/SSD = दीर्घकालिक स्मृति
- Windows Registry = मस्तिष्क की वह स्मृति जिसमें सभी नियम, आदतें और निर्देश सुरक्षित रहते हैं।

अर्थात, Registry वह स्थान है जहाँ Windows यह "याद" रखता है कि सिस्टम को कैसे चलना है।

वास्तविक उदाहरण (Example 1 - Wallpaper)

मान लीजिए आपने अपने कंप्यूटर का Wallpaper बदलकर अपनी फोटो लगा दी।

जब आप कंप्यूटर Restart करते हैं, तब भी वही Wallpaper दिखाई देता है।

प्रश्न: Windows को यह कैसे पता चला कि कौन-सा Wallpaper दिखाना है?

उत्तर:

क्योंकि उसका Path Registry में सुरक्षित है।

उदाहरण:

HKEY_CURRENT_USER

- └─ Control Panel
- └─ Desktop
- └─ Wallpaper

मान:

Wallpaper

C:\Users\Shiv\Pictures\Nature.jpg

अब Windows Boot होने पर Registry पढ़ता है और उसी फ़ाइल को Wallpaper बना देता है।

Example 2 – Printer

मान लीजिए आपने HP LaserJet M1005 Printer Install किया।

Registry में निम्न जानकारी संग्रहीत होगी—

- Printer Name
- Driver Version
- Port
- USB Connection
- Default Printer
- Driver Path

यदि Printer Driver खराब हो जाए तो Registry की गलत Entries के कारण Windows Printer को पहचान नहीं पाता।

Example 3 – WiFi Password

जब आप पहली बार WiFi से Connect होते हैं—

SSID : HomeWiFi

Password : abc@12345

Restart के बाद Password दोबारा नहीं पूछता।

क्योंकि Registry में WiFi Profile सुरक्षित रहता है।

2. Registry क्यों बनाई गई?

Windows 3.1 तक Configuration अलग-अलग INI Files में रखी जाती थी।

उदाहरण

system.ini

win.ini

config.sys

autoexec.bat

समस्या

यदि 100 Programs हों

तो 100 अलग-अलग Configuration Files

इससे

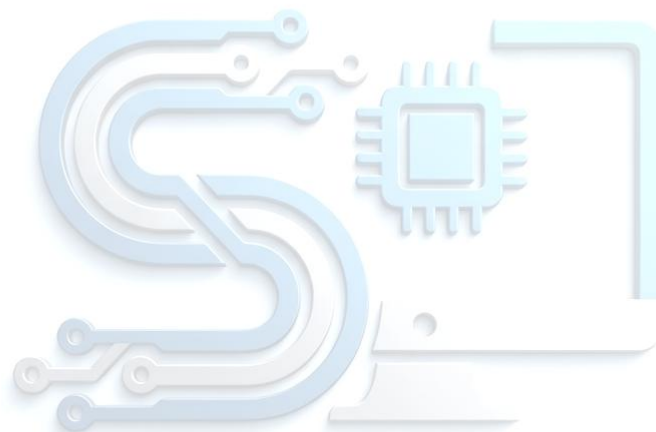
- Performance कम
- Searching कठिन
- Backup कठिन
- Security कमजोर

इसलिए Microsoft ने Registry Database बनाया।

Registry की तुलना Database से

यदि कोई बैंक Database रखता है

Customer



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

417

Account



Balance



Loan



ATM

ठीक उसी प्रकार Windows Registry भी एक Database है।

Registry



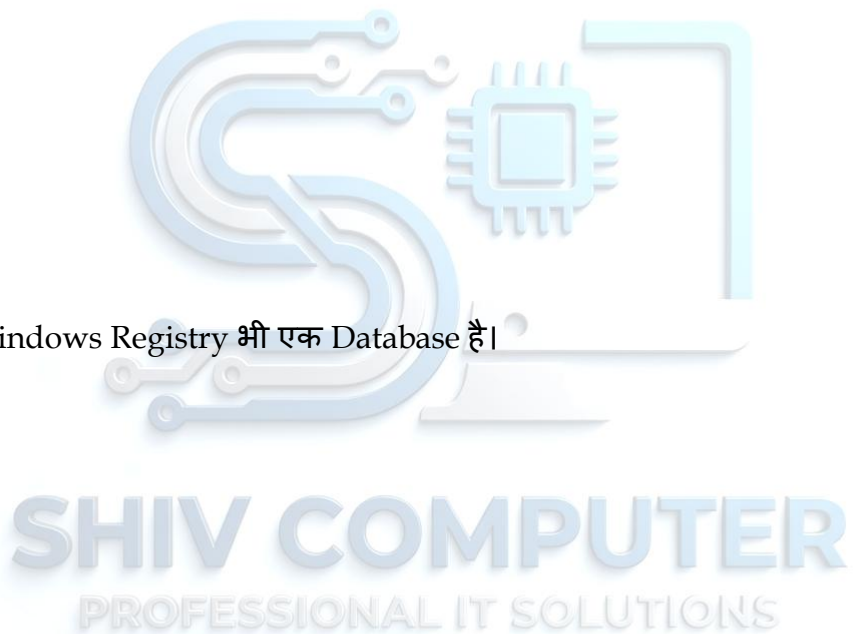
Software



Windows



Explorer



Settings

Registry की संरचना (Hierarchy)

Registry एक Tree की तरह होती है।

Registry

|

— Root Key

| |

| — Sub Key

| | |

| | — Sub Key

| | | |

| | | — Values



यह बिल्कुल Hard Disk के Folder Structure जैसा है।

Example

मान लीजिए Folder है

D:\College

वैसे ही Registry

HKCU

Software

Microsoft

Windows

CurrentVersion

Explorer



Registry के मुख्य भाग (Root Keys)

Windows Registry में पाँच प्रमुख Root Keys होती हैं।

1. HKEY_LOCAL_MACHINE (HKLM)

यह पूरे Computer की Settings रखती है।

इसमें मिलता है—

- Processor
- RAM
- BIOS
- Drivers
- Installed Software

- Network
- Security

उदाहरण

यदि Computer में 16GB RAM है

तो Registry में इसकी जानकारी उपलब्ध रहती है।

2. HKEY_CURRENT_USER (HKCU)

Current User की व्यक्तिगत Settings।

उदाहरण

यदि दो User हैं—

Administrator

Shiv

दोनों का Wallpaper अलग हो सकता है।

क्यों?

HKCU अलग-अलग User के लिए अलग Registry Data रखता है।

3. HKEY_USERS

सभी Users की Registry।

4. HKEY_CLASSES_ROOT

यह बताता है

.pdf

.docx

.jpg



किस Software से खुलेंगे।

Example

यदि आप PDF पर Double Click करते हैं

Registry देखती है

.pdf



Adobe Acrobat

और Acrobat खोल देती है।

5. HKEY_CURRENT_CONFIG

Current Hardware Profile

यदि Laptop Docking Station से जुड़ा है

तो उसकी Settings यहाँ रहती हैं।

Registry के अंदर Value कैसे होती है?

मान लीजिए

Desktop



Wallpaper

Registry में

Wallpaper

REG_SZ

C:\Users\Shiv\Picture.jpg

यहाँ

Wallpaper = Name

REG_SZ = Type

Picture Path = Data

Registry Value Types**REG_SZ**

साधारण Text

उदाहरण

User Name

Shiv Kumar

REG_DWORD

संख्या

उदाहरण

Screen Timeout

300

REG_BINARY

Binary Data

Driver Information

REG_MULTI_SZ

एक से अधिक Text



Printer1

Printer2

Printer3

Digital Forensics में Registry क्यों महत्वपूर्ण है?

कल्पना कीजिए

एक Cyber Criminal ने

- Pendrive लगाया
- Malware चलाया
- Password चुराया
- Browser History Delete कर दी

उसे लगता है कि सबूत मिट गए।

लेकिन Registry में अभी भी कई महत्वपूर्ण Artifacts मौजूद हो सकते हैं।

जैसे—

- USB Device का Serial Number
- Program Execution History
- Last Login User
- Recently Opened Files
- Network Shares
- AutoRun Entries
- Installed Malware का रिकॉर्ड

यही कारण है कि Registry Analysis Digital Forensics की सबसे महत्वपूर्ण तकनीकों में से एक मानी जाती है।

वास्तविक केस अध्ययन (Case Study)

मामला: परीक्षा प्रश्नपत्र की चोरी

एक विश्वविद्यालय के कंप्यूटर से प्रश्नपत्र लीक हो गया।

संदिग्ध कर्मचारी ने दावा किया:

"मैंने कभी Pendrive नहीं लगाई।"

Forensic Investigator ने Registry का विश्लेषण किया।

Registry Key:

HKLM\SYSTEM\CurrentControlSet\Enum\USBSTOR

यहाँ निम्न जानकारी मिली:

- Vendor: SanDisk
- Product: Cruzer Blade
- Serial Number: 4C530001230
- First Connected: 10:15 AM
- Last Connected: 10:48 AM

इसके बाद CCTV फुटेज और Access Logs का मिलान किया गया।

निष्कर्ष:

- ठीक उसी समय कर्मचारी सिस्टम पर लॉगिन था।
- वही Serial Number वाली Pendrive उसके पास से बरामद हुई।
- Registry ने डिजिटल साक्ष्य (Digital Evidence) प्रदान किया, जिसे अन्य साक्ष्यों के साथ जोड़कर अपराध सिद्ध किया गया।

यह भाग-1 Registry Analysis की आधारभूत अवधारणाओं का विस्तृत अध्ययन था।

भाग-2 में हम Registry Hive Files, NTUSER.DAT, SYSTEM, SOFTWARE, SAM, SECURITY, DEFAULT, LastWrite Time, UserAssist, ShellBags, RecentDocs, OpenSaveMRU, TypedURLs, Run Keys, USBSTOR, ShimCache, Amcache, BAM/DAM, तथा Registry Forensic Artifacts को प्रत्येक Registry Key के वास्तविक उदाहरण, स्क्रीन-जैसी संरचना, और Forensic Investigation Case Studies के साथ PhD स्तर पर विस्तार से समझेंगे।

अध्याय : Registry Analysis

भाग-2 : Registry Hive Files एवं Forensic Artifacts

उदाहरण सहित विस्तृत अध्ययन

भाग-1 में हमने Registry की मूल अवधारणा, संरचना तथा Root Keys को समझा। अब भाग-2 में हम Registry की वास्तविक फ़ाइलों (Hive Files), उनके कार्य, तथा Digital Forensics में उनके महत्व का गहन अध्ययन करेंगे।

1. Registry Hive क्या होती है?

Windows Registry वास्तव में एक ही फ़ाइल नहीं होती। यह कई अलग-अलग Binary Database Files से मिलकर बनी होती है, जिन्हें Registry Hive कहा जाता है।

Hive का अर्थ है—Registry का एक स्वतंत्र भाग, जो किसी विशेष प्रकार की जानकारी संग्रहीत करता है।

इसे समझने के लिए एक पुस्तकालय (Library) का उदाहरण लें।

- पुस्तकालय = Windows Registry
- विभिन्न अलमारियाँ = Registry Hives
- प्रत्येक अलमारी में अलग विषय की पुस्तकें = अलग-अलग प्रकार की सिस्टम जानकारी

उदाहरण:

Hive	इसमें क्या संग्रहीत रहता है?
SYSTEM	हार्डवेयर, ड्राइवर, Services
SOFTWARE	Installed Software, Windows Settings
SAM	User Accounts
SECURITY	Security Policies
DEFAULT	Default User Profile

2. Registry Hive कहाँ स्थित होती हैं?

मुख्य Registry Hive निम्न स्थान पर होती हैं—

C:\Windows\System32\Config\

इस फ़ोल्डर में सामान्यतः निम्न फ़ाइलें मिलती हैं—

SYSTEM
SOFTWARE
SAM
SECURITY
DEFAULT
COMPONENTS
BCD

ये सभी Binary Files होती हैं।

उदाहरण

यदि Investigator हार्ड डिस्क की Forensic Image खोलता है तो उसे यह फ़ोल्डर मिलेगा—

```
Windows
├── System32
│   └── Config
│       ├── SYSTEM
│       ├── SOFTWARE
│       ├── SAM
│       ├── SECURITY
│       └── DEFAULT
```

यही Windows Registry का वास्तविक Database है।

3. User Registry कहाँ रहती है?

प्रत्येक User की व्यक्तिगत Registry अलग होती है।

उदाहरण:

C:\Users\Shiv\NTUSER.DAT

यदि Computer में तीन User हैं—

Administrator

Shiv

Student

तो प्रत्येक User की अलग NTUSER.DAT फ़ाइल होगी।

वास्तविक उदाहरण

यदि Shiv का Wallpaper बदला गया है

तो उसकी Entry

C:\Users\Shiv\NTUSER.DAT

में मिलेगी।

लेकिन

Student User का Wallpaper अलग होगा।

4. NTUSER.DAT क्या है?

यह सबसे महत्वपूर्ण User Hive है।

इसमें User की लगभग सभी Personal Settings होती हैं।

जैसे—

- Desktop
 - Wallpaper
 - Browser
 - Recent Files
 - Explorer History
 - Network Drives
 - USB History (User Context)
 - Run Commands
-

वास्तविक उदाहरण

मान लीजिए

User ने Word खोला

फिर

Excel खोला

फिर

Chrome खोला

इनकी जानकारी NTUSER.DAT में विभिन्न Registry Keys के माध्यम से सुरक्षित हो सकती है।

Digital Forensics में NTUSER.DAT का महत्व

यदि किसी User ने Browser History Delete कर दी

तब भी

NTUSER.DAT से पता चल सकता है—

- कौन-सा Program चला
- कौन-सी File Open हुई
- कौन-सा Folder Access किया गया

इसी कारण यह Forensic Investigation में अत्यंत महत्वपूर्ण साक्ष्य (Evidence) है।

5. SYSTEM Hive

SYSTEM Hive में Computer की Hardware Configuration रहती है।

इसमें मिलता है—

- Drivers
- Services
- Boot Information

- Time Zone
- USB Devices
- Mounted Devices
- Control Sets

वास्तविक उदाहरण

Computer में नया Printer लगाया गया।

Registry में इसकी जानकारी SYSTEM Hive में आ जाएगी।

SYSTEM Hive का स्थान

C:\Windows\System32\Config\SYSTEM

Forensic उदाहरण

यदि Malware किसी Driver के रूप में Install हुआ है

तो Investigator SYSTEM Hive में Driver Entry खोजता है।

6. SOFTWARE Hive

इसमें Installed Software की जानकारी रहती है।

उदाहरण

- Adobe Acrobat
- Chrome
- VLC
- Microsoft Office

Registry Path

HKLM

वास्तविक उदाहरण

यदि किसी आरोपी ने File Recovery Software Install किया था

तो उसकी जानकारी SOFTWARE Hive में मिल सकती है।

7. SAM Hive

SAM का अर्थ है

Security Account Manager

इसमें Computer के Local User Accounts रहते हैं।

उदाहरण

Administrator

Guest

Shiv

Student

इसमें

- User SID
- Password Hash
- Login Information

संग्रहीत रहती है।

Forensic महत्व

यदि Password ज्ञात नहीं है

तो Investigator

SAM Hive तथा SYSTEM Hive की सहायता से Offline Password Hash Analysis कर सकता है।

8. SECURITY Hive

इसमें Local Security Policy रहती है।

उदाहरण

- Audit Policy
- User Rights
- Security Descriptors
- LSA Secrets

वास्तविक उदाहरण

यदि Computer Domain में जुड़ा था

तो कई Security Settings यहाँ मिल सकती हैं।

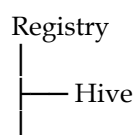
9. DEFAULT Hive

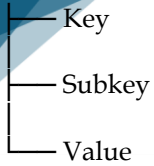
यह Default User की Registry होती है।

जब नया User बनाता है

तो प्रारम्भिक Settings यहीं से ली जाती हैं।

10. Registry का Hierarchy Model





उदाहरण

HKCU

Software

Microsoft

Windows

CurrentVersion

Explorer

RecentDocs

यहाँ

HKCU = Hive

Software = Key

Microsoft = Subkey

RecentDocs = Value Container



11. Registry Key क्या होती है?

Folder जैसी Structure

उदाहरण

Software

12. Registry Value क्या होती है?

File जैसी होती है।

उदाहरण

Wallpaper

REG_SZ

C:\Photo.jpg

13. Registry Last Write Time

हर Registry Key का अपना Time Stamp होता है।

यह बताता है—

आखिरी बार Registry Key कब बदली गई।

वास्तविक उदाहरण

Last Write Time

22 July 2026

10:25:31

यदि Malware 10:25 पर Install हुआ

तो Run Key का Last Write Time भी लगभग वही होगा।

14. Control Sets

SYSTEM Hive में कई Control Sets होती हैं।

CurrentControlSet

ControlSet001

ControlSet002

Windows Boot होने पर CurrentControlSet सक्रिय रहती है।

उदाहरण

यदि किसी Driver की समस्या हो

तो Investigator पुराने Control Set की तुलना कर सकता है।

15. MountedDevices

Registry Key

HKLM\SYSTEM\MountedDevices

इसमें Drive Letters का Mapping रहता है।

उदाहरण

यदि Pendrive

पहली बार लगी

तो

E:

फिर दूसरी बार

F:

यह जानकारी Registry में मिल सकती है।

16. USBSTOR

Registry Path

HKLM\SYSTEM\CurrentControlSet\Enum\USBSTOR

यह बताती है—

- USB Vendor
 - Model
 - Serial Number
 - Device Type
-

वास्तविक उदाहरण

SanDisk

Cruzer Blade

16 GB

Serial

4C530001230

यदि अपराधी Pendrive हटा भी दे

तब भी Registry में उसका रिकॉर्ड रह सकता है।

17. CurrentControlSet

यह वर्तमान में उपयोग हो रही Hardware Configuration को दर्शाती है।

इसमें—

- Services
- Drivers
- USB
- Control Manager

की जानकारी होती है।

18. Case Study - चोरी हुआ डेटा

एक कंपनी से गोपनीय डेटा लीक हो गया।

आरोपी ने कहा—

"मैंने USB कभी नहीं लगाई।"

Investigator ने Registry की USBSTOR Key की जाँच की।

उसे मिला—

Vendor : Kingston

Product : DataTraveler

Serial : 60A44C2212

Last Write Time :

21 July 2026

09:40 AM

इसके बाद CCTV फुटेज देखी गई।

उसी समय आरोपी अपने सिस्टम पर उपस्थित था।

Network Logs में भी उसी समय बड़ी मात्रा में डेटा कॉपी होने के संकेत मिले।

USB डिवाइस जब्त की गई और उसका Serial Number Registry में मिले Serial Number से मेल खा गया।

निष्कर्ष: Registry ने महत्वपूर्ण डिजिटल साक्ष्य उपलब्ध कराया, जिसने अन्य साक्ष्यों (CCTV, Network Logs, File Copy Events) के साथ मिलकर घटना का पुनर्निर्माण (Event Reconstruction) संभव बनाया।

19. इस भाग का सार

इस भाग में हमने सीखा—

- Registry Hive क्या है।
- SYSTEM, SOFTWARE, SAM, SECURITY, DEFAULT तथा NTUSER.DAT की भूमिका।
- Registry Hierarchy (Hive → Key → Subkey → Value)।
- Last Write Time का महत्व।
- USBSTOR और MountedDevices जैसी महत्वपूर्ण Forensic Keys।
- वास्तविक Cyber Crime Investigation में Registry का उपयोग कैसे किया जाता है।

अगले भाग (भाग-3) में

हम Registry Forensic Artifacts का अत्यंत विस्तृत अध्ययन करेंगे, जिनमें शामिल होंगे—

- UserAssist
- RecentDocs
- OpenSaveMRU
- RunMRU
- TypedURLs
- ShellBags
- MUICache
- BAM/DAM
- Run एवं RunOnce Keys
- Amcache
- ShimCache (AppCompatCache)

इन सभी Registry Artifacts को वास्तविक Registry Paths, Hex/Data संरचना, Forensic Tools (RegRipper, Registry Explorer, RECcmd आदि), तथा वास्तविक साइबर अपराध जाँच (Case Studies) के साथ PhD स्तर पर विस्तार से समझाया जाएगा।

अध्याय : Windows Registry Analysis (PhD Level)

भाग-3 : Registry Forensic Artifacts (उदाहरण सहित अत्यंत विस्तृत अध्ययन)

Digital Forensics में केवल Registry पढ़ना पर्याप्त नहीं होता। असली जांच Registry Artifacts की होती है।

Registry Artifact वह डिजिटल साक्ष्य (Digital Evidence) है जो किसी User, Program, USB, Browser या Malware की गतिविधियों का रिकॉर्ड Registry में छोड़ जाता है।

1. Registry Artifact क्या होता है?

जब कोई User कंप्यूटर पर कोई कार्य करता है, तो Windows उसके बारे में Registry में कुछ जानकारी सुरक्षित कर देता है। यही जानकारी Registry Artifact कहलाती है।

उदाहरण

मान लीजिए User ने निम्न कार्य किए—

- Chrome खोला
- Word में Resume.docx खोला

- Pendrive लगाई
- CMD चलाया
- Calculator खोला

इन सभी कार्यों के अलग-अलग निशान Registry में मिल सकते हैं।

इसे ऐसे समझें—

जैसे कोई व्यक्ति गीली मिट्टी पर चलता है तो उसके पैरों के निशान रह जाते हैं, उसी प्रकार Windows में की गई गतिविधियों के "डिजिटल पदचिह्न" Registry Artifacts होते हैं।

Registry Artifact Flow

User Activity



Windows API



Registry Update



Registry Artifact



Digital Forensic Evidence



2. UserAssist

परिचय

UserAssist Windows Registry का सबसे महत्वपूर्ण Forensic Artifact माना जाता है।

यह बताता है—

- कौन-कौन से Programs Run हुए

- कितनी बार Run हुए
- कब Run हुए (अन्य Artifacts के साथ Correlation करके)
- GUI से Launch हुए या नहीं

Registry Path

HKCU\

Software\

Microsoft\

Windows\

CurrentVersion\

Explorer\

UserAssist

यह कैसे कार्य करता है?

मान लीजिए User ने

- Chrome
- Paint
- Notepad
- Calculator

खोले।

Windows इन Programs की जानकारी UserAssist में दर्ज कर सकता है।

वास्तविक उदाहरण

मान लीजिए User ने 25 बार Calculator खोला।

Registry में (Decoded रूप में) यह जानकारी मिल सकती है—

Program Run Count

Calculator 25

Program Run Count

Chrome 102

Paint 8

Word 54

महत्वपूर्ण तथ्य

UserAssist में Program Name सामान्य Text में नहीं होता।

यह ROT-13 Encoding में Stored होता है।

उदाहरण

P:\Jvaqbjf\Flfgrz32\pnyp.rkr

ROT-13 Decode करने पर

C:\Windows\System32\calc.exe

Forensic महत्व

यदि Browser History Delete कर दी गई हो

फिर भी UserAssist यह संकेत दे सकता है कि Chrome चला था।

Case Study - UserAssist

एक कर्मचारी ने कहा—

"मैंने Excel कभी नहीं खोला।"

Investigator ने UserAssist देखा।

मिला—

EXCEL.EXE

Run Count : 47

निष्कर्ष—

User ने Excel कई बार चलाया था।

3. RecentDocs

परिचय

यह Registry Key उन Files का रिकॉर्ड रखती है जिन्हें हाल ही में Open किया गया।

Registry Path

HKCU\
Software\
Microsoft\
Windows\
CurrentVersion\
Explorer\
RecentDocs

उदाहरण

मान लीजिए User ने खोला—

- Thesis.docx
- Salary.xlsx
- Secret.pdf

Registry में इनके संदर्भ मिल सकते हैं।

संभावित सूची

File

Thesis.docx

Salary.xlsx

Secret.pdf

Forensic उपयोग

यदि User कहे—

"मैंने Secret.pdf कभी नहीं खोली।"

लेकिन RecentDocs में उसका रिकॉर्ड मिले—

तो यह महत्वपूर्ण डिजिटल संकेत है।

ध्यान दें: केवल RecentDocs से यह सिद्ध नहीं होता कि User ने फ़ाइल की सामग्री पढ़ी; यह केवल Open Activity का संकेत देता है। अंतिम निष्कर्ष अन्य साक्ष्यों के साथ मिलाकर निकाला जाता है।

4. OpenSaveMRU

MRU क्या है?

MRU = Most Recently Used

यह बताता है—

किन Files को Open अथवा Save किया गया।

Registry Path

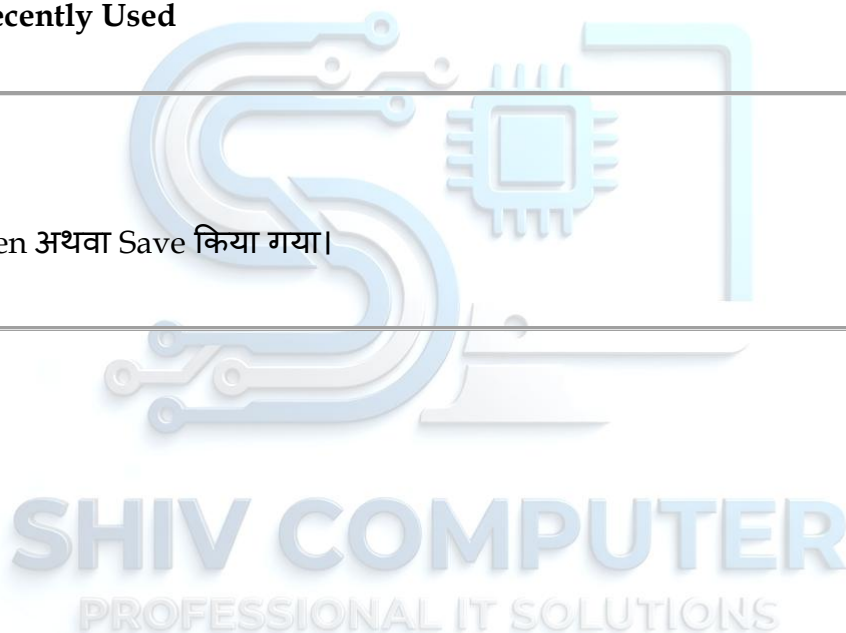
HKCU\
Software\
Microsoft\
Windows\
CurrentVersion\
Explorer\
ComDlg32\
OpenSaveMRU

उदाहरण

User ने Word में

Research.docx

Open किया।



फिर

Cyber.pdf

Save किया।

इनका रिकॉर्ड OpenSaveMRU में मिल सकता है।

Case Study

एक आरोपी ने दावा किया—

"मैंने Confidential.docx नहीं खोला।"

लेकिन Registry में मिला—

OpenSaveMRU

Confidential.docx

इसके साथ File System Metadata तथा Shortcut (.lnk) Artifacts भी मिले।

यह संयुक्त साक्ष्य जांच को मजबूत बनाते हैं।

5. RunMRU

परिचय

जब User Windows के Run Dialog (Win + R) का उपयोग करता है

तो उसकी History यहाँ रहती है।

Registry Path

HKCU\

Software\

Microsoft\

Windows\

CurrentVersion\

Explorer\

RunMRU

उदाहरण

User ने चलाया—

cmd

powershell

regedit

msconfig

notepad

Registry में इनके रिकॉर्ड मिल सकते हैं।

Forensic महत्व

यदि किसी User ने

powershell

Run किया

तो यह Incident Response में महत्वपूर्ण संकेत हो सकता है, विशेषकर यदि अन्य PowerShell Logs भी उपलब्ध हों।

6. TypedURLs

परिचय

Internet Explorer में Address Bar में जो URLs Type किए जाते थे

उनका रिकॉर्ड यहाँ मिलता था।

Registry Path

HKCU\

Software\

Microsoft\

Internet Explorer\

TypedURLs

उदाहरण

https://example.com

https://mail.example.org

https://research.example.edu

Forensic उपयोग

यह पुराने Internet Explorer आधारित मामलों में उपयोगी हो सकता है।

आधुनिक Browser (Chrome, Edge, Firefox) अपने अलग Databases और Artifacts का उपयोग करते हैं।

7. TypedPaths

जब User Explorer Address Bar में

D:\Secret

E:\Backup

\\Server\Data

जैसे Paths लिखता है

तो उनकी जानकारी यहाँ मिल सकती है।

Registry Path

HKCU\

Software\

Microsoft\
Windows\
CurrentVersion\
Explorer\
TypedPaths

8. LastVisitedPidlMRU

यह Registry Key Explorer द्वारा हाल ही में उपयोग किए गए Folder Paths का रिकॉर्ड रखने में सहायता करती है।

उदाहरण

D:\Research

E:\Forensics

F:\Evidence

9. Case Study – Data Theft Investigation

एक कर्मचारी ने दावा किया—

"मैंने कंपनी का Secret Folder कभी नहीं खोला।"

Forensic Analysis में पाया गया—

- TypedPaths में:
- D:\Company\Secret
- OpenSaveMRU में:
- Budget2026.xlsx
- RecentDocs में:
- Budget2026.xlsx
- UserAssist में:

- EXCEL.EXE

इन सभी Artifacts को File Access Logs, Event Logs तथा USB Analysis के साथ मिलाकर एक मजबूत Event Timeline तैयार की गई।

10. Registry Artifact Correlation

किसी एक Artifact पर निर्भर रहना उचित नहीं है।

एक पेशेवर Digital Forensic Investigator कई Artifacts को जोड़कर निष्कर्ष निकालता है।

Artifact	क्या बताता है?
UserAssist	कौन-सा Program चला
RecentDocs	हाल में खोली गई Files
OpenSaveMRU	Open/Save Dialog History
RunMRU	Win+R Commands
TypedPaths	Explorer में टाइप किए गए Paths
USBSTOR	USB Device History
MountedDevices	Drive Letter Mapping
Event Logs	System Events
Prefetch	Program Execution संकेत
Amcache	Executable संबंधी जानकारी

PhD स्तर की जांच में दृष्टिकोण

उच्च स्तरीय Digital Forensics में उद्देश्य केवल यह देखना नहीं होता कि कोई Registry Key मौजूद है या नहीं, बल्कि यह समझना होता है कि:

1. कौन-से Artifacts एक-दूसरे की पुष्टि (Corroborate) करते हैं।
2. कौन-से Artifacts समयरेखा (Timeline) बनाने में सहायता करते हैं।
3. कौन-से Artifacts Malware, Insider Threat या Data Exfiltration जैसी घटनाओं से जुड़े हैं।

4. क्या Registry, File System, Event Logs, Memory तथा Network Evidence एक-दूसरे के अनुरूप हैं।

इस प्रकार Registry Artifacts किसी भी साइबर अपराध की वैज्ञानिक जाँच में अत्यंत महत्वपूर्ण भूमिका निभाते हैं।

भाग-4 में हम अत्यंत उन्नत Registry Artifacts का अध्ययन करेंगे, जिनमें शामिल होंगे—

- ShellBags Analysis
- MUICache Analysis
- BAM (Background Activity Moderator)
- DAM (Desktop Activity Moderator)
- Run एवं RunOnce Keys
- Startup Persistence
- StartupApproved Keys
- Winlogon Registry Analysis
- Services Registry Analysis
- Malware Persistence Techniques
- वास्तविक Ransomware एवं APT केस स्टडी के साथ Registry Forensics (शैक्षिक दृष्टिकोण से)

यह भाग Digital Forensics, Incident Response और Malware Analysis के लिए सबसे महत्वपूर्ण अध्यायों में से एक माना जाता है।

अध्याय : Active Directory (AD)

भाग-1 :

1. Active Directory (AD) क्या है?

Active Directory (AD) Microsoft द्वारा विकसित एक **Directory Service** है, जिसका उपयोग किसी संगठन (Organization) के सभी **Users, Computers, Servers, Printers, Groups, Policies** तथा **अन्य Network Resources** का केंद्रीकृत (Centralized) प्रबंधन करने के लिए किया जाता है।

इसे पहली बार **Windows Server 2000** में प्रस्तुत किया गया था और आज यह **Enterprise Networks** की आधारभूत तकनीकों में से एक है।

सरल परिभाषा:

Active Directory एक केंद्रीकृत पहचान एवं संसाधन प्रबंधन प्रणाली (Centralized Identity and Resource Management System) है, जो नेटवर्क में उपस्थित सभी उपयोगकर्ताओं और संसाधनों का प्रमाणीकरण (Authentication), प्राधिकरण (Authorization) तथा प्रशासन (Administration) करती है।

2. वास्तविक जीवन का उदाहरण

मान लीजिए एक विश्वविद्यालय है, जिसमें—

- 15,000 विद्यार्थी
- 1,200 शिक्षक
- 350 कर्मचारी
- 800 कंप्यूटर
- 150 प्रिंटर
- 80 सर्वर

यदि प्रत्येक कंप्यूटर पर अलग-अलग User Account बनाए जाएँ, तो प्रबंधन अत्यंत कठिन होगा।

बिना Active Directory

- प्रत्येक कंप्यूटर पर अलग User Account

- अलग Password
- अलग Permissions
- प्रत्येक सिस्टम पर अलग Login

यदि किसी विद्यार्थी का Password बदलना हो, तो कई कंप्यूटरों पर परिवर्तन करना पड़ेगा।

Active Directory के साथ

सभी User Accounts एक Server पर सुरक्षित रहते हैं।

जब विद्यार्थी किसी भी Computer पर Login करता है—

1. Computer Domain Controller से संपर्क करता है।
2. Username और Password सत्यापित होते हैं।
3. User की Permissions प्राप्त होती हैं।
4. Login सफल हो जाता है।

इस प्रकार User किसी भी Domain Computer पर अपना Account उपयोग कर सकता है।

3. Active Directory की आवश्यकता क्यों पड़ी?

Windows Workgroup Model छोटे नेटवर्क के लिए उपयुक्त था।

लेकिन जब Network बड़ा हुआ—

- हजारों Users
- हजारों Computers
- अनेक Departments
- अनेक Branch Offices

तब Workgroup मॉडल असफल होने लगा।

समस्याएँ

- User Management कठिन
- Password Policy लागू करना कठिन
- Security कमजोर
- Software Deployment जटिल

- Audit करना कठिन

इन समस्याओं के समाधान के लिए Active Directory विकसित किया गया।

4. Directory Service क्या होती है?

Directory Service ऐसी प्रणाली है जो नेटवर्क के सभी संसाधनों की जानकारी संग्रहीत करती है।

इसे टेलीफोन डायरेक्टरी से समझें।

पुरानी Telephone Directory में—

- व्यक्ति का नाम
- पता
- फोन नंबर

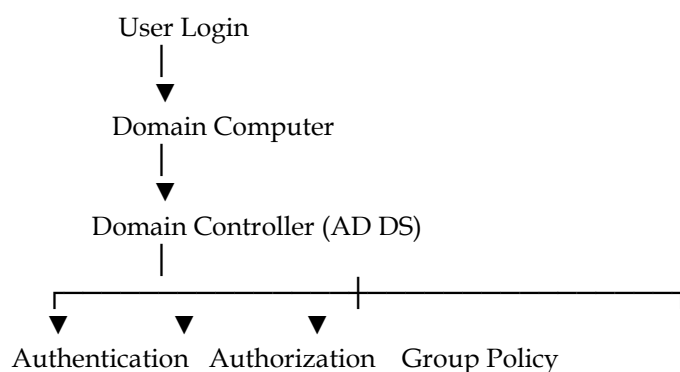
मिलता था।

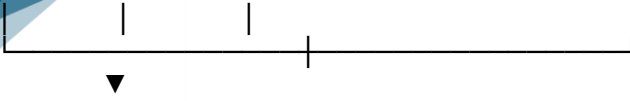
इसी प्रकार Active Directory में—

- User Name
- Department
- Email
- Computer Name
- Printer
- Group Membership
- Security Permissions

संग्रहीत रहती हैं।

5. Active Directory कैसे कार्य करती है?





User gets Access

6. Active Directory के मुख्य Components

Active Directory कई महत्वपूर्ण घटकों से मिलकर बनी होती है।

- Domain
 - Domain Controller
 - Forest
 - Tree
 - Organizational Unit (OU)
 - User Objects
 - Computer Objects
 - Group Objects
 - Group Policy
 - Sites
 - Trust Relationship
 - Schema
 - Global Catalog
-

7. Domain क्या होता है?

Domain एक Logical Boundary है, जिसके अंतर्गत Users, Computers और Policies का केंद्रीकृत प्रबंधन किया जाता है।

उदाहरण

college.local

या

csjmu.edu.in

इस Domain के सभी Users एक ही केंद्रीय Database से प्रमाणित होंगे।

8. वास्तविक उदाहरण

मान लीजिए Domain है—

gpmschool.local

इसमें—

- Principal
- Teachers
- Students
- Office Staff

सभी के Accounts Active Directory में बनाए गए हैं।

अब कोई Teacher किसी भी Domain Computer पर Login कर सकता है।

9. Domain Controller (DC)

Domain Controller वह Windows Server है जिस पर Active Directory स्थापित होती है।

यह पूरे Domain का "हृदय" (Heart of the Domain) माना जाता है।

इसका कार्य—

- User Authentication
- Authorization
- Password Verification
- Group Policy लागू करना
- LDAP Directory प्रदान करना
- Kerberos Authentication
- DNS Integration

उदाहरण

यदि User Login करता है—

Username

shiv.kumar

Password

Computer यह जानकारी Domain Controller को भेजता है।

Domain Controller Password की जाँच करता है।

यदि सही है—

Access Granted

अन्यथा—

Access Denied

10. Active Directory Database

Active Directory का Database निम्न फ़ाइल में सुरक्षित रहता है—

C:\Windows\NTDS\NTDS.dit

यह Enterprise की सबसे महत्वपूर्ण Database Files में से एक है।

इसमें—

- Users
- Password Hashes
- Groups
- Computers
- Policies

की जानकारी रहती है।



11. Authentication क्या है?

Authentication का अर्थ है—

User वास्तव में वही है जो वह स्वयं को बता रहा है या नहीं।

उदाहरण—

Username

Shiv

Password

यदि Password सही है—

User प्रमाणित (Authenticated) हो जाता है।

12. Authorization क्या है?

Authentication के बाद यह तय किया जाता है कि User क्या-क्या कर सकता है।

उदाहरण—

Teacher

- ✓ Student Records देख सकता है
 - ✓ Attendance भर सकता है
 - ✗ Salary Database नहीं खोल सकता
-

13. Active Directory Objects

AD में प्रत्येक Resource को Object कहा जाता है।

उदाहरण—

- User
 - Computer
 - Printer
 - Group
 - Shared Folder
 - Service Account
-

उदाहरण

User

↓

Shiv Kumar

↓
Department

↓
Computer Science

↓
Email

↓
shiv@example.edu

यह पूरा Record एक Object है।

14. Distinguished Name (DN)

Active Directory प्रत्येक Object की एक विशिष्ट पहचान (Unique Identity) रखती है।

उदाहरण—

CN=Shiv Kumar,
OU=Faculty,
DC=gpschool,
DC=local

जहाँ—

- **CN (Common Name)** = Shiv Kumar
- **OU (Organizational Unit)** = Faculty
- **DC (Domain Component)** = gpschool.local

15. वास्तविक केस अध्ययन

Case Study - विश्वविद्यालय नेटवर्क

एक विश्वविद्यालय में—

- 12 Departments
- 20 Computer Labs
- 8 Hostels

प्रत्येक Department का अलग OU बनाया गया।

University.local

|

|— Faculty

|— Students

|— Accounts

|— Library

|— Examination

|— Administration

अब यदि Library Department के सभी Computers पर नया Software Install करना हो—

Administrator केवल Library OU पर Group Policy लागू करेगा।

कुछ ही समय में सभी संबंधित Computers पर Software उपलब्ध हो जाएगा।

यदि यही कार्य बिना Active Directory के किया जाए, तो प्रत्येक Computer पर अलग-अलग जाकर Install करना पड़ेगा।

16. Active Directory के लाभ

1. Centralized User Management
2. Single Sign-On (SSO)
3. Centralized Authentication
4. Group Policy Management
5. Software Deployment
6. Security Policy Enforcement
7. Password Policy Management
8. Resource Sharing
9. Audit और Logging
10. Scalability (हजारों से लाखों Objects तक)

17. निष्कर्ष

Active Directory आधुनिक Enterprise Networks की आधारशिला है। यह केवल User Login प्रणाली नहीं है, बल्कि Identity Management, Authentication, Authorization, Policy Enforcement, Resource Management और Enterprise Security का एक व्यापक ढाँचा है। Digital Forensics और Cyber Security में Active Directory का गहन ज्ञान आवश्यक है, क्योंकि अधिकांश Enterprise Attack (जैसे Privilege Escalation, Lateral Movement, Pass-the-Hash, Kerberoasting आदि) AD Environment को लक्ष्य बनाते हैं।

भाग-2 में हम Domain Controller, Forest, Tree, Organizational Unit (OU), Group Policy (GPO), LDAP, Kerberos Authentication, DNS Integration, Replication तथा Active Directory Architecture का चित्रों, वास्तविक नेटवर्क उदाहरणों और PhD स्तर की तकनीकी व्याख्या के साथ विस्तृत अध्ययन करेंगे।



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय : Active Directory (AD)

भाग-2 :

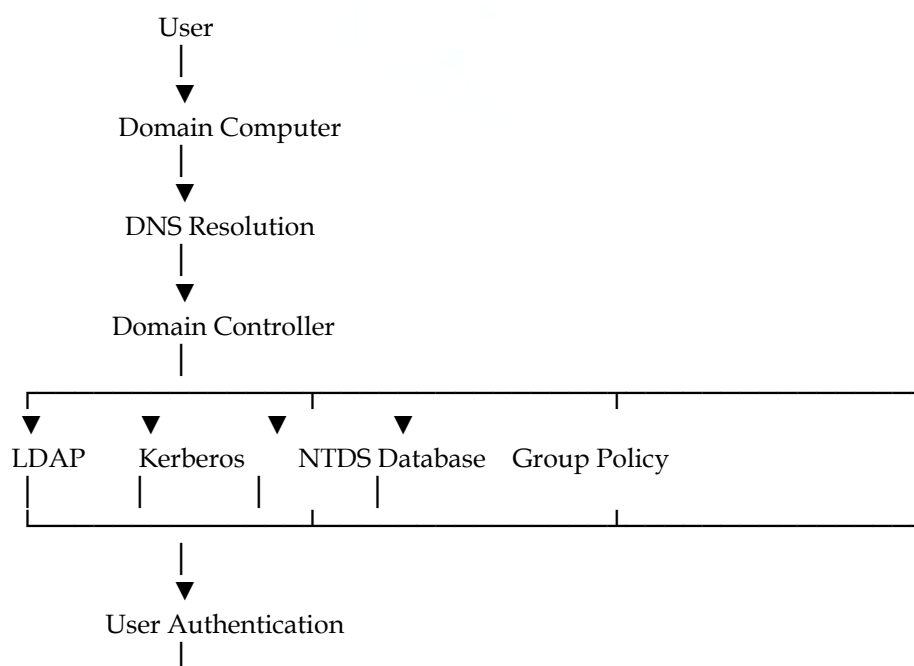
Active Directory Architecture, Domain Controller, Forest, Tree, OU, LDAP, Kerberos एवं DNS

1. Active Directory Architecture (आर्किटेक्चर)

Active Directory (AD) केवल एक Software नहीं है, बल्कि कई Services, Databases, Protocols तथा Servers से मिलकर बनी एक Enterprise Identity Management Architecture है।

जब कोई User Domain में Login करता है, तो केवल Username और Password की जाँच नहीं होती, बल्कि अनेक Components मिलकर कार्य करते हैं।

Active Directory Architecture



2. Domain Controller (DC)

Domain Controller क्या है?

Domain Controller वह Windows Server होता है जिस पर **Active Directory Domain Services (AD DS)** स्थापित होती है।

यह पूरे Domain का **Authentication Server** होता है।

इसी Server पर

- User Accounts
- Computer Accounts
- Password Hash
- Security Policies
- Group Policies

संग्रहीत रहती हैं।

वास्तविक उदाहरण

मान लीजिए

एक कॉलेज में

500 Computers हैं।

सभी Computers एक Domain में जुड़े हैं

gpmcollege.local

जब Student Login करता है—

Username

student01

Password



तो Login Request Domain Controller को जाती है।

यदि Password सही है

Access Granted

यदि गलत

Access Denied

Domain Controller के मुख्य कार्य

1. Authentication

User की पहचान सत्यापित करना।

2. Authorization

User को क्या Access मिलेगा।

3. Policy Distribution

सभी Computers पर Group Policy लागू करना।

4. Time Synchronization

पूरे Domain में समान समय बनाए रखना।

5. DNS Service

Domain Name Resolution

6. Replication

यदि कई Domain Controllers हों

तो सभी का Database समान रखना।

3. Active Directory Database

Domain Controller पर Database रहती है

C:\Windows\NTDS\

मुख्य File

NTDS.dit

इस Database में

- Users
- Groups
- Password Hash
- Security Identifiers
- OU
- Group Policy
- Computers

सब Stored रहते हैं।

उदाहरण

NTDS.dit

↓

Shiv Kumar

↓

Faculty

↓

Computer Science

↓

Member Of

↓

Faculty Group

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

4. Forest क्या है?

Forest

Active Directory की सबसे बड़ी Logical Boundary होती है।

एक Forest में

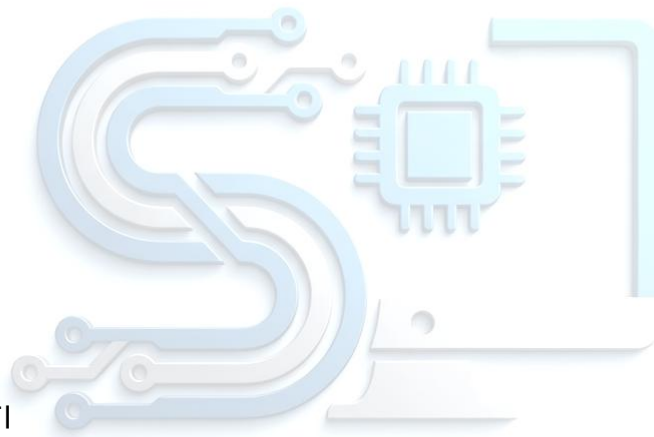
एक या कई Domains हो सकते हैं।

उदाहरण

University Forest

- |
- Engineering.local
- Medical.local
- Law.local
- Pharmacy.local

यह पूरा Forest कहलाता है।



Forest क्यों आवश्यक है?

यदि University में

अलग-अलग Departments

अलग-अलग Domains चाहते हैं

तो Forest उन्हें जोड़ता है।

वास्तविक उदाहरण

मान लीजिए

के अंतर्गत

Engineering.csjmu.local

Medical.csjmu.local

Law.csjmu.local

Management.csjmu.local

चारों Domains

एक Forest का भाग हो सकते हैं।

5. Tree क्या है?

Tree

ऐसे Domains का समूह है

जो समान Namespace साझा करते हैं।

उदाहरण

company.com

|

— sales.company.com

— hr.company.com

— finance.company.com

यह एक Tree है।

यदि

abc.com

xyz.org

हों



Forest और Tree में अंतर

Tree

समान Namespace

Parent-Child Domain

उदाहरण: sales.company.com

Forest

अलग Namespace भी हो सकते हैं

कई Trees का समूह

उदाहरण: company.com + university.edu

6. Organizational Unit (OU)

OU

Active Directory का Logical Container है।

इसका उपयोग

Users

Computers

Groups

को व्यवस्थित करने के लिए किया जाता है।



उदाहरण

University.local

|

└─ Faculty

└─ Students

└─ Accounts

└─ Library

└─ Hostel

└─ Examination

OU क्यों आवश्यक है?

मान लीजिए

केवल Library Department के Computers पर

PDF Reader Install करना है।

Administrator

सिर्फ

Library OU

पर Policy लागू करेगा।

वास्तविक उदाहरण

Faculty OU

↓

Teachers

↓

Professor

↓

Assistant Professor

7. Group Policy (GPO)

Group Policy

Windows Computers की Settings नियंत्रित करती है।

Administrator चाहता है

- USB बंद रहे
- Control Panel बंद रहे
- CMD Disable हो
- Wallpaper समान हो
- Password 12 Characters का हो

ये सब

Group Policy द्वारा लागू किया जा सकता है।

वास्तविक उदाहरण

School Computer Lab

में

Students

Games Install नहीं कर सकते।

क्यों?

Group Policy लागू है।

8. LDAP (Lightweight Directory Access Protocol)

LDAP

वह Protocol है

जिसके माध्यम से

Applications

उदाहरण

एक HR Software

Employee की जानकारी AD से लेना चाहता है।

वह LDAP Query भेजेगा।

LDAP Query

Find User

↓

Shiv Kumar

उत्तर

Name

Department

Email

Phone

Designation



LDAP का वास्तविक उदाहरण

मान लीजिए

Company में

5000 Employees हैं।

Administrator खोजता है

Department

Computer Science

LDAP तुरंत सभी Users की सूची देता है।

9. Kerberos Authentication

Kerberos

Active Directory का Default Authentication Protocol है।

यह Password को सीधे Network पर नहीं भेजता।

बल्कि

Ticket आधारित प्रणाली का उपयोग करता है।

Kerberos के Components

Client



KDC



TGT



Service Ticket



Server

Kerberos Login Process

User



Username

Password

470



KDC



TGT



Service Ticket



File Server



Access

वास्तविक उदाहरण

User

Shiv

Login करता है।

Password Verify होने के बाद

उसे

Ticket Granting Ticket

मिलता है।

अब

उसे हर Server पर Password नहीं देना पड़ता।

Kerberos का लाभ

Password बार-बार नहीं भेजा जाता।

इससे

10. DNS Integration

Active Directory

DNS के बिना कार्य नहीं कर सकती।

DNS

Domain Controller का पता बताती है।

उदाहरण

User Login करता है

student01

Computer पहले DNS से पूछता है

Domain Controller कहाँ है?

DNS उत्तर देता है

DC01.gpmcollege.local

फिर

Authentication होती है।

11. Active Directory Replication

यदि

दो Domain Controllers हों

DC01

DC02

और



Administrator ने नया User बनाया

Rahul

तो

कुछ समय बाद

DC02 पर भी

Rahul

दिखाई देगा।

इसे

Replication कहते हैं।

वास्तविक उदाहरण

Company

Lucknow Office

Delhi Office

दोनों में Domain Controller है।

Lucknow में Password बदला गया।

Replication के बाद

Delhi में भी वही Password कार्य करेगा।

12. Sites

यदि Company की कई Branches हैं

Kanpur

Lucknow

Delhi

तो प्रत्येक Branch

एक अलग Site हो सकती है।

Replication

Network Speed

Bandwidth

के अनुसार नियंत्रित होती है।

13. Trust Relationship

यदि

दो अलग Domains हों

College.local

University.local

तो

Trust बनाकर

एक Domain का User

दूसरे Domain के Resources उपयोग कर सकता है।

उदाहरण

Teacher

College Domain

का है।



14. वास्तविक Enterprise Case Study

बैंक का नेटवर्क

एक राष्ट्रीय बैंक में—

- 25 राज्य
- 2000 शाखाएँ
- 80,000 कर्मचारी

Architecture:

Bank Forest

```

|
|— North.bank.local
|— South.bank.local
|— East.bank.local
|— West.bank.local
|
|— Lucknow OU
|— Kanpur OU
|— Delhi OU
  
```



Administrator ने Policy बनाई—

- Password 14 Characters
- USB Storage Disabled
- Screen Lock 10 Minutes
- Firewall Enabled
- BitLocker Mandatory

इन Policies को GPO के माध्यम से पूरे नेटवर्क में लागू किया गया।

15. Active Directory Architecture का सारांश

Component	कार्य
Domain	Users और Computers का Logical Group
Domain Controller	Authentication एवं Authorization
Forest	सबसे बड़ी Logical Boundary
Tree	समान Namespace वाले Domains
OU	Objects का Logical Organization
LDAP	Directory Query Protocol
Kerberos	Secure Authentication Protocol
DNS	Domain Controller Resolution
Replication	Domain Controllers के बीच Database Synchronization
Group Policy	केंद्रीकृत Configuration एवं Security Management
Sites	भौगोलिक नेटवर्क संरचना का प्रबंधन
Trust	Domains/Forests के बीच संसाधन साझा करना

निष्कर्ष

Active Directory Architecture किसी भी Enterprise Network की रीढ़ (Backbone) है। इसकी सुरक्षा और संरचना सीधे संगठन की Cyber Security को प्रभावित करती है। Domain Controller, Kerberos, LDAP, DNS और Group Policy मिलकर सुरक्षित पहचान प्रबंधन (Identity Management), केंद्रीकृत प्रशासन तथा संसाधनों की नियंत्रित पहुँच सुनिश्चित करते हैं। किसी भी Digital Forensics या Incident Response जांच में Active Directory के Logs, NTDS Database, Authentication Records और Replication Events का विश्लेषण अत्यंत महत्वपूर्ण होता है।

भाग-3 में हम Active Directory Security, NTDS.dit Database Analysis, Security Identifiers (SID), Access Control Lists (ACL), Privilege Escalation, Pass-the-Hash, Pass-the-Ticket, Kerberoasting, Golden Ticket, Silver Ticket, तथा Active

Directory Forensics का वास्तविक हमलों और जांच प्रक्रियाओं के संदर्भ में विस्तार से अध्ययन करेंगे।



अध्याय :

Active Directory (AD)

भाग-3 : Active Directory Security, SID, ACL, NTDS.dit, Kerberos Attacks एवं Active Directory Forensics

महत्वपूर्ण नोट: यह अध्याय सुरक्षा, डिजिटल फॉरेंसिक और रक्षा (Defensive Security) के शैक्षणिक अध्ययन के उद्देश्य से है। इसमें अवधारणाओं, जांच और सुरक्षा उपायों पर ध्यान दिया गया है।

1. Active Directory Security का परिचय

किसी भी Enterprise Network की सुरक्षा का सबसे महत्वपूर्ण भाग Active Directory Security होती है।

यदि कोई हमलावर (Attacker) Active Directory पर नियंत्रण प्राप्त कर लेता है, तो वह पूरे Domain के Users, Computers और Servers तक पहुँच प्राप्त कर सकता है।

इसी कारण Microsoft Active Directory को Enterprise की "Identity Backbone" कहता है।

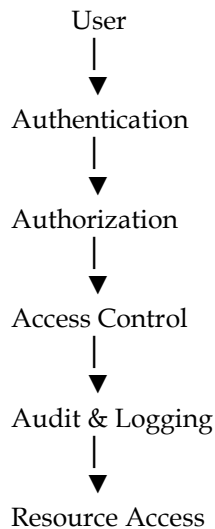
वास्तविक उदाहरण

एक बैंक में—

- 12,000 कर्मचारी
- 1,500 Servers
- 20,000 Computers
- 600 ATM Systems

यदि Attacker केवल एक सामान्य User Account से Domain Administrator बन जाए, तो वह पूरे बैंक के IT Infrastructure को प्रभावित कर सकता है।

Active Directory Security Model



2. Security Identifier (SID)

SID क्या है?

SID (Security Identifier) Windows द्वारा प्रत्येक User, Group और Computer को दिया गया एक Unique Identifier है।

नाम (Name) बदला जा सकता है, लेकिन SID सामान्यतः नहीं बदलता।

उदाहरण

User का नाम

Shiv Kumar

SID

S-1-5-21-3623811015-3361044348-30300820-1013

यदि User का नाम बदलकर

Dr. Shiv Kumar

कर दिया जाए

SID क्यों आवश्यक है?

Windows Permissions Name पर नहीं बल्कि SID पर आधारित होती हैं।

उदाहरण

Folder Permission

Research Folder

↓

Allow

↓

SID

↓

S-1-5-21-...

Windows नाम नहीं देखता।

SID देखकर Permission देता है।



3. Relative Identifier (RID)

SID का अंतिम भाग

RID कहलाता है।

उदाहरण

S-1-5-21-3623811015-3361044348-30300820-500

यहाँ

500

RID है।

RID Account

500 Administrator

501 Guest

512 Domain Admins Group

513 Domain Users

514 Domain Guests

4. Access Control List (ACL)

ACL यह निर्धारित करती है कि

किस User को

क्या Permission मिलेगी।

उदाहरण

Folder

Salary

Permissions

User	Permission
HR Manager	Full Control
Accountant	Modify
Employee	Read Only

यह जानकारी ACL में रहती है।

ACL के प्रकार

(1) DACL

Discretionary Access Control List

यह बताती है

कौन Access कर सकता है।

(2) SACL

System Access Control List

यह बताती है

किस Activity का Audit होगा।

उदाहरण

यदि Administrator चाहता है

कि

Salary Folder

को जो भी खोले

उसकी Log Entry बने।

तो

SACL Enable की जाएगी।



5. Access Token

जब User Login करता है

Windows

User को

एक

Access Token

देता है।

इसमें होता है—

- SID
- Group Membership
- Privileges
- Integrity Level

उदाहरण

User

Shiv

का Token

SID

↓

Groups

↓

Faculty

↓

Remote Desktop Users

↓

Backup Operators



जब User File खोलता है

Windows

Token की तुलना ACL से करता है।

यदि Permission मिलती है

तो Access दिया जाता है।

6. NTDS.dit Database

यह Active Directory की सबसे महत्वपूर्ण Database होती है।

Location

C:\Windows\NTDS\

मुख्य File

NTDS.dit

इसमें Stored रहता है—

- Users
- Groups
- Computers
- Password Hashes
- OU
- Group Policy Links
- Trust Information

उदाहरण

User



Shiv Kumar



Department



Computer Science



Password Hash



Group Membership



Forensic महत्व

यदि किसी Domain Controller की Disk की Forensic Image ली जाए

तो Investigator

NTDS Database का विश्लेषण कर सकता है ताकि यह सत्यापित किया जा सके कि—

- कौन-कौन से Accounts मौजूद थे।
- कौन-से Groups बनाए गए थे।
- किन Accounts को उच्च Privileges प्राप्त थे।

7. Password Hash

Windows सामान्यतः Password को Plain Text में संग्रहित नहीं करता।

इसके स्थान पर Password का Cryptographic Hash सुरक्षित रखा जाता है।

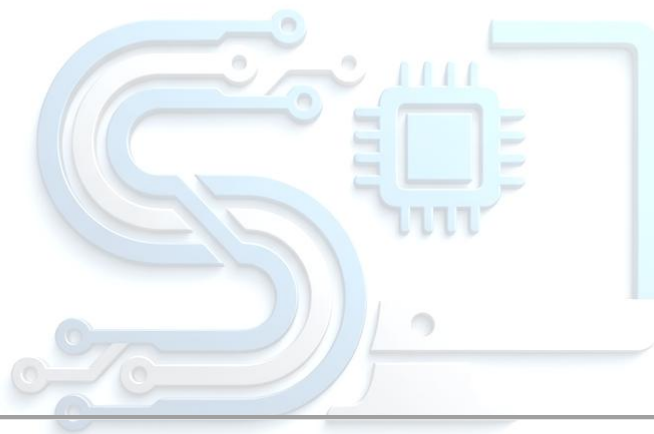
उदाहरण

Password

Shiv@123

Storage

Hashed Value



सुरक्षा का उद्देश्य

यदि Database चोरी हो जाए

तो Plain Password तुरंत दिखाई न दे।

8. Least Privilege Principle

Cyber Security का मूल सिद्धांत

हर User को

उतनी ही Permission

मिले

जितनी उसके कार्य के लिए आवश्यक है।

उदाहरण

Student

✗ Domain Admin नहीं होना चाहिए।

Teacher

✗ HR Database Access नहीं होना चाहिए।

Accountant

✗ Server Configuration नहीं बदल सकता।

9. Kerberos Authentication Review

Kerberos

Ticket आधारित Authentication करता है।

सरल प्रवाह—

User

↓

Domain Controller

↓

Ticket Granting Ticket (TGT)

↓

Service Ticket

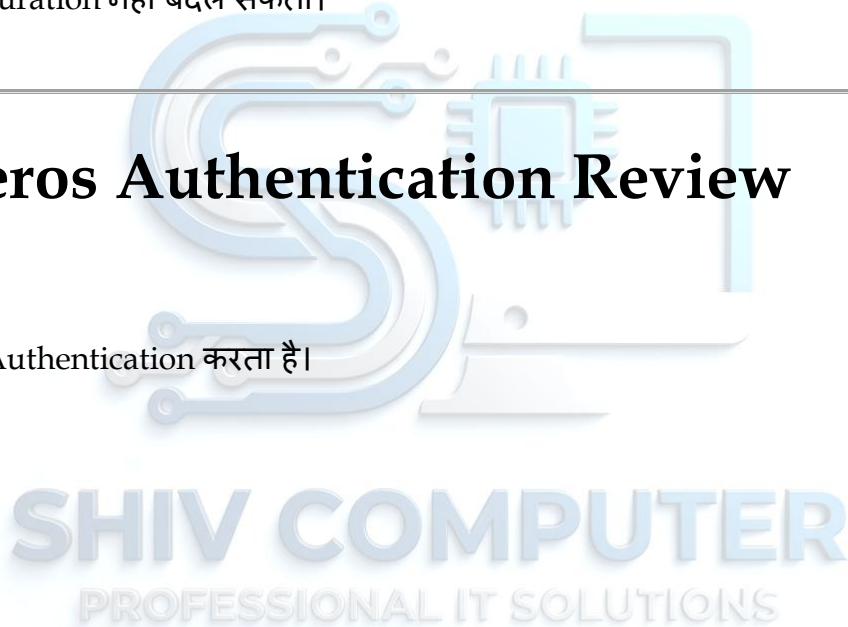
↓

File Server

↓

Access

इस प्रक्रिया में Password हर Service तक बार-बार नहीं भेजा जाता।



10. Kerberos आधारित हमलों की अवधारणा (Conceptual Overview)

आधुनिक Enterprise हमलों में Kerberos से संबंधित कुछ तकनीकों का उल्लेख मिलता है, जैसे—

- Pass-the-Ticket
- Kerberoasting
- Golden Ticket
- Silver Ticket

ये सभी Active Directory के विरुद्ध उपयोग की जाने वाली प्रसिद्ध Attack Categories हैं।

महत्वपूर्ण: इनका उद्देश्य यहाँ केवल यह समझना है कि Defender और Forensic Investigator इन्हें कैसे पहचानते हैं।

(A) Pass-the-Ticket

अवधारणा

यदि किसी वैध Kerberos Ticket का दुरुपयोग किया जाए, तो उसे Pass-the-Ticket कहा जाता है।

Defender क्या देखेगा?

- असामान्य Login Pattern
- अलग-अलग Systems पर एक ही Ticket का उपयोग
- असामान्य Authentication Logs

(B) Kerberoasting

अवधारणा

यह उन Service Accounts को लक्ष्य बनाता है जिनके Password कमजोर होते हैं।

सुरक्षा उपाय

- लंबे और मजबूत Password
- Managed Service Accounts

- नियमित Password Rotation

(C) Golden Ticket

अवधारणा

यदि Domain की अत्यंत संवेदनशील Kerberos Signing Material से समझौता हो जाए, तो पूरे Domain की सुरक्षा गंभीर रूप से प्रभावित हो सकती है।

बचाव

- Domain Controller की सुरक्षा
- Tiered Administration
- नियमित Monitoring
- Incident Response

(D) Silver Ticket

यह विशेष Services को प्रभावित करने से संबंधित अवधारणा है।

11. Active Directory Forensics

Digital Forensics में निम्न Evidence महत्वपूर्ण होते हैं—

Authentication Logs

बताते हैं

किस User ने Login किया।

Group Membership

बताती है

कौन Domain Admin है।

किसने Group Policy बदली।

Account Creation

किसने नया User बनाया।

Password Reset

Password कब बदला गया।

Computer Join

कौन-सा Computer Domain में जोड़ा गया।

12. वास्तविक Case Study – Unauthorized Privilege

एक संस्था में एक सामान्य कर्मचारी अचानक Domain Admin अधिकारों का उपयोग करने लगा।

Forensic Investigation में पाया गया—

- Event Logs में Group Membership बदली गई थी।
- Active Directory Audit Logs में Domain Admins Group में नया Member जोड़ा गया।
- GPO Logs से Administrator Account का दुरुपयोग होने के संकेत मिले।
- SIEM ने असामान्य Privileged Login पर Alert उत्पन्न किया।

जांच के आधार पर प्रभावित Account को Disable किया गया, Password Reset किए गए और Privileged Groups की समीक्षा की गई।

13. Active Directory Hardening (सुरक्षा सुदृढीकरण)

एक सुरक्षित Enterprise में निम्न उपाय अपनाए जाते हैं—

- Multi-Factor Authentication (MFA)
- Tiered Administrative Accounts
- Strong Password Policy
- Privileged Access Workstations (PAW)
- नियमित Patch Management
- LAPS / Windows LAPS
- Audit Logging
- SIEM Monitoring
- Domain Controller Backup
- Restricted Admin Rights

14. Enterprise Case Study - विश्वविद्यालय नेटवर्क

एक विश्वविद्यालय में—

- 30,000 Students
- 2,000 Faculty
- 500 Staff
- 3 Domain Controllers

सुरक्षा नीतियाँ—

- Password Minimum Length: 14 Characters
- MFA: Faculty एवं Administrators के लिए
- Student USB Access: Restricted
- BitLocker: सभी Laptops पर
- Domain Controller: केवल Dedicated Admins द्वारा प्रबंधित
- सभी Privileged Logins की SIEM Monitoring

इस प्रकार Identity Security और Audit दोनों मजबूत बनाए गए।

15. Active Directory Security का सारांश

Component	कार्य
SID	प्रत्येक Object की Unique पहचान
RID	SID का अंतिम भाग
ACL	Access Permissions
DACL	कौन Access कर सकता है
SACL	Audit Configuration
Access Token	Login के बाद User की Security जानकारी
NTDS.dit	Active Directory Database
Kerberos	Secure Authentication
LDAP	Directory Queries
Group Policy	Security एवं Configuration Management
Audit Logs	Investigation एवं Compliance

निष्कर्ष

Active Directory Security केवल User Login तक सीमित नहीं है, बल्कि यह Enterprise Identity Protection, Access Control, Privilege Management, Auditing और Incident Response का केंद्रीय आधार है। किसी भी Digital Forensic Investigation में SID, ACL, NTDS Database, Authentication Logs, Group Membership, GPO Changes तथा Domain Controller Logs का संयुक्त विश्लेषण संगठन की सुरक्षा घटनाओं का वैज्ञानिक पुनर्निर्माण करने में महत्वपूर्ण भूमिका निभाता है।

भाग-4 में हम Active Directory Replication, FSMO Roles, Global Catalog, Schema Master, Infrastructure Master, PDC Emulator, RID Master, Trust Relationships, Cross-Forest Authentication, DNS Internals, SYSVOL, NETLOGON, तथा Active Directory Disaster Recovery का अत्यंत विस्तृत PhD-स्तरीय अध्ययन करेंगे।

अध्याय : Active Directory (AD)

भाग-4 :

Active Directory Replication, FSMO Roles, Global Catalog, SYSVOL, NETLOGON, Trust Relationship एवं Disaster Recovery

महत्वपूर्ण: इस भाग में Active Directory के उन आंतरिक (Internal) घटकों का अध्ययन किया गया है जो Enterprise Networks को उच्च उपलब्धता (High Availability), विश्वसनीयता (Reliability) तथा केंद्रीकृत प्रबंधन प्रदान करते हैं।

1. Active Directory Replication क्या है?

Active Directory Replication वह प्रक्रिया है जिसके द्वारा एक Domain Controller (DC) पर किया गया परिवर्तन (Change) अन्य सभी Domain Controllers तक सुरक्षित रूप से पहुँचाया जाता है।

यदि नेटवर्क में केवल एक DC हो, तो Replication की आवश्यकता नहीं होती। लेकिन बड़े संगठनों में अनेक Domain Controllers होते हैं।

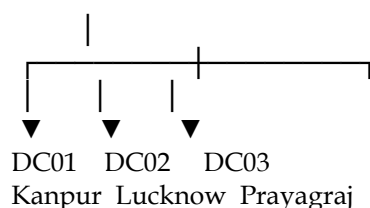
वास्तविक उदाहरण

एक विश्वविद्यालय में तीन Campus हैं—

- Kanpur
- Lucknow
- Prayagraj

प्रत्येक Campus में एक Domain Controller स्थापित है।

University.local



यदि Kanpur Campus में नया User बनाया जाए—

तो कुछ समय बाद यही जानकारी Lucknow और Prayagraj के Domain Controllers पर भी उपलब्ध हो जाएगी।

इसी प्रक्रिया को **Replication** कहते हैं।

2. Replication की आवश्यकता

यदि Replication न हो तो—

- अलग-अलग DC पर अलग-अलग Users दिखाई देंगे।
 - Password Synchronize नहीं होंगे।
 - Login Fail हो सकते हैं।
 - Group Policy अलग-अलग हो सकती है।
 - Authentication में समस्या होगी।
-

3. Multi-Master Replication

Active Directory **Multi-Master Replication** का उपयोग करती है।

अर्थात् अधिकांश Objects में परिवर्तन किसी भी Domain Controller पर किया जा सकता है।

फिर वह परिवर्तन अन्य Domain Controllers तक पहुँच जाता है।

उदाहरण

DC01

↓

Create User

↓

Replication

↓

DC02

वास्तविक उदाहरण

यदि Administrator Lucknow Office में Password बदलता है—

User : Shiv

Old Password : *****

New Password : *****

कुछ समय बाद वही Password Kanpur Office में भी कार्य करेगा।

4. Replication Topology

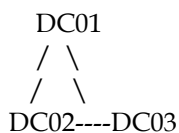
Replication को Knowledge Consistency Checker (KCC) व्यवस्थित करता है।

KCC यह सुनिश्चित करता है कि Domain Controllers के बीच ऐसा Network Path बने जिससे—

- कम Bandwidth उपयोग हो।
- तेज Synchronization हो।
- किसी DC के बंद होने पर वैकल्पिक मार्ग उपलब्ध रहे।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

उदाहरण



यदि DC01 अस्थायी रूप से उपलब्ध न हो, तो DC02 और DC03 सीधे Replicate कर सकते हैं।

5. Intra-Site एवं Inter-Site Replication

(A) Intra-Site Replication

एक ही Site के भीतर होने वाली Replication।

- High Speed
- Frequent Synchronization
- LAN आधारित

(B) Inter-Site Replication

दो अलग-अलग Sites के बीच Replication।

विशेषताएँ—

- WAN आधारित
- Bandwidth Optimization
- निर्धारित Schedule के अनुसार

उदाहरण

Kanpur Site

↓

LAN

↓

DC01

=====

Delhi Site

↓

WAN

↓

DC02

6. FSMO (Flexible Single Master Operations) Roles

यद्यपि Active Directory Multi-Master है, फिर भी कुछ विशेष कार्य केवल एक ही Server द्वारा किए जाते हैं।

इन्हें FSMO Roles कहा जाता है।

कुल पाँच FSMO Roles होती हैं।

FSMO Roles

FSMO Role	कार्य
Schema Master	Schema में परिवर्तन
Domain Naming Master	नया Domain जोड़ना
RID Master	नए SID/RID जारी करना
PDC Emulator	Password एवं Time Synchronization
Infrastructure Master	Cross-Domain References अद्यतन करना

7. Schema Master

Schema क्या है?

Schema Active Directory की "डेटा संरचना (Data Structure)" है।

यह निर्धारित करती है कि किसी Object में कौन-कौन से Attributes होंगे।

उदाहरण

यदि User Object है—

Name

Email

Phone

Department

ये सभी Attributes Schema द्वारा परिभाषित होते हैं।

वास्तविक उदाहरण

मान लीजिए University चाहती है कि प्रत्येक Student का

Scholar Number

भी Active Directory में संग्रहीत हो।

इसके लिए Schema में नया Attribute जोड़ा जाएगा।

यह कार्य केवल Schema Master कर सकता है।

8. Domain Naming Master

यदि नया Domain बनाना हो—

engineering.university.local

तो यह कार्य Domain Naming Master द्वारा नियंत्रित किया जाता है।

9. RID Master

प्रत्येक User को SID दिया जाता है।

SID का अंतिम भाग RID कहलाता है।

उदाहरण—

S-1-5-21-3623811015-3361044348-30300820-1105

यहाँ—

1105

RID है।

RID Master यह सुनिश्चित करता है कि दो Users को एक जैसा RID न मिले।

10. PDC Emulator

यह सबसे महत्वपूर्ण FSMO Role माना जाता है।

मुख्य कार्य—

- Password Change Synchronization
- Time Synchronization
- Legacy System Support
- Account Lockout सहायता

वास्तविक उदाहरण

User ने Password बदला।

यदि तुरंत दूसरे Computer से Login किया जाए—

तो PDC Emulator Password Verification में सहायता करता है ताकि User को प्रतीक्षा न करनी पड़े।

11. Infrastructure Master

यदि Forest में अनेक Domains हों—

Faculty.local

Student.local

तो Cross-Domain References को अद्यतन रखने का कार्य Infrastructure Master करता है।

12. Global Catalog (GC)

Global Catalog Active Directory का विशेष Server Role है।

इसमें पूरे Forest के सभी Domains की चयनित (Partial) जानकारी रहती है।

उदाहरण

University.local

Engineering.local

Medical.local

Law.local

यदि Administrator खोजता है—

User : Shiv Kumar

तो Global Catalog पूरे Forest में खोज सकता है।

वास्तविक उदाहरण

मान लीजिए User Engineering Domain में है।

लेकिन Administrator Medical Domain में बैठकर Search करता है।

Global Catalog तुरंत परिणाम उपलब्ध करा देता है।

13. SYSVOL Folder

SYSVOL Domain Controllers का अत्यंत महत्वपूर्ण Shared Folder है।

स्थान—

C:\Windows\SYSVOL

इसमें सामान्यतः—

- Group Policy Objects (GPO)
- Logon Scripts
- Startup Scripts

संग्रहीत रहते हैं।

उदाहरण

यदि Administrator सभी Computers पर Login Script लागू करता है—

तो Script SYSVOL में रखी जाती है और Replication द्वारा अन्य DC तक पहुँचती है।

14. NETLOGON Share

NETLOGON भी Domain Controller का एक महत्वपूर्ण Shared Folder है।

इसका उपयोग—

- Login Scripts
- Client Authentication सहायता
- Domain Join प्रक्रियाओं

में होता है।

उदाहरण

Student Login करते समय—

NETLOGON से Login Script प्राप्त कर सकता है, जैसे—

- Network Drive Mapping
- Printer Mapping
- Environment Variables

15. Trust Relationship

जब दो Domains या Forests एक-दूसरे के Users को नियंत्रित तरीके से संसाधनों का उपयोग करने की अनुमति देते हैं, तो इसे **Trust Relationship** कहा जाता है।

उदाहरण

College.local

↔

यदि Trust स्थापित है—

तो College का Teacher University Library के संसाधनों का उपयोग कर सकता है (यदि अनुमति दी गई हो)।

Trust के प्रकार

- Parent-Child Trust
 - Tree-Root Trust
 - External Trust
 - Forest Trust
 - Shortcut Trust
-

16. Cross-Forest Authentication

दो अलग-अलग Forests—

Government.local

University.local

यदि Forest Trust हो—

तो सीमित और नियंत्रित Authentication संभव हो सकता है।

17. Active Directory Backup

किसी Domain Controller की Backup अत्यंत महत्वपूर्ण है।

Backup में शामिल होना चाहिए—

- NTDS.dit
 - SYSVOL
 - Registry
 - DNS Configuration
 - Group Policy
-

18. Disaster Recovery

यदि Domain Controller Failure हो जाए—

Recovery के प्रमुख चरण—

1. Hardware Restore
2. Windows Server Recovery
3. Active Directory Restore
4. SYSVOL Restore
5. DNS Verification
6. Replication Verification
7. Authentication Testing

वास्तविक उदाहरण

एक Data Center में आग लगने से DC01 नष्ट हो गया।

क्योंकि—

- DC02 उपलब्ध था।
- Replication अद्यतन थी।
- नियमित System State Backup लिया गया था।

इसलिए Active Directory Services बिना बड़े व्यवधान के पुनर्स्थापित कर दी गईं।

19. Enterprise Case Study

एक बहुराष्ट्रीय कंपनी—

- 60 देशों में कार्यालय
- 3 Forest
- 25 Domains
- 150 Domain Controllers

सुरक्षा व्यवस्था—

- प्रत्येक Region में कम से कम दो Domain Controllers
- Global Catalog Servers
- नियमित Replication Health Monitoring
- System State Backup

- अलग Disaster Recovery Site
- समय-समय पर Recovery Drill

इससे किसी एक Data Center के प्रभावित होने पर भी Authentication Services जारी रहती हैं।

20. Active Directory Health Monitoring

नियमित रूप से निम्न बिंदुओं की निगरानी की जाती है—

- Replication Status
- DNS Health
- FSMO Role Availability
- SYSVOL Replication
- Disk Space
- Event Logs
- Time Synchronization
- Backup Status

21. सारांश

Component	कार्य
Replication	Domain Controllers के बीच डेटा Synchronization
Multi-Master	अधिकांश परिवर्तन किसी भी DC से संभव
FSMO Roles	विशेष कार्यों के लिए Single Master
Schema Master	Schema परिवर्तन
RID Master	Unique RID प्रदान करना
PDC Emulator	Password एवं Time Synchronization
Infrastructure Master	Cross-Domain References
Global Catalog	Forest-व्यापी Search
SYSVOL	GPO एवं Scripts
NETLOGON	Login Scripts एवं Domain Logon सहायता
Trust	Domains/Forests के बीच नियंत्रित Access
Disaster Recovery	Domain Controller Failure के बाद पुनर्प्राप्ति

Active Directory की विश्वसनीयता केवल Authentication पर निर्भर नहीं करती, बल्कि Replication, FSMO Roles, Global Catalog, SYSVOL, NETLOGON, DNS Integration तथा Disaster Recovery जैसी आंतरिक व्यवस्थाओं पर आधारित होती है। Enterprise स्तर पर इन सभी Components की सही योजना, नियमित Monitoring, Backup तथा Recovery Testing किसी भी संगठन की Identity Infrastructure को सुरक्षित, उपलब्ध (Highly Available) और विश्वसनीय बनाए रखते हैं।

भाग-5 में हम Active Directory Administration एवं Enterprise Management का गहन अध्ययन करेंगे, जिसमें शामिल होंगे—

- Active Directory Users and Computers (ADUC)
- PowerShell द्वारा AD Management
- Group Policy Management Console (GPMC)
- Fine-Grained Password Policies
- Delegation of Control
- Service Accounts एवं Managed Service Accounts
- Read-Only Domain Controller (RODC)
- Active Directory Certificate Services (AD CS)
- Azure AD / Microsoft Entra ID का परिचय
- Hybrid Identity Architecture
- Active Directory Security Best Practices
- Enterprise Digital Forensics एवं Incident Response में AD Logs का विश्लेषण

यह भाग प्रशासनिक (Administrative), सुरक्षा (Security) और फॉरेंसिक (Forensic) तीनों दृष्टिकोणों से अत्यंत महत्वपूर्ण है।

अध्याय :

Active Directory (AD)

भाग-5 : Active Directory Administration, PowerShell, GPO, RODC, AD CS, Hybrid Identity एवं Enterprise Management

यह अध्याय Active Directory के प्रशासन (Administration), सुरक्षा (Security), स्वचालन (Automation), तथा Enterprise Management का सबसे महत्वपूर्ण भाग है।

1. Active Directory Administration क्या है?

Active Directory Administration वह प्रक्रिया है जिसके माध्यम से Administrator पूरे Enterprise Network के—

- Users
- Groups
- Computers
- Servers
- Printers
- Policies
- Security
- Permissions
- Authentication

का केंद्रीकृत प्रबंधन करता है।

वास्तविक उदाहरण

मान लीजिए

CSJMU University में—

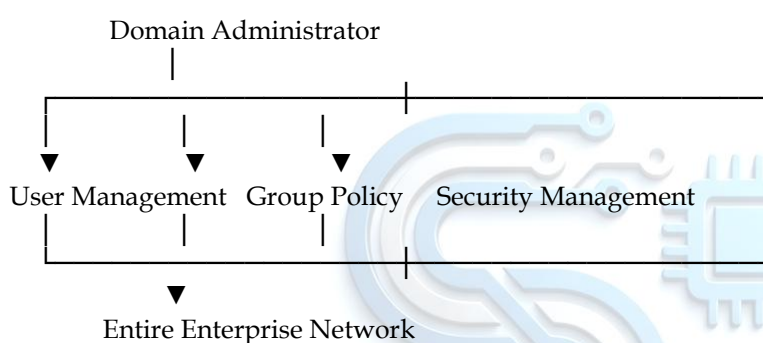
- 35,000 Students
- 2,500 Faculty

- 600 Staff
- 3 Campuses
- 2,000 Computers
- 150 Servers

यदि प्रत्येक Computer पर अलग-अलग User बनाए जाएँ तो पूरा System अव्यवस्थित हो जाएगा।

लेकिन Active Directory Administrator केवल Domain Controller पर कार्य करके पूरे नेटवर्क का प्रबंधन कर सकता है।

Enterprise Management Model



2. Active Directory Users and Computers (ADUC)

ADUC (Active Directory Users and Computers) सबसे महत्वपूर्ण Management Console है।

यह Microsoft Management Console (MMC) आधारित Tool है।

ADUC का उपयोग

ADUC द्वारा Administrator निम्न कार्य कर सकता है—

- नया User बनाना
- User Delete करना
- Password Reset करना
- Group बनाना
- Computer Join करना
- OU बनाना

- Account Disable करना
- Unlock Account करना

वास्तविक उदाहरण

Administrator नया Faculty User बनाता है—

Name : Dr. Shiv Kumar

Department : Computer Science

Username : shiv.kumar

Email : shiv@csjmu.ac.in

ADUC में यह Object कुछ सेकंड में तैयार हो जाता है।

3. User Account Management

Enterprise में प्रत्येक User का एक Domain Account होता है।

उदाहरण—

Username

student101

↓

Password

↓

Faculty Group

↓

Student OU

Administrator द्वारा किए जाने वाले सामान्य कार्य

- Account Create
- Disable
- Enable
- Password Reset

- Expiration Date
- Lock/Unlock
- Profile Path
- Home Folder

वास्तविक उदाहरण

एक Student का Password भूल गया।

Administrator

ADUC खोलता है

↓

Student खोजता है

↓

Password Reset

↓

नई Password Policy लागू

↓

Student Login कर लेता है।



4. Group Management

Enterprise में हजारों Users को व्यक्तिगत Permission देना कठिन होता है।

इसलिए Groups बनाए जाते हैं।

उदाहरण

Faculty Group

↓

Professor

↓
Assistant Professor



Guest Faculty

अब

Folder Permission

Faculty Group

को दे दी जाती है।

सभी Faculty स्वतः Access प्राप्त कर लेते हैं।

5. Security Groups

मुख्य प्रकार—

- Domain Admins
- Enterprise Admins
- Domain Users
- Backup Operators
- Account Operators
- Print Operators

वास्तविक उदाहरण

Accounts Department



Salary Folder



Permission



Accounts Group

अब केवल वही लोग Salary Folder खोल पाएँगे जो Accounts Group के सदस्य हैं।

6. Group Policy Management Console (GPMC)

Group Policy Management Console (GPMC) से पूरे Domain की Policies नियंत्रित की जाती हैं।

Administrator क्या-क्या नियंत्रित कर सकता है?

- USB Enable/Disable
- Control Panel Block
- CMD Disable
- Registry Lock
- Desktop Wallpaper
- Password Length
- Firewall
- Windows Defender
- Windows Update
- BitLocker
- Microsoft Office Policies

वास्तविक उदाहरण

Computer Lab

में

Student

Games Install नहीं कर सकते।

क्यों?

GPO लागू है।

GPO Architecture

Domain Controller



Group Policy



OU



Computers



Users

7. Password Policy

Administrator निर्धारित करता है—

- Minimum Length
- Complexity
- Expiration
- Lockout Threshold
- Password History

उदाहरण

Policy

Minimum Length

14 Characters



Uppercase



Lowercase



Number



Special Character

अब

abc123



8. Fine-Grained Password Policy (FGPP)

यदि अलग-अलग Users के लिए अलग Password Policy चाहिए

तो FGPP का उपयोग किया जाता है।

उदाहरण

Students

10 Character Password

Faculty

14 Character Password

Administrators

20 Character Password

9. PowerShell द्वारा Active Directory Management

PowerShell Active Directory Administration का सबसे शक्तिशाली माध्यम है।

इसके द्वारा—

- Bulk User Creation
- Bulk Password Reset
- Report Generation
- Automation
- User Search
- Group Management

जैसे कार्य किए जाते हैं।

उदाहरण (केवल अवधारणा)

यदि 500 Students का Admission हुआ है, तो Administrator प्रत्येक User को अलग-अलग बनाने के बजाय स्वचालित प्रक्रिया (Automation Script) से सभी Accounts तैयार कर सकता है।

वास्तविक उदाहरण

हर वर्ष

BCA

500 Students

आते हैं।

PowerShell Automation

500 Accounts

कुछ मिनटों में बना सकता है।

10. Delegation of Control

हर Administrator को Full Domain Admin बनाना सुरक्षित नहीं है।

इसलिए Delegation उपयोग किया जाता है।

उदाहरण

Computer Science Department

के Administrator

केवल

Computer Science OU

Manage कर सकते हैं।

को नहीं बदल सकते।

Delegation Model

Domain Admin

|

— Faculty Admin

— Library Admin

— Hostel Admin

— Accounts Admin

11. Read-Only Domain Controller (RODC)

RODC

Read Only Database रखता है।

इसमें परिवर्तन नहीं किए जा सकते।

RODC कहाँ उपयोग होता है?

- Remote Branch
 - Bank Branch
 - Village Office
 - Small Campus
-

वास्तविक उदाहरण

गाँव के Campus में

Internet बार-बार बंद हो जाता है।

RODC स्थापित कर दिया गया।

अब

स्थानीय Login

सामान्य रूप से हो सकता है।

लेकिन Database Modification केवल मुख्य Domain Controller पर होगी।

12. Managed Service Accounts (MSA)

कई Services

विशेष User Accounts पर चलती हैं।

यदि Password बदल जाए

तो Service बंद हो सकती है।

MSA

इन Passwords का सुरक्षित एवं स्वचालित प्रबंधन करता है।

उदाहरण

SQL Server

Backup Service

Web Server

सभी अलग-अलग Managed Service Accounts का उपयोग कर सकते हैं।

13. Active Directory Certificate Services (AD CS)

AD CS

प्रदान करता है।

इसका उपयोग—

- Digital Certificate
- Smart Card Login
- SSL Certificate
- VPN Authentication
- Code Signing

में किया जाता है।

वास्तविक उदाहरण

University Portal

HTTPS

पर चलता है।

SSL Certificate

AD CS द्वारा जारी किया जा सकता है (Enterprise वातावरण में)।

14. Hybrid Identity

आज अधिकांश Organizations

केवल On-Premises AD

नहीं चलाते।

वे

Cloud भी उपयोग करते हैं।

Hybrid Architecture

On-Premises AD

↓
Synchronization



Cloud Identity



Microsoft 365



Teams



Exchange



OneDrive

15. Microsoft Entra ID (पूर्व नाम Azure Active Directory)

Microsoft Entra ID क्लाउड आधारित Identity एवं Access Management सेवा है।

यह पारंपरिक On-Premises Active Directory से अलग है, लेकिन Hybrid वातावरण में दोनों साथ मिलकर कार्य कर सकते हैं।

वास्तविक उदाहरण

Employee

Office में

Domain Account

से Login करता है।

घर से

Microsoft 365

16. Active Directory Security Best Practices

Enterprise में निम्न Best Practices अपनाई जाती हैं—

Strong Password Policy

कम से कम 14-16 Characters

Multi-Factor Authentication (MFA)

विशेष रूप से Administrators के लिए

Least Privilege

आवश्यक न्यूनतम Permission

Tiered Administration

Admin Accounts को अलग-अलग स्तरों में विभाजित करना

LAPS / Windows LAPS

Local Administrator Password का सुरक्षित एवं स्वचालित प्रबंधन

Regular Backup

- NTDS
 - SYSVOL
 - DNS
 - Group Policy
-

Patch Management

Audit Logs

Authentication

Group Changes

Password Changes

का रिकॉर्ड

17. Enterprise Digital Forensics

Active Directory Investigation में निम्न Evidence महत्वपूर्ण होते हैं—

- Login Events
- Failed Login
- Group Membership Changes
- Password Reset Events
- Account Lockout
- GPO Modification
- Domain Controller Logs
- Replication Events
- DNS Logs

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

वास्तविक केस अध्ययन

एक कंपनी में किसी ने रात 2:15 बजे Domain Administrator Account से Login किया।

जांच में—

- Security Event Logs
- Group Membership Logs
- Domain Controller Authentication Logs
- VPN Logs
- SIEM Alerts

का मिलान किया गया।

पता चला कि यह अधिकृत Maintenance Window का भाग नहीं था।

Administrator Account को तुरंत Disable किया गया, Password बदले गए और आगे की Incident Response प्रक्रिया शुरू की गई।

18. Enterprise Case Study – CSJMU University

कल्पना करें—

- 40,000 Students
- 3,000 Faculty
- 500 Staff
- 4 Campuses
- 5 Domain Controllers

OU Structure

CSJMU.local

- |
- Students
- Faculty
- Administration
- Accounts
- Examination
- Library
- Hostels
- Research



लागू Policies

- MFA: Faculty एवं Administrators
- USB Restriction: Students
- BitLocker: Laptops
- Windows Defender: Mandatory
- Password Length: 14 Characters
- Audit Logging: Enabled
- SIEM Integration: Enabled
- नियमित Backup एवं Disaster Recovery Drill

इस प्रकार पूरा विश्वविद्यालय एक केंद्रीकृत और सुरक्षित Identity Infrastructure पर संचालित हो सकता है।

19. Active Directory Administration का सारांश

Component	कार्य
ADUC	User एवं Computer Management
GPMC	Group Policy Management
FGPP	अलग-अलग Password Policies
PowerShell	Automation एवं Bulk Management
Delegation	सीमित प्रशासनिक अधिकार
RODC	Remote Branch Authentication
MSA	Service Account Management
AD CS	Certificates एवं PKI
Microsoft Entra ID	Cloud Identity Management
Hybrid Identity	On-Premises + Cloud Integration
Audit Logs	Monitoring एवं Investigation

20. निष्कर्ष

Active Directory Administration केवल Users बनाने या Password Reset करने तक सीमित नहीं है। यह Enterprise Identity Governance, Access Control, Automation, Cloud Integration, Certificate Management, Security Hardening और Digital Forensics का व्यापक ढाँचा है। आधुनिक संगठनों में Active Directory और Microsoft Entra ID का संयुक्त उपयोग सुरक्षित, स्केलेबल और केंद्रीकृत पहचान प्रबंधन (Identity Management) का आधार बन चुका है।

इस श्रृंखला का अगला उन्नत भाग (भाग-6 : PhD Research Level)

यदि आप PhD स्तर का अध्ययन कर रहे हैं, तो अगला भाग शोध (Research) एवं उन्नत सुरक्षा (Advanced Security) पर केंद्रित होगा, जिसमें शामिल होंगे—

1. Active Directory Internal Database Structure (NTDS.dit Internals)
2. LDAP Internals एवं Query Processing
3. Kerberos Protocol का गहन विश्लेषण
4. Active Directory Replication Metadata

5. BloodHound आधारित Attack Path Analysis (रक्षात्मक दृष्टिकोण से)
6. Active Directory Threat Modeling
7. Zero Trust Architecture एवं Active Directory
8. Identity Governance एवं PAM (Privileged Access Management)
9. Active Directory Digital Forensics एवं Incident Response Framework
10. Enterprise Case Studies (MITRE ATT&CK Mapping, Detection एवं Defense)

यह भाग शोधार्थियों, साइबर सुरक्षा विशेषज्ञों, डिजिटल फॉरेंसिक विश्लेषकों तथा Enterprise Security Architects के लिए विशेष रूप से उपयोगी होगा।

अध्याय : Active Directory (AD)

भाग-6 : Active Directory Internals, Threat Modeling, Identity Governance एवं Digital Forensics (PhD Research Level)

स्तर: PhD / Cyber Security Research / Digital Forensics / Enterprise Security Architect

यह भाग Active Directory के आंतरिक (Internal) कार्यों, Identity Security, Threat Modeling, Digital Forensics, Zero Trust, Enterprise Detection, तथा Advanced Defensive Architecture पर केंद्रित है।

1. Active Directory Internals (आंतरिक संरचना)

अधिकांश लोग Active Directory को केवल User Login System समझते हैं।

लेकिन वास्तव में Active Directory पाँच प्रमुख Layers पर कार्य करती है।

Applications

|

Active Directory API

|

LDAP + Kerberos + DNS

|

NTDS Database Engine

|

Windows Kernel

प्रत्येक Layer का कार्य

Layer-1 : Applications

उदाहरण

- Outlook
- Microsoft Teams
- Exchange
- SharePoint
- SQL Server

ये सभी Active Directory से User Identity प्राप्त करते हैं।

Layer-2 : Active Directory Services

यह Layer

- Authentication
- Authorization
- Object Management

का कार्य करती है।

Layer-3 : LDAP एवं Kerberos

LDAP

↓

Directory Query

Kerberos

↓
Authentication

DNS

↓

Domain Controller खोजता है।

Layer-4 : NTDS Database

यहीं पूरा Database रहता है।

Layer-5 : Windows Kernel

Memory

Security

Access Token

Privilege

सब Windows Kernel नियंत्रित करता है।

2. NTDS.dit Database का आंतरिक विश्लेषण

NTDS.dit एक सामान्य SQL Database नहीं है।

यह Extensible Storage Engine (ESE) पर आधारित Database है।

इसमें Stored Objects

Users

Computers

Groups

Printers

Trust

Schema

DNS

Certificates

प्रत्येक Object के Attributes होते हैं।

उदाहरण

User Object

Name

SID

Password Hash

Department

Phone

Email

Manager

Last Logon

Password Last Set



Member Of

Description

वास्तविक उदाहरण

User

Dr. Shiv Kumar

का Object

CN = Dr. Shiv Kumar

Department = Computer Science

Designation = Professor

Office = Kanpur

Employee ID = CS00125

Manager = HOD

Email = shiv@csjmu.ac.in

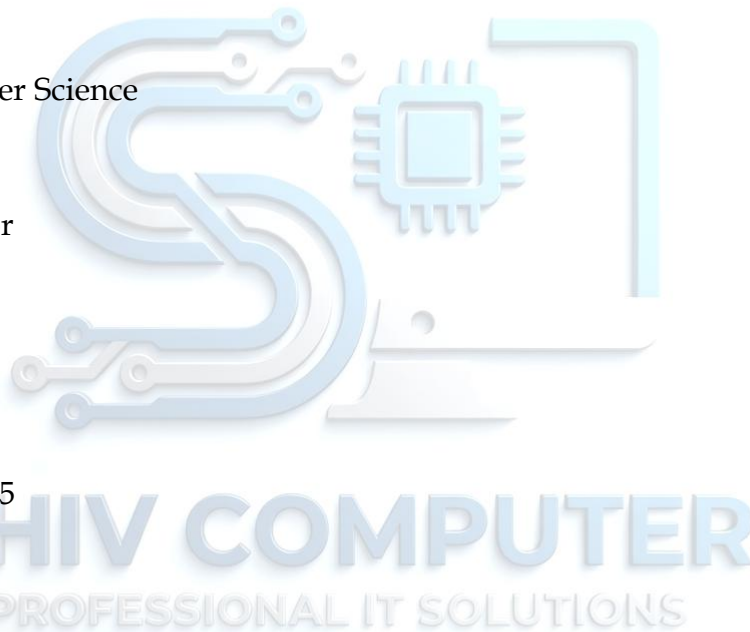
यह सब NTDS Database में Stored रहता है।

3. LDAP Internals

LDAP केवल Search Protocol नहीं है।

यह पूरा Directory Access Framework है।

LDAP Operations



Search

Compare

Add

Modify

Delete

ModifyDN

Unbind

उदाहरण

Application पूछती है

Find all Faculty

LDAP

पूरे Database में Search करता है।

उत्तर

Faculty List

LDAP Search Process

Client

↓





Domain Controller



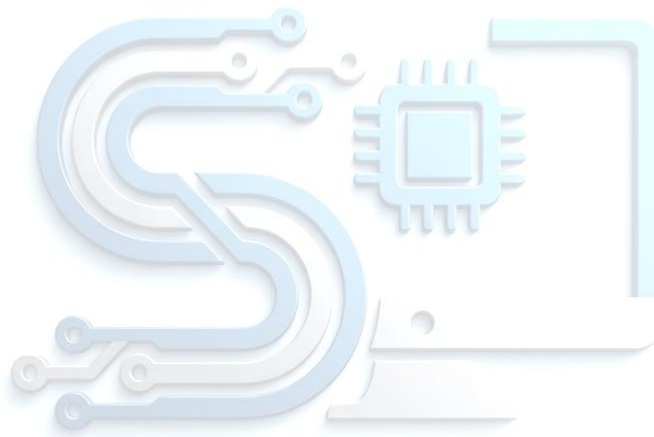
NTDS Search



Result



Client



वास्तविक उदाहरण

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

HR Software

पूछता है

Department

Computer Science

LDAP

300 Faculty

तुरंत Return करता है।

4. Kerberos Internals

Kerberos तीन प्रमुख चरणों में कार्य करता है।

चरण 1

Authentication Service



User की पहचान

चरण 2

Ticket Granting Service



TGT प्रदान

चरण 3

Service Ticket



File Server



SQL Server



Exchange

**Kerberos Flow**

User



AS





TGS



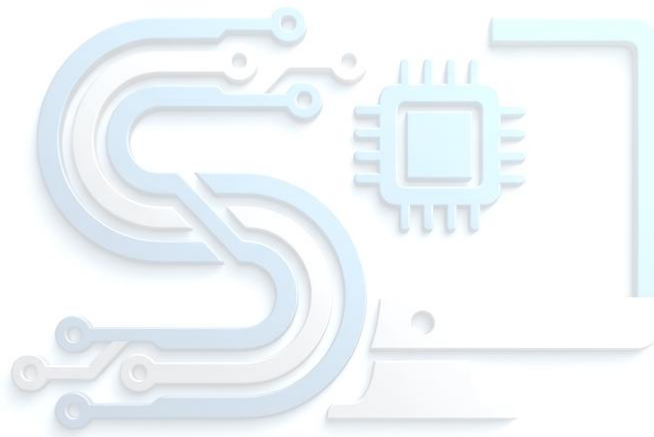
Service Ticket



Server



Access



5. Active Directory Replication Metadata

Replication केवल Database Copy नहीं है।

प्रत्येक Object के साथ Metadata रहती है।

उदाहरण

Object



Version



USN



Time Stamp



Originating DC



Invocation ID

USN

Update Sequence Number

प्रत्येक परिवर्तन का Unique Number

उदाहरण

User

Rahul

Department बदला

USN

785432

6. Active Directory Threat Modeling

Threat Modeling का अर्थ

Attack होने से पहले

Threat Sources

- Insider Threat
 - Compromised Account
 - Malware
 - Ransomware
 - Phishing
 - Credential Theft
 - Misconfiguration
-

Enterprise Threat Model

Attacker



Credential



User



Privilege



Server



Domain Controller

वास्तविक उदाहरण

Attacker

Student Account

से Login करता है।

फिर

कमजोर Configuration के कारण

अधिक Privilege प्राप्त कर लेता है।

यही Threat Model में विश्लेषित किया जाता है।

7. Identity Governance

Identity Governance

बताती है

कौन

क्या

कब

क्यों

Access करेगा।

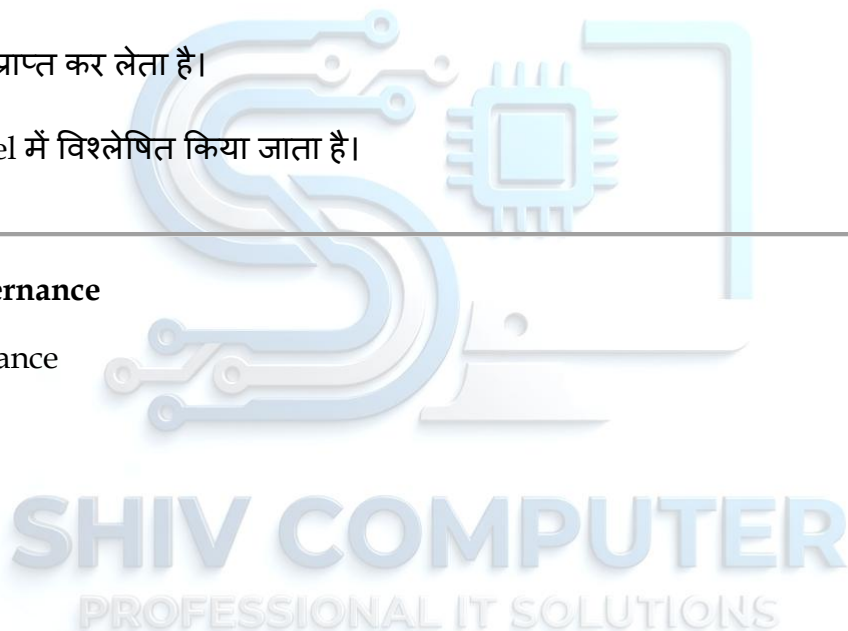
इसमें शामिल

Identity Lifecycle

Access Review

Role Management

Approval Workflow



उदाहरण

Employee

Resign करता है।

Identity Governance

स्वतः

Account Disable

VPN बंद

Email बंद

Office Access समाप्त

8. Privileged Access Management (PAM)

सभी Administrator Accounts

हमेशा उपयोग नहीं होने चाहिए।

PAM

Just-In-Time Access

देता है।

उदाहरण

Administrator

को

30 Minutes

के लिए

Domain Admin

Permission मिलती है।

फिर

Permission समाप्त।

9. Zero Trust Architecture

पुराना Model

Login



Full Trust

Zero Trust

Login



Verify



MFA



Device Check





Risk Score



Access

सिद्धांत

Never Trust

Always Verify

वास्तविक उदाहरण

Administrator

भारत से Login करता है।

5 मिनट बाद

दूसरे देश से Login प्रयास।

System

Risk पहचानता है।

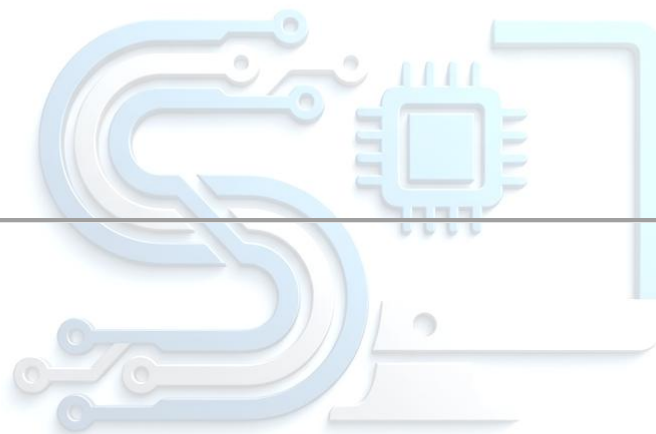
Access रोक देता है।

10. Active Directory Digital Forensics

Forensic Investigator

केवल Logs नहीं देखता।

वह Correlation करता है।



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS



Registry



Event Logs



DNS Logs



Kerberos



LDAP



Firewall



SIEM



Timeline

वास्तविक उदाहरण

रात

02:15

Domain Admin Login



VPN Log



Firewall Log



DNS Query



PowerShell Activity



GPO Modification



User Creation



Evidence Timeline

11. Event Correlation

Enterprise SIEM

हजारों Logs जोड़ता है।

उदाहरण



+

DNS

+

Firewall

+

PowerShell

+

Sysmon

+

Windows Event

↓

Attack Detection



12. Enterprise Detection Strategy

Blue Team

निम्न गतिविधियों की निगरानी करता है—

- नए Administrator Accounts

- असामान्य Login Time
- Multiple Failed Logins
- GPO Changes
- Replication Errors
- DC Restart
- Account Lockout
- Password Reset
- LDAP Enumeration की असामान्य मात्रा
- Privileged Group Membership Changes

13. MITRE ATT&CK Mapping

Enterprise Defender

MITRE ATT&CK Framework का उपयोग करता है।

उदाहरण

चरण	Defensive Focus
Initial Access	MFA, Email Security
Credential Access	Credential Protection
Discovery	Monitoring एवं Detection
Lateral Movement	Network Segmentation
Privilege Escalation	Least Privilege
Persistence	Startup एवं Policy Monitoring
Defense Evasion	Logging एवं Tamper Protection
Exfiltration	DLP एवं Network Monitoring

14. Enterprise Case Study

राष्ट्रीय बैंक

Network

540

150000 Users

850 Domain Controllers

4500 Branches

Security

Zero Trust

+

Microsoft Entra ID

+

MFA

+

PAM

+

SIEM

+

EDR

+



यदि

Administrator Login

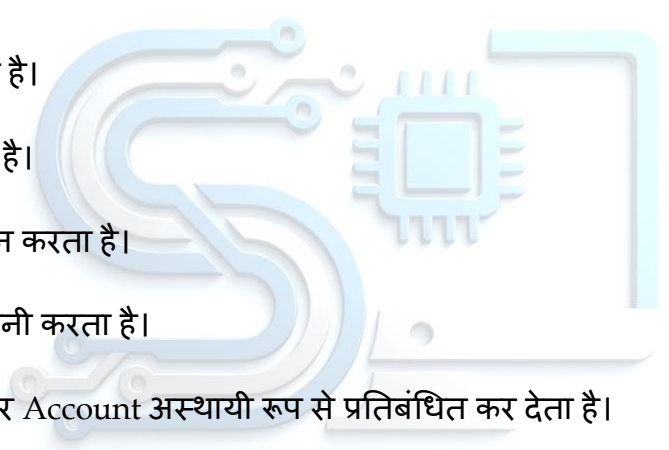
रात

03:00

होता है।

System

स्वतः:

- Risk Score बढ़ाता है।
 - MFA पुनः माँगता है।
 - SOC Alert उत्पन्न करता है।
 - Session की निगरानी करता है।
 - आवश्यकता होने पर Account अस्थायी रूप से प्रतिबंधित कर देता है।
- 

15. Research Topics (PhD)

Active Directory पर वर्तमान शोध के प्रमुख क्षेत्र—

1. AI आधारित Anomaly Detection
2. Machine Learning आधारित Insider Threat Detection
3. Graph-Based Identity Attack Analysis
4. Zero Trust Identity Architecture
5. Cloud Hybrid Identity Security
6. Post-Quantum Authentication
7. Behavioral Authentication
8. Identity Risk Scoring
9. Automated Incident Response

16. Active Directory Best Practices (Enterprise)

क्षेत्र	सर्वोत्तम अभ्यास
Password	कम से कम 14-16 अक्षर, मजबूत नीति
MFA	सभी Privileged Accounts पर
PAM	Just-In-Time Administration
Tiering	अलग-अलग Admin Tiers
LAPS	Local Admin Password Management
Monitoring	SIEM + EDR + Sysmon
Backup	नियमित System State एवं AD Backup
Replication	नियमित Health Check
GPO	Change Control एवं Versioning
Audit	सभी महत्वपूर्ण Events की समीक्षा
Disaster Recovery	नियमित Recovery Drill

17. Active Directory Research Architecture

User

|

Identity Management

|

Active Directory / Entra ID

|

Authentication (Kerberos)

|

Authorization (ACL / SID)

|

Resource Access Control

|

SIEM + EDR + SOC Monitoring

|

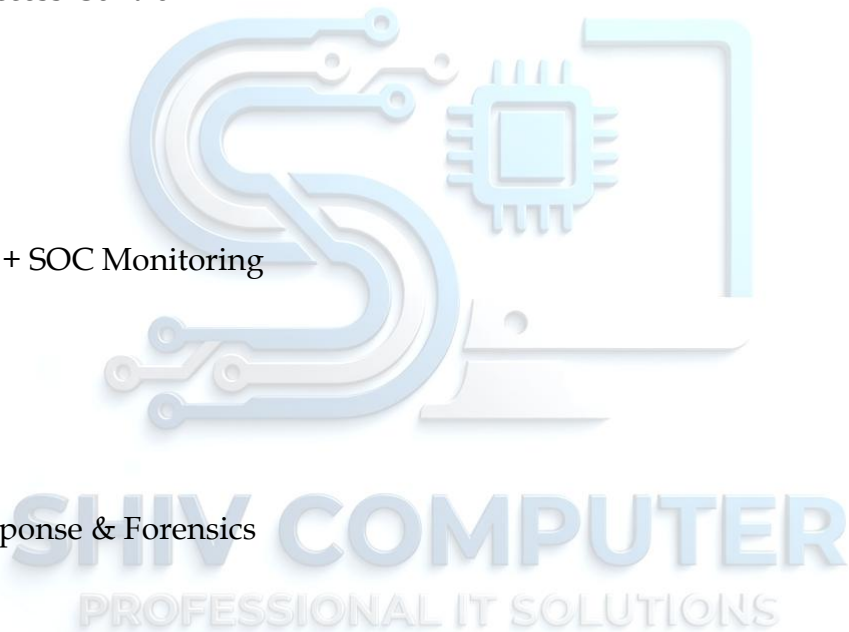
Incident Response & Forensics

|

Threat Intelligence Feedback

|

Continuous Security Improvement



18. अंतिम निष्कर्ष

Active Directory आधुनिक Enterprise की Identity Security Backbone है। इसका अध्ययन केवल User Management तक सीमित नहीं है, बल्कि इसमें Authentication Protocols, Database Internals, Directory Services, Identity Governance, Zero Trust, Threat Modeling, Digital Forensics, SIEM Integration, Cloud Identity तथा Enterprise Defense जैसे अनेक उन्नत विषय शामिल हैं।

PhD स्तर पर Active Directory का उद्देश्य केवल यह समझना नहीं है कि "User Login कैसे करता है", बल्कि यह विश्लेषण करना है कि—

- पहचान (Identity) कैसे स्थापित होती है,
- विश्वास (Trust) कैसे निर्मित और सत्यापित होता है,
- अधिकार (Authorization) कैसे नियंत्रित किए जाते हैं,
- हमलों का पता कैसे लगाया जाता है,
- तथा Digital Evidence के आधार पर किसी सुरक्षा घटना का वैज्ञानिक पुनर्निर्माण (Forensic Reconstruction) कैसे किया जाता है।

यहाँ Active Directory का PhD-स्तरीय सिद्धांतात्मक अध्ययन पूर्ण होता है।

इसके बाद यदि आप Digital Forensics एवं Enterprise Security में और गहराई चाहते हैं, तो अगला स्वाभाविक विषय होगा:

1. Windows Event Logs Analysis (PhD Level)
2. Kerberos Protocol Deep Dive (RFC आधारित अध्ययन)
3. NTFS Forensics
4. Memory Forensics (Volatility Framework)
5. SIEM एवं SOC Architecture
6. Microsoft Defender for Identity एवं Enterprise Detection
7. Windows Internals (Kernel, LSASS, Security Subsystem)

ये विषय Active Directory के साथ मिलकर एक पूर्ण Enterprise Cyber Security एवं Digital Forensics विशेषज्ञता का आधार बनाते हैं।

अध्याय :

NTFS Permissions (NTFS अनुमतियाँ)

1. परिचय (Introduction)

NTFS (New Technology File System) Microsoft द्वारा विकसित एक उन्नत (Advanced) File System है, जिसे Windows NT परिवार (Windows 2000, XP, Vista, 7, 8, 10, 11 तथा Windows Server) के लिए बनाया गया। NTFS केवल डेटा संग्रहीत करने का माध्यम नहीं है, बल्कि यह सुरक्षा (Security), अनुमति नियंत्रण (Permission Control), डेटा अखंडता (Data Integrity), एन्क्रिप्शन (Encryption), ऑडिटिंग (Auditing) और एक्सेस कंट्रोल (Access Control) जैसी सुविधाएँ प्रदान करता है।

NTFS का सबसे महत्वपूर्ण सुरक्षा तंत्र NTFS Permissions है, जिसके माध्यम से यह नियंत्रित किया जाता है कि कौन-सा उपयोगकर्ता (User) या समूह (Group) किसी File या Folder पर कौन-सी क्रिया कर सकता है।

2. NTFS Permissions क्या हैं?

NTFS Permissions वे सुरक्षा नियम (Security Rules) हैं जो यह निर्धारित करते हैं कि किसी File या Folder पर कौन-सा User या Group क्या कर सकता है।

इन अनुमतियों के माध्यम से निम्न कार्य नियंत्रित किए जाते हैं—

- File खोलना (Open)
 - File पढ़ना (Read)
 - File लिखना (Write)
 - File संशोधित करना (Modify)
 - File हटाना (Delete)
 - Permission बदलना
 - Ownership बदलना
 - Folder की सामग्री देखना
 - नई File या Folder बनाना
-

सरल उदाहरण

मान लीजिए किसी विद्यालय में तीन प्रकार के लोग हैं—

- Principal
- Teacher
- Student

अब "Exam Paper" नाम का एक Folder है।

उपयोगकर्ता अधिकार

Principal Full Control

Teacher Read एवं Modify

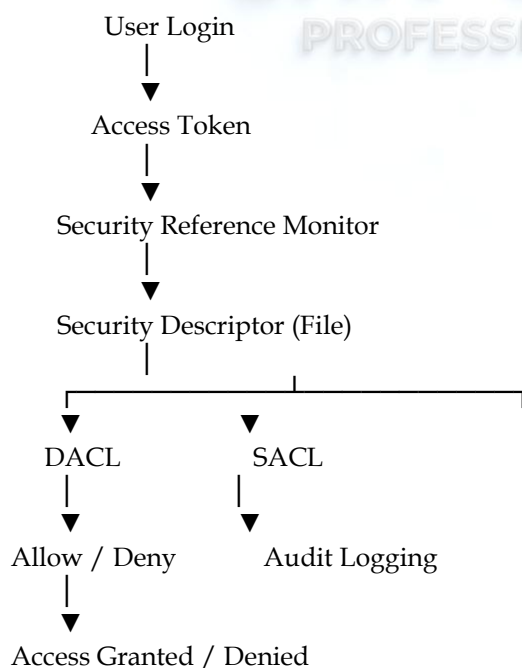
Student Read Only

इसका अर्थ—

- Principal सब कुछ कर सकता है।
- Teacher प्रश्नपत्र पढ़ और संशोधित कर सकता है।
- Student केवल पढ़ सकता है, बदल नहीं सकता।

यही कार्य Windows में NTFS Permissions करती हैं।

3. NTFS Permission Architecture



4. NTFS Permission कैसे कार्य करती है?

जब कोई User किसी File को खोलता है, तब Windows निम्न चरणों का पालन करता है—

चरण 1

User Login करता है।

चरण 2

Windows उस User का Access Token बनाता है।

इस Token में—

- SID
- Group Membership
- Privileges

होते हैं।

चरण 3

Windows उस File का Security Descriptor पढ़ता है।

चरण 4

Security Descriptor की DACL (Discretionary Access Control List) का Access Token से मिलान किया जाता है।

चरण 5

यदि Permission उपलब्ध है—

Access Granted

अन्यथा—

Access Denied

5. NTFS Permission के प्रकार

Microsoft छह Standard Permissions प्रदान करता है।

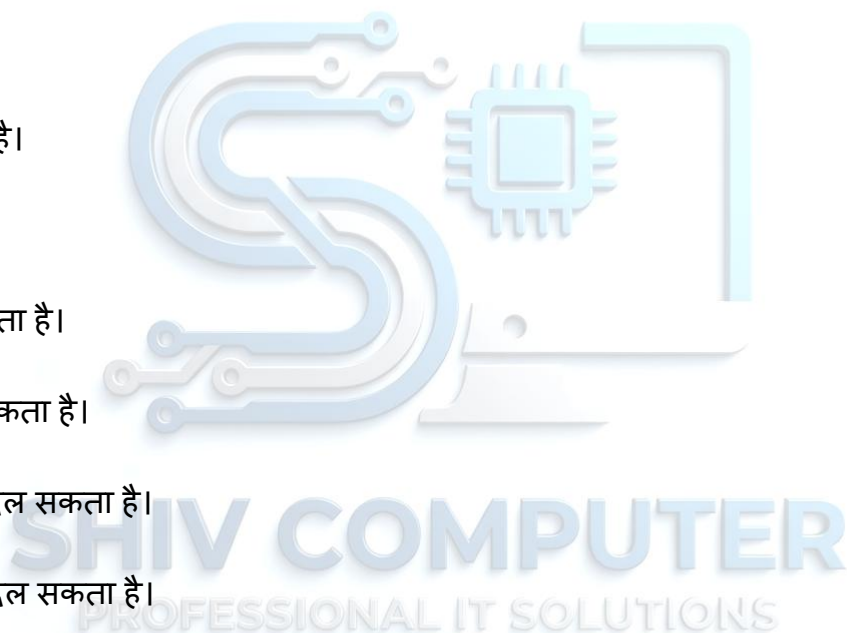
Permission	कार्य
Full Control	पूर्ण नियंत्रण
Modify	संशोधन
Read & Execute	पढ़ना एवं चलाना
List Folder Contents	Folder देखना
Read	केवल पढ़ना
Write	लिखना

6. Full Control

यह सबसे उच्च Permission है।

इसमें User –

- ✓ File पढ़ सकता है।
- ✓ लिख सकता है।
- ✓ Delete कर सकता है।
- ✓ Rename कर सकता है।
- ✓ Permission बदल सकता है।
- ✓ Ownership बदल सकता है।



उदाहरण

Company का Administrator

Salary Folder

पर Full Control रखता है।

वह

- Salary बदल सकता है।
- Folder Delete कर सकता है।

- Permission बदल सकता है।
- नया User जोड़ सकता है।

7. Modify Permission

Modify Permission

User को

- Read
- Write
- Delete

की अनुमति देती है।

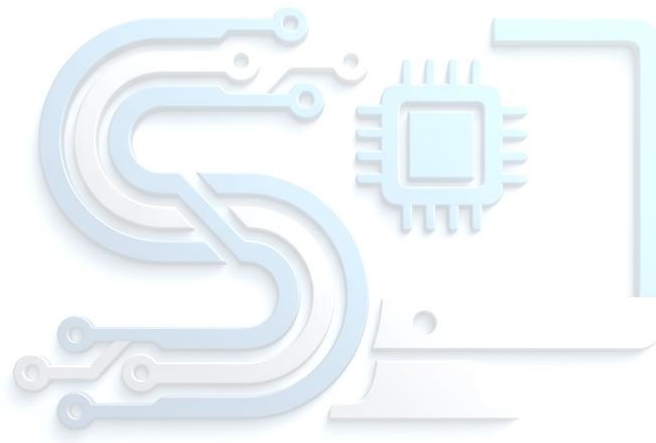
लेकिन

Permission Change

और

Ownership Change

नहीं करने देती।



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

उदाहरण

Teacher

Question Paper

Modify कर सकता है।

लेकिन

Permission

नहीं बदल सकता।

8. Read Permission

User केवल File पढ़ सकता है।

उदाहरण

Library

में रखी PDF

Student

पढ़ सकता है।

लेकिन

Edit नहीं कर सकता।

9. Write Permission

Write Permission

User

नई File बना सकता है।

Data जोड़ सकता है।

लेकिन Delete आवश्यक नहीं कि कर सके।

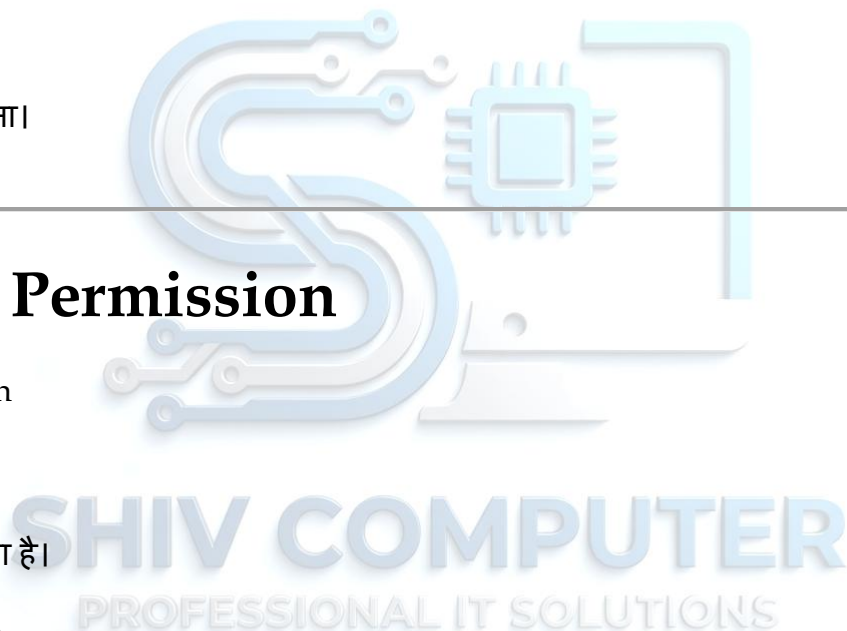
उदाहरण

Student

Assignment Upload

कर सकता है।

लेकिन



10. Read & Execute

यह Permission

Program

चलाने की अनुमति देती है।

उदाहरण

Computer Lab

में

Student

Calculator.exe

चला सकता है।

लेकिन

उस Program में परिवर्तन नहीं कर सकता।



11. List Folder Contents

यह केवल Folder के अंदर की Files देखने की अनुमति देती है।

उदाहरण

Folder

Research

Student

देख सकता है

कि Folder में कौन-कौन सी Files हैं।

लेकिन

Open करना आवश्यक नहीं कि संभव हो।

12. Special Permissions

Windows में Standard Permissions के अतिरिक्त **Special Permissions** भी होती हैं।

इनमें शामिल हैं—

- Traverse Folder
- Execute File
- Delete
- Delete Subfolders
- Read Attributes
- Write Attributes
- Read Extended Attributes
- Write Extended Attributes
- Read Permissions
- Change Permissions
- Take Ownership
- Synchronize



उदाहरण

Administrator

केवल

Take Ownership

Permission

दे सकता है।

13. Allow एवं Deny

Windows

दो प्रकार की Permission रखता है।

Allow

Permission देना।

Deny

Permission रोकना।

उदाहरण

Teacher

को

Read

Allow

दिया गया।

लेकिन

Delete

Deny

दिया गया।

तो

Teacher

Delete नहीं कर पाएगा।



महत्वपूर्ण नियम

यदि

Allow

और

Deny

दोनों हों

तो

Deny सामान्यतः Allow पर प्राथमिकता रखता है।

14. Permission Inheritance

Inheritance

का अर्थ

Parent Folder

की Permission

Child Folder

तक पहुँचना।

उदाहरण

College

|

└─ Faculty

|

└─ Student

|

यदि

College Folder

पर

Read

Permission

दी गई

तो

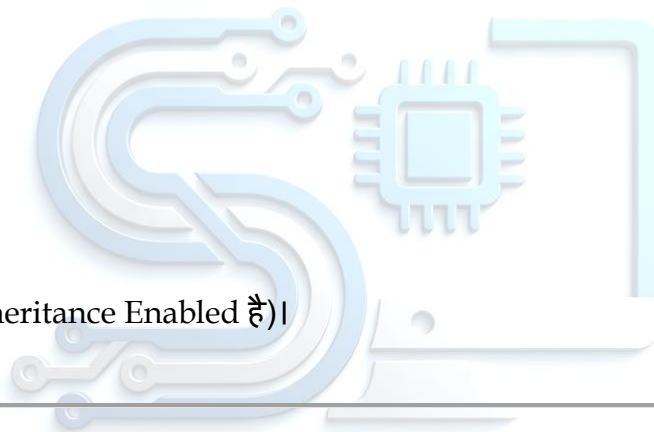
वह सामान्यतः

Faculty

Student

Library

पर भी लागू होगी (यदि Inheritance Enabled है)।



15. Explicit एवं Inherited Permission

Explicit Permission

जो सीधे Object पर लगाई गई हो।

Inherited Permission

जो Parent से प्राप्त हुई हो।

उदाहरण

Folder

Research

पर

Explicit

Modify

दी गई।

Parent

से

Read

मिली।

तो

दोनों लागू हो सकती हैं।

16. Effective Permissions

किसी User की अंतिम Permission को Effective Permission कहते हैं।

यह कई Factors पर निर्भर करती है—

- User की Direct Permission
- Group Membership
- Inheritance
- Deny Entries

उदाहरण

User

Faculty Group

में है।

Faculty Group

को

Modify

Permission है।

User

को व्यक्तिगत रूप से

Read

Permission है।

Effective Permission

Modify

होगी।

17. Ownership

प्रत्येक File का एक Owner होता है।

Owner —

- Permission बदल सकता है।
- Ownership Transfer कर सकता है।

उदाहरण

Administrator

Folder का Owner है।

वह

Permission बदल सकता है।

18. NTFS Permission एवं Share Permission में अंतर

NTFS Permission**Share Permission**

Local एवं Network दोनों पर लागू केवल Network Sharing पर लागू

अधिक विस्तृत नियंत्रण

सीमित नियंत्रण

File एवं Folder दोनों पर

Shared Folder पर

DACL आधारित

Share आधारित

उदाहरण

यदि

Share Permission = Full Control

लेकिन

NTFS = Read

तो

User

केवल Read कर सकेगा।

सबसे प्रतिबंधात्मक (Most Restrictive) प्रभावी अनुमति लागू होती है।

SHIV COMPUTER

19. Digital Forensics में NTFS Permissions

Digital Forensics Investigation में Investigator निम्न प्रश्नों का उत्तर खोजता है—

- File का Owner कौन था?
- Permission किसने बदली?
- किस User को Access था?
- Deny कब लगाया गया?
- कौन-सा Group अनुमति रखता था?
- क्या Permission परिवर्तन किसी सुरक्षा घटना से संबंधित है?

उदाहरण

एक कंपनी में "Salary.xlsx" फ़ाइल लीक हो गई।

जाँच में पाया गया—

- Folder पर "Everyone - Read" Permission गलती से दी गई थी।
- Audit Logs से Permission परिवर्तन का समय ज्ञात हुआ।
- File Owner तथा Group Membership का विश्लेषण किया गया।
- सुरक्षा नीति संशोधित कर Least Privilege लागू किया गया।

20. Enterprise Case Study

एक बैंक में—

- 50,000 कर्मचारी
- 2,000 शाखाएँ
- लाखों संवेदनशील दस्तावेज

Permission Structure —

Finance Folder

- |
- Finance Manager → Full Control
- Accountant → Modify
- Auditor → Read
- Employee → No Access

परिणाम—

- अनधिकृत Access कम हुआ।
- Audit सरल हुआ।
- Regulatory Compliance (जैसे ISO 27001, PCI DSS) सुनिश्चित हुई।

21. NTFS Permission Best Practices

1. **Least Privilege Principle** अपनाएँ।
2. Individual Users की बजाय Groups को Permission दें।
3. "Everyone" को Full Control न दें।

4. Deny का उपयोग केवल आवश्यकता होने पर करें।
5. नियमित Permission Review करें।
6. Sensitive Folders पर Auditing Enable करें।
7. Backup एवं Recovery योजना बनाएँ।
8. Ownership का नियंत्रण सीमित रखें।
9. Inheritance को समझकर ही Disable करें।
10. महत्वपूर्ण Folders की Access Logs नियमित जाँचें।

22. NTFS Permission का सारांश

विषय	विवरण
NTFS Permission	File एवं Folder सुरक्षा
Full Control	पूर्ण अधिकार
Modify	पढ़ना, लिखना, हटाना
Read	केवल पढ़ना
Write	लिखना एवं नई File बनाना
Read & Execute	पढ़ना एवं Program चलाना
List Folder Contents	Folder की सामग्री देखना
Allow	अनुमति देना
Deny	अनुमति रोकना
Inheritance	Parent से Permission प्राप्त करना
Ownership	File का स्वामी
ACL	Permission सूची
DACL	Access Control
SACL	Auditing
Effective Permission	अंतिम लागू Permission

23. निष्कर्ष

NTFS Permissions Windows Security Architecture का एक मूलभूत एवं अत्यंत शक्तिशाली घटक है। यह केवल File Access को नियंत्रित नहीं करती, बल्कि Identity Management, Access Control, Compliance, Auditing और Digital Forensics में भी केंद्रीय भूमिका निभाती है। बड़े Enterprise वातावरण

में सही Permission Design, Group आधारित Access Control, Least Privilege, Auditing और नियमित Permission Review किसी भी संगठन की सूचना सुरक्षा (Information Security) की आधारशिला मानी जाती है। PhD स्तर पर NTFS Permissions का अध्ययन Windows Security Model, Security Descriptors, Access Tokens, ACL Evaluation तथा Digital Forensic Evidence के साथ मिलाकर किया जाता है।



अध्याय : Group Policy (ग्रुप पॉलिसी)

1. परिचय (Introduction)

Group Policy (GPO - Group Policy Object) Microsoft Windows Active Directory की एक अत्यंत महत्वपूर्ण और शक्तिशाली सुविधा (Feature) है, जिसके माध्यम से किसी संगठन (Organization) के सभी Computers तथा Users की **Security Settings, Configuration, Restrictions तथा Administrative Rules** को **केंद्रीय रूप से (Centralized)** नियंत्रित किया जाता है।

सरल शब्दों में—

Group Policy वह प्रणाली है जिसके माध्यम से Administrator एक ही स्थान (Domain Controller) से हजारों Computers और Users पर एक साथ नियम (Policies) लागू कर सकता है।

यदि किसी संगठन में 20,000 Computer हों, तो Administrator प्रत्येक Computer पर जाकर Settings नहीं बदलता, बल्कि Group Policy के माध्यम से सभी Computers पर एक साथ नियम लागू कर देता है।

2. वास्तविक जीवन का उदाहरण

मान लीजिए CSJMU University में—

- 40,000 विद्यार्थी
- 3,000 शिक्षक
- 500 कर्मचारी
- 2,500 Computers
- 4 Campus

विश्वविद्यालय चाहता है—

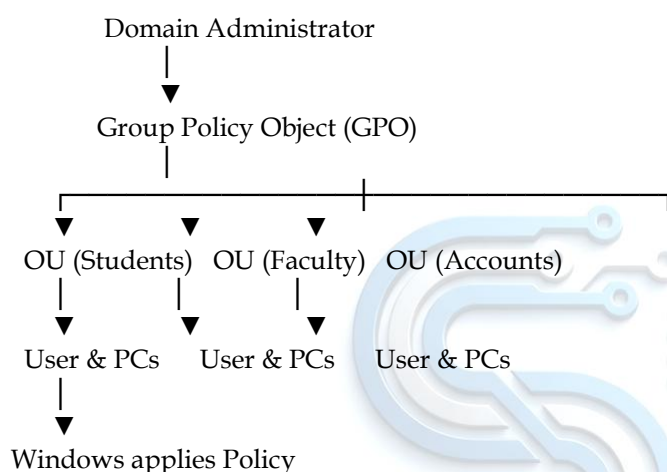
- विद्यार्थी USB Drive का उपयोग न करें।
- सभी Computer पर एक ही Wallpaper दिखाई दे।
- Control Panel बंद रहे।
- CMD और Registry Editor Disable रहें।
- Password कम से कम 14 Characters का हो।
- Screen 10 मिनट बाद Lock हो जाए।

- Windows Defender हमेशा चालू रहे।

यदि ये कार्य प्रत्येक Computer पर अलग-अलग किए जाएँ, तो महीनों लग सकते हैं।

लेकिन Group Policy के माध्यम से Administrator केवल Domain Controller पर Policy बनाता है और वह Policy कुछ समय बाद पूरे Domain में लागू हो जाती है।

3. Group Policy Architecture



4. Group Policy क्या नियंत्रित कर सकती है?

Group Policy द्वारा हजारों Settings नियंत्रित की जा सकती हैं।

मुख्य श्रेणियाँ—

- Password Policy
- Account Lockout Policy
- Desktop Settings
- Start Menu
- Taskbar
- USB Devices
- Printer Settings
- Network Configuration
- Firewall Rules
- Windows Defender
- BitLocker
- Windows Update
- Microsoft Office Settings
- Browser Policies
- Scripts
- Software Deployment

- Folder Redirection
- Security Options
- Audit Policy
- Login Banner
- Remote Desktop
- Power Settings

Windows Server के नवीन संस्करणों में हजारों Policy Settings उपलब्ध हैं।

5. Group Policy Object (GPO)

Group Policy की वास्तविक इकाई (Unit) को Group Policy Object (GPO) कहा जाता है।

एक GPO में अनेक Policies का समूह होता है।

उदाहरण—

Student Lab Policy

↓

USB Disabled

↓

Control Panel Disabled

↓

Wallpaper Fixed

↓

CMD Disabled

↓

Windows Update Controlled

↓

Screen Lock = 10 Minutes



6. Group Policy के प्रकार

मुख्यतः दो प्रकार—

(1) Local Group Policy

यह केवल एक Computer पर लागू होती है।

उदाहरण—

Home PC

gpedit.msc

(2) Domain Group Policy

यह Active Directory Domain के माध्यम से हजारों Computers पर लागू होती है।

उदाहरण—

University

↓

2000 Computers

↓

एक GPO

↓

सभी Computers



7. Local Group Policy

यदि Computer Domain में नहीं है, तब भी Local Group Policy लागू की जा सकती है।

उदाहरण—

Computer Shop

में

Customer

को

USB Disable

8. Domain Group Policy

यह Active Directory आधारित होती है।

उदाहरण—

University.local

|

— Students OU

— Faculty OU

— Library OU

— Accounts OU

Administrator

Student OU

पर अलग Policy

Faculty OU

पर अलग Policy

लागू कर सकता है।



9. Computer Configuration एवं User Configuration

हर GPO दो भागों में विभाजित होती है।

Computer Configuration

Computer पर लागू होने वाली Settings।

जैसे—

- Firewall
- BitLocker
- Windows Update
- Defender
- Drivers
- Startup Scripts

User Configuration

User पर लागू होने वाली Settings।

जैसे—

- Desktop
- Wallpaper
- Start Menu
- Printer
- Folder Redirection
- Office Settings

10. Group Policy Processing

जब Computer Start होता है—

Computer Start

↓

Computer Policy

↓

User Login

↓

User Policy

↓

Desktop Ready

यदि बाद में Policy बदली जाए—

तो Refresh Cycle में नई Policy लागू हो सकती है।

11. Group Policy Refresh

Domain Computers समय-समय पर नई Policies प्राप्त करते हैं।

यदि Administrator कोई नई Security Policy बनाता है, तो Clients उसे Refresh के बाद लागू करते हैं।

उदाहरण

Administrator ने

USB Disable

Policy बनाई।

कुछ समय बाद

सभी Domain Computers पर USB Storage उपयोग नहीं हो पाएगा।

12. Group Policy Inheritance

Policies Parent से Child तक पहुँचती हैं।

Domain

|

└─ Faculty OU

| |

| └─ Professor

| └─ Assistant Professor

यदि Domain पर Password Policy लागू है—

तो सामान्यतः Faculty एवं उसके Child OU पर भी लागू होगी।

13. GPO Link

GPO निम्न स्तरों पर Link की जा सकती है—

- Site
- Domain
- Organizational Unit (OU)

उदाहरण

Library OU

↓

Library GPO

↓

केवल Library Computers

14. GPO Processing Order (LSDOU)

Policies निम्न क्रम में लागू होती हैं—

Local

↓

Site

↓

Domain

↓

Organizational Unit

इसे LSDOU Order कहा जाता है।

यदि दो Policies में टकराव हो, तो बाद में लागू होने वाली Policy सामान्यतः प्राथमिकता प्राप्त करती है (अन्य विशेष सेटिंग्स जैसे Enforced या Block Inheritance को छोड़कर)।

15. Block Inheritance

यदि कोई OU Parent की Policies नहीं लेना चाहता—
तो Block Inheritance उपयोग किया जा सकता है।

उदाहरण

Research Department

अपनी अलग Security Policy चाहता है।

वह Domain की कुछ Policies रोक सकता है।

16. Enforced Policy

यदि Administrator चाहता है कि कोई महत्वपूर्ण Policy हर स्थिति में लागू रहे—
तो उसे Enforced किया जा सकता है।

उदाहरण

Password Policy

को कोई OU Override न कर सके।

17. Security Filtering

सभी Users पर Policy लागू करना आवश्यक नहीं होता।

उदाहरण—

Faculty Group

↓

Policy

↓

Faculty Only

18. Loopback Processing

Computer यह निर्धारित कर सकता है कि User Policy किस आधार पर लागू होगी।

यह सुविधा विशेष रूप से उपयोगी है—

- Computer Labs
 - Libraries
 - Kiosk Systems
 - Examination Centers
-

उदाहरण

Student कहीं से भी Login करे—

Exam Lab में

Exam Policy

ही लागू होगी।



19. Folder Redirection

Documents

Desktop

Downloads

को

Network Server

पर Redirect किया जा सकता है।

लाभ

यदि Computer खराब हो जाए

Data सुरक्षित रहेगा।

उदाहरण

Student Desktop



Server Storage

20. Software Deployment

Administrator

एक Software

पूरे Domain में

स्वचालित रूप से उपलब्ध करा सकता है।

उदाहरण

Adobe Reader



GPO



2000 Computers



Automatic Installation

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

21. Logon एवं Startup Scripts

Administrator Scripts चला सकता है—

- Login पर
 - Logout पर
 - Startup पर
 - Shutdown पर
-

उदाहरण

Login होते ही—

- Network Drive Map
 - Printer Connect
 - Department Folder Mount
-

22. Password Policy

GPO द्वारा नियंत्रित—

- Minimum Length
 - Complexity
 - History
 - Expiration
 - Lockout Threshold
-

उदाहरण

Password

Minimum Length = 14

History = 10

Expiry = 90 Days

23. Audit Policy

Administrator यह निर्धारित करता है कि कौन-कौन सी गतिविधियाँ Log हों।

उदाहरण—

- Login Success
- Login Failure
- File Access
- Account Lockout
- Group Membership Changes

24. Enterprise Case Study

एक राष्ट्रीय बैंक—

- 80,000 कर्मचारी
- 3,500 शाखाएँ
- 120 Domain Controllers

Policies—

- USB Disabled
- BitLocker Mandatory
- Defender Always Enabled
- Firewall Mandatory
- MFA Required (Privileged Users)
- Password 16 Characters
- Audit Enabled
- Office Macros Restricted

परिणाम—

- Malware का जोखिम कम हुआ।
- Data Leakage में कमी आई।
- Compliance मजबूत हुई।

25. Digital Forensics में Group Policy

Forensic Investigation के दौरान यह जाँचा जाता है—

- कौन-सी GPO लागू थी?
- किसने Policy बदली?

- कब बदली?
- किस OU पर लागू थी?
- क्या किसी Policy का दुरुपयोग हुआ?

उदाहरण

यदि किसी घटना के बाद Firewall बंद पाया गया—

Investigator जाँच करेगा—

- क्या GPO बदली गई थी?
- किस Administrator ने बदलाव किया?
- क्या Change Authorized था?

26. Group Policy Best Practices

1. Policies को OU आधारित बनाएँ।
2. एक GPO में बहुत अधिक असंबंधित Settings न रखें।
3. Meaningful Naming Convention अपनाएँ।
4. नियमित GPO Backup लें।
5. Test OU में पहले परीक्षण करें।
6. Delegation का उपयोग करें।
7. नियमित Audit करें।
8. Security Filtering का उचित उपयोग करें।
9. Documentation बनाए रखें।
10. Production में लागू करने से पहले प्रभाव का मूल्यांकन करें।

27. Group Policy का सारांश

विषय	विवरण
Group Policy	केंद्रीकृत Configuration Management
GPO	Policies का समूह
Local GPO	एक Computer

विषय	विवरण
Domain GPO	पूरे Domain पर
Computer Configuration	Computer आधारित Settings
User Configuration	User आधारित Settings
LSDOU	Processing Order
Inheritance	Parent से Child तक Policy
Enforced	अनिवार्य Policy
Block Inheritance	Parent Policy रोकना
Security Filtering	चयनित Users/Groups पर Policy
Loopback Processing	Computer आधारित User Policy
Folder Redirection	User Data को Server पर Redirect करना
Software Deployment	स्वचालित Software वितरण
Audit Policy	Security Event Logging

28. निष्कर्ष

Group Policy आधुनिक Windows Enterprise Administration की सबसे शक्तिशाली तकनीकों में से एक है। यह केवल Desktop Settings बदलने का साधन नहीं है, बल्कि **Security Hardening, Configuration Management, Compliance, Automation, Software Deployment, User Experience Control और Enterprise Governance** का केंद्रीय तंत्र है।

PhD स्तर पर Group Policy का अध्ययन **Active Directory Architecture, Security Descriptors, LDAP, SYSVOL Replication, Client-Side Extensions (CSE), Windows Registry Processing, तथा Enterprise Digital Forensics** के साथ किया जाता है। सही ढंग से डिज़ाइन और प्रबंधित Group Policies किसी भी बड़े संगठन की सुरक्षा, मानकीकरण (Standardization) और संचालन क्षमता (Operational Efficiency) का आधार होती हैं।

अध्याय :

Windows Defender (Microsoft Defender Antivirus)

1. परिचय (Introduction)

Windows Defender, जिसे वर्तमान में Microsoft Defender Antivirus कहा जाता है, Microsoft द्वारा विकसित एक एकीकृत (Integrated) Endpoint Security Solution है, जो Windows Operating System का डिफ़ॉल्ट सुरक्षा तंत्र है। इसका उद्देश्य कंप्यूटर को Virus, Malware, Ransomware, Spyware, Rootkit, Trojan, Worm, Phishing तथा अन्य Cyber Threats से सुरक्षित रखना है।

आधुनिक Windows (Windows 10, Windows 11 तथा Windows Server के नवीन संस्करणों) में Defender केवल Antivirus नहीं है, बल्कि यह एक बहु-स्तरीय (Multi-layered) Endpoint Protection Platform है।

2. Windows Defender का विकास

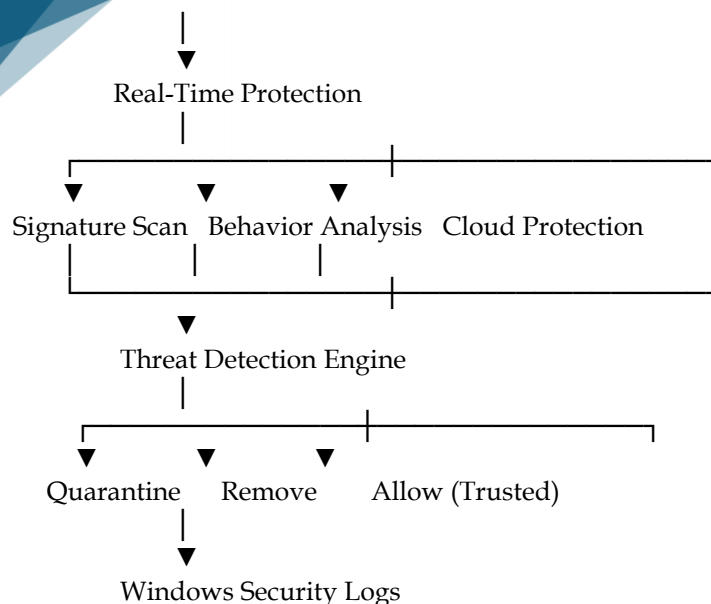
Windows संस्करण Defender की स्थिति

Windows XP	Microsoft AntiSpyware (प्रारंभिक रूप)
Windows Vista	Windows Defender (Anti-Spyware)
Windows 7	सीमित सुरक्षा
Windows 8	पूर्ण Antivirus
Windows 10	Advanced Defender
Windows 11	AI एवं Cloud आधारित सुरक्षा के साथ आधुनिक Defender

आज Microsoft Defender, Microsoft Security Ecosystem (जैसे Microsoft Defender for Endpoint, Microsoft Defender for Identity आदि) का महत्वपूर्ण भाग है।

3. Windows Defender Architecture

User Files



4. Windows Defender के प्रमुख Components

(1) Microsoft Defender Antivirus

- Virus Detection
- Malware Detection
- Trojan Detection
- Worm Detection
- Spyware Protection

(2) Real-Time Protection

यह प्रत्येक File को खोलते समय Scan करता है।

उदाहरण

यदि User USB Drive से कोई File खोलता है—

USB Drive

↓

File Open

↓

Real-Time Scan

↓

यदि सुरक्षित → Open

(3) Cloud Delivered Protection

नई Malware पहचानने के लिए Defender Microsoft Cloud Intelligence का उपयोग करता है।

लाभ

- Zero-Day Threat Detection
- तेज Signature Updates
- AI आधारित विश्लेषण

(4) Automatic Sample Submission

यदि कोई संदिग्ध File मिले—

तो (संगठन की नीति एवं Privacy Settings के अनुसार) उसका विश्लेषण Cloud में भेजा जा सकता है।

5. Virus Detection Process

Unknown File



Hash Generation



Signature Matching



Behavior Analysis



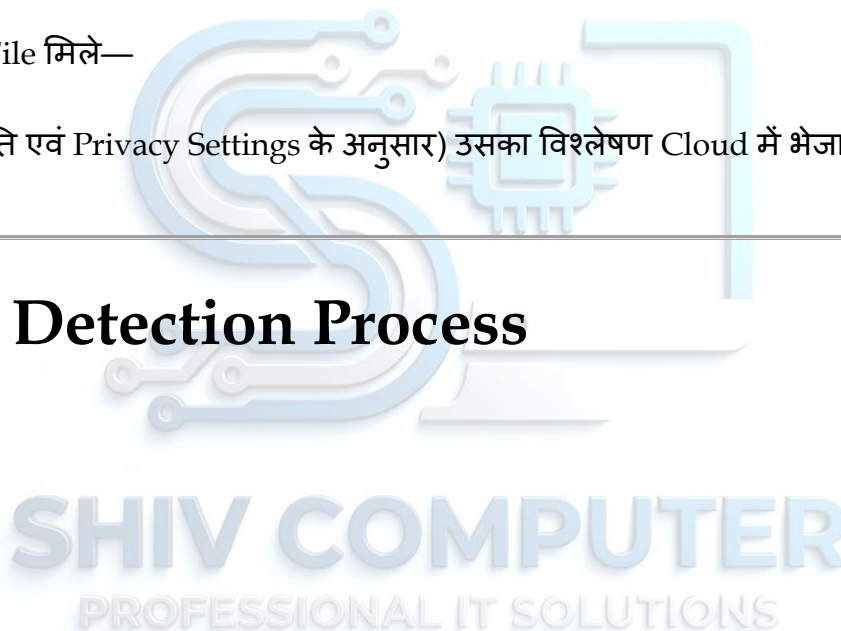
Cloud Intelligence



Decision



Allow / Quarantine / Remove



6. Defender Scanning Types

(A) Quick Scan

- Memory
- Startup Programs
- Running Processes
- महत्वपूर्ण System Locations

समय कम लगता है।

(B) Full Scan

पूरी Hard Disk Scan होती है।

उपयोग—

- Malware Infection
 - Forensic Verification
 - Deep Inspection
-

(C) Custom Scan

User किसी विशेष Folder को Scan कर सकता है।

(D) Microsoft Defender Offline Scan

यदि Rootkit जैसी जटिल Threat का संदेह हो, तो Offline Scan उपयोगी हो सकती है क्योंकि यह सामान्य Windows Session के बाहर Scan करती है।

7. Real-Time Protection

Real-Time Protection हर File Access को Monitor करती है।

उदाहरण—

Download File

↓
Real-Time Scan

↓

Safe

↓

Open

यदि Threat मिले—

Quarantine

8. Behavior-Based Detection

केवल Signature पर्याप्त नहीं होती।

Defender संदिग्ध गतिविधियों का भी विश्लेषण करता है।

उदाहरण—

- कोई Process असामान्य संख्या में Files Encrypt करने लगे।
- कोई Program System Settings में असामान्य परिवर्तन करे।
- कोई Application संदिग्ध Memory Activity करे।

ऐसी गतिविधियाँ अतिरिक्त जाँच का कारण बन सकती हैं।

9. Signature-Based Detection

Malware के ज्ञात Signature Database से तुलना की जाती है।

यदि Signature मेल खाता है—

Threat Found

10. Heuristic Analysis

यदि Malware नया हो—

तो Defender उसके व्यवहार और संरचना का विश्लेषण करता है।

इससे अज्ञात (Unknown) खतरों का भी पता लगाने में सहायता मिलती है।

11. Cloud Intelligence

Microsoft प्रतिदिन करोड़ों Endpoint से प्राप्त Threat Intelligence का विश्लेषण करता है।

यदि किसी नए Malware की पहचान होती है—

तो Cloud आधारित सुरक्षा अन्य Systems को भी शीघ्र सुरक्षा प्रदान कर सकती है।

12. Ransomware Protection

Windows Defender में Controlled Folder Access जैसी सुविधा उपलब्ध है।

उद्देश्य

महत्वपूर्ण Folders को अनधिकृत Modification से बचाना।

उदाहरण

Documents

Pictures

Desktop

Research

↓

Protected Folder

यदि कोई संदिग्ध Program इन Folders में परिवर्तन करना चाहे—

Blocked

13. Firewall Integration

Windows Defender, Windows Defender Firewall के साथ मिलकर कार्य करता है।

यह नियंत्रित करता है—

- Incoming Traffic
- Outgoing Traffic
- Application Rules
- Port Access

14. SmartScreen

SmartScreen उपयोगकर्ता को संभावित रूप से असुरक्षित Websites एवं Downloads के बारे में चेतावनी देता है।

उदाहरण

User कोई संदिग्ध Application Download करता है।

यदि उसकी Reputation संदिग्ध है—

SmartScreen Warning दिखा सकता है।

15. Tamper Protection

Tamper Protection यह सुनिश्चित करती है कि सामान्य उपयोगकर्ता या Malware आसानी से Defender की महत्वपूर्ण सुरक्षा Settings न बदल सकें।

16. Windows Defender Security Components

Component	कार्य
Antivirus	Virus Detection
Firewall	Network Protection
SmartScreen	Web Protection
Controlled Folder Access	Ransomware Protection
Cloud Protection	AI आधारित Detection
Tamper Protection	Security Settings की रक्षा
Offline Scan	Boot-Level Malware Detection

17. Windows Defender एवं Group Policy

Enterprise में Administrator Group Policy द्वारा Defender नियंत्रित कर सकता है।

उदाहरण—

- Real-Time Protection की नीति
- Scheduled Scan
- Cloud Protection Configuration
- Exclusions
- Controlled Folder Access
- Scan Schedule

18. Windows Defender एवं PowerShell

PowerShell का उपयोग Defender की स्थिति देखने, Configuration प्रबंधित करने तथा Enterprise Automation के लिए किया जा सकता है।

उदाहरण के उपयोग—

- वर्तमान सुरक्षा स्थिति की जाँच
- Scan आरंभ करना
- Policy Compliance की पुष्टि

(उत्पादन वातावरण में केवल अधिकृत Administrator द्वारा।)

19. Windows Defender Logs

Defender विभिन्न Security Events रिकॉर्ड करता है।

इनमें शामिल हो सकते हैं—

- Malware Detection
- Quarantine Events
- Scan Results
- Update Status
- Protection Status

20. Digital Forensics में Windows Defender

Forensic Investigator निम्न बिंदुओं का विश्लेषण करता है—

- Threat Detection History
- Scan Reports
- Quarantine Records
- Security Event Logs
- Windows Event Logs
- Timeline Analysis

उदाहरण

यदि किसी कंप्यूटर पर Malware मिला—

Investigator जाँच करेगा—

- Malware पहली बार कब Detect हुआ?
- किस File में मिला?
- क्या उसे Quarantine किया गया?
- क्या User ने उसे Restore किया?
- Detection के समय कौन-सा User Logged-in था?

21. Enterprise Case Study

एक राष्ट्रीय बैंक—

- 90,000 कर्मचारी
- 4,000 शाखाएँ
- 60,000 Windows Endpoints

सुरक्षा व्यवस्था—

- Microsoft Defender Antivirus
- Windows Defender Firewall
- Controlled Folder Access

- BitLocker
- Group Policy द्वारा केंद्रीकृत Configuration
- Microsoft Defender for Endpoint (EDR)
- SIEM Integration

परिणाम—

- Malware Detection में सुधार
- Ransomware जोखिम में कमी
- तेज Incident Response
- केंद्रीकृत Monitoring

22. Windows Defender Best Practices

1. Real-Time Protection हमेशा Enabled रखें।
2. Cloud-Delivered Protection सक्रिय रखें।
3. Security Intelligence (Definitions) नियमित Update करें।
4. नियमित Quick एवं Full Scans की योजना बनाएँ।
5. Controlled Folder Access का उपयोग करें।
6. Tamper Protection सक्षम रखें।
7. Group Policy द्वारा केंद्रीकृत प्रबंधन करें।
8. Logs की नियमित समीक्षा करें।
9. Defender को SIEM/EDR के साथ एकीकृत करें।
10. केवल विश्वसनीय Applications को ही Exclusions में जोड़ें।

23. Windows Defender एवं अन्य सुरक्षा तकनीकों का संबंध

तकनीक

Windows Defender

BitLocker

Group Policy

Active Directory

Windows Firewall

Microsoft Defender for Endpoint EDR एवं Advanced Threat Detection

भूमिका

Endpoint Protection

Disk Encryption

Centralized Configuration

Identity Management

Network Security

24. शोध (PhD) के प्रमुख विषय

Windows Defender पर उन्नत शोध के प्रमुख क्षेत्र—

1. AI आधारित Malware Detection
2. Machine Learning द्वारा Behavioral Analysis
3. Zero-Day Threat Detection
4. Cloud-Assisted Security Intelligence
5. Defender Telemetry Analysis
6. EDR एवं XDR Architectures
7. Ransomware Detection Models
8. Memory-Based Malware Detection
9. Threat Hunting Frameworks
10. Enterprise Endpoint Security Optimization

25. निष्कर्ष

Windows Defender आधुनिक Windows पारिस्थितिकी (Ecosystem) का एक व्यापक Endpoint Security Platform है। यह केवल Virus Detection तक सीमित नहीं है, बल्कि **Real-Time Protection, Behavior Analysis, Cloud Intelligence, Ransomware Protection, Firewall Integration, SmartScreen, Tamper Protection** तथा **Enterprise Security Management** जैसी बहु-स्तरीय सुरक्षा प्रदान करता है।

PhD स्तर पर Windows Defender का अध्ययन **Windows Security Architecture, Endpoint Detection and Response (EDR), Threat Intelligence, Digital Forensics, Malware Analysis, Artificial Intelligence आधारित Detection Models** तथा **Enterprise Incident Response** के साथ किया जाता है। किसी भी आधुनिक Enterprise Security Framework में Windows Defender एक महत्वपूर्ण रक्षात्मक (Defensive) घटक के रूप में स्थापित है।

अध्याय :

BitLocker Drive Encryption (बिटलॉकर ड्राइव एन्क्रिप्शन)

1. परिचय (Introduction)

BitLocker Drive Encryption Microsoft द्वारा विकसित एक **Full Disk Encryption (FDE)** तकनीक है, जिसका उद्देश्य Computer, Laptop, Server अथवा Portable Storage Device पर संग्रहीत डेटा को **अनधिकृत (Unauthorized) Access** से सुरक्षित रखना है।

यदि कोई व्यक्ति Computer या Hard Disk चुरा ले, तो सामान्य स्थिति में वह दूसरी मशीन में Disk लगाकर डेटा पढ़ सकता है। BitLocker इस जोखिम को समाप्त करता है क्योंकि Disk पर संग्रहीत पूरा डेटा **एन्क्रिप्टेड (Encrypted)** होता है। सही Recovery Key, TPM या Authentication के बिना डेटा पढ़ना अत्यंत कठिन होता है।

सरल शब्दों में: BitLocker हार्ड डिस्क पर संग्रहीत डेटा को इस प्रकार एन्क्रिप्ट करता है कि यदि Disk चोरी हो जाए या किसी अन्य Computer में लगाई जाए, तो बिना वैध Authentication के डेटा उपयोग योग्य नहीं रहता।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

2. BitLocker की आवश्यकता

आज अधिकांश साइबर घटनाएँ केवल नेटवर्क हमलों से नहीं होतीं, बल्कि **Laptop Theft, Lost Devices, Insider Threat** और **Physical Access Attack** के कारण भी संवेदनशील डेटा लीक हो जाता है।

BitLocker इन जोखिमों को कम करने के लिए बनाया गया है।

वास्तविक उदाहरण

एक बैंक के अधिकारी का Laptop यात्रा के दौरान चोरी हो गया।

Laptop में—

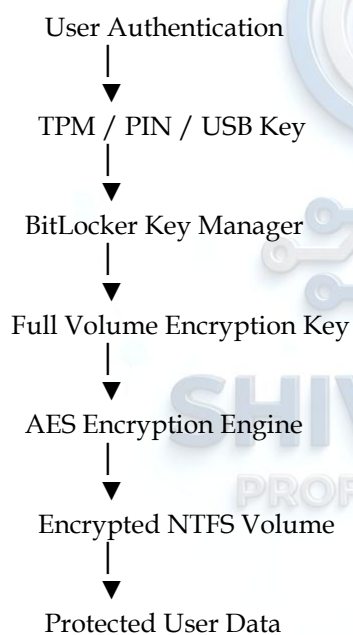
- ग्राहकों का डेटा
- वित्तीय रिपोर्ट
- Password Database
- Confidential Documents

संग्रहीत थे।

यदि BitLocker सक्षम नहीं होता, तो हमलावर Hard Disk निकालकर किसी अन्य Computer में लगाकर डेटा पढ़ सकता था।

लेकिन BitLocker सक्षम होने के कारण पूरी Disk एन्क्रिप्टेड थी और डेटा सुरक्षित रहा।

3. BitLocker Architecture



4. BitLocker कैसे कार्य करता है?

BitLocker केवल File को Encrypt नहीं करता, बल्कि पूरे Volume (Partition) को Encrypt करता है।

कार्य प्रक्रिया—

1. BitLocker चालू किया जाता है।
2. Encryption Key बनाई जाती है।
3. Volume Encryption Key (VEK) तैयार होती है।

4. Full Volume Encrypt होता है।
5. Boot के समय Authentication होता है।
6. सफल Authentication के बाद Disk Transparent रूप से उपलब्ध हो जाती है।

5. Encryption क्या है?

Encryption वह प्रक्रिया है जिसमें सामान्य (Plaintext) डेटा को गणितीय Algorithm द्वारा अपठनीय (Ciphertext) बना दिया जाता है।

उदाहरण—

Original Data

Salary = ₹85,000

Encryption के बाद—

A7F91CBB4D8E2A.....

यह Ciphertext कहलाता है।

सही Key के बिना इसे समझना संभव नहीं होता।

6. BitLocker के प्रमुख Components

Component	कार्य
TPM	Secure Key Storage
Volume Master Key (VMK)	Master Encryption Key
Full Volume Encryption Key (FVEK)	Disk Encryption Key
Recovery Key	आपातकालीन Unlock
BitLocker Metadata	Encryption Configuration

7. Trusted Platform Module (TPM)

TPM एक Hardware Security Chip है जो Motherboard पर होती है।

इसका कार्य—

- Encryption Keys सुरक्षित रखना।
- Boot की Integrity जाँचना।
- Secure Boot में सहायता करना।
- Hardware आधारित सुरक्षा प्रदान करना।

उदाहरण

Computer Start

↓

TPM Check

↓

Boot Integrity Verified

↓

BitLocker Unlock

↓

Windows Start

यदि Boot Files में अनधिकृत परिवर्तन मिले, तो TPM सामान्य Unlock प्रक्रिया को रोक सकता है और Recovery की आवश्यकता हो सकती है।

8. TPM के बिना BitLocker

यदि Computer में TPM उपलब्ध नहीं है, तो भी BitLocker का उपयोग कुछ परिस्थितियों में किया जा सकता है।

Authentication के विकल्प—

- USB Startup Key
- Password
- Recovery Key

हालाँकि TPM आधारित सुरक्षा सामान्यतः अधिक मजबूत मानी जाती है।

9. BitLocker Authentication Methods

(A) TPM Only

केवल TPM द्वारा Unlock।

(B) TPM + PIN

TPM के साथ User PIN भी दर्ज करता है।

(C) TPM + USB Key

TPM और USB Startup Key दोनों आवश्यक।

(D) Password Based

मुख्यतः Data Drives के लिए।

(E) Recovery Key

आपातकालीन स्थिति में उपयोग।

10. Encryption Algorithms

BitLocker आधुनिक Windows संस्करणों में मजबूत Encryption Algorithms का उपयोग करता है।

उदाहरण—

- AES 128-bit
- AES 256-bit

Enterprise वातावरण में संगठन अपनी सुरक्षा नीति के अनुसार उपयुक्त विकल्प चुन सकते हैं।

11. BitLocker Encryption Process

Hard Disk



Sector Read



Encryption Engine



AES Encryption



Encrypted Sector



Write Back

पूरा Volume क्रमशः Encrypt होता है।

12. BitLocker Recovery Key

Recovery Key एक विशेष सुरक्षा कुंजी होती है।

यह सामान्यतः 48-अंकों की Recovery Key के रूप में उपलब्ध होती है।

उदाहरण

Recovery Key

123456-234567-345678-...

यदि—

- TPM Failure
- Motherboard Replacement
- Boot Configuration Change
- PIN भूल जाना

जैसी स्थिति हो, तो Recovery Key की आवश्यकता पड़ सकती है।

13. BitLocker और Active Directory

Enterprise वातावरण में Administrator Recovery Keys को सुरक्षित रूप से Active Directory में Backup कर सकता है।

उदाहरण

Laptop



BitLocker Enabled



Recovery Key



Active Directory

यदि User Key भूल जाए—

Administrator Directory से Recovery जानकारी प्राप्त कर सकता है (उचित अधिकारों के साथ)।

14. BitLocker और Microsoft Entra ID

Hybrid एवं Cloud आधारित वातावरण में Recovery Keys को Microsoft Entra ID (पूर्व Azure AD) से भी संबद्ध किया जा सकता है।

15. BitLocker और Group Policy

Administrator Group Policy द्वारा नियंत्रित कर सकता है—

- TPM आवश्यक हो या नहीं।
- Encryption Algorithm।
- Recovery Key Storage।
- PIN Length।
- Removable Drive Encryption।
- Fixed Drive Encryption।
- Operating System Drive Policies।

16. BitLocker और USB Drives (BitLocker To Go)

BitLocker केवल Internal Drive ही नहीं, बल्कि USB Flash Drive और External Hard Disk को भी Encrypt कर सकता है।

इसे BitLocker To Go कहा जाता है।

उदाहरण

Research Data



USB Drive



BitLocker To Go



Password Protected

यदि USB खो जाए, तो डेटा सुरक्षित रहेगा।



17. BitLocker और Secure Boot

Secure Boot और BitLocker मिलकर Boot Chain की सुरक्षा को मजबूत करते हैं।

Power On



UEFI Firmware



Secure Boot Verification



TPM Validation



BitLocker Unlock



Windows Boot

यदि Boot Files में छेड़छाड़ का संदेह हो, तो Recovery प्रक्रिया प्रारंभ हो सकती है।

18. Digital Forensics में BitLocker

BitLocker Forensic Investigation को चुनौतीपूर्ण बना सकता है क्योंकि डेटा एन्क्रिप्टेड होता है।

Forensic Investigator निम्न बातों का विश्लेषण करता है—

- क्या Drive Encrypt थी?
- Recovery Key उपलब्ध है?
- TPM की स्थिति क्या थी?
- Boot Configuration में परिवर्तन हुआ था?
- Memory Acquisition के दौरान Unlock Keys उपलब्ध थीं या नहीं?

वास्तविक उदाहरण

एक Corporate Laptop चोरी हो गया।

जाँच में—

- Laptop BitLocker Protected था।
- Recovery Key सुरक्षित रूप से Directory में उपलब्ध थी।
- Data Leakage का कोई प्रमाण नहीं मिला क्योंकि Drive एन्क्रिप्टेड थी।

19. Enterprise Case Study

एक बहुराष्ट्रीय कंपनी—

- 80,000 कर्मचारी
- 45 देशों में कार्यालय
- 60,000 Laptops

Security Policy –

- सभी Laptops पर BitLocker अनिवार्य।
- TPM 2.0 आवश्यक।
- Recovery Key Active Directory में Backup।
- PIN आधारित Authentication।
- Group Policy द्वारा केंद्रीकृत प्रबंधन।
- नियमित Compliance Audit।

परिणाम—

- Lost Device Incidents में Data Exposure लगभग समाप्त।
- Compliance (ISO 27001, GDPR आदि) में सुधार।
- Physical Theft से डेटा सुरक्षा मजबूत।

20. BitLocker बनाम EFS (Encrypting File System)

BitLocker

EFS

पूरे Drive को Encrypt करता है केवल चयनित Files/Folders को Encrypt करता है
Full Disk Encryption File-Level Encryption

TPM के साथ कार्य कर सकता है User Certificate आधारित

Physical Theft से बेहतर सुरक्षा File Sharing पर अधिक केंद्रित

21. BitLocker की सीमाएँ

- Recovery Key का सुरक्षित प्रबंधन आवश्यक।
- Drive Unlock होने के बाद अधिकृत User द्वारा Access सामान्य रूप से संभव होता है।
- यह Malware Protection का विकल्प नहीं है।
- Backup एवं Key Management के बिना Recovery कठिन हो सकती है।

22. Best Practices

1. TPM 2.0 का उपयोग करें।
2. Recovery Key को सुरक्षित स्थान पर Backup करें।
3. Enterprise में Recovery Key को Active Directory या Microsoft Entra ID में सुरक्षित रखें।
4. Strong PIN का उपयोग करें (जहाँ लागू हो)।
5. Group Policy द्वारा केंद्रीकृत Configuration करें।
6. Secure Boot सक्षम रखें।
7. नियमित Backup लें।
8. Encryption Status का समय-समय पर Audit करें।
9. Unauthorized BIOS/UEFI Changes को नियंत्रित करें।
10. Lost Device Response Policy तैयार रखें।

23. शोध (PhD) के प्रमुख विषय

BitLocker पर उन्नत शोध के क्षेत्र—

1. Full Disk Encryption Performance Analysis
2. TPM Security एवं Hardware Trust
3. Post-Quantum Disk Encryption
4. BitLocker Forensic Challenges
5. Memory-Based Key Recovery Research
6. Enterprise Key Management
7. Secure Boot एवं Measured Boot का विश्लेषण
8. AI आधारित Encryption Compliance Monitoring
9. Hybrid Cloud Key Management
10. Hardware Security Module (HSM) Integration

24. सारांश

विषय

BitLocker

TPM

VMK

FVEK

Recovery Key

विवरण

Full Disk Encryption

Hardware आधारित Key Protection

Volume Master Key

Full Volume Encryption Key

Emergency Unlock

विषय**विवरण**

BitLocker To Go

USB एवं External Drive Encryption

Group Policy

Centralized BitLocker Management

Active Directory Integration

Recovery Key Backup

Microsoft Entra ID Integration Cloud आधारित Recovery

Secure Boot

Boot Integrity Protection

25. निष्कर्ष

BitLocker आधुनिक Windows सुरक्षा तंत्र का एक अत्यंत महत्वपूर्ण घटक है, जो **Full Disk Encryption, Hardware आधारित Key Protection, TPM Integration, Secure Boot, Enterprise Key Management, तथा Recovery Infrastructure** के माध्यम से संवेदनशील डेटा को Physical Theft और Unauthorized Access से सुरक्षित रखता है।

PhD स्तर पर BitLocker का अध्ययन केवल Drive Encryption तक सीमित नहीं है, बल्कि इसमें **Cryptography, Trusted Computing, TPM Architecture, Key Lifecycle Management, Digital Forensics, Enterprise Compliance, Incident Response तथा Zero Trust Security Architecture** का भी गहन विश्लेषण शामिल होता है। Enterprise Cyber Security में BitLocker को Data-at-Rest Protection की आधारभूत तकनीकों में से एक माना जाता है।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय :

Windows Event Logs (विंडोज़ इवेंट लॉग्स)

1. परिचय (Introduction)

Windows Event Logs Windows Operating System का एक अत्यंत महत्वपूर्ण **Logging एवं Monitoring Framework** है, जिसका उद्देश्य कंप्यूटर में होने वाली प्रत्येक महत्वपूर्ण गतिविधि (Activity) का रिकॉर्ड (Record) सुरक्षित रूप से संग्रहीत करना है।

ये Logs केवल सामान्य त्रुटियों (Errors) को रिकॉर्ड नहीं करते, बल्कि—

- User Login
- User Logout
- File Access
- Driver Loading
- Software Installation
- Windows Update
- Security Events
- Network Activity
- Application Errors
- System Crash
- Power Failure
- Service Start/Stop
- USB Device Connection
- Group Policy Processing
- Active Directory Authentication

जैसी हजारों घटनाओं का विवरण भी सुरक्षित रखते हैं।

Windows Event Logs का महत्व

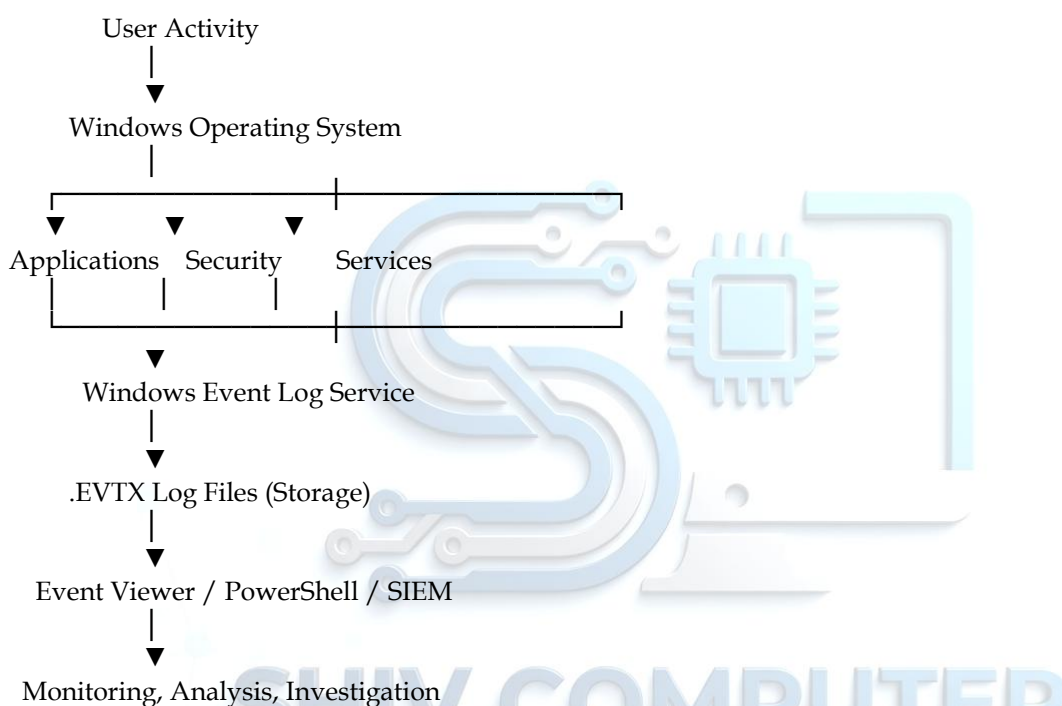
Windows Event Logs निम्न क्षेत्रों में अत्यंत महत्वपूर्ण हैं—

- System Administration
- Cyber Security Monitoring
- Digital Forensics
- Incident Response
- Threat Hunting
- Malware Analysis

- Compliance Audit
- SOC (Security Operations Center)
- SIEM (Security Information and Event Management)

Windows Event Logs को Windows Operating System की "डिजिटल डायरी (Digital Diary)" कहा जाता है, क्योंकि यह सिस्टम में होने वाली लगभग प्रत्येक महत्वपूर्ण घटना का कालानुक्रमिक (Chronological) रिकॉर्ड रखती है।

2. Windows Event Logging Architecture



3. Event Logging Process

जब कोई घटना होती है—

उदाहरण—

User Login करता है।

Windows

↓

Authentication Process

↓

Security Subsystem

↓
Event Generate



Event Log Service



EVTX File



Event Viewer

वास्तविक उदाहरण

Rahul



Login



Password Verified



Authentication Success



Security Event Generated



Security Log में रिकॉर्ड



4. Event Viewer क्या है?

Event Viewer (eventvwr.msc) Windows का Built-in Tool है, जिसके माध्यम से Administrator एवं Forensic Investigator सभी Event Logs को देख सकते हैं।

5. Event Viewer की मुख्य Categories

Windows Logs

|

— Application

— Security

— Setup

— System

— Forwarded Events

— Custom Views

6. Application Log

इसमें Application से संबंधित घटनाएँ होती हैं।

उदाहरण—

- Microsoft Office Error
- Adobe Crash
- SQL Server Error
- Browser Error

वास्तविक उदाहरण

यदि Microsoft Word अचानक बंद हो जाए

तो

Application Log

में Crash Information मिलेगी।

7. Security Log

यह सबसे महत्वपूर्ण Log है।

इसमें Security संबंधी घटनाएँ होती हैं।

उदाहरण—

- Login Success
- Login Failure
- Password Change
- User Creation
- Group Membership Change
- File Access
- Privilege Use
- Account Lockout

वास्तविक उदाहरण

User

Administrator

ने रात

02:10

पर Login किया।

Security Log

में पूरा विवरण मिलेगा।



8. System Log

System Components से संबंधित घटनाएँ—

- Driver Loading
- Service Start
- Service Stop
- Hardware Error
- Disk Error
- Boot Process

उदाहरण

यदि Hard Disk Failure हो

तो

System Log

में Error दर्ज होगा।

9. Setup Log

Windows Installation

Update

Patch Installation

का विवरण।

10. Forwarded Events

यदि अनेक Computers के Logs

एक Central Server

पर भेजे जाएँ

तो

वे यहाँ दिखाई देते हैं।

11. Event ID

Windows प्रत्येक घटना को एक Unique Event ID प्रदान करता है।

उदाहरण—

Event ID सामान्य अर्थ

4624 सफल Login (Successful Logon)

Event ID सामान्य अर्थ

4625	असफल Login (Failed Logon)
4634	Logoff
4648	Explicit Credentials का उपयोग
4672	विशेष Privileges के साथ Logon
4720	नया User Account बनाया गया
4722	User Account Enabled
4725	User Account Disabled
4726	User Account Deleted
4728	User को Security Group में जोड़ा गया
4732	Local Group Membership बदली
4740	Account Lockout
4768	Kerberos TGT Request
4769	Kerberos Service Ticket
4771	Kerberos Authentication Failure
4776	NTLM Authentication
1102	Security Log Cleared

नोट: Event IDs Windows संस्करण, Audit Policy और भूमिका (Client/Server/Domain Controller) के अनुसार भिन्न हो सकते हैं।

12. Event Structure

प्रत्येक Event में निम्न जानकारी होती है—

Event ID

Time

Date

User

Computer Name

Source

Task Category

Keywords

Level

Description

उदाहरण

Event ID : 4624

User : Shiv Kumar

Time : 09:45 AM

Computer : LAB-PC-12

Result : Login Success

13. Event Levels

Level	अर्थ
Information	सामान्य सूचना
Warning	संभावित समस्या
Error	त्रुटि
Critical	गंभीर समस्या
Verbose	विस्तृत Diagnostic जानकारी

14. Security Auditing

Windows दो प्रकार की Auditing करता है।

Success Audit

कार्य सफल रहा।

Failure Audit

कार्य असफल रहा।

उदाहरण

Password सही

↓

Success Audit



Failure Audit

15. EVTX File Format

Windows आधुनिक Event Logs को .evtx फॉर्मेट में संग्रहीत करता है।

सामान्य स्थान—

C:\Windows\System32\winevt\Logs\

उदाहरण—

Security.evtx

System.evtx

Application.evtx

16. Event Log Retention

Administrator निर्धारित कर सकता है—

- Maximum Log Size
 - Overwrite Policy
 - Archive
 - Manual Backup
-

17. Windows Event Forwarding (WEF)

Enterprise में हजारों Computers के Logs

एक Central Collector

को भेजे जा सकते हैं।

PC1

PC2

PC3

↓
Windows Event Collector

↓

SIEM

↓

SOC

18. Windows Event Logs एवं Active Directory

Domain Controller

निम्न Events रिकॉर्ड करता है—

- Kerberos Authentication
 - NTLM Login
 - Group Membership Changes
 - Password Reset
 - Domain Join
 - GPO Processing
-

उदाहरण

नया User

Rahul

Domain में जोड़ा गया।

Security Log

में User Creation Event दर्ज होगा।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

19. Windows Event Logs एवं Group Policy

यदि Group Policy लागू होती है—

तो उसका परिणाम संबंधित Operational Logs तथा Group Policy Processing Events में रिकॉर्ड हो सकता है।

उदाहरण

USB Disable Policy



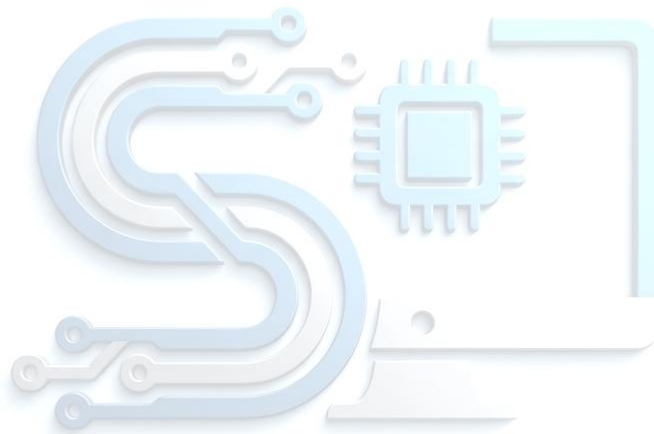
Client Policy Refresh



Policy Applied



Event Generated



20. Windows Event Logs एवं Windows Defender

Defender निम्न Events रिकॉर्ड कर सकता है—

- Malware Detection
- Scan Started
- Scan Completed
- Threat Removed
- Quarantine Action
- Signature Update

21. Windows Event Logs एवं BitLocker

- Encryption Started
- Encryption Completed
- Recovery Requested
- TPM Validation
- Unlock Events

22. Digital Forensics में Windows Event Logs

Forensic Investigation में Event Logs सबसे महत्वपूर्ण Digital Evidence होते हैं।

Investigator निम्न प्रश्नों के उत्तर खोजता है—

- Login कब हुआ?
- किस User ने किया?
- Failed Login कितने हुए?
- USB कब जोड़ी गई?
- नया User कब बना?
- Group Policy कब बदली?
- Defender ने Malware कब Detect किया?
- BitLocker Recovery कब हुई?

23. Timeline Analysis

Forensic Timeline का उदाहरण—

08:00 Login

08:05 USB Connected

08:08 File Copied

08:15 PowerShell Started

08:20 Defender Alert

08:25 Account Disabled

यह Timeline पूरी घटना को समझने में सहायता करती है।

24. Enterprise Case Study

एक बहुराष्ट्रीय कंपनी में रात 1:45 बजे असामान्य गतिविधि देखी गई।

जाँच में—

- Event ID 4625 (लगातार Failed Login)
- फिर Event ID 4624 (Successful Login)
- उसके बाद Privileged Group Membership में परिवर्तन
- PowerShell Execution
- Windows Defender Alert
- Firewall Rule Change

इन सभी Logs का Correlation कर Incident Response Team ने समझा कि एक अधिकृत खाते का दुरुपयोग हुआ था और समय रहते कार्रवाई की गई।

25. SIEM Integration

Enterprise वातावरण में Windows Event Logs को SIEM में भेजा जाता है।

Windows Logs



Windows Event Forwarding



SIEM



Correlation Engine



SOC Analyst



Incident Response

26. Threat Hunting

Threat Hunters निम्न संकेतों की खोज करते हैं—

- बार-बार Failed Login
 - Unusual Login Time
 - Administrator Group Changes
 - Log Clearing (जैसे Event ID 1102)
 - PowerShell का असामान्य उपयोग
 - Service Installation
 - Driver Loading
 - Scheduled Task Creation
-

27. शोध (PhD) के प्रमुख विषय

Windows Event Logs पर उन्नत शोध के क्षेत्र—

1. AI आधारित Log Analysis
 2. Machine Learning द्वारा Anomaly Detection
 3. SIEM Correlation Optimization
 4. Insider Threat Detection
 5. Log Tampering Detection
 6. Behavioral Analytics
 7. Windows Event Graph Analysis
 8. Cloud एवं Hybrid Event Correlation
 9. Automated Incident Response
 10. Digital Forensic Timeline Reconstruction
-

28. Windows Event Logs Best Practices

1. Advanced Audit Policy सक्षम करें।
 2. Log Size पर्याप्त रखें।
 3. महत्वपूर्ण Logs का नियमित Backup लें।
 4. Windows Event Forwarding लागू करें।
 5. SIEM Integration करें।
 6. Log Clearing Events की निगरानी करें।
 7. Time Synchronization (NTP) सुनिश्चित करें।
 8. Least Privilege लागू करें।
 9. नियमित Log Review करें।
 10. Forensic Readiness Policy बनाएँ।
-

29. सारांश

विषय	विवरण
Event Viewer	Log देखने का Tool
Application Log	Application Events
Security Log	Authentication एवं Security
System Log	OS एवं Hardware
Setup Log	Installation एवं Updates
EVTX	Event Log File Format
Event ID	घटना की पहचान
Success Audit	सफल गतिविधि
Failure Audit	असफल गतिविधि
WEF	Windows Event Forwarding
SIEM	Log Correlation
Timeline Analysis	घटना का कालक्रम
Digital Forensics	Evidence Analysis

30. निष्कर्ष

Windows Event Logs Windows सुरक्षा संरचना का केंद्रीय (Core) घटक हैं। ये केवल Error Messages का संग्रह नहीं हैं, बल्कि **Authentication, Authorization, System Health, Group Policy Processing, Active Directory Operations, Windows Defender Alerts, BitLocker Events** तथा **Security Auditing** का विस्तृत रिकॉर्ड प्रदान करते हैं।

PhD स्तर पर Windows Event Logs का अध्ययन **Digital Forensics, Threat Hunting, Incident Response, SIEM Engineering, SOC Operations, Malware Investigation, MITRE ATT&CK Mapping**, तथा **Enterprise Security Analytics** के संदर्भ में किया जाता है। किसी भी आधुनिक Cyber Security Infrastructure में Windows Event Logs सबसे महत्वपूर्ण **Digital Evidence Source** और **Security Telemetry** माने जाते हैं, क्योंकि वे किसी भी सुरक्षा घटना के वैज्ञानिक विश्लेषण और पुनर्निर्माण (Forensic Reconstruction) का आधार प्रदान करते हैं।

अध्याय :

Sysinternals Suite (सिसइंटरनल्स सूट)

1

विषय (Introduction)

27. **Sysinternals Suite** Microsoft द्वारा विकसित एक अत्यंत उन्नत (Advanced) Windows System Utilities का संग्रह (Collection) है, जिसका उपयोग **System Administration, Windows Internals Analysis, Digital Forensics, Malware Investigation, Incident Response, Performance Analysis** तथा **Cyber Security Research** में किया जाता है।

इसका विकास **Mark Russinovich** एवं **Bryce Cogswell** ने 1996 में किया था। बाद में Microsoft ने Sysinternals को अधिग्रहित कर इसे Windows के आधिकारिक Diagnostic Tools का हिस्सा बना दिया।

PhD स्तर पर Sysinternals केवल Tools का संग्रह नहीं है, बल्कि Windows Internals को समझने का सबसे महत्वपूर्ण शोध उपकरण (Research Platform) माना जाता है।

2. Sysinternals का महत्व

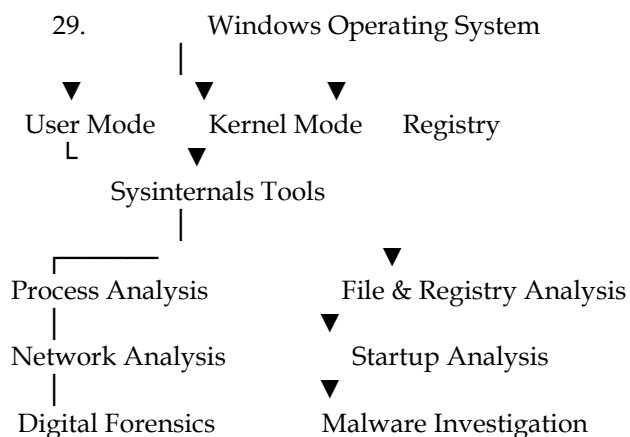
28. Windows Task Manager केवल सीमित जानकारी देता है।

लेकिन Sysinternals निम्न प्रश्नों के उत्तर दे सकता है—

- कौन-सा Process वास्तव में क्या कर रहा है?
- कौन-सी DLL Load हुई है?
- कौन-सा Registry Key Access हुआ?
- कौन-सी File किस Process ने खोली?
- कौन-सा Process Malware हो सकता है?
- कौन-सा Driver Kernel में चल रहा है?
- कौन-सा Process Network से जुड़ा है?
- कौन-सी Auto-Start Entry संदिग्ध है?

इसी कारण यह System Administrator, SOC Analyst, Malware Researcher और Digital Forensic Investigator के लिए अत्यंत महत्वपूर्ण है।

3. sysinternals Architecture



4. Sysinternals Su में प्रमुख Tools

30. Microsoft Sysinternals में 70+ से अधिक Utilities उपलब्ध हैं।

मुख्य Tools –

Tool	उद्देश्य
Process Explorer	Advanced Task Manager
Process Monitor	File, Registry, Process Monitoring
Autoruns	Startup Analysis
TCPView	Network Connections
PsExec	Remote Administration
PsList	Process Information
PsKill	Process Termination
PsLoggedOn	Logged-on Users
PsService	Windows Services
AccessChk	Permission Analysis
Sigcheck	Digital Signature Verification
Handle	Open Handles
RAMMap	Memory Analysis
VMMMap	Virtual Memory Analysis
Disk2vhd	Physical to Virtual Conversion
BgInfo	Desktop System Information

5. Process Exploreरिचय

31. Process Explorer को अक्सर "Advanced Task Manager" कहा जाता है।

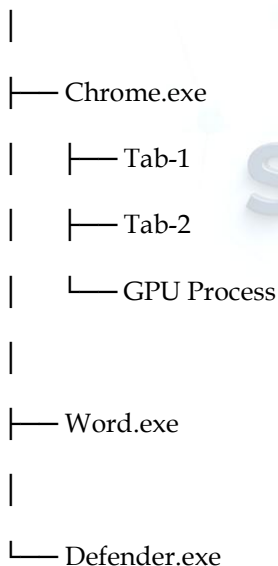
यह Windows के प्रत्येक Process की विस्तृत जानकारी देता है।

मुख्य विशेषताएँ

- Parent-Child Process Tree
- CPU Usage
- Memory Usage
- Threads
- DLLs
- Handles
- Digital Signature
- Command Line
- Network Activity
- VirusTotal Integration (वैकल्पिक)

Architecture

Explorer.exe



वास्तविक उदाहरण

यदि कोई Malware

Explorer.exe

के अंदर Inject हो जाए

Process Explorer

उसकी Parent Relationship

Loaded DLL

Memory

Threads

का विश्लेषण करने में सहायता करता है।

6. Process MonitorrocMon)

परिचय

32. Process Monitor

Windows में होने वाली लगभग प्रत्येक

- Registry Access
- File Access
- Process Activity
- Thread Activity

को Real-Time में Monitor करता है।

Monitoring Flow

Application

↓

Registry

↓

File System

↓

Network

↓



वास्तविक उदाहरण

User

Notepad खोलता है।

Process Monitor दिखाएगा—

- कौन-सी DLL Load हुई।
- कौन-सा Font पढ़ा गया।
- कौन-सी Registry Key Access हुई।
- कौन-सी File Open हुई।

7. ProcMon Event Ts

- Create File

33. Read File

- Write File
- Close File
- Registry Open
- Registry Read
- Registry Write
- Process Start
- Process Exit
- Thread Create
- Thread Exit

8. Digital Forensics में Process Monitor

यदि Malware

34. Registry में Persistence बनाता है

उस Registry Key तक पहुँचने की गतिविधि दिखा सकता है।

9. Autoruns

35. AutoruWindows में Boot या Login के समय

स्वतः चलने वाले सभी Programs दिखाता है।

Startup Locations

- Run Key
- RunOnce
- Startup Folder
- Services
- Drivers
- Scheduled Tasks
- Explorer Extensions
- Browser Helper Objects
- AppInit DLLs
- Winlogon Entries



उदाहरण

Malware

Run Key

में Entry जोड़ देता है।

Autoruns

उसे तुरंत दिखा देगा।

10. TCPView

36. UDP

Connections

को Real-Time में दिखाता है।

उदाहरण

Chrome.exe

↓

142.250.xxx.xxx

↓

HTTPS

↓

ESTABLISHED

यदि कोई अज्ञात Process संदिग्ध IP से जुड़ा हो, तो यह जाँच का विषय हो सकता है।

11. PsExec

PsExec

37. te Computer

पर Command चलाने के लिए उपयोग किया जाता है।

Enterprise वातावरण में इसका उपयोग अधिकृत प्रशासन (Authorized Administration) के लिए किया जाता है।

उदाहरण

Administrator

पर

Remote Maintenance

कर सकता है।

12. AccessChk

AccessChk

NTFS Permissions

Security Descriptor

ACL

का विश्लेषण करता है।

उदाहरण

Folder

Salary

↓

AccessChk

↓

कौन-कौन Access कर सकता है?

13. Sigcheck

Sigcheck

Executable File

की



Verify करता है।

उदाहरण

notepad.exe

↓

Microsoft Signed

यदि कोई महत्वपूर्ण System File Unsigned हो, तो आगे जाँच की जा सकती है।

14. Handle

Windows में प्रत्येक Open Object का एक Handle होता है।

Handle Utility

बताती है—

कौन-सा Process

कौन-सी File

Open किए हुए है।



उदाहरण

Word.exe

↓

Research.docx

↓

Handle Open

15. RAMMap

RAMMap

Physical Memory

का विस्तृत विश्लेषण करता है।

दिखाता है

- File Cache
- Driver Memory
- Kernel Memory
- Working Set
- Standby Memory

16. VMMap

Virtual Memory

का विस्तृत विश्लेषण।

उपयोग

Software Development

Memory Leak Analysis

Performance Research

17. BgInfo

Desktop

पर

System Information

दिखाता है।



- Computer Name
- IP Address
- OS Version
- RAM
- CPU

18. Process Injection Detection

Malware

कभी-कभी

Explorer.exe

में

DLL Inject

कर देता है।

Process Explorer

DLL

Threads

Memory

देखकर Investigation में सहायता करता है।



19. Sysinternals एवं Windows Internals

Sysinternals निम्न Windows Components का अध्ययन करने में उपयोगी है—

- Process
- Thread
- Handle
- Registry
- Memory
- Kernel Objects
- Services
- Drivers

- Session Manager
- Security Tokens

20. Sysinternals एवं Digital Forensics

Investigator

Sysinternals का उपयोग करता है—

- Live Response
- Malware Detection
- Persistence Analysis
- Timeline Creation
- Registry Analysis
- DLL Analysis
- Process Tree Analysis

वास्तविक उदाहरण

Incident के दौरान—

Unknown.exe

चल रहा था।

जाँच में—

- Process Explorer
- Process Monitor
- Autoruns
- TCPView

के संयोजन से पता चला कि Program Startup पर चलता था, Registry में Persistence रखता था और बाहरी सर्वर से Network Connection स्थापित करता था।

21. Enterprise Case Study

एक बहुराष्ट्रीय कंपनी में कर्मचारियों के कई Computers धीमे हो गए।

SOC टीम ने—

- Process Explorer से CPU उपयोग देखा।
- Process Monitor से लगातार File Access का विश्लेषण किया।
- Autoruns से Startup Entries जाँचीं।
- TCPView से Network Connections की समीक्षा की।
- Sigcheck से संदिग्ध Executables की Signature सत्यापित की।

परिणाम—

एक अनधिकृत Application बार-बार Startup होकर अनावश्यक संसाधनों का उपयोग कर रही थी। उसे हटाने के बाद सभी Systems सामान्य हो गए।

22. Sysinternals एवं SIEM

Enterprise वातावरण में Sysinternals से प्राप्त अवलोकन (Observations) को Windows Event Logs, EDR और SIEM के साथ मिलाकर व्यापक जाँच की जाती है।

Sysinternals

↓

Windows Event Logs

↓

EDR

↓

SIEM

↓

SOC

↓

Incident Response

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

23. शोध (PhD) के प्रमुख विषय

Sysinternals आधारित शोध के क्षेत्र—

1. Windows Kernel Behavior Analysis
2. Process Injection Detection
3. Memory Forensics

4. Registry Forensics
5. Malware Persistence Analysis
6. DLL Hijacking Detection
7. Live Response Methodology
8. Windows API Monitoring
9. Insider Threat Investigation
10. Advanced Endpoint Telemetry

24. Sysinternals Best Practices

1. केवल आधिकारिक Microsoft Sysinternals Tools का उपयोग करें।
2. Investigation से पहले Evidence Preservation सुनिश्चित करें।
3. Live System पर परिवर्तन न्यूनतम रखें।
4. Process Monitor में Filters का उपयोग करें ताकि अनावश्यक Events कम हों।
5. Process Explorer में Digital Signatures जाँचें।
6. Autoruns से संदिग्ध Startup Entries की नियमित समीक्षा करें।
7. TCPView से अज्ञात Network Connections की निगरानी करें।
8. Logs एवं Observations का उचित Documentation रखें।
9. Windows Event Logs एवं EDR Alerts के साथ Correlation करें।
10. Enterprise वातावरण में परिवर्तन नियंत्रित प्रक्रिया (Change Management) के अंतर्गत करें।

25. Sysinternals Tools का सारांश

Tool	प्रमुख उपयोग
Process Explorer	Advanced Process Analysis
Process Monitor	File, Registry एवं Process Monitoring
Autoruns	Startup एवं Persistence Analysis
TCPView	Network Connections
Psexec	Remote Administration
AccessChk	NTFS एवं ACL Analysis
Sigcheck	Digital Signature Verification
Handle	Open File Handles
RAMMap	Physical Memory Analysis
VMMMap	Virtual Memory Analysis
BgInfo	Desktop System Information

26. निष्कर्ष

Sysinternals Suite Windows Internals के अध्ययन के लिए सबसे महत्वपूर्ण और व्यापक Diagnostic Toolkit में से एक है। यह System Administrators, Cyber Security Analysts, Malware Researchers, Digital Forensic Investigators तथा SOC Teams को **Process Analysis, Registry Monitoring, Memory Analysis, Startup Investigation, Network Monitoring, Permission Analysis और Live Incident Response** जैसी उन्नत क्षमताएँ प्रदान करता है।

PhD स्तर पर Sysinternals का अध्ययन केवल Tool Usage तक सीमित नहीं है, बल्कि **Windows Kernel Architecture, Process Lifecycle, Security Tokens, Memory Management, Registry Internals, Malware Persistence, Digital Evidence Collection तथा Enterprise Threat Hunting** के वैज्ञानिक विश्लेषण के साथ किया जाता है। यही कारण है कि Sysinternals आधुनिक Windows Forensics एवं Enterprise Cyber Security अनुसंधान का एक अनिवार्य उपकरण माना जाता है।



अध्याय :

Credential Guard (क्रेडेंशियल गार्ड)

1. परिचय (Introduction)

Credential Guard Microsoft Windows की एक उन्नत (Advanced) सुरक्षा तकनीक है, जिसका उद्देश्य Windows में संग्रहीत **User Credentials** (पासवर्ड, NTLM Hash, Kerberos Ticket, Domain Credentials आदि) को चोरी (Credential Theft) से सुरक्षित रखना है।

यह सुविधा **Virtualization-Based Security (VBS)** का उपयोग करके संवेदनशील प्रमाण-पत्र (Credentials) को सामान्य Windows Operating System से अलग एक सुरक्षित (Isolated) वातावरण में संग्रहीत करती है।

सरल शब्दों में: Credential Guard Windows की "तिजोरी (Digital Vault)" है, जिसमें Login Credentials सुरक्षित रखे जाते हैं ताकि यदि Malware सामान्य Windows तक पहुँच भी जाए, तब भी वह Credentials तक आसानी से न पहुँच सके।

2. Credential Guard की आवश्यकता

Enterprise Cyber Attacks में सबसे सामान्य लक्ष्य होता है—

- Administrator Password
- NTLM Hash
- Kerberos Ticket
- Domain Credentials
- Service Account Credentials

यदि हमलावर इन्हें प्राप्त कर ले, तो वह पूरे Domain में आगे बढ़ सकता है (Lateral Movement)।

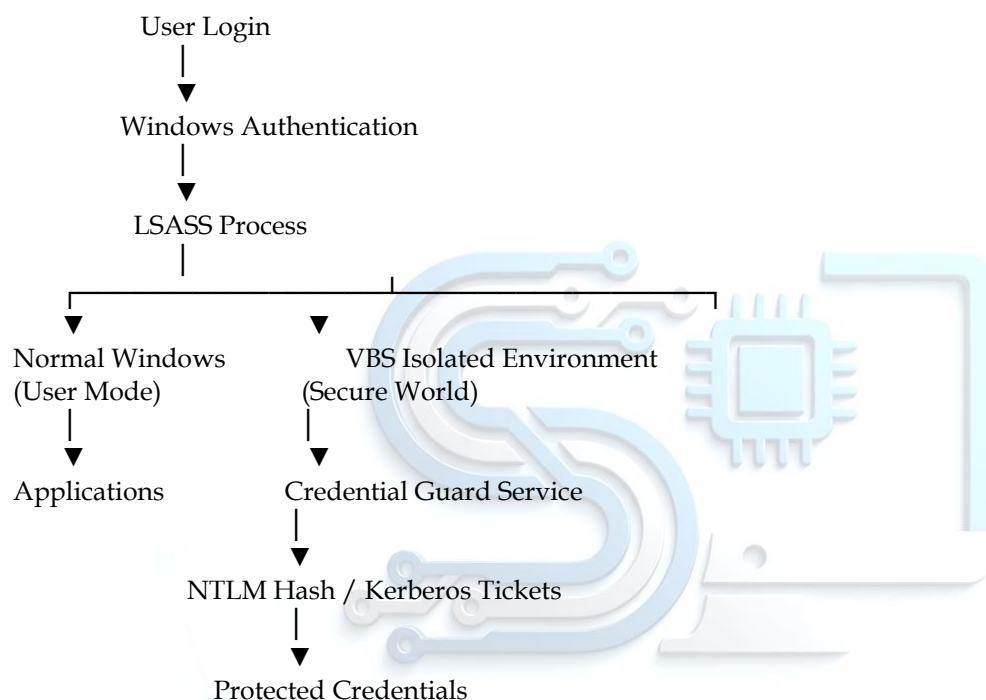
Credential Guard का मुख्य उद्देश्य इसी जोखिम को कम करना है।

वास्तविक उदाहरण

एक विश्वविद्यालय के Domain Administrator ने Domain Controller पर Login किया।

यदि किसी संक्रमित Software ने LSASS (Local Security Authority Subsystem Service) की Memory से Credentials निकालने का प्रयास किया, तो Credential Guard सक्रिय होने पर संवेदनशील Credentials सामान्य LSASS Memory में सीधे उपलब्ध नहीं होते, जिससे ऐसे हमलों की सफलता कठिन हो जाती है।

3. Credential Guard Architecture



4. Credential Guard कैसे कार्य करता है?

सामान्य Windows में—

User Login



LSASS



Credentials Memory

यदि Malware LSASS Memory पढ़ सके, तो Credential Theft संभव हो सकता है।

Credential Guard Enabled होने पर—



LSASS



Credential Guard



Virtual Secure Mode (VSM)



Protected Credentials

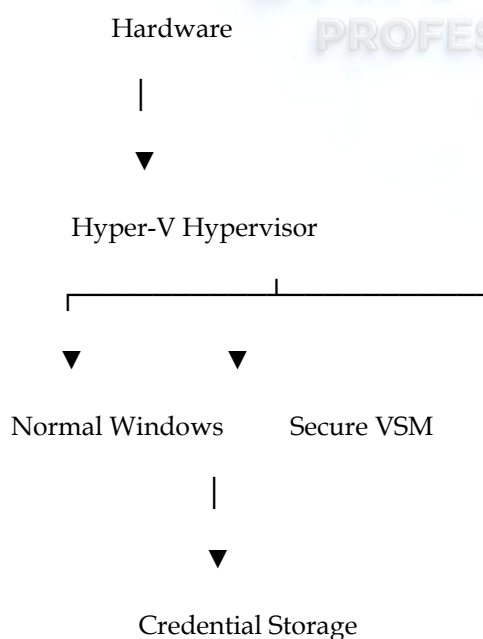
अब संवेदनशील Credential Data एक पृथक सुरक्षित वातावरण में संरक्षित रहता है।

5. Virtualization-Based Security (VBS)

Credential Guard का आधार **Virtualization-Based Security (VBS)** है।

VBS, Hardware Virtualization (जैसे Intel VT-x या AMD-V) तथा Hypervisor का उपयोग करके Operating System के भीतर एक अलग सुरक्षित क्षेत्र बनाता है।

Architecture



6. LSASS क्या है?

LSASS (Local Security Authority Subsystem Service) Windows का वह Process है जो—

- User Authentication
- NTLM
- Kerberos
- Security Policy
- Access Tokens

का प्रबंधन करता है।

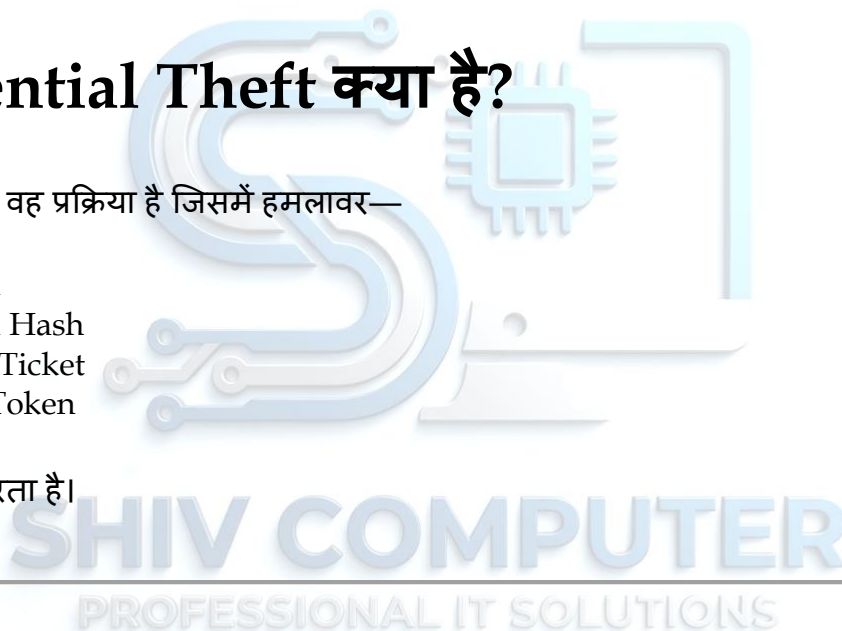
Credential Guard, LSASS की Credential Handling को अतिरिक्त सुरक्षा प्रदान करता है।

7. Credential Theft क्या है?

Credential Theft वह प्रक्रिया है जिसमें हमलावर—

- Password
- Password Hash
- Kerberos Ticket
- Security Token

चुराने का प्रयास करता है।



उदाहरण

यदि किसी Administrator ने Laptop पर Login किया और उस System में Malware आ गया, तो Malware LSASS से Credentials प्राप्त करने का प्रयास कर सकता है।

Credential Guard इस प्रकार के हमलों के विरुद्ध सुरक्षा को मजबूत करता है।

8. NTLM Hash Protection

Windows Login के दौरान NTLM आधारित Authentication (जहाँ लागू हो) में संबंधित Credential Material की सुरक्षा महत्वपूर्ण होती है।

Credential Guard NTLM से संबंधित संवेदनशील जानकारी को सुरक्षित रखने में सहायता करता है।

9. Kerberos Protection

Kerberos Ticket भी Enterprise Environment में अत्यंत महत्वपूर्ण होते हैं।

Credential Guard इनकी सुरक्षा को मजबूत करता है।

उदाहरण

Employee Login



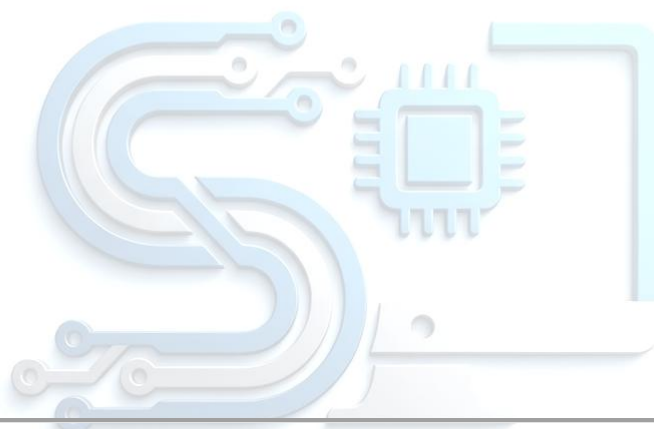
Kerberos Ticket



Credential Guard



Protected Storage



10. Pass-the-Hash Attack

यह क्या है?

Pass-the-Hash (PtH) में हमलावर Password की बजाय NTLM Hash का उपयोग करके Authentication का प्रयास करता है।

Credential Guard ऐसे हमलों की संभावना को कम करने में महत्वपूर्ण भूमिका निभाता है क्योंकि Credential Material की सुरक्षा बेहतर होती है।

11. Pass-the-Ticket Attack

Kerberos Ticket की चोरी कर उसका दुरुपयोग करने का प्रयास।

Credential Guard Kerberos संबंधित Credential Protection को मजबूत करता है।

12. Credential Guard Components

Component	कार्य
VBS	Secure Environment
Hypervisor	Isolation
LSASS Integration	Authentication Support
Isolated LSA	Credential Protection
Secure Kernel	Trusted Execution

13. Hardware Requirements

Credential Guard के लिए सामान्यतः—

- 64-bit Windows
- Hardware Virtualization Support
- UEFI Firmware
- Secure Boot
- TPM (अनुशंसित)
- VBS Support

की आवश्यकता होती है।

14. Credential Guard एवं TPM

TPM और Credential Guard दोनों अलग तकनीकें हैं, लेकिन साथ में उपयोग होने पर सुरक्षा अधिक मजबूत हो जाती है।

TPM

↓

Hardware Trust

Credential Guard

↓

Credential Isolation

15. Credential Guard एवं BitLocker

BitLocker



Disk Protection

Credential Guard



Credential Protection

दोनों का उद्देश्य अलग है—

BitLocker डेटा (Data at Rest) की रक्षा करता है।

Credential Guard पहचान (Identity Secrets) की रक्षा करता है।

16. Credential Guard एवं Windows Defender

दोनों मिलकर कार्य करते हैं—

Windows Defender Malware रोकता है

Credential Guard **Credentials सुरक्षित रखता है**

17. Credential Guard एवं Active Directory

Domain Environment में—

- Domain Admin
- Enterprise Admin
- Service Accounts

की सुरक्षा अत्यंत महत्वपूर्ण होती है।

Credential Guard Domain Credentials की सुरक्षा को मजबूत करता है।

18. Credential Guard एवं Group Policy

Enterprise Administrator Group Policy द्वारा—

- Credential Guard Enable
- VBS Configuration
- Hardware Security Settings

का केंद्रीकृत प्रबंधन कर सकता है।

19. Credential Guard एवं Microsoft Entra ID

Hybrid Identity Environment में—

- On-Premises Active Directory
- Microsoft Entra ID

दोनों के साथ उपयोग होने पर Endpoint Credential Protection बेहतर होती है।

20. Digital Forensics में Credential Guard

Forensic Investigator निम्न प्रश्नों का विश्लेषण करता है—

- Credential Guard Enabled था?
- VBS सक्रिय था?
- Secure Boot चालू था?
- Credential Theft का प्रयास हुआ?
- LSASS पर असामान्य गतिविधि हुई?

वास्तविक उदाहरण

एक सरकारी विभाग के Computer में Malware मिला।

जाँच में—

- Credential Guard Enabled था।

- VBS सक्रिय था।
- BitLocker Enabled था।
- Windows Defender ने Threat Detect किया।

परिणाम—

Malware मौजूद होने के बावजूद Domain Administrator Credentials सुरक्षित रहे।

21. Enterprise Case Study

एक बहुराष्ट्रीय बैंक—

- 75,000 कर्मचारी
- 50 देशों में कार्यालय
- 5,000 Domain Administrators
- Hybrid Identity Infrastructure

Security Policy —

- Credential Guard Mandatory
- BitLocker Mandatory
- Secure Boot Enabled
- TPM 2.0 Required
- Microsoft Defender for Endpoint
- Multi-Factor Authentication
- Privileged Access Management

परिणाम—

- Credential Theft Attempts में उल्लेखनीय कमी
- Pass-the-Hash Attack का जोखिम कम
- Identity Security मजबूत
- Compliance बेहतर

22. Credential Guard की सीमाएँ

Credential Guard बहुत प्रभावी सुरक्षा प्रदान करता है, लेकिन—

- यह सभी प्रकार के Malware को नहीं रोकता।

- यदि कोई उपयोगकर्ता वैध रूप से Authentication के बाद संवेदनशील डेटा तक पहुँचता है, तो उस Access को यह नियंत्रित नहीं करता।
- इसे प्रभावी बनाने के लिए Hardware एवं Operating System की आवश्यकताओं का पूरा होना आवश्यक है।
- यह सुरक्षा की बहु-स्तरीय रणनीति (Defense in Depth) का एक भाग है, अकेला समाधान नहीं।

23. Best Practices

1. Credential Guard सक्षम रखें।
2. VBS और Secure Boot सक्रिय रखें।
3. TPM 2.0 का उपयोग करें।
4. BitLocker सक्षम रखें।
5. Multi-Factor Authentication लागू करें।
6. Privileged Accounts के लिए अलग Workstations का उपयोग करें।
7. LSASS Protection एवं अन्य Windows Security Features का उपयोग करें।
8. Microsoft Defender for Endpoint जैसी EDR तकनीकों का उपयोग करें।
9. Group Policy द्वारा केंद्रीकृत Configuration करें।
10. Windows Event Logs एवं SIEM के माध्यम से निगरानी करें।

24. शोध (PhD) के प्रमुख विषय

Credential Guard पर उन्नत शोध—

1. Virtualization-Based Security Architecture
2. Secure Kernel Design
3. Hardware Root of Trust
4. Credential Theft Detection
5. Identity Protection Models
6. Zero Trust Endpoint Security
7. Enterprise Authentication Security
8. Hypervisor आधारित Isolation
9. Windows Identity Internals
10. AI आधारित Credential Attack Detection

25. Credential Guard बनाम अन्य तकनीकें

तकनीक

BitLocker

Windows Defender

Credential Guard

Windows Hello for Business

Microsoft Defender for Endpoint

LAPS

Secure Boot

मुख्य उद्देश्य

Disk Encryption

Malware Protection

Credential Protection

Passwordless Authentication

Endpoint Detection & Response

Local Administrator Password Management

Boot Integrity

26. सारांश

विषय

Credential Guard

VBS

Hypervisor

LSASS Integration

NTLM Protection

Kerberos Protection

TPM

BitLocker Integration

Active Directory

Group Policy

विवरण

Credential Protection

Virtualization-Based Security

Secure Isolation

Authentication Support

Hash Security

Ticket Security

Hardware Trust

Data एवं Identity Security

Domain Credential Protection

Centralized Configuration

27. निष्कर्ष

Credential Guard आधुनिक Windows Enterprise Security की सबसे महत्वपूर्ण Identity Protection Technologies में से एक है। यह Virtualization-Based Security (VBS), Hypervisor Isolation, Isolated LSA, तथा Secure Kernel के माध्यम से Windows Credentials को सामान्य Operating System से अलग सुरक्षित वातावरण में संरक्षित रखता है।

PhD स्तर पर Credential Guard का अध्ययन केवल एक Windows Feature के रूप में नहीं किया जाता, बल्कि Identity Security, Trusted Computing, Hypervisor Security, Zero Trust Architecture, Enterprise Authentication, Digital Forensics तथा Advanced Threat Protection के व्यापक संदर्भ में किया जाता है। Enterprise Cyber Security में यह तकनीक विशेष रूप से Pass-the-Hash, Pass-the-Ticket, और अन्य Credential Theft आधारित हमलों के विरुद्ध बहु-स्तरीय सुरक्षा (Defense in Depth) का एक महत्वपूर्ण घटक मानी जाती है।

अध्याय :

LSASS Protection (Local Security Authority Subsystem Service Protection)

1. परिचय (Introduction)

LSASS Protection Windows Operating System की एक उन्नत सुरक्षा तकनीक है, जिसका उद्देश्य **Local Security Authority Subsystem Service (LSASS.exe)** को अनधिकृत (Unauthorized) Access, Credential Theft, Memory Dump Attacks तथा Malware Injection से सुरक्षित रखना है।

LSASS Windows का सबसे महत्वपूर्ण Security Process है क्योंकि यही User Authentication, Password Validation, Kerberos, NTLM Authentication, Access Tokens तथा Security Policies का प्रबंधन करता है।

यदि कोई हमलावर LSASS की Memory तक पहुँच जाए, तो वह कई प्रकार की संवेदनशील जानकारी प्राप्त करने का प्रयास कर सकता है। इसी जोखिम को कम करने के लिए Microsoft ने **LSASS Protection** (विशेष रूप से **Protected Process Light - PPL**) जैसी सुरक्षा सुविधाएँ विकसित की हैं।

सरल शब्दों में: LSASS Protection Windows की "सुरक्षा तिजोरी का सुरक्षा प्रहरी" है, जो यह सुनिश्चित करता है कि कोई सामान्य Process या Malware LSASS तक आसानी से पहुँच न सके।

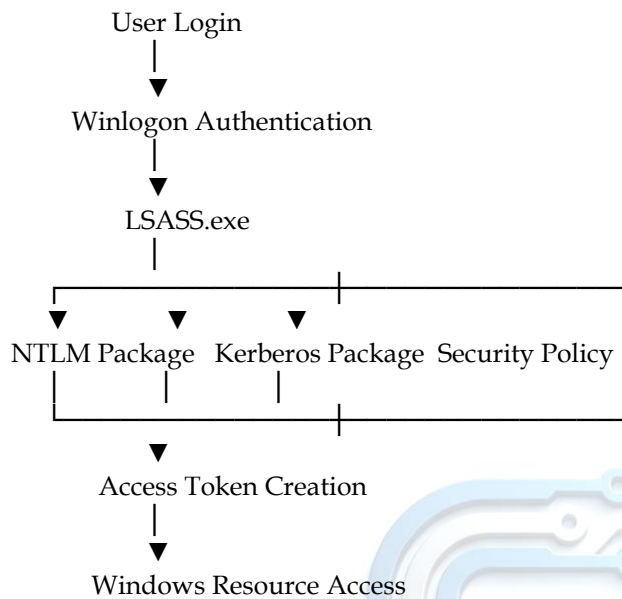
2. LSASS क्या है?

LSASS (Local Security Authority Subsystem Service) Windows का एक Core System Process है।

मुख्य कार्य—

- User Authentication
- Password Verification
- NTLM Authentication
- Kerberos Authentication
- Access Token Creation
- Security Policy Enforcement
- Account Validation

LSASS Architecture



3. User Login Process

जब User Login करता है—

Username



Password



Winlogon



LSASS



Credential Verification



Authentication Success



Access Token



यदि Password गलत हो—

Authentication Failed

4. LSASS की भूमिका

LSASS निम्न कार्य करता है—

Authentication

Password सही है या नहीं।

Authorization

User किस Resource तक पहुँच सकता है।

Access Token बनाना

हर सफल Login के बाद Windows एक Access Token बनाता है।

Security Policy लागू करना

- Password Policy
 - Account Lockout
 - Audit Policy
-

Kerberos Ticket Management

Domain Environment में Kerberos Authentication का प्रबंधन।

NTLM Authentication

पुरानी प्रणालियों के साथ Compatibility के लिए।

5. Access Token

जब User सफलतापूर्वक Login करता है—

User Login



LSASS



Access Token

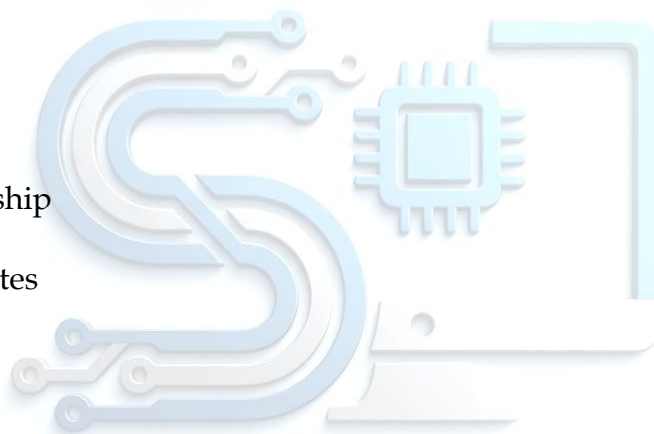


Application

Access Token में—

- User SID
- Group Membership
- Privileges
- Security Attributes

होते हैं।



6. Credential Theft क्या है?

यदि Malware LSASS की Memory तक पहुँच जाए—

तो वह निम्न प्रकार की संवेदनशील जानकारी प्राप्त करने का प्रयास कर सकता है—

- Authentication Secrets
- NTLM संबंधित जानकारी
- Kerberos Ticket Information
- Security Tokens

यही कारण है कि LSASS Protection अत्यंत आवश्यक है।

7. Memory Dump Attack

Memory Dump में कोई Process दूसरे Process की Memory पढ़ने का प्रयास करता है।

उदाहरण—

Malware

↓

LSASS Memory

↓

Dump Attempt

↓

Credential Theft

LSASS Protection इस प्रकार के प्रयासों को कठिन बनाती है।

8. Protected Process Light (PPL)

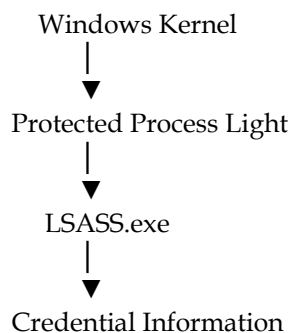
LSASS Protection का मुख्य आधार Protected Process Light (PPL) है।

जब LSASS को PPL के रूप में चलाया जाता है—

- सामान्य User Process
- अधिकांश Third-Party Applications
- सामान्य Malware

उसकी Memory तक सीधे पहुँच नहीं पाते।

PPL Architecture



9. PPL कैसे कार्य करता है?

यदि कोई सामान्य Process —

Unknown.exe

↓

Read LSASS Memory

का प्रयास करे—

Windows

↓

Access Check

↓

Denied

10. LSASS Protection एवं Credential Guard

दोनों का उद्देश्य अलग है।

LSASS Protection

Credential Guard

LSASS Process की सुरक्षा

Credentials की Isolation

Memory Access Protection VBS आधारित Credential Storage

PPL आधारित सुरक्षा

Virtual Secure Mode

दोनों साथ मिलकर Enterprise Identity Security को मजबूत बनाते हैं।

11. LSASS एवं Windows Defender

Windows Defender Malware को Detect करने का प्रयास करता है।

LSASS Protection सुनिश्चित करती है कि यदि Malware System में पहुँच भी जाए, तो LSASS तक उसकी पहुँच सीमित रहे।

12. LSASS एवं BitLocker

BitLocker



Disk Security

LSASS Protection



Credential Security

13. LSASS एवं Active Directory

Domain Controller पर LSASS अत्यंत महत्वपूर्ण होता है क्योंकि—

- Kerberos
- NTLM
- Domain Authentication
- Trust Relationship

इसी Process द्वारा संचालित होते हैं।

14. LSASS एवं Group Policy

Enterprise Administrator Group Policy द्वारा संबंधित सुरक्षा Configuration नियंत्रित कर सकता है।

उदाहरण—

- LSASS Protection संबंधित Security Configuration
- Credential Protection Policies
- Audit Policies

15. LSASS एवं Windows Event Logs

LSASS से संबंधित महत्वपूर्ण Security Events Windows Event Logs में रिकॉर्ड हो सकते हैं।

Forensic Investigation में इनका उपयोग किया जाता है।

16. LSASS एवं Digital Forensics

Forensic Investigator निम्न प्रश्नों की जाँच करता है—

- क्या LSASS Protected था?
- क्या Memory Dump का प्रयास हुआ?
- क्या कोई Unauthorized Process LSASS तक पहुँचना चाहता था?
- कौन-सा User उस समय Login था?
- क्या Security Policies में परिवर्तन हुआ?

उदाहरण

एक सरकारी विभाग के Computer में संदिग्ध गतिविधि मिली।

जाँच में—

- Windows Defender Alert मिला।
- LSASS Protection सक्षम थी।
- Credential Guard सक्रिय था।
- Memory Dump Attempt विफल रहा।

परिणाम—

Identity Compromise नहीं हुआ।

17. Enterprise Case Study

एक बहुराष्ट्रीय बैंक—

- 1,20,000 कर्मचारी
- 70,000 Windows Endpoints
- Hybrid Active Directory Environment

- LSASS Protection (PPL)
- Credential Guard
- BitLocker
- Secure Boot
- TPM 2.0
- Microsoft Defender for Endpoint
- Multi-Factor Authentication

परिणाम—

- Credential Theft Attempts में उल्लेखनीय कमी
- Pass-the-Hash आधारित हमलों का जोखिम कम
- Identity Security अधिक मजबूत

18. LSASS Protection की सीमाएँ

- यह सभी प्रकार के Malware को नहीं रोकती।
- यदि किसी हमलावर को उच्च स्तर (Kernel-Level) का नियंत्रण मिल जाए, तो अतिरिक्त जोखिम उत्पन्न हो सकते हैं।
- यह सुरक्षा की बहु-स्तरीय रणनीति (Defense in Depth) का केवल एक भाग है।
- Hardware एवं Windows Version के अनुसार उपलब्ध सुविधाओं में अंतर हो सकता है।

19. Best Practices

1. LSASS Protection सक्षम रखें।
2. Credential Guard का उपयोग करें।
3. BitLocker सक्षम रखें।
4. TPM 2.0 एवं Secure Boot का उपयोग करें।
5. Microsoft Defender for Endpoint जैसी EDR तकनीक लागू करें।
6. Multi-Factor Authentication का उपयोग करें।
7. Least Privilege Principle अपनाएँ।
8. Windows Event Logs की नियमित निगरानी करें।
9. Group Policy द्वारा केंद्रीकृत सुरक्षा लागू करें।
10. नियमित Security Audits करें।

20. शोध (PhD) के प्रमुख विषय

LSASS Protection पर उन्नत शोध—

1. Protected Process Light (PPL) Architecture
2. Windows Authentication Internals
3. Credential Theft Detection
4. Memory Forensics
5. Kernel Security Mechanisms
6. Hypervisor आधारित सुरक्षा
7. Identity Attack Mitigation
8. Zero Trust Endpoint Security
9. Advanced Endpoint Telemetry
10. AI आधारित Credential Attack Detection

21. LSASS Protection बनाम अन्य तकनीकें

तकनीक

LSASS Protection

Credential Guard

BitLocker

Windows Defender

Secure Boot

TPM

Microsoft Defender for Endpoint Endpoint Detection & Response

मुख्य उद्देश्य

LSASS Process Security

Credential Isolation

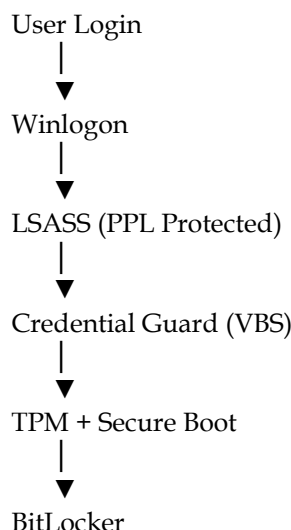
Full Disk Encryption

Malware Protection

Boot Integrity

Hardware Root of Trust

22. Windows Authentication Security Stack



23. सारांश

विषय	विवरण
LSASS	Local Security Authority Subsystem Service
मुख्य कार्य	Authentication एवं Security Policy
PPL	Protected Process Light
Access Token	User Security Context
Credential Guard	Credential Isolation
Windows Defender	Malware Detection
Active Directory	Domain Authentication
Windows Event Logs	Security Monitoring
Digital Forensics	Credential Attack Investigation

24. निष्कर्ष

LSASS Protection आधुनिक Windows सुरक्षा संरचना का एक अत्यंत महत्वपूर्ण घटक है। यह **Protected Process Light (PPL)** के माध्यम से **LSASS.exe** को अनधिकृत Memory Access, Credential Dumping तथा अनेक प्रकार के Credential Theft प्रयासों से सुरक्षित रखने में सहायता करता है।

PhD स्तर पर LSASS Protection का अध्ययन केवल एक Windows Feature के रूप में नहीं किया जाता, बल्कि **Windows Authentication Architecture, Identity Security, Memory Protection, Kernel Security, Digital Forensics, Threat Hunting, Zero Trust Security** तथा **Enterprise Incident Response** के व्यापक संदर्भ में किया जाता है। यह तकनीक **Credential Guard, BitLocker, TPM, Secure Boot और Microsoft Defender** जैसी अन्य सुरक्षा तकनीकों के साथ मिलकर Windows आधारित Enterprise वातावरण में बहु-स्तरीय (Defense-in-Depth) सुरक्षा प्रदान करती है।

अध्याय : Windows Internals (विंडोज इंटरनल्स)

(PhD Level | अत्यंत विस्तृत अध्ययन | हिंदी | उदाहरण सहित |
Windows Architecture, Kernel, Security एवं Digital Forensics)

1. परिचय (Introduction)

Windows Internals वह अध्ययन (Study) है जिसमें Windows Operating System की आंतरिक संरचना (Internal Architecture), उसके विभिन्न Components, Kernel, Memory Management, Process Management, Security Mechanisms, File System, Registry, Device Drivers तथा System Calls के कार्य करने की प्रक्रिया का वैज्ञानिक विश्लेषण किया जाता है।

सामान्य उपयोगकर्ता Windows का केवल बाहरी भाग (GUI) देखता है, जैसे—

- Desktop
- Start Menu
- Taskbar
- Explorer
- Settings

लेकिन इन सभी के पीछे हजारों Processes, Threads, Drivers, System Services तथा Kernel Components कार्य कर रहे होते हैं। इन्हीं आंतरिक भागों का अध्ययन **Windows Internals** कहलाता है।

सरल शब्दों में: Windows Internals वह विज्ञान है जो यह समझाता है कि Windows वास्तव में "अंदर से" कैसे कार्य करता है।

2. Windows Internals का महत्व

Windows Internals का अध्ययन निम्न क्षेत्रों के लिए अत्यंत आवश्यक है—

- Operating System Development
- System Programming
- Kernel Development
- Cyber Security
- Digital Forensics
- Malware Analysis

- Reverse Engineering
- Memory Forensics
- Incident Response
- Performance Engineering

वास्तविक उदाहरण

यदि कोई Malware केवल Task Manager बंद कर देता है, तो एक सामान्य उपयोगकर्ता केवल Task Manager का बंद होना देखेगा।

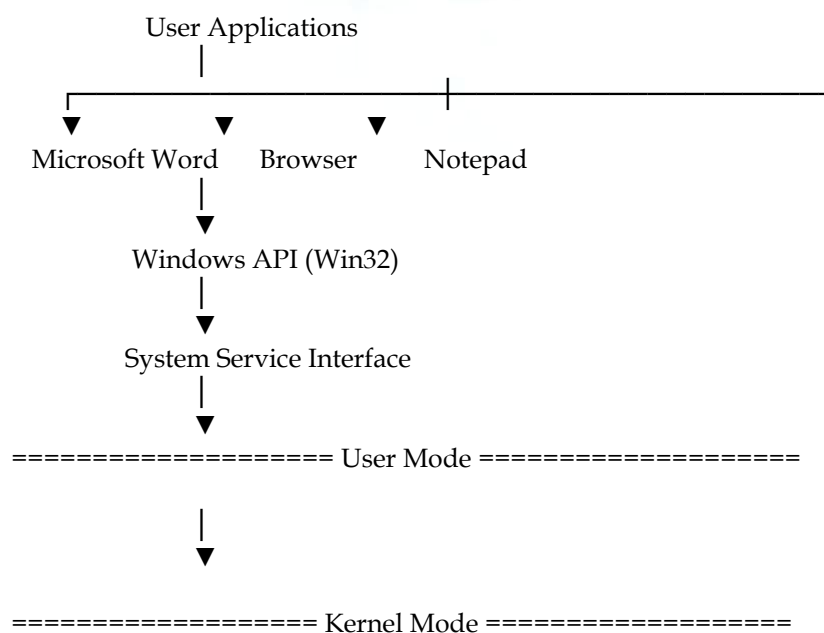
लेकिन Windows Internals का विशेषज्ञ यह जाँच करेगा—

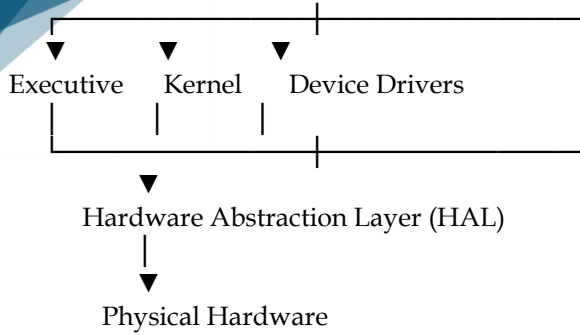
- किस Process ने यह किया?
- कौन-सी API Call उपयोग हुई?
- कौन-सा Driver Load हुआ?
- क्या Kernel Hooking हुई?
- क्या Registry बदली गई?
- क्या LSASS या Explorer में Code Injection हुआ?

3. Windows Architecture

Windows एक Hybrid Kernel Operating System है।

इसकी मूल संरचना निम्न प्रकार की होती है—





4. Windows के मुख्य Layers

Windows मुख्यतः दो भागों में विभाजित है—

(A) User Mode

जहाँ सामान्य Applications चलती हैं।

उदाहरण—

- Chrome
- Microsoft Word
- Notepad
- Calculator

यदि कोई Application Crash हो जाए तो सामान्यतः पूरा Windows बंद नहीं होता।

(B) Kernel Mode

यह Windows का सबसे महत्वपूर्ण भाग है।

Kernel Mode नियंत्रित करता है—

- Memory
- CPU
- Drivers
- Hardware
- File System
- Process Scheduling
- Interrupts
- Security

यदि Kernel में गंभीर त्रुटि हो जाए, तो Blue Screen of Death (BSOD) जैसी स्थिति उत्पन्न हो सकती है।

5. Windows Kernel

Kernel Windows का "हृदय (Heart)" है।

मुख्य कार्य—

- Process Management
- Thread Scheduling
- Memory Management
- Device Communication
- Interrupt Handling
- Synchronization
- Security

उदाहरण

Application



Windows API



Kernel



Hard Disk



Result



जब User File खोलता है, तो Application सीधे Disk से बात नहीं करती; अनुरोध Kernel के माध्यम से जाता है।

6. Windows Executive

Windows Executive Kernel के ऊपर कार्य करने वाले Core Components का समूह है।

मुख्य Components —

- Object Manager
- Process Manager
- Memory Manager

- Security Reference Monitor
- I/O Manager
- Configuration Manager (Registry)
- Cache Manager
- Plug and Play Manager
- Power Manager

7. Object Manager

Windows लगभग प्रत्येक संसाधन (Resource) को एक **Object** के रूप में प्रबंधित करता है।

उदाहरण—

- File
- Process
- Thread
- Event
- Mutex
- Registry Key
- Device

Object Manager इन सभी का निर्माण, प्रबंधन और सुरक्षा करता है।

8. Process Manager

Process Manager —

- Process बनाता है।
- समाप्त करता है।
- Parent-Child संबंध बनाए रखता है।
- Process IDs (PID) आवंटित करता है।

उदाहरण

Explorer.exe

↓

Notepad.exe

↓

9. Thread Manager

एक Process में अनेक Threads हो सकते हैं।

उदाहरण—

Chrome Browser

↓

Tab-1

↓

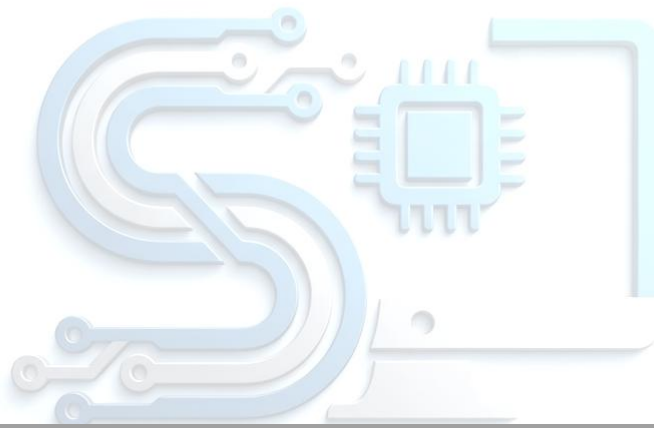
Thread-1

↓

Thread-2

↓

Thread-3



10. Memory Manager

Memory Manager नियंत्रित करता है—

- Virtual Memory
- Physical RAM
- Paging
- Swapping
- Memory Protection

उदाहरण

यदि RAM कम हो जाए—

Windows कुछ Memory Pages को Page File में स्थानांतरित कर सकता है।

11. Virtual Memory

प्रत्येक Process को अपना Virtual Address Space मिलता है।

Application



Virtual Address



Memory Manager



Physical RAM

इससे Processes एक-दूसरे की Memory में सीधे हस्तक्षेप नहीं कर पाते।

12. I/O Manager

Input/Output Manager सभी Devices के साथ संचार का समन्वय करता है।

उदाहरण—

- Keyboard
- Mouse
- Printer
- SSD
- USB Drive
- Network Adapter

13. Configuration Manager

Configuration Manager Windows Registry का प्रबंधन करता है।

कार्य—

- Registry पढ़ना
- Registry लिखना
- Registry Cache
- Registry Hive Management

14. Cache Manager

बार-बार उपयोग होने वाले Data को Memory में Cache करके प्रदर्शन (Performance) बेहतर करता है।

उदाहरण—

यदि एक ही File बार-बार खोली जाए, तो Cache के कारण Access तेज हो सकता है।

15. Security Reference Monitor (SRM)

SRM Windows Security का मुख्य घटक है।

यह जाँचता है—

- User कौन है?
- उसके पास कौन-से अधिकार (Privileges) हैं?
- क्या वह File पढ़ सकता है?
- क्या उसे Delete करने की अनुमति है?

उदाहरण

User

↓

Open Salary.xlsx

↓

Security Check

↓

Access Granted / Denied

16. Hardware Abstraction Layer (HAL)

HAL Hardware और Windows Kernel के बीच एक मानकीकृत परत प्रदान करता है।

इससे Windows विभिन्न Hardware Platforms पर कार्य कर सकता है।

17. Device Drivers

Drivers Hardware और Windows के बीच संचार स्थापित करते हैं।

उदाहरण—

- Printer Driver
- GPU Driver
- Network Driver
- Audio Driver
- Storage Driver

18. Windows Boot Process

Power On



UEFI Firmware



Windows Boot Manager



Windows Loader



Kernel (ntoskrnl.exe)



HAL



Drivers



Services



Winlogon



User Login



19. Windows Security Architecture

मुख्य Components –

- LSASS
- Security Accounts Manager (SAM)
- Active Directory (Domain Environment)
- Credential Guard
- Windows Defender
- BitLocker
- Windows Firewall
- SmartScreen

20. Windows Registry

Registry Windows की केंद्रीय Configuration Database है।

इसमें संग्रहीत होता है—

- Hardware Configuration
- Installed Software
- Drivers
- Services
- User Profiles
- Startup Programs
- Security Settings

21. NTFS File System

Windows मुख्यतः NTFS का उपयोग करता है।

विशेषताएँ—

- Access Control Lists (ACL)
- Encryption (EFS)
- Compression
- Journaling
- Large File Support

22. Windows Services

Services वे Programs हैं जो Background में चलते हैं।

उदाहरण—

- Windows Update
- Print Spooler
- DHCP Client
- Windows Time
- Defender Antivirus

23. Windows Event Logging

Windows प्रत्येक महत्वपूर्ण घटना का रिकॉर्ड रखता है—

- Login
- Logoff
- Software Installation
- Driver Loading
- Service Start
- Security Events

ये Logs Digital Forensics में अत्यंत महत्वपूर्ण होते हैं।

24. Windows Internals एवं Digital Forensics

Forensic Investigator Windows Internals का उपयोग करके जाँच करता है—

- कौन-सा Process चला?
- कौन-सी DLL Load हुई?
- कौन-सा Driver Install हुआ?
- Registry में क्या परिवर्तन हुआ?
- Memory में क्या मौजूद है?
- कौन-सा User Login था?
- कौन-सा USB Device जोड़ा गया?

वास्तविक उदाहरण

एक कंपनी के Computer से गोपनीय डेटा लीक हो गया।

जाँच में—

- Process Tree का विश्लेषण
- Registry Startup Entries
- Windows Event Logs
- NTFS Metadata
- Prefetch Files
- Memory Analysis
- Network Connections

के आधार पर पता चला कि एक अनधिकृत Application ने डेटा कॉपी किया था।

25. Windows Internals एवं Malware Analysis

Malware अक्सर—

- Process Injection
- DLL Hijacking
- Registry Persistence
- Driver Installation
- API Hooking
- Process Hollowing

जैसी तकनीकों का उपयोग करता है।

Windows Internals का ज्ञान इनके विश्लेषण के लिए अनिवार्य है।

26. Windows Internals एवं Sysinternals

Sysinternals Tools Windows Internals के अध्ययन के लिए अत्यंत उपयोगी हैं—

Tool	उपयोग
Process Explorer	Process Analysis
Process Monitor	Registry एवं File Monitoring
Autoruns	Persistence Analysis

Tool	उपयोग
RAMMap	Memory Analysis
TCPView	Network Analysis
Handle	Open Handles

27. शोध (PhD) के प्रमुख विषय

Windows Internals पर उन्नत शोध के क्षेत्र—

1. Windows Kernel Architecture
2. Memory Management Algorithms
3. Kernel Security Mechanisms
4. Process एवं Thread Scheduling
5. Windows Object Manager Internals
6. Registry Internals
7. NTFS Metadata Analysis
8. Driver Security
9. Hypervisor एवं Virtualization-Based Security (VBS)
10. Digital Forensics एवं Memory Acquisition
11. Endpoint Detection and Response (EDR)
12. Kernel-Level Rootkit Detection
13. Secure Boot एवं Measured Boot
14. AI आधारित System Telemetry Analysis
15. Windows Security Subsystem Optimization

28. Windows Internals के Best Practices (अनुसंधान एवं सुरक्षा)

1. Windows Architecture को User Mode और Kernel Mode दोनों स्तरों पर समझें।
2. Sysinternals Tools के साथ Windows Event Logs का संयुक्त विश्लेषण करें।
3. Memory Forensics और Registry Analysis को Incident Response का भाग बनाएँ।
4. Kernel Drivers केवल विश्वसनीय स्रोतों से स्थापित करें।
5. ETW (Event Tracing for Windows) एवं Performance Monitor जैसे Diagnostic Framework का उपयोग करें।
6. Windows Security Features (Credential Guard, LSASS Protection, BitLocker, Defender) को सक्षम रखें।
7. Debugging एवं Reverse Engineering के लिए नियंत्रित Lab Environment का उपयोग करें।

8. Digital Evidence का विश्लेषण करते समय Chain of Custody बनाए रखें।
9. Performance तथा Security Telemetry का नियमित Audit करें।
10. Windows Internals का अध्ययन Microsoft के आधिकारिक दस्तावेज़ों एवं शोध सामग्री के साथ निरंतर अद्यतन रखें।

29. Windows Internals का समग्र सारांश

घटक	मुख्य कार्य
User Mode	Applications का निष्पादन
Kernel Mode	Hardware एवं Core OS नियंत्रण
Windows Kernel	Process, Memory, Scheduling
Executive	Core OS Services
Object Manager	Objects का प्रबंधन
Memory Manager	RAM एवं Virtual Memory
I/O Manager	Device Communication
Configuration Manager	Windows Registry
Security Reference Monitor	Access Control
HAL	Hardware Abstraction
Device Drivers	Hardware Interface
NTFS	File System
Event Logs	Security एवं System Logging
LSASS	Authentication
Windows Defender	Malware Protection
BitLocker	Disk Encryption
Credential Guard	Credential Protection

30. निष्कर्ष

Windows Internals आधुनिक Windows Operating System की वैज्ञानिक एवं तकनीकी समझ का आधार है। यह केवल Operating System के घटकों का परिचय नहीं, बल्कि Kernel Architecture, Memory Management, Process एवं Thread Lifecycle, Object Management, Registry Internals, NTFS, Security Architecture, Driver Model, Virtualization, तथा Digital Forensics का समग्र अध्ययन है।

PhD स्तर पर Windows Internals का अध्ययन Operating System Research, Cyber Security, Malware Analysis, Reverse Engineering, Incident Response, Memory Forensics, Threat

Hunting, तथा Enterprise Security Engineering का मूल आधार माना जाता है। Windows आधारित किसी भी उन्नत Cyber Security या Digital Forensics अनुसंधान में Windows Internals की गहन समझ अनिवार्य होती है।



Linux Security

Linux Architecture

(लिनक्स आर्किटेक्चर) — पूर्ण विस्तृत अध्ययन

Linux Architecture (लिनक्स की आंतरिक संरचना)

Linux Architecture (लिनक्स आर्किटेक्चर) वह संरचना (Structure) है जो यह निर्धारित करती है कि Linux Operating System किस प्रकार कार्य करता है, विभिन्न हार्डवेयर संसाधनों (Hardware Resources) का प्रबंधन कैसे करता है, उपयोगकर्ता (User) से इनपुट कैसे प्राप्त करता है, और प्रोग्राम (Programs) को किस प्रकार सुरक्षित एवं कुशलतापूर्वक चलाता है।

सरल शब्दों में,

Linux Architecture वह Blueprint (नक्शा) है जिसके आधार पर पूरा Linux Operating System कार्य करता है।

Linux Architecture का इतिहास

1991 में Linus Torvalds ने Linux Kernel विकसित किया।

इसके बाद GNU Project के Software जोड़कर एक पूर्ण Operating System बनाया गया जिसे GNU/Linux कहा गया।

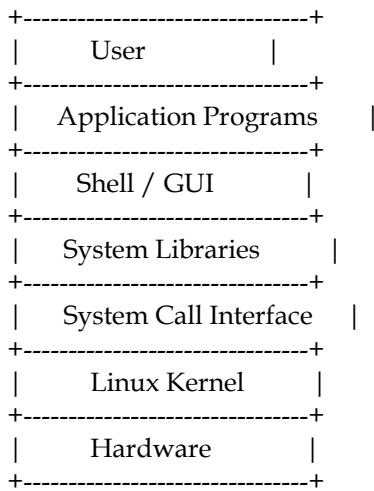
Linux का Design UNIX Architecture से प्रेरित है।

Linux का मुख्य उद्देश्य था—

- Stability
- Security
- Multiuser Support
- Multitasking
- Portability
- Scalability

Linux Architecture का मूल सिद्धांत

Linux को मुख्यतः Layered Architecture में डिजाइन किया गया है।



यहाँ प्रत्येक Layer नीचे वाली Layer पर निर्भर करती है।

Linux Architecture की प्रमुख Layers

Linux Architecture को मुख्यतः 7 Layers में समझा जाता है।

1. Hardware Layer

यह Linux की सबसे नीचे वाली Layer होती है।

इसमें सभी Physical Devices आती हैं।

जैसे—

- CPU
- RAM
- Hard Disk
- SSD
- GPU
- Keyboard
- Mouse
- Monitor
- Network Card
- USB

- Printer

उदाहरण

मान लीजिए आपके Computer में

Intel Core i7
16 GB RAM
512 GB SSD
NVIDIA GPU

ये सभी Hardware Layer का भाग हैं।

Linux सीधे Hardware से बात नहीं करता।

इसके लिए Kernel Driver का प्रयोग करता है।

Hardware Driver क्या होता है?

Driver एक Software Module है।

जो Hardware और Kernel के बीच Translator की तरह कार्य करता है।

उदाहरण

Printer Driver

User
↓

Linux

↓

Driver

↓

Printer

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Device Driver Architecture

Linux में Driver दो प्रकार के होते हैं।

Character Driver

एक Character एक बार में पढ़ता है।

उदाहरण

Keyboard

Serial Port

Mouse

Block Driver

Data को Block में पढ़ता है।

उदाहरण

Hard Disk

SSD

DVD

Network Driver

Network Packet Handle करता है।

उदाहरण

Ethernet

Wi-Fi

Bluetooth

Hardware Abstraction

Linux Hardware को Abstract कर देता है।

Application को Hardware की जानकारी नहीं होती।

उदाहरण

Application केवल लिखती है—

Read File

Kernel तय करेगा

Hard Disk

SSD

USB

Network Drive

कहाँ से पढ़ना है।

2. Kernel Layer

यह Linux का सबसे महत्वपूर्ण भाग है।

Kernel Operating System का Heart कहलाता है।

Kernel का कार्य—

- Memory Management
- Process Management
- CPU Scheduling
- Device Management
- Security
- File System
- Networking

Kernel क्या है?

Kernel Hardware और User के बीच Bridge है।

चित्र

User

↓

Application

↓

Kernel



Hardware

Kernel के बिना Computer कार्य नहीं करेगा।

Linux Kernel की विशेषताएँ

- Monolithic Kernel
 - Modular
 - Portable
 - Open Source
 - Preemptive
 - Multitasking
 - SMP Support
 - NUMA Support
-

Monolithic Kernel

Linux एक Monolithic Kernel प्रयोग करता है।

इसमें सभी मुख्य Services Kernel Space में रहती हैं।

Memory

File System

Drivers

Networking

Security

सभी Kernel के भीतर रहते हैं।

Kernel Modules

Linux Runtime पर Module Load कर सकता है।

उदाहरण

USB Driver

WiFi Driver

Printer Driver

Command

lsmod

Loaded Modules दिखाता है।

```
modprobe usb_storage
```

USB Driver Load करता है।

Kernel के मुख्य Components

अब प्रत्येक Component को विस्तार से समझते हैं।

Process Management

Linux प्रत्येक Running Program को Process कहता है।

उदाहरण

Firefox

Chrome

VS Code

Terminal

सभी अलग Process हैं।

Kernel प्रत्येक Process को PID देता है।

उदाहरण

PID = 2456

Process States

Running

Ready

Sleeping

Waiting

Zombie

Stopped

चित्र

Ready

↓

Running

↓

Waiting

↓

Ready

↓

Running

↓

Terminated



Scheduler

Scheduler तय करता है

CPU किस Process को कब मिलेगा।

Linux का Scheduler

Completely Fair Scheduler (CFS)

है।

उदाहरण

Chrome

VS Code

Video Player

तीनों चल रहे हैं।

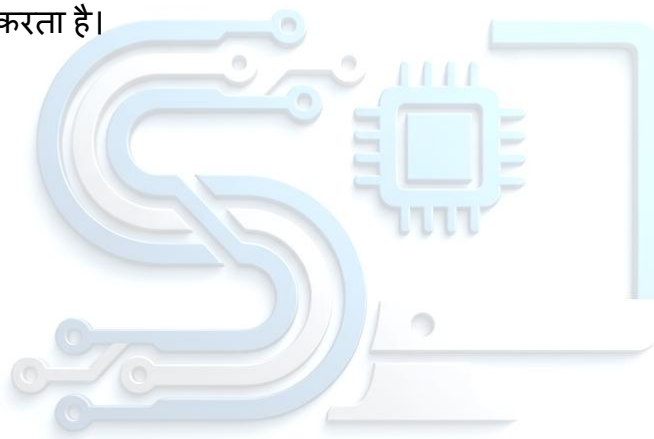
तो Scheduler CPU Time बाँट देगा।

Memory Management

Kernel RAM का प्रबंधन करता है।

मुख्य कार्य

- Allocation
- Deallocation
- Virtual Memory
- Paging
- Swapping
- Caching



चित्र

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Application



Virtual Memory



Physical Memory

Virtual Memory

यदि RAM कम हो जाए

Linux Disk का प्रयोग करता है।

इसे Swap कहते हैं।

उदाहरण

8 GB RAM

2 GB Swap

RAM भरने पर

Swap उपयोग होगी।

File System Management

Linux सब कुछ File मानता है।

उदाहरण

Keyboard

Printer

Hard Disk

USB

Process

सब File के रूप में दिखते हैं।



उदाहरण

/dev/sda

/dev/input

/dev/tty

Device Management

Kernel सभी Devices को Manage करता है।

Commands

lsblk

Storage दिखाता है।

Networking

Kernel TCP/IP Stack संभालता है।

Protocols

TCP

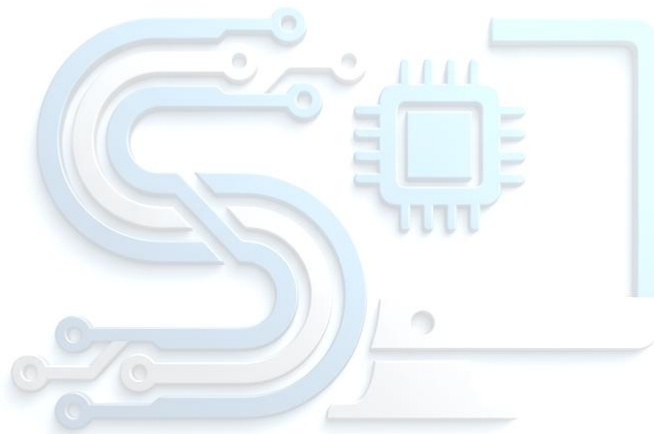
UDP

ICMP

ARP

IPv4

IPv6



उदाहरण

ping google.com

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Kernel ICMP Packet भेजता है।

Security

Kernel Security लागू करता है।

जैसे

Permission

ACL

SELinux

3. System Call Interface (SCI)

Application सीधे Kernel से बात नहीं करती।

System Call के माध्यम से Request भेजती है।

चित्र

Application

↓

System Call

↓

Kernel

उदाहरण

open()

read()

write()

fork()

exec()

close()

यदि कोई Program File खोलना चाहता है

open()

System Call उपयोग होगी।

System Call Flow



glibc



System Call



Kernel



Driver



Hardware

4. System Libraries

Libraries पहले से लिखे गए Functions का संग्रह हैं।

सबसे प्रसिद्ध

GNU C Library (glibc)

उदाहरण

`printf()`

`malloc()`

`scanf()`

ये Library Function हैं।

यदि

`printf("Hello");`

चलता है।

Library

System Call

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

तक संदेश पहुँचाती है।

Shared Library

libc.so

libm.so

libpthread.so

लाभ

RAM कम उपयोग

Fast Loading

Reuse

5. Shell Layer

Shell User और Kernel के बीच Interpreter है।

चित्र

User

↓

Shell

↓

Kernel

Shell के प्रकार

Bash

Zsh

Fish

उदाहरण

mkdir Test

Shell

↓

Kernel

↓

Directory बन जाती है।

यदि लिखें

cp file1 file2

Shell इसे System Calls में बदल देती है।

Bash Shell

Linux में सबसे लोकप्रिय Shell

bash

Commands

pwd

ls

cd

mkdir

rm

mv

cp

Shell Script

```
#!/bin/bash
```

```
echo Hello
```

```
date
```

GUI Layer

Linux केवल Command Line नहीं है।

GUI भी होती है।

जैसे

GNOME

KDE

XFCE

LXQt



GUI Components

Window Manager

Display Server

Widgets

Desktop Environment

Display Server

पुराना

X11

चित्र

Application

↓

GTK

↓

Wayland

↓

Kernel

↓

GPU

6. User Applications

Linux पर चलने वाले सभी Software

Application Layer में आते हैं।

उदाहरण

Firefox

LibreOffice

GIMP

VLC

Chrome

VS Code

Python

Docker

MySQL

Application Execution

जब User

firefox

चलाता है।

Flow

Shell

↓

Loader

↓

Library

↓

Kernel

↓

CPU

↓

Firefox



7. User Layer

यह सबसे ऊपर की Layer है।

यही Computer का वास्तविक उपयोगकर्ता है।

User दो प्रकार के होते हैं—

Root User

Normal User

Root User

Linux का Administrator।

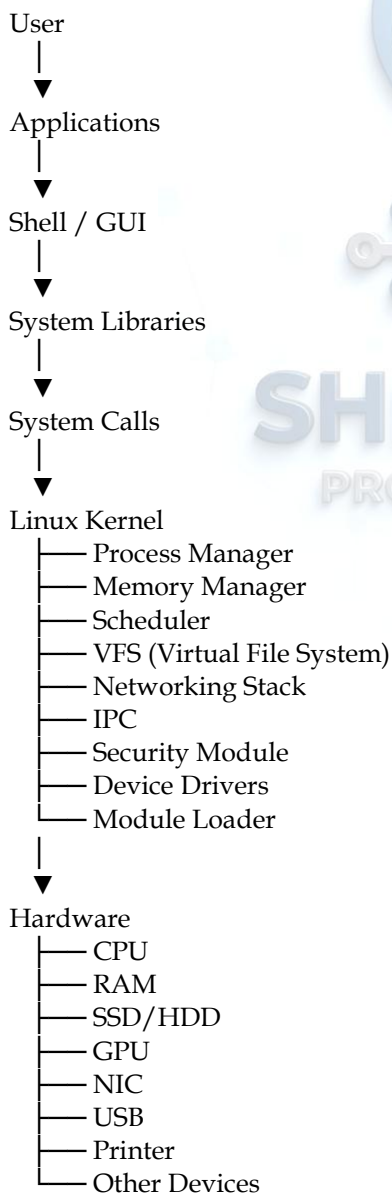
सब कुछ कर सकता है।

UID = 0

Normal User

सीमित अधिकार।

सम्पूर्ण Linux Architecture का Flow



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

एक वास्तविक उदाहरण: `cat report.txt`

मान लीजिए उपयोगकर्ता टर्मिनल में यह कमांड लिखता है:

```
cat report.txt
```

पूरी आर्किटेक्चर में क्या होता है?

1. **User Layer:** उपयोगकर्ता कमांड टाइप करता है।
2. **Shell:** Bash कमांड को पार्स करता है और `cat` प्रोग्राम चलाता है।
3. **System Libraries:** `cat` आवश्यक लाइब्रेरी (जैसे `glibc`) का उपयोग करता है।
4. **System Calls:**
 - `open("report.txt")`
 - `read()`
 - `write()`
 - `close()`
5. **Kernel:**
 - फ़ाइल का Permission जाँचता है।
 - Virtual File System (VFS) के माध्यम से वास्तविक फ़ाइल सिस्टम (`ext4`, `XFS` आदि) तक पहुँचता है।
 - SSD/HDD Driver को डेटा पढ़ने का निर्देश देता है।
6. **Hardware:**
 - स्टोरेज डिवाइस से डेटा RAM में लाया जाता है।
7. **Kernel → User Space:**
 - डेटा `cat` को वापस मिलता है।
8. **Terminal:**
 - `write()` System Call के माध्यम से स्क्रीन पर फ़ाइल की सामग्री प्रदर्शित होती है।

Linux Architecture की प्रमुख विशेषताएँ

विशेषता	विवरण
Open Source	स्रोत कोड उपलब्ध, कोई भी अध्ययन और संशोधन कर सकता है।
Monolithic Kernel Modular	मुख्य सेवाएँ Kernel में, पर Drivers Module के रूप में Load/Unload हो सकते हैं।
Multuser	अनेक उपयोगकर्ता एक साथ कार्य कर सकते हैं।
Multitasking	कई Processes समानांतर चल सकती हैं।
Virtual Memory	RAM के साथ Swap Space का उपयोग।
Strong Security	Users, Groups, Permissions, ACL, SELinux/ AppArmor आदि।

विशेषता	विवरण
Portable	x86, ARM, RISC-V, PowerPC सहित अनेक Architecture पर चलता है।
Stable	Server, Supercomputer, Cloud और Embedded Systems के लिए अत्यंत विश्वसनीय।

निष्कर्ष

Linux Architecture एक **बहु-स्तरीय (Layered)** तथा **मॉड्यूलर (Modular)** संरचना है जिसमें **Hardware, Linux Kernel, System Call Interface, System Libraries, Shell/GUI, Applications** और **User** मिलकर एक सुरक्षित, कुशल और उच्च-प्रदर्शन Operating System का निर्माण करते हैं। Kernel इस पूरी संरचना का केंद्रीय भाग है, जो CPU, Memory, File System, Device Drivers, Networking और Security का समन्वय करता है। यही सुविचारित आर्किटेक्चर Linux को विश्व के अधिकांश **Servers, Cloud Platforms, Android Devices, Supercomputers, IoT Systems** तथा **Cyber Security और Digital Forensics** के क्षेत्र में सबसे अधिक उपयोग किए जाने वाले Operating Systems में से एक बनाती है।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्याय 15

Kernel Security (कर्नेल सुरक्षा)

Linux Kernel Security –

प्रस्तावना (Introduction)

जब हम Linux Operating System का उपयोग करते हैं, तब अधिकांश उपयोगकर्ताओं को केवल Desktop, Terminal, या Applications दिखाई देते हैं। लेकिन इन सभी के पीछे जो सबसे महत्वपूर्ण भाग कार्य करता है, वह Linux Kernel है।

यदि Linux Operating System की तुलना मानव शरीर से की जाए, तो—

- Hardware = शरीर
- Applications = हाथ-पैर
- User = मस्तिष्क से आदेश देने वाला व्यक्ति
- Kernel = हृदय (Heart) और तंत्रिका तंत्र (Nervous System)

यदि Kernel सुरक्षित नहीं रहेगा, तो पूरा Operating System असुरक्षित हो जाएगा।

इसीलिए Cyber Security में एक प्रसिद्ध कथन है—

"If the Kernel is Compromised, the Entire System is Compromised."
यदि Kernel पर हमला सफल हो गया, तो पूरा सिस्टम हमलावर के नियंत्रण में जा सकता है।

Kernel Security क्या है?

Kernel Security उन सभी तकनीकों, नियमों, सुरक्षा मॉड्यूलों, स्मृति-सुरक्षा (Memory Protection), एक्सेस नियंत्रण (Access Control), प्रक्रिया पृथक्करण (Process Isolation), ड्राइवर सुरक्षा, और हार्डवेयर सुरक्षा तंत्रों का समूह है जिनका उद्देश्य Linux Kernel को अनधिकृत पहुँच, दुर्भावनापूर्ण कोड, मेमोरी हमलों और विशेषाधिकार (Privilege) बढ़ाने वाले हमलों से सुरक्षित रखना है।

दूसरे शब्दों में—

Kernel Security वह विज्ञान है जो Kernel को स्वयं सुरक्षित रखता है तथा उसके माध्यम से पूरे Operating System की सुरक्षा सुनिश्चित करता है।

Kernel Security की आवश्यकता क्यों?

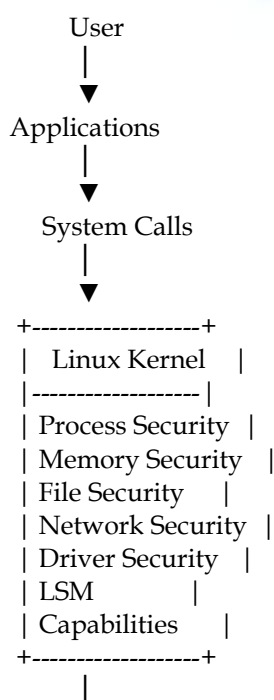
कल्पना कीजिए कि किसी कंपनी का Linux Server बैंक के करोड़ों ग्राहकों का डेटा संभाल रहा है।

यदि कोई हमलावर Kernel में प्रवेश कर ले—

- Root Access प्राप्त कर सकता है।
- Password बदल सकता है।
- Memory पढ़ सकता है।
- Encryption Keys चुरा सकता है।
- Logs मिटा सकता है।
- Rootkit स्थापित कर सकता है।
- Network Traffic बदल सकता है।
- पूरा Server अपने नियंत्रण में ले सकता है।

इसलिए Kernel Security केवल Operating System की सुरक्षा नहीं, बल्कि पूरे संगठन की सुरक्षा का आधार है।

Linux Security Architecture



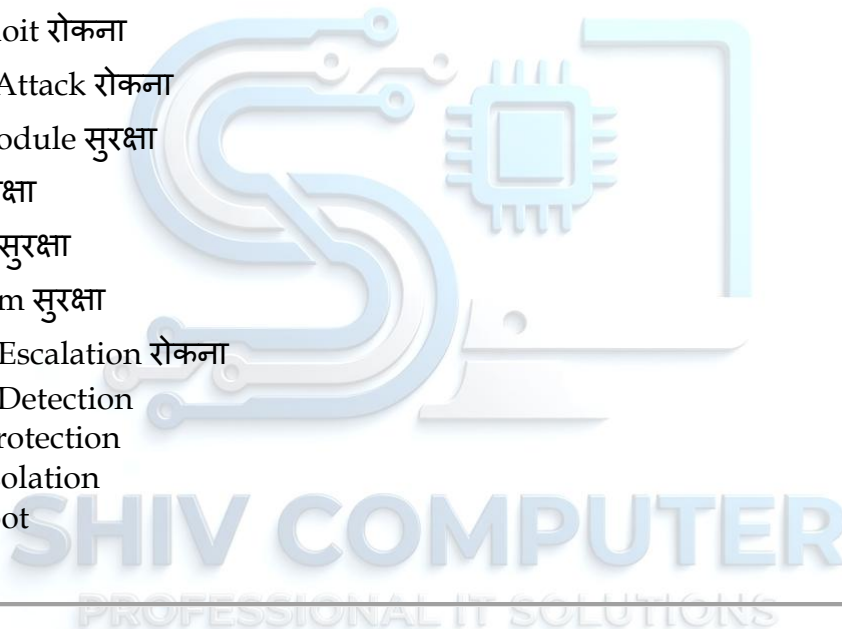
Kernel प्रत्येक स्तर पर सुरक्षा लागू करता है।

Kernel Security के प्रमुख उद्देश्य

Kernel Security का मुख्य लक्ष्य केवल वायरस रोकना नहीं है, बल्कि पूरे सिस्टम की विश्वसनीयता बनाए रखना है।

मुख्य उद्देश्य—

- Unauthorized Access रोकना
- Root Exploit रोकना
- Memory Attack रोकना
- Kernel Module सुरक्षा
- Driver सुरक्षा
- Network सुरक्षा
- File System सुरक्षा
- Privilege Escalation रोकना
- Malware Detection
- Rootkit Protection
- Process Isolation
- Secure Boot



Kernel Protection Layers

Linux Kernel कई सुरक्षा स्तरों (Security Layers) पर कार्य करता है।

User Authentication



Access Control



Permissions



Capabilities



LSM



Memory Protection

Hardware Protection

हर स्तर अगले स्तर की रक्षा करता है।

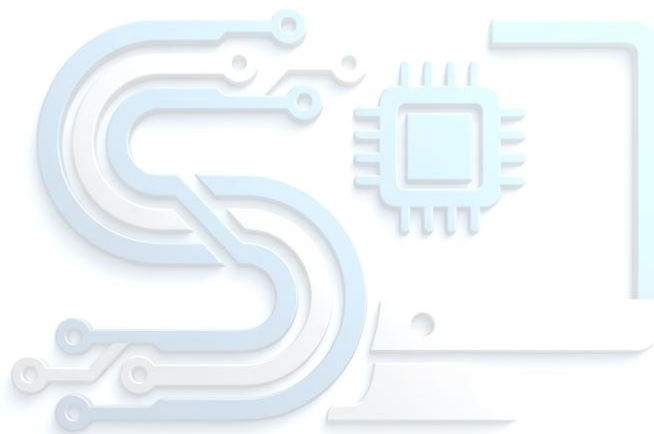
User Space और Kernel Space

Kernel Security को समझने से पहले User Space और Kernel Space को समझना आवश्यक है।

+-----+	
User Space	
Firefox	
Chrome	
VLC	
LibreOffice	
+-----+	

System Calls

+-----+	
Kernel Space	
Memory Manager	
Scheduler	
File System	
Drivers	
+-----+	



User Space

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

यहाँ सामान्य Applications चलती हैं।

उदाहरण—

- Firefox
- Chrome
- VS Code
- Python

इनके पास Hardware का सीधा नियंत्रण नहीं होता।

Kernel Space

यह सबसे सुरक्षित भाग होता है।

यहाँ केवल Kernel Code चलता है।

यह सीधे नियंत्रित करता है—

- CPU
- RAM
- SSD
- Network Card
- USB
- Printer

यदि कोई सामान्य Application सीधे Kernel Memory तक पहुँचने का प्रयास करे, तो Kernel उसे रोक देता है और आवश्यक होने पर Process को समाप्त (Kill) भी कर सकता है।

Kernel Memory Protection

Linux प्रत्येक Process के लिए अलग Virtual Address Space बनाता है।

Process A

```
+-----+
| Memory |
| Stack  |
| Heap   |
+-----+
```

Process B

```
+-----+
| Memory |
| Stack  |
| Heap   |
+-----+
```



Process A सीधे Process B की Memory नहीं पढ़ सकता।

इसी प्रकार User Space सीधे Kernel Memory नहीं पढ़ सकता।

Kernel Address Space Layout Randomization (KASLR)

यदि Kernel हमेशा Memory के एक ही Address पर Load हो, तो Attackers उसके Function Address आसानी से खोज सकते हैं।

उदाहरण (असुरक्षित स्थिति):

Kernel
0xffffffff81000000

हर बार यही Address।

अब हमलावर Exploit तैयार कर सकता है।

समाधान

Linux Boot के समय Kernel को Random Memory Location पर Load करता है।

उदाहरण:

पहला Boot

Kernel
0xffffffff84000000

दूसरा Boot

Kernel
0xffffffff8c000000

तीसरा Boot

Kernel
0xffffffff92000000

हर बार Address बदल जाता है।

इसे KASLR (Kernel Address Space Layout Randomization) कहते हैं।

इससे Return-Oriented Programming (ROP) और Memory Corruption Exploits की सफलता की संभावना काफी कम हो जाती है।

Write XOR Execute (W^X)

Kernel Memory के किसी भाग को एक साथ लिखने योग्य (Writable) और चलाने योग्य (Executable) नहीं बनने देता।

सरल नियम:

- यदि Memory में लिखा जा सकता है → उसे Execute नहीं किया जा सकता।
- यदि Memory Execute हो सकती है → उसमें नया Code नहीं लिखा जा सकता।

इससे Shellcode Injection जैसे कई हमले कठिन हो जाते हैं।

SMEP (Supervisor Mode Execution Prevention)

SMEP एक आधुनिक CPU सुरक्षा सुविधा है।

यदि Kernel Mode में चल रहा Code User Space के किसी पते पर स्थित Code को Execute करने का प्रयास करे, तो CPU उसे रोक देता है और Exception उत्पन्न करता है।

इसका उद्देश्य है कि Kernel को User Space में छिपाए गए दुर्भावनापूर्ण Code को चलाने से रोका जाए।

SMAP (Supervisor Mode Access Prevention)

SMAP Kernel को User Space Memory को अनावश्यक रूप से पढ़ने या लिखने से रोकता है।

जब तक Kernel विशेष रूप से अनुमति न दे, वह User Memory तक पहुँच नहीं सकता।

यह Memory Safety को और मजबूत बनाता है।

NX Bit (No-eXecute)

Memory के कुछ क्षेत्रों (जैसे Stack और Heap) को केवल Data रखने के लिए उपयोग किया जाता है।

यदि कोई हमलावर Stack में Shellcode Inject करे और उसे चलाने की कोशिश करे, तो NX Bit उस Memory को Execute होने से रोक देता है।

Kernel Stack Protection

Kernel प्रत्येक Thread के लिए अलग Stack प्रदान करता है।

इसके साथ कई सुरक्षा तंत्र जोड़े जाते हैं, जैसे—

- Stack Canary
- Stack Overflow Detection
- Stack Guard Pages

यदि Stack Overflow का प्रयास होता है, तो Kernel Process को Crash कर सकता है ताकि हमला आगे न बढ़ सके।

Stack Canary

Stack Canary एक विशेष मान (Secret Value) होता है जो Return Address से पहले रखा जाता है।

यदि Buffer Overflow के कारण Return Address बदलने का प्रयास होता है, तो Canary भी बदल जाता है।

Kernel Canary की जाँच करता है।

यदि Canary बदल चुका हो—

Kernel Panic
या
Process Abort

हमला विफल हो जाता है।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

निष्कर्ष

Kernel Security Linux की सुरक्षा का सबसे महत्वपूर्ण आधार है। यह केवल User Authentication तक सीमित नहीं है, बल्कि Memory Protection, Process Isolation, Hardware Security Features (KASLR, SMEP, SMAP, NX), Stack Protection, और Privilege Control जैसी अनेक परतों के माध्यम से पूरे Operating System की रक्षा करती है। आधुनिक Linux Kernel "Defense in Depth" सिद्धांत का पालन करता है, जहाँ एक सुरक्षा परत के विफल होने पर दूसरी परत हमले को रोकने का प्रयास करती है।

यह "भाग-1" है। आगे के भागों में Linux Security Modules (SELinux, AppArmor), Capabilities, seccomp, Namespaces, cgroups, Kernel Lockdown, Secure Boot, Module Signing, Rootkits, eBPF Security, Integrity Measurement Architecture (IMA), Extended Verification Module (EVM), Kernel Self-Protection Project (KSPP) तथा वास्तविक Cyber Attack और Digital Forensics Case Studies का पुस्तक-स्तरीय विस्तृत अध्ययन किया जाएगा।



अध्याय 15 (भाग-2)

Kernel Security (कर्नेल सुरक्षा)

Linux Security Modules (LSM), SELinux, AppArmor, Capabilities एवं Kernel Access Control

भूमिका

पिछले भाग में हमने Kernel Security की मूल अवधारणाओं को समझा था—

- Kernel Space
- User Space
- Memory Protection
- KASLR
- SMEP
- SMAP
- NX Bit
- Stack Canary

अब प्रश्न यह उठता है—

यदि कोई User Root बन जाए, तो क्या वह सब कुछ कर सकता है?

पुराने UNIX सिस्टम में उत्तर था—

हाँ।

लेकिन आधुनिक Linux में उत्तर है—

हमेशा नहीं।

यही आधुनिक Linux Security का सबसे बड़ा परिवर्तन है।

आज Linux केवल User ID (UID) पर निर्भर नहीं करता, बल्कि अनेक अतिरिक्त सुरक्षा परतों का उपयोग करता है।

इनमें सबसे महत्वपूर्ण हैं—

- Linux Security Modules (LSM)

- SELinux
- AppArmor
- Capabilities
- seccomp
- Landlock
- TOMOYO
- Smack

Linux Security Modules (LSM)

LSM क्या है?

Linux Security Modules (LSM) Kernel के अंदर एक Framework है जो विभिन्न Security Modules को Kernel के साथ जोड़ने की सुविधा देता है।

दूसरे शब्दों में—

LSM स्वयं Security नहीं करता।

यह केवल Security Modules को Kernel के अंदर काम करने का Platform देता है।

उदाहरण

मान लीजिए एक कंपनी में Security Gate बना हुआ है।

Gate स्वयं किसी को नहीं रोकता।

Gate पर Guard बैठा होता है।

Gate = LSM

Guard = SELinux

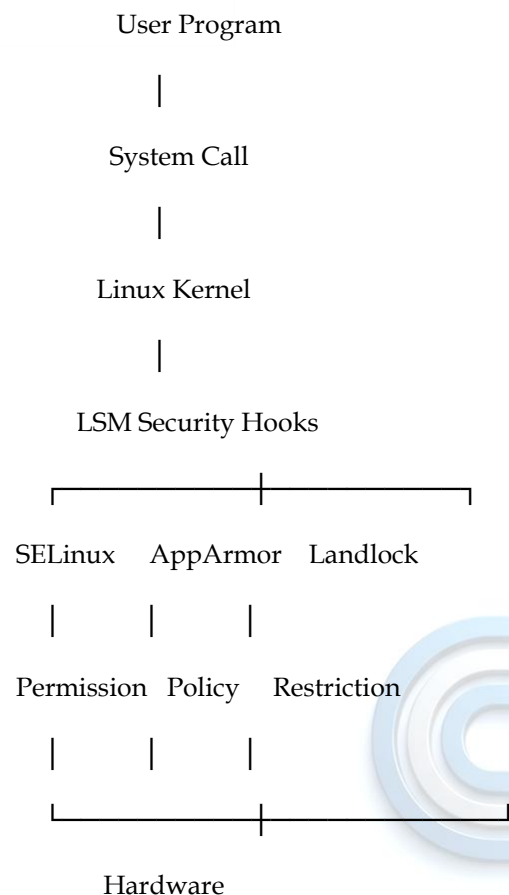
या

Guard = AppArmor

LSM Framework है।

SELinux Policy लागू करता है।

LSM Architecture



Security Hook क्या होता है?

Linux Kernel के हजारों स्थानों पर Security Hooks लगे होते हैं।

उदाहरण

जब कोई Process File खोलती है—

Kernel पहले File नहीं खोलता।

सबसे पहले पूछता है—

क्या अनुमति है?

यह प्रश्न LSM से पूछा जाता है।

यदि LSM अनुमति देता है—

File Open

वास्तविक उदाहरण

मान लीजिए

```
cat secret.txt
```

चलाया गया।

Flow

User



Shell



open()



Kernel



LSM Hook



SELinux Policy



Permission?



YES



File Open

यदि Policy मना कर दे

Permission Denied



LSM Hooks कहाँ-कहाँ होते हैं?

Linux Kernel में लगभग हर संवेदनशील कार्य के पहले Hook लगाया गया है।

जैसे—

File Access

open()

read()

write()

unlink()

Process

fork()

exec()

kill()

Networking

Socket Create

Bind

Listen

Connect

Accept

IPC

Shared Memory

Semaphore

Message Queue

Mount

Mount

Unmount



SELinux

अब सबसे प्रसिद्ध Security Module।

SELinux

पूरा नाम

Security Enhanced Linux

इसे विकसित किया

NSA

(National Security Agency)

ने।

बाद में

Red Hat

Fedora

CentOS

Oracle Linux

में शामिल किया गया।

SELinux क्यों बनाया गया?

पहले Linux केवल

User

Group

से सुरक्षा करता था।

लेकिन यदि Root Account Hack हो जाए

तो

Root

सब कुछ कर सकता था।

NSA ने कहा—

Root को भी सीमित करना चाहिए।

यहीं से SELinux आया।

SELinux का सिद्धांत

SELinux

DAC नहीं

MAC प्रयोग करता है।

DAC

Discretionary Access Control

Owner Permission देता है।

MAC

Mandatory Access Control

Policy Permission देती है।

Owner भी Policy नहीं बदल सकता।

उदाहरण

मान लीजिए

secret.db

Root के पास है।

लेकिन SELinux Policy कहती है—

Database Process

ही

इसे पढ़ सकता है।

अब

Root

यदि

cat secret.db

चलाए

तो

SELinux

मना कर देगा।



SELinux Context

SELinux केवल Permission नहीं देखता।

यह प्रत्येक Object को Context देता है।

उदाहरण

User

Role

Type

एक File

system_u

object_r

httpd_sys_content_t

s0

Context रख सकती है।

इसका अर्थ

system_u



System User

object_r



Object Role

httpd_sys_content_t



Apache Content

s0



Security Level

यदि Apache File पढ़ना चाहे

Apache



SELinux



Context Check





Allow

यदि Firefox पढ़ना चाहे

Firefox



SELinux



Reject

SELinux Modes

SELinux तीन Mode में चलता है।

1. Enforcing

Policy लागू

गलत कार्य

Block

हो जाएगा।

2. Permissive

Policy लागू नहीं होती।

लेकिन

Log बनता है।

Allowed

+

Log Generated



3. Disabled

SELinux पूरी तरह बंद।

Security नहीं।

Command

getenforce

Output

Enforcing

AppArmor

अब दूसरा प्रसिद्ध Security Module।

AppArmor

Ubuntu

Debian

OpenSUSE

में अधिक उपयोग होता है।

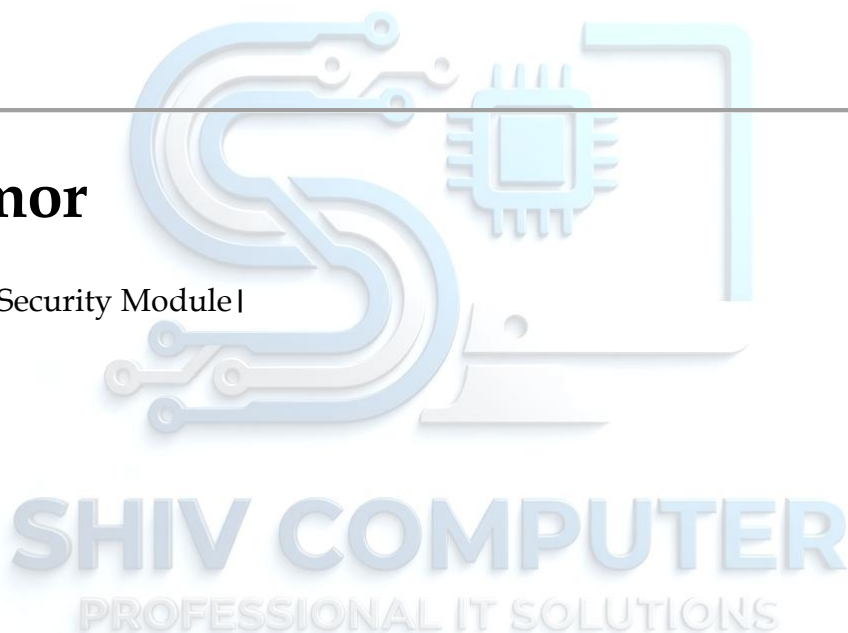
SELinux

Context आधारित है।

लेकिन

AppArmor

Path आधारित है।



/home/user/data.txt

के लिए Rule

Read

Write

Execute

अलग बनाए जा सकते हैं।

उदाहरण

Firefox Profile

/usr/bin/firefox

के लिए

Read Only

Network Allowed

USB Denied

Policy बनाई जा सकती है।



SELinux बनाम AppArmor

विशेषता	SELinux	AppArmor
नियंत्रण मॉडल	Mandatory Access Control (MAC)	Mandatory Access Control (MAC)
पहचान	Label (Context) आधारित	File Path आधारित
जटिलता	अधिक	अपेक्षाकृत कम
सुरक्षा	अत्यधिक मजबूत	सरल लेकिन प्रभावी
प्रमुख उपयोग	RHEL, Fedora, CentOS, Oracle Linux	Ubuntu, Debian, SUSE

Linux Capabilities

अब सबसे रोचक विषय।

पहले

Root

=

सभी Permission।

लेकिन आधुनिक Linux ने

Root Power

को छोटे-छोटे भागों में बाँट दिया।

इन्हें कहते हैं

Capabilities

उदाहरण

Root के पास

100 शक्तियाँ थीं।

Linux ने उन्हें अलग-अलग Capabilities में बाँट दिया।

जैसे—

CAP_NET_ADMIN

↓

Network बदल सकता है।

CAP_SYS_TIME

↓

System Time बदल सकता है।

CAP_SYS_MODULE

↓

Kernel Module Load कर सकता है।



Reboot कर सकता है।

CAP_SYS_ADMIN



बहुत शक्तिशाली Capability

CAP_CHOWN



Owner बदल सकता है।

CAP_DAC_OVERRIDE



Permission Ignore कर सकता है।

वास्तविक उदाहरण

मान लीजिए

एक Backup Program है।

उसे केवल

File Read

चाहिए।

Root बनाने की आवश्यकता नहीं।

तो उसे केवल

CAP_DAC_READ_SEARCH

दी जा सकती है।

बाकी Capabilities नहीं।

यदि Program Hack हो जाए



Capabilities के लाभ

- Least Privilege Principle लागू होता है।
- Root की शक्ति सीमित होती है।
- Privilege Escalation का जोखिम घटता है।
- किसी Process को केवल आवश्यक अधिकार मिलते हैं।

इस भाग का सार

इस भाग में हमने Linux Kernel की उन्नत सुरक्षा संरचना का अध्ययन किया—

- **Linux Security Modules (LSM)** - Kernel में सुरक्षा नीतियों के लिए Framework।
- **Security Hooks** - प्रत्येक संवेदनशील Kernel Operation से पहले अनुमति की जाँच।
- **SELinux** - Context/Label आधारित Mandatory Access Control।
- **AppArmor** - Path आधारित Mandatory Access Control।
- **Linux Capabilities** - Root अधिकारों को छोटे-छोटे विशेषाधिकारों में विभाजित करने की प्रणाली।

इन सभी का मूल उद्देश्य **Least Privilege, Mandatory Policy Enforcement** और **Defense in Depth** को लागू करना है, जिससे किसी एक कमजोरी के कारण पूरा सिस्टम प्रभावित न हो।

अगले भाग (भाग-3) में हम अत्यंत गहराई से अध्ययन करेंगे:

- **seccomp (Secure Computing Mode)**
- **eBPF Security**
- **Namespaces**
- **cgroups**
- **Kernel Lockdown Mode**
- **Secure Boot**
- **Kernel Module Signing**
- **Kernel Rootkits**
- **Real-World Linux Kernel Exploits**
- **Digital Forensics में Kernel Security का महत्व**
- **CVE आधारित वास्तविक केस स्टडी**



अध्याय 15 (भाग-3)

Linux Kernel Security

seccomp, Namespaces, cgroups, Kernel Lockdown, Secure Boot, Module Signing तथा आधुनिक Kernel सुरक्षा तंत्र

भूमिका

पिछले भागों में हमने समझा कि Linux Kernel स्वयं को सुरक्षित रखने के लिए अनेक तकनीकों का उपयोग करता है। लेकिन आधुनिक Cyber Attack केवल Memory Corruption या Permission तक सीमित नहीं हैं।

आज के हमले निम्न प्रकार के होते हैं—

- Browser Sandbox Escape
- Container Escape
- Privilege Escalation
- Kernel Exploit
- Supply Chain Attack
- Malicious Kernel Module
- Bootkit
- Rootkit
- Firmware Attack

इन्हें रोकने के लिए आधुनिक Linux Kernel ने कई उन्नत सुरक्षा तकनीकों को अपनाया है, जिनमें प्रमुख हैं—

- seccomp
- Namespaces
- cgroups
- Secure Boot
- Kernel Lockdown
- Module Signing
- eBPF सुरक्षा नियंत्रण

1. seccomp (Secure Computing Mode)

seccomp क्या है?

seccomp (Secure Computing Mode) Linux Kernel की एक सुरक्षा सुविधा है जो किसी Process को केवल सीमित System Calls करने की अनुमति देती है।

सरल शब्दों में:

"यदि किसी Application को केवल 10 System Calls की आवश्यकता है, तो उसे शेष 400+ System Calls उपयोग करने की अनुमति ही नहीं दी जाएगी।"

System Call Filtering

मान लीजिए Firefox चल रहा है।

उसे आवश्यकता है—

```
read()
write()
open()
close()
mmap()
poll()
recvmsg()
sendmsg()
```

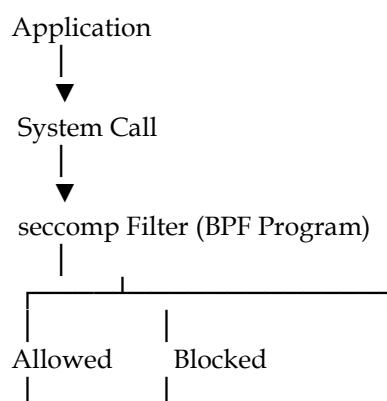
लेकिन यदि Malware उसमें Inject होकर

```
mount()
ptrace()
reboot()
init_module()
```

जैसी System Calls चलाने का प्रयास करे—

Kernel तुरंत रोक देगा।

seccomp Architecture



वास्तविक उदाहरण

मान लीजिए एक Calculator Application है।

उसे केवल चाहिए—

```
read()  
write()  
exit()
```

यदि कोई Exploit उसमें

```
execve("/bin/bash")
```

चलाने का प्रयास करे—

seccomp कहेगा—

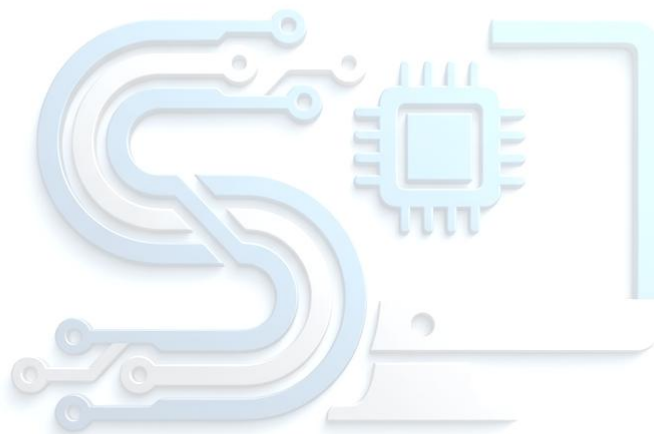
System Call Not Allowed

↓

SIGSYS

↓

Program Terminated



SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

seccomp के लाभ

- Sandbox Security
- Browser Protection
- Docker Security
- Malware रोकना
- Privilege Escalation कम करना

seccomp + Docker

Docker लगभग प्रत्येक Container में seccomp Profile प्रयोग करता है।

उदाहरण



Allowed Syscalls



300

Blocked



150+

इससे Container Host Kernel पर पूर्ण नियंत्रण नहीं प्राप्त कर सकता।

2. Linux Namespaces

अब Linux की सबसे क्रांतिकारी तकनीकों में से एक।

Namespace क्या है?

Namespace Kernel का Isolation Mechanism है।

यह विभिन्न Processes को अलग-अलग दुनिया (Virtual Environment) में रहने का अनुभव कराता है।

उदाहरण

मान लीजिए

एक ही Computer पर

5 Containers चल रहे हैं।

हर Container सोचता है—

मैं ही पूरा Linux हूँ।

लेकिन वास्तव में सभी एक ही Kernel साझा कर रहे होते हैं।

Linux Kernel

Container A Container B

Namespace Namespace

Namespace के प्रकार

Linux कई प्रकार के Namespaces प्रदान करता है।

1. PID Namespace

प्रत्येक Container का अपना Process Tree होता है।

उदाहरण

Host

PID

1

2

3

500

1000

Container

PID

1

2

3

Container के अंदर PID 1 वास्तव में Host पर PID 5230 हो सकता है।

2. Mount Namespace

प्रत्येक Container अपना अलग File System देख सकता है।

Container A

/

etc

home

var

Container B

/

etc

usr

opt

दोनों अलग-अलग File System देखते हैं।

3. Network Namespace

हर Container का अलग

- IP Address
- Routing Table
- Firewall
- Interface

हो सकता है।

उदाहरण

Container A

192.168.1.10

Container B

172.18.0.5

दोनों एक ही मशीन पर हैं।

4. User Namespace

Root User को भी Virtual बनाया जा सकता है।

Container के अंदर

UID 0

Host पर

UID 100000

हो सकता है।

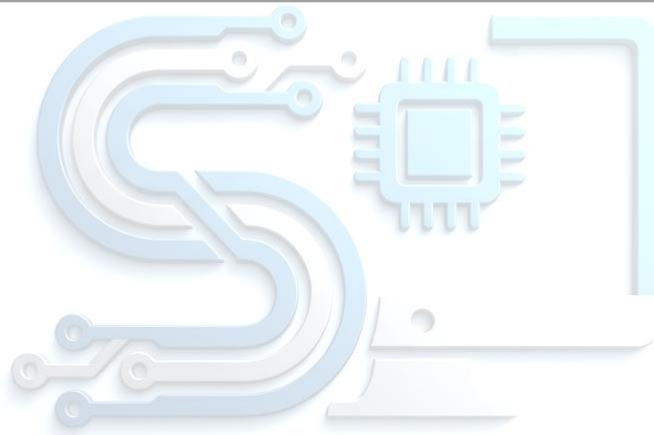
इससे Container Root वास्तव में Host Root नहीं होता।

5. IPC Namespace

हर Container की

- Shared Memory
- Semaphore
- Message Queue

अलग होती है।



6. UTS Namespace

Hostname अलग।

उदाहरण

Container A

webserver

Container B

database

Host

ubuntu-server

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

Namespace का वास्तविक उपयोग

Docker

Podman

Kubernetes

LXC

सभी Namespaces का उपयोग करते हैं।

3. cgroups (Control Groups)

अब प्रश्न उठता है—

यदि एक Process पूरी RAM खा जाए तो?

या

सारा CPU उपयोग कर ले?

Linux इसका समाधान देता है—

cgroups

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

cgroups क्या हैं?

Control Groups किसी Process के Resource उपयोग को सीमित करते हैं।

इनके द्वारा नियंत्रित संसाधन—

- CPU
 - RAM
 - Disk I/O
 - Network
 - PIDs
-

चित्र



cgroup



CPU = 20%

RAM = 1 GB

Disk = 50 MB/s

उदाहरण

मान लीजिए

Web Server

को केवल

CPU

20%

चाहिए।

यदि वह

100%

CPU उपयोग करने लगे—

Kernel उसे

20%

तक सीमित रखेगा।



Memory Control

Container A

RAM

512 MB

दोनों अलग-अलग Memory Limit में रहेंगे।

Docker + cgroups

Docker Container वास्तव में

Namespaces

-

cgroups

का संयोजन है।

4. Kernel Lockdown Mode

Kernel Lockdown आधुनिक Linux की अत्यंत महत्वपूर्ण सुरक्षा सुविधा है।

इसका उद्देश्य है—

Root User भी Kernel को Modify न कर सके।

Lockdown Mode के प्रकार

Integrity Mode

रोकता है—

- /dev/mem Access
 - PCI Configuration
 - Kernel Image Modification
-

Confidentiality Mode

इसके अतिरिक्त रोकता है—

- Kernel Memory पढ़ना
- Debug Interface
- Sensitive Information Access

उदाहरण

यदि Root User

/dev/mem

से Kernel Memory पढ़ना चाहे—

Lockdown Mode

Access Denied

दे सकता है।

5. Secure Boot

आज अधिकांश आधुनिक Computer

UEFI

का उपयोग करते हैं।

Secure Boot सुनिश्चित करता है—

Boot होने वाला प्रत्येक Component

विश्वसनीय (Trusted)

हो।

Boot Sequence

Firmware

↓
Secure Boot

↓

GRUB

↓

Signed Kernel

↓

Signed Modules

↓

Linux

यदि Kernel में छेड़छाड़ हुई हो—

Boot Failed

Secure Boot क्यों आवश्यक है?

यदि किसी ने Kernel बदल दिया—

और उसमें Rootkit जोड़ दिया—

तो?

Secure Boot

Signature Verify करेगा।

यदि Signature गलत है—

Kernel Boot ही नहीं होगा।

6. Kernel Module Signing

Linux Kernel में Drivers

Kernel Module

के रूप में Load होते हैं।

उदाहरण

e1000e

usb_storage

snd_hda_intel

यदि कोई Malware

अपना Driver Load करना चाहे—

तो?

Module Signing उसे रोक सकता है।

कार्यप्रणाली

Module

↓

Digital Signature

↓

Kernel Verification

↓

Valid?

↓

YES → Load

NO → Reject

उदाहरण

modprobe evil_driver

यदि Module Signed नहीं है—

Kernel



दिखा सकता है।

7. eBPF Security (परिचय)

eBPF (Extended Berkeley Packet Filter) Linux Kernel में सुरक्षित रूप से छोटे Programs चलाने की तकनीक है।

इसका उपयोग—

- Network Filtering
- Performance Monitoring
- Security Monitoring
- Observability

में होता है।

eBPF Verifier

कोई भी eBPF Program सीधे Kernel में नहीं चलता।

पहले—

Verifier

जाँच करता है—

- Infinite Loop?
- Unsafe Pointer?
- Memory Corruption?
- Invalid Access?

यदि Program सुरक्षित है—

तभी Kernel उसे चलाता है।

वास्तविक सुरक्षा उदाहरण

मान लीजिए किसी Server पर Malware बार-बार

execve()

System Call चला रहा है।

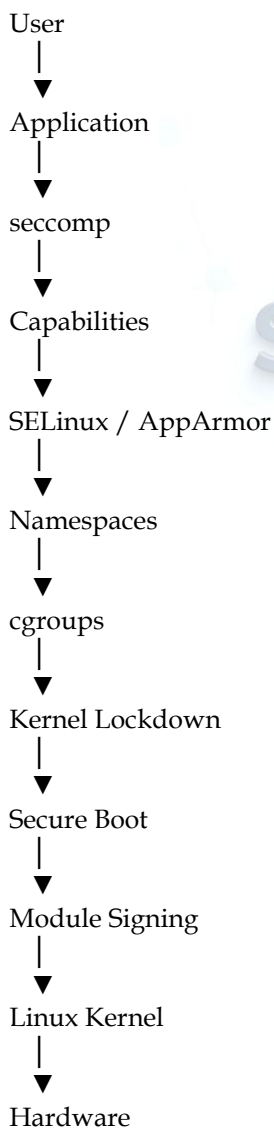
eBPF Program इसे Monitor कर सकता है।

यदि संदिग्ध व्यवहार मिले—

- Alert
- Logging
- Blocking

किया जा सकता है।

आधुनिक Linux सुरक्षा का संयुक्त मॉडल



Cyber Security एवं Digital Forensics में महत्व

इन तकनीकों का उपयोग निम्न क्षेत्रों में व्यापक रूप से होता है—

- Cloud Security (AWS, Azure, GCP)
- Kubernetes Cluster सुरक्षा
- Docker Container सुरक्षा
- Web Server Hardening
- Digital Forensics में Compromise Analysis
- Malware Sandboxing
- SOC (Security Operations Center)
- Endpoint Detection and Response (EDR)
- Threat Hunting
- Incident Response

उदाहरण के लिए, यदि किसी Container से Host पर हमला करने का प्रयास किया जाता है, तो Forensic Investigator को Namespaces, cgroups, Capabilities, seccomp Policies, Audit Logs, और SELinux/AppArmor Logs का विश्लेषण करना पड़ता है ताकि यह निर्धारित किया जा सके कि हमला किस स्तर पर रोका गया या कहाँ से सफल हुआ।

अगले भाग (भाग-4) में

अगले भाग में हम Linux Kernel Security के और भी गहरे विषयों का अध्ययन करेंगे:

- Kernel Rootkits (LKM एवं Memory Rootkits)
- Kernel Exploitation Techniques
- Privilege Escalation की वास्तविक प्रक्रिया
- Kernel Heap एवं SLAB/SLUB सुरक्षा
- Use-After-Free और Buffer Overflow Exploits
- Kernel Self Protection Project (KSPP)
- Linux Audit Framework
- IMA (Integrity Measurement Architecture)
- EVM (Extended Verification Module)
- वास्तविक CVE आधारित केस स्टडी
- Digital Forensics द्वारा Kernel Compromise की पहचान और जाँच

यह भाग Linux Kernel Security को Offensive Security और Defensive Security दोनों दृष्टिकोणों से समझने में सहायता करेगा।



अध्याय 15 (भाग-4)

Linux Kernel Security

Kernel Rootkits, Kernel Exploitation, Memory Protection और Digital Forensics

भूमिका

अब तक हमने Linux Kernel Security की Defensive (रक्षात्मक) तकनीकों का अध्ययन किया। इस भाग में हम यह समझेंगे कि वास्तविक दुनिया में हमलावर Kernel को किस प्रकार लक्ष्य बनाते हैं, किन प्रकार की कमजोरियों का दुरुपयोग करते हैं, और आधुनिक Linux Kernel उन हमलों के विरुद्ध किस प्रकार सुरक्षा प्रदान करता है।

महत्वपूर्ण: यह अध्याय केवल शैक्षिक (Educational) और Defensive Cyber Security के उद्देश्य से है। इसका उद्देश्य सुरक्षा तंत्र को समझना, सुरक्षित सिस्टम डिजाइन करना और Digital Forensics के माध्यम से घटनाओं का विश्लेषण करना है। इसमें किसी हमले को करने के चरण या दुरुपयोग योग्य निर्देश नहीं दिए जा रहे हैं।

अध्याय की रूपरेखा

इस भाग में हम निम्न विषयों का अध्ययन करेंगे—

1. Kernel Rootkit क्या है?
2. Rootkit का इतिहास
3. Rootkit के प्रकार
4. Kernel Module (LKM) आधारित Rootkit
5. Memory आधारित Rootkit
6. Bootkit और Firmware आधारित खतरे
7. Kernel Vulnerabilities का परिचय
8. Memory Corruption की अवधारणा
9. Buffer Overflow
10. Use-After-Free (सैद्धांतिक)

11. Race Condition
12. Integer Overflow
13. Linux Kernel Memory Allocator
14. SLAB, SLUB और SLOB
15. Kernel Heap सुरक्षा
16. Kernel Self Protection Project (KSPP)
17. Digital Forensics में Rootkit Detection

Rootkit क्या होता है?

Rootkit एक ऐसा दुर्भावनापूर्ण (Malicious) Software Framework है जिसका उद्देश्य हमलावर की उपस्थिति को छिपाना तथा उच्च स्तर का नियंत्रण बनाए रखना होता है।

Rootkit सामान्य Malware से अधिक खतरनाक होता है क्योंकि यह—

- स्वयं को छिपा सकता है।
- Processes छिपा सकता है।
- Files छिपा सकता है।
- Network Connections छिपा सकता है।
- Logs में परिवर्तन कर सकता है।
- सुरक्षा उपकरणों से बचने का प्रयास कर सकता है।

Rootkit का नाम क्यों पड़ा?

UNIX में Administrator को

Root

कहा जाता है।

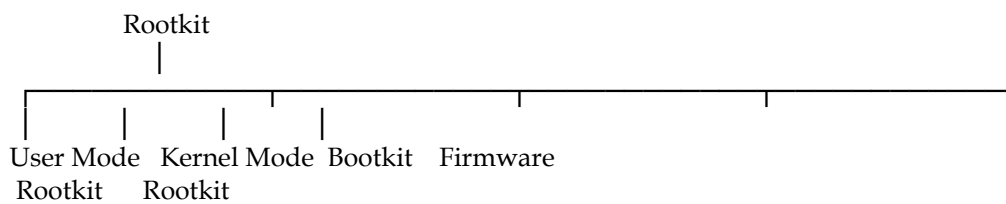
जो Tool Root अधिकार प्राप्त करने या Root स्तर पर छिपकर कार्य करने के लिए बनाए गए, उन्हें

Root + Kit = Rootkit

कहा गया।

Rootkit के प्रकार

Linux में Rootkits को कई श्रेणियों में बाँटा जा सकता है।



1. User Mode Rootkit

यह User Space में कार्य करता है।

यह सामान्य Applications या Libraries को प्रभावित करने का प्रयास करता है।

उदाहरण के रूप में यह—

- Fake Library का उपयोग
- Environment Manipulation
- Process Hiding

जैसी तकनीकों का उपयोग कर सकता है।

2. Kernel Mode Rootkit

यह सबसे खतरनाक श्रेणी है।

यदि कोई दुर्भावनापूर्ण कोड Kernel Mode में पहुँच जाए तो वह पूरे सिस्टम के व्यवहार को प्रभावित कर सकता है।

इसलिए आधुनिक Linux Kernel में—

- Module Signing
- Secure Boot
- Lockdown Mode
- LSM

जैसी सुरक्षा तकनीकें महत्वपूर्ण भूमिका निभाती हैं।

Kernel Rootkit क्यों खतरनाक है?

Kernel के पास पहुँच होती है—

- CPU
- RAM
- Storage
- Network
- Device Drivers
- Process Scheduler

अर्थात् Kernel के स्तर पर छेड़छाड़ पूरे Operating System को प्रभावित कर सकती है।

Linux Kernel Module (LKM)

Linux Kernel को इस प्रकार बनाया गया है कि कई Drivers तथा Components को Runtime में Module के रूप में जोड़ा जा सके।

उदाहरण—

USB Driver

Wi-Fi Driver

Bluetooth Driver

Filesystem Driver

इन Modules का उद्देश्य वैध Hardware Support देना है।

इसी कारण Module Loading की सुरक्षा अत्यंत महत्वपूर्ण होती है।

आधुनिक Linux Module सुरक्षा

Kernel निम्न सुरक्षा उपायों का उपयोग कर सकता है—

- Digital Signature Verification
- Secure Boot
- Kernel Lockdown
- Trusted Keys
- Revoked Certificates

यदि Module विश्वसनीय नहीं है, तो उसे Load होने से रोका जा सकता है।

Memory आधारित Rootkit

कुछ प्रकार के दुर्भावनापूर्ण कार्यक्रम केवल Memory में रहते हैं।

विशेषताएँ—

- Reboot के बाद समाप्त हो सकते हैं।
- Disk पर कोई स्पष्ट File न हो।
- Detection कठिन हो सकती है।

इसी कारण Memory Forensics अत्यंत महत्वपूर्ण है।

Bootkit

Bootkit Boot Process को लक्ष्य बनाता है।

यदि Boot Loader या Boot Chain प्रभावित हो जाए तो Operating System के प्रारंभ होने से पहले ही दुर्भावनापूर्ण कोड सक्रिय हो सकता है।

इसीलिए—

- UEFI Secure Boot
- Trusted Platform Module (TPM)
- Signed Boot Loader

का उपयोग किया जाता है।

Firmware आधारित खतरे

Firmware Hardware के भीतर चलने वाला Software होता है।

उदाहरण—

- UEFI Firmware
- SSD Firmware

- Network Card Firmware

Firmware सुरक्षा का उद्देश्य यह सुनिश्चित करना है कि Hardware स्तर पर अनधिकृत परिवर्तन न हो।

Kernel Vulnerability क्या है?

Kernel Vulnerability वह कमजोरी है जिसके कारण Kernel अपेक्षित सुरक्षा व्यवहार से भिन्न कार्य कर सकता है।

कारण—

- Programming Error
 - Logic Error
 - Memory Handling Bug
 - Synchronization Bug
 - Input Validation की कमी
-

Memory Corruption

Memory Corruption वह स्थिति है जिसमें Memory का डेटा अनजाने में बदल जाता है।

यह कई कारणों से हो सकता है—

- Invalid Pointer
 - Out-of-Bounds Access
 - Double Free
 - Use-After-Free
 - Integer Overflow
-

आधुनिक Kernel इन जोखिमों को कम करने के लिए अनेक सुरक्षा उपाय अपनाता है।

Buffer Overflow (सैद्धांतिक समझ)

कल्पना कीजिए कि एक डिब्बे में केवल 10 गेंदें रखने की जगह है।

यदि उसमें 20 गेंदें डालने का प्रयास किया जाए—

तो गेंदें बाहर फैल जाएँगी।

यही अवधारणा Buffer Overflow की है।

Kernel में ऐसे जोखिमों को कम करने के लिए—

- Stack Canary
- Fortified Functions
- Compiler Hardening
- Bounds Checking

का उपयोग किया जाता है।

Use-After-Free (सैद्धांतिक)

कल्पना करें—

आपने किसी पुस्तकालय की पुस्तक वापस कर दी।

लेकिन बाद में उसी पुस्तक को अपना मानकर उपयोग करने लगे।

यह अवधारणा Use-After-Free से मिलती-जुलती है।

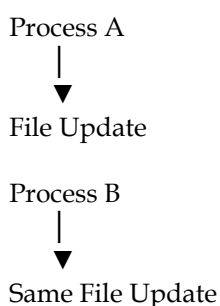
Kernel विकास में यह एक गंभीर Programming Bug माना जाता है।

आधुनिक Memory Safety तकनीकें ऐसे जोखिमों को कम करने का प्रयास करती हैं।

Race Condition

Race Condition तब होती है जब दो या अधिक Threads या Processes एक ही संसाधन पर लगभग एक ही समय में कार्य करते हैं और परिणाम अनिश्चित हो जाता है।

उदाहरण—



यदि Synchronization सही न हो तो डेटा असंगत (Inconsistent) हो सकता है।

Linux Memory Allocator

Kernel Memory Allocation के लिए विशेष Allocators का उपयोग करता है।

मुख्य प्रकार—

- SLAB
- SLUB
- SLOB (पुराने Embedded Systems में)

इनका उद्देश्य है—

- तेज Allocation
- कम Fragmentation
- बेहतर Performance
- सुरक्षित Memory प्रबंधन

SLAB Allocator

SLAB समान प्रकार की Objects को Cache में रखता है।

उदाहरण—

यदि Kernel बार-बार एक ही आकार की Objects बनाए—

तो हर बार नई Memory खोजने की आवश्यकता नहीं पड़ती।

इससे Performance बढ़ती है।

SLUB Allocator

आधुनिक Linux में SLUB अधिक प्रचलित है।

इसके लाभ—

- सरल Design
- कम Memory Overhead

- बेहतर Scalability
- Multi-Core Performance

Kernel Heap Protection

Kernel Heap की सुरक्षा के लिए आधुनिक Linux कई उपाय अपनाता है—

- Randomization
- Memory Initialization
- Poisoning
- Hardened Allocator
- Bounds Checking

इनका उद्देश्य Memory Corruption के प्रभाव को कम करना है।

Kernel Self Protection Project (KSPP)

KSPP (Kernel Self Protection Project) का लक्ष्य Linux Kernel को स्वयं अधिक सुरक्षित बनाना है।

मुख्य उद्देश्य—

- Memory Safety
- Control Flow Protection
- Compiler Hardening
- Stack Protection
- Heap Protection
- Safer APIs
- Bug Mitigation

यह Linux समुदाय की एक दीर्घकालिक सुरक्षा पहल है।

Digital Forensics में Rootkit Detection

यदि किसी Linux Server पर संदिग्ध गतिविधि दिखाई दे—

तो Forensic Investigator निम्न स्रोतों का अध्ययन करता है—

1. System Logs

- journalctl

- syslog
- auth logs

2. Kernel Logs

dmesg

Kernel Events का महत्वपूर्ण स्रोत।

3. Loaded Modules

यह जाँचा जाता है कि कौन-कौन से वैध Kernel Modules सक्रिय हैं।

4. Running Processes

Hidden Process या असामान्य Process व्यवहार की जाँच।

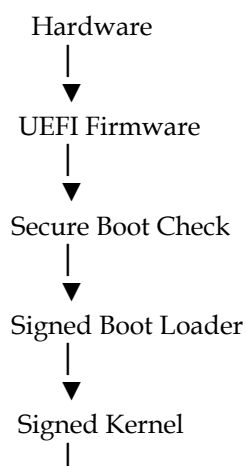
5. Memory Analysis

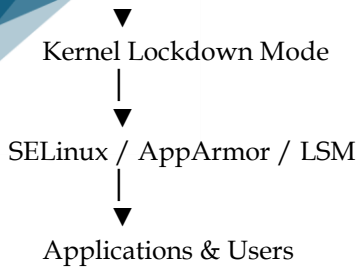
RAM का विश्लेषण कर यह पता लगाया जाता है कि कोई संदिग्ध कोड केवल Memory में तो सक्रिय नहीं है।

6. Boot Chain Verification

Secure Boot, Boot Loader और Kernel Image की Integrity जाँची जाती है।

वास्तविक सुरक्षा मॉडल





यदि किसी एक स्तर पर हमला हो भी जाए, तो अन्य सुरक्षा परतें उसे रोकने या उसके प्रभाव को सीमित करने का प्रयास करती हैं। यही **Defense in Depth** का मूल सिद्धांत है।

अध्याय का सार

इस भाग में हमने Linux Kernel Security के उन पहलुओं का अध्ययन किया जो आधुनिक Cyber Security और Digital Forensics दोनों के लिए अत्यंत महत्वपूर्ण हैं—

- Rootkit की अवधारणा और प्रकार
- Kernel Module सुरक्षा
- Memory आधारित खतरे
- Bootkit और Firmware सुरक्षा
- Kernel Vulnerabilities का परिचय
- Buffer Overflow, Use-After-Free और Race Condition की सैद्धांतिक समझ
- SLAB/SLUB Memory Allocators
- Kernel Self Protection Project (KSPP)
- Digital Forensics में Kernel सुरक्षा का विश्लेषण

इन विषयों की गहरी समझ किसी भी Linux Security Engineer, Digital Forensic Investigator, SOC Analyst, Malware Analyst, या PhD शोधकर्ता के लिए अत्यंत उपयोगी है।

अगले भाग (भाग-5) में

हम Linux Kernel Security के और भी उन्नत विषयों का अध्ययन करेंगे—

- Linux Audit Framework (auditd)
- Integrity Measurement Architecture (IMA)
- Extended Verification Module (EVM)
- Trusted Platform Module (TPM)
- Measured Boot
- Remote Attestation
- dm-verity
- fs-verity

- Confidential Computing (SEV, TDX आदि का परिचय)
- Enterprise Linux Hardening
- वास्तविक CVE विश्लेषण और Forensic Case Studies



अध्याय 15 (भाग-5)

Linux Kernel Security

Linux Audit Framework (auditd), IMA, EVM, TPM, Measured Boot, dm-verity, fs-verity एवं Enterprise Kernel Security

प्रस्तावना

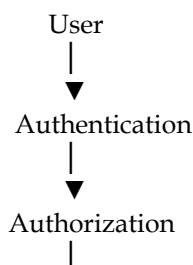
पिछले चार भागों में हमने Linux Kernel Security की मूलभूत एवं उन्नत अवधारणाओं का अध्ययन किया। अब हम उन सुरक्षा तकनीकों की ओर बढ़ते हैं जिनका उपयोग सरकारी संस्थानों, रक्षा संगठनों, बैंकिंग सेक्टर, क्लाउड डेटा सेंटर, डिजिटल फॉरेंसिक प्रयोगशालाओं और बड़े Enterprise Linux सर्वरों में किया जाता है।

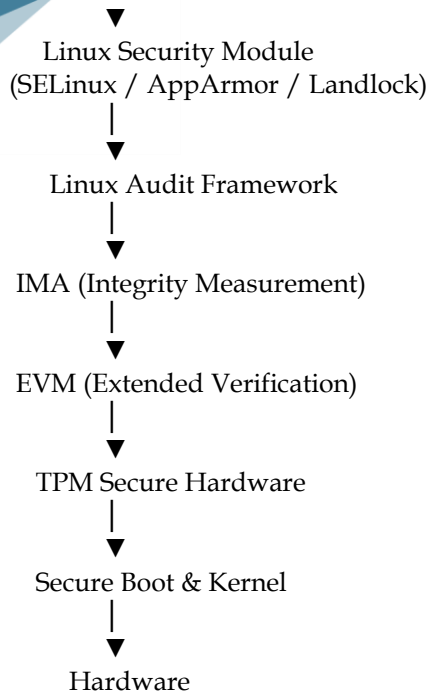
आधुनिक Linux सुरक्षा केवल इस बात तक सीमित नहीं है कि "कौन सिस्टम में लॉगिन कर सकता है?" बल्कि यह भी सुनिश्चित करती है कि:

- सिस्टम फ़ाइलों में अनधिकृत परिवर्तन तो नहीं हुआ?
- Kernel वही है जो Boot के समय होना चाहिए?
- कोई Driver बदला तो नहीं गया?
- कोई Rootkit Boot Process में छिपा तो नहीं है?
- कोई File बिना अनुमति के संशोधित तो नहीं हुई?
- किसी ने सुरक्षा Logs मिटाने का प्रयास तो नहीं किया?

इन सभी प्रश्नों के उत्तर Linux की उन्नत सुरक्षा तकनीकें देती हैं।

Linux Enterprise Security Architecture





Linux Audit Framework

Audit क्या है?

Audit का अर्थ केवल Log बनाना नहीं है।

Audit का वास्तविक अर्थ है—

"सिस्टम में हुई प्रत्येक महत्वपूर्ण सुरक्षा घटना का प्रमाण (Evidence) सुरक्षित रखना।"

यदि किसी Server पर Cyber Attack हो जाए, तो सबसे पहला प्रश्न होता है—

हमलावर ने क्या किया?

इसका उत्तर Audit Logs देते हैं।

Audit Framework क्या है?

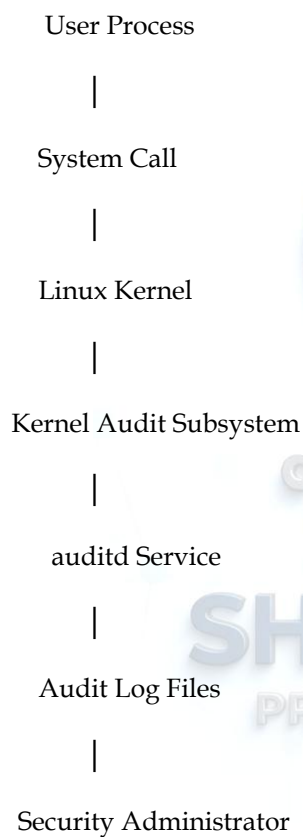
Linux Kernel के अंदर एक विशेष Audit Subsystem होता है।

यह निम्न गतिविधियों की निगरानी कर सकता है—

- Login
- Logout

- File Access
- File Delete
- Permission Change
- User Creation
- Process Execution
- Network Event
- SELinux Event
- Privilege Escalation प्रयास
- Security Policy परिवर्तन

Audit Architecture



उदाहरण

मान लीजिए—

एक User

secret.doc

खोलता है।

Kernel पहले Event बनाता है।

User



System Call



Audit Event



auditd



Log File

बाद में Administrator देख सकता है—

- किस User ने File खोली?
- कब खोली?
- कितनी बार खोली?
- Permission क्या थी?

auditd क्या है?

auditd

Linux का Audit Daemon है।

यह Kernel से Events लेकर उन्हें सुरक्षित रूप से Log में लिखता है।

Audit Logs कहाँ रहते हैं?

सामान्यतः

/var/log/audit/

मुख्य Log

Audit Event के मुख्य भाग

प्रत्येक Event में सामान्यतः निम्न जानकारी होती है—

- Timestamp
- PID
- UID
- GID
- Process Name
- Executable Path
- System Call
- Result (Success/Fail)

उदाहरण (सरल रूप)

Time

↓

User

↓

Command

↓

Result

↓

Permission

Digital Forensics में यही सबसे महत्वपूर्ण Evidence बनता है।

Audit Rules

Audit Framework नियमों (Rules) के आधार पर कार्य करता है।

उदाहरण के लिए—

- किसी विशेष Directory की निगरानी

- किसी विशेष System Call की निगरानी
- Root User की गतिविधियों की निगरानी
- किसी File के Permission परिवर्तन की निगरानी

इन नियमों का उद्देश्य आवश्यक सुरक्षा घटनाओं का रिकॉर्ड रखना है।

Digital Forensics में Audit का महत्व

यदि किसी Server से Data Leak हुआ हो—

Forensic Investigator Audit Logs से पता लगा सकता है—

- किस User ने File Access की?
- किस समय किया?
- कौन-सा Process चला?
- कौन-सी System Call उपयोग हुई?

Audit Logs अक्सर Investigation का प्रारम्भिक आधार बनते हैं।

Integrity Measurement Architecture (IMA)

अब हम Linux की अत्यंत महत्वपूर्ण सुरक्षा तकनीक समझते हैं।

Integrity क्या है?

Integrity का अर्थ है—

डेटा या File में बिना अनुमति कोई परिवर्तन न हुआ हो।

यदि किसी File का एक Byte भी बदल जाए—

तो उसकी Integrity बदल जाती है।

IMA क्या है?

IMA

(Integrity Measurement Architecture)

Linux Kernel की सुरक्षा प्रणाली है जो महत्वपूर्ण Files की Integrity जाँचती है।

यह—

- Hash बनाती है।
- Measurement करती है।
- रिकॉर्ड सुरक्षित रखती है।
- आवश्यकता होने पर Verification करती है।

IMA कैसे कार्य करती है?

मान लीजिए

/bin/bash

नामक File है।

Kernel उसका Hash बनाता है।

उदाहरण

SHA-256

↓

ABC123....

यदि बाद में वही File बदल जाए—

तो नया Hash अलग होगा।

Old Hash

↓

ABC123

New Hash

↓

Kernel पहचान लेगा—

File बदल चुकी है।

IMA Architecture

File Open



Linux Kernel



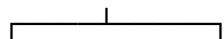
Hash Calculate



IMA Database



Integrity Check



OK Modified



IMA के लाभ

- File Tampering Detection
- Malware Detection
- Rootkit Detection
- Secure Boot Verification
- Enterprise Compliance

Extended Verification Module (EVM)

IMA केवल यह बताता है—

File बदली है।

लेकिन

यदि कोई Hash ही बदल दे?

इस समस्या का समाधान है—

EVM

EVM क्या करता है?

EVM

File Metadata की सुरक्षा करता है।

जैसे—

- Owner
- Group
- Permission
- Security Label
- Extended Attributes

इन सबकी Integrity भी सुरक्षित रखता है।

IMA + EVM

IMA

↓

File Data सुरक्षित

EVM

↓

Metadata सुरक्षित

Trusted Platform Module (TPM)

अब Hardware Security।

TPM क्या है?

TPM

एक विशेष Hardware Security Chip है।

यह Motherboard पर लगी होती है।

इसका कार्य—

- Cryptographic Keys सुरक्षित रखना
- Random Number Generation
- Secure Boot समर्थन
- Encryption Keys की सुरक्षा
- Platform Measurement

चित्र

CPU

|

RAM

|

TPM Chip

|

SSD

TPM क्या-क्या सुरक्षित रख सकता है?

- BitLocker Key
- LUKS Encryption Key
- Certificates
- Secure Boot Keys
- Signing Keys

TPM क्यों आवश्यक है?

यदि Hard Disk चोरी हो जाए—

लेकिन Encryption Key TPM में सुरक्षित हो—

तो केवल Disk चुराने से Data नहीं पढ़ा जा सकता।

Measured Boot

Secure Boot केवल Signature Verify करता है।

Measured Boot

Boot के प्रत्येक चरण का Measurement भी करता है।

चित्र

Firmware



Measure



Boot Loader



Measure



Kernel



Measure



↓
Initramfs

↓

Measure

सभी Measurements TPM में सुरक्षित किए जा सकते हैं।

Remote Attestation

कल्पना करें—

एक Company के

500 Linux Server हैं।

Administrator जानना चाहता है—

क्या सभी Server सुरक्षित हैं?

TPM आधारित Remote Attestation से यह जाँचा जा सकता है कि कोई Server अपेक्षित स्थिति में Boot हुआ है या नहीं।

dm-verity

अब File System सुरक्षा।

dm-verity

Read-only File Systems की Integrity जाँचता है।

यह मुख्यतः उपयोग होता है—

- Android
- Embedded Linux
- IoT Devices

यदि Storage में किसी Block में परिवर्तन हो जाए—

Kernel पहचान लेता है।

fs-verity

fs-verity

व्यक्तिगत Files की Integrity जाँचता है।

यह Read-only Verification देता है।

उदाहरण

Large ISO File

↓

Verify
Database Backup

↓

Verify

Enterprise Linux Hardening

Enterprise Linux में केवल Firewall पर्याप्त नहीं होता।

Hardening के मुख्य चरण—

- Secure Boot
- SELinux
- AppArmor (जहाँ लागू)
- Audit Framework
- IMA
- EVM
- TPM
- Disk Encryption
- Kernel Lockdown
- Module Signing
- Least Privilege
- Multi-Factor Authentication
- Log Monitoring
- Vulnerability Management
- Patch Management

Cyber Security में उपयोग

इन तकनीकों का उपयोग—

- Banking
- Defence
- Government
- Data Centers
- Cloud Computing
- Healthcare
- Digital Evidence Storage
- Critical Infrastructure

में व्यापक रूप से किया जाता है।

Digital Forensics में उपयोग

यदि किसी Linux Server पर हमला हो जाए—

Forensic Investigator निम्न स्रोतों का अध्ययन करेगा—

- Audit Logs
- IMA Measurements
- EVM Verification
- TPM Event Logs
- Kernel Logs
- Secure Boot Status
- Module Signature Verification
- File Integrity Records

इन सभी स्रोतों को मिलाकर यह निर्धारित किया जा सकता है कि—

- हमला कब हुआ?
- किस File में परिवर्तन हुआ?
- Boot Process सुरक्षित था या नहीं?
- Kernel विश्वसनीय था या नहीं?

अध्याय का सार

इस भाग में हमने Linux Kernel Security की Enterprise-स्तरीय सुरक्षा तकनीकों का विस्तृत अध्ययन किया—

- **Linux Audit Framework (auditd)** – सुरक्षा घटनाओं का विश्वसनीय रिकॉर्ड।
- **IMA (Integrity Measurement Architecture)** – फ़ाइलों की Integrity की जाँच।
- **EVM (Extended Verification Module)** – फ़ाइल Metadata की सुरक्षा।
- **TPM (Trusted Platform Module)** – हार्डवेयर आधारित Cryptographic सुरक्षा।
- **Measured Boot** – Boot प्रक्रिया के प्रत्येक चरण का Measurement।
- **Remote Attestation** – दूरस्थ सिस्टम की विश्वसनीयता का सत्यापन।
- **dm-verity एवं fs-verity** – File System और Files की Integrity Verification।
- **Enterprise Linux Hardening** – बहु-स्तरीय सुरक्षा (Defense in Depth) का व्यावहारिक मॉडल।

अगले भाग (भाग-6 – अंतिम एवं सबसे उन्नत)

अगले भाग में हम Linux Kernel Security के शोध-स्तरीय विषयों का अध्ययन करेंगे—

- Linux Kernel Security का भविष्य
- Rust in Linux Kernel
- Memory-Safe Kernel Development
- eBPF आधारित Threat Detection
- AI आधारित Kernel Security Monitoring
- Live Kernel Patching (kpatch, kGraft, KernelCare)
- Confidential Computing
- Zero Trust Kernel Architecture
- Hypervisor एवं Virtualization Security
- Cloud-Native Kernel Security
- वास्तविक CVE विश्लेषण (शैक्षिक दृष्टिकोण)
- PhD Research Topics एवं भविष्य की शोध दिशाएँ

यह भाग Linux Kernel Security को आधुनिक अनुसंधान और भविष्य की तकनीकों के संदर्भ में पूर्ण करेगा।

अध्याय: SELinux (Security-Enhanced Linux)

पुस्तक शैली में विस्तृत विवरण (मध्यम विस्तार)

1. SELinux क्या है?

SELinux (Security-Enhanced Linux) Linux Kernel में उपलब्ध एक उन्नत सुरक्षा प्रणाली (Advanced Security Framework) है, जिसका उद्देश्य Linux सिस्टम को अनधिकृत पहुँच (Unauthorized Access), Malware, Rootkit, Privilege Escalation और अन्य साइबर हमलों से सुरक्षित रखना है।

सामान्य Linux में सुरक्षा मुख्य रूप से File Permissions (Read, Write, Execute) पर आधारित होती है, लेकिन SELinux इससे एक कदम आगे बढ़कर Security Policies लागू करता है। यह तय करता है कि कौन-सा User, Process या Service किस संसाधन (Resource) तक पहुँच सकती है।

दूसरे शब्दों में,

SELinux एक Policy-Based Security System है, जो Linux Kernel के अंदर कार्य करके प्रत्येक Process और File की सुरक्षा सुनिश्चित करता है।

2. SELinux का इतिहास

SELinux का विकास National Security Agency (NSA) ने 2000 के आसपास किया। NSA का उद्देश्य ऐसा Linux सुरक्षा मॉडल विकसित करना था जो सरकारी, सैन्य, बैंकिंग और उच्च सुरक्षा वाले सर्वरों पर भी सुरक्षित रूप से उपयोग किया जा सके।

बाद में SELinux को Open Source समुदाय ने अपनाया और इसे Linux Kernel का हिस्सा बना दिया।

आज SELinux मुख्य रूप से निम्न Linux Distribution में उपलब्ध है—

- Red Hat Enterprise Linux (RHEL)
- Fedora
- CentOS Stream
- Rocky Linux
- AlmaLinux
- Oracle Linux

Android में भी SELinux आधारित सुरक्षा मॉडल का उपयोग किया जाता है।

3. SELinux की आवश्यकता क्यों पड़ी?

पुराने Linux में सुरक्षा केवल DAC (Discretionary Access Control) पर आधारित थी।

उदाहरण:

यदि किसी File का Owner User है, तो वह उसकी Permission बदल सकता है।

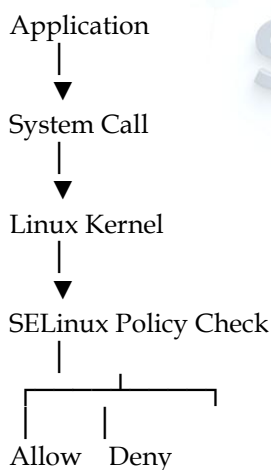
यदि किसी Hacker को Root Access मिल जाए, तो वह लगभग पूरे सिस्टम को नियंत्रित कर सकता है।

यहीं SELinux की आवश्यकता महसूस हुई।

SELinux ने MAC (Mandatory Access Control) लागू किया, जहाँ केवल File Permission ही नहीं, बल्कि Security Policy भी Access को नियंत्रित करती है।

4. SELinux कैसे कार्य करता है?

जब कोई Application किसी File, Directory, Network Port या Device तक पहुँचने का प्रयास करती है, तो निम्न प्रक्रिया होती है—



यदि Policy अनुमति देती है, तो कार्य सफल होता है।

यदि Policy अनुमति नहीं देती, तो Access तुरंत रोक दिया जाता है।

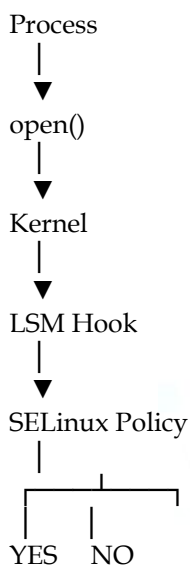
5. Linux Security Modules (LSM) और SELinux

SELinux सीधे Kernel में नहीं लिखा गया, बल्कि यह Linux Security Modules (LSM) Framework के माध्यम से कार्य करता है।

LSM Kernel के विभिन्न स्थानों (Security Hooks) पर जाँच करता है।

उदाहरण:

यदि कोई Process File खोलती है—



6. SELinux का सुरक्षा मॉडल

SELinux मुख्य रूप से Mandatory Access Control (MAC) का उपयोग करता है।

इसमें तीन महत्वपूर्ण बातें होती हैं—

1. User की पहचान
2. Process की पहचान
3. Security Policy

इन तीनों के आधार पर Access का निर्णय लिया जाता है।

7. DAC और MAC में अंतर

DAC

Owner Permission बदल सकता है Policy सर्वोच्च होती है

Root लगभग सब कुछ कर सकता है Root भी Policy से बंधा होता है

सरल सुरक्षा मॉडल

Desktop में अधिक उपयोग

MAC

अधिक सुरक्षित मॉडल

Enterprise Servers में अधिक उपयोग

8. Security Context

SELinux प्रत्येक File, Directory, Process और Device को एक **Security Context** प्रदान करता है।

एक सामान्य Context इस प्रकार दिखाई देता है—

`system_u:object_r:httpd_sys_content_t:s0`

इसके चार भाग होते हैं—

- **User** → system_u
- **Role** → object_r
- **Type** → httpd_sys_content_t
- **Level** → s0

SELinux मुख्य रूप से **Type** के आधार पर निर्णय लेता है।

9. Type Enforcement (TE)

Type Enforcement, SELinux का सबसे महत्वपूर्ण भाग है।

यह निर्धारित करता है कि—

- कौन-सी Process किस Type की File पढ़ सकती है।
- कौन-सी Process किस Device का उपयोग कर सकती है।
- कौन-सी Service किस Network Port तक पहुँच सकती है।

उदाहरण:

Apache Web Server का Type है—

`httpd_t`

अब केवल Apache Process ही उन Files को Access कर सकती है।

यदि कोई अन्य Process उन्हें पढ़ने का प्रयास करे, तो SELinux उसे रोक देगा।

10. SELinux Modes

SELinux तीन Mode में कार्य करता है—

(1) Enforcing

- सभी Policies लागू होती हैं।
- गलत Access तुरंत Block हो जाता है।
- Production Server में यही Mode उपयोग होता है।

(2) Permissive

- Access Block नहीं होता।
- केवल Log बनता है।
- Testing और Troubleshooting के लिए उपयोग किया जाता है।

(3) Disabled

- SELinux पूरी तरह बंद रहता है।
- कोई Policy लागू नहीं होती।

11. SELinux के मुख्य लाभ

- Malware का प्रभाव कम करता है।
- Root Access मिलने पर भी नुकसान सीमित करता है।
- Web Server सुरक्षा बढ़ाता है।
- Process Isolation प्रदान करता है।
- Least Privilege Principle लागू करता है।

- Digital Forensics के लिए उपयोगी Logs बनाता है।
- Enterprise Server की सुरक्षा बढ़ाता है।

12. वास्तविक उदाहरण

मान लीजिए एक Linux Server पर Apache Web Server चल रहा है।

एक Hacker ने किसी कमजोरी का लाभ उठाकर Apache Process पर नियंत्रण प्राप्त कर लिया।

अब Hacker /etc/shadow File पढ़ना चाहता है।

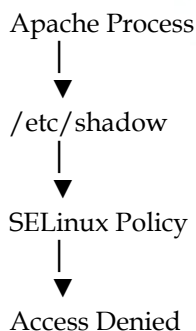
सामान्य Linux Permission पर्याप्त होने पर यह जोखिमपूर्ण हो सकता है।

लेकिन SELinux Policy कहती है—

- Apache केवल Web Content पढ़ सकता है।
- System Password Files नहीं।

इसलिए Kernel तुरंत Access रोक देता है।

परिणाम—



इस प्रकार Hacker का हमला सीमित रह जाता है।

13. Digital Forensics में SELinux

यदि किसी Server पर हमला हो जाए, तो SELinux Logs बहुत उपयोगी होते हैं।

इनसे पता लगाया जा सकता है—

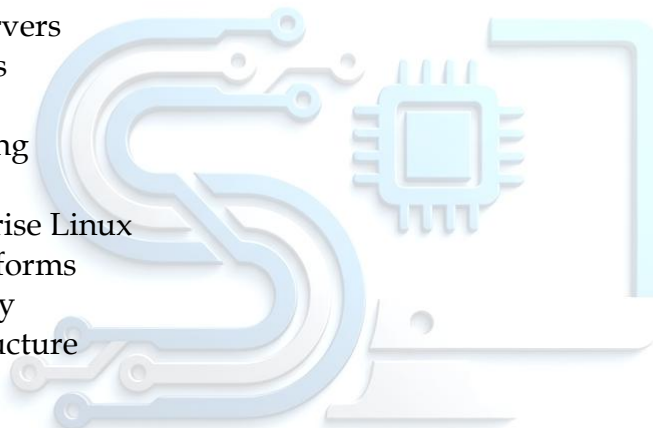
- किस Process ने कौन-सी File Access करने की कोशिश की।
- कौन-सा Access Block हुआ।
- कौन-सी Policy लागू हुई।
- किस समय घटना हुई।
- कौन-सा User या Service शामिल थी।

इसलिए Incident Response और Digital Forensics में SELinux अत्यंत महत्वपूर्ण माना जाता है।

14. Cyber Security में उपयोग

SELinux का उपयोग निम्न क्षेत्रों में व्यापक रूप से किया जाता है—

- Government Servers
- Defence Systems
- Banking Servers
- Cloud Computing
- Data Centers
- Red Hat Enterprise Linux
- Kubernetes Platforms
- Android Security
- Critical Infrastructure



15. SELinux के प्रमुख घटक (Components)

- Linux Security Modules (LSM)
- Security Policies
- Security Context
- Type Enforcement (TE)
- Role-Based Access Control (RBAC)
- Multi-Level Security (MLS)
- Multi-Category Security (MCS)
- Access Vector Cache (AVC)
- Policy Modules
- File Labeling

निष्कर्ष

SELinux Linux Kernel की सबसे उन्नत सुरक्षा प्रणालियों में से एक है। यह केवल File Permission पर निर्भर नहीं रहता, बल्कि **Policy-Based Mandatory Access Control (MAC)** लागू करता है। प्रत्येक Process, File, Directory और Device को Security Context दिया जाता है और Kernel प्रत्येक Access से पहले Policy की जाँच करता है। यदि Access अनुमति के अनुरूप नहीं होता, तो उसे तुरंत रोक दिया जाता है।

इसी कारण SELinux आज **Enterprise Linux Servers, Cloud Infrastructure, Government Networks, Banking Systems, Android Security, Cyber Security Operations और Digital Forensics** का एक अत्यंत महत्वपूर्ण भाग माना जाता है। इसकी सहायता से Privilege Escalation, Malware, Web Server Exploits और कई प्रकार के आधुनिक Cyber Attacks के प्रभाव को काफी हद तक सीमित किया जा सकता है।



अध्यायः

AppArmor (Application Armor)

1. परिचय (Introduction)

AppArmor (Application Armor) Linux की एक उन्नत सुरक्षा प्रणाली (Linux Security Module - LSM) है, जिसका उद्देश्य किसी भी Application या Process को केवल उन्हीं संसाधनों तक पहुँचने देना है जिनकी उसे वास्तव में आवश्यकता होती है। यदि कोई Application Hack हो जाए या उसमें कोई कमजोरी (Vulnerability) हो, तब भी AppArmor उसके कार्यक्षेत्र (Scope) को सीमित करके पूरे सिस्टम को सुरक्षित रखने का प्रयास करता है।

सरल शब्दों में,

AppArmor एक सुरक्षा कवच (Security Shield) है, जो प्रत्येक Application के चारों ओर सुरक्षा सीमा (Security Boundary) बनाता है।

यदि कोई Application इस सीमा के बाहर जाने का प्रयास करती है, तो AppArmor उसे रोक देता है।

2. AppArmor क्या है?

AppArmor एक **Mandatory Access Control (MAC)** आधारित सुरक्षा प्रणाली है। यह Linux Kernel के **Linux Security Modules (LSM) Framework** का उपयोग करके कार्य करती है।

सामान्य Linux में किसी Program की सुरक्षा केवल User Permission पर निर्भर होती है, जबकि AppArmor प्रत्येक Program के लिए अलग-अलग **Security Profile** बनाता है।

इन Profiles में लिखा होता है कि—

- कौन-सी File पढ़ सकता है।
 - कौन-सी File लिख सकता है।
 - कौन-सी Directory में जा सकता है।
 - कौन-सा Network उपयोग कर सकता है।
 - कौन-सा Command चला सकता है।
-

3. AppArmor का इतिहास

AppArmor का विकास मूल रूप से **Immunix** नामक कंपनी ने किया था। बाद में **Novell** ने इसे अपनाया और इसके बाद यह Open Source Linux का हिस्सा बन गया।

आज यह मुख्य रूप से निम्न Linux Distribution में उपयोग किया जाता है—

- Ubuntu
- Debian
- openSUSE
- SUSE Linux Enterprise
- Linux Mint

Ubuntu में AppArmor पहले से सक्रिय (Enabled) रहता है।

4. AppArmor की आवश्यकता

मान लीजिए आपके Linux Server पर Apache Web Server चल रहा है।

यदि किसी Hacker ने Apache की किसी कमजोरी का लाभ उठाकर उस Process पर नियंत्रण प्राप्त कर लिया, तो सामान्य स्थिति में वह पूरे सिस्टम तक पहुँचने का प्रयास कर सकता है।

लेकिन AppArmor पहले से Apache के लिए एक Profile लागू कर देता है।

उस Profile में लिखा होता है—

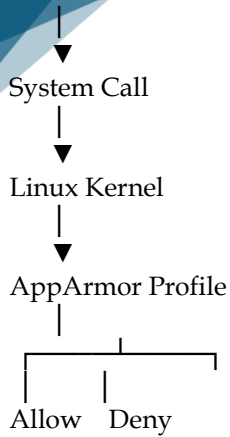
- Apache केवल `/var/www/` पढ़ सकता है।
- `/etc/shadow` नहीं पढ़ सकता।
- `/home/` Directory में नहीं जा सकता।
- केवल आवश्यक Network Port उपयोग कर सकता है।

इस प्रकार यदि Apache Hack भी हो जाए, तो नुकसान सीमित रहेगा।

5. AppArmor कैसे कार्य करता है?

जब कोई Application किसी संसाधन तक पहुँचने का प्रयास करती है, तो निम्न प्रक्रिया होती है—

Application



यदि Profile अनुमति देती है, तो कार्य पूरा हो जाता है।

अन्यथा Kernel Access Denied कर देता है।

6. Linux Security Modules (LSM) और AppArmor

AppArmor Linux Kernel के **Linux Security Modules (LSM)** Framework के माध्यम से कार्य करता है।

LSM Kernel में Security Hooks प्रदान करता है।

जब कोई Process—

- File खोलती है,
- Network उपयोग करती है,
- Program Execute करती है,

तो Kernel पहले AppArmor से अनुमति माँगता है।

7. Security Profile क्या है?

AppArmor का सबसे महत्वपूर्ण भाग Profile है।

Profile एक नियमों (Rules) की फ़ाइल होती है।

उदाहरण के लिए किसी Browser के लिए Profile यह निर्धारित कर सकती है—

- Downloads Folder पढ़ सकता है।
- System Password Files नहीं पढ़ सकता।
- केवल HTTPS Network उपयोग कर सकता है।
- Camera उपयोग कर सकता है या नहीं।

अर्थात Profile ही Application की सीमाएँ तय करती है।

8. Path-Based Security

SELinux जहाँ Security Context (Labels) का उपयोग करता है, वहीं AppArmor File Path के आधार पर सुरक्षा प्रदान करता है।

उदाहरण:

यदि किसी Profile में लिखा है कि Application केवल

/home/user/Documents/

Directory तक पहुँच सकती है,

तो वह

/etc/

Directory में नहीं जा सकेगी।

यही कारण है कि AppArmor को Path-Based Access Control कहा जाता है।

9. AppArmor के Mode

AppArmor मुख्यतः दो Mode में कार्य करता है।

(1) Enforce Mode

- सभी नियम लागू होते हैं।
- गलत Access तुरंत Block हो जाता है।
- Production System में यही Mode उपयोग होता है।

(2) Complain Mode

- Access Block नहीं होता।
- केवल Log बनाया जाता है।
- नई Profile बनाने और Testing के लिए उपयोग किया जाता है।

10. AppArmor Profile के मुख्य भाग

एक Profile में सामान्यतः निम्न प्रकार के नियम होते हैं—

- File Access
- Directory Access
- Network Permission
- Capability Rules
- Signal Rules
- Mount Rules
- Process Execution Rules

इन सभी नियमों के आधार पर Application का व्यवहार नियंत्रित किया जाता है।

11. वास्तविक उदाहरण

मान लीजिए Firefox Browser के लिए Profile बनी है।

Profile कहती है—

- Downloads Folder पढ़ सकता है।
- Home Directory पढ़ सकता है।
- Password Files नहीं पढ़ सकता।
- Root Directory Modify नहीं कर सकता।

अब यदि Browser में Malware आ जाए और वह

/etc/shadow

पढ़ने का प्रयास करे,

तो AppArmor तुरंत Access रोक देगा।

12. AppArmor के लाभ

AppArmor के मुख्य लाभ—

- Application Isolation
- Malware Protection
- Least Privilege लागू करना
- आसान Configuration
- Ubuntu में पहले से उपलब्ध
- कम Performance Overhead
- Enterprise Server सुरक्षा

13. AppArmor और SELinux में अंतर

आधार	AppArmor	SELinux
सुरक्षा मॉडल	Mandatory Access Control (MAC)	Mandatory Access Control (MAC)
कार्य करने का आधार	File Path	Security Label (Context)
Configuration	अपेक्षाकृत सरल	अधिक जटिल
सीखने में कठिनाई	कम	अधिक
प्रमुख उपयोग	Ubuntu, Debian, SUSE	RHEL, Fedora, CentOS
Performance	हल्का	थोड़ा अधिक जटिल
Enterprise नियंत्रण	अच्छा	अत्यधिक शक्तिशाली

14. Cyber Security में उपयोग

AppArmor का उपयोग निम्न क्षेत्रों में किया जाता है—

- Ubuntu Servers
- Web Servers
- Docker Containers
- Snap Packages
- Desktop Linux
- Cloud Instances
- Virtual Machines

विशेष रूप से Ubuntu आधारित Server में AppArmor एक महत्वपूर्ण सुरक्षा परत है।

15. Digital Forensics में महत्व

यदि किसी Linux System पर हमला होता है, तो AppArmor Logs से यह पता लगाया जा सकता है—

- कौन-सी Application ने कौन-सी File Access करनी चाही।
- कौन-सा Access Block हुआ।
- कौन-सी Profile लागू थी।
- किस समय घटना हुई।
- कौन-सा Process जिम्मेदार था।

ये Logs Incident Response और Digital Forensics में महत्वपूर्ण साक्ष्य (Evidence) प्रदान करते हैं।

16. AppArmor की सीमाएँ

हालाँकि AppArmor एक प्रभावी सुरक्षा प्रणाली है, फिर भी इसकी कुछ सीमाएँ हैं—

- यह Path-Based है; यदि File Path बदल जाए, तो Profile को भी अद्यतन करना पड़ सकता है।
- अत्यधिक बड़े Enterprise वातावरण में Profile Management जटिल हो सकता है।
- SELinux की तुलना में इसकी Policy Control क्षमता कुछ मामलों में कम व्यापक मानी जाती है।

17. निष्कर्ष

AppArmor Linux की एक शक्तिशाली और उपयोग में अपेक्षाकृत सरल **Mandatory Access Control (MAC)** प्रणाली है। यह प्रत्येक Application के लिए अलग Security Profile बनाकर उसके कार्यक्षेत्र को सीमित करता है। यदि कोई Application या Service Hack हो जाए, तो AppArmor उसे केवल निर्धारित संसाधनों तक ही सीमित रखता है, जिससे पूरे सिस्टम पर हमले का प्रभाव कम हो जाता है।

Ubuntu, Debian और SUSE आधारित Linux प्रणालियों में AppArmor एक महत्वपूर्ण सुरक्षा तंत्र है। Web Servers, Containers, Desktop Applications और Cloud Systems की सुरक्षा बढ़ाने में इसकी महत्वपूर्ण भूमिका है। इसकी सरल Profile प्रणाली, कम Performance Overhead और प्रभावी Application Isolation इसे आधुनिक Linux सुरक्षा का एक अत्यंत उपयोगी घटक बनाते हैं।

अध्यायः

iptables (Linux Firewall)

1. परिचय (Introduction)

किसी भी Computer Network में सबसे महत्वपूर्ण प्रश्न होता है—

"कौन-सा Network Traffic सिस्टम के अंदर आने दिया जाए और कौन-सा रोका जाए?"

इसी समस्या का समाधान Firewall करता है।

Linux Operating System में Firewall लागू करने के लिए कई तकनीकों का उपयोग किया जाता है, जिनमें सबसे प्रसिद्ध है **iptables**।

iptables Linux Kernel के **Netfilter Framework** पर आधारित एक शक्तिशाली Firewall Management Tool है। यह आने वाले (Incoming), जाने वाले (Outgoing) तथा Forward होने वाले Network Packets को नियमों (Rules) के आधार पर नियंत्रित करता है।

सरल शब्दों में,

iptables Linux का Firewall है, जो यह तय करता है कि कौन-सा Network Packet सिस्टम में प्रवेश करेगा, कौन-सा बाहर जाएगा और कौन-सा Block होगा।

2. Firewall क्या होता है?

Firewall एक सुरक्षा प्रणाली (Security Mechanism) है जो Network Traffic की निगरानी (Monitoring) और नियंत्रण (Filtering) करती है।

यदि किसी Server को इंटरनेट से जोड़ा गया है, तो हजारों Packet हर सेकंड उस तक पहुँचते हैं।

Firewall का कार्य है—

- वैध (Legitimate) Traffic को अनुमति देना।
- संदिग्ध (Suspicious) Traffic को रोकना।
- अनधिकृत Access को Block करना।

- Server को Cyber Attack से सुरक्षित रखना।

3. iptables क्या है?

iptables एक **Command-Line Utility** है, जिसके माध्यम से Administrator Linux Kernel के Netfilter Framework में Firewall Rules जोड़ता, हटाता और संशोधित करता है।

यह निम्न कार्य कर सकता है—

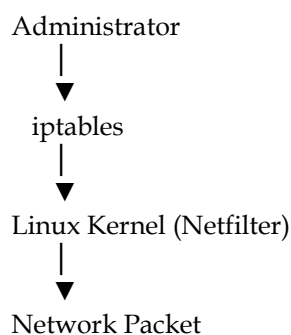
- Port Block करना
- Port Allow करना
- IP Address Block करना
- IP Address Allow करना
- Protocol Filter करना (TCP, UDP, ICMP)
- NAT (Network Address Translation)
- Packet Logging
- Packet Forwarding

4. Netfilter और iptables का संबंध

बहुत से लोग समझते हैं कि iptables ही Firewall है, जबकि वास्तव में—

- **Netfilter** → Linux Kernel के अंदर मौजूद Firewall Framework है।
- **iptables** → Netfilter को नियंत्रित करने वाला User-Space Tool है।

इसे इस प्रकार समझें—



5. Packet Filtering क्या है?

Packet Filtering का अर्थ है—

Network से आने वाले प्रत्येक Packet की जाँच करना और नियमों के अनुसार निर्णय लेना।

उदाहरण—

यदि नियम कहता है—

Port 22 Allow

तो SSH Traffic स्वीकार होगा।

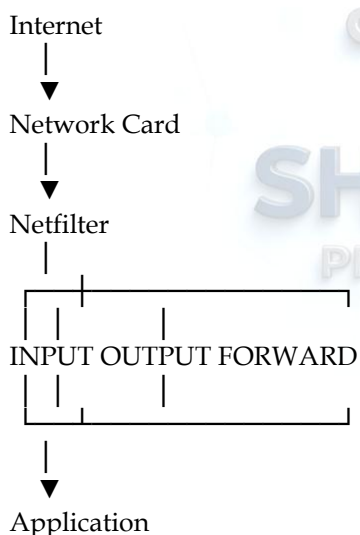
यदि नियम कहता है—

Port 23 Block

तो Telnet Traffic रोक दिया जाएगा।

6. iptables Architecture

Linux में प्रत्येक Packet कई चरणों से होकर गुजरता है।



हर चरण पर अलग-अलग नियम लागू किए जा सकते हैं।

7. Tables क्या होती हैं?

iptables में Rules को व्यवस्थित रखने के लिए Tables होती हैं।

मुख्य Tables हैं—

(1) Filter Table

सबसे अधिक उपयोग होने वाली Table।

कार्य—

- Packet Allow
- Packet Block

(2) NAT Table

कार्य—

- Network Address Translation
- Port Forwarding
- Internet Sharing

(3) Mangle Table

Packet के Header में परिवर्तन करने के लिए।

(4) Raw Table

विशेष प्रकार की Packet Processing के लिए।

(5) Security Table

SELinux जैसी सुरक्षा प्रणालियों के साथ उपयोग की जाती है।

8. Chains क्या होती हैं?

प्रत्येक Table में कई Chains होती हैं।

मुख्य Chains —

INPUT

जो Packet इस Computer के लिए आते हैं।

उदाहरण—

कोई User आपके Web Server को खोलता है।

Packet → INPUT Chain

OUTPUT

जो Packet इस Computer से बाहर जाते हैं।

उदाहरण—

आप Browser से Website खोलते हैं।

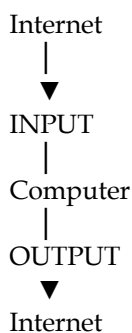
Packet → OUTPUT Chain

FORWARD

जो Packet इस System से होकर किसी अन्य Network की ओर जाते हैं।

यह मुख्यतः Router और Gateway में उपयोग होती है।

चित्र



9. Rules क्या होती हैं?

Firewall Rules यह निर्धारित करती हैं कि Packet के साथ क्या किया जाए।

यदि

- Source IP = 192.168.1.10
- Port = 22
- Protocol = TCP

तो

Action = ACCEPT

10. Targets

Rule का अंतिम निर्णय Target कहलाता है।

मुख्य Targets —

ACCEPT

Packet को अनुमति।

DROP

Packet को बिना उत्तर दिए समाप्त कर देना।

REJECT

Packet को अस्वीकार करना और Sender को सूचना देना।

LOG

Packet की जानकारी Log में लिखना।

RETURN

Chain से वापस लौटना।

11. Packet Matching

iptables विभिन्न मानदंडों के आधार पर Packet पहचान सकता है।

जैसे—

- Source IP
- Destination IP
- Source Port
- Destination Port
- TCP
- UDP
- ICMP
- MAC Address
- Interface
- Time

12. Stateful Firewall

iptables केवल Packet नहीं देखता, बल्कि Connection की स्थिति भी पहचान सकता है।

उदाहरण—

एक TCP Connection की अवस्थाएँ—

- NEW
- ESTABLISHED
- RELATED
- INVALID

यदि Connection पहले से स्थापित है, तो उसका Response Packet आसानी से स्वीकार किया जा सकता है।

13. Network Address Translation (NAT)

NAT का उपयोग Private IP को Public IP में बदलने के लिए किया जाता है।

उदाहरण—

घर के Router में—

192.168.1.10
192.168.1.20
192.168.1.30

Internet पर एक ही Public IP का उपयोग करते हैं।

यह कार्य NAT द्वारा किया जाता है।

14. Port Forwarding

यदि बाहरी दुनिया से आने वाला Traffic किसी विशेष Internal Server तक भेजना हो, तो Port Forwarding उपयोग होती है।

उदाहरण—

Internet



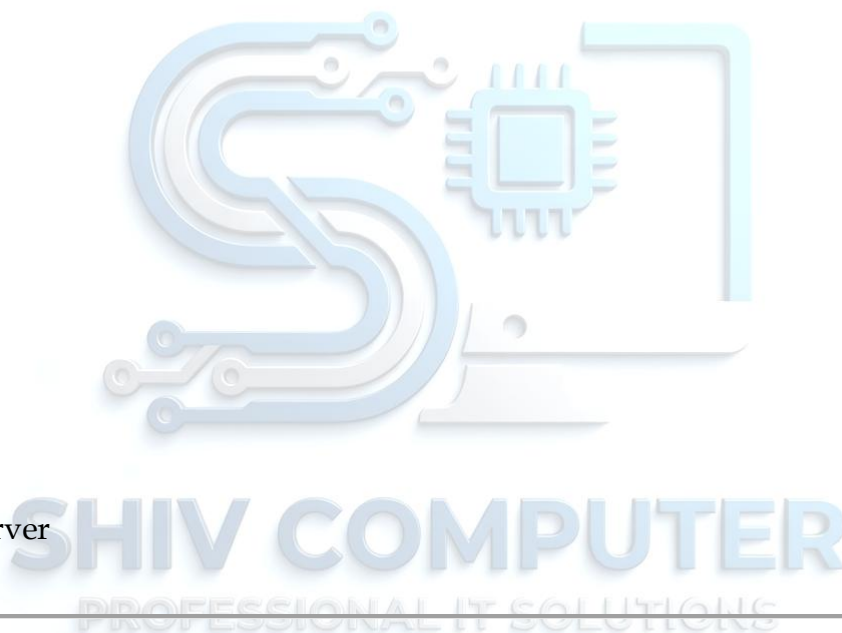
Public IP



Port 80



Internal Web Server



15. Logging

iptables संदिग्ध Packet की जानकारी Log में दर्ज कर सकता है।

इससे Administrator जान सकता है—

- किस IP से हमला हुआ।
- कौन-सा Port Target किया गया।
- कितनी बार प्रयास हुआ।

16. Cyber Security में उपयोग

iptables का उपयोग निम्न कार्यों में किया जाता है—

- SSH सुरक्षा
- Web Server सुरक्षा
- DDoS Attack का प्रभाव कम करना
- Port Scanning रोकना
- IP Filtering
- VPN सुरक्षा
- IDS/IPS के साथ Integration
- Cloud Server Hardening

17. Digital Forensics में महत्व

यदि किसी Linux Server पर हमला हुआ हो, तो Investigator निम्न की जाँच करता है—

- Firewall Rules
- Packet Logs
- Blocked IP Addresses
- Allowed Services
- Connection History

Firewall Logs से Attack Pattern समझने में सहायता मिलती है।

18. iptables के लाभ

- अत्यधिक शक्तिशाली Firewall
- Linux Kernel में एकीकृत
- Stateful Packet Inspection
- NAT समर्थन
- Packet Logging
- Port Filtering
- IP Filtering
- उच्च Performance
- Enterprise Server के लिए उपयुक्त

19. iptables की सीमाएँ

- Command Syntax अपेक्षाकृत जटिल हो सकती है।
- बड़ी संख्या में Rules का प्रबंधन कठिन हो सकता है।
- आधुनिक Linux Distribution में **nftables** को भविष्य का विकल्प माना जा रहा है, हालाँकि iptables अभी भी व्यापक रूप से उपयोग किया जाता है।

20. वास्तविक उदाहरण

मान लीजिए किसी Company का Web Server है।

Firewall Policy इस प्रकार है—

Port Service Action

80	HTTP	Allow
443	HTTPS	Allow
22	SSH	केवल Administrator IP से Allow
21	FTP	Block
23	Telnet	Block

अब यदि कोई Hacker Telnet द्वारा Server तक पहुँचने का प्रयास करेगा, तो iptables उस Packet को Block कर देगा।

निष्कर्ष

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

iptables Linux का एक शक्तिशाली Firewall Management Tool है, जो **Netfilter Framework** के माध्यम से Network Packets को नियंत्रित करता है। यह **Packet Filtering**, **Stateful Inspection**, **NAT**, **Port Forwarding**, **Logging** और **Access Control** जैसी सुविधाएँ प्रदान करता है। Enterprise Servers, Cloud Infrastructure, Data Centers और Cyber Security वातावरण में iptables एक महत्वपूर्ण सुरक्षा परत है। इसकी सहायता से अनधिकृत Network Traffic को रोका जा सकता है, सेवाओं को सुरक्षित रखा जा सकता है और सुरक्षा घटनाओं के विश्लेषण के लिए महत्वपूर्ण Logs प्राप्त किए जा सकते हैं।

अध्यायः

nftables (Next Generation Linux Firewall)

1. परिचय (Introduction)

किसी भी आधुनिक Computer Network की सुरक्षा के लिए Firewall सबसे महत्वपूर्ण सुरक्षा तंत्रों में से एक है। जैसे-जैसे Network का आकार बढ़ा, Cyber Attacks अधिक जटिल हुए और Cloud Computing, Virtualization तथा Container Technology का उपयोग बढ़ा, वैसे-वैसे Linux Firewall को भी अधिक शक्तिशाली, तेज़ और सरल बनाने की आवश्यकता महसूस हुई।

Linux में कई वर्षों तक iptables Firewall का उपयोग किया गया, लेकिन समय के साथ उसकी कुछ सीमाएँ सामने आई—

- नियम (Rules) बहुत अधिक होने पर प्रबंधन कठिन हो जाता था।
- IPv4 और IPv6 के लिए अलग-अलग Tools थे।
- Performance सीमित हो सकती थी।
- Rule Management जटिल था।

इन समस्याओं को दूर करने के लिए Linux Kernel में nftables विकसित किया गया।

nftables Linux का आधुनिक (Next Generation) Firewall Framework है, जो Netfilter पर आधारित है और iptables का उत्तराधिकारी (Successor) माना जाता है।

2. nftables क्या है?

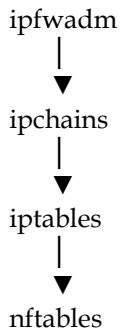
nftables Linux Kernel के Netfilter Framework का आधुनिक Firewall Subsystem है। यह Network Packets को Filter करने, NAT (Network Address Translation), Packet Logging, Port Filtering, IP Filtering तथा Traffic Control जैसे कार्य करता है।

सरल शब्दों में,

nftables Linux का आधुनिक Firewall है जो Network Traffic को नियमों (Rules) के आधार पर नियंत्रित करता है।

3. nftables का इतिहास

Linux में Firewall की विकास यात्रा इस प्रकार रही—



nftables को Linux Kernel 3.13 (2014) में शामिल किया गया और इसका उद्देश्य iptables की सभी कमियों को दूर करना था।

4. nftables की आवश्यकता

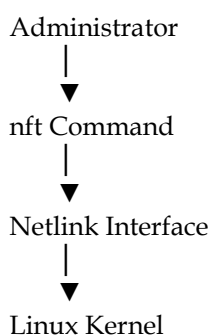
कल्पना कीजिए कि किसी Data Center में 10,000 Firewall Rules हैं।

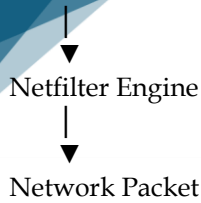
iptables में—

- Rule Search धीमी हो सकती है।
- Rules दोहराए जा सकते हैं।
- IPv4 और IPv6 अलग-अलग प्रबंधित करने पड़ते हैं।

nftables इन समस्याओं का समाधान देता है।

5. nftables Architecture



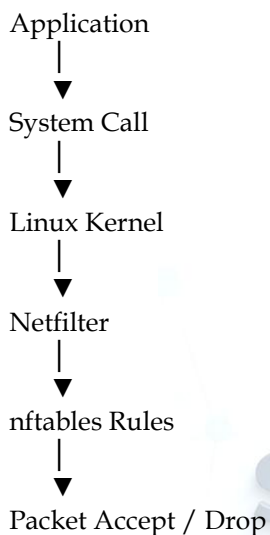


Administrator nft Command का उपयोग करता है और Kernel Netfilter के माध्यम से Packet पर नियम लागू करता है।

6. Netfilter Framework

nftables स्वयं Packet Filter नहीं है।

वास्तविक Filtering Linux Kernel के Netfilter Framework द्वारा की जाती है।



7. nftables के मुख्य Components

nftables मुख्यतः पाँच Components पर आधारित है—

1. Tables
2. Chains
3. Rules
4. Sets
5. Maps

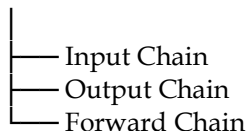
ये सभी मिलकर Firewall Policy बनाते हैं।

8. Tables

Table Rules का संग्रह (Collection) होती है।

उदाहरण—

Firewall Table



एक Table में कई Chains हो सकती हैं।

9. Chains

Chain वह स्थान है जहाँ Packet पर Rules लागू होते हैं।

मुख्य Chains —

INPUT

जो Packet इस Computer के लिए आते हैं।

उदाहरण—

Browser से आपके Web Server पर Request।

OUTPUT

जो Packet इस Computer से बाहर जाते हैं।

उदाहरण—

Server द्वारा किसी Client को Response।

FORWARD

जो Packet इस System से होकर किसी अन्य System की ओर जाते हैं।

Router में सबसे अधिक उपयोग।

10. Rules

Rules यह निर्धारित करती हैं कि Packet के साथ क्या करना है।

उदाहरण—

यदि—

- Source IP = 192.168.1.100
- Protocol = TCP
- Destination Port = 22

तो Action = Allow

11. Verdicts (Actions)

iptables निम्न मुख्य Actions प्रदान करता है—

Accept

Packet को अनुमति देना।

Drop

Packet को बिना उत्तर दिए समाप्त कर देना।

Reject

Packet को अस्वीकार करना और Error भेजना।

Continue

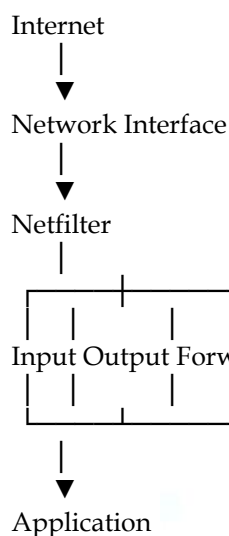
अगले Rule की जाँच करना।

Jump

Return

वर्तमान Chain से वापस लौटना।

12. Packet Flow



13. Stateful Firewall

nftables केवल Packet नहीं देखता बल्कि Connection की स्थिति भी पहचानता है।

TCP Connection की अवस्थाएँ—

- NEW
- ESTABLISHED
- RELATED
- INVALID

यदि Connection पहले से स्थापित है, तो उसके उत्तर (Response) को सरलता से अनुमति दी जा सकती है।

14. Sets

nftables की सबसे शक्तिशाली विशेषताओं में से एक है Sets।

यदि 1000 IP Address Block करने हों—

iptables में 1000 Rules बन सकती हैं।

nftables में—

एक Set बनाया जाता है।

Blocked_IPs

↓

IP1

IP2

IP3

...

IP1000

अब केवल एक Rule पर्याप्त है।

इससे Performance बढ़ती है।

15. Maps

Maps का उपयोग Dynamic Translation के लिए किया जाता है।

उदाहरण—

अलग-अलग Port के लिए अलग-अलग Action निर्धारित किए जा सकते हैं।

Maps बड़े Enterprise वातावरण में Rule Management को सरल बनाते हैं।

16. NAT (Network Address Translation)

nftables NAT भी प्रदान करता है।

मुख्य प्रकार—

- Source NAT (SNAT)
- Destination NAT (DNAT)

- Masquerading
- Port Forwarding

घर के Router, Cloud Gateway तथा Enterprise Firewalls में NAT का व्यापक उपयोग होता है।

17. Logging

nftables संदिग्ध Packet की जानकारी Log में लिख सकता है।

उदाहरण—

यदि कोई Hacker बार-बार SSH Login का प्रयास कर रहा हो—

तो उसका IP Address तथा प्रयासों की संख्या Log में दर्ज की जा सकती है।

18. Performance

nftables को Performance को ध्यान में रखकर विकसित किया गया है।

मुख्य कारण—

- कम Memory उपयोग
- Rule Optimization
- Sets एवं Maps
- कम Duplicate Rules
- तेज़ Packet Processing

इस कारण बड़े Data Centers में इसका उपयोग अधिक उपयुक्त माना जाता है।

19. nftables और iptables में अंतर

विशेषता	iptables	nftables
पीढ़ी	पुरानी	आधुनिक
Rule Management	अपेक्षाकृत जटिल	सरल एवं लचीला
IPv4 / IPv6	अलग-अलग Tools	एकीकृत (Unified)
Sets Support	सीमित	उत्कृष्ट

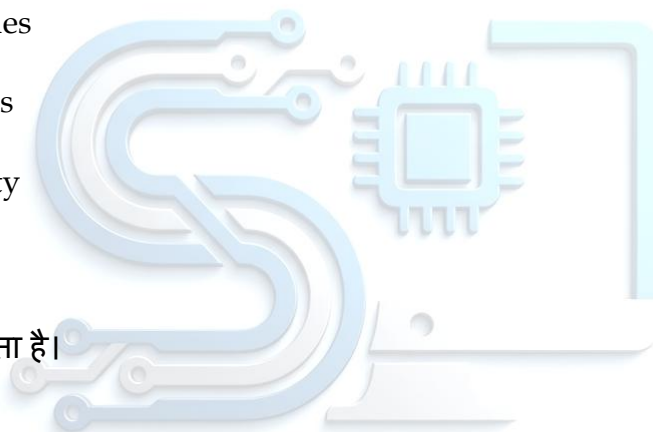
विशेषता	iptables	nftables
Maps	नहीं	उपलब्ध
Performance	अच्छी	बेहतर
Scalability	मध्यम	बहुत अच्छी
Future Support	Legacy	वर्तमान एवं भविष्य का मानक

20. Cyber Security में उपयोग

nftables का उपयोग—

- Enterprise Firewall
- Cloud Infrastructure
- Kubernetes Nodes
- Docker Hosts
- Virtual Machines
- Linux Servers
- Network Security
- Data Centers
- VPN Servers

में व्यापक रूप से किया जाता है।



21. Digital Forensics में महत्व

PROFESSIONAL IT SOLUTIONS

यदि किसी Linux Server पर हमला हुआ हो—

Investigator निम्न का विश्लेषण करता है—

- Firewall Rules
- Blocked Connections
- Allowed Connections
- NAT Configuration
- Packet Logs
- Suspicious IP Addresses
- Traffic Pattern

इन्से यह समझने में सहायता मिलती है कि हमला किस दिशा से हुआ और Firewall ने उसे रोका या नहीं।

22. nftables के लाभ

- आधुनिक Firewall Framework
- सरल Rule Management
- IPv4 और IPv6 का एकीकृत समर्थन
- उच्च Performance
- बेहतर Scalability
- कम Memory उपयोग
- Sets एवं Maps का समर्थन
- Stateful Packet Inspection
- NAT और Logging
- Enterprise एवं Cloud के लिए उपयुक्त

23. nftables की सीमाएँ

- पुराने System Administrator को नया Syntax सीखना पड़ता है।
- Legacy Scripts जो iptables पर आधारित हैं, उन्हें संशोधित करना पड़ सकता है।
- Migration के दौरान Rules की सावधानीपूर्वक समीक्षा आवश्यक होती है।

24. वास्तविक उदाहरण

मान लीजिए किसी Company का Linux Server Internet से जुड़ा है।

Firewall Policy इस प्रकार है—

Service	Port	Action
HTTP	80	Allow
HTTPS	443	Allow
SSH	22	केवल Administrator IP से Allow
FTP	21	Block
Telnet	23	Block
Unknown Traffic सभी अन्य Drop		

यदि कोई Hacker Telnet द्वारा प्रवेश करने का प्रयास करेगा, तो nftables उस Packet को तुरंत Drop कर देगा।

निष्कर्ष

nftables Linux का आधुनिक, शक्तिशाली और उच्च-प्रदर्शन Firewall Framework है, जिसे **iptables** का उत्तराधिकारी माना जाता है। यह **Netfilter Framework** पर आधारित है और Packet Filtering, Stateful Inspection, NAT, Logging, Sets, Maps तथा Unified IPv4/IPv6 Management जैसी उन्नत सुविधाएँ प्रदान करता है। Cloud Computing, Data Centers, Enterprise Servers, Containers और आधुनिक Linux Systems में nftables को भविष्य की Firewall तकनीक माना जाता है, क्योंकि यह अधिक सरल, तेज़, लचीला और Scalability प्रदान करता है।



अध्यायः

SSH Security (Secure Shell Security)

1. परिचय (Introduction)

आज के समय में अधिकांश Linux Server, Cloud Server, Web Server, Database Server और Virtual Machines को दूरस्थ (Remote) स्थान से प्रबंधित किया जाता है। यदि Administrator को हर बार Server के पास जाकर कार्य करना पड़े, तो यह व्यावहारिक नहीं होगा।

इसी समस्या के समाधान के लिए SSH (Secure Shell) का विकास किया गया।

SSH एक Secure Network Protocol है, जिसके माध्यम से किसी Remote Computer या Server को सुरक्षित रूप से नियंत्रित (Manage) किया जा सकता है।

सरल शब्दों में,

SSH (Secure Shell) एक सुरक्षित संचार प्रोटोकॉल है, जो दो Computers के बीच Encrypted Communication स्थापित करके Remote Login, Command Execution, File Transfer और System Administration की सुविधा प्रदान करता है।

आज Linux System Administration में SSH का वही महत्व है जो Windows में Remote Desktop (RDP) का है।

2. SSH क्या है?

SSH (Secure Shell) एक Cryptographic Network Protocol है, जो असुरक्षित नेटवर्क (जैसे Internet) पर भी दो Computers के बीच सुरक्षित संचार (Secure Communication) स्थापित करता है।

SSH निम्न कार्यों के लिए उपयोग किया जाता है—

- Remote Login
- Server Administration
- File Transfer (SCP, SFTP)
- Secure Command Execution
- Remote Backup
- Port Forwarding

3. SSH का इतिहास

पहले Remote Login के लिए Telnet का उपयोग किया जाता था।

Telnet की सबसे बड़ी समस्या थी कि यह—

- Username
- Password
- Commands

को Plain Text में भेजता था।

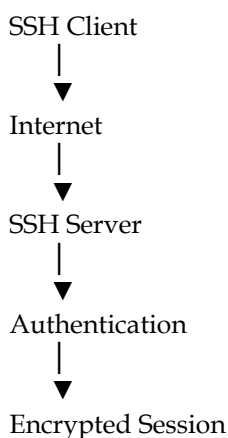
इसका अर्थ था कि यदि कोई Attacker Network Traffic को Capture कर ले, तो वह Login Credentials आसानी से पढ़ सकता था।

इस समस्या को दूर करने के लिए SSH विकसित किया गया।

आज लगभग सभी आधुनिक Linux Servers में SSH ही मानक Remote Access Protocol है।

4. SSH कैसे कार्य करता है?

जब Client किसी Remote Server से जुड़ता है, तो निम्न प्रक्रिया होती है—



यदि Authentication सफल होती है, तो दोनों के बीच एक सुरक्षित (Encrypted) Session स्थापित हो जाता है।

5. SSH Architecture

SSH मुख्यतः दो भागों में विभाजित है—

(1) SSH Client

जिस Computer से Connection बनाया जाता है।

उदाहरण—

- Laptop
- Desktop
- Administrator Workstation

(2) SSH Server

जिस Linux System पर Remote Login किया जाता है।

उदाहरण—

- Web Server
- Database Server
- Cloud Server
- Virtual Machine



6. SSH के प्रमुख घटक (Components)

SSH तीन मुख्य सेवाएँ प्रदान करता है—

(1) Remote Login

दूरस्थ Server पर सुरक्षित Login।

(2) Secure File Transfer

- SCP
- SFTP

के माध्यम से सुरक्षित File Transfer।

अन्य Protocols को सुरक्षित रूप से Tunnel करना।

7. SSH में Encryption

SSH की सबसे महत्वपूर्ण विशेषता Encryption है।

Encryption का अर्थ है—

डेटा को ऐसे रूप में बदल देना जिसे केवल अधिकृत व्यक्ति ही पढ़ सके।

उदाहरण—

Original Data



Encryption



Encrypted Data



Network



Decryption



Original Data



यदि कोई Attacker बीच में Packet Capture कर ले, तो उसे केवल Encrypted Data दिखाई देगा।

8. SSH में Authentication

SSH दो प्रमुख तरीकों से Authentication करता है—

(1) Password Authentication

User अपना Username और Password दर्ज करता है।

यदि सही हो, तो Login सफल होता है।

(2) Public Key Authentication

यह अधिक सुरक्षित विधि है।

इसमें दो Keys होती हैं—

- Public Key
- Private Key

Server Public Key को पहचानता है और केवल संबंधित Private Key रखने वाला User ही Login कर सकता है।

यह Password आधारित Login की तुलना में अधिक सुरक्षित माना जाता है।

9. SSH Port

SSH सामान्यतः TCP Port 22 का उपयोग करता है।

हालाँकि सुरक्षा कारणों से कई संस्थाएँ इसे किसी अन्य Port पर भी कॉन्फ़िगर करती हैं, ताकि स्वचालित स्कैनिंग और सामान्य Port आधारित हमलों की संभावना कम हो सके।

10. SSH Security Best Practices

SSH को सुरक्षित बनाने के लिए निम्न उपाय अपनाए जाते हैं—

1. मजबूत Password Policy

- लंबे Password
 - Complex Password
 - नियमित परिवर्तन
-

2. Public Key Authentication

Password की अपेक्षा Key आधारित Authentication अधिक सुरक्षित होती है।

3. Root Login को सीमित करना

Root Account से सीधे Remote Login की अनुमति न देना एक सामान्य सुरक्षा अभ्यास है। इसके बजाय सामान्य User से Login करके आवश्यकता पड़ने पर प्रशासनिक अधिकार प्राप्त किए जाते हैं।

4. Multi-Factor Authentication (MFA)

Password के साथ OTP, Hardware Token या Authenticator App का उपयोग सुरक्षा को और बढ़ाता है।

5. Firewall का उपयोग

केवल आवश्यक IP Address या Network से SSH Access की अनुमति देना।

6. नियमित Updates

OpenSSH तथा Linux System को नियमित रूप से Update रखना ताकि ज्ञात Vulnerabilities का जोखिम कम हो।

7. Login Monitoring

SSH Login Attempts की निगरानी करना और संदिग्ध गतिविधियों का विश्लेषण करना।

11. SSH में होने वाले सामान्य Cyber Attacks

SSH स्वयं सुरक्षित Protocol है, लेकिन उसकी गलत Configuration या कमजोर Authentication के कारण निम्न प्रकार के हमलों का जोखिम हो सकता है—

Brute Force Attack

बार-बार Password Guess करने का प्रयास।

चोरी किए गए Username/Password का उपयोग।

Man-in-the-Middle (MitM)

यदि Server की पहचान (Host Key) सत्यापित न की जाए, तो Attacker बीच में संचार को प्रभावित करने का प्रयास कर सकता है।

Stolen Private Key

यदि Private Key सुरक्षित न रखी जाए, तो उसका दुरुपयोग हो सकता है।

Misconfiguration

अनावश्यक सेवाएँ, कमजोर नीतियाँ या गलत Permissions सुरक्षा जोखिम बढ़ा सकती हैं।

12. SSH और Digital Forensics

यदि किसी Linux Server पर हमला होता है, तो SSH से संबंधित Logs महत्वपूर्ण साक्ष्य प्रदान करते हैं।

Forensic Investigator निम्न जानकारी का विश्लेषण करता है—

- Login Time
- Source IP Address
- Authentication Method
- Failed Login Attempts
- Successful Login
- Executed Commands (यदि Logging उपलब्ध हो)
- User Activity

इनसे यह पता लगाया जा सकता है कि—

- किस User ने Login किया?
- कहाँ से Login किया?
- कितनी बार प्रयास हुआ?
- कौन-सा Account Target किया गया?

13. SSH का Enterprise उपयोग

SSH का उपयोग निम्न क्षेत्रों में व्यापक रूप से किया जाता है—

- Linux Server Administration
- Cloud Computing (AWS, Azure, Google Cloud)
- DevOps
- Kubernetes Nodes
- Docker Hosts
- Database Servers
- Network Devices (Routers, Switches)
- High Performance Computing (HPC)
- Government एवं Banking Infrastructure

14. SSH के लाभ

- सुरक्षित Remote Login
- End-to-End Encryption
- सुरक्षित File Transfer (SCP/SFTP)
- Public Key Authentication
- Port Forwarding एवं Secure Tunneling
- Cross-Platform Support
- Enterprise स्तर की सुरक्षा

15. SSH की सीमाएँ

- कमजोर Password होने पर जोखिम बढ़ जाता है।
- Private Key की सुरक्षा अत्यंत आवश्यक है।
- गलत Configuration सुरक्षा कमजोर कर सकती है।
- नियमित Monitoring और Updates आवश्यक हैं।

16. वास्तविक उदाहरण

मान लीजिए एक कंपनी का Linux Web Server Internet पर उपलब्ध है।

Firewall Policy के अनुसार—

- केवल Administrator Office Network से SSH Access की अनुमति है।
- Public Key Authentication अनिवार्य है।
- Root Login निषिद्ध है।
- सभी SSH Login Events Log किए जाते हैं।

यदि कोई Attacker किसी अन्य देश से Login करने का प्रयास करता है, तो—

- Firewall उसे रोक सकता है, या
- Authentication विफल हो जाएगी, और
- घटना Logs में दर्ज हो जाएगी।

इस प्रकार Server की सुरक्षा कई परतों (Defense in Depth) द्वारा सुनिश्चित की जाती है।

17. निष्कर्ष

SSH (Secure Shell) Linux और UNIX आधारित प्रणालियों के लिए सबसे महत्वपूर्ण Remote Administration Protocol है। यह **Encryption**, **Authentication** और **Data Integrity** के माध्यम से सुरक्षित संचार स्थापित करता है। आधुनिक Enterprise Infrastructure, Cloud Computing, DevOps, System Administration और Digital Forensics में SSH की भूमिका अत्यंत महत्वपूर्ण है। उचित Configuration, मजबूत Authentication, नियमित Monitoring और सुरक्षा नीतियों के साथ SSH दूरस्थ प्रबंधन के लिए एक विश्वसनीय और सुरक्षित समाधान प्रदान करता है।

अध्याय: PAM (Pluggable Authentication Modules)

पुस्तक शैली में विस्तृत विवरण (PhD स्तर | हिंदी)

1. परिचय (Introduction)

किसी भी Operating System की सुरक्षा का सबसे महत्वपूर्ण भाग **Authentication (प्रमाणीकरण)** होता है। जब कोई उपयोगकर्ता (User) Linux System में Login करता है, sudo का उपयोग करता है, SSH से जुड़ता है या किसी Service तक पहुँचने का प्रयास करता है, तब सबसे पहला प्रश्न होता है—

"क्या यह वास्तव में अधिकृत (Authorized) उपयोगकर्ता है?"

Linux में इस समस्या का समाधान **PAM (Pluggable Authentication Modules)** करता है।

PAM एक ऐसा Framework है जो विभिन्न Applications और Services के लिए Authentication, Authorization, Account Management तथा Session Management की सुविधा प्रदान करता है।

सरल शब्दों में,

PAM Linux का एक केंद्रीय Authentication Framework है, जो यह निर्धारित करता है कि कौन-सा User किस प्रकार और किन शर्तों के साथ सिस्टम में प्रवेश कर सकता है।

2. PAM क्या है?

PAM (Pluggable Authentication Modules) एक **Modular Authentication Framework** है, जो Linux और UNIX आधारित प्रणालियों में उपयोगकर्ताओं की पहचान (Identity Verification) तथा Login प्रक्रिया को नियंत्रित करता है।

PAM का सबसे बड़ा लाभ यह है कि किसी Application (जैसे SSH, Login, FTP, Sudo आदि) का Source Code बदले बिना उसकी Authentication Policy बदली जा सकती है।

3. PAM का इतिहास

1990 के दशक में विभिन्न Applications अपनी-अपनी Authentication प्रणाली उपयोग करती थीं।

उदाहरण—

- Login Program की अलग Authentication
- FTP Server की अलग Authentication
- Mail Server की अलग Authentication

इससे प्रबंधन कठिन हो जाता था।

इस समस्या को दूर करने के लिए PAM Framework विकसित किया गया, जिससे सभी Applications एक समान Authentication प्रणाली का उपयोग करने लगीं।

4. PAM की आवश्यकता

कल्पना कीजिए कि किसी Company में 500 Linux Servers हैं।

यदि प्रत्येक Service की अलग Authentication प्रणाली हो—

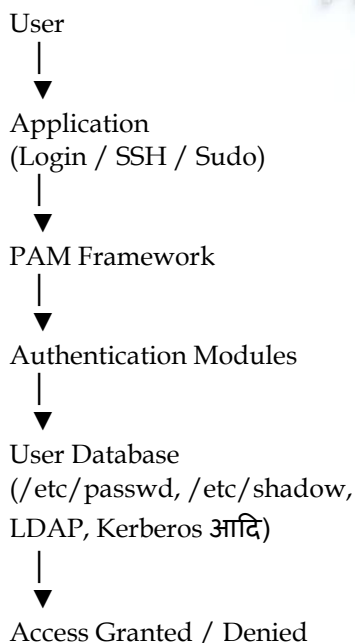
- Password अलग
- नियम अलग
- Security Policy अलग

तो Administrator के लिए इन्हें प्रबंधित करना अत्यंत कठिन होगा।

PAM सभी Applications के लिए एक समान Authentication Framework उपलब्ध कराता है।

5. PAM कैसे कार्य करता है?

जब कोई User Login करता है, तो प्रक्रिया इस प्रकार होती है—



PAM स्वयं Password Verify नहीं करता, बल्कि विभिन्न Modules की सहायता से निर्णय लेता है।

6. PAM Architecture

PAM चार मुख्य भागों पर आधारित है—

1. Application
2. PAM Library
3. PAM Modules
4. Authentication Source

इन सभी के सहयोग से Login प्रक्रिया पूरी होती है।

7. PAM Modules क्या हैं?

PAM में प्रत्येक कार्य अलग-अलग Module द्वारा किया जाता है।

उदाहरण—

- Password Verification
- Fingerprint Authentication
- OTP Authentication
- LDAP Authentication
- Smart Card Authentication

Administrator आवश्यकता अनुसार Modules जोड़ या हटा सकता है।

8. PAM के चार मुख्य Module Types

(1) Authentication Module (auth)

यह User की पहचान सत्यापित करता है।

कार्य—

- Password जाँचना
- OTP सत्यापित करना
- Fingerprint Verify करना

- Smart Card Verify करना

(2) Account Module (account)

यह निर्धारित करता है कि User को Login की अनुमति है या नहीं।

उदाहरण—

- Account Expired?
- Password Expired?
- User Locked?
- Login Time Allowed?

(3) Password Module (password)

यह Password बदलने और Password Policy लागू करने का कार्य करता है।

उदाहरण—

- Password की न्यूनतम लंबाई
- Password Complexity
- Password History
- Password Expiry

(4) Session Module (session)

Login और Logout के दौरान आवश्यक कार्य करता है।

उदाहरण—

- Home Directory Mount करना
- Login Log बनाना
- Environment Variables सेट करना
- Session Cleanup

9. PAM Control Flags

PAM प्रत्येक Module के लिए Control Flag का उपयोग करता है।

Required

Module सफल होना आवश्यक है।

यदि असफल हुआ, तो Login अंततः असफल होगा।

Requisite

यदि Module असफल हुआ, तो तुरंत प्रक्रिया रोक दी जाती है।

Sufficient

यदि यह Module सफल हो गया और पहले कोई Required Module असफल नहीं हुआ, तो आगे के कुछ Modules की आवश्यकता नहीं रहती।

Optional

इस Module का परिणाम सामान्यतः अंतिम निर्णय को प्रभावित नहीं करता, जब तक विशेष रूप से आवश्यक न हो।

10. Authentication Sources

PAM विभिन्न स्रोतों से User की पहचान सत्यापित कर सकता है—

- Local Password Database
- LDAP
- Kerberos
- Active Directory
- RADIUS
- Fingerprint
- Smart Card
- OTP (One-Time Password)

इससे Enterprise वातावरण में एकीकृत पहचान प्रबंधन (Identity Management) संभव होता है।

11. PAM Configuration

PAM की Configuration Files सामान्यतः Linux में

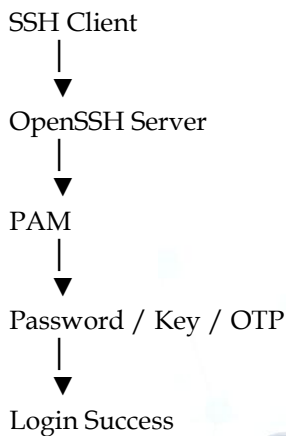
/etc/pam.d/

Directory में होती हैं।

यहाँ प्रत्येक Service (जैसे login, sshd, sudo आदि) के लिए अलग Configuration उपलब्ध हो सकती है।

12. PAM और SSH

जब कोई User SSH से Login करता है—



इस प्रकार SSH Authentication में भी PAM महत्वपूर्ण भूमिका निभाता है।

13. PAM और sudo

जब कोई User sudo का उपयोग करता है—

- PAM User की पहचान सत्यापित करता है।
- Password Policy लागू करता है।
- आवश्यकता होने पर Account Restrictions की जाँच करता है।

14. PAM और Multi-Factor Authentication (MFA)

PAM का उपयोग करके Linux में Multi-Factor Authentication लागू किया जा सकता है।

उदाहरण—

पहला Factor:

- Password

दूसरा Factor:

- OTP
- Authenticator App
- Hardware Token
- Fingerprint

इससे सुरक्षा कई गुना बढ़ जाती है।

15. Cyber Security में PAM का महत्व

PAM निम्न सुरक्षा सिद्धांतों को लागू करने में सहायता करता है—

- Strong Authentication
 - Multi-Factor Authentication
 - Password Policy Enforcement
 - Account Lockout
 - Least Privilege
 - Identity Management
 - Centralized Authentication
-

16. Digital Forensics में PAM

यदि किसी Linux Server पर हमला होता है, तो PAM Logs से निम्न जानकारी प्राप्त की जा सकती है—

- Login Attempts
- Failed Authentication
- Successful Login
- Password Change Events

- Account Lock Events
- Session Start एवं End

इन Logs से यह पता लगाया जा सकता है कि—

- किस User ने Login किया?
- कितनी बार गलत Password दर्ज किया गया?
- किस समय Session प्रारंभ हुई?
- कौन-सा Authentication Method उपयोग हुआ?

17. PAM के लाभ

- Modular Architecture
- Centralized Authentication
- अनेक Authentication Methods का समर्थन
- Password Policy लागू करना
- Multi-Factor Authentication
- Enterprise Integration
- आसान विस्तार (Extensibility)

18. PAM की सीमाएँ

- गलत Configuration से Login समस्याएँ उत्पन्न हो सकती हैं।
- नए Administrator के लिए Configuration समझना चुनौतीपूर्ण हो सकता है।
- Module Order और Control Flags का सही उपयोग आवश्यक है।

19. वास्तविक उदाहरण

मान लीजिए किसी बैंक के Linux Server पर निम्न सुरक्षा नीति लागू है—

- User Password अनिवार्य
- OTP अनिवार्य
- Password हर 90 दिन में बदलना
- 5 गलत प्रयासों के बाद Account Lock

- Login का समय केवल कार्यालय समय तक सीमित

जब कोई कर्मचारी Login करता है—

1. PAM Password सत्यापित करता है।
2. OTP की जाँच करता है।
3. Account Expiry जाँचता है।
4. Login Time Policy जाँचता है।
5. Session प्रारंभ करता है।
6. सभी घटनाओं का Log बनाता है।

इस प्रकार केवल अधिकृत और वैध उपयोगकर्ता ही सिस्टम तक पहुँच पाते हैं।

20. निष्कर्ष

PAM (Pluggable Authentication Modules) Linux की एक अत्यंत महत्वपूर्ण सुरक्षा प्रणाली है, जो **Authentication, Authorization, Account Management और Session Management** को एकीकृत Framework के माध्यम से नियंत्रित करती है। इसकी **Modular Architecture** के कारण बिना Applications में परिवर्तन किए विभिन्न Authentication Methods (Password, LDAP, Kerberos, OTP, Fingerprint आदि) का उपयोग किया जा सकता है।

Enterprise Linux Servers, Cloud Infrastructure, Banking Systems, Government Networks तथा Digital Forensics में PAM की भूमिका अत्यंत महत्वपूर्ण है। उचित Configuration के साथ PAM Linux की सुरक्षा को अधिक मजबूत, लचीला और केंद्रीकृत (Centralized) बनाता है।

अध्याय: Log Analysis (लॉग विश्लेषण)

1. परिचय (Introduction)

किसी भी Computer System, Network, Server, Application या Security Device द्वारा किए गए प्रत्येक महत्वपूर्ण कार्य (Event) का एक रिकॉर्ड बनाया जाता है। इस रिकॉर्ड को Log (लॉग) कहा जाता है।

जब किसी सिस्टम में Login होता है, कोई File Delete होती है, कोई Software Install होता है, कोई Error आता है, कोई Hacker Login करने का प्रयास करता है, या कोई Service बंद होती है—इन सभी घटनाओं का विवरण Log Files में सुरक्षित रहता है।

इन Logs का व्यवस्थित अध्ययन, जाँच और व्याख्या करने की प्रक्रिया को Log Analysis (लॉग विश्लेषण) कहा जाता है।

Log Analysis वह प्रक्रिया है जिसके माध्यम से किसी सिस्टम, नेटवर्क या एप्लिकेशन द्वारा उत्पन्न Logs का विश्लेषण करके सुरक्षा घटनाओं, त्रुटियों, प्रदर्शन समस्याओं तथा उपयोगकर्ता गतिविधियों का पता लगाया जाता है।

2. Log क्या है?

Log एक डिजिटल रिकॉर्ड (Digital Record) है, जिसमें किसी सिस्टम या एप्लिकेशन की गतिविधियों का क्रमबद्ध विवरण होता है।

एक Log Entry में सामान्यतः निम्न जानकारी होती है—

- दिनांक (Date)
- समय (Time)
- Host Name
- User Name
- Process Name
- Event Type
- Error Code (यदि हो)
- Source IP Address
- Destination IP Address
- Event Description

उदाहरण:

यह Log बताता है कि 23 जुलाई 2026 को 10:15:45 बजे 192.168.1.25 IP से "admin" User के लिए SSH Login असफल हुआ।

3. Log Analysis की आवश्यकता

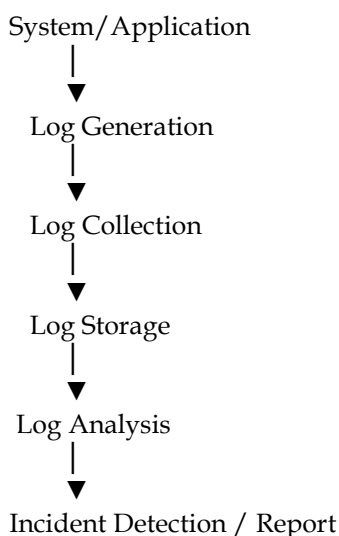
यदि किसी कंपनी का Linux Server अचानक बंद हो जाए, कोई Database Delete हो जाए या किसी Hacker ने सिस्टम में प्रवेश किया हो, तो सबसे पहले Administrator या Digital Forensic Investigator Logs की जाँच करता है।

Log Analysis की आवश्यकता निम्न कारणों से होती है—

- Cyber Attack का पता लगाना
- Unauthorized Access की पहचान
- System Error ढूँढना
- Performance Monitoring
- Compliance (ISO 27001, PCI-DSS आदि)
- Digital Forensics
- Incident Response
- Troubleshooting

4. Log Analysis कैसे कार्य करता है?

Log Analysis एक चरणबद्ध प्रक्रिया है—



5. Logs के प्रकार (Types of Logs)

(1) System Logs

Operating System की गतिविधियों का रिकॉर्ड।

उदाहरण—

- System Boot
 - Shutdown
 - Kernel Messages
 - Driver Errors
-

(2) Authentication Logs

User Login और Authentication से संबंधित जानकारी।

उदाहरण—

- Successful Login
 - Failed Login
 - SSH Login
 - sudo उपयोग
-

(3) Application Logs

Application द्वारा उत्पन्न Logs।

उदाहरण—

- Apache
 - Nginx
 - MySQL
 - PostgreSQL
 - Docker
-

(4) Security Logs

Security Events का रिकॉर्ड।

उदाहरण—

- Firewall
- SELinux
- AppArmor
- IDS/IPS Alerts

(5) Network Logs

Network Devices द्वारा बनाए गए Logs।

उदाहरण—

- Router
- Switch
- Firewall
- VPN
- Proxy

(6) Audit Logs

किस User ने कौन-सा कार्य किया, इसका विस्तृत रिकॉर्ड।

6. Linux में महत्वपूर्ण Log Files

Linux में अधिकांश Logs /var/log/ Directory में संग्रहीत होते हैं।

Log File	उपयोग
/var/log/syslog	सामान्य System Events
/var/log/messages	System Messages
/var/log/auth.log	Authentication Logs
/var/log/secure	Security Logs (कुछ Distributions)
/var/log/kern.log	Kernel Logs
/var/log/dmesg	Boot Messages
/var/log/boot.log	Boot Process
/var/log/faillog	Failed Login Attempts
/var/log/wtmp	Login History
/var/log/btmp	Failed Login History

7. Log Entry की संरचना

एक सामान्य Log Entry इस प्रकार हो सकती है—

```
Jul 23 10:20:15 server1 sshd[3245]:
Accepted password for shiv from 192.168.1.50 port 53211 ssh2
```

इसमें—

- **Jul 23 10:20:15** → दिनांक एवं समय
- **server1** → Host Name
- **sshd** → Process
- **3245** → Process ID
- **Accepted password** → Event
- **shiv** → User
- **192.168.1.50** → Source IP

8. Log Analysis के चरण

चरण 1: Log Collection

विभिन्न स्रोतों से Logs एकत्रित करना।

चरण 2: Normalization

Logs को एक समान प्रारूप में बदलना।

चरण 3: Filtering

अनावश्यक Logs हटाना।

चरण 4: Correlation

अलग-अलग Logs को जोड़कर घटनाओं का संबंध समझना।

चरण 5: Investigation

संदिग्ध गतिविधियों की जाँच करना।

चरण 6: Reporting

9. Log Analysis में उपयोग होने वाले प्रमुख उपकरण

- **journalctl** – systemd Logs देखने के लिए
- **grep** – विशेष शब्द खोजने के लिए
- **awk** – Log Parsing
- **sed** – Log Editing
- **tail** – अंतिम Entries देखने के लिए
- **less** – बड़े Logs पढ़ने के लिए
- **rsyslog** – Log Management
- **syslog-ng** – Centralized Logging
- **ELK Stack (Elasticsearch, Logstash, Kibana)** – बड़े पैमाने पर Log Analysis
- **Graylog** – Log Management
- **Splunk** – Enterprise Log Analysis
- **Wazuh** – Security Monitoring और SIEM

10. Cyber Security में Log Analysis

Log Analysis से निम्न गतिविधियों का पता लगाया जा सकता है—

- Brute Force Attack
- Malware Infection
- Ransomware Activity
- Privilege Escalation
- Unauthorized Login
- Data Exfiltration
- Port Scanning
- DDoS Attack
- Suspicious File Access

11. Digital Forensics में महत्व

Digital Forensics में Logs सबसे महत्वपूर्ण डिजिटल साक्ष्यों (Digital Evidence) में से एक हैं।

इनकी सहायता से पता लगाया जा सकता है—

- हमला कब हुआ?
- किस IP Address से हुआ?
- किस User ने Login किया?
- कौन-सी File Access की गई?
- कौन-सी Service प्रभावित हुई?
- किस समय System Restart हुआ?

12. वास्तविक उदाहरण

मान लीजिए किसी कंपनी के Linux Server पर रात 2:00 बजे कई असफल SSH Login प्रयास हुए।

Authentication Log में निम्न Entry मिलती है—

Jul 23 02:05:12 server sshd[4102]:
Failed password for root from 203.0.113.15 port 51120 ssh2

कुछ मिनट बाद—

Jul 23 02:08:44 server sshd[4120]:
Accepted publickey for admin from 203.0.113.15 port 51135 ssh2

विश्लेषण से यह निष्कर्ष निकाला जा सकता है कि—

1. पहले कई असफल Login प्रयास हुए।
2. बाद में उसी IP से सफल Login हुआ।
3. यह संदिग्ध गतिविधि हो सकती है।
4. आगे User Activity, Commands और File Access की जाँच आवश्यक होगी।

13. Log Analysis के लाभ

- सुरक्षा घटनाओं का शीघ्र पता चलता है।
- Troubleshooting आसान होती है।
- Performance समस्याओं की पहचान होती है।
- Compliance आवश्यकताओं को पूरा करने में सहायता मिलती है।
- Incident Response तेज़ होता है।
- Digital Forensics के लिए विश्वसनीय साक्ष्य उपलब्ध होते हैं।

14. सीमाएँ

- बड़े संगठनों में Logs की मात्रा बहुत अधिक होती है।
 - Log Rotation और Storage का सही प्रबंधन आवश्यक है।
 - Logs में संवेदनशील जानकारी हो सकती है, इसलिए उनकी सुरक्षा भी महत्वपूर्ण है।
 - गलत समय (Time Synchronization) होने पर घटनाओं का क्रम समझना कठिन हो सकता है।
-

15. निष्कर्ष

Log Analysis Cyber Security, System Administration और Digital Forensics का एक अत्यंत महत्वपूर्ण भाग है। यह केवल त्रुटियों को खोजने का माध्यम नहीं, बल्कि सुरक्षा घटनाओं की पहचान, हमलों की जाँच, उपयोगकर्ता गतिविधियों के विश्लेषण, Compliance तथा Incident Response का आधार भी है। Linux में `/var/log/` के अंतर्गत उपलब्ध विभिन्न Log Files तथा आधुनिक SIEM और Log Management Tools का उपयोग करके किसी भी संगठन की सुरक्षा स्थिति का प्रभावी विश्लेषण किया जा सकता है। इसलिए Log Analysis को प्रत्येक Cyber Security Professional, System Administrator और Digital Forensic Investigator के लिए एक अनिवार्य कौशल माना जाता है।

SHIV COMPUTER
PROFESSIONAL IT SOLUTIONS

अध्यायः

Linux Forensics (लिनक्स फॉरेंसिक्स)

1. परिचय (Introduction)

आज Linux विश्व के अधिकांश Web Servers, Cloud Servers, Data Centers, Super Computers, IoT Devices, Android Devices, Embedded Systems तथा Enterprise Networks का आधार है। Google, Amazon, Meta, Microsoft Azure, Oracle Cloud, ISRO, DRDO, बैंकिंग संस्थान और सरकारी संगठन बड़ी संख्या में Linux आधारित सर्वरों का उपयोग करते हैं।

जब किसी Linux System पर Cyber Attack, Data Theft, Ransomware Attack, Insider Threat, Privilege Escalation, Malware Infection या Unauthorized Access होता है, तब केवल Antivirus चलाना पर्याप्त नहीं होता। यह जानना आवश्यक होता है कि—

- हमला कब हुआ?
- किसने किया?
- किस IP Address से किया?
- कौन-सी Files बदली गई?
- कौन-सा User Account उपयोग हुआ?
- कौन-से Commands चलाए गए?
- क्या Data चोरी हुआ?

इन सभी प्रश्नों के उत्तर खोजने की वैज्ञानिक प्रक्रिया को Linux Forensics कहा जाता है।

Linux Forensics वह वैज्ञानिक प्रक्रिया है जिसके माध्यम से Linux आधारित सिस्टम से डिजिटल साक्ष्य (Digital Evidence) को सुरक्षित रूप से एकत्रित, संरक्षित, विश्लेषित और न्यायालय में प्रस्तुत करने योग्य बनाया जाता है।

2. Linux Forensics क्या है?

Linux Forensics डिजिटल फॉरेंसिक्स (Digital Forensics) की वह शाखा है जो Linux Operating System पर केंद्रित होती है।

इसका मुख्य उद्देश्य है—

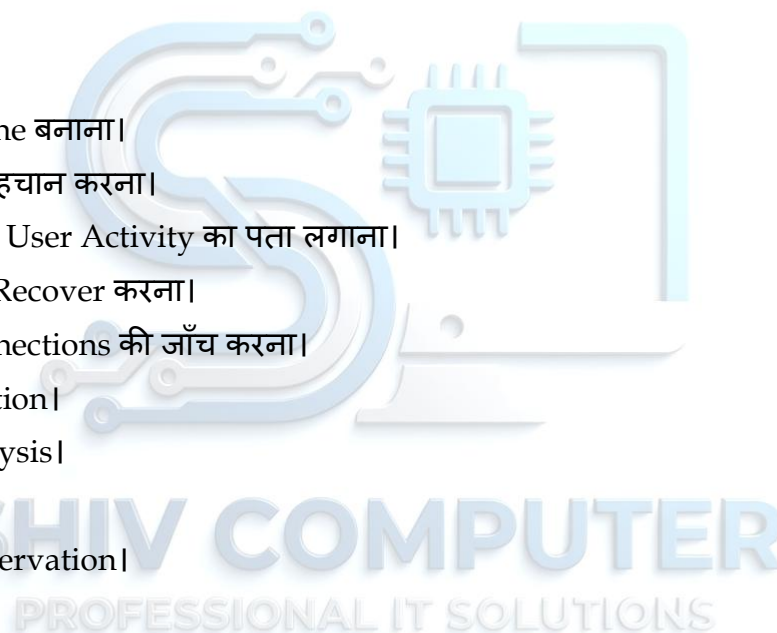
- डिजिटल साक्ष्य (Digital Evidence) एकत्रित करना।
- साक्ष्य की अखंडता (Integrity) बनाए रखना।
- घटनाओं का पुनर्निर्माण (Event Reconstruction) करना।
- हमले के स्रोत (Attack Source) की पहचान करना।
- न्यायिक जाँच (Legal Investigation) में उपयोग योग्य रिपोर्ट तैयार करना।

3. Linux Forensics के उद्देश्य

Linux Forensics का उद्देश्य केवल अपराधी को पकड़ना नहीं है, बल्कि पूरे Cyber Incident को समझना है।

मुख्य उद्देश्य—

- Attack Timeline बनाना।
- Malware की पहचान करना।
- Unauthorized User Activity का पता लगाना।
- Deleted Files Recover करना।
- Network Connections की जाँच करना।
- Rootkit Detection।
- Memory Analysis।
- Log Analysis।
- Evidence Preservation।



4. Linux Forensics की आवश्यकता

आज लगभग सभी बड़े संगठन Linux Servers का उपयोग करते हैं।

यदि किसी बैंक का Linux Database Server Hack हो जाए—

तो Investigator को पता लगाना होगा—

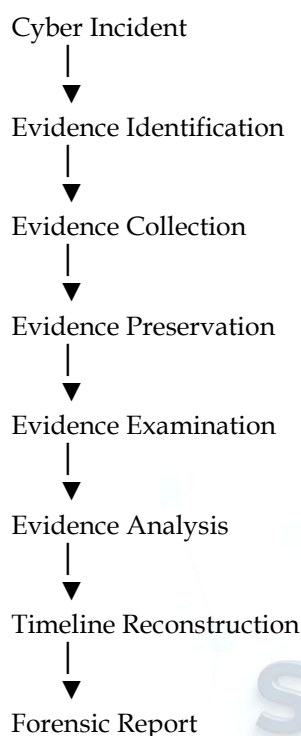
- Hacker कब Login हुआ?
- कौन-सा Account उपयोग हुआ?
- Password कैसे प्राप्त किया गया?
- कौन-सा Database Access हुआ?

- कौन-सी Tables Export हुई?
- कौन-सा Data Internet पर भेजा गया?

इन सभी प्रश्नों का उत्तर Linux Forensics देता है।

5. Linux Forensics की प्रक्रिया (Forensic Process)

Linux Forensics सामान्यतः निम्न चरणों में की जाती है—



6. डिजिटल साक्ष्य (Digital Evidence)

Linux System में निम्न चीजें Digital Evidence हो सकती हैं—

(1) Hard Disk

- SSD
- HDD
- NVMe

(2) RAM (Memory)

- Running Processes

- Encryption Keys
 - Malware
 - Network Connections
-

(3) Log Files

- Authentication Logs
 - System Logs
 - Application Logs
 - Kernel Logs
-

(4) User Files

- Documents
 - Images
 - Videos
 - Databases
-

(5) Browser History

- Visited Websites
 - Download History
 - Cookies
-

(6) Network Evidence

- Open Ports
 - Active Connections
 - Routing Tables
 - Firewall Rules
-

7. Linux में महत्वपूर्ण Forensic Locations

Linux Forensics के दौरान Investigator विशेष रूप से निम्न स्थानों की जाँच करता है—

Location उपयोग

/var/log/ System एवं Security Logs

/etc/ Configuration Files

Location उपयोग

/home/	User Data
/root/	Root User Files
/tmp/	Temporary Files
/var/tmp/	Temporary Data
/boot/	Boot Loader एवं Kernel
/proc/	Running Process Information
/sys/	Kernel एवं Hardware जानकारी
/dev/	Devices

8. Linux Logs का महत्व

Logs किसी भी Investigation का सबसे महत्वपूर्ण स्रोत हैं।

मुख्य Logs –

- auth.log
- syslog
- messages
- secure
- kern.log
- boot.log
- journalctl

इनसे पता चलता है—

- Login
- Failed Login
- SSH Activity
- Service Start
- Errors
- Kernel Events



9. Memory Forensics

यदि System चालू है, तो RAM सबसे महत्वपूर्ण Evidence होती है।

RAM में निम्न जानकारी मिल सकती है—

- Running Malware
- Encryption Keys
- Active Sessions

- Password Fragments
- Running Processes
- Network Connections

इसीलिए Live Response के दौरान Memory Acquisition को प्राथमिकता दी जाती है।

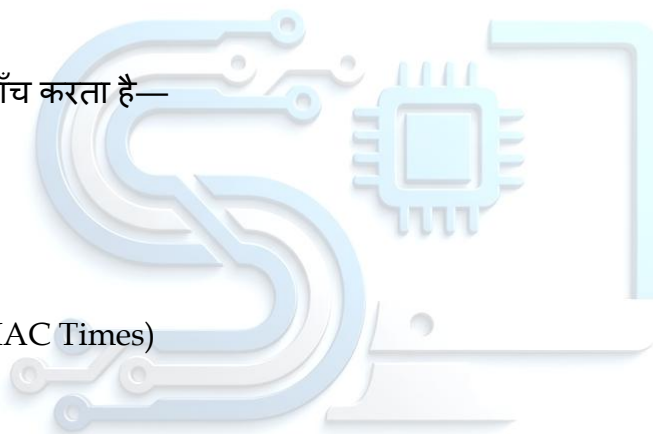
10. File System Forensics

Linux में मुख्य File Systems —

- EXT2
- EXT3
- EXT4
- XFS
- Btrfs

Investigator निम्न की जाँच करता है—

- Deleted Files
- File Metadata
- File Permissions
- Ownership
- Time Stamps (MAC Times)
- Hidden Files



11. Timeline Analysis

Timeline Analysis से घटनाओं का क्रम तैयार किया जाता है।

उदाहरण—

समय घटना

09:15 User Login

09:18 SSH Connection

09:22 Privilege Escalation

09:25 Sensitive File Access

09:28 Data Transfer

09:30 Logout

इससे हमले की पूरी कहानी समझ में आती है।

12. Rootkit Investigation

Rootkit ऐसा Malware है जो स्वयं को छिपाने का प्रयास करता है।

Investigator जाँच करता है—

- Hidden Processes
- Hidden Files
- Modified Kernel Modules
- Suspicious Libraries
- Unauthorized Services

13. Network Forensics

Network Analysis में निम्न जानकारी देखी जाती है—

- Open Ports
- Active Connections
- Firewall Rules
- SSH Sessions
- DNS Queries
- Packet Capture (PCAP)

इससे Data Exfiltration और Command-and-Control (C2) गतिविधियों का पता चल सकता है।

14. Linux Forensics Tools

प्रमुख Tools—

Disk एवं File Analysis

- Autopsy
- The Sleuth Kit (TSK)
- TestDisk
- PhotoRec

Memory Analysis

- Volatility Framework
- LiME (Linux Memory Extractor)

Log Analysis

- journalctl
- grep
- awk
- ELK Stack
- Splunk
- Wazuh

Network Analysis

- Wireshark
- tcpdump
- Zeek

System Information

- ps
- top
- ss
- netstat
- lsof

15. Chain of Custody

Forensic Investigation में प्रत्येक Evidence का रिकॉर्ड रखा जाता है—

- Evidence किसने प्राप्त किया?
- कब प्राप्त किया?
- कहाँ रखा गया?
- किसे सौंपा गया?
- कब विश्लेषण किया गया?

यह प्रक्रिया Chain of Custody कहलाती है और न्यायालय में साक्ष्य की विश्वसनीयता बनाए रखने के लिए अत्यंत महत्वपूर्ण है।

16. Cyber Attack Investigation (उदाहरण)

मान लीजिए किसी Linux Web Server पर संदिग्ध गतिविधि हुई।

Investigator निम्न चरण अपनाता है—

1. Server को अनावश्यक परिवर्तन से बचाते हुए सुरक्षित करता है।

2. RAM एवं Disk का Forensic Image प्राप्त करता है।
3. Hash Value (जैसे SHA-256) से Integrity सत्यापित करता है।
4. Authentication Logs की जाँच करता है।
5. SSH Login History का विश्लेषण करता है।
6. Running Processes की समीक्षा करता है।
7. Network Connections की जाँच करता है।
8. Web Server Logs का विश्लेषण करता है।
9. Timeline तैयार करता है।
10. अंतिम Forensic Report बनाता है।

17. Cyber Security में Linux Forensics का महत्व

Linux Forensics का उपयोग—

- Incident Response
- Malware Analysis
- Insider Threat Investigation
- Cloud Security
- Digital Crime Investigation
- Compliance Audit
- Data Breach Analysis
- National Security
- Banking एवं Financial Sector

में व्यापक रूप से किया जाता है।



18. Linux Forensics की चुनौतियाँ

- Full Disk Encryption
- Anti-Forensics Techniques
- Rootkits
- Log Deletion
- Cloud Environments
- Containers
- Virtual Machines
- Live System Acquisition

इन परिस्थितियों में सही तकनीक और उपकरणों का चयन अत्यंत महत्वपूर्ण होता है।

19. Linux Forensics के लाभ

- वैज्ञानिक जाँच प्रक्रिया
 - न्यायालय में स्वीकार्य डिजिटल साक्ष्य
 - Attack Reconstruction
 - Malware Detection
 - Timeline Analysis
 - Root Cause Analysis
 - Compliance Support
 - Incident Response में सहायता
-

20. निष्कर्ष

Linux Forensics डिजिटल फॉरेंसिक्स की एक महत्वपूर्ण शाखा है, जो Linux आधारित सिस्टम से डिजिटल साक्ष्य एकत्रित करने, संरक्षित करने, विश्लेषित करने और घटनाओं का वैज्ञानिक पुनर्निर्माण करने की प्रक्रिया है। इसमें **Disk Forensics, Memory Forensics, Log Analysis, File System Analysis, Network Forensics और Timeline Reconstruction** जैसी तकनीकों का उपयोग किया जाता है।

आज के समय में, जब अधिकांश Web Servers, Cloud Infrastructure, Containers और Enterprise Systems Linux पर आधारित हैं, Linux Forensics का महत्व अत्यधिक बढ़ गया है। Cyber Security Professionals, SOC Analysts, Incident Responders और Digital Forensic Investigators के लिए Linux Forensics का गहन ज्ञान आधुनिक साइबर अपराधों की जाँच और डिजिटल साक्ष्यों के संरक्षण के लिए अनिवार्य है।

{अगले भाग – २ में आगे की चर्चा जारी है - macOS Security}